FRM PART II • 2026 • EXAM 25 NOVEMBER 2026

Operational Risk and Resilience

Notes + Question Workbook

P1 • P2 • P3, in order of importance

64 learning objectives from 22 readings, banded by the Master LO Map v3. P4 is excluded. Built from Vardeez's notes, the GARP 2026 Operational Risk and Resilience book, the Schweser-Notes 2026 book, the Tier A and B–D Recall Workbooks and the Operational Risk and Resilience Question Bank.

How to use this book

- The book runs **P1, then P2, then P3**. Inside each part, LOs follow syllabus order. The syllabus index at the front lists all 64 LOs in GARP order with their band and page.
- Each LO is one block: **focus box** (why it sits in its band, Vardeez's pointer and the reported exam shapes), **notes** limited to that focus, a **formula card** or comparison table, **exam traps**, then **6 to 10 practice questions**. **Solutions** sit at the end of each block, so attempt first.
- LO wording is verbatim from the official GARP 2026 learning objectives, as listed in the Master LO Map.
- Type tags: CALC numerical questions expected; CONCEPT statement questions (only the reported workbook calculations appear); BOTH a mix set by the reported shapes and Vardeez's focus.
- Question sources, in priority order: Tier workbook (August 2026 recall and mapped shapes), GARP-tagged bank questions (practice exams, GARP book, mocks), other bank questions, and *New* questions written in GARP style from the readings where an LO was short. Every number has been recomputed.
- Green-edged boxes mark corrections to the source notes or to a bank key. Figures are drawn for black-and-white printing.

Contents by priority

P1 Most important 9

ORR-1 • Introduction to Operational Risk and Resilience

ORR-1 b	CONCEPT	Describe the seven Basel II event risk categories and identify examples of operational risk events in each category.	10
ORR-1 d	CONCEPT	Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience.	21

ORR-2 • Risk Governance

ORR-2 b	CONCEPT	Describe and compare the roles of different committees and the board of directors in operational risk governance.	35
ORR-2 c	CONCEPT	Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense.	46
ORR-2 d	CONCEPT	Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture.	60

ORR-3 • Risk Identification

ORR-3 d	CONCEPT	Describe and apply the Level 1, 2, and 3 categories in the Basel operational risk taxonomy.	70

ORR-4 • Risk Measurement and Assessment

ORR-4 f	CONCEPT	Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations.	84
ORR-4 g	CONCEPT	Describe and explain the steps to ensure a strong level of operational resilience, and to test the operational resilience of important business services.	99

ORR-8 • Cyber-resilience: Range of Practices

ORR-8 b	CONCEPT	Describe current practices by banks and supervisors in the governance of a cyber-risk management framework, including roles and responsibilities.	109
ORR-8 c	CONCEPT	Explain methods for supervising cyber-resilience, testing and incident response approaches, and cybersecurity and resilience metrics.	121

ORR-9 • Cyberthreats and Information Security Risks

ORR-9 a	CONCEPT	Provide examples of cyber threats and information security risks, and describe frameworks and best practices for managing cyber risks.	133
ORR-9 b	CONCEPT	Describe lessons learned from the Equifax case study.	143

ORR-10 • Sound Management of Risks related to Money Laundering and Financing of Terrorism

ORR-10 a	CONCEPT	Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks.	151
ORR-10 b	CONCEPT	Describe recommended practices for the acceptance, verification, and identification of customers at a bank.	165
ORR-10 c	CONCEPT	Explain practices for managing ML/FT risks in a group-wide and cross-border context.	176

ORR-11 • Financial Crime and Fraud

ORR-11 a	CONCEPT	Describe elements of a control framework to manage financial fraud risk and money laundering risk.	187

ORR-18 • Risk Capital Attribution and Risk-Adjusted Performance Measurement

ORR-18 c	CALC	Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance.	197
ORR-18 e	CALC	Calculate the hurdle rate and apply this rate in making business decisions using RAROC.	213
ORR-18 f	CALC	Calculate the adjusted RAROC for a project to determine its viability.	226

ORR-21 • Capital Regulation Before the Global Financial Crisis

ORR-21 c	CONCEPT	Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book.	238
ORR-21 e	CONCEPT	Compare the standardized internal ratings-based (IRB) approach, the foundation IRB approach, and the advanced IRB approach for the calculation of credit risk capital under Basel II.	253
ORR-21 f	CALC	Calculate credit risk capital under Basel II utilizing the IRB approach.	265

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis

ORR-22 a	CALC	Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge.	279
ORR-22 f	CALC	Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio.	294

ORR-23 • High-level Summary of Basel III Reforms

ORR-23 b	CONCEPT	Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework	308
ORR-23 c	CALC	Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor.	323

P2 Second priority 334

ORR-11 • Financial Crime and Fraud

ORR-11 b	CONCEPT	Summarize the regulatory findings and describe the lessons learned from the USAA case study.	335

ORR-12 • Guidance on Managing Outsourcing Risk

ORR-12 a	CONCEPT	Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk.	344
ORR-12 b	CONCEPT	Explain how financial institutions should perform due diligence on third-party service providers.	356
ORR-12 c	CONCEPT	Describe topics and provisions that should be addressed in a contract with a third-party service provider.	365

ORR-13 • Third-Party Risk Management

ORR-13 a	CONCEPT	Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework.	374

ORR-13 b CONCEPT Describe the lessons learned from the presented case studies. 386

ORR-14 • Investor Protection and Compliance Risks in Investment Activities

ORR-14 a CONCEPT Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank. 396

ORR-14 b CONCEPT Describe lessons learned from the case studies involving violations of investor protection or compliance regulations. 411

ORR-15 • Supervisory Guidance on Model Risk Management

ORR-15 a CONCEPT Describe model risk and explain how it can arise in the implementation of a model. 421

ORR-15 b CONCEPT Describe elements of an effective model risk management process. 431

ORR-15 c CONCEPT Explain best practices for the development and implementation of models. 440

ORR-15 d CONCEPT Describe elements of a strong model validation process and challenges to an effective validation process. 448

ORR-16 • Case Study: Model Risk and Model Validation

ORR-16 a CONCEPT Define a model and describe different ways that financial institutions can become exposed to model risk. 460

ORR-16 b CONCEPT Describe the role of the model risk management function and explain best practices in the model risk management and validation processes. 469

ORR-16 c CONCEPT Describe lessons learned from the three case studies involving model risk. 478

ORR-23 • High-level Summary of Basel III Reforms

ORR-23 a CONCEPT Explain the motivations for revising the Basel III framework and the goals and impacts of the December 2017 reforms to the Basel III framework. 487

P3 Third priority 497

ORR-4 • Risk Measurement and Assessment

ORR-4 a CONCEPT Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations. 498

ORR-4 b CONCEPT Explain operational risk-assessment processes and tools, including risk control self-assessments (RCSAs), likelihood assessment scales, and heatmaps. 508

ORR-4 c CONCEPT Describe the differences among key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs). 517

ORR-5 • Risk Mitigation

ORR-5 b CONCEPT Compare different types of internal controls and provide examples of each type of internal control. 524

ORR-5 c CONCEPT Describe control automation, internal control design, and control testing, including risks and challenges that arise in these processes and ways to make them more effective. 533

ORR-7 • Integrated Risk Management

ORR-7 b CONCEPT Explain and differentiate between regulatory capital and economic capital requirements as prescribed in Basel regulations. 542

ORR-8 • Cyber-resilience: Range of Practices

ORR-8 e CONCEPT Describe practices for the governance of risks of interconnected third-party service providers. 550

ORR-17 • Stress Testing Banks

ORR-17 a	CONCEPT	Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital Assessment Program (SCAP) stress tests.	560
ORR-17 b	CONCEPT	Explain challenges in designing stress test scenarios, including the problem of coherence in modeling risk factors.	572

ORR-18 • Risk Capital Attribution and Risk-Adjusted Performance Measurement

ORR-18 a	CONCEPT	Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital.	582

ORR-20 • Capital Planning at Large Bank Holding Companies

ORR-20 a	CONCEPT	Describe the Federal Reserve's Capital Plan Rule and explain the seven principles of an effective capital adequacy process for bank holding companies (BHCs) subject to the Capital Plan Rule.	593
ORR-20 b	CONCEPT	Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections	603

ORR-21 • Capital Regulation Before the Global Financial Crisis

ORR-21 a	CONCEPT	Explain the motivations for introducing the Basel regulations, including key risk exposures addressed, and explain the reasons for revisions to Basel regulations over time.	619
ORR-21 b	CALC	Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines.	628
ORR-21 d	CONCEPT	Describe changes to the Basel regulations made as part of Basel II, including the three pillars.	639

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis

ORR-22 b	CONCEPT	Explain the process of calculating the incremental risk capital charge for positions held in a bank's trading book.	648
ORR-22 c	CONCEPT	Describe the comprehensive risk (CR) capital charge for portfolios of positions that are sensitive to correlations between default risks.	656
ORR-22 d	CALC	Define in the context of Basel III and calculate where appropriate: - Tier 1 capital and its components - Tier 2 capital and its components - Required Tier 1 equity capital, total Tier 1 capital, and total capital	665
ORR-22 e	CALC	Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs).	675
ORR-22 g	CONCEPT	Describe the mechanics of contingent convertible bonds (CoCos) and explain the motivations for banks to issue them.	686

ORR-24 • Basel III: Finalising Post-Crisis Reforms

ORR-24 b	CONCEPT	Compare the Standardized Measurement Approach (SMA) to earlier methods of calculating operational risk capital, including the Advanced Measurement Approaches (AMA).	696
ORR-24 c	CONCEPT	Describe general and specific criteria recommended by the Basel Committee for the identification, collection, and treatment of operational loss data.	707

Syllabus index (GARP order)

Every LO in this book, in the order of the official 2026 learning objectives. P4 LOs are not in this book.

ORR-1 • Introduction to Operational Risk and Resilience

ORR-1 b P1 CONCEPT 10
ORR-1 d P1 CONCEPT 21

ORR-2 • Risk Governance

ORR-2 b P1 CONCEPT 35
ORR-2 c P1 CONCEPT 46
ORR-2 d P1 CONCEPT 60

ORR-3 • Risk Identification

ORR-3 d P1 CONCEPT 70

ORR-4 • Risk Measurement and Assessment

ORR-4 a P3 CONCEPT 498
ORR-4 b P3 CONCEPT 508
ORR-4 c P3 CONCEPT 517
ORR-4 f P1 CONCEPT 84
ORR-4 g P1 CONCEPT 99

ORR-5 • Risk Mitigation

ORR-5 b P3 CONCEPT 524
ORR-5 c P3 CONCEPT 533

ORR-7 • Integrated Risk Management

ORR-7 b P3 CONCEPT 542

ORR-8 • Cyber-resilience: Range of Practices

ORR-8 b P1 CONCEPT 109
ORR-8 c P1 CONCEPT 121
ORR-8 e P3 CONCEPT 550

ORR-9 • Cyberthreats and Information Security Risks

ORR-9 a P1 CONCEPT 133
ORR-9 b P1 CONCEPT 143

ORR-10 • Sound Management of Risks related to Money Laundering and Financing of Terrorism

ORR-10 a P1 CONCEPT 151
ORR-10 b P1 CONCEPT 165
ORR-10 c P1 CONCEPT 176

ORR-11 • Financial Crime and Fraud

ORR-11 a P1 CONCEPT 187
ORR-11 b P2 CONCEPT 335

ORR-12 • Guidance on Managing Outsourcing Risk

ORR-12 a P2 CONCEPT 344
ORR-12 b P2 CONCEPT 356
ORR-12 c P2 CONCEPT 365

ORR-13 • Third-Party Risk Management

ORR-13 a P2 CONCEPT 374
ORR-13 b P2 CONCEPT 386

ORR-14 • Investor Protection and Compliance Risks in Investment Activities

ORR-14 a P2 CONCEPT 396
ORR-14 b P2 CONCEPT 411

ORR-15 • Supervisory Guidance on Model Risk Management

ORR-15 a P2 CONCEPT 421
ORR-15 b P2 CONCEPT 431
ORR-15 c P2 CONCEPT 440
ORR-15 d P2 CONCEPT 448

ORR-16 • Case Study: Model Risk and Model Validation

ORR-16 a P2 CONCEPT 460
ORR-16 b P2 CONCEPT 469
ORR-16 c P2 CONCEPT 478

ORR-17 • Stress Testing Banks

ORR-17 a P3 CONCEPT 560
ORR-17 b P3 CONCEPT 572

ORR-18 • Risk Capital Attribution and Risk-Adjusted Performance Measurement

ORR-18 a P3 CONCEPT 582
ORR-18 c P1 CALC 197
ORR-18 e P1 CALC 213
ORR-18 f P1 CALC 226

ORR-20 • Capital Planning at Large Bank Holding Companies

ORR-20 a P3 CONCEPT 593
ORR-20 b P3 CONCEPT 603

ORR-21 • Capital Regulation Before the Global Financial Crisis

ORR-21 a P3 CONCEPT 619
ORR-21 b P3 CALC 628
ORR-21 c P1 CONCEPT 238
ORR-21 d P3 CONCEPT 639
ORR-21 e P1 CONCEPT 253
ORR-21 f P1 CALC 265

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis

ORR-22 a P1 CALC 279
ORR-22 b P3 CONCEPT 648
ORR-22 c P3 CONCEPT 656
ORR-22 d P3 CALC 665
ORR-22 e P3 CALC 675
ORR-22 f P1 CALC 294
ORR-22 g P3 CONCEPT 686

ORR-23 • High-level Summary of Basel III Reforms

ORR-23 a P2 CONCEPT 487
ORR-23 b P1 CONCEPT 308
ORR-23 c P1 CALC 323

ORR-24 • Basel III: Finalising Post-Crisis Reforms

ORR-24 b P3 CONCEPT 696
ORR-24 c P3 CONCEPT 707

OPERATIONAL RISK AND RESILIENCE • PART

P1

Most important

Tier A recall topics and the concepts Vardeez flags in Very Important chapters. 26 LOs from 12 readings.

ORR-1 • Introduction to Operational Risk and Resilience • Vardeez: UNTIERED (crash-course notes)

ORR-1 b

P1 CONCEPT

Describe the seven Basel II event risk categories and identify examples of operational risk events in each category.

Workbook: A22 Three Lines of Defence and Operational Risk Governance • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic (A22): your August 2026 recall lists "Three lines of defence, 2Q" for the section, and the topic map has it at #29 (4 of 16 sources), with "Ops Risk Level 3 categorisation" reported as a separate recall item: the Basel event-type taxonomy.

Vardeez: his crash-course notes are his primary notes for ORR-1 to ORR-9. For this LO (his "LO 40.b", consolidated volume p.56) they are a single table: the seven Level 1 categories, two examples each, and a frequency and a severity label for each (his Figure 40.2). ORR-1 is rank 13 of 55 in his ROI ranking.

Reported exam shapes

- **S2** Basel event-type taxonomy, Level 1, Level 2 and the Level 3 examples.

What the questions look like: a loss event told in one or two sentences (a late settlement, a fiduciary lawsuit, a hacked database, a code clean-up); you name its Level 1 event type, and the distractors are the neighbouring types or a Level 2 label posing as a Level 1 answer. A second family reads the frequency and severity profile of GARP Table 1.1: which type is frequent but small, which carries half the losses. All statement questions; nothing to compute.

See also: workbook A22.3 also tags this LO; it is worked under ORR-3 d, which covers Levels 2 and 3 in full.

1. What the seven types classify

The Basel Committee (BCBS) defines operational risk as "the risk of loss resulting from inadequate or failed internal processes, people, and systems, or from external events". The definition names four *causes*. It includes legal risk and excludes strategic and reputational risk. The seven event types classify something else: the *events*, the losses that actually occur. Every loss in a bank's database is mapped to one of them, which is why GARP calls them the "Basel level 1 types". Each is split into Level 2 regulatory categories and illustrated by Level 3 examples (the full three-level taxonomy is ORR-3 d).

Level 1 event type	What triggers it (Basel definition, condensed)	Examples (GARP Table 1.1, Vardeez)	Freq / Sev
1 Internal fraud (IF)	Acts intended to defraud, misappropriate property or circumvent regulations, the law or company policy, involving **at least one internal party**; discrimination events excluded	Fraud and unauthorised activities by employees: embezzlement ("defalcation"), rogue trading	2% / 2%
2 External fraud (EF)	The same kind of acts, committed **by a third party**	Theft and fraud, hacking damage; credit card fraud	30% / 9%
3 Employment practices and workplace safety (EPWS)	Acts inconsistent with employment, health or safety laws or agreements; personal injury claims; diversity and discrimination events	Contract termination issues, discrimination, employer's liability	15% / 5%

Level 1 event type	What triggers it (Basel definition, condensed)	Examples (GARP Table 1.1, Vardeez)	Freq / Sev
4 Clients, products and business practices (CPBP)	Unintentional or negligent failure to meet a professional obligation to specific clients (fiduciary, suitability), or the nature or design of a product	Client misinformation, complaints and compensation for errors, product misspecification, regulatory fines	22% / 52%
5 Damage to physical assets (DPA)	Loss or damage to physical assets from natural disaster or other events	Destruction of equipment, natural disasters; terrorism, vandalism	1% / 1%
6 Business disruption and system failures (BDSF)	Disruption of business or system failures	IT breakdown, outages: hardware, software, telecoms, utilities	2% / 5%
7 Execution, delivery and process management (EDPM)	Failed transaction processing or process management; relations with trade counterparties and vendors	Processing errors, missing documentation, vendor disputes	28% / 27%

Definitions from GARP Table 3.1 (the BCBS Level 1 definitions); examples from GARP Table 1.1 and Vardeez's Figure 40.2; "Freq / Sev" is each type's share of the number of loss events and of total loss amounts in ORX bank data, 2014 to 2019 (GARP Table 1.1).

2. Frequency against severity: GARP Table 1.1

GARP computes each type's share of loss *events* (frequency) and of loss *amounts* (severity) from ORX bank loss data for 2014 to 2019, and treats it as representative of the industry. Set side by side (Figure 1), the two shares tell you how large a typical event in each type is.

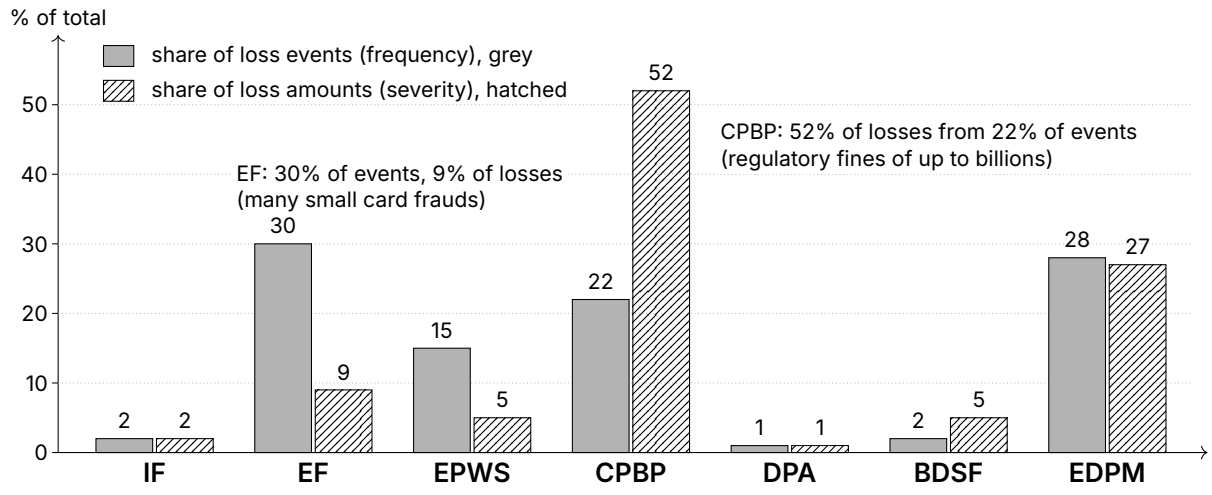


Figure 1. GARP Table 1.1 as paired bars: grey bars are each type's share of the number of loss events, hatched bars its share of total loss amounts (ORX, 2014 to 2019). Where the hatched bar is taller, the typical event is large (CPBP, BDSF); where the grey bar is taller, the typical event is small (EF, EPWS).

How GARP reads the table

- **EF is over-represented in frequency.** Large retail banks record thousands of card frauds a month,

most of them small. Yet the same type contains hacking damage, which can be very severe: there is significant *heterogeneity within each type*.

- **CPBP is more than half of all losses from less than a quarter of the events.** The reason is that regulatory fines, sometimes billions of dollars, are booked here.
- **Concentration.** Four types (EF, EPWS, CPBP, EDPM) hold almost all events; two (CPBP and EDPM) explain 79% of the losses. EPWS is particularly frequent in Latin American banks and barely present in Europe.
- **Direct losses only.** The table captures the direct financial loss of each incident. Indirect consequences of large events (reputational damage, a fall in market capitalisation, management turnover, remediation) sometimes far exceed it.

Vardeez's labels translate the numbers: high frequency (EF, CPBP, EDPM), moderate (EPWS), low (IF, DPA, BDSF); very high severity (CPBP), high (EDPM), low (the rest).

Correction to the source notes.

- GARP's text says "75% of the frequency of operational risk events are concentrated in four categories: EF, EPWS, CPBP, and EDPM", and that CPBP and EDPM explain 79% of severity "(86% including EF)". Its own Table 1.1 gives $30+15+22+28 = 95\%$ of frequency for the four types, and $52+27+9 = 88\%$ of severity with EF. The 79% is consistent. Use the table: **95%** and **88%**.
- SchweserNotes (Reading 44) says EDPM "typically has the highest frequency of occurrence". On GARP's ORX data external fraud is the most frequent type (30% against 28%). EDPM is second in both frequency and severity.

3. Telling neighbouring types apart

Almost every classification question is decided by one of five tests. The type is fixed by the *nature of the event*, not by who ends up bearing the loss.

Neighbours	The test	Goes to the first	Goes to the second
IF vs EF	Is at least one *internal* party involved?	Employee embezzles, forges a signature, trades without authority	A customer acting alone kites cheques; an outside hacker steals data
IF vs CPBP	Did the employee act for himself or on the *firm's* behalf?	Insider trading for a personal account	Insider trading on the firm's account, market manipulation, money laundering, antitrust
CPBP vs EDPM	Was a professional obligation to a client breached, or did a processing step fail?	Unsuitable advice, misinformation, fiduciary breach, a flawed product	Data entry error, late settlement, missing legal documents, vendor dispute
DPA vs BDSF	Was a physical asset lost or *damaged*?	Flood, earthquake, terrorism, vandalism	Hardware, software, telecoms or utility outage with no damage
EPWS vs IF / CPBP	Does it arise from the employment relationship or workplace safety?	Wrongful termination, discrimination, injury claims, workers' compensation	Theft by staff (IF); harm to a client through a product (CPBP)

4. Legal and compliance losses, and the cases GARP uses

Legal risk is part of operational risk but is not an eighth event type. Legal losses (enforceability or breach of contracts, laws) can attach to nearly every type, most commonly EPWS and EDPM. **Compliance** failures, and the regulatory fines that follow them, were captured from the start by CPBP; that is why CPBP dominates severity.

Case (GARP Ch.1, Box 1.1 and Section 1.5)	Level 1
Rogue trading: Jérôme Kerviel at Société Générale (EUR 4.9 billion, 2008); UBS (USD 2 billion, 2011); Nick Leeson at Barings (GBP 660 million)	IF
Hacking and data theft: Equifax and Uber, both with customer data exposed by hackers	EF
Fines and mis-selling: Bank of America (USD 16.7 billion, 2014), Lloyds PPI (GBP 21.9 billion, 2015 to 2019), HSBC anti-money-laundering failures (USD 1.9 billion, 2012), BNPP embargo breaches	CPBP
Extreme physical events: the 11 September 2001 attacks, the Fukushima earthquake	DPA

Exam traps

- **Level 2 label posing as a Level 1 answer.** "Improper Business or Market Practices", "Theft and Fraud", "Systems Security" are Level 2 categories. A Level 1 answer is one of the seven types.
- **Fraud by perpetrator, not by location.** A customer acting alone at a branch is EF; any internal party makes it IF.
- **Misconduct for the firm is CPBP.** Market manipulation, money laundering and insider trading on the firm's account are not internal fraud.
- **No damage, no DPA.** Outages and software or code problems are BDSF; software is not a physical asset.
- **CPBP against EDPM.** A breached duty to a client is CPBP; a failed processing step is EDPM, even when a client or a counterparty ends up compensated.
- **Legal risk excluded.** It is inside operational risk; legal losses are mapped to the event types, mostly EPWS and EDPM.
- **Frequency and severity swapped.** EF is the most frequent type (30%) but only 9% of losses; CPBP carries 52% of losses; DPA is the smallest on both counts (1%).
- **Table 1.1 is direct losses only.** Reputational and other indirect costs are not in it.

Practice questions: ORR-1 b

Question ORR-1 b.1

Bank Q5 • AnalystPrep Q.5048

BCBS divides operational risk into seven "Basel level 1" event types, further subdivided into level 2 regulatory types and level 3 examples. Which of the following statements about these categories is correct?

A. Internal fraud and external fraud belong to the same event risk category.

B. Acts that violate laws designed to protect the health, safety and well-being of employees and customers fall under clients, products, and business practices.

C. Data entry errors and incomplete legal documentation fall under execution, delivery, and process management.

D. Losses from theft and hacking are examples of the damage to physical assets category.

Question ORR-1 b.2

Bank Q12 • AP Mock 1 Q45

The head of risk management at a large bank must identify the event category of a loss suffered last year. Which event category covers losses from failed transaction processing and from relations with trade counterparties and vendors?

A. Internal fraud

B. Execution, delivery, and process management

C. Employment practices and workplace safety

D. Business disruption and system failures

Question ORR-1 b.3

Bank Q10 • BT notes P2.T7.603.1 (rebuilt)

A bank's loss data (2014 to 2019, consistent with industry ORX data) show that one Basel level 1 event type accounts for roughly 30% of all loss events but only about 9% of total loss severity. Most events are small (for example, thousands of card fraud incidents), though the category also includes rare, severe hacking events. Which event type is this?

A. External fraud

B. Clients, products, and business practices

C. Employment practices and workplace safety

D. Execution, delivery, and process management

Question ORR-1 b.4 Bank Q8 • BT P2.T7.23.1.1 (rebuilt)

An operational risk analyst maps her bank's historical losses to the Basel level 1 categories (for example, an employee embezzling customer funds is classified as internal fraud, and a network outage blocking online access is classified as business disruption and system failures). Assume her frequency and severity profile resembles the industry (ORX) findings summarized by GARP. Which of the following statements is FALSE?

A. External fraud is high-frequency but heterogeneous, containing both low-severity and high-severity events.

B. In terms of severity, the largest losses accrue to the clients, products, and business practices (CPBP) category.

C. She excluded legal-risk losses because they cannot be cleanly mapped to any single level 1 category.

D. Damage to physical assets (DPA) tends to produce among the least severe losses and has among the lowest frequencies.

Question ORR-1 b.5 Bank Q9 • BT P2.T7.600.3 (rebuilt)

Goodholdings Bank released a major upgrade of its custom-built enterprise resource planning (ERP) software platform, which exposed problems in the existing codebase (technical debt: the development effort needed to fix structural software problems caused by sub-optimal programming). Consultants were hired to re-factor the code, and management treats the consulting cost as an operational loss. To which Basel level 1 event type should the loss be assigned?

A. Internal fraud

B. Business disruption and system failures

C. Employment practices and workplace safety

D. Damage to physical assets

Question ORR-1 b.6 Bank Q13 • BT P2.T7.600.1

Trader Ben Smith enters a foreign exchange (FX) spot transaction, buying euros for dollars. He then quickly enters another transaction selling euros for dollars. He makes a quick profit from these two transactions; however, due to confusion in the back office, settlement to the counterparty is delayed to four days later. The counterparty demands compensation for the delayed settlement, and the claim includes lost (forgone) interest. The cost of the mistake exceeds the profit on the trade, resulting in an operational loss. To which Basel Level 1 event risk category should this loss be assigned?

A. Improper Business or Market Practices

B. Business Disruption and System Failures

C. Clients, Products, and Business Practices

D. Execution, Delivery, and Process Management

Question ORR-1 b.7 Bank Q14 • BT P2.T7.600.2 (rebuilt)

An investment advisor at a division of an international bank was sued by an employer-based retirement plan sponsor for fiduciary breach. The client claimed that the advisor's recommendation put the advisor's intention to earn a commission and the firm's profit motive above the client's best interest. The lawsuit was settled. To which Basel Level 1 event risk category should this loss be assigned?

A. Internal Fraud

B. Business Disruption and System Failures

C. Clients, Products, and Business Practices

D. Execution, Delivery, and Process Management

Solutions • ORR-1 b

Solution ORR-1 b.1

Answer: C

Bank Q5 • AnalystPrep Q.5048

Step 1 – Recall the seven Level 1 types

IF, EF, EPWS, CPBP, DPA, BDSF, EDPM. Each is defined by what triggered the loss.

Step 2 – Test each statement against its trigger

Data entry errors are a Level 3 example under EDPM / Transaction Capture, Execution and Maintenance, and missing or incomplete legal documents under EDPM / Customer Intake and Documentation.

$\Rightarrow$ C is correct: both are failures of a processing step.

Interpretation

The statement set checks one boundary per option: fraud is split by perpetrator, workplace and safety law goes to EPWS, and theft or hacking is fraud, not physical damage.

Why the other options are wrong

A is incorrect. Internal and external fraud are separate types: IF needs at least one internal party, EF is committed by a third party.

B is incorrect. Breaches of employment, health or safety laws, including personal injury claims, are EPWS. CPBP covers obligations to clients and product design.

D is incorrect. Theft and hacking damage are EF (Level 2 Theft and Fraud, Systems Security). DPA needs loss or damage to physical assets from a disaster or similar event.

LO: ORR-1 b: Describe the seven Basel II event risk categories and identify examples of operational risk events in each category. • **Reference:** GARP ORR Ch.1, 1.1 and Table 1.1; Ch.3, Table 3.1

Solution ORR-1 b.2

Answer: B

Bank Q12 • AP Mock 1 Q45

Step 1 – Match the wording to a Basel definition

The stem quotes the Level 1 definition of EDPM almost word for word: "losses from failed transaction processing or process management, from relations with trade counterparties and vendors".

Step 2 – Check the neighbours

Nothing intentional (IF), nothing about employment (EPWS), and no system outage (BDSF) is described.

$\Rightarrow$ The answer is EDPM.

Interpretation

EDPM is the home of errors in doing the work: wrong data, missed deadlines, failed deliveries, counterparty and vendor disputes; it is second in both frequency and severity.

Why the other options are wrong

A is incorrect. Internal fraud requires an act intended to defraud or circumvent rules by at least one internal party.

C is incorrect. EPWS covers employment relations, workplace safety and discrimination.

D is incorrect. BDSF covers the failure of a system itself (hardware, software, telecoms, utilities); here a process failed, not a system.

LO: ORR-1 b: Describe the seven Basel II event risk categories and identify examples of operational risk events in each category. • **Reference:** GARP ORR Ch.1, Table 1.1; Ch.3, Table 3.1

Solution ORR-1 b.3 — Answer: A

Bank Q10 • BT notes P2.T7.603.1

Step 1 – Read Table 1.1 for a 30% / 9% profile

EF 30% / 9%; EPWS 15% / 5%; CPBP 22% / 52%; EDPM 28% / 27%.
⇒ Only external fraud has about 30% of events and about 9% of losses.

Step 2 – Confirm with the description

Thousands of small card frauds alongside rare, severe hacking events: GARP's own example of heterogeneity within external fraud.

Interpretation

A frequency share well above the severity share means a small typical event. External fraud is the textbook case; CPBP is the mirror image.

Why the other options are wrong

B is incorrect. CPBP is the reverse profile: 22% of events but 52% of losses, driven by regulatory fines.
C is incorrect. EPWS is 15% of events and 5% of losses, and has no hacking component.
D is incorrect. EDPM is roughly proportional (28% of events, 27% of losses), not skewed to small losses.

LO: ORR-1 b: Describe the seven Basel II event risk categories and identify examples of operational risk events in each category. • **Reference:** GARP ORR Ch.1, 1.1 and Table 1.1

Solution ORR-1 b.4 — Answer: C

Bank Q8 • BT P2.T7.23.1.1

Step 1 – Check the three profile statements against Table 1.1

A: EF is 30% of events, 9% of losses, and mixes small card frauds with severe hacking. True.
B: CPBP is 52% of losses, the largest share. True.
D: DPA is 1% of events and 1% of losses, the lowest on both. True.

Step 2 – Check the legal-risk statement

The BCBS definition of operational risk *includes* legal risk. Legal losses are mapped to the event types, most commonly EPWS and EDPM; compliance breaches and fines sit in CPBP.
⇒ C is false, so it is the answer.

Interpretation

Legal risk is a cross-cutting source of loss, not a separate type and not out of scope. Excluding it would drop a large share of CPBP and EDPM losses from the database.

Why the other options are wrong

A is incorrect. True statement (EF heterogeneity), so not the answer to a "FALSE" question.
B is incorrect. True statement (CPBP 52% of severity).
D is incorrect. True statement (DPA 1% and 1%).

LO: ORR-1 b: Describe the seven Basel II event risk categories and identify examples of operational risk events in each category. • **Reference:** GARP ORR Ch.1, 1.1, Table 1.1 and 1.3 (Legal Risk and Compliance)

Solution ORR-1 b.5 — Answer: B

Bank Q9 • BT P2.T7.600.3

Step 1 – What failed?

The upgrade exposed structural problems in the software code. Nothing was stolen, nobody

acted with intent, and no physical asset was damaged.

Step 2 – Place it

BDSF covers "disruption of business or system failures"; its single Level 2 category, Systems, lists hardware, software, telecommunications and utility outages as Level 3 examples.
⇒ A software problem is BDSF / Systems / Software.

Interpretation

Management's decision to treat the consultants' fee as a loss is given in the stem; the question is only where to file it. The trap is DPA: code is not a physical asset.

Why the other options are wrong

A is incorrect. Internal fraud needs an intentional act by an internal party; none is described.
C is incorrect. Nothing relates to employment, health or safety.
D is incorrect. DPA needs loss of or damage to physical assets (buildings, equipment); software is not one.

LO: ORR-1 b: Describe the seven Basel II event risk categories and identify examples of operational risk events in each category. • **Reference:** GARP ORR Ch.1, Table 1.1; Ch.3, Table 3.1

Solution ORR-1 b.6 — Answer: D

Bank Q13 • BT P2.T7.600.1

Step 1 – Separate the trade from the loss

The two trades were valid and profitable. The loss came from "confusion in the back office" that delayed settlement, and from the counterparty's compensation claim.

Step 2 – Place it

A failed settlement is a transaction-processing failure: EDPM, Level 2 Transaction Capture, Execution and Maintenance (Level 3: delivery failure, missed deadline).
⇒ The answer is EDPM.

Interpretation

The counterparty is compensated, but that does not make it a client event: the type follows what failed (a processing step), not who is paid.

Why the other options are wrong

A is incorrect. "Improper Business or Market Practices" is a Level 2 category under CPBP, not a Level 1 type, and it covers misconduct such as market manipulation, not a settlement error.
B is incorrect. No IT or system outage is described; the cause was human confusion in a process.
C is incorrect. CPBP covers obligations to clients (suitability, disclosure, fiduciary) and product design; this is a processing error with a trade counterparty.

LO: ORR-1 b: Describe the seven Basel II event risk categories and identify examples of operational risk events in each category. • **Reference:** GARP ORR Ch.1, Table 1.1; Ch.3, Table 3.1

Solution ORR-1 b.7 — Answer: C

Bank Q14 • BT P2.T7.600.2

Step 1 – Identify the obligation

The plan sponsor is a client, and the claim is that the advisor breached a fiduciary duty by putting commission and firm profit above the client's interest.

Step 2 – Place it

CPBP covers "an unintentional or negligent failure to meet a professional obligation to specific clients (including fiduciary and suitability requirements)". Level 2: Suitability, Disclosure and

Fiduciary; Level 3: fiduciary breaches.
⇒ The settled lawsuit is a CPBP loss.

Interpretation

A self-interested recommendation settled as a civil claim is a breach of duty to the client, not internal fraud: there is no act intended to defraud, misappropriate property or circumvent the law. Losses of this kind, together with regulatory fines, are why CPBP carries over half of all losses.

Why the other options are wrong

A is incorrect. Internal fraud needs an intentional act to defraud, misappropriate or circumvent rules; the claim here is a civil fiduciary breach.
B is incorrect. No system failure is described.
D is incorrect. EDPM covers processing and documentation failures, not a breach of duty to a client.

LO: ORR-1 b: Describe the seven Basel II event risk categories and identify examples of operational risk events in each category. • **Reference:** GARP ORR Ch.1, Table 1.1; Ch.3, Table 3.1

ORR-1 • Introduction to Operational Risk and Resilience • Vardeez: UNTIERED (crash-course notes)

ORR-1 d

P1 CONCEPT

Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience.

Workbook: A23 Cyber Risk and Operational Resilience • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic (A23): your August 2026 recall lists "Cyber risk", and the topic map has the section at #31 (4 of 16 sources). Reported: "operational resiliency", and a detailed applied item, "which bank was more vulnerable during COVID: payment bank or community bank?".

Vardeez: his crash-course notes for this LO (his "LO 40.d", consolidated volume p.57) stress three things: the definition (anticipating, reacting to and recovering from disruptions), the five components (business continuity, key services, impact tolerance, disruption processes, feedback), and a table of regulatory emphasis by jurisdiction (UK, US, BCBS, EU DORA, Singapore), with the shift from preventing cyber incidents to managing them.

Reported exam shapes

- **S2** Operational resiliency as a regulatory concept: UK first, then BCBS, ECB, MAS.
- **S3** Applied vulnerability comparison: payment bank versus community bank during COVID (workbook A23.2).

What the questions look like: two families. Matching: which statement describes a UK component, a Fed building block or a BCBS principle correctly, or which body had issued official guidance by May 2022. Applied: a brokerage, a fintech or a payment bank must meet the new rules; the right action protects an *important business service* within an *impact tolerance*, and the distractors offer capital, cost cutting, prevention alone, or recovery targets set process by process.

1. What operational resilience is

Attention to resilience grew in the late 2010s. Regulators wanted banks and insurers to be *operationally* stable, not only financially sound: able to prevent, and recover from, large operational disruptions. Two dependencies drove it: on IT systems and infrastructure, and on critical third parties (cloud and internet providers, payment infrastructure, central clearing counterparties). The TSB Bank IT migration failure of April 2018 (millions of customers disrupted, about 100,000 without access for weeks) and a run of high-profile cyberattacks made the point; COVID-19 then tested it.

UK regulators define it as "the ability of firms and the financial sector as a whole to **prevent, adapt, respond to, recover from, and learn from** operational disruptions". Vardeez and Schweser shorten this to anticipating, reacting to and recovering from disruptions. Two things to keep: it applies to the *sector* as well as the firm, and *learning* is part of it.

2. The five components (UK, 2018)

The UK paper does not define resilience in one sentence; it builds it from five components. Vardeez and Schweser use shorter labels for the same five.

GARP component	Vardeez label	What it requires
Continuity of business services	Business continuity	The element closest to classic business continuity planning: prevent and mitigate disruption of critical business provisions.
Important business services	Key services	**The innovation.** The regulator moved from a process-based to a *service-based* view: identify the services whose disruption would cause "intolerable levels of harm to consumers or market integrity" and keep them running within tolerance.
Impact tolerance levels	Impact tolerance	"Quantify the amount of disruption that could be tolerated in the event of an incident." Close to a recovery time objective, but set for a critical business *service*, not for a process. It helps the board "set their own standards for operational resilience, prioritize, and make investment decisions".
Management of disruption	Disruption processes	The response to disruption, keeping the trust of key stakeholders, and clear communication in a crisis.
Lessons learned	Feedback	Learn from internal accidents *and* from events made public at other organisations; keep improving resilience to unanticipated extreme shocks. GARP: this is what differentiates resilience from traditional business continuity.

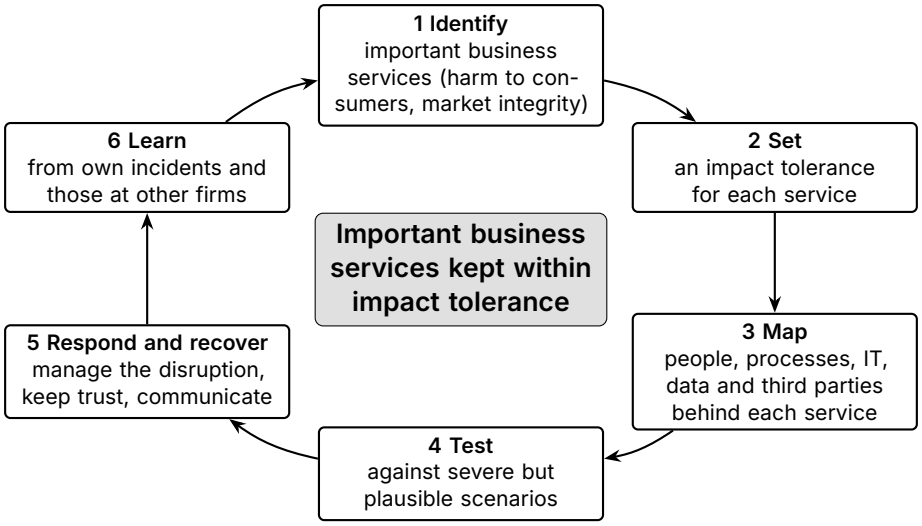


Figure 1. The resilience loop: the five UK components put in working order, with mapping (BCBS Principle 4) and scenario testing made explicit. The shaded centre is the outcome regulators look for; the open boxes are the steps, and the arrows close the loop through lessons learned.

3. Business continuity against operational resilience

	Classic business continuity	Operational resilience
Unit of analysis	Each internal process	Important business services
Target	Recovery time objective per process	Impact tolerance per service: the maximum tolerable disruption
Stance	Prevention	Prevent, detect and correct: severe disruptions are accepted as occasionally inevitable

	Classic business continuity	Operational resilience
Scenarios	The scenarios already tested	Severe but plausible, extreme as well as ordinary
Learning	Own incidents	Own incidents and events made public at other firms
Status	Existing requirement	Sits *alongside* existing operational risk requirements; does not replace them

The mindset shift. After several high-profile cyberattacks the industry accepted that severe operational disruptions are inevitable, at least occasionally. Firms and regulators moved from a purely preventive approach to "a more-balanced view of preventing, detecting, and correcting operational incidents when they occur, to minimize their overall net impact". Vardeez puts it as a shift from solely preventing cyber incidents to managing them effectively.
Not a new silo. The Bank of England (2018): operational resilience "is already a responsibility of firms" and "an outcome supported by the existing regulatory framework"; the new requirements supplement existing operational risk management.

4. Regulatory expectations, in the order they came (shape S2)

United Kingdom first (July 2018)

The FCA, the PRA and the Bank of England issued the first paper, the joint discussion paper *Building the UK financial sector's operational resilience*, and the five components above come from it. GARP: it "reads very much like a response to the TSB Bank disruption". At the time the industry feared IT disruption and cyberattacks, and built much of its resilience around the continuity of IT infrastructure and services.

United States (2020)

The Federal Reserve's *Sound Practices to Strengthen Operational Resilience* follows the same lines (important business services, impact tolerance) and views operational resilience as **a key outcome of an effective operational risk management framework**, to be inserted in a holistic enterprise framework. GARP rearranges the Fed's chapters into building blocks (Figure 2, after the BCBS table).

BCBS (March 2021)

The *Principles for Operational Resilience* were published together with the revised Principles for the Sound Management of Operational Risk, on purpose: for Basel, "operational resilience is an outcome that benefits from the effective management of operational risk", and a robust operational risk framework is the first condition for it. GARP adds that this later guidance integrates lessons from COVID-19.

Principle	Banks should...	Same spirit as
1 Governance	utilise their existing governance structure	a holistic framework
2 Operational risk management	leverage their functions for managing operational risk	a holistic framework
3 Business continuity planning and testing	have business continuity plans in place	the Fed paper

Principle	Banks should...	Same spirit as
4 Mapping interconnections and interdependencies	map the internal and external interconnections and interdependencies needed to deliver critical operations	the UK approach
5 Third-party dependency management	manage dependencies on third parties and intragroup entities	the Fed paper
6 Incident management	develop response and recovery plans for incidents that could disrupt critical operations	the UK approach
7 ICT including cybersecurity	ensure resilient ICT, including cybersecurity	the Fed paper

Principles 4 and 6 are the pair aimed directly at delivering critical services without intolerable disruption.

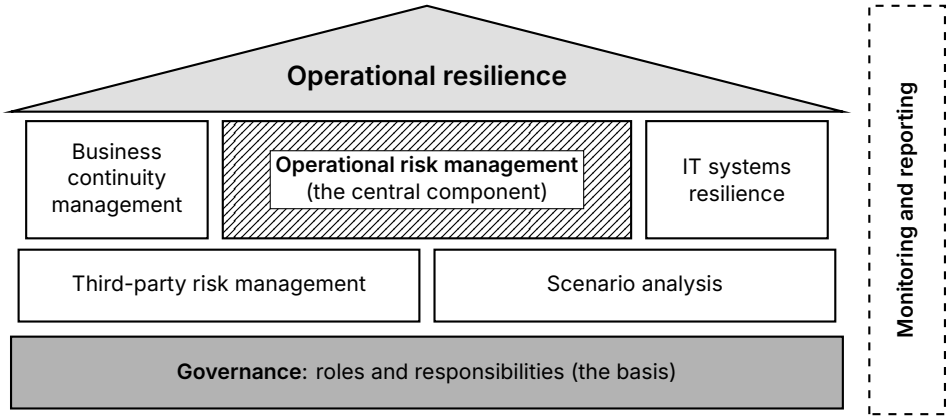


Figure 2. Building blocks of operational resilience (GARP Figure 1.3, after the Fed's 2020 paper; redrawn from GARP's description). Governance (dark grey) is the basis; operational risk management (hatched) is the centre, with its two specialisations, third-party risk management (supply-chain resilience) and scenario analysis (preparedness for tail events); business continuity management and IT systems resilience are the two supporting pillars; monitoring and reporting (dashed band) covers all of them.

Other regulators: ECB and MAS

- **ECB, September 2020**, in GARP's account: a *draft* Digital Operational Resilience Act (DORA), supporting digital finance while mitigating its risks, with ICT-related requirements for financial entities in one EU regulation.
- **MAS with the Association of Banks in Singapore, March 2021**: *Risk Management and Operational Resilience in a Remote Working Environment*: the risks of COVID-era remote working (operations, technology and information security, fraud and staff misconduct, legal and regulatory), example controls, and people and culture (awareness, vigilance, reassessing existing controls).

Status, as of May 2022 (GARP's cut-off): the **UK, the US and the BCBS** are the three main regulators with official guidelines on operational resilience. The ECB and MAS documents are a draft regulation and a paper on aspects of resilience.

Corrections to the source notes.

- **Vardeez's Figure 40.3** gives the UK row as "IT service continuity and adjustments for work-from-home environments" (Schweser says the same). In GARP the 2018 UK paper predates COVID and centres on IT continuity; the COVID lessons go into the BCBS 2021 principles, and the remote-working paper is MAS-ABS (2021). A question asking which publication addresses remote working points to MAS.

- **TSB date.** GARP Section 1.5 places the TSB disruption in 2016; its own Box 1.1, and the record, give April 2018.
- **DORA's author.** GARP and Schweser credit the September 2020 draft to the ECB. It was a European Commission legislative proposal; DORA was adopted in 2022 and has applied since January 2025. For the exam, keep GARP's framing: as of May 2022 DORA was a draft, and the ECB is not one of the three bodies with official guidance.

5. Applying it: which firm is more vulnerable? (shape S3)

GARP does not rank bank types; the exam item asks you to reason from the framework. Work through the same four questions for each firm:

1. **Which important business service, and who is harmed if it stops?** Payments are critical for consumers and market integrity.
2. **What does it depend on, and how concentrated is that?** One app, one IT stack and one critical third party (a cloud provider) is a concentrated dependency; a service spread across branches, staff and local relationships is not. Attention to resilience "emanated from the financial industry's critical dependence on IT systems and infrastructure".
3. **What does a severe but plausible scenario do to it?** Under COVID, call centres moved to living rooms and "critical payments and key market transactions had to operate in the most extreme conditions, much beyond any stress scenario they had tested before". GARP Ch.11 adds that fraud attempts tripled and phishing e-mails rose six- to seven-fold in the first year.
4. **Who is responsible?** The firm. Outsourcing a service does not transfer responsibility to the provider (ORR-8 e); the firm maps the dependency and sets its own impact tolerance.

The firm whose important service rests on concentrated ICT and third-party dependencies, the ones BCBS Principles 4, 5 and 7 single out and COVID stressed, is the more vulnerable. The fix is never "more capital" or "more prevention" alone: it is a mapped service, an impact tolerance, and tested response and recovery.

Exam traps

- **Processes instead of services.** Impact tolerances attach to important business services, not to each internal process; process-by-process recovery targets are the old continuity view.
- **Prevention alone.** Regulators accept that severe disruptions will occasionally happen; resilience is prevent, detect and correct.
- **Resilience replaces ORM.** It sits alongside existing operational risk requirements and is an *outcome* of effective ORM (Fed, BCBS).
- **Capital or outsourcing as the answer.** Capital absorbs losses after the event; it does not keep a service running within tolerance. Outsourcing never transfers responsibility.
- **Component labels swapped.** Response, stakeholder trust and communication are *management of disruption*; keeping critical provisions going is *continuity of business services*.
- **Regulator roll-call.** By May 2022 the UK, the US and the BCBS had official guidance; the ECB (DORA) had a draft; MAS covered remote working.
- **Principle numbers.** BCBS 4 (mapping) and 6 (incident management) are the critical-service pair; 3, 5 and 7 (continuity, third parties, ICT) mirror the Fed paper.

Practice questions: ORR-1 d

Question ORR-1 d.1

Bank Q18 • AnalystPrep Q.5052 (rebuilt)

Bank ABC wishes to strengthen its operational resilience. A consultant explains that UK regulators (FCA, PRA and Bank of England) do not define resilience in a single sentence but instead describe it through several components. Which of the following components is correctly described?

A. Continuity of business services: to contribute to the stability of the system, firms should respond to disruptions, maintain trust among key stakeholders, and provide clarity of communication during a crisis.

B. Important business services: from a process-based view of continuity, the regulator moved to a service-based view to ensure continuity.

C. Management of disruption: it protects vital business services from disruption.

D. Lessons learned: firms should learn from past events and cover predictable shocks only.

Question ORR-1 d.2

Bank Q26 • Mock 1 Q52

The risk management department of a large bank needs to determine whether it has sufficient resilience to recover from a major operational event that causes loss of profits and reputation. In that regard, their goal is to enhance the bank's resilience by identifying, assessing, mitigating, and monitoring risks. When developing their operational resilience framework, the bank should consider the:

A. continuity of important business services in nonextreme situations only.

B. continuity of important business services in extreme and nonextreme situations.

C. continuity of each business process and recovery on a timely basis in nonextreme situations only.

D. continuity of each business process and recovery on a timely basis in extreme and nonextreme situations.

Question ORR-1 d.3 Bank Q27 • BT P2.T7.20.16.2 (rebuilt, key corrected)

A bank's board is reviewing its operational resilience framework against the 2018 UK and 2020 U.S. regulatory approaches. Which of the following statements is INCONSISTENT with the elements of operational resilience and with regulatory expectations?

A. The bank should identify the key business services whose disruption would cause intolerable harm to consumers or market integrity, and ensure their continuity within tolerance levels.

B. The bank should set impact tolerance levels by quantifying the amount of disruption that could be tolerated, which resembles a recovery time objective but is tied to critical services rather than individual processes.

C. The bank should aim to prevent all severe operational disruptions, because regulators expect that with strong enough preventive controls such disruptions will not occur, so planning for response and recovery is secondary.

D. The bank should learn from its own incidents and from events made public at other firms and continuously improve its ability to withstand unanticipated extreme shocks.

Question ORR-1 d.4 Bank Q19 • AnalystPrep Q.5053 (rebuilt)

The Federal Reserve's 2020 *Sound Practices to Strengthen Operational Resilience* treat operational resilience as a key outcome of an effective operational risk management framework (ORMF). Which of the following is NOT a regulatory expectation for operational resilience?

A. Effective coordination of ORM relies on a solid foundation of governance and assigning roles and responsibilities to each party.

B. Firms should monitor and report on the coordination and maintenance of business continuity management (BCM) and IT systems resilience.

C. A strong ORM framework is necessary in order to achieve operational resilience.

D. Firms are required to reduce their reliance on third parties.

Question ORR-1 d.5 Bank Q24 • Schweser Module Quiz 42.2 Q3

Which of the following pairs of resilience principles directly addresses the issue of providing critical services with minimal or no disruption?

A. Third-party dependency management; incident management.

B. Mapping interconnections and interdependencies; incident management.

C. Business continuity planning and testing; third-party dependency management.

D. Business continuity planning and testing; mapping interconnections and interdependencies.

Question ORR-1 d.6 Bank Q23 • Schweser Module Quiz 42.2 Q2

To date, which of the following entities is least likely to be considered a key regulator to have issued official guidance for operational resilience?

A. Bank of England.

B. U.S. Federal Reserve.

C. European Central Bank.

D. Basel Committee on Banking Supervision.

Question ORR-1 d.7 Bank Q22 • GARP PE1 Q3

A UK-based retail brokerage firm has recently experienced rapid growth through a series of acquisitions and plans to improve its operational resilience in order to comply with new requirements issued by national regulators. The CRO asks an operational risk manager to assess best practices in this area and to suggest potential actions that the firm should take to meet this objective. Which of the following actions would be most appropriate for the manager to recommend in order to comply with the regulatory guidelines concerning operational resilience for important business services?

A. Increase the existing performance incentives for the firm's brokers and sales representatives to further enhance their productivity.

B. Reduce costs by consolidating the human resources and payroll functions of the acquired firms into a single firm-wide process.

C. Reserve additional economic capital for operational risk to provide an incremental capital cushion against potentially extreme operational losses.

D. Increase the bandwidth capacity for the firm's equity trading platform and procure remote backup capabilities so the platform can continue to function during an outage.

Question ORR-1 d.8 Workbook A23.2 • S2, S3 • Map #31

A risk consultant is presenting to the risk committee of a UK banking group a review of how two subsidiaries came through the COVID-19 pandemic:

- a digital payment bank whose customers transact only through its app, with payment processing running on a third-party cloud provider;
- a community bank with a branch network, a local deposit base and mainly face-to-face relationship lending.

The committee asks which subsidiary was more vulnerable from an operational resilience perspective, and what follows for its resilience framework. Which of the following responses is most appropriate?

A. Neither can be ranked, because resilience is assessed process by process, so each bank should set recovery time objectives for its internal processes rather than for its services.

B. The payment bank was less vulnerable, because sufficiently strong preventive IT controls can stop severe operational disruptions to a digital service from ever occurring.

C. The payment bank was more vulnerable, because its important business service rests on IT systems and a third party, the channels COVID-era remote fraud targeted; it should set an impact tolerance for that service.

D. The payment bank was more vulnerable, but outsourcing payment processing to the cloud provider transfers responsibility for the disruption, so the bank need not set its own impact tolerance.

Solutions • ORR-1 d

Solution ORR-1 d.1 — Answer: B

Bank Q18 • AnalystPrep Q.5052

Step 1 – List the five UK components

Continuity of business services; important business services; impact tolerance levels; management of disruption; lessons learned.

Step 2 – Match each description to its component

"Respond, keep stakeholders' trust, communicate clearly" is management of disruption (A's text). "Protect vital services from disruption" is continuity of business services (C's text). Lessons learned aim at *unanticipated* extreme shocks (D says the opposite).
⇒ Only B pairs a component with its own description.

Interpretation

Important business services is the UK innovation: a service-based view, centred on services whose disruption would cause intolerable harm to consumers or market integrity.

Why the other options are wrong

A is incorrect. Label swap: the text describes management of disruption, not continuity of business services.
C is incorrect. Label swap: protecting critical provisions from disruption is continuity of business services; management of disruption is the response.
D is incorrect. Absolute and backwards: firms learn from internal and external events to withstand *unanticipated* extreme shocks.

LO: ORR-1 d: Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience. • **Reference:** GARP ORR Ch.1, 1.6 (First Regulatory Guidance: the UK)

Solution ORR-1 d.2 — Answer: B

Bank Q26 • Mock 1 Q52

Step 1 – The unit: services or processes?

The UK approach builds resilience around *important business services*, with impact tolerances tied to services "rather than to processes per se". That rules out C and D.

Step 2 – The breadth: which situations?

Severe disruptions are accepted as occasionally inevitable, and the board must consider "a broad range of severe but plausible scenarios". That rules out A.
⇒ B: important business services, in extreme and nonextreme situations.

Interpretation

The options form a two-by-two grid (unit, breadth); only B is right on both.

Why the other options are wrong

A is incorrect. Right unit, wrong breadth: extreme events are exactly what resilience is built for.
C is incorrect. Wrong on both: process-based, ordinary conditions only.
D is incorrect. Right breadth, wrong unit: the process-based view of classic business continuity.

LO: ORR-1 d: Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience. • **Reference:** GARP ORR Ch.1, 1.6; Ch.2, 2.3 c) (board role for resilience)

Solution ORR-1 d.3 — Answer: C

Bank Q27 • BT P2.T7.20.16.2

Step 1 – Check the consistent elements

A restates important business services; B restates impact tolerance (like a recovery time objective, but service-based); D restates lessons learned (internal and external events, unanticipated shocks).

Step 2 – Test C against the mindset shift

GARP: the industry accepted "that severe operational disruptions are inevitable, at least occasionally", and moved from a purely preventive approach to preventing, detecting and correcting incidents to minimise their net impact.
$\Rightarrow$ C contradicts this, so it is the inconsistent statement.

Interpretation

Response and recovery are not secondary: incident management is a BCBS principle (6), and management of disruption is a UK component. (The bank marks this item as key-corrected against its original source; C is confirmed by GARP Section 1.6.)

Why the other options are wrong

A is incorrect. Consistent: the important business services component.
B is incorrect. Consistent: impact tolerance, tied to services rather than processes.
D is incorrect. Consistent: lessons learned, the element that differentiates resilience from traditional business continuity.

LO: ORR-1 d: Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience. • **Reference:** GARP ORR Ch.1, 1.6

Solution ORR-1 d.4 — Answer: D

Bank Q19 • AnalystPrep Q.5053

Step 1 – Recall the building blocks (Figure 2)

Governance is the basis; ORM is the central component, with third-party risk management and scenario analysis; BCM and IT systems resilience are the supporting pillars; everything is monitored and reported.

Step 2 – Test each option

A is the governance foundation; B is monitoring and reporting of BCM and IT resilience; C is "resilience is not possible without proper ORM".
$\Rightarrow$ D is not an expectation: third-party dependencies are to be *managed*, not cut.

Interpretation

Third-party risk management is a building block precisely because firms depend on cloud, payment and clearing providers; the goal is resilient supply chains, not fewer suppliers.

Why the other options are wrong

A is incorrect. A genuine expectation: governance and clear roles are the required starting point.
B is incorrect. A genuine expectation: the coordination and maintenance of these activities must be monitored and reported.
C is incorrect. A genuine expectation: ORM is the central component of operational resilience.

LO: ORR-1 d: Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience. • **Reference:** GARP ORR Ch.1, 1.6 (US Regulation) and Figure 1.3

Solution ORR-1 d.5 — Answer: B

Bank Q24 • Schweser Module Quiz 42.2 Q3

Step 1 – Number the seven BCBS principles

1 governance, 2 ORM, 3 BCP and testing, 4 mapping interconnections and interdependencies, 5 third-party dependency management, 6 incident management, 7 ICT including cybersecurity.

Step 2 – Find the critical-service pair

GARP: "mapping dependencies and interconnections for the delivery of critical services, to prevent intolerable disruptions, and having plans if any occur, are among the central principles of BCBS (principles 4 and 6), in the same spirit as the UK regulators' approach."
⇒ Principles 4 and 6: B.

Interpretation

Principles 1 and 2 integrate resilience into existing governance and ORM; 3, 5 and 7 echo the Fed paper; 4 and 6 echo the UK's service-based approach.

Why the other options are wrong

A is incorrect. Principle 5 (third parties) is one of the Fed-style elements; only principle 6 of this pair is the critical-service principle.
C is incorrect. Principles 3 and 5 are both Fed-style elements.
D is incorrect. Principle 4 fits, but principle 3 is a Fed-style element; the pair needs incident management (6).

LO: ORR-1 d: Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience. • **Reference:** GARP ORR Ch.1, 1.6 and Table 1.3; Schweser-Notes 2026 Book 3, Reading 42, LO 42.d

Solution ORR-1 d.6 — Answer: C

Bank Q23 • Schweser Module Quiz 42.2 Q2

Step 1 – Who had issued official guidance by May 2022?

The UK (Bank of England with the PRA and FCA, 2018), the US (Federal Reserve, 2020) and the BCBS (March 2021): "the three main regulators having issued official guidelines for operational resilience".

Step 2 – Place the ECB

The ECB is credited with a *draft* regulation, DORA (September 2020), focused on ICT requirements.
⇒ The ECB is the least likely to count as a key issuer of official guidance.

Interpretation

The roll-call follows the chronology of shape S2: UK first, then the US and BCBS; the ECB (DORA) and MAS (remote working) addressed aspects of resilience. On the authorship of DORA, see the correction box in Section 4.

Why the other options are wrong

A is incorrect. The Bank of England, with the PRA and FCA, issued the first guidance (2018).
B is incorrect. The Fed issued its Sound Practices in 2020.
D is incorrect. The BCBS issued its seven Principles for Operational Resilience in March 2021.

LO: ORR-1 d: Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience. • **Reference:** GARP ORR Ch.1, 1.6 (Other Regulators on Other Aspects of Resilience)

Solution ORR-1 d.7 — Answer: D

Bank Q22 • GARP PE1 Q3

Step 1 – Name the important business service

For a retail brokerage, clients' ability to trade is the service whose disruption would harm consumers and market integrity: the equity trading platform.

Step 2 – Choose the action that keeps it running

Extra bandwidth and remote backup keep the platform within tolerance during an outage: continuity of an important business service.

⇒ D.

Interpretation

Rapid growth by acquisition adds integration and capacity risk to client-facing systems, which is where the resilience effort should go first.

Why the other options are wrong

A is incorrect. Sales incentives raise productivity (and possibly conduct risk); they do nothing for service continuity.

B is incorrect. Consolidating HR and payroll is an internal cost measure, not an important business service, and can create a single point of failure.

C is incorrect. Capital absorbs losses after the fact; it does not keep the service running within its impact tolerance.

LO: ORR-1 d: Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience. • **Reference:** GARP ORR Ch.1, 1.6

Solution ORR-1 d.8 — Answer: C

Workbook A23.2 • S2, S3

Step 1 – The regulatory lens (UK first, then BCBS, ECB, MAS)

UK regulators (BoE, PRA, FCA, July 2018) moved from a process-based to a service-based view: identify important business services whose disruption would cause intolerable harm to consumers or market integrity, and set impact tolerances for them. The BCBS principles (March 2021) add mapping of interconnections and interdependencies, third-party dependency management and resilient ICT including cybersecurity. The ECB's DORA draft is ICT-focused; MAS (2021) addressed remote-working risks.

⇒ The question to ask of each subsidiary: which important service could be disrupted, and through which dependencies?

Step 2 – Map each bank's exposure to those principles

Payment bank: one digital service, critical payments, dependence on IT and on a critical third party (the cloud provider). Attention to resilience "emanated from the financial industry's critical dependence on IT systems and infrastructure" and on cloud and payment infrastructure providers. Process-based firms such as payment processors may even organise their risk appetite around key processes (ORR-2), and a payment company's taxonomy centres on operations and IT risk (ORR-3, Box 3.4). Under COVID, critical payments ran "in the most extreme conditions, much beyond any stress scenario they had tested"; fraud attempts tripled, phishing rose six- to seven-fold, and the rise in remote transactions made anomalies harder to detect (ORR-11). Community bank: its service is spread across branches and people rather than concentrated in one IT channel and one provider (applied reasoning from the scenario; the source does not rank these two bank types).

⇒ The payment bank concentrates its important business service in exactly the dependencies

(ICT, cyber, third party) that the BCBS principles single out and that COVID stressed.

Step 3 – Who carries the responsibility

If an institution outsources, the ultimate responsibility remains with the institution (ORR-8 e). The payment bank must map the cloud dependency, align the provider's continuity plans with its own, and set its own impact tolerance.

Step 4 – Prevention is not enough

After high-profile cyberattacks the industry accepted that severe operational disruptions are inevitable, at least occasionally, and moved from purely preventive management to preventing, detecting and correcting incidents.

Interpretation

C is correct. The recommendation: treat the payment service as an important business service, set an impact tolerance for it, map its ICT and cloud dependencies, and test response and recovery against severe but plausible scenarios, including pandemic-style remote operation and fraud surges.

Why the other options are wrong

A is incorrect. Sibling swap: replaces the service-based view (important business services, impact tolerances) with the process-based view of classic business continuity that the UK approach moved beyond.

B is incorrect. Absolute claim: severe disruptions are accepted as occasionally inevitable; resilience requires detection, response and recovery, not prevention alone.

D is incorrect. Role misassignment: outsourcing does not transfer responsibility; the ultimate responsibility remains with the institution, which must manage the third-party dependency.

LO: ORR-1 d: Describe operational resilience, identify the elements of an operational resilience framework, and summarize regulatory expectations for operational resilience. ORR-8 e: Describe practices for the governance of risks of interconnected third-party service providers. • **Reference:** GARP ORR Ch.1, 1.6 and Table 1.3; BCBS (2018), GARP ORR Ch.8, 8.6; GARP ORR Ch.11 (COVID fraud)

ORR-2 • Risk Governance • Vardeez: UNTIERED (crash-course notes)

ORR-2 b

P1 CONCEPT

Describe and compare the roles of different committees and the board of directors in operational risk governance.

Workbook: A22 Three Lines of Defence and Operational Risk Governance • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic (A22): your August 2026 recall lists "Three lines of defence, 2Q" for the section, and the topic map has it at #29 (4 of 16 sources). Shape S3 of that section is the committee-and-board question.

Vardeez: his crash-course notes for this LO (his "LO 41.b", consolidated volume p.36) give the three levels of operational risk committees, the two governance documents (terms of reference; policies and procedures), and a two-column table of what the board owns for operational risk and for operational resilience (his Figure 41.2). ORR-2 is rank 7 of 55 in his ROI ranking.

Reported exam shapes

- **S3** Committees versus the board, and who owns risk appetite and limits (workbook A22.2).

What the questions look like: a committee structure or a list of duties, and you decide who does what: the full board (ultimately responsible; approves the framework and the appetite), the board risk committee (oversees, recommends), the group operational risk committee (consolidates and reports upward), business or regional committees (oversee their scope, escalate), senior management (implements). Every distractor moves a duty one level up or down.

See also: workbook A22.2 also tags ORR-2 d, where the appetite half of the shape is covered. Two GARP-style questions on Basel governance expectations (bank LO 43.a, ORR-2 a, not in this book) are re-filed here.

1. Who is ultimately responsible

The board of directors "is ultimately responsible for the general administration of the firm, including risk management". Corporate governance codes, in BCBS's terms, make it responsible for determining "the nature and extent of the significant risks the firm is willing to take": it **sets the risk appetite and makes sure the firm operates within it**. The board delegates tasks to senior management and staff, but not its accountability. The CRO is part of senior management and does not take on ultimate responsibility, even when the board was poorly informed.

2. What the board owns, for operational risk and for resilience

Vardeez's Figure 41.2 splits the board's role in two columns. With GARP's detail (RPSMOR 2021 for operational risk; BCBS resilience Principle 1 and the UK PRA and FCA papers for resilience):

Operational risk	Operational resilience
Validate (approve) the ORMF and ensure its periodic revision (Principle 3)	Use the **existing governance structure** to establish, oversee and implement the resilience approach
Get assurance that senior management implements the ORMF's policies, processes and systems effectively at all levels, for example through the committee structure (Principle 3)	**Oversee senior management's implementation** and receive assurance through timely reporting, particularly on deficiencies that could affect critical operations
Set the risk appetite: approve and periodically review the appetite and tolerance statement (Principle 4)	Make the approach consider the **appetite and tolerance for disruption** to critical operations, under a broad range of severe but plausible scenarios
Establish the risk culture and communicate it effectively (Principle 1: led by the board, implemented by senior management)	Communicate the resilience objectives clearly, as part of its responsibility for risk culture
Be trained, and ensure every function involved in ORM is trained	Ensure sufficient **financial and technical resources**; demonstrate the board's training, knowledge, skills and experience; training for all staff

Senior management develops and implements the policies, processes and systems (Principle 5): it translates the ORMF into business-unit procedures, builds challenge and issue-resolution mechanisms, staffs and trains. Shorthand: *the board approves, oversees and gets assurance; senior management implements.* Under the RPSMOR the board's review also includes making sure the ORMF is subject to independent review.

3. The committee pyramid

Governance of operational risk is organised around **committees taking collegial decisions** on reported and escalated information. Larger firms have a pyramid (GARP Figure 2.3), redrawn in Figure 1:

- **Lowest level:** committees by business type or function (corporate banking, investment banking, support services) or by geography (country, region). They oversee operational risk in their scope, provide information for the firm-wide assessment, and **escalate** significant issues, or those exceeding predetermined limits, to a firm-wide or second-line risk committee.
- **Group (organisation) operational risk committee:** oversees, manages, monitors and **reports the consolidated picture** to the executive risk committee, the management committee and the board risk committee.
- **Board risk committee** (board-created, enterprise level): **oversees all operational risk** and **makes recommendations to the full board** on risk-based decisions, risk exposure and risk management; reviews and monitors the investigation of larger incidents. Regulators require its members to have *recent and relevant* experience. The board and the board risk committee receive regular risk reporting.

Size decides the shape. A small firm may have a single operational risk committee reporting to the management committee and the board risk committee; any structure is fine if the size and complexity of the business justify it. Large firms often split operational risk into specialised types (fraud, information security, legal and compliance), each with its own committee, coordinated either under the

operational risk committee (operational risk sets the framework for all non-financial risks) or directly by the enterprise risk committee alongside credit and market risk.



Figure 1. The committee pyramid of a large bank (after GARP Figure 2.3 and Section 2.3 a). Solid arrows carry escalation and reporting upward; the dashed arrow on the left carries delegation downward. Shading darkens towards the board, the only body that approves; the dashed box is senior management, which also receives the consolidated picture.

4. Documents that prove governance

- **Terms of reference ("committee charter"):** the specific authority a committee holds over its delegated area: role and purpose, membership, members' roles and responsibilities, meeting frequency, and any amendments to the charter with their motivation.
- **Minutes:** committees review risk reporting, take decisions and review and validate ORM policies. The discussions, decisions and their motivation must be recorded in approved minutes. Regulators apply the **use test** (ORM must be embedded in decisions, not rubber-stamped) and in their eyes "**absence of evidence is evidence of absence**".
- **Policies and procedures** are directive controls. They work only if publicised, regularly updated, embedded in daily practice and meaningful; they also serve as training, notably for new joiners.

Corrections to the source notes.

- Vardeez's top level reads: the board risk committee oversees all levels, "advising the board on risk exposures *and making key decisions*". In GARP the board risk committee *makes recommendations* to the full board "with regards to risk-based decisions"; the board itself approves the ORMF and the risk appetite. A statement that the committee decides on its own is the planted error (Question ORR-2 b.4).
- GARP's text calls the two ORM and ERM committee structures "Figures 1.4 and 1.5"; they are Figures 2.4 and 2.5 of Chapter 2.

Body	Does	Does not
Board of directors	Ultimately responsible; approves and reviews the ORMF and the appetite statement; owns the limits; leads culture; ensures resilience resources	Design or run procedures and controls
Board risk committee	Oversees all operational risk; recommends to the board; reviews larger incidents; often holds the delegated oversight of limits	Approve the ORMF or the appetite without the board
Executive risk and management committees	Senior management's forums: receive the consolidated picture; implement	Carry ultimate responsibility
Group operational risk committee	Consolidates, monitors and reports the firm-wide picture upward	Sit at the top or advise the full board directly
Business and regional committees	Oversee their scope; supply information; escalate issues and limit breaches	Set firm-wide appetite

Exam traps

- **Committee decides.** The board risk committee recommends; the full board approves the ORMF and the appetite.
- **Group committee on top.** The group operational risk committee reports upward to the board risk committee; it is not the link to the full board.
- **Board does the work.** Designing procedures, building challenge mechanisms, recruiting and training staff are senior management's job; the board approves, oversees and gets assurance.
- **Responsibility moves.** Ultimate responsibility stays with the board: not the CRO, not senior management, not the business lines, however poorly the board was informed.
- **Principle numbers.** RPSMOR 3: board approval and review of the ORMF; 4: appetite and tolerance statement; 5: senior management implements.
- **One structure fits all.** A small firm's single committee is fine if justified by size and complexity.
- **Undocumented decisions.** Without minutes the regulator concludes the practice does not exist.

Practice questions: ORR-2 b

Question ORR-2 b.1

Bank Q37 • AnalystPrep Q.5569 (rebuilt)

After a major operational loss, a review finds that a bank's chief risk officer (CRO) and senior management had given the full board only limited information on the bank's operational risks. Within the bank's operational risk governance, which party is ultimately responsible for operational risk management and resilience?

A. The chief risk officer.

B. The board of directors.

C. The senior management team.

D. The employees in the business lines.

Question ORR-2 b.2

Bank Q34 • BT P2.T7.800.3 (rebuilt)

Under the Basel principles for the sound management of operational risk, the board of directors and senior management have distinct responsibilities for the operational risk management framework (ORMF). Which of the following is a responsibility of the board of directors rather than of senior management?

A. Establishing and maintaining robust challenge mechanisms and effective issue-resolution processes.

B. Translating the ORMF into specific policies and procedures that can be implemented and verified within each business unit.

C. Recruiting experienced technical staff and organising the operational risk training needed to implement the ORMF in each business unit.

D. Validating the ORMF and ensuring it is reviewed periodically, so that the bank's operational risks are properly identified and managed.

Question ORR-2 b.3

Bank Q31 • AnalystPrep Q.5057 • re-filed from bank LO 43.a

Principle 3 of the Basel Principles for the Sound Management of Operational Risk outlines the role of the board of directors in operational risk governance. Which of the following board roles is in line with Principle 3?

A. Identify the types and levels of operational risk the bank is willing to assume, and approve risk appetite and risk tolerance statements.

B. Regularly review the appropriateness of the bank's risk appetite and tolerance statements.

C. Ensure the ORM framework is subject to independent review by sufficiently skilled personnel.

D. Ensure that all risks are considered when approving risk appetite and tolerance statements that detail risk limits and thresholds.

Question ORR-2 b.4 Bank Q36 • AP Mock 1 Q48 (rebuilt)

A large bank has a pyramid of operational risk committees. Which of the following tasks is most likely performed by the board (enterprise-level) risk committee?

A. Making recommendations to the full board on risk exposures and risk-based decisions, and reviewing larger operational risk incidents escalated from lower committees.

B. Overseeing operational risk only within a single business line or country and passing information upward.

C. Setting the bank's risk appetite and approving the ORMF without any reference to the full board.

D. Preparing the day-to-day first-line risk and control self-assessments for each business unit.

Question ORR-2 b.5 New • built from GARP Ch.2

Following new operational resilience rules modelled on the BCBS Principles for Operational Resilience, the board of a Dutch bank is reviewing a draft memo, prepared by the chief operating officer, on the board's own role. Which of the following statements in the memo is consistent with regulatory expectations of the board?

A. The board should create a governance structure for resilience separate from its existing risk committees, so that resilience is not diluted by routine operational risk business.

B. The board should oversee senior management's implementation of the resilience approach, ensure sufficient financial and technical resources, and receive timely reporting on deficiencies.

C. The board should hear about resilience only after a severe disruption, and its members need no specific training in resilience as long as senior management is trained.

D. The board should calibrate the resilience approach to disruptions the bank has already experienced, leaving out any scenario more severe than its own history.

Question ORR-2 b.6 Bank Q33 • GARP PE1 Q4 • Mock 3 Q76 • re-filed from bank LO 43.a

The board of directors of a midsize bank has recommended that the bank improve its processes for managing operational risk. The CEO asks an enterprise risk manager to review the bank's tools and processes and to suggest improvements consistent with Basel II and Basel III guidelines for operational risk governance. The bank also plans to adopt the new Basel III standardized approach (SA) to determine its regulatory capital for operational risk. Which of the following actions should the manager recommend?

A. Use third-party outsourcing agreements to replace most internal controls performed by senior managers and business line managers.

B. Develop an internal approach to model the distribution of operational risk losses and use it to determine the bank's regulatory capital.

C. Require an independent review of the bank's operational risk management framework.

D. Designate the risk management function as the primary owner of risk exposures within each business line.

Question ORR-2 b.7 Workbook A22.2 • S3 • Map #29

A newly appointed non-executive director on the board risk committee of an Australian bank asks the company secretary for a briefing note on operational risk governance. The bank's large committee structure includes regional risk committees, a group operational risk committee, an executive risk committee and the board risk committee, and its risk appetite statement declares "minimal tolerance for data breaches". Which of the following statements is correct to include in the note?

A. The board ultimately owns the operational risk limits and validates them periodically, often delegating this to the board risk committee, which relies on the risk function to implement and report on them.

B. The group operational risk committee sits at the top of the structure and makes recommendations directly to the full board on risk-based decisions, risk exposure and risk management.

C. A statement of minimal tolerance for data breaches is credible on its own, since an appetite statement need not be tied to specific key controls or to monitoring metrics.

D. Senior management approves and periodically reviews the operational risk appetite and tolerance statement, and the board receives the approved statement for information.

Solutions • ORR-2 b

Solution ORR-2 b.1 — Answer: B

Bank Q37 • AnalystPrep Q.5569

Step 1 – Locate ultimate responsibility

"The board of directors is ultimately responsible for the general administration of the firm, including risk management"; with the new resilience rules its responsibilities extend to operational resilience.

Step 2 – Separate delegation from accountability

The board delegates tasks to senior management (including the CRO) and to staff. Delegation does not move ultimate responsibility, and a failure by management to inform the board does not shift it either.

$\Rightarrow$ The board of directors.

Interpretation

The case is a reminder of why the board must *obtain assurance*: it carries the responsibility, so it must insist on complete and adequate reporting through the committee structure.

Why the other options are wrong

A is incorrect. The CRO is part of senior management and holds delegated, not ultimate, responsibility; blaming the person who under-reported is the tempting error.

C is incorrect. Senior management implements the ORMF and is accountable to the board for it, but is not ultimately responsible.

D is incorrect. Business-line staff are first-line risk owners with delegated day-to-day responsibility.

LO: ORR-2 b: Describe and compare the roles of different committees and the board of directors in operational risk governance. • **Reference:** GARP ORR Ch.2, 2.3 c) (The Role of the Board); SchweserNotes 2026 Book 3, Reading 43, LO 43.b

Solution ORR-2 b.2 — Answer: D

Bank Q34 • BT P2.T7.800.3

Step 1 – The board's ORMF duties

Regulators require the board to validate the ORMF, ensure its periodic revision, and get assurance that senior management implements it effectively at all levels (RPSMOR Principle 3).

Step 2 – Senior management's duties

Senior management develops and implements the policies, processes and systems (Principle 5): challenge and issue-resolution mechanisms, business-unit procedures, staffing and training.

$\Rightarrow$ Only D is an approval-and-review duty; A, B and C are implementation.

Interpretation

The board does make sure that the functions involved in ORM are trained, but recruiting staff and organising the training is executive work; option C was reworded from the bank's version to make that unambiguous.

Why the other options are wrong

A is incorrect. Building challenge mechanisms and issue-resolution processes is senior management implementing the framework.

B is incorrect. Translating the ORMF into business-unit policies and procedures is implementation.

C is incorrect. Hiring and organising training to implement the ORMF is an executive task; the board oversees it.

LO: ORR-2 b: Describe and compare the roles of different committees and the board of directors in operational risk governance. • **Reference:** GARP ORR Ch.2, Table 2.1 and 2.3 c)

Solution ORR-2 b.3 — Answer: C

Bank Q31 • AnalystPrep Q.5057

Step 1 – What Principle 3 covers

RPSMOR Principle 3 is "board review and approval of the ORMF": the board validates the framework, ensures its periodic revision and independent review, and gets assurance on its implementation.

Step 2 – What Principle 4 covers

Principle 4 is the "risk appetite and tolerance statement for operational risk to be approved and periodically reviewed by the board". A, B and D all concern that statement.
⇒ Only C is about the framework itself: Principle 3.

Interpretation

The board has two separate approval roles, the framework (Principle 3) and the appetite (Principle 4). The exam separates them by principle number. Re-filed from ORR-2 a because it tests the board's roles.

Why the other options are wrong

A is incorrect. Setting and approving appetite and tolerance is Principle 4.
B is incorrect. Reviewing the appetite and tolerance statements is Principle 4.
D is incorrect. Considering all risks when approving limits and thresholds in the statements is part of Principle 4.

LO: ORR-2 b: Describe and compare the roles of different committees and the board of directors in operational risk governance. ORR-2 a: Explain the Basel regulatory expectations for the governance of an operational risk management framework. • **Reference:** GARP ORR Ch.2, Table 2.1 and 2.3 c)

Solution ORR-2 b.4 — Answer: A

Bank Q36 • AP Mock 1 Q48

Step 1 – Place each task in the pyramid

Single business line or country: lowest-level committee (B). Day-to-day self-assessments: first-line business units (D). Approving appetite and the ORMF: the full board (C).

Step 2 – The board risk committee's own role

It oversees all operational risk, "makes recommendations to the full board with regards to risk-based decisions, risk exposure, and risk management", and "reviews and monitors the investigation of larger incidents".
⇒ A.

Interpretation

The board risk committee is the top *committee*, but it advises; it does not replace the board. This is the point Vardeez's notes blur (see the correction box).

Why the other options are wrong

B is incorrect. Describes a lowest-level business-line or country committee.
C is incorrect. The full board sets the appetite and approves the ORMF; the committee recommends.

D is incorrect. Risk and control self-assessments are a first-line activity in the business units.

LO: ORR-2 b: Describe and compare the roles of different committees and the board of directors in operational risk governance. • **Reference:** GARP ORR Ch.2, 2.3 a) and Figure 2.3

Solution ORR-2 b.5 — Answer: B

New • built from GARP Ch.2

Step 1 – BCBS resilience Principle 1

Directors "utilize their existing governance structure to establish, oversee and implement an effective operational resilience approach".

Step 2 – The board's resilience duties

The board "oversees senior management's implementation", "ensures that sufficient financial and technical resources are allocated", and receives "timely reporting from senior management, particularly when significant deficiencies could affect the delivery of the firm's critical operations". The approach must consider "a broad range of severe but plausible scenarios", and the firm must show the board has been trained.
$\Rightarrow$ B states exactly these duties.

Interpretation

The resilience role mirrors the operational risk role: oversee, resource, get assurance. It is built into existing governance, not bolted on.

Why the other options are wrong

A is incorrect. Scope error: the principle is to use the existing governance structure, not to create a parallel one.
C is incorrect. Polarity flip: assurance comes through ongoing, timely reporting, and the board's own training must be demonstrable.
D is incorrect. Scope error: the approach must cover a broad range of severe but plausible scenarios, including ones the bank has never lived through.

LO: ORR-2 b: Describe and compare the roles of different committees and the board of directors in operational risk governance. • **Reference:** GARP ORR Ch.2, 2.3 c) (Regulatory Guidance on the Role of the Board for Operational Resilience)

Solution ORR-2 b.6 — Answer: C

Bank Q33 • GARP PE1 Q4

Step 1 – What Basel governance expects

The board validates the ORMF, ensures its periodic revision and gets assurance on its implementation; part of that assurance is an independent review of the framework.

Step 2 – Test the other actions

Outsourcing cannot replace internal controls (A). Under the SA (from January 2023) Pillar 1 capital is ORC $=$ BIC $\times$ ILM; internal loss models no longer set it (B). The business lines, the first line, own the risk exposures (D).
$\Rightarrow$ C.

Interpretation

A GARP item on Basel governance (ORR-2 a), placed here because the answer is a board-level duty and two distractors misplace roles.

Why the other options are wrong

A is incorrect. Outsourcing may complement controls but cannot replace them; responsibility

stays with the bank.
B is incorrect. Internal models (AMA) were discontinued for Pillar 1; the SA is a single standardised measure.
D is incorrect. Role misassignment: the risk function is the second line; it challenges, it does not own the exposures.

LO: ORR-2 b: Describe and compare the roles of different committees and the board of directors in operational risk governance. ORR-2 a: Explain the Basel regulatory expectations for the governance of an operational risk management framework. • **Reference:** GARP ORR Ch.2, 2.2 c) and 2.3 c), d)

Solution ORR-2 b.7 Answer: A

Workbook A22.2 • S3

Step 1 – Place each committee in the pyramid

Regional and business committees escalate to a firm-wide committee; the group operational risk committee reports the consolidated picture to the executive risk committee, the management committee and the board risk committee. The board risk committee oversees all operational risk and makes recommendations to the full board.
⇒ The top of the committee pyramid, and the link to the full board, is the board risk committee.

Step 2 – Who approves appetite and owns limits

RPSMOR Principle 4: the risk appetite and tolerance statement is approved and periodically reviewed by the board. ORR-2: "It is the role of the board of directors to ultimately own the risk limits and to validate them periodically. In practice, the board often delegates this responsibility to the board risk committee, which in turn requests the support of the risk function."

Step 3 – What makes the statement credible

A firm declaring minimal tolerance for data breaches must corroborate it with strong controls and monitoring measures; an actionable appetite combines exposure limits, key controls, tolerated incidents and monitoring metrics (appetite KRIs).

Interpretation

A is correct. The director should expect to see limits owned by the board, overseen in practice by the board risk committee, and backed by key controls and KRIs on data security, with the risk function reporting against them.

Why the other options are wrong

B is incorrect. Sibling swap: attributes the board risk committee's role (recommendations to the full board) to the group operational risk committee, which reports upward to it.
C is incorrect. Scope/condition error: drops the requirement that appetite statements be supported by key controls and monitored through indicators on exposure, controls and losses.
D is incorrect. Role misassignment: the board approves and periodically reviews the risk appetite and tolerance statement; senior management develops and implements policies and systems.

LO: ORR-2 b: Describe and compare the roles of different committees and the board of directors in operational risk governance. ORR-2 d: Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture. • **Reference:** GARP ORR Ch.2, 2.2 b), 2.3 a) and c), 2.4 a) and b)

ORR-2 • Risk Governance • Vardeez: UNTIERED (crash-course notes)

ORR-2 c

P1 CONCEPT

Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense.

Workbook: A22 Three Lines of Defence and Operational Risk Governance • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic (A22): your August 2026 recall lists "Three lines of defence, 2Q", and the topic map has it at #29 (4 of 16 sources): "Business lines own risk (first line); the risk function sets framework and challenges (second); internal audit provides independent assurance (third). Any statement moving an activity across those boundaries is the defect."
Vardeez: his crash-course notes for this LO (his "LO 41.c", consolidated volume p.37) are one comparison table of the three lines: who each line is, its roles and responsibilities, and its relationship with the other lines (his Figure 41.3).

Reported exam shapes

- **S1** Three lines of operational risk management: who does what, with every distractor moving an activity across a line (workbook A22.1).

What the questions look like: a responsibilities matrix, a re-design draft, or a description of someone's job; you place each activity in its line or find the misplaced one. The planted moves: sign-off to the second line, ownership to risk champions, framework design or continuous monitoring to internal audit, exclusive reliance by internal audit on others, a risk function reporting through a risk-taking unit.

1. Three lines, defined by role

Born in the military, the three lines have become "the generally accepted and recommended way to organize controls and risk management in financial services organizations". The BCBS (RPSMOR) names each line:

- **Line 1, "business unit management":** the risk owners, the front line of the business.
- **Line 2, "an independent corporate operational risk management function (CORF)":** independent oversight of business processes and of the implementation of the risk policies and framework; it challenges the activities and behaviour of the business lines.
- **Line 3, "independent assurance":** the internal audit function.

What defines a line is the role and responsibility, not the name of the department. Delineation is harder for operational risk than for credit or market risk because ORM is less centralised and because control functions such as finance, legal or security do not always map to one line.

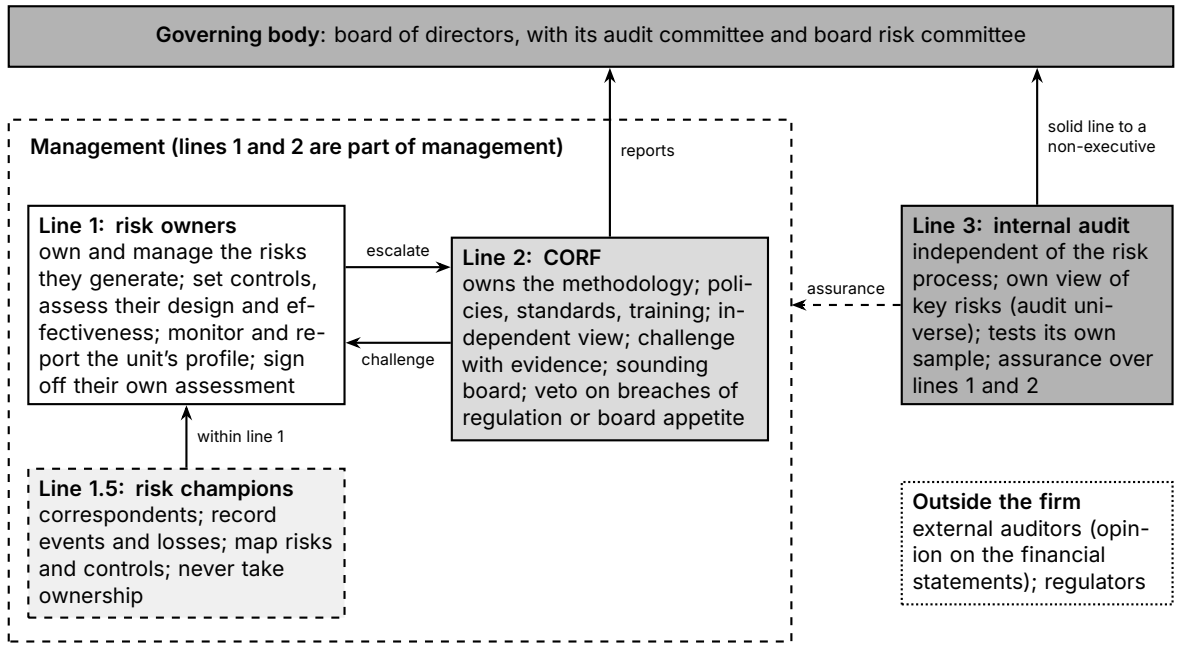


Figure 1. The three lines (after GARP 2.3 d and the IIA 2021 model). Shading darkens with independence from the business: open box for the first line, light grey for the second, dark grey for internal audit. The dashed frame is management; the dotted box sits outside the firm. Solid arrows: escalation, challenge and reporting; the dashed arrow: internal audit's assurance over both management lines.

2. Line 1: the risk owners

"Risk is managed where it is generated": risk is *not* owned by the risk function but by the business. Better to say **risk owners** than "the business": the head of IT owns IT risk. An effective first line:

- identifies and assesses the materiality of the operational risks inherent in its business;
- establishes appropriate controls and assesses their design and effectiveness;
- monitors and reports the business unit's operational risk profile;
- reports to the second line any lack of resources, tools or training, and residual risks not mitigated by controls (loss events, control deficiencies, process inadequacies, breaches of tolerance).

Line 1.5, risk champions (specialists, "stewards", correspondents), common in larger firms: main correspondent for risk issues; collect and record risk events and losses; map risks and controls to group definitions; follow up control rules, action plans and audit tracking. They remain first line, and **ownership must not be assumed by, or passed to, them**.

3. Line 2: the corporate operational risk function

The second line **develops the framework and reviews and challenges its implementation** by the first line; it is not directly involved in first-line risk management. Its responsibilities:

1. develop and maintain ORM and measurement policies, standards and guidelines, and design and deliver risk training;
2. form an independent view of the units' risk identification, key controls and respect of appetite and tolerance limits;
3. challenge the relevance and consistency of the units' use of ORM tools, measurement and reporting, *and provide evidence of that challenge*;

4. review and contribute to the monitoring and reporting of the operational risk profile.

It is also a **sounding board** for decisions that change the risk profile (new ventures, acquisitions, products, markets), and needs **delegated authority to veto** decisions that contradict regulation or exceed the board's appetite limits.
Independence varies with size: at small banks it may come from separation of duties and independent review; in larger banks the CORF should have **a reporting structure independent of the risk-generating units** and is responsible for the design, maintenance and development of the ORMF.
Guidance against challenge. Pure independence risks redundancy with internal audit, and challenge is hard before practices mature, so the risk function's first role is to educate (what operational risk is, how incidents are recognised and reported, the benefits of good ORM, the pitfalls of poor ORM). It stays independent by *asking questions without pre-empting the answers*: a second-line risk manager may run an RCSA workshop, then collect and challenge the answers, but the first line signs off its own assessment. **"The second line owns the methodology; the first line owns the risks."**

4. Line 3: internal audit

The line with the clearest boundaries. Internal audit is independent of the risk management process and assesses the control system and compliance with policies across the organisation, *including the risk function*; it builds its own view of key risks (its audit universe). IIA guidance:

- it is neither responsible for, nor part of, risk management, compliance or finance, and includes them in its scope;
- "in no circumstances should internal audit rely exclusively" on their work; it always examines its own sample;
- it may take account of their work, and reduce its own scrutiny, only after evaluating that function's effectiveness.

It **reports in solid line to a non-executive director** (the audit committee chair, the senior independent director or the non-executive chairman). Assurance goes to the governing body, senior management and external stakeholders (regulators, investors): internal audit for the system of operational controls, the **external auditors**, also independent, for the financial statements and the controls over financial reporting. Audit and risk may coordinate agendas and share findings to avoid duplicate visits.

5. Hybrid functions, and the 2021 updates

When finance, HR, legal, ICT or security lack the staff for separate functions, they act in both lines. BCBS: **document and distinguish** the first and second line responsibilities, emphasising the independence of the second line.

Department	First line role	Second line role
Legal	Drafting contracts	Overseeing legal activity in the business lines
HR	Administering pay, recording performance against objectives	Overseeing people management in the business lines
IT security	Encrypting data, partitioning the network, monitoring network activity	Verifying the implementation of ICT controls in business operations, enforcing security policies
Finance	Managing treasury and accounting	Verifying whether business exposures remain under authorised limits

IIA Three Lines Model (2021). It reinforces the second line's *expertise and support* role, limits its challenge to risk-related matters, and recalls that the second line is **part of, and reports to, manage-**

ment: risk helps the firm create and protect value, rather than only controlling it. **"Three lines of accountability"** is a renaming that stresses accountability; it is not a departure from the model.

Line	Owns and does	Must not	Reports to
1 Risk owners	The risks; controls; profile reporting; sign-off of own assessments; risk-taking within appetite	Hand ownership to champions or to the risk function	Business management; escalates to line 2
1.5 Champions	Liaison, event and loss collection, mapping, follow-up	Take ownership of the risks	Within line 1
2 CORF	The methodology; policies, training; independent view; challenge; veto on breaches	Run line 1's risk management or pre-empt its answers	Independently of risk-generating units (CRO)
3 Internal audit	Independent assurance over lines 1 and 2; own universe and sample	Design or run the framework; rely exclusively on others; monitor continuously	A non-executive (audit committee chair)
External audit	Opinion on the financial statements	Be part of the three lines	Outside the firm; independent

Exam traps

- **Sign-off moved to line 2.** The second line may run the RCSA and challenge it; the first line signs off.
- **Ownership moved.** Not to risk champions (line 1.5), not to the risk function, not to internal audit.
- **Internal audit designs or monitors.** Designing and implementing the ORMF is the CORF's job; continuous monitoring is second line; audit gives independent, periodic assurance.
- **Exclusive reliance.** A positive evaluation of the risk function allows less intense scrutiny, never exclusive reliance.
- **Reporting lines.** A risk function reporting through a risk-taking unit (head of credit) is not independent; internal audit never reports to the CRO.
- **Line by department name.** A hybrid function's line is set by each role, documented separately.
- **Second line as auditor.** Under the IIA 2021 model it is part of management and provides support as well as challenge, on risk matters only.
- **Risk appetite to line 1.** The board sets appetite; the first line takes risk within it.

Practice questions: ORR-2 c

Question ORR-2 c.1

Bank Q41 • AP Mock 3 Q36

Which of the following is most likely a role and responsibility of the second line of defense for the overall risk management of a firm under risk governance?

A. Making decisions for managing risks.

B. Establishing risk management methods and measurement methods.

C. Overseeing the risk management activities of the third line of defense.

D. Reporting independently to the board of directors.

Question ORR-2 c.2

Bank Q48 • AP Mock 1 Q36

Which of the following tasks is performed under the second line of defense, an independent corporate operational risk management function?

A. Keeping track of risk events and losses through the collection and recording of data.

B. Following up on the implementation of control rules, risk management action plans, and audit tracking.

C. Identifying risks and controls in accordance with the group definitions.

D. Reviewing and taking part in the monitoring and reporting of the operational risk profile.

Question ORR-2 c.3

Bank Q40 • AP Mock 1 Q63 (rebuilt)

Angela Myer is reviewing the bank's cyber-security controls, including firewalls, and independently assessing whether departments, including the risk function itself, comply with policies and procedures. She does not manage the risks and reports to a non-executive director. Ms Myer is most likely part of the bank's:

A. Internal audit team.

B. Senior management.

C. Risk management department.

D. Board of directors.

Question ORR-2 c.4

Bank Q39 • MockExam 1 Q17 (rebuilt)

A bank uses the three lines of defense model. Which of the following parties provides independent assurance to stakeholders such as regulators and investors from outside the bank's three internal lines (often informally called a "fourth line")?

A. Business line staff

B. The bank's internal audit function

C. The credit risk management department

D. The independent external auditors

Question ORR-2 c.5 Bank Q38 • AP Mock 2 Q39 (rebuilt)

Prime Bank of India is a large lender to small and medium enterprises. It has established a risk management unit (RMU) to manage risk categories and ensure exposures are authorised and consistent with the bank's risk appetite. Under the reporting framework, the chief risk officer reports to the head of credit, who in turn reports to the board. Which of the following statements is most accurate?

A. The structure is appropriate because credit is the bank's dominant risk, so the RMU should be accountable to the head of credit.

B. Independence is satisfied because the RMU is a separate unit, whatever its reporting line.

C. The RMU lacks independence because it reports through a risk-generating business line; it should have a reporting structure independent of the risk-generating units.

D. Independence would be improved by moving the RMU inside the credit unit so it sits closer to the risk it monitors.

Question ORR-2 c.6 Bank Q43 • BT P2.T7.23.2.2 • BT Mock Q18

The three lines of defense model (3LoD) has existed in some variation for over 30 years, although it achieved more visibility in 2013 when the Institute of Internal Auditors (IIA) published its initial position paper on the 3LoD, which it updated in 2021 (The IIA's Three Lines Model). In regard to the 3LoD model, each of the following is true EXCEPT which is false?

A. The first line defines the organization's risk appetite but should not attempt to directly influence its risk culture.

B. The first line is responsible for implementing and maintaining effective controls to manage material operational risks.

C. The second line is part of management (and owns the ORM methodology) but provides support to the first line in order to help the firm create and protect value.

D. The third line has the clearest boundaries due to its independence.

Question ORR-2 c.7 Bank Q44 • BT P2.T7.800.1 (rebuilt)

Risk manager Beth has drafted a re-design of her bank's operational risk management framework (ORMF) that assigns roles to the three lines of defense: (i) business line management, (ii) an independent corporate operational risk management function (CORF), and (iii) internal audit. Her draft includes the following responsibilities:

I. Business line management identifies and manages the risks inherent in the products, activities, processes, and systems for which it is accountable.

II. The CORF challenges the business lines' inputs to, and outputs from, the bank's operational risk management, measurement, and reporting systems.

III. Internal audit provides independent assurance and, to do so, designs and implements the ORMF.

Beth's draft looks reasonable, but it contains one mistake. Which of the following is a TRUE statement that explains her mistake?

A. Business line management is not a line of defense.

B. The CORF should not challenge the business lines' outputs because doing so creates a self-review threat.

C. Internal audit cannot design or implement the ORMF without compromising the independence of its assurance role.

D. Internal audit should report to the head of the CORF in order to remain independent.

Question ORR-2 c.8 Bank Q49 • AnalystPrep Q.5152 (rebuilt)

A bank applies the three lines of defense model, as used in operational risk management, to its model risk management (MRM) framework. Which of the following statements is correct?

A. Model developers and model owners, as risk owners, form the first line of defense.

B. The second line of defense helps the first line build the models and co-signs their validation so that it can ensure consistency.

C. The second line of defense owns the model risk it oversees.

D. The first line of defense oversees and challenges the activities of the second line of defense.

Question ORR-2 c.9 Bank Q46 • GARP PE1 Q39 • Mock 3 Q41 (rebuilt)

A community bank uses the three lines of defense approach for operational risk and the CRO decides to extend the approach to the bank's enterprise risk management (ERM) framework. Which of the following would be the most appropriate recommendation for allocating responsibilities and authority?

A. The risk management function should approve every transaction that creates a new risk exposure for the bank.

B. Business line managers, as the first line of defense, should have the authority to take on risk exposures within the bank's risk appetite limits.

C. The third line of defense should continuously monitor the implementation of the ERM framework to ensure its effectiveness.

D. As part of the second line of defense, the executive committee should perform an independent review of the risk management framework.

Question ORR-2 c.10 Workbook A22.1 • S1 • Aug-2026 • Map #29

The head of operational risk at a Canadian bank is reviewing a draft responsibilities matrix ahead of a supervisory visit. The bank uses the three lines of defence model, and its IT security, legal and finance departments are hybrid functions. Which of the following entries in the draft is consistent with the three lines of defence model for operational risk governance?

A. A second-line risk manager facilitates each business unit's risk and control self-assessment and gives the final sign-off on its results, as the second line owns the methodology.

B. The payments department's risk champions take over ownership of the department's operational risks, so that the head of payments can concentrate on running the business.

C. After evaluating the corporate operational risk function as effective, internal audit relies exclusively on that function's control testing when auditing the payments department.

D. In IT security, encrypting data and partitioning the network are documented as first-line roles, while verifying ICT controls and enforcing security policies are documented as second-line roles.

Solutions • ORR-2 c

Solution ORR-2 c.1

Answer: B

Bank Q41 • AP Mock 3 Q36

Step 1 – The second line's first duty

"Developing and maintaining operational risk management and measurement policies, standards and guidelines."

⇒ Establishing risk management and measurement methods is second line: B.

Step 2 – Place the other options

Risk decisions belong to the risk owners (line 1). Internal audit is independent and reviews the second line, not the reverse. Reporting independently to a non-executive is internal audit's feature.

Interpretation

"The second line owns the methodology; the first line owns the risks." Each distractor moves a feature of line 1 or line 3 into line 2.

Why the other options are wrong

A is incorrect. Risk-taking decisions are first line; the second line challenges and can veto breaches, but does not decide.

C is incorrect. Direction reversed: internal audit assesses the risk function; the second line does not oversee the third.

D is incorrect. Independent reporting to the board (a non-executive director) is the third line's hallmark.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. • **Reference:** GARP ORR Ch.2, 2.3 d) (Roles and Responsibilities of the Second Line of Defense)

Solution ORR-2 c.2

Answer: D

Bank Q48 • AP Mock 1 Q36

Step 1 – List the risk champions' tasks (line 1.5)

Main correspondent for risk issues; collecting and recording risk events and losses; mapping risks and controls in line with group definitions; following up control rules, action plans and audit tracking.

⇒ A, B and C are copied from this list: first-line tasks.

Step 2 – List the CORF's tasks

Policies and training; an independent view; challenge with evidence; "reviewing and contributing to the monitoring and reporting of the operational risk profile".

⇒ D.

Interpretation

GARP's two lists sit side by side in Section 2.3 d), and the exam lifts items from one to dress them as the other. Hands-on collection and follow-up is line 1.5; review and contribution to reporting is line 2.

Why the other options are wrong

A is incorrect. Collecting and recording events and losses is a risk champion (first-line) task.

B is incorrect. Following up control rules, action plans and audit tracking is a risk champion task.

C is incorrect. Mapping risks and controls to group definitions is a risk champion task; the second line challenges it.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. • **Reference:** GARP ORR Ch.2, 2.3 d) (Risk Champions; Second Line of Defense)

Solution ORR-2 c.3 — Answer: A

Bank Q40 • AP Mock 1 Q63

Step 1 – Read the three clues

She independently assesses compliance with policies across departments "including that of the risk function"; she does not manage the risks; she reports to a non-executive director.

Step 2 – Match them to a line

All three are GARP's description of internal audit: independent of the risk process, assessing every department including risk, reporting "in solid line to a non-executive director".
⇒ Internal audit.

Interpretation

Assessing the risk function itself is the giveaway: only the third line can audit the second.

Why the other options are wrong

B is incorrect. Senior management runs the business and its controls; it is not independent of them.
C is incorrect. The risk function is itself reviewed by internal audit and is part of management.
D is incorrect. The board oversees; it does not test controls hands-on.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. • **Reference:** GARP ORR Ch.2, 2.3 d) (Third Line of Defense)

Solution ORR-2 c.4 — Answer: D

Bank Q39 • MockExam 1 Q17

Step 1 – Place the internal parties

Business staff are line 1; the credit risk department is line 2 oversight; internal audit is line 3. All are inside the bank.

Step 2 – Assurance from outside

GARP: independent assurance goes to external stakeholders "by internal audit for the general system of operational controls and by the external auditors for the organization's financials and the system of controls around financial reporting". External audit "must also remain independent".
⇒ The external auditors.

Interpretation

"Fourth line" is an informal label, not GARP's. External audit sits outside the firm and opines on the financial statements; internal audit covers the operational control system.

Why the other options are wrong

A is incorrect. Business line staff are the first line, inside the bank.
B is incorrect. Internal audit is the third line, inside the bank.
C is incorrect. A risk department is second-line oversight, inside the bank.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. • **Reference:** GARP ORR Ch.2, 2.3 d) (Third Line of Defense)

Solution ORR-2 c.5 — Answer: C

Bank Q38 • AP Mock 2 Q39

Step 1 – Identify the unit's line

The RMU oversees risk categories and checks exposures against appetite: a second-line function, the CORF role.

Step 2 – Test its independence

GARP: in larger banks the CORF "should have a reporting structure independent of the risk-generating business units". Here the CRO reports to the head of credit, a risk-taking business.
⇒ Independence, and with it effective challenge, is compromised: C.

Interpretation

A risk function cannot challenge, let alone veto, the business it reports to. Independence is a property of the reporting line, not of the organisation chart's boxes.

Why the other options are wrong

A is incorrect. Credit being the dominant risk is a reason for more independence from it, not less.
B is incorrect. A separate unit label is not independence; the reporting line decides.
D is incorrect. Moving the RMU into the credit unit removes independence entirely and creates a self-review threat.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. • **Reference:** GARP ORR Ch.2, 2.3 d) (Lines of Defense Delineation)

Solution ORR-2 c.6 — Answer: A

Bank Q43 • BT P2.T7.23.2.2

Step 1 – Check the true statements

B: the first line establishes controls and assesses their design and effectiveness. C: the IIA 2021 model reminds that the second line "is part of and reports to general management" and stresses expertise and support, helping the firm "create and protect value"; it owns the methodology. D: internal audit is "probably the line with the clearest boundaries".

Step 2 – Test A

Risk appetite is set by the board (approved under RPSMOR Principle 4), not defined by the first line; and risk culture is everyone's, the first line included.
⇒ A is false: two misstatements in one.

Interpretation

The first line takes risk *within* the appetite the board has set, and lives the culture the board leads.

Why the other options are wrong

B is incorrect. True statement of first-line responsibility.
C is incorrect. True: the IIA update emphasises the second line's support role inside management.
D is incorrect. True: independence gives internal audit the clearest boundaries.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. • **Reference:** GARP ORR Ch.2, 2.3 d) (The IIA's Three Lines Model) and 2.4

Solution ORR-2 c.7 — Answer: C

Bank Q44 • BT P2.T7.800.1

Step 1 – Check each responsibility

I: risk owners identify and manage the risks they generate. Correct.
II: challenging the first line's inputs and outputs is the CORF's core duty. Correct.
III: designing and implementing the ORMF is the CORF's job; internal audit is "independent of the risk management process".

Step 2 – Name the mistake

If internal audit designed the framework it would then audit its own work: a self-review threat that destroys its assurance.
$\Rightarrow$ C.

Interpretation

The fix for Beth's draft: give framework design to the CORF and keep internal audit on independent assurance over both lines.

Why the other options are wrong

A is incorrect. Business line management is the first line, the risk owners.
B is incorrect. Challenge is exactly the CORF's job; the self-review threat arises when the second line takes part in first-line work, not when it challenges.
D is incorrect. Internal audit reports in solid line to a non-executive director; reporting to the CORF would tie it to a function it must audit.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. • **Reference:** GARP ORR Ch.2, 2.3 d)

Solution ORR-2 c.8 — Answer: A

Bank Q49 • AnalystPrep Q.5152

Step 1 – Translate the lines to model risk

First line: those who generate and manage the risk, the model developers, owners and users. Second line: an independent function that oversees and challenges them (validation). Third line: internal audit over both.

Step 2 – Test each option

Only A puts the risk owners in the first line.
$\Rightarrow$ A.

Interpretation

The model is generic: whatever the risk, ownership sits with whoever generates it, and independence of the second line rules out co-building.

Why the other options are wrong

B is incorrect. Building models and co-signing their validation is involvement in first-line work: a self-review threat.
C is incorrect. The first line, not the second, owns the risk.
D is incorrect. Oversight runs from the second line to the first, not the reverse.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. • **Reference:** GARP ORR Ch.2, 2.3 d)

Solution ORR-2 c.9 — Answer: B

Bank Q46 • GARP PE1 Q39

Step 1 – Line 1 under ERM

"Risk is managed where it is generated": business line managers own their risks and take them, within the limits of the board's risk appetite.
⇒ B.

Step 2 – Check where the others go wrong

Approving every transaction (A) would make the risk function a first-line decision maker. Continuous monitoring (C) is a second-line activity; internal audit gives periodic, independent assurance. The executive committee (D) is management, not an independent reviewer, and independent review is the third line's role.

Interpretation

Extending the model to ERM changes nothing about who does what: ownership and authority to take risk in line 1, oversight and veto in line 2, independent assurance in line 3.

Why the other options are wrong

A is incorrect. Pulls the second line into first-line decisions; it challenges and can veto breaches, it does not approve every deal.
C is incorrect. Moves a second-line monitoring task into the third line.
D is incorrect. Misclassifies the executive committee as second line and as independent.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. • **Reference:** GARP ORR Ch.2, 2.3 d)

Solution ORR-2 c.10 — Answer: D

Workbook A22.1 • S1 • Aug-2026

Step 1 – Who owns the risk

The first line ("business unit management") owns the risks it generates and must give the final sign-off on its risk and control assessment. The second line may run the RCSA workshop, then collect and challenge the answers, while staying independent of the content.
⇒ "The second line owns the methodology; the first line owns the risks." Sign-off is a first-line act.

Step 2 – Where risk champions sit

Risk champions (line 1.5) record events, map risks and controls and follow up action plans inside the business. Firms must ensure ownership of operational risk is not assumed by, or passed to, them.

Step 3 – How far internal audit may rely on others

IIA guidance: internal audit may take account of others' work after evaluating that function, but in no circumstances relies exclusively on risk, compliance or finance; it always examines its own sample.

Step 4 – Hybrid functions

BCBS requires a hybrid function to document and distinguish its first and second line responsibilities, emphasising the independence of the second line. Table 2.4 gives exactly this split for IT security: encrypting data, partitioning and monitoring the network (line 1) versus verifying the implementation of ICT controls in business operations and enforcing security policies (line 2).

Interpretation

D is correct. The matrix entry places each IT security activity in the line its role defines, which is what the supervisor will test: the line is set by the role, not by the department's name. The fix for

the other entries is to return sign-off and ownership to the first line and restore internal audit's own sampling.

Why the other options are wrong

A is incorrect. Role misassignment: the final sign-off on the risk and control assessment belongs to the first line; the second line owns only the methodology and the challenge.

B is incorrect. Sibling swap: substitutes the risk champions (line 1.5) for the risk owners (line 1); ownership must stay with the business managers.

C is incorrect. Absolute claim: a positive evaluation can justify less intense scrutiny, never exclusive reliance; internal audit must always test its own sample.

LO: ORR-2 c: Describe the "three lines of defense" model for operational risk governance and compare roles and responsibilities for each line of defense. CR-2 a: Define risk management responsibilities in an organization and explain the three lines of defense framework for effective risk management and control. • **Reference:** GARP ORR Ch.2, 2.3 d) and Table 2.4; Bouteille and Coogan-Pushner Ch.2

ORR-2 • Risk Governance • Vardeez: UNTIERED (crash-course notes)

ORR-2 d

P1 CONCEPT

Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture.

Workbook: A22 Three Lines of Defence and Operational Risk Governance • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic (A22): your August 2026 recall lists "Three lines of defence, 2Q" for the section (map #29, 4 of 16 sources); shape S3 asks who owns risk appetite and limits.
Vardeez: his crash-course notes for this LO (his "LO 41.d", consolidated volume p.37) set two short lists side by side, regulatory expectations against best practices for risk appetite (his Figure 41.4: "regulatory expectations set the floor; best practice goes beyond it"), and four points on risk culture: it reduces operational risk; ethical leadership and a code of conduct; compensation and training; accountability, openness and whistleblowing.

Reported exam shapes

- **S3** Committees versus the board, and who owns risk appetite and limits.

What the questions look like: a list of candidate features or contents of an appetite statement (which one does not belong); an owner to name (risk, controls or metrics owner); a new product to govern within appetite; or a culture scenario (publicised dismissals, blame, escalation, training exemptions).

See also: workbook A22.2, the S3 question itself (the board owns the limits and delegates their oversight to the board risk committee), is worked under ORR-2 b, Question ORR-2 b.7.

1. Risk appetite: what regulators expect

"The Board is responsible for determining the nature and extent of the significant risks it is willing to take in achieving its strategic objectives" (Walker report, 2009). Defining appetite means assessing the key risks, setting the boundaries between acceptable and unacceptable incidents, and creating the controls those limits require. Done thoroughly, it can expose "painful truths": gaps between what the firm says and what really happens. Many firms struggle with it, especially for non-financial risks. Consistently defined appetite and tolerance **drive the priorities of the whole control environment**.

BCBS Principle 4 (RPSMOR): the risk appetite and tolerance statement for operational risk is **approved and periodically reviewed by the board**. The statements must:

- be **easy to communicate and understand**;
- **justify** the reasons for taking, limiting or avoiding certain types of operational risk;
- be **aligned with strategy** and business plans;
- be **monitored through indicators** on risk exposure, the control environment and loss events;
- be **forward-looking**, subject to scenario and stress testing, with a view of what events could push the bank outside its limits.

Consistent with operations. A firm claiming "minimal tolerance for data breaches" must corroborate it with strong controls and monitoring, to show the board and the regulator that the risk really is minimal.
Who owns the limits. "It is the role of the board of directors to ultimately own the risk limits and to validate them periodically. In practice, the board often delegates this responsibility to the board

risk committee, which in turn requests the support of the risk function" to implement the limits in controls and exposures, and to report on them.
Appetite and tolerance. In the BCBS wording used by bank questions, the appetite statement is the high-level, forward-looking view of risk acceptance; the tolerance statement is the more specific level of variation accepted around business objectives.

2. Risk appetite: best practice

Motivations and trade-offs. Appetite "should articulate the motivations for taking or avoiding certain types of risk" (BCBS): taking risk is needed to reach objectives, and avoiding risk has a cost too.
Actionable structure (GARP Figure 2.7). A well-articulated appetite is aligned to strategic objectives and guides business decisions through three kinds of boundary, each monitored by metrics that BCBS calls "boundaries or indicators" and banks report as **appetite KRIs**:

- **exposure limits** at business level; **key controls** (minimum requirements); **tolerated incidents** (thresholds on frequency and severity).

Unit of expression. Usually per main risk type. Process-based firms (payment processors, clearing houses) may organise appetite, limits and controls around their key processes. Operational resilience rules require **maximum impact tolerances on critical business services**: a form of appetite for disruption risk.
Evidence. Document the key controls behind each main risk type; compare incidents and near misses with the tolerated limits to see whether the controls keep losses inside appetite. Other expressions of appetite: the risk scales of assessment heatmaps and the thresholds on KRIs.
Governance (GARP Figure 2.8): a **risk owner** for each risk type in the appetite structure (managing, maintaining and monitoring the risk within the stated limits: the first line); **controls owners** (design, implementation and effectiveness of the controls); **metrics owners** (collection, reporting and monitoring of the metrics).

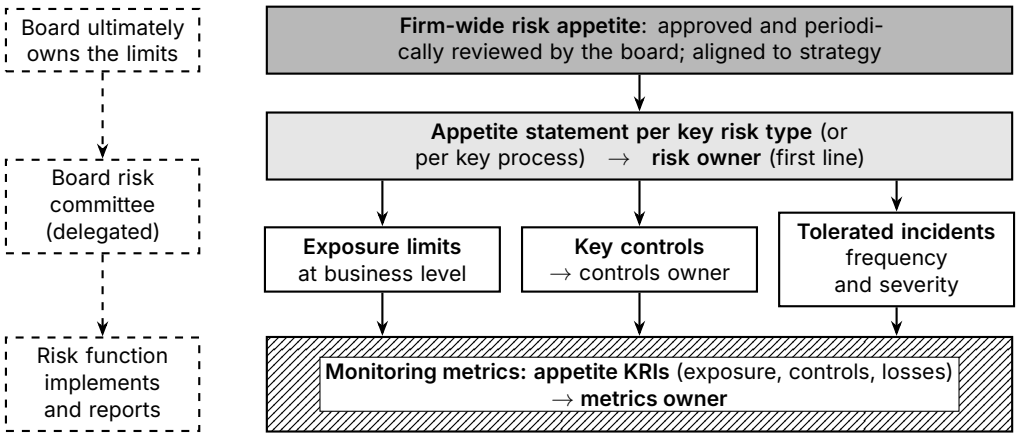


Figure 1. Actionable risk appetite and its owners (GARP Figures 2.7 and 2.8 combined). The appetite cascades from the board-approved statement (darkest) through each key risk to three kinds of boundary, all tracked by appetite KRIs (hatched band). The dashed chain on the left is who owns the limits: the board, in practice through the board risk committee and the risk function.

A stylised example (GARP Box 2.1, conduct risk in sales). Statement: minimal tolerance for breaches of conduct in the sales process, with controls and rewards designed so that a systematic breach is extremely unlikely; isolated, unintentional mis-selling is accepted if it is corrected swiftly and customers are fully compensated. KRIs and targets: share of the sales force involved in conduct breaches at most 0.2%; complaints answered within 24 hours, 95%; complaints resolved within five working days, 98%.

3. Risk culture

Why regulators care. Culture is in the first RPSMOR principle: "banks with a strong culture of risk management and ethical business practices are less likely to experience damaging operational risk events and are better placed to effectively deal with those events that occur". Regulators tie culture to conduct and ethics: the board establishes a **code of conduct or ethics policy** that applies to *both staff and board members*, is regularly reviewed and approved by the board, and is *attested by employees*. The board and senior management promote ethical behaviour that "convincingly reinforces" codes, compensation strategies and training.

Deploying a risk culture programme

- **Tone at the top:** the board leads the culture and senior management implements it, by their own conduct and by setting expectations and consequences for staff. It is documented in policies and codes that apply to everyone.
- **Skin in the game:** risk-takers bear the consequences of their actions, losses as well as benefits (the pilot sits in the plane he flies).
- **Training:** induction for new hires, online modules for all, specialised training for the risk function; many regulators require formal, regular risk training for senior managers and the board.
- **Reinforcement without unnecessary blame:** rules are taken seriously, but blaming the person who reports, or caused, an incident suppresses escalation. "No-blame culture" and "tone from the top" are the two most common recommendations; the UK military's refinement is *no unnecessary blame*, since repeated errors and carelessness must still be sanctioned.
- **Speak up:** "If you see something, say something". Staff must not fear retaliation; whistleblowing remains one of the most effective controls against misconduct and fraud. The UK regulator requires firms to be "open and honest"; hiding incidents is sanctioned.

Toxic culture is triggered by overambitious growth and profit targets, undue pressure on staff and resistance to bad news (Wells Fargo, sanctioned for massive mis-selling). **Signs of a healthy culture** (Box 2.2): the same rules for everyone ("if you do the crime, you do the time"), swift escalation ("raise your hand; do your best"), and shared lessons. **The most telling sign: talking about internal incidents without undue blame or embarrassment, for collective learning.**

	Regulatory expectation (the floor)	Best practice (beyond it)
Approval	Board approves and periodically reviews the appetite and tolerance statement (Principle 4)	Board owns the limits; board risk committee oversees; risk function implements and reports
Content	Easy to understand; reasons for taking, limiting or avoiding risk; aligned with strategy	Explicit risk-return trade-off; exposure limits, key controls, tolerated incidents
Monitoring	Indicators on exposure, controls and losses; forward-looking; stress and scenario tested	Appetite KRIs with thresholds; incidents and near misses compared with limits
Credibility	Consistent with how the firm actually operates	Documented key controls per main risk type; impact tolerances for critical services
Governance	Board accountable	Risk owner, controls owner and metrics owner for each risk type
Culture	Code of conduct for staff and board, approved by the board, attested by staff	Tone at the top, skin in the game, training, no unnecessary blame, whistleblowing

Exam traps

- **Retrospective appetite.** Appetite is forward-looking and stress and scenario tested, not a review of past losses.
- **Expected losses in the statement.** The contents are exposure limits, key controls and tolerated incidents, with KRIs.
- **Words without controls.** "Minimal tolerance for data breaches" is not credible on its own.
- **Owner swaps.** The risk owner manages the risk within limits (first line); controls owners run controls; metrics owners run metrics; internal audit owns nothing.
- **Who approves.** The board approves the statement; senior management does not, and the board does not approve every control.
- **Appetite and tolerance reversed.** Appetite is the broad statement; tolerance is the more specific one.
- **Frozen appetite.** It is reviewed and responds to changing conditions.
- **Culture cannot be managed.** It is led, documented, trained and reinforced.
- **Blame as discipline.** Blaming reporters suppresses escalation; "no *unnecessary* blame" still sanctions repeated carelessness.

Practice questions: ORR-2 d

Question ORR-2 d.1

Bank Q56 • Schweser Module Quiz 43.2 Q2

Which of the following items is least likely to appear in a bank's risk appetite statement?

A. Key controls.

B. Exposure limits.

C. Expected losses.

D. Tolerated incidents.

Question ORR-2 d.2

Bank Q52 • AnalystPrep Q.5061

According to the 4th principle of operational risk management, the board must identify the types and levels of operational risks the bank is willing to assume, as well as approve risk appetite and risk tolerance statements. Which of the following is not a correct feature of these statements?

A. Be easy to communicate and understand

B. Provide reasons for taking or avoiding certain operational risks

C. Be forward-looking and subject to scenario and stress testing

D. Perform scenario analysis retrospectively

Question ORR-2 d.3

Bank Q55 • Mock 2 Q79 (rebuilt)

In a bank's risk appetite governance structure, a business line head is responsible for managing, maintaining and monitoring a risk within the stated limits of appetite and tolerance, and forms part of the first line of defense. This person is best described as which of the following?

A. Risk owner

B. Controls owner

C. Metrics owner

D. Internal audit

Question ORR-2 d.4

Bank Q53 • BT P2.T7.23.2.3

Steven is a new employee at a large publicly-traded financial services firm. He is learning about the firm's approach to operational risk, which is codified in an operational risk management framework. Before arriving, he had a rather straightforward view that risk is the possibility for bad things to happen. However, the firm's training material offers a more sophisticated perspective and includes specific vocabulary terms, including risk culture, risk appetite, risk tolerance, risk controls, and risk owners. In regard to these risk concepts (culture, appetite, tolerance, controls, and owners), which of the following statements is TRUE?

A. Risk tolerance is a broader, more general concept than risk appetite which is more specific.

B. An organization's risk appetite should be sufficiently stable that it does not respond to external events or changes in market conditions.

C. Because a firm's risk culture is intangible, subjective, and difficult to discern, it cannot be managed directly.

D. It is effective, good practice to cascade down the firm-wide risk appetite into controls, limits, and monitoring metrics via risk, control, and metrics owners.

Question ORR-2 d.5

Bank Q54 • BT P2.T7.24.5.1 (rebuilt)

A bank launches a new real-time peer-to-peer payments feature with significant fraud and data-breach exposure. The CRO wants the feature governed in line with the board-approved operational risk appetite. Which action is most consistent with best practice?

A. Translate the appetite into exposure limits, key controls and monitoring metrics for the feature, and assign a risk owner, a controls owner and a metrics owner.

B. Set a single firm-wide statement of "low tolerance for fraud" and leave the business to decide on controls after launch.

C. Have the board approve each individual control and metric directly, bypassing the risk committee.

D. Hand all monitoring of the feature to internal audit, which then owns the risk.

Question ORR-2 d.6

Bank Q51 • AP Mock 2 Q40 (rebuilt)

A bank is considering publicizing the reasons for employee dismissals to show staff the conduct it expects and to signal discipline. Based on best practice for building a strong risk culture, what is the main danger of this approach if it is applied with unnecessary blame?

A. It may suppress the escalation of issues and incidents because staff fear being blamed for reporting them.

B. It will weaken the board's responsibility for the code of conduct.

C. It removes the need for risk training programs.

D. It makes the code of conduct inapplicable to board members.

Question ORR-2 d.7

New • built from GARP Ch.2

After a culture review, the CRO of a Swiss private bank asks the head of operational risk which of the review's observations is the strongest evidence of a healthy risk culture. Which observation should the head point to?

A. The bank has a board-approved code of conduct, published on the intranet and sent to every new joiner on the first day of employment.

B. Business managers discuss internal incidents openly in team meetings, without undue blame, so that the whole unit learns from them.

C. No operational incidents have been reported by the relationship managers over the past year, a year of record growth in client assets.

D. Senior managers are exempt from the annual risk training, since they already set the tone at the top through their own conduct.

Solutions • ORR-2 d

Solution ORR-2 d.1

Answer: C

Bank Q56 • Schweser Module Quiz 43.2 Q2

Step 1 – Recall the structure of actionable appetite

Exposure limits at business level, minimum requirements on key controls, and thresholds on the frequency and severity of tolerated incidents, all monitored by appetite KRIs (GARP Figure 2.7).

Step 2 – Find the outsider

Expected losses are not one of the three boundaries.
$\Rightarrow$ C.

Interpretation

Appetite is expressed in terms the business can act on and monitor: how much exposure, which controls, how many and how large incidents. An expected-loss figure is an output of measurement, not a boundary.

Why the other options are wrong

A is incorrect. Key controls are a component of the statement.
B is incorrect. Exposure limits at business level are a component.
D is incorrect. Tolerated incidents (frequency and severity thresholds) are a component.

LO: ORR-2 d: Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture. • **Reference:** GARP ORR Ch.2, 2.4 b) and Figure 2.7

Solution ORR-2 d.2

Answer: D

Bank Q52 • AnalystPrep Q.5061

Step 1 – List Principle 4's features

Easy to communicate and understand; justify taking, limiting or avoiding risks; aligned with strategy; monitored through indicators; "forward-looking and subject to scenario and stress testing".

Step 2 – Find the contradiction

A retrospective scenario analysis contradicts the forward-looking requirement.
$\Rightarrow$ D.

Interpretation

The test is whether the bank knows what events *could* push it outside its limits, not whether it can explain those that already did.

Why the other options are wrong

A is incorrect. A required feature.
B is incorrect. A required feature: appetite must articulate the motivations for taking or avoiding risk.
C is incorrect. A required feature.

LO: ORR-2 d: Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture. • **Reference:** GARP ORR Ch.2, 2.4 a)

Solution ORR-2 d.3 — Answer: A

Bank Q55 • Mock 2 Q79

Step 1 – The three owners

Risk owners manage, maintain and monitor the risks within the stated limits of appetite and tolerance, and are the first line. Controls owners design, implement and answer for the effectiveness of controls. Metrics owners collect, report and monitor the metrics.

Step 2 – Match the description

The stem quotes the risk owner's definition.
$\Rightarrow$ A.

Interpretation

A business line head is the natural risk owner; controls and metrics may be owned by others below or beside them.

Why the other options are wrong

B is incorrect. A controls owner answers for specific controls, not for the risk against its limits.
C is incorrect. A metrics owner produces and monitors the KRIs; he does not own the risk.
D is incorrect. Internal audit is the third line and owns no risk.

LO: ORR-2 d: Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture. • **Reference:** GARP ORR Ch.2, 2.4 c) and Figure 2.8

Solution ORR-2 d.4 — Answer: D

Bank Q53 • BT P2.T7.23.2.3

Step 1 – Test the definitions

Appetite is the broad, high-level statement; tolerance is the more specific level of variation (A reverses them). Appetite is forward-looking and periodically reviewed, so it responds to changing conditions (B is false).

Step 2 – Test the culture and governance claims

Culture is actively managed: led by the board, documented, trained, reinforced (C is false). Cascading firm-wide appetite into limits, controls and metrics through risk, controls and metrics owners is GARP's recommended structure (D).
$\Rightarrow$ D.

Interpretation

Each false statement takes a real feature and pushes it to an absolute: "more specific" flipped, "stable" made frozen, "intangible" made unmanageable.

Why the other options are wrong

A is incorrect. Polarity flip: appetite is broader; tolerance is more specific.
B is incorrect. Appetite must be reviewed and forward-looking, not frozen.
C is incorrect. The board establishes and leads the culture; it is managed through codes, compensation, training and reinforcement.

LO: ORR-2 d: Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture. • **Reference:** GARP ORR Ch.2, 2.4 and 2.5

Solution ORR-2 d.5 — Answer: A

Bank Q54 • BT P2.T7.24.5.1

Step 1 – Make the appetite actionable

For a new feature with fraud and data-breach exposure, appetite must become exposure limits, key controls and tolerated-incident thresholds, monitored by KRIs.

Step 2 – Assign owners

A risk owner (first line), controls owners and metrics owners, as in GARP Figure 2.8.
$\Rightarrow$ A.

Interpretation

This is the "minimal tolerance for data breaches" point in practice: a stated tolerance is credible only when controls and monitoring are in place before launch.

Why the other options are wrong

B is incorrect. A bare statement with controls deferred until after launch is not credible.
C is incorrect. The board owns the limits but delegates their oversight to the board risk committee with the risk function's support; it does not approve every control.
D is incorrect. Internal audit is the third line: it gives assurance and owns no risk; monitoring belongs to the metrics owners and the second line.

LO: ORR-2 d: Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture. • **Reference:** GARP ORR Ch.2, 2.4 a) to c)

Solution ORR-2 d.6 — Answer: A

Bank Q51 • AP Mock 2 Q40

Step 1 – Reinforcement is a valid tool

"Reinforcement of adherence to the code of conduct and signaling of discipline are effective ways to influence behaviors", provided rules are taken seriously.

Step 2 – The limit: unnecessary blame

A "no-blame culture" (with "tone from the top") is the most common recommendation; it "refers to the need to avoid suppressing the escalation of issues and incidents by blaming the person reporting it or at the origin of it".
$\Rightarrow$ A.

Interpretation

Visible discipline helps only when it targets misconduct and repeated carelessness ("no unnecessary blame"); if staff fear blame for reporting, incidents stay hidden.

Why the other options are wrong

B is incorrect. The board remains responsible for the code of conduct whatever the communication policy.
C is incorrect. Training is a separate pillar of culture; discipline does not replace it.
D is incorrect. The code applies to staff and board members alike.

LO: ORR-2 d: Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture. • **Reference:** GARP ORR Ch.2, 2.5 b)

Solution ORR-2 d.7 **Answer: B**

New • built from GARP Ch.2

Step 1 – GARP's ranking of signs

Box 2.2: reliable signs are the same rules for everyone, swift escalation and shared lessons; "the most telling sign of risk culture is arguably the capacity to talk about internal incidents without undue blame or embarrassment for collective learning and improvement".
$\Rightarrow$ B.

Step 2 – Read the other observations as evidence

A code that is only published says nothing about whether it is lived, reviewed and attested. Zero reported incidents during record growth points to under-reporting under target pressure, a toxic-culture trigger. Exempting senior managers breaks "same rules for all" and ignores regulators' requirement of formal, regular training for senior managers.

Interpretation

Culture is judged by behaviour, not by documents or by silence: open discussion of incidents is the behaviour that makes escalation and learning work.

Why the other options are wrong

A is incorrect. Scope error: a code of conduct is necessary, but publication alone is not evidence that it is applied to everyone, reviewed and attested.
C is incorrect. Polarity flip: an absence of reported incidents amid record growth is a warning sign (resistance to bad news, target pressure), not a strength.
D is incorrect. Absolute claim: tone at the top does not exempt senior managers from training; the rules must apply to everyone.

LO: ORR-2 d: Explain best practices and regulatory expectations for the development of a risk appetite for operational risk and for a strong risk culture. • **Reference:** GARP ORR Ch.2, 2.5 and Box 2.2

ORR-3 • Risk Identification • Vardeez: UNTIERED (crash-course notes)

ORR-3 d

P1 CONCEPT

Describe and apply the Level 1, 2, and 3 categories in the Basel operational risk taxonomy.

Workbook: A22 Three Lines of Defence and Operational Risk Governance • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic (A22): your August 2026 recall lists "Three lines of defence, 2Q" for the section, and the topic map has it at #29 (4 of 16 sources), with "Ops Risk Level 3 categorisation" reported as a separate recall item: the Basel event-type taxonomy at its third level.

Vardeez: his crash-course notes for this LO (his "LO 42.d", consolidated volume p.122) give the three levels as a stack (Level 1: seven event types; Level 2: 20 subcategories, the level regulated banks report; Level 3: detailed examples, not a regulatory requirement) and a table with one Level 2 category and one Level 3 example for each Level 1 type (his Figure 42.4). ORR-3 is rank 28 of 55 in his ROI ranking.

Reported exam shapes

- **S2** Basel event-type taxonomy, Level 1, Level 2 and the Level 3 examples (workbook A22.3).

What the questions look like: an analyst classifies a list of loss events for the regulatory return, and you pick the one classification that is right, at the level named. The distractors use the wrong sibling (own account or the firm's, internal party or third party, intentional or not, product design or processing, damage or disruption), or name a correct label at the wrong level (a Level 2 category offered as a Level 3 example). All statement questions; nothing to compute.

See also: the seven Level 1 definitions, their examples and their frequency and severity profile (GARP Table 1.1) are in ORR-1 b; this block builds on them. ORR-1 b's own taxonomy questions are worked there.

1. Three levels, two of them regulatory

The official taxonomy of operational risk for banks is the BCBS one (GARP Table 3.1). It was defined in the late 1990s, while the Basel operational risk rules were being prepared, and more than twenty years later it is still the official one: **regulated firms report their operational risk to the regulator using this categorisation**.

- **Level 1, the event-type category:** the highest level, seven types, each with a formal definition (ORR-1 b).
- **Level 2, the categories:** "a detailed version of level 1". Twenty in all: IF 2, EF 2, EPWS 3, CPBP 5, DPA 1, BDSF 1, EDPM 6.
- **Level 3, the activity examples:** examples and illustrations of each Level 2 category.

The Basel Committee recognises only the first two levels as regulatory categories. Level 3 is illustrative: it tells you where an event belongs, it is not a reporting cell. GARP adds a design rule that holds in management practice too: use the *minimum meaningful number of categories* and leave detail to examples, because too much detail "is detrimental to the quality of information, is difficult to review, and can drain effort and resources".

What the taxonomy classifies. Each entry is a risk *event*, an adverse occurrence ("what could go

wrong?"), not a cause or an impact. Manual processing is a cause; a data entry error is the event. A regulatory fine is an impact; the event behind it decides the category.

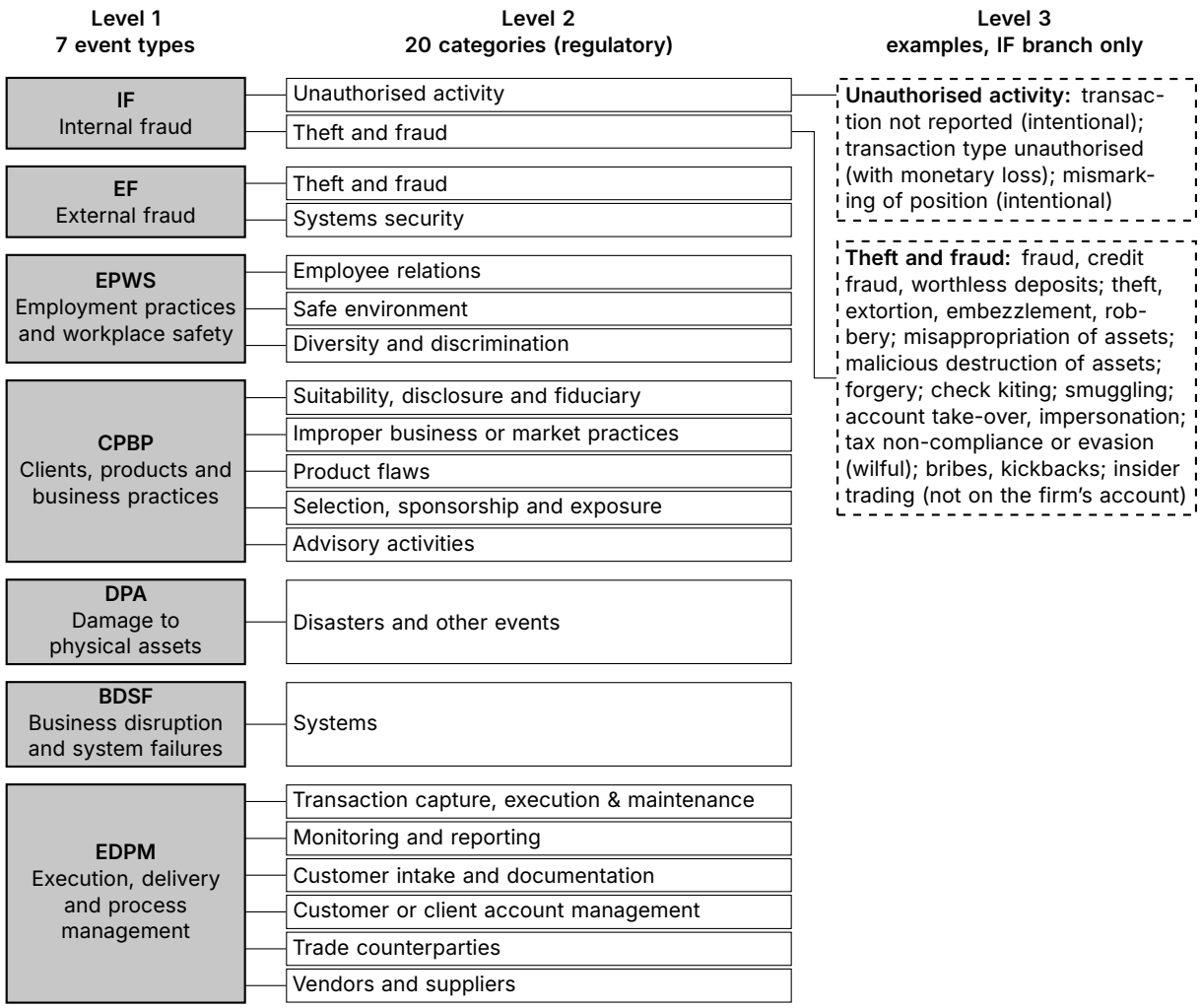


Figure 1. The Basel taxonomy as a tree (GARP Table 3.1). Level 1 event types are the grey boxes on the left; the 20 Level 2 categories, the only other regulatory level, are the solid open boxes; Level 3 examples are in dashed boxes, drawn in full for internal fraud only (Table 1 lists them all). "Theft and fraud" is a Level 2 name under both IF and EF: the internal party decides.

2. The full taxonomy: Level 2 categories and their Level 3 examples

Level 1	Level 2 category	Level 3 activity examples
IF	Unauthorised Activity	Transaction not reported (intentional); transaction type unauthorised (with monetary loss); mismarking of position (intentional)
	Theft and Fraud	Fraud, credit fraud, worthless deposits; theft, extortion, embezzlement, robbery; misappropriation of assets; malicious destruction of assets; forgery; check kiting; smuggling; account take-over, impersonation; tax non-compliance or evasion (wilful); bribes, kickbacks; insider trading (not on the firm's account)
EF	Theft and Fraud	Theft, robbery, forgery, check kiting
	Systems Security	Hacking damage; theft of information (with monetary loss)

Level 1	Level 2 category	Level 3 activity examples
EPWS	Employee Relations	Compensation, benefit, termination issues; organised labour activity
	Safe Environment	General liability (slip and fall, etc.); employee health and safety rules events; workers' compensation
	Diversity and Discrimination	All discrimination types
CPBP	Suitability, Disclosure and Fiduciary	Fiduciary breaches, guideline violations; suitability and disclosure issues (KYC, etc.); retail consumer disclosure violations; breach of privacy; aggressive sales; account churning; misuse of confidential information; lender liability
	Improper Business or Market Practices	Antitrust; improper trade or market practices; market manipulation; insider trading (on the firm's account); unlicensed activity; money laundering
	Product Flaws	Product defects (unauthorised, etc.); model errors
	Selection, Sponsorship and Exposure	Failure to investigate client per guidelines; exceeding client exposure limits
	Advisory Activities	Disputes over performance of advisory activities
DPA	Disasters and Other Events	Natural disaster losses; human losses from external sources (terrorism, vandalism)
BDSF	Systems	Hardware; software; telecommunications; utility outage or disruptions
EDPM	Transaction Capture, Execution and Maintenance	Miscommunication; data entry, maintenance or loading error; missed deadline or responsibility; model or system misoperation; accounting error, entity attribution error; other task misperformance; delivery failure; collateral management failure; reference data maintenance failure
	Monitoring and Reporting	Failed mandatory reporting obligation; inaccurate external report (loss incurred)
	Customer Intake and Documentation	Client permissions or disclaimers missing; legal documents missing or incomplete
	Customer/Client Account Management	Unapproved access given to accounts; incorrect client records (loss incurred); negligent loss or damage of client assets
	Trade Counterparties	Non-client counterparty misperformance; miscellaneous non-client counterparty disputes
	Vendors and Suppliers	Outsourcing; vendor disputes

Table 1. GARP Table 3.1 (source: BIS, Operational Risk Loss Data Collection Exercise, 2002), Levels 2 and 3 in full. The Level 1 definitions are in ORR-1 b.

3. Applying it: the Level 3 qualifier decides

Two events that sound alike often sit in different cells, and the tie-breaker is a qualifier GARP prints in the Level 3 wording. Work in three questions: **who acted, and for whom?** (an insider for himself, a third party, or the firm towards its clients and markets); **what failed?** (a duty to a client or a product's design, a processing step, a system, a physical asset, the employment relationship); **which Level 3 example matches?** The example fixes the Level 2 category, and the Level 2 category fixes the Level 1 type.

The question	One side	The other side
Whose account?	Insider trading *not* on the firm's account: IF / Theft and Fraud	Insider trading *on* the firm's account, market manipulation, money laundering: CPBP / Improper Business or Market Practices
Intentional?	Position mismarked or transaction not reported *intentionally*, unauthorised transaction type: IF / Unauthorised Activity	Data entry error, missed deadline, model or system misoperation: EDPM / Transaction Capture, Execution and Maintenance
Internal party?	Forgery, check kiting, theft, account take-over with at least one insider: IF / Theft and Fraud	The same acts by a customer or outsider alone: EF / Theft and Fraud; hacking: EF / Systems Security
Design or operation?	Model errors, product defects built into a product: CPBP / Product Flaws	A model or system misoperated in processing: EDPM / Transaction Capture, Execution and Maintenance
Damage or disruption?	Natural disaster, terrorism, vandalism: DPA / Disasters and Other Events	Hardware, software, telecoms or utility outage with no damage: BDSF / Systems
Destruction by whom?	Malicious destruction of assets by an insider: IF / Theft and Fraud	Vandalism or terrorism from external sources: DPA
Duty or account servicing?	Account churning, aggressive sales, breach of privacy, misuse of confidential information: CPBP / Suitability, Disclosure and Fiduciary	Incorrect client records, unapproved access to accounts, negligent loss or damage of client assets: EDPM / Customer/Client Account Management
Client selection or paperwork?	Failure to investigate a client per guidelines, exceeding client exposure limits: CPBP / Selection, Sponsorship and Exposure	Client permissions or disclaimers missing, legal documents missing: EDPM / Customer Intake and Documentation
Fine or event?	Failed mandatory reporting obligation, inaccurate external report: EDPM / Monitoring and Reporting, even when a fine follows	Fines for misconduct towards clients or markets: CPBP
Vendor or system?	Outsourcing problems, vendor disputes: EDPM / Vendors and Suppliers, even with an IT provider	A system itself failing: BDSF / Systems
Workplace?	Slip and fall (general liability), workers' compensation: EPWS / Safe Environment	Compensation, benefits, termination, organised labour: EPWS / Employee Relations

4. Beyond the Basel taxonomy

- **Firms tailor it** to the nature, size and location of their business: more compliance risk types in heavily regulated environments (US, UK); more physical and business disruption risk types, *particularly at the secondary level*, in regions exposed to severe weather or sociopolitical instability.

- **It has aged.** Digitalisation (cybercrime), wider outsourcing and supply chains, conduct and financial crime have grown since the late 1990s. The **ORX reference taxonomy (2019)** has 14 Level 1 risk types against Basel's 7, elevating some Level 2 risks: third-party failure, statutory reporting and tax, business continuity, data management, information security (including cyber) and model risk. At GARP's writing ORX did not yet use it to report its loss analysis.
- **Practice varies.** Cyber risk sits in external fraud, IT risk or its own Level 1; third-party risk stands alone, sits in IT, or stays in EDPM as Basel placed it; some firms list control failures or causes as Level 2 "risks". Other taxonomies (ORX causes, impacts, controls) are ORR-3 c.

Corrections to the source notes.

- **Vardeez's Figure 42.4** gives the BDSF subcategory as "Hardware, software, telecommunications, and utility outage". In GARP Table 3.1 BDSF has a single Level 2 category, **Systems**; hardware, software, telecommunications and utility outages are its Level 3 examples (SchweserNotes calls them "failed activity examples"). An option that offers "hardware" or "utility outage" as a Level 2 category is planting exactly this slip.
- **SchweserNotes (Reading 44)** says EDPM and CPBP "have higher frequency and severity of losses" and that EDPM "typically has the highest frequency". On GARP's ORX data (Table 1.1) they are the two most severe types (52% and 27% of losses), but external fraud is the most frequent (30% of events, against 28% for EDPM and 22% for CPBP). See the ORR-1 b correction box.

Exam traps

- **Wrong level.** "Theft and Fraud", "Unauthorised Activity", "Improper Business or Market Practices", "Systems" are Level 2; "insider trading", "check kiting", "hardware", "collateral management failure" are Level 3.
- **All three levels regulatory.** Only Levels 1 and 2 are regulatory categories; Level 3 gives examples.
- **One label, two parents.** Theft and Fraud sits under IF and EF; at least one internal party makes it IF.
- **Insider trading has two homes.** Own account: IF; firm's account: CPBP / Improper Business or Market Practices.
- **Intent splits IF from EDPM.** Intentional mismarking or unreported trades are IF / Unauthorised Activity; honest errors are EDPM.
- **Model errors against misoperation.** A flaw in a product's design is CPBP / Product Flaws; misoperating a model in processing is EDPM.
- **A fine is an impact.** Classify the event behind it: a failed mandatory report is EDPM / Monitoring and Reporting.
- **The word in the stem is not the category.** An "IT provider" dispute is EDPM / Vendors and Suppliers; a "client" harmed by wrong records is EDPM, not CPBP; an injured customer is EPWS.
- **No damage, no DPA**; malicious destruction by an insider is IF, vandalism by outsiders is DPA.

Practice questions: ORR-3 d

Question ORR-3 d.1

Bank Q80 • Schweser Module Quiz 44.2 Q1

Regarding the Basel taxonomy of operational risks for banks and the Level 1 category of internal fraud, which of the following items would most appropriately be included at Level 3?

A. Insider trading.

B. Theft and fraud.

C. Unauthorized activity.

D. Losses due to acts of a type intended to defraud.

Question ORR-3 d.2

Bank Q77 • bank-written, GARP style • re-filed from bank LO 44.c

Omar is the head of operational risk at a bank operating in a region heavily exposed to severe weather events and sociopolitical instability. He is deciding how to design the bank's operational risk taxonomy relative to the Basel taxonomy. Which of the following approaches is most consistent with how organizations tailor operational risk taxonomies?

A. Adopt the Basel Level 1, 2, and 3 categories without change because the regulator treats all three levels as mandatory reporting categories.

B. Include more physical and business disruption risk types in the taxonomy, particularly at the secondary level, to reflect the bank's exposures.

C. Expand the number of secondary-level categories as far as possible so that every specific incident type has its own category.

D. Classify cyber risk as external fraud, because all organizations place cyber risk in that category.

Question ORR-3 d.3

Bank Q78 • AP Mock 1 Q44

A large bank operating in South America has been fined USD 20 million by the regulator for market manipulation and insider trading on the firm's own account. Under which of the Basel Level 1 event-type categories does this action most likely fall?

A. Business Disruption and System Failures.

B. Internal Fraud.

C. Employment Practices and Workplace Safety.

D. Clients, Products and Business Practices.

Question ORR-3 d.4 New • built from GARP Ch.3

The head of operational risk data at a Polish universal bank is reviewing how four loss events have been mapped to Basel Level 2 categories before the quarterly regulatory return is filed. Which of the following mappings is correct?

A. A relationship manager took on a corporate client without the investigation the guidelines require and let its exposure exceed the approved limit: EDPM, Customer Intake and Documentation.

B. The bank was fined after it failed to submit a mandatory regulatory report by the deadline: CPBP, Improper Business or Market Practices.

C. A customer slipped on a wet floor in one of the bank's branches, and the bank paid the personal injury claim: EPWS, Safe Environment.

D. A contractual dispute with the bank's outsourced IT provider over service levels ended in a settlement paid by the bank: BDSF, Systems.

Question ORR-3 d.5 New • built from GARP Ch.3

A trader at a Singapore bank deliberately mismarked an illiquid bond position for three months to conceal losses. The bank's operational risk analyst records the event under Level 1 Internal Fraud, Level 2 Unauthorised Activity. Which of the following events belongs to the same Level 2 category?

A. A customer took over another client's online banking account by impersonation and transferred the funds out.

B. An operations clerk keyed a bond trade at the wrong price, and the error was found only after settlement.

C. A branch teller embezzled cash from customers' dormant accounts over several years.

D. A trader deliberately executed a transaction type outside his mandate, did not report it, and the bank lost money unwinding it.

Question ORR-3 d.6 Bank Q79 • GARP PE1 Q17 • Mock 3 Q63

An operational risk analyst at a large bank is preparing a year-end report of the bank's operational loss events. The analyst uses the Basel operational risk taxonomy to classify different events into Level 1, Level 2, and Level 3. As part of this process, the analyst considers the following four events that occurred during the year:

1. A sales representative in the lending department forged a senior manager's signature to approve an application for a large commercial loan that defaulted.
2. The bank failed to deliver sufficient collateral to support a swap position, which was later terminated at a loss.
3. Several managers in the bank's wealth management group were found to have misused confidential customer information by sharing this information with other employees and a third-party vendor representative.
4. Some personal customer information was stolen in a cyber-attack in which an external hacker broke into a database stored in the cloud.

In classifying the four events and considering the Basel taxonomy in general, which of the following actions would be most appropriate for the analyst to take?

A. The analyst should classify the forged signature under the Level 1 category of Clients, Products, and Business Practices.

B. The analyst should classify the failure to deliver sufficient collateral under the Level 3 category of Improper Business or Market Practices.

C. The analyst should classify the misuse of confidential information under the Level 2 category of Suitability, Disclosure, and Fiduciary.

D. The analyst should classify both the forged signature and the cyber-attack under the same Level 1 event-type category.

Question ORR-3 d.7 Workbook A22.3 • S2 • Map #29

An operational risk analyst at a Brazilian bank is classifying the quarter's loss events for regulatory reporting, which uses the Basel Level 1 and Level 2 categories, with Level 3 activities used as examples. The events are:

- an employee traded shares on inside information for his personal account, and the bank paid a settlement;
- an error in the pricing model embedded in a structured deposit product led to client compensation;
- a customer, acting alone, kited cheques between accounts at the bank and at another bank;
- a utility power outage halted the bank's main data centre for six hours, with no damage to equipment.

Which of the following classifications is correct?

A. The insider trading event: Level 1 Clients, Products and Business Practices; Level 2 Improper Business or Market Practices.

B. The pricing model error: Level 1 Clients, Products and Business Practices; Level 2 Product Flaws.

C. The cheque kiting event: Level 1 Internal Fraud; Level 2 Theft and Fraud.

D. The utility outage: Level 1 Damage to Physical Assets; Level 2 Disasters and Other Events.

Solutions • ORR-3 d

Solution ORR-3 d.1

Answer: A

Bank Q80 • Schweser Module Quiz 44.2 Q1

Step 1 – Read each option's level

D paraphrases the Level 1 definition of internal fraud ("losses due to acts of a type intended to defraud, misappropriate property or circumvent regulations..."). B and C are the two Level 2 categories of internal fraud: Theft and Fraud, and Unauthorised Activity.

Step 2 – Find the activity example

Level 3 lists concrete activities. Under IF / Theft and Fraud, Table 3.1 lists forgery, check kiting, bribes and kickbacks and "insider trading (not on firm's account)".
⇒ Insider trading is the Level 3 item: A.

Interpretation

The three levels answer three different questions: what kind of event (Level 1, with a definition), which category (Level 2, a label), which concrete activity (Level 3). Insider trading appears at Level 3 twice: not on the firm's account under IF, on the firm's account under CPBP.

Why the other options are wrong

B is incorrect. Theft and Fraud is a Level 2 category of internal fraud (and, separately, of external fraud).
C is incorrect. Unauthorised Activity is the other Level 2 category of internal fraud.
D is incorrect. This is the opening of the Level 1 definition, not an activity example.

LO: ORR-3 d: Describe and apply the Level 1, 2, and 3 categories in the Basel operational risk taxonomy. • **Reference:** GARP ORR Ch.3, 3.3 (The Basel Taxonomy) and Table 3.1; SchweserNotes 2026 Book 3, Reading 44, LO 44.d

Solution ORR-3 d.2

Answer: B

Bank Q77 • bank-written, GARP style

Step 1 – What is regulatory in the Basel taxonomy

"The Basel Committee only recognizes the first two levels as regulatory categories. Level 3 provides examples and illustrations." Regulated firms report with Levels 1 and 2; nothing obliges them to run their own management taxonomy at Level 3 detail.

Step 2 – How firms tailor

Taxonomies are made "more specific to their own exposures", depending on "the nature and size of the activities and the location of their business". Firms in regions heavily exposed to weather events or sociopolitical instability "include more physical and business disruption risk types in their taxonomies, particularly at the secondary level".
⇒ B.

Interpretation

Tailoring adds categories where the firm is exposed, but keeps to the minimum meaningful number: detail goes into Level 3 examples, not into an ever longer list of Level 2 cells. Re-filed from ORR-3 c (taxonomies in general) because three of its four options test the status and design of the Basel levels.

Why the other options are wrong

A is incorrect. Only Levels 1 and 2 are regulatory categories; Level 3 is illustrative, and firms commonly tailor their taxonomy.
C is incorrect. Too much detail "is detrimental to the quality of information, is difficult to review,

and can drain effort and resources"; specifics belong in Level 3 examples.
D is incorrect. Absolute claim: cyber risk is placed in external fraud in some firms, in IT risk in others, and as a separate Level 1 risk in others.

LO: ORR-3 d: Describe and apply the Level 1, 2, and 3 categories in the Basel operational risk taxonomy. ORR-3 c: Describe and apply an operational risk taxonomy and give examples of different taxonomies of operational risks. • **Reference:** GARP ORR Ch.3, 3.3 (The Basel Taxonomy; Difference in Risk Description and Taxonomies Across Organizations)

Solution ORR-3 d.3 — Answer: D

Bank Q78 • AP Mock 1 Q44

Step 1 – Place the activities at Level 3

Market manipulation and "insider trading (on firm's account)" are Level 3 examples of the Level 2 category Improper Business or Market Practices.

Step 2 – Go up to Level 1

Improper Business or Market Practices belongs to Clients, Products and Business Practices.
$\Rightarrow$ CPBP: D.

Interpretation

The misconduct was carried out for the firm, in the market, so it is a business-practice failure, not fraud by an insider for personal gain. The USD 20 million fine is the impact and plays no part in the classification; fines of this kind are why CPBP carries 52% of all losses in GARP Table 1.1 (ORR-1 b).

Why the other options are wrong

A is incorrect. BDSF covers hardware, software, telecommunications and utility outages; nothing failed or was disrupted.
B is incorrect. Internal fraud takes insider trading only when it is *not* on the firm's account. This is the planted trap.
C is incorrect. EPWS covers employee relations, safe environment and discrimination; it has nothing to do with trading misconduct.

LO: ORR-3 d: Describe and apply the Level 1, 2, and 3 categories in the Basel operational risk taxonomy. • **Reference:** GARP ORR Ch.3, Table 3.1

Solution ORR-3 d.4 — Answer: C

New • built from GARP Ch.3

Step 1 – Read the Level 3 qualifier in each event

Client not investigated per guidelines and its exposure limit exceeded: "failure to investigate client per guidelines / exceeding client exposure limits". Report not filed: "failed mandatory reporting obligation". Customer injured in a fall: "general liability (slip and fall, etc.)". Dispute with an outsourcer: "outsourcing / vendor disputes".

Step 2 – Read off Level 2 and Level 1

Event	Correct cell	Mapped as
A. client not investigated	CPBP / Selection, Sponsorship and Exposure	EDPM / Customer Intake
B. report not filed	EDPM / Monitoring and Reporting	CPBP / Improper Practices
C. customer fall	EPWS / Safe Environment	EPWS / Safe Environment
D. outsourcer dispute	EDPM / Vendors and Suppliers	BDSF / Systems

⇒ Only C is mapped correctly.

Interpretation

Two wrong mappings follow a word in the stem rather than the event: "fined" pulls towards CPBP and "IT provider" towards BDSF. The fine is an impact; the event behind it is a failed reporting step. EPWS covers "payment of personal injury claims" under general liability, whoever the injured person is.

Why the other options are wrong

A is incorrect. Sibling swap: Customer Intake and Documentation holds missing client permissions, disclaimers and legal documents. Failing to investigate a client and exceeding its exposure limit is CPBP / Selection, Sponsorship and Exposure.

B is incorrect. A failed mandatory reporting obligation is a Level 3 example under EDPM / Monitoring and Reporting; the fine that followed does not move it to CPBP.

D is incorrect. No system failed. A dispute with a vendor or outsourcer is EDPM / Vendors and Suppliers; BDSF / Systems covers hardware, software, telecommunications and utility outages.

LO: ORR-3 d: Describe and apply the Level 1, 2, and 3 categories in the Basel operational risk taxonomy. • **Reference:** GARP ORR Ch.3, Table 3.1

Solution ORR-3 d.5

Answer: D

New • built from GARP Ch.3

Step 1 – What Unauthorised Activity holds

Its Level 3 examples: "transaction not reported (intentional)", "transaction type unauthorized (w/monetary loss)", "mismarking of position (intentional)". The common thread is an insider deliberately acting beyond his authority in the firm's business, rather than taking value for himself.

Step 2 – Place each event

A: a customer acting alone is a third party, so EF / Theft and Fraud. B: an unintentional data entry error, so EDPM / Transaction Capture, Execution and Maintenance. C: embezzlement, so IF / Theft and Fraud. D: an unauthorised transaction type with monetary loss, deliberately not reported, so IF / Unauthorised Activity.

⇒ D shares the mismarking's Level 2 category.

Interpretation

Intent and authority split the cells: a deliberate breach of trading authority is Unauthorised Activity; a deliberate taking of value is Theft and Fraud; an honest mistake is EDPM. GARP counts rogue trading as internal fraud (Ch.1); its Level 3 signatures (mismarked positions, unauthorised and unreported trades) place it in Unauthorised Activity.

Why the other options are wrong

A is incorrect. Wrong Level 1: no internal party is involved, so the event is external fraud (EF / Theft and Fraud).

B is incorrect. Wrong Level 1: there is no intent; a data entry error is EDPM / Transaction Capture, Execution and Maintenance.

C is incorrect. Right Level 1, wrong Level 2: embezzlement is a Level 3 example under IF / Theft and Fraud.

LO: ORR-3 d: Describe and apply the Level 1, 2, and 3 categories in the Basel operational risk taxonomy. • **Reference:** GARP ORR Ch.3, Table 3.1; Ch.1, 1.5 (Characteristics of Operational Risk: heterogeneous)

Solution ORR-3 d.6 — Answer: C

Bank Q79 • GARP PE1 Q17

Step 1 – Classify the four events

Event	Level 1	Level 2	Level 3
1 Forged signature (employee)	IF	Theft and Fraud	Forgery
2 Collateral not delivered	EDPM	Transaction Capture, Execution and Maintenance	Collateral management failure
3 Confidential information misused	CPBP	Suitability, Disclosure and Fiduciary	Misuse of confidential information
4 External hacker	EF	Systems Security	Theft of information

Step 2 – Test each option against the table

Only C names the right category at the right level: Suitability, Disclosure and Fiduciary is the Level 2 parent of "misuse of confidential information".
⇒ C.

Interpretation

GARP tests the level as much as the category: B names a real Level 2 category but calls it Level 3, and on the wrong branch. The forgery and the hack are both frauds, but the perpetrator (an employee against an external hacker) puts them in different Level 1 types.

Why the other options are wrong

A is incorrect. A forgery by an employee is internal fraud (at least one internal party); CPBP covers unintentional or negligent failures towards clients.

B is incorrect. Improper Business or Market Practices is a Level 2 category, not Level 3, and belongs to CPBP; a collateral management failure is a Level 3 example under EDPM / Transaction Capture, Execution and Maintenance.

D is incorrect. The forgery is IF and the hack is EF: different Level 1 categories.

LO: ORR-3 d: Describe and apply the Level 1, 2, and 3 categories in the Basel operational risk taxonomy. • **Reference:** GARP ORR Ch.3, Table 3.1

Solution ORR-3 d.7 — Answer: B

Workbook A22.3 • S2

Step 1 – Insider trading: whose account?

Table 3.1 lists "Insider trading (not on firm's account)" under Internal Fraud / Theft and Fraud, and "Insider trading (on firm's account)" under CPBP / Improper Business or Market Practices. Trading for a personal account is the first.
⇒ The Level 3 qualifier decides the Level 1 category.

Step 2 – Model error in a product

"Model errors" is a Level 3 example under CPBP / Product Flaws (losses from the nature or design of a product). By contrast, "Model/system misoperation" sits under EDPM / Transaction Capture, Execution and Maintenance.
⇒ A flaw built into the product's design is CPBP; a mistake in operating a model during processing would be EDPM.

Step 3 – Cheque kiting: who acted?

Internal fraud requires "at least one internal party"; external fraud is "by a third party". A customer acting alone is a third party, so the event is External Fraud / Theft and Fraud (Level 3:

theft, robbery, forgery, check kiting).

Step 4 – Outage without damage

DPA covers loss or damage to physical assets from natural disaster or other events. A utility outage without damage is BDSF / Systems (Level 3: utility outage/disruptions).

Interpretation

B is correct. Only Levels 1 and 2 are regulatory categories, so each event must land in the right Level 1 and Level 2 cell; the Level 3 examples (on or off the firm's account, model error vs misoperation, internal vs third party, damage vs disruption) are the tie-breakers GARP uses.

Why the other options are wrong

A is incorrect. Sibling swap: uses the "on firm's account" entry; insider trading for a personal account is Internal Fraud / Theft and Fraud.

C is incorrect. Role misassignment: assigns the act to an internal party; a customer acting alone makes it External Fraud / Theft and Fraud.

D is incorrect. Scope/condition error: DPA needs loss or damage to physical assets; a disruption with no damage is Business Disruption and System Failures / Systems.

LO: ORR-3 d: Describe and apply the Level 1, 2, and 3 categories in the Basel operational risk taxonomy. ORR-1 b: Describe the seven Basel II event risk categories and identify examples of operational risk events in each category. • **Reference:** GARP ORR Ch.3, Section 3.3 and Table 3.1; Ch.1, Table 1.1

ORR-4 • Risk Measurement and Assessment • Vardeez: UNTIERED (crash-course notes)

ORR-4 f

P1 CONCEPT

Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations.

Workbook: A10 Altman Z-Score and Linear Discriminant Analysis • Tier A • August 2026 recall A17 Extreme Value Theory: GEV vs POT • Tier A • August 2026 recall D19 LDA for Operational Risk • Tier D

WHAT IS TESTED HERE

Why P1. Tier A workbook topic. Your August 2026 recall lists a "GEV theory question" (A17, map #25, 5 of 16 sources), and the map flags "the operational-risk framing of EVT vs. block maxima" as examinable. Map #74 (D19, Tier D) reports "LDA approach" and "calculate z score (LDA)", an ambiguous recall that the workbook splits between the two LDAs (A10 and D19).
Vardeez: his crash-course notes label this LO "LO 43.f" (consolidated volume pp.137 and 138). They stress the loss distribution approach (frequency and severity combined by Monte Carlo) with its two strengths and four weaknesses, the two EVT methods and their limitations, internal versus external data, and capital modelling after the standardized approach (ICAAP scenario analysis). "LDA Approach" and "EVT & Block Maxima (Comparison)" are themes 5 and 6 of his ORR list. ORR-4 is ROI rank 32 of 55 ("quick win").

Reported exam shapes

- **A10·S5** The two LDAs: linear discriminant analysis (credit scoring) versus the loss distribution approach (operational capital).
- **A17·S6** The operational-risk framing of EVT: block maxima versus peaks over threshold, and the single-mechanism caution.
- **D19·S1** Loss frequency × severity convolution into an aggregated annual loss distribution.
- **D19·S2** Operational risk capital as the 99.9th percentile of the aggregated distribution, with aggregation across units of measure.

What the questions look like: "which statement is correct" items on the steps, assumptions and limitations of the LDA, on how internal and external data are mixed, and on what EVT adds in the tail. One workbook question (D19.1) asks you to read the 99.9th percentile off a small convolution: it carries figures and stays in as a workbook question (TYPE rule exception). No other question here needs a calculation.

See also: workbook A10.2 (linear discriminant analysis with numbers) belongs to the credit risk workbook (CR-9 b). Fault trees and factor models are ORR-4 d and e (P4); SMA versus AMA is ORR-24 b; regulatory versus economic capital is ORR-7 b. Section 1 below is the shared background for the whole of ORR-4: ORR-4 a, b and c (P3 part) point back to it.

1. ORR-4 at a glance (background for the whole reading)

The reading moves from qualitative to quantitative tools. Its first part follows the ORM framework that ING drew in 2000 as four concentric circles (GARP Figure 4.1): the **loss database** at the centre feeds the **RCSAs**, which feed the **KRIs**, with **lessons learned** from large incidents in the outer circle. Then come factor models, stochastic capital models (this LO) and the quantification of resilience (ORR-4 g). Operational loss data are hard to model because they are firm-specific and mostly unrelated to markets, have very wide tails, are scarce, can stay hidden for a long time, and are complex to interpret. Every limitation in Sections 3 and 4 traces back to these features.

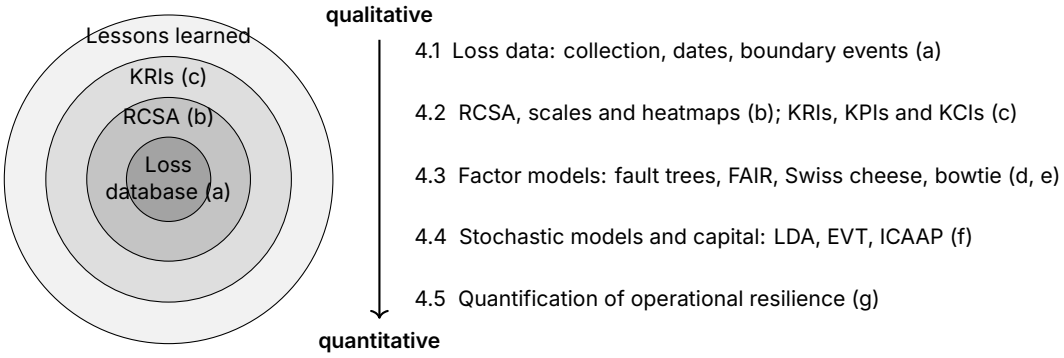


Figure 1. Left: ING's four concentric circles (GARP Figure 4.1 redrawn), darker towards the centre. Right: the sections of the reading, from qualitative (top) to quantitative (bottom), with the LO letter that tests each.

2. The loss distribution approach (shapes D19·S1, S2)

The capital models of the reading are **stochastic**: fit distributions to the *frequency* and the *severity* of past losses (internal and external), simulate the firm's loss distribution, and set **economic capital at its 99.9th percentile**. The **LDA** is the most widespread technique, used essentially by Tier-1 banks and insurers, and is complemented by EVT or scenario data in the tail. It is an old actuarial technique; splitting each loss into frequency and severity *doubles* the observations available, which mattered when operational data were scarce (Frachot, Georges and Roncalli, Crédit Lyonnais, 2001).

	Frequency	Severity
Nature	Discrete: events per period, typically one year	Continuous, asymmetric, heavy-tailed: many small losses, a few very large ones
Usual choice	Poisson (9 of 10 AMA firms, BIS 2009); negative binomial otherwise	Lognormal; increasingly Weibull and generalized Pareto (GPD)
Key facts	One parameter $\lambda = E[N] = \mathrm{Var}[N]$; additive: $\mathrm{Pois}(\lambda_X) + \mathrm{Pois}(\lambda_Y) = \mathrm{Pois}(\lambda_X + \lambda_Y)$	$\ln X$ normal; positive values only; mode $\mathrm{e}^{\mu-\sigma^2}$

Convolution. The two distributions are estimated *independently*, then convoluted into an aggregated loss distribution, usually by **Monte Carlo** (a million or more draws); fast Fourier transform and Panjer recursion are equation-based alternatives (more mathematics, less computer time).

$$S = \sum_{i=1}^{N} X_i, \qquad P(N=k) = \frac{\lambda^k \mathrm{e}^{-\lambda}}{k!}, \qquad \boxed{\text{stand-alone capital} = q_{99.9\%}(S),\ \text{one year}}$$

GARP equates capital with the percentile itself; EL is not subtracted. Outside the reading, $E[S] = \lambda\, E[X]$ is a useful check (D19.1).

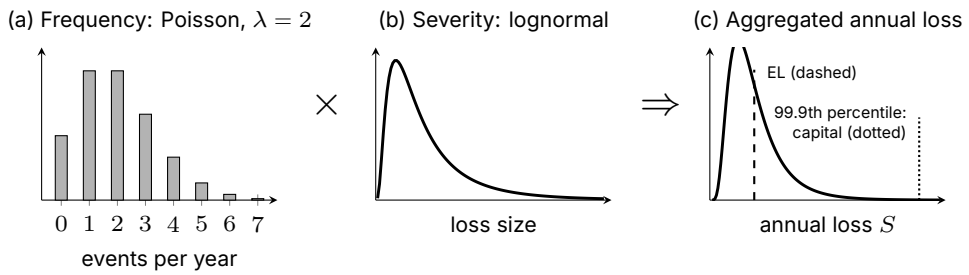


Figure 2. The LDA for one unit of measure (schematic): a discrete frequency (bars) and a right-skewed severity (solid curve), fitted independently, are convoluted into the annual loss distribution. Dashed line: expected loss; dotted line: 99.9th percentile, the stand-alone capital.

Units of measure (UoMs) and aggregation. The LDA runs on each UoM, a homogeneous set of events driven by the same factors (external fraud by business line; damage to physical assets for all lines; internal fraud per business entity; processing errors by business line). Finer UoMs are more homogeneous but hold *less data*: more uncertainty and a harder aggregation. UoMs are aggregated with explicit correlations or **copulas**, which can capture tail dependence. Adding stand-alone percentiles assumes perfect dependence. The dependency structure drives the capital result, so validators and regulators focus on it.

3. Limitations of the LDA

1. **Frequency and severity assumed independent**: a strong condition, given the contrast between the frequency of small and of large events.
2. **Losses i.i.d. within each UoM** (no implicit correlation, one generating mechanism): "a very strong hypothesis" for heterogeneous operational events; tested by clustering homogeneous losses and checking for no autocorrelation.
3. **Homogeneity costs data**: heterogeneous events are hard to cluster into homogeneous UoMs.
4. **The tail**: LDA models "are not quite sufficient to account for the extreme skewness"; complete the data with large external losses, EVT, scenario data, or all of these.

Vardeez adds the practical weakness (heavy reliance on data quality and quantity) and two strengths: internal data are probably the most relevant to the bank, and the LDA gives a comprehensive view of potential losses.

> **Correction to the source notes.** SchweserNotes (LO 45.f) writes that the no-correlation (i.i.d.) assumption within a risk class "is consistent with the heterogeneous nature of operational risk incidents". GARP says the opposite: given that heterogeneity, it "is a very strong hypothesis". Treat it as a limitation.

4. Extreme value theory for the tail (shape A17·S6)

Block maxima (Fisher-Tippett) models "the maxima equally spaced in time", for example the largest loss per quarter and per UoM (the GEV of MR-3). **Peaks over threshold (POT)** models the losses above a high threshold u; for u high enough, the excess over u converges to the generalized Pareto distribution (Balkema and de Haan; Pickands).

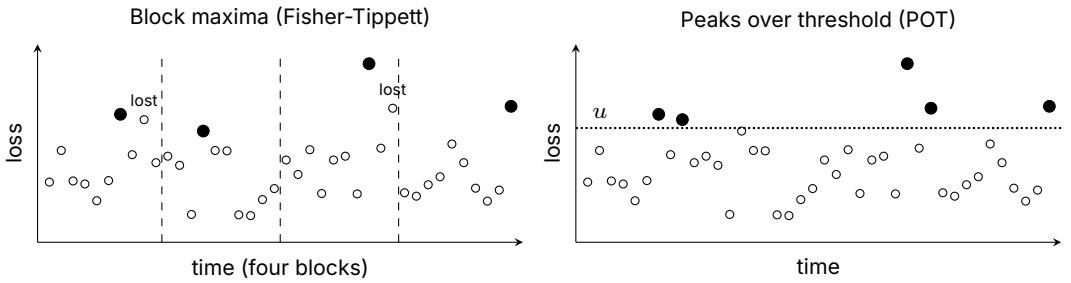


Figure 3. GARP Figure 4.11 redrawn with the same 40 losses in both panels. Left: one maximum per block (filled dots; blocks split by dashed lines); two large losses are lost because they share a block with a larger one, while a modest maximum (second block) is kept. Right: all five losses above the dotted threshold u are used, at the cost of choosing u.

EVT: a word of caution. EVT's asymptotic results hold only under regularity conditions. For losses from different institutions, business lines and risk types it would be valid only "if a single mechanism is responsible for all observed losses" and can produce larger future losses. This is unlikely, which "raises concerns about the applicability of EVT in operational risk". Alternatives: scenarios, causal modelling, fixed multipliers, macro determinants. From MR-3: block maxima fits the three-parameter GEV and needs no threshold but wastes data in crowded blocks; POT fits the two-parameter GP and keeps every tail loss but the threshold is a judgment call; $\xi > 0$ (Fréchet) means heavy tails.

5. Data, and capital after the AMA

Internal data are the backbone of the LDA and best for the *body* (frequent, moderate losses): more relevant and more detailed. **External data** fill the tail: public databases (full context, scarcer) or consortia (ORX: 103 members, 800,000 events in 2022; anonymous, little detail per event). Mixing them takes three choices: **scaling** (adjust for size or inflation), **cut-off mix** (the severity level above which external data enter) and **filtering** (inclusion and exclusion rules that rule out cherry picking). Near misses, accidental gains and rapidly recovered losses need explicit rules: the most conservative firms count them in frequency *and* severity.

From AMA to ICAAP. The AMA set capital for all operational losses up to 99.9% at one year, from four inputs: internal and external loss data (the past), scenario data and business environment and internal control factors (BEICF, the prospective view). Since the standardized approach (1 January 2023) there is no formal requirement to model operational risk capital; the effort moves to **Pillar 2 (ICAAP)**, stress testing and resilience, often with hybrid models (LDA body, scenario tail). The ICAAP is a regulator-mandated self-assessment covering *all* risks. Smaller firms aggregate scenarios simply: capital at least equal to the *largest* scenario and to a *cluster* of two to four scenarios that could occur together (a pandemic, a key employee departure and a cyberattack); Tier-1 firms use variance-covariance matrices or copulas, and the report must justify the scenarios discarded. Economic capital is what the firm itself judges necessary to survive or keep its rating: "to a large extent, economic capital and ICAAP have the same purpose".

Approach	How capital is set	Application	Main limitation
LDA	99.9th percentile of convolved frequency and severity per UoM; UoMs joined by correlations or copulas	Body of the distribution; core of former AMA models	Independence and i.i.d. assumptions; UoM trade-off; weak tail
EVT (block maxima, POT)	GEV on maxima per period, or GP on excesses over u	Completes the tail	Single-mechanism condition; few large losses; data waste or a judgmental threshold
Scenario aggregation	At least the largest scenario and clusters of two to four; or variance-covariance and copulas	ICAAP (Pillar 2), forward-looking	Judgment and repeatability; discarded scenarios must be justified
Hybrid	LDA body plus scenario or EVT tail	Tier-1 banks' Pillar 2	Complexity; dependency structure drives the result

The other LDA (shape A10·S5). *Linear discriminant analysis* (Altman's Z-score, CR-9 b) puts fixed weights on five accounting ratios and uses cut-off values to assign a borrower to a group: a credit scoring tool. The *loss distribution approach* convolves frequency and severity and gives a capital figure. Same acronym, different fields: read the stem.

Exam traps

- **Acronym swap.** "LDA" in a credit-scoring stem is discriminant analysis; in an operational capital stem it is the loss distribution approach.
- **Correlation reversed.** Losses are i.i.d. *within* a UoM; dependence is modelled *across* UoMs. Both independence assumptions are limitations, not facts.
- **Adding stand-alone percentiles** assumes perfect dependence and overstates capital for independent UoMs.
- **Wrong capital definition.** The 99.9th percentile at one year, not the 99th, and EL is not subtracted.
- **EVT as a cure-all.** It needs one mechanism behind all losses.
- **Mixing methods swapped.** Size or inflation: scaling; entry threshold for external data: cut-off mix; inclusion rules: filtering.
- **Modelling still mandatory.** Since 2023 the SA needs no model; modelling lives in the ICAAP, which covers all risks.

Practice questions: ORR-4 f

Question ORR-4 f.1

Bank Q111 • AnalystPrep Q.5108 (rebuilt)

A bank's operational risk manager asks an analyst to build a model that fits separate frequency and severity distributions for each unit of measure and then convolutes them into an aggregated annual loss distribution, whose 99.9th percentile gives stand-alone capital. Which approach is the analyst applying?

A. Reverse stress testing

B. Loss distribution approach

C. Fixed multiplier approach

D. Scenario aggregation using variance-covariance matrices

Question ORR-4 f.2

New • built from GARP Ch.4 (4.4) and workbook A10, D19

The chief risk officer of a German bank receives two model documents, both titled "LDA model". Document 1 combines five accounting ratios with fixed weights into a single score and uses cut-off values of the score to assign each corporate borrower to a credit-quality group. Document 2 fits a frequency and a severity distribution to each unit of measure of operational losses and combines them into an annual loss distribution. Which of the following statements is correct?

A. Both documents apply the loss distribution approach; document 1 is its severity step, which scores how large each loss is likely to be.

B. Document 1 applies linear discriminant analysis, a scoring tool; document 2 applies the loss distribution approach, whose 99.9th percentile sets stand-alone capital.

C. Document 1 applies the loss distribution approach to credit risk, and document 2 applies linear discriminant analysis to operational losses.

D. Document 2 needs no external data or scenarios, because splitting each loss into frequency and severity doubles the observations available for the tail.

Question ORR-4 f.3 Bank Q108 • BT P2.T7.23.5.2

In order to determine his firm's internal operational risk capital requirements, Robert is employing the loss distribution approach (LDA). He will take the following steps: collect and clean data; categorize data according to well-defined risk classes (aka, units of measure, UoM); estimate (aka, fit) the frequency distributions; fit the severity distributions; calculate expected loss (EL) and unexpected loss (UL) for each risk class; and aggregate. In regard to this LDA, each of the following statements is true EXCEPT which is false?

A. Monte Carlo simulation convolutes frequency and severity distributions into an aggregated loss distribution.

B. In practice, LDA frequency distributions tend to be either Poisson or negative binomial; severity distributions tend to be lognormal, Weibull, or Generalized Pareto Distribution (GPD).

C. Within each unit of measure (UoM; aka, risk class), losses should be correlated and heterogeneous; however, the many UoMs should be aggregated according to an independent and identically distributed (i.i.d.) assumption.

D. Because the history of internal loss data is insufficient for the task of describing tails, the dataset likely needs to be completed with extreme value theory's (EVT's) tail distributions and/or external data must be added to the mix, where key methodological decisions include scaling, cut-off mix, and filtering.

Question ORR-4 f.4 Bank Q110 • Schweser Module Quiz 45.3 Q1

A quantitative analyst is combining internal and external loss data for model calibration. The analyst has established specific criteria for the inclusion and exclusion of losses in the dataset. The method used by the analyst is best described as:

A. cut-off mix.

B. filtering.

C. scaling.

D. rule based.

Question ORR-4 f.5 Bank Q112 • BT notes P2.T7.2.4 (rebuilt)

Which of the following statements about the limitations of approaches used to determine operational risk capital is INCORRECT?

A. The LDA assumes frequency and severity are independent, which is questionable because empirical evidence shows many low-severity events and few high-severity events.

B. Segmenting losses into homogeneous units of measure reduces the data available in each UoM, making results less reliable.

C. LDA cannot properly handle the very high skewness of operational losses without adding large losses, applying EVT, or using scenario analysis.

D. EVT is well suited to operational risk because losses typically arise from one main underlying cause that will generate larger future losses.

Question ORR-4 f.6 Workbook A17.1 • S1, S2, S5, S6 • Aug-2026 • Map #25

The head of operational risk modelling at a European insurer is presenting to newly hired analysts on how extreme value theory can complement the loss distribution approach in the tail of the severity distribution. She compares the block maxima (GEV) approach, applied to the largest loss per quarter in each unit of measure, with the peaks-over-threshold approach. Which of the following statements should she include in the presentation?

A. The block maxima approach fits a two-parameter generalised Pareto distribution to the largest loss in each quarter, so it needs fewer parameters than the peaks-over-threshold approach.

B. The block maxima approach needs no threshold choice, but it can waste useful data because a quarter may contain more than one extreme loss; the peaks-over-threshold approach models all losses above a high threshold.

C. A positive tail index places the fitted GEV in the Weibull case with lighter than normal tails, so a positive estimate signals that extreme losses are less likely than under a normal parent.

D. Because both approaches rest on extreme-value theorems, they remain valid for losses pooled across business lines and risk types, whatever mechanism produced each loss.

Question ORR-4 f.7 Bank Q109 • BT P2.T7.24.4.2

In the aftermath of a cyber-attack that cost FX Banco $500 million in losses, the bank is developing a model to calculate operational risk capital for economic capital purposes. The bank has comprehensive internal data on frequent operational losses, such as minor process failures, but it is also concerned with accurately modeling rare, extreme events like major fraud or cyber-attacks. The bank wants to use a method that allows it to address infrequent but large, catastrophic losses in a balanced way. Which of the following approaches should FX Banco choose?

A. A method that estimates operational risk capital based on a percentage of the bank's gross income. While easy to implement, it does not account for specific loss events or their severity.

B. A method that separately models the frequency and severity of losses and combines them using statistical simulations. This approach is effective for regular losses but may not be as precise for extreme, catastrophic events.

C. A method that focuses on extreme events by using statistical techniques to model the tail of the loss distribution. This method is highly effective at estimating the impact of rare, large losses but may not adequately capture frequent, smaller losses.

D. A method that combines a general loss modeling approach with additional techniques specifically designed to improve the accuracy of extreme event estimation, effectively balancing both frequent, smaller losses and rare, catastrophic losses.

Question ORR-4 f.8 Workbook D19.1 • S1, S2 • Map #74

An operational risk modeller at a Swiss private bank is calibrating the loss distribution approach (LDA) for the bank's ICAAP economic capital. Two units of measure (UoMs) cover external fraud, one in private banking and one in asset management. The scenario-based calibration gives:

- External fraud, private banking: Poisson frequency, mean 0.05 events per year
- External fraud, asset management: Poisson frequency, mean 0.03 events per year
- Severity for both UoMs (same scenario set): CHF 40 million with probability 0.75 and CHF 160 million with probability 0.25

Validation has confirmed that the two UoMs are independent of each other, that frequency and severity are independent, and that the severity data are homogeneous, so the modeller merges the two into a single UoM. Run stand-alone, each UoM has a 99.9th percentile annual loss of CHF 160 million. Which of the following gives the expected annual loss and the economic capital of the merged UoM, using the confidence level and horizon applied in the reading?

A. Expected annual loss CHF 5.6 million; economic capital CHF 200 million

B. Expected annual loss CHF 5.6 million; economic capital CHF 160 million

C. Expected annual loss CHF 5.6 million; economic capital CHF 320 million

D. Expected annual loss CHF 8.0 million; economic capital CHF 200 million

Solutions • ORR-4 f

Solution ORR-4 f.1

Answer: B

Bank Q111 • AnalystPrep Q.5108

Step 1 – Match the three fingerprints

Separate frequency and severity distributions per unit of measure; convolution into an aggregated annual loss distribution; the 99.9th percentile as stand-alone capital. This is GARP's description of the loss distribution approach (Section 4.4).

⇒ Frequency and severity split, convolution, 99.9th percentile: only the LDA has all three.

Step 2 – Place the other names

Reverse stress testing starts from a failure outcome and works backward (ORR-7 c). A fixed multiplier is one of the alternatives GARP lists to EVT; it fits no distributions. Variance-covariance matrices and copulas are how Tier-1 firms aggregate ICAAP scenarios.

Interpretation

The LDA is the most widespread operational risk model. The 99.9th percentile of one UoM is only *stand-alone* capital: the UoMs are then aggregated, and the dependency structure chosen for that step has a great influence on the final number.

Why the other options are wrong

A is incorrect. Reverse stress testing does not fit loss distributions; it asks what circumstances could make the firm fail.

C is incorrect. A fixed multiplier scales an indicator; there is no frequency or severity fitting.

D is incorrect. Scenario aggregation combines scenario estimates in the ICAAP; it does not convolve fitted frequency and severity distributions.

LO: ORR-4 f: Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.4 Loss Distribution Approach for Operational Risk; SchweserNotes 2026 Book 3, Reading 45, LO 45.f

Solution ORR-4 f.2

Answer: B

New • built from GARP Ch.4 (4.4) and workbook A10, D19

Step 1 – Read document 1

Fixed weights on five accounting ratios produce one score, and cut-off values assign each borrower to a group: this is Altman's linear discriminant function (the Z-score of CR-9 b), a credit scoring and classification tool.

Step 2 – Read document 2

Frequency and severity per unit of measure, combined into an annual loss distribution: the loss distribution approach. Its 99.9th percentile is the stand-alone operational risk capital.

⇒ Same acronym, different fields: one classifies borrowers, the other sizes capital.

Interpretation

The August recall "calculate z score (LDA)" is ambiguous precisely because of this acronym. In a credit stem with ratios and cut-offs, think Altman; in an operational stem with frequency, severity and a percentile, think capital.

Why the other options are wrong

A is incorrect. Sibling merge. The LDA's severity step fits a loss-size distribution; it does not combine accounting ratios into a score for borrowers.

C is incorrect. Labels swapped. Discriminant analysis is the scoring tool; the loss distribution

approach is the capital model.
D is incorrect. A true fact used for a false conclusion. The split does double the data points, but the LDA "is not quite sufficient to account for the extreme skewness" of losses: the tail still needs external data, EVT or scenarios.

LO: ORR-4 f: Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.4 Key Principles; Hull, RMFI 6e, Ch.17, 9.1.2 (Altman's Z-score)

Solution ORR-4 f.3 — Answer: C

Bank Q108 • BT P2.T7.23.5.2

Step 1 – Test the true statements

A: Monte Carlo is the most common convolution method. B: Poisson (or negative binomial) frequency, lognormal, Weibull or GPD severity, as in the reading. D: internal data are thin in the tail, so it is completed with EVT, external data or scenarios; mixing data involves scaling, cut-off mix and filtering.

Step 2 – Find the reversal

Within a UoM, losses are assumed i.i.d.: no implicit correlation, one data-generating mechanism, so UoMs should be as *homogeneous* as possible. Across UoMs, the distributions are aggregated with explicit correlations or copulas, not under an independence assumption.
⇒ Statement C reverses both halves, so it is the false one.

Interpretation

The stem's step "calculate EL and UL for each risk class" is BT's framing. GARP sets stand-alone capital as the 99.9th percentile of the aggregated distribution itself, then aggregates the UoMs with a dependency model.

Why the other options are wrong

A is incorrect. True: Monte Carlo draws of frequency and severity build the aggregated distribution.
B is incorrect. True: these are the distributions the reading names.
D is incorrect. True: the tail needs external data, EVT or scenarios, with the three mixing choices.

LO: ORR-4 f: Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.4 Frequency Modeling, Severity Modeling, Limitations and Constraints, Interrelationships and Correlations

Solution ORR-4 f.4 — Answer: B

Bank Q110 • Schweser Module Quiz 45.3 Q1

Step 1 – Recall the three mixing choices

Scaling adjusts external losses for size or inflation; the cut-off mix sets the severity level above which external data enter; filtering sets the criteria for including or excluding losses.

Step 2 – Match the stem

Specific criteria for inclusion and exclusion are filtering.
⇒ Regulators want these rules written down to prevent "cherry picking" and manipulation of results.

Interpretation

All three are methodological decisions that can move the capital figure significantly, which is why GARP wants operational risk managers able to challenge modellers on them.

Why the other options are wrong

A is incorrect. The cut-off mix is a severity threshold for external data, not a general set of inclusion criteria.

C is incorrect. Scaling resizes losses; it does not decide which losses are in the dataset.

D is incorrect. "Rule based" is not one of the three named methods.

LO: ORR-4 f: Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.4 Mixing Internal and External Loss Data; SchweserNotes 2026 Book 3, Reading 45, LO 45.f

Solution ORR-4 f.5 — Answer: D

Bank Q112 • BT notes P2.T7.2.4

Step 1 – Check the LDA limitations (A, B, C)

A: independence of frequency and severity is a strong condition given the contrast between frequent small and rare large events. B: finer UoMs are more homogeneous but hold less data, so results are less reliable. C: the LDA cannot handle the extreme skewness without added large losses, EVT or scenarios. All three are in the reading.

Step 2 – Check the EVT claim (D)

EVT is valid only if "a single mechanism is responsible for all observed losses" and can produce future losses beyond those observed. Operational losses come from different business lines and risk types, so the condition is unlikely to hold.

$\Rightarrow$ D states the condition as if it were the normal case: it is the incorrect statement.

Interpretation

GARP's conclusion is that the single-mechanism condition "raises concerns about the applicability of EVT in operational risk", which is why scenarios, causal models, fixed multipliers or macro determinants are offered as alternatives.

Why the other options are wrong

A is incorrect. A correct statement of the first LDA limitation.

B is incorrect. A correct statement of the UoM trade-off.

C is incorrect. A correct statement of the tail limitation and its three remedies.

LO: ORR-4 f: Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.4 Limitations and Constraints; EVT: A Word of Caution

Solution ORR-4 f.6 — Answer: B

Workbook A17.1 • S1, S2, S5, S6 • Aug-2026

Step 1 – What block maxima is (GEV theory)

By the Fisher-Tippett theorem, the distribution of the maximum of a large i.i.d. sample converges to the GEV, with location μ, scale σ and tail index ξ. The operational-risk reading frames it as examining "the maxima equally spaced in time (e.g., the maximum operational loss per period of time and per UoM)".

Step 2 – What POT is

POT models excess losses over a high threshold u; by the GPBdH theorem they converge to the two-parameter generalised Pareto distribution (β, ξ) as u gets large.

Step 3 – Compare them

Dowd: the GEV "typically involves an additional parameter relative to the POT", and block max-

ima "can involve some loss of useful data relative to the POT approach, because some blocks might have more than one extreme in them"; on the other hand, POT "requires us to grapple with the problem of choosing the threshold, and this problem does not arise with the GEV".
⇒ Statement B carries exactly these properties (Figure 3).

Interpretation

Neither approach dominates: "either approach is usually reasonable". With a short internal loss history, POT keeps more of the scarce tail observations; block maxima avoids the subjective threshold and handles clustered losses better, at the cost of efficiency.

Why the other options are wrong

A is incorrect. Sibling swap. The two-parameter GP distribution belongs to POT; the GEV fitted to block maxima has three parameters, typically one more than POT.
C is incorrect. Polarity flip. $\xi > 0$ is the Fréchet case: power-law, heavy tails, more extreme losses than a normal parent. The Weibull case with lighter than normal tails is $\xi < 0$.
D is incorrect. Absolute claim. The ORR reading cautions that EVT "would only be valid if a single mechanism is responsible for all observed losses"; with losses from different business lines and risk types this is unlikely, which "raises concerns about the applicability of EVT in operational risk".

LO: MR-3 b: Describe extreme value theory (EVT) and its use in risk management. MR-3 d: Compare and contrast the generalized extreme value (GEV) and POT approaches to estimating extreme risks. ORR-4 f: Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations. • **Reference:** Dowd, Measuring Market Risk 2e, Ch.7, 3.1 and GEV vs POT; GARP, Operational Risk and Resilience, Ch.4, Extreme Value Theory and EVT: A Word of Caution

Solution ORR-4 f.7

Answer: D

Bank Q109 • BT P2.T7.24.4.2

Step 1 – Name each method

A is an income-based indicator (a business indicator times a multiplier). B is the LDA. C is EVT on its own. D is a hybrid: a general loss model (the LDA) completed with tail techniques (EVT or scenarios).

Step 2 – Match the bank's need

The bank has rich internal data for the body (frequent, small losses) and worries about the tail (fraud, cyber). The LDA handles the body but is "not quite sufficient" for the extreme skewness; the tail must be completed with EVT, scenario data, or both.
⇒ Only the hybrid covers both ends of the distribution.

Interpretation

This is the structure of GARP's Box 4.4 (two distributions for body and tail, four inputs) and of the hybrid models that former AMA banks now run for their Pillar 2 assessment.

Why the other options are wrong

A is incorrect. An indicator approach ignores actual loss events and their severity, so it cannot model the tail the bank is worried about.
B is incorrect. The LDA alone is good for the body but weak in the tail, as the option itself admits.
C is incorrect. EVT alone models only the tail and neglects the frequent losses the bank has data for; it also needs a single loss-generating mechanism.

LO: ORR-4 f: Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.4 Limitations

and Constraints; Capital Modeling for Operational Risk, Box 4.4

Solution ORR-4 f.8 **Answer: A**

Workbook D19.1 • S1, S2

Step 1 – Merge the frequencies (Poisson additivity)

$$\lambda = \lambda_X + \lambda_Y = 0.05 + 0.03 = 0.08 \text{ events per year}$$

⇒ Independent Poisson UoMs with the same severity combine exactly into one Poisson UoM with intensity 0.08: on average one external fraud event every 12.5 years across both business lines.

Step 2 – Expected annual loss

$$E[X] = 0.75 \times 40 + 0.25 \times 160 = 30 + 40 = \text{CHF } 70 \text{ million per event}$$
$$E[S] = \lambda E[X] = 0.08 \times 70 = \text{CHF } 5.6 \text{ million}$$

⇒ The compound Poisson mean (outside-source) is the yearly loss budget for this risk class: small next to the tail, as the ORX asymmetry statistics predict.

Step 3 – Poisson probabilities of the annual event count

$P(N = k) = \lambda^k \mathrm{e}^{-\lambda}/k!$: $P(0) = \mathrm{e}^{-0.08} = 0.923116$; $P(1) = 0.08 \times 0.923116 = 0.073849$; $P(2) = 0.08^2/2 \times 0.923116 = 0.002954$; $P(3) = 0.000079$.

Step 4 – Convolve frequency and severity

One event: CHF 40m with $0.073849 \times 0.75 = 0.055387$; CHF 160m with $0.073849 \times 0.25 = 0.018462$.

Two events: CHF 80m with $0.002954 \times 0.75^2 = 0.001662$; CHF 200m with $0.002954 \times 2 \times 0.75 \times 0.25 = 0.001108$; CHF 320m with $0.002954 \times 0.25^2 = 0.000185$.

Three events add about 0.000033 at CHF 120m and smaller amounts higher up.

Cumulative: $P(S \le 0) = 0.923116$; $P(S \le 40) = 0.978503$; $P(S \le 80) = 0.980165$; $P(S \le 120) = 0.980198$; $P(S \le 160) = 0.998661$; $P(S \le 200) = 0.999769$.

⇒ The aggregated distribution has a large mass at zero, then lumps at each sum of severities.

Step 5 – Read the 99.9th percentile

$P(S \le 160) = 0.998661 < 0.999$ and $P(S \le 200) = 0.999769 \ge 0.999$, so $q_{99.9\%}(S) =$ CHF 200 million.

⇒ The capital is set by a year with one large and one small fraud $(160 + 40)$: once the two UoMs are merged, the 0.11% probability of that combination matters at the 99.9% level.

Interpretation

The bank holds CHF 200 million of ICAAP economic capital for external fraud against an expected annual loss of CHF 5.6 million: the gap shows why operational risk capital is driven by rare, severe events. Merging also gives a lower figure than adding the two stand-alone results, because the UoMs are independent.

Why the other options are wrong

B is incorrect. Dropped term: convolving only zero- and one-event years caps the loss at the largest single severity, CHF 160 million; it ignores the two-event years that carry the merged distribution past 99.9%. (Using the 99th percentile, also CHF 160 million, is the same answer from the wrong confidence level.)

C is incorrect. Aggregation error: adds the stand-alone 99.9th percentiles, $160 + 160 = 320$, which implicitly assumes perfect dependence between the UoMs, contradicting the validated independence.

D is incorrect. Wrong severity mean: uses the unweighted average of the two severity points, $(40 + 160)/2 = 100$, so $0.08 \times 100 = 8.0$; the probabilities 0.75 and 0.25 must weight the mean.

LO: ORR-4 f: Describe approaches used to determine the level of operational risk capital for economic capital purposes, including their application and limitations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.4 Loss Distribution Approach for Operational Risk (Key Principles, Frequency Modeling, Severity Modeling, Interrelationships and Correlations of Operational Risk Events); Capital Modeling for Operational Risk

ORR-4 • Risk Measurement and Assessment • Vardeez: UNTIERED (crash-course notes)

ORR-4 g

P1 CONCEPT

Describe and explain the steps to ensure a strong level of operational resilience, and to test the operational resilience of important business services.

Workbook: A23 Cyber Risk and Operational Resilience • Tier A • August 2026 recall D2 Outsourcing and Third-Party Risk • Tier D

WHAT IS TESTED HERE

Why P1. Tier A workbook topic. Your August 2026 recall lists "Cyber risk", and map #31 (A23, 4 of 16 sources) reports "operational resiliency", with operational resilience as a regulatory concept (UK first, then BCBS, ECB, MAS) as the adjacent theory item. Workbook D2.2 (map #51, Tier D) adds the resilience angle of a concentrated critical provider.

Vardeez: his crash-course notes label this LO "LO 43.g" (consolidated volume p.139). They stress that resilience plans cover critical services, not all processes, and list the key steps: identify the critical services, set tolerances for outages, map dependencies, test with realistic scenarios, learn from the tests and adjust, and have communication plans.

Reported exam shapes

- **A23·S2** Operational resiliency as a regulatory concept: UK first, then BCBS, ECB, MAS.
- **D2·S2** (through D2.2) Concentration in a critical service provider and its resilience implications.

What the questions look like: a firm (often a FinTech or a payment business) asks what to do first, or next. Distractors swap services for processes, impact tolerances for recovery time objectives, resilience for capital, or the firm's accountability for its provider's. Expect the order of the seven steps and the FCA definitions.

See also: workbook A23.2 (payment bank versus community bank during COVID) is worked under ORR-1 d, which also carries the full regulatory history; D2.1 is worked under ORR-12 a. The background to the whole reading is ORR-4 f, Section 1.

1. Resilience as a regulatory concept (shape A23·S2)

Regulators see resilience as an *outcome* of sound operational risk management. BIS (2021): "Operational resilience is an outcome that benefits from the effective management of operational risk"; identification, assessment, mitigation and monitoring "work together to minimize operational disruptions and their effects". Firms must consider plausible disasters that may never have happened to them or to their peers.

- **UK first.** BoE, PRA and FCA joint discussion paper, July 2018: the ability to prevent, adapt, respond to, recover from and learn from disruptions. Its innovation is the **important business service**: a move from a process-based to a *service-based* view, with **impact tolerances**, management of disruption and lessons learned. Severe disruptions are accepted as occasionally inevitable (prevent, detect *and* correct), and the new rules sit *alongside* existing ORM requirements.
- **Then** the Fed's Sound Practices (2020), the **BCBS** seven Principles for Operational Resilience (March 2021, published with the revised PSMOR), the draft **DORA** (September 2020, ICT requirements; "ECB" in GARP) and the **MAS** and ABS paper on remote working (March 2021).

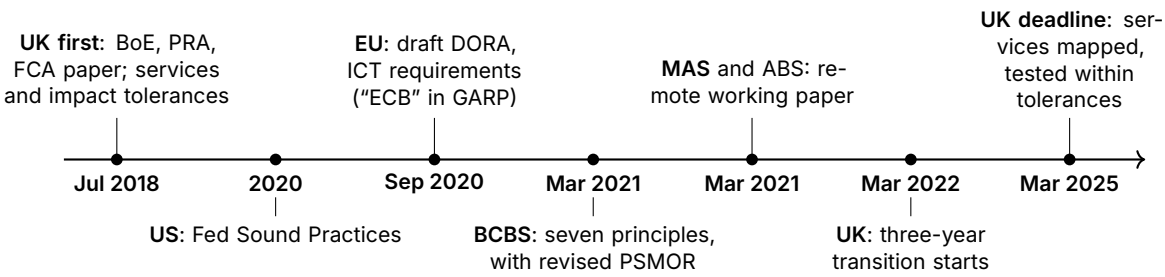


Figure 1. Operational resilience as a regulatory concept (GARP Ch.1, Section 1.6; UK deadlines from Ch.6). Events are evenly spaced for legibility, not to scale.

Correction to the source notes. (1) GARP Ch.1 attributes the September 2020 DORA draft to the ECB; the legislative proposal came from the European Commission, as part of the digital finance strategy the same GARP sentence mentions. Exam items follow GARP's pairing of DORA with the ECB. (2) SchweserNotes (LO 45.g) says resilience "only considers important business services in non-extreme situations". GARP is narrower: intolerable impacts "must be truly exceptional" and resilience is "the maintenance of critical business services in all but most extreme conditions"; tests deliberately use *severe* but plausible scenarios.

2. Important business services and impact tolerances

	Business continuity management	Operational resilience
Unit of analysis	Each business process	Each important business service (IBS)
Limit	Recovery time objective (RTO)	Impact tolerance ("equivalent to RTOs")
Anchored on	Recovery of the firm's own process	Intolerable harm to clients, or risk to the system or markets

FCA definitions (GARP Box 4.7). An **important business service**, if disrupted, could cause intolerable harm to one or more of the firm's clients, or pose a risk to the soundness, stability or resilience of the UK financial system or the orderly operation of markets. The **impact tolerance** is the maximum tolerable level of disruption to an IBS, measured by a length of time plus any other relevant metrics, at the point where further disruption could cause such harm. IBS depend on the firm (retail payments for banks; order booking and trading for asset managers; short-term funding and FX execution for corporate banking), and not every service is important: prioritization is the point.

3. The seven steps

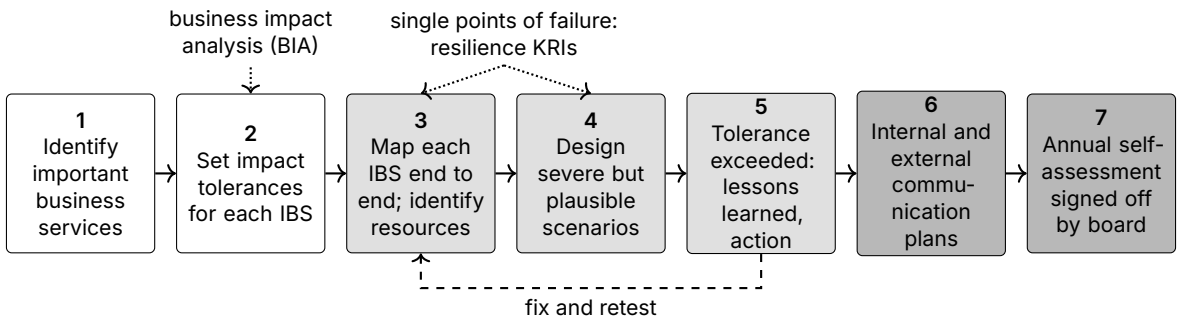


Figure 2. GARP Figure 4.12 redrawn. White: identify and set (1, 2); light grey: map and test (3 to 5); darker grey: respond and govern (6, 7). Dashed arrow: the loop when a test breaches a tolerance. Dotted arrows: inputs from the BIA and from single points of failure.

- **Set (step 2).** Tolerances build on BCM's **business impact analysis**: lost or delayed income, extra costs, fines and contractual penalties, customer attrition, delayed plans, and the resources needed to recover. Restore first what has the greatest impact.
- **Map (step 3).** Dependencies and critical paths; complexity "grows exponentially" in large firms and needs a multi-disciplinary team (ORM as coordinator, BCM, HR, third-party management, IT, operations, infrastructure). In Box 4.8 a Canadian bank maps each step of lending with its tolerance in hours and its system dependencies.
- **Test and learn (steps 4, 5).** Severe but plausible scenarios; where a tolerance is breached, act on the lessons (remove the dependency, add redundancy), then retest.
- **Resilience KRIs (Table 4.2): single points of failure.** Key employees without back-ups or documented processes (coders, pricing modellers, cybersecurity specialists); key suppliers with low substitutability (cloud, data, payment platforms, utilities); key systems (critical-path nodes). Remove them through back-ups and redundancy, or reflect them in tolerances and stress tests.

Exam traps

- **Process for service.** Tolerances attach to important business services; process-level RTOs are BCM.
- **Tolerance as capability.** The tolerance marks intolerable harm; it is not reset to what a test achieved.
- **Steps out of order.** Identify, set tolerances, *then* map, *then* test.
- **Prevention only**, or **capital as the answer**: resilience needs detection and recovery; capital does not restore a service.
- **Resilience replaces ORM.** It sits alongside existing requirements and is an outcome of good ORM.
- **Outsourced, so not ours.** Accountability stays with the firm; a concentrated provider is a single point of failure.
- **Regulator swap.** UK 2018 (services, tolerances); BCBS 2021 (seven principles); DORA (ICT); MAS (remote working).

Practice questions: ORR-4 g

Question ORR-4 g.1

New • built from GARP Ch.1 (1.6) and Ch.4 (4.5)

A consultant is briefing the board of a bank headquartered in Singapore, with branches in London and Frankfurt, on how operational resilience became a regulatory concept. Which of the following statements is accurate?

A. The BCBS issued the first resilience guidance in 2018; UK regulators then turned its seven principles into the concepts of important business services and impact tolerances.

B. The resilience requirements replace the existing operational risk management requirements, because they assume that strong preventive controls can stop severe disruptions from occurring.

C. UK regulators were first, with a 2018 paper that moved from a process-based to a service-based view; the 2021 BCBS principles treat resilience as an outcome of effective operational risk management.

D. The ECB's draft DORA of 2020 dealt mainly with the risks of remote working arrangements, while the MAS paper of 2021 set ICT requirements for financial entities across the EU.

Question ORR-4 g.2

Bank Q113 • GARP book PE2 Q10 • Mock 4 Q11

A fast-growing UK-based FinTech firm offers savings accounts, cryptocurrency accounts, domestic bill payment services, and services that allow customers to make payments in different currencies. A senior operations manager at the firm is developing a plan to comply with new UK regulatory requirements for operational resilience. Which of the following steps should the manager recommend that the firm take to best comply with the regulatory expectations in this area?

A. Develop an impact tolerance for each of the internal processes performed by the firm.

B. Identify important business services and map the dependencies between these services.

C. Calculate the 1-year 99.9% VaR for operational risk for each of the firm's business divisions and use this result to reserve additional capital for each division.

D. Create an operational resilience team that is led by the IT department, with its other members coming from the operational risk management, legal, and compliance functions.

Question ORR-4 g.3 Bank Q115 • BT P2.T7.20.16.3 (rebuilt)

A bank has just identified its important business services (IBSs) and established impact tolerances for each. Following the seven-step process for operational resilience, which of the following correctly gives the order of the next three steps?

A. Design severe but plausible scenarios; map the IBSs and required resources; ensure communication plans are ready

B. Map the IBSs and required resources; design severe but plausible scenarios; if impact tolerances are breached, review lessons learned and take action

C. Map the IBSs and required resources; ensure communication plans are ready; obtain board sign-off on the annual self-assessment

D. Set an impact tolerance for each internal process; map the IBSs; design severe but plausible scenarios

Question ORR-4 g.4 Bank Q114 • BT P2.T7.23.5.3

Alice is developing her bank's operational resilience framework. Historically, her firm's language did not include the concept of resilience. According to the Bank for International Settlements (BIS), "operational resilience is an outcome that benefits from the effective management of operational risk." Her workflow steps will include the following: identify important business services; set impact tolerances; map the important services end-to-end and identify required resources; design severe but plausible scenarios in order to test vulnerabilities; where tolerance(s) is exceeded, examine lessons learned and take action; ensure internal/external communications; get sign-off on an annual self-assessment document. In regard to operational resilience, each of the following is true EXCEPT which is false?

A. Single points of failure (SPOF) are likely to be key risk indicators (KRI), and whenever possible, they should be mitigated or removed.

B. The important business services (IBS) vary by the nature of the institution, and prioritization assumes that not every process is important to an institution.

C. The key difference between resilience frameworks and business continuity management (BCM) is that resilience is articulated around important business services (IBS).

D. The framework should be qualitative (because it complements the factor models), non-complex (to achieve successful implementation), and resource-light in generation (because participants already working on the ORM framework should not bias the resilience framework with dual assignments).

Question ORR-4 g.5 Workbook D2.2 • S2 • Map #51

An operational risk manager at a Canadian bank is reviewing the bank's third-party register. Three important business services (retail payments, client data hosting and the mortgage servicing platform) all run on one cloud provider from a single geographic region. The bank's risk-based vendor rating scores the provider "critical business operations would be halted without the vendor" on process criticality and "none or very limited" on substitutability. Which of the following recommendations should the manager make?

A. Concentration risk here refers only to systemic risk for the banking industry from many banks using the same provider, so it is a matter for supervisors rather than for the bank to manage.

B. Because the provider is a large, reputable firm with strong built-in security, the bank can reduce the frequency of its monitoring and place reliance on the provider's own controls.

C. The bank should set a recovery time objective for each internal process the provider supports, since under resilience rules the process-level RTO is the unit of tolerance to be tested.

D. The bank should treat the provider as a single point of failure: map each important business service end to end, track key-supplier dependency as a KRI, and keep an exit strategy with comparable providers.

Question ORR-4 g.6 New • built from GARP Ch.4 (4.5, Figure 4.12, Box 4.7)

A UK bank has set an impact tolerance of 24 hours for its mortgage servicing platform, an important business service. A severe but plausible scenario test (loss of the primary data centre) shows the service would be restored only after 30 hours, because a single database administrator holds the recovery know-how. Which of the following responses is most appropriate?

A. Raise the impact tolerance to 30 hours, so that the tolerance matches the recovery time the bank has shown it can achieve.

B. Examine the lessons learned, act on the key-person dependency, for example by documenting procedures and training a back-up, then retest.

C. Replace the scenario with a milder one, because resilience testing should cover only non-extreme situations.

D. Hold additional operational risk capital against the six-hour shortfall, which brings the service back within its tolerance.

Solutions • ORR-4 g

Solution ORR-4 g.1

Answer: C

New • built from GARP Ch.1 (1.6) and Ch.4 (4.5)

Step 1 – Who was first

"UK regulators were the first to publish a consultative paper, then regulatory guidance on resilience": the BoE, PRA and FCA joint discussion paper of July 2018. Its innovation was important business services, a move "beyond a process-based view of continuity, to a service-based view".

Step 2 – What the BCBS added

The BCBS Principles for Operational Resilience (March 2021) came out with the revised PSMOR, on purpose: "Operational resilience is an outcome that benefits from the effective management of operational risk."
⇒ C states both facts in the right order.

Interpretation

The chronology to remember: UK 2018 (services and tolerances), Fed 2020 (sound practices), DORA draft 2020 (ICT), BCBS 2021 (seven principles), MAS and ABS 2021 (remote working). Throughout, resilience sits alongside existing ORM requirements.

Why the other options are wrong

A is incorrect. Order reversed. The UK came first (2018); the BCBS principles followed in 2021.
B is incorrect. Two errors. The BoE stated that resilience requirements supplement the existing framework rather than replace it, and the industry's mindset moved *away* from pure prevention after accepting that severe disruptions are occasionally inevitable.
D is incorrect. Sibling swap. DORA brings ICT-related requirements for EU financial entities (GARP attributes the draft to the ECB; see the correction box); the MAS and ABS paper dealt with remote working.

LO: ORR-4 g: Describe and explain the steps to ensure a strong level of operational resilience, and to test the operational resilience of important business services. • **Reference:** GARP, Operational Risk and Resilience, Ch.1, 1.6 (UK, US, BCBS, ECB and MAS); Ch.4, 4.5

Solution ORR-4 g.2

Answer: B

Bank Q113 • GARP book PE2 Q10

Step 1 – Start where the UK rules start

The UK framework is built on important business services: the firm first identifies the services whose disruption would cause intolerable harm (here payments, bill payment, savings), then sets an impact tolerance for each.

Step 2 – Mapping follows

Step 3 maps each service end to end, with its dependencies and the resources required to deliver it, so that severe but plausible scenarios can then test it.
⇒ Of the four options, only B is a genuine resilience step.

Interpretation

For a FinTech the mapping will expose its dependencies on IT and third-party platforms, the dependencies the BCBS principles single out (principles 4, 5 and 7).

Why the other options are wrong

A is incorrect. Impact tolerances are set for important business services, not for every internal

process; a process-level view is business continuity management.
C is incorrect. Resilience is not a capital calculation; a VaR-based reserve does not keep any service within its tolerance.
D is incorrect. Resilience is multi-disciplinary, with ORM usually as coordinator alongside BCM, human resources, third-party management, IT and operations; an IT-led team with only risk, legal and compliance members misses most of them.

LO: ORR-4 g: Describe and explain the steps to ensure a strong level of operational resilience, and to test the operational resilience of important business services. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.5 Important Business Services and Impact Tolerance, Figure 4.12

Solution ORR-4 g.3 Answer: B

Bank Q115 • BT P2.T7.20.16.3

Step 1 – Recite the seven steps

(1) Identify IBS; (2) set impact tolerances; (3) map the IBS end to end and identify the resources; (4) design severe but plausible scenarios; (5) where a tolerance is exceeded, lessons learned and action; (6) communication plans; (7) annual self-assessment signed off by the board.

Step 2 – Read off the next three

Steps 1 and 2 are done, so the next three are 3, 4 and 5.
$\Rightarrow$ Map, test, then learn and act.

Interpretation

The logic is causal: a scenario can only test the delivery of a service that has been mapped, and the lessons only exist once a test has breached a tolerance.

Why the other options are wrong

A is incorrect. Puts scenario design before mapping and skips step 5.
C is incorrect. Skips the testing and the lessons learned (steps 4 and 5) and jumps to steps 6 and 7.
D is incorrect. Repeats step 2 at the wrong level: tolerances belong to services, not to internal processes, and they are already set.

LO: ORR-4 g: Describe and explain the steps to ensure a strong level of operational resilience, and to test the operational resilience of important business services. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.5, Figure 4.12; SchweserNotes 2026 Book 3, Reading 45, LO 45.g

Solution ORR-4 g.4 Answer: D

Bank Q114 • BT P2.T7.23.5.3

Step 1 – Test the true statements

A: single points of failure are resilience KRIs (Table 4.2) and should be removed through back-ups and redundancy where possible. B: the IBS depend on the institution and its customers, and not every service is important. C: BCM is articulated by business process, resilience around IBS.

Step 2 – Test D

Mapping dependencies and critical paths is "a complex part" of the assessment; complexity "grows exponentially" in large institutions and needs large teams, resources and data, with a multi-disciplinary team (ORM as coordinator, BCM, HR, third-party management, IT, operations, infrastructure).
$\Rightarrow$ Non-complex and resource-light is the opposite of the reading: D is false.

Interpretation

Resilience reuses the people already running the ORM framework; that is the point of treating it as an outcome of ORM, not a source of bias.

Why the other options are wrong

A is incorrect. True: SPOFs are standard resilience KRIs.
B is incorrect. True: IBS differ by institution and must be prioritized.
C is incorrect. True: process (BCM) versus important business service (resilience).

LO: ORR-4 g: Describe and explain the steps to ensure a strong level of operational resilience, and to test the operational resilience of important business services. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.5, Box 4.7, Table 4.2 (KRIs for Resilience)

Solution ORR-4 g.5 Answer: D

Workbook D2.2 • S2 • Map #51

Step 1 – Identify the risk

SR 13-19: concentration risk arises when outsourced services are provided by a limited number of providers or are concentrated in limited geographic locations. Here one provider in one region supports three important business services.
⇒ This is a firm-level concentration the bank must manage, not only an industry issue.

Step 2 – Read the vendor rating

Process criticality at the top level and substitutability "none or very limited" put the provider in the highest risk class, which calls for the most frequent and stringent monitoring, a designated point of contact and a tailored mitigation plan.

Step 3 – The resilience response

Single points of failure, including key supplier dependency with low substitutability, are KRIs for resilience; they should be removed through back-ups and redundancy where possible, otherwise reflected in impact tolerances and stress tests. Resilience is organised around important business services, mapped end to end, with impact tolerances. Contingency planning requires an exit strategy with a pool of comparable providers and alignment of the provider's DR/BCP with the bank's own.

Interpretation

D is correct. The recommendation reduces dependency where it can (redundancy, multi-region or second provider), measures what remains, and prepares the exit.

Why the other options are wrong

A is incorrect. Scope/condition error: SR 13-19 defines concentration as few providers or few locations for the firm's own services, and the cyber-resilience reading stresses the firm's lack of control over a single provider, not systemic risk; the bank's board remains responsible for managing it.
B is incorrect. Polarity flip: the risk-based rating makes this a higher-risk provider, which requires more frequent and stringent monitoring; Capital One shows that built-in cloud controls still have to be used and checked by the customer.
C is incorrect. Sibling swap: process-level recovery time objectives belong to business continuity management; operational resilience is articulated around important business services and their impact tolerances.

LO: ORR-12 a: Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk. ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. ORR-4 g: Describe and explain the steps to ensure a strong level of operational resilience, and to test the operational resilience

of important business services. • **Reference:** Federal Reserve SR 13-19 (GARP ORR Ch.12, 12.2, 12.4 E and F); GARP ORR Ch.13, Risk-Based Vendor Rating and Capital One case; Ch.4, 4.5 Quantification of Operational Resilience (KRIs for Resilience)

Solution ORR-4 g.6 Answer: B

New • built from GARP Ch.4 (4.5, Figure 4.12, Box 4.7)

Step 1 – Locate the bank in the seven steps

Tolerance set (step 2), service mapped (step 3), severe but plausible scenario run (step 4): the test breaches the tolerance by $30 - 24 = 6$ hours. Step 5 applies: "where impact tolerance is exceeded, examine lessons learned from stress tests and take actions."

Step 2 – Find the cause and the fix

The breach comes from a key-person dependency, the first single point of failure in Table 4.2 ("key employees without back-ups, without documented processes, with unique knowledge and skills"). Remove it where possible (documentation, a trained back-up), then test again.
$\Rightarrow$ Fix the dependency and retest; the tolerance stays where client harm puts it.

Interpretation

The FCA defines the tolerance by the point at which further disruption could cause intolerable harm to clients or markets. It is a limit on the service, chosen from the client's side, not a record of what the bank can currently achieve.

Why the other options are wrong

A is incorrect. Reverses the logic of the tolerance: resetting it to the tested capability would accept the very harm the tolerance is meant to prevent.
C is incorrect. Scenarios are meant to be severe but plausible; only the most extreme conditions are outside the scope of resilience.
D is incorrect. Capital absorbs losses; it does not restore a service faster. The six-hour gap remains.

LO: ORR-4 g: Describe and explain the steps to ensure a strong level of operational resilience, and to test the operational resilience of important business services. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.5, Figure 4.12, Box 4.7, Table 4.2

ORR-8 • Cyber-resilience: Range of Practices • Vardeez: UNTIERED (crash-course notes)

ORR-8 b

P1 CONCEPT

Describe current practices by banks and supervisors in the governance of a cyber-risk management framework, including roles and responsibilities.

Workbook: A23 Cyber Risk and Operational Resilience • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: your August 2026 recall lists "Cyber risk", and the topic map has it at #31 (4 of 16 sources), reported as "cyber risk framework" and "one cyber risk question". **Vardeez:** untiered, but ORR-8 is rank 8 of 55 in the consolidated volume, and for ORR-1 to 9 his crash-course notes are the primary notes. Under "LO 47.b" (consolidated volume p.38) he reduces governance to five headings: strategy (expected even where not mandated; three approaches), management roles (board and senior management; 3LD with responsibilities the bank defines), awareness (common risk culture, training, background checks, NDAs), architecture and standards (no consistent rules) and workforce (skills vary; training).

Reported exam shapes

- **S1** (A23) Cyber risk framework, "the one cyber risk question": supervisory practice, frameworks and the Equifax lessons. Expect one "which statement is correct" item that mixes governance with information sharing and Equifax.

What the questions look like: statement selection. Three options change a quantifier ("most regulators require" for "most do not require"), flip a polarity (least observed for most observed) or swap a sibling (the CISO's line to the CRO for a line to the CEO). Learn what supervisors *expect*, what they *require*, and in how many jurisdictions.

See also: the definition of cyber-resilience (ORR-8 a, P4) is shared background and sits in Section 1 here. Information sharing (ORR-8 d, P4) is summarised under ORR-8 c, Section 5; Equifax is ORR-9 b. Workbook A23.1 is worked here as the last question.

1. The reading and its key definition

ORR-8 is the Basel Committee's December 2018 report *Cyber-resilience: range of practices*, written by its Operational Resilience Working Group (ORG). Its aim is to *identify, describe and compare* the cyber-resilience practices of banks, regulators and supervisors across jurisdictions, using an FSB survey (April 2017), members' own experience and nine case studies (Boxes 8.1 to 8.9). It is a survey of practice, not a standard: most findings begin with "most", "some" or "a few" jurisdictions, and GARP builds its distractors by changing those words.

Cyber-resilience (FSB Cyber Lexicon, adopted by the BCBS): "the ability of an organisation to continue to carry out its mission by anticipating and adapting to cyber threats and other relevant changes in the environment and by withstanding, containing and rapidly recovering from cyber incidents". Three ideas: keep the mission going; anticipate and adapt; withstand, contain and recover. Preventing every incident is *not* part of it. The report also separates **cyber-risk management** (vulnerabilities and threats) from the broader **IT risk management**.

Why now. Automation and integration with third parties and customers create an attack surface that keeps growing and "is accessible from anywhere"; third parties enlarge the regulators' perimeter of interest and cloud services make it shared. Most jurisdictions treat cyber "through the lens of IT and general operational risk", drawing on NIST, ISO/IEC 27000 and COBIT. Banking is the only financial sector in which every FSB jurisdiction has issued at least a regulation, guidance or a supervisory

practice. Report map: 8.2 standards (ORR-8 a, P4); **8.3 governance (this LO)**; 8.4 supervision, testing, response, metrics (ORR-8 c); 8.5 information sharing (ORR-8 d, P4, summarised in ORR-8 c); 8.6 third parties (ORR-8 e, P3).

2. Cyber-security strategy: expected, not required

Regulators have issued principles-based guidance or prescriptive rules that cover enterprise IT risk management in general, rarely cyber risk in critical business functions, interconnectedness or third parties specifically. The report reviews governance under five headings: **strategy, management roles and responsibilities, awareness culture, architecture and standards, workforce**.

The sentence to know: "Although most regulators do not require regulated entities to develop a cyber-security strategy, **all expect** regulated institutions to have a **board-approved information security strategy, policy and procedures** under the broad remit of effective oversight of technology."

- Many jurisdictions (Australia, Brazil, across Europe) expect cyber risk to be covered by the risk management and/or information security framework of the whole organisation, monitored and reviewed by senior executives.
- So most supervisors review the *information security* strategy (plans, implementation, key initiatives and timelines, stakeholder communication); very few require or evaluate a *standalone* cyber-security strategy.

Jurisdictions enforce strategy expectations through three **non-mutually exclusive** approaches:

	Approach	Where it is found
1	The regulator sets cyber-security strategy requirements, sector-specific or across industries, and institutions comply	Emerging market economies with relatively **homogeneous** banking systems
2	Each institution sets its own strategy under principles-based risk management; the regulator reviews it within the firm's overall risk management	Principles-based regimes (SAMA used approaches 1 and 2 together)
3	The supervisor examines whether the firm has an **IT strategy** with accompanying security provisions	Prevalent in **Europe**

3. Roles and responsibilities: board, three lines, CISO

Board and senior management

Almost all jurisdictions stress management roles for cyber-governance; specific guidance mostly prioritises the board of directors (BoD) and senior management. In the US, EU and Japan, high-level guidelines encourage G-SIBs and D-SIBs to run well-defined, risk-sensitive frameworks under board initiatives; the EBA and many emerging markets are more granular and prescriptive. Box 8.1: **APRA CPS 234** makes the board ultimately responsible for information security, with clearly defined roles, tested controls and notification of material incidents to APRA; the **New York DFS** requires a board-approved (or senior-officer-approved) written policy and a CISO.

Three lines of defence (3LD)

The majority of regulators use 3LD *to assess* cyber-security risk and controls. However, "most regulators do not require the implementation of 3LD at regulated entities and do not prescribe precisely how responsibilities should be distributed across the lines"; banks must define responsibilities themselves and **leave no gaps between the lines**. Supervisory focus is greater on the **first and second lines** than

on the third, which "could hamper the effectiveness of the 3LD checks and balances". Only a few jurisdictions set expectations for an **independent reporting line from the chief audit executive to the board's audit committee**.

The CISO (Box 8.2)

In large, globally active banks the chief information security officer is the executive responsible for cyber-security management. The role is to act as a **"circuit breaker"**: to balance the firm's risk appetite with security protection "long before" digital services or products are introduced or expanded. In most cases the CISO reports to the **CRO or the CIO, with no independent line to the CEO or board**. Placing the CISO under the CRO is **not ideal**: CROs typically emphasise compliance, and when the CISO pursues risk-based controls that accommodate innovation (through the plan-do-check-act cycle) the CRO may put compliance first. Some global banks have therefore moved the CISO to report **directly to the CEO or the board**. SAMA (Saudi Arabia) goes further: the cyber-security function must be **independent from IT**, with its own budget and staff evaluations, reporting to the CEO or managing director or to the senior manager of a control function, and banks self-assess against the framework periodically, subject to SAMA review.

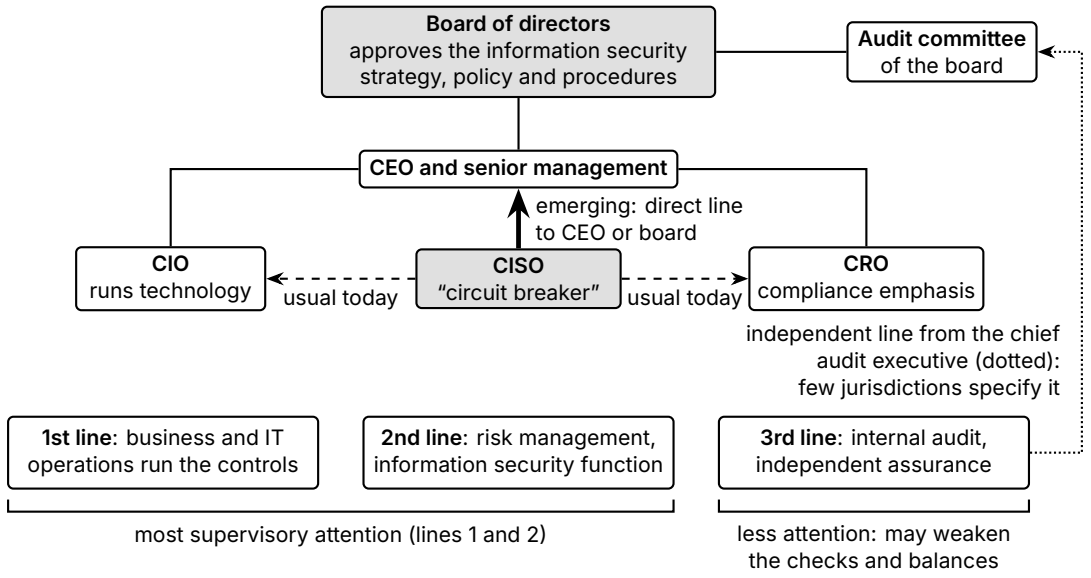


Figure 1. Cyber-governance as the BCBS observes it. The board approves the information security strategy (shaded). The CISO (shaded) usually reports to the CIO or CRO (dashed arrows); some global banks now give it a direct line to the CEO or board (thick arrow). Supervisors use the three lines as an assessment lens and look harder at lines 1 and 2 (left bracket) than at line 3; only a few jurisdictions specify the independent line from the chief audit executive to the audit committee (dotted).

4. Awareness, architecture and workforce

Awareness culture. Staff awareness and a common industry risk culture are "prerequisites" for cyber-resilience; guidance covers staff and management at all levels, including BoDs and third-party employees:

- awareness training **during each phase of employment, from recruitment to termination** (some jurisdictions); non-disclosure clauses in staff agreements;
- insider-threat controls: **screening and background verification** of new employees and **periodic reverification** of existing ones;

- checks that employees, contractors and third-party vendors understand their responsibilities, suit their roles and have the skills to reduce theft, fraud or misuse of facilities;
- some regulators assess each bank's **cyber-risk appetite** (business model, core strategy, key technologies), and some treat cyber-security as a **critical business function**, since an attack could make a bank insolvent or disrupt the sector.

Architecture and standards. For most jurisdictions general requirements are **not in place** or coverage is lacking. A few give guidance: the US FFIEC handbook asks supervisors to confirm that network architecture diagrams are current, securely stored and reflect a **defence-in-depth** architecture (this is what Vardeez's "up-to-date content storage" refers to); in Saudi Arabia architecture practices are subject to periodic self-assessment.

Workforce. Skills and practices "differ markedly" and most jurisdictions are at an early stage. Most supervisors assess the workforce in **on-site inspections**; self-assessment questionnaires are becoming common; training processes are particularly scrutinised, and authorities have challenged the qualifications of a head of IT or information security. Some regulate IT staff roles directly (Argentina, Australia, the EU, Japan, Saudi Arabia). **Only Hong Kong, Singapore and the UK** have dedicated frameworks to **certify** cyber-workforce skills (Box 8.3: HKMA's Professional Development Programme, MAS board training, the Bank of England's CBEST accreditation with CREST); Japan's FISC and Korea's FSI are public-private partnerships that set workforce guidelines.

5. Governance practice in one table

Area	What supervisors expect or observe	What they do *not* do (the trap)
Strategy	All expect a board-approved information security strategy, policy and procedures; cyber inside the firm-wide framework	Most do not require a standalone cyber-security strategy
3LD	Most use 3LD to assess cyber risk; banks define roles with no gaps	Most neither require 3LD nor prescribe the split; line 3 gets less attention
CISO	Executive in charge of cyber; "circuit breaker" before new digital services	Usually no independent line to CEO or board; under the CRO is "not ideal"
Awareness	Common risk culture; training through the employment cycle; screening, reverification, NDAs	Not limited to IT staff: board, contractors and vendors are in scope
Architecture	A few: current, secure diagrams, defence in depth; self-assessment	Most jurisdictions have no general requirement
Workforce	On-site inspections, training reviewed, self-assessment questionnaires	Only Hong Kong, Singapore and the UK certify skills

What A23.1 also tests. The workbook question mixes this LO with information sharing (sharing among regulators is the *least* observed type, 29% of jurisdictions; ORR-8 c, Section 5) and Equifax (a patch had been available for three days; ORR-9 b). Its solution carries the facts you need.

Exam traps

- **Expected versus required.** A standalone cyber-security strategy is expected by many and required by few; a board-approved *information security* strategy is expected by all.
- **Absolute claim on 3LD.** Most regulators use 3LD to assess cyber risk; most do not require it or prescribe how responsibilities are split.
- **Polarity on supervisory attention.** More on lines 1 and 2 than on line 3; only a few jurisdictions address the chief audit executive's line to the audit committee.
- **CISO line.** Usually to the CRO or CIO; that placement is common but not ideal; the trend is a direct line to the CEO or board.

- **SAMA.** The cyber-security function is independent *from* IT, not inside it.
- **Certification.** Only Hong Kong, Singapore and the UK certify cyber-workforce skills.
- **Resilience is not prevention.** The definition is about continuing the mission, adapting, withstanding and recovering.
- **Sibling lists.** Five governance areas (8.3: strategy, roles, awareness, architecture, workforce) against four risk-management areas (8.4: supervision, controls testing, response and recovery, metrics).

Practice questions: ORR-8 b

Question ORR-8 b.1

Bank Q188 • AnalystPrep Q.4264, Q.4481 (rebuilt) • filed under ORR-8 a

A risk analyst preparing a cyber-governance induction for new board members quotes the definition of cyber-resilience that the Basel Committee's report on cyber-resilience practices adopts from the FSB Lexicon. Which of the following is NOT part of that definition?

A. Anticipating and adapting to cyber threats and other relevant changes in the environment

B. Withstanding, containing and rapidly recovering from cyber incidents

C. Continuing to carry out the organisation's mission

D. Eliminating all cyber vulnerabilities so that incidents cannot occur

Question ORR-8 b.2

Bank Q192 • AnalystPrep Q.4484

According to the Basel Committee's report on cyber-resilience practices, cyber-risk awareness and risk culture at regulated institutions is enhanced through:

A. Cyber training incorporated in all phases of employment, from recruitment to termination

B. Effective processes and controls ensuring that employees, contractors and third-party vendors understand their responsibilities and are suitable for their roles, to reduce the risk of theft, fraud or misuse of facilities

C. Establishing a common risk culture to ensure effective cyber-risk management

D. All of the above

Question ORR-8 b.3

Bank Q195 • Schweser Module Quiz 49.1 Q1

Country X's banking regulator established sector-specific cybersecurity requirements. This most likely indicates that Country X is a(n):

A. emerging economy with a homogeneous banking system.

B. developed economy with a homogeneous banking system.

C. emerging economy with a fragmented banking system.

D. developed economy with a fragmented banking system.

Question ORR-8 b.4 Bank Q196 • AnalystPrep Q.4273 (rebuilt)

Exim Bank has completed a cyber-risk assessment and business impact analysis (BIA) of its online banking service. The results show a residual cyber risk above the risk appetite approved by the board. The information security manager and the business department manager disagree over who should make the final evaluation of the results and the resulting risk decision. Consistent with the Basel Committee's findings on cyber-governance roles and responsibilities, the best course of action is to:

A. adopt the information security manager's decision, since cyber-risk is a technical matter.

B. adopt the business department manager's decision, since the business owns the risk.

C. escalate the report to the board and senior management, who are expected to oversee cyber-risk and resolve the dispute.

D. commission a new risk assessment and BIA to remove the disagreement.

Question ORR-8 b.5 Bank Q194 • BT P2.T7.20.14.3 (rebuilt)

According to the Basel Committee report on cyber-resilience practices, each of the following statements about the three-lines-of-defence (3LD) model in cyber-governance is correct EXCEPT:

A. The majority of regulators have adopted the 3LD model to assess cyber-security risk and controls.

B. Most regulators require institutions to implement 3LD and prescribe precisely how responsibilities are distributed across the lines.

C. There is a greater supervisory focus on the first and second lines than on the third line of defence.

D. Only a few jurisdictions have specific expectations on the independent reporting line from the chief audit executive to the audit committee.

Question ORR-8 b.6 New • built from GARP Ch.8, Box 8.2

The chief risk officer (CRO) of a large, globally active bank chairs a review of the bank's cyber-governance structure. The chief information security officer (CISO) currently reports to the CRO and has no reporting line to the CEO or the board. Drawing on the Basel Committee's case study on the role of CISOs, which of the following observations is correct?

A. The bank is an outlier, since at most large banks the CISO already has an independent reporting line to the board.

B. The arrangement is the preferred one, since the CRO's emphasis on compliance gives risk-based cyber controls the strongest support.

C. The arrangement is common but not ideal, since the CRO may favour compliance over innovation; some global banks now have the CISO report to the CEO or board.

D. The arrangement should move to the CIO, since regulators such as SAMA require the cyber-security function to sit within the IT function.

Question ORR-8 b.7 Workbook A23.1 • S1 • Aug-2026 • Map #31

The chief information security officer of a German bank is drafting a board paper on the bank's cyber risk framework. The paper summarises supervisory practice as described by the Basel Committee's cyber-resilience range of practices report and the lessons the bank has drawn from the Equifax breach. Which of the following statements is correct to include in the paper?

A. Most regulators require banks to implement the three lines of defence model for cyber risk and prescribe how cyber responsibilities are distributed across the three lines.

B. Of the five types of cyber-security information sharing, sharing among regulators is the most widely observed, mainly through supervisory colleges and memoranda of understanding.

C. The Equifax breach exploited a vulnerability for which no patch had yet been released, so the main lesson is to invest in threat intelligence rather than in patch management.

D. Most regulators do not require a standalone cyber-security strategy, but all of them expect a board-approved information security strategy, policy and procedures.

Solutions • ORR-8 b

Solution ORR-8 b.1 — Answer: D

Bank Q188 • AnalystPrep Q.4264, Q.4481 • filed under ORR-8 a

Step 1 – Recall the definition the BCBS adopts

Cyber-resilience is "the ability of an organisation to continue to carry out its mission by anticipating and adapting to cyber threats and other relevant changes in the environment and by withstanding, containing and rapidly recovering from cyber incidents".
⇒ Three elements: continue the mission; anticipate and adapt; withstand, contain and recover.

Step 2 – Match each option

A is the "anticipating and adapting" clause, B the "withstanding, containing and rapidly recovering" clause and C the core of the definition. Eliminating all vulnerabilities appears nowhere.
⇒ D is the exception.

Interpretation

Resilience assumes that incidents will happen and asks whether the firm keeps operating through them and recovers fast. That is why the report gives response, recovery and exercising (ORR-8 c) as much weight as prevention. The bank filed this question under ORR-8 a (P4, not built); it sits here because the definition is the shared background for the whole reading.

Why the other options are wrong

A is incorrect. Part of the definition: "anticipating and adapting to cyber threats and other relevant changes in the environment".
B is incorrect. Part of the definition: "withstanding, containing and rapidly recovering from cyber incidents".
C is incorrect. The core of the definition: the ability "to continue to carry out its mission".

LO: ORR-8 a: Define cyber-resilience and compare recent regulatory initiatives in the area of cyber-resilience. • **Reference:** BCBS, Cyber-Resilience: Range of Practices (2018), GARP ORR Ch.8, Section 8.1; SchweserNotes 2026 Book 3, Reading 49, LO 49.a

Solution ORR-8 b.2 — Answer: D

Bank Q192 • AnalystPrep Q.4484

Step 1 – Training across the employment cycle (option A)

"In some jurisdictions, regulators require cyber-security awareness training during each phase of the employment process, from recruitment to termination."
⇒ A is an observed practice.

Step 2 – Role and suitability controls (option B)

In some jurisdictions regulators assess whether banks have processes and controls to ensure that "employees, contractors and third-party vendors understand their responsibilities, are suitable for their roles and have the requisite skills to reduce the risk of theft, fraud or misuse of facilities".
⇒ B is an observed practice.

Step 3 – Common risk culture (option C)

"The majority of the regulators encourage the development of a common risk culture sufficient to ensure effective cyber-risk management."
⇒ C is an observed practice, so all three apply.

Interpretation

Awareness is the people side of cyber-governance. Its scope is wide: staff and management at

all levels, including boards and third-party employees, plus insider-threat controls such as non-disclosure clauses, screening of new hires and periodic reverification.

Why the other options are wrong

A is incorrect. True, but incomplete: B and C are also cited.
B is incorrect. True, but incomplete: A and C are also cited.
C is incorrect. True, but incomplete: A and B are also cited.

LO: ORR-8 b: Describe current practices by banks and supervisors in the governance of a cyber-risk management framework, including roles and responsibilities. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.3 (Cyber-Risk Awareness Culture); SchweserNotes 2026 Book 3, Reading 49, LO 49.b

Solution ORR-8 b.3 Answer: A

Bank Q195 • Schweser Module Quiz 49.1 Q1

Step 1 – Identify the approach

A regulator that itself sets sector-specific cyber-security requirements is using the first of the three approaches to enforcing strategy expectations.

Step 2 – Where that approach is found

GARP: "This is a common approach in emerging market economies with relative homogeneity in their banking systems."
⇒ Emerging economy, homogeneous banking system.

Interpretation

Homogeneity is what makes one set of regulator-written rules workable for every bank. The other two approaches are the bank-set strategy reviewed by the regulator (principles-based) and the review of the firm's IT strategy and security provisions (prevalent in Europe). They are not mutually exclusive: SAMA used the first two together.

Why the other options are wrong

B is incorrect. Developed economies are associated with the other approaches, in particular the IT-strategy review prevalent in Europe.
C is incorrect. A fragmented system is the opposite of the "relative homogeneity" that makes regulator-set rules practical.
D is incorrect. Wrong on both attributes.

LO: ORR-8 b: Describe current practices by banks and supervisors in the governance of a cyber-risk management framework, including roles and responsibilities. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.3 (Cyber-Security Strategy Is Expected But Not Required); SchweserNotes 2026 Book 3, Reading 49, LO 49.b

Solution ORR-8 b.4 Answer: C

Bank Q196 • AnalystPrep Q.4273 (rebuilt)

Step 1 – Locate the decision

The residual risk lies above the appetite the board approved. Neither the information security manager nor the business manager has the authority to accept a risk outside the board's appetite.
⇒ The decision belongs above both of them.

Step 2 – What the report says about roles

"Almost all the jurisdictions emphasise the importance of management roles and responsibilities for cyber-governance and key controls", and most specific guidance "prioritises the roles and responsibilities of the BoD and senior management". APRA's CPS 234, for example, makes the board ultimately responsible for information security.

⇒ Escalate to the board and senior management.

Interpretation

The 3LD expectation is that the bank defines responsibilities with no gaps between the lines; escalation is the mechanism when the first-line and second-line views conflict on a risk outside appetite. (The bank's version did not say the risk exceeded appetite, which left option B arguable; the stem now states it and the options are reordered.)

Why the other options are wrong

A is incorrect. Lets one function decide alone. Cyber risk is a business risk overseen by the board, not a purely technical matter, and accepting a breach of the board's appetite is not the security manager's call.

B is incorrect. The business owns day-to-day risk within appetite, but it cannot accept a risk above the board-approved appetite.

D is incorrect. Repeating the assessment changes no facts; the disagreement is about authority, so it would persist.

LO: ORR-8 b: Describe current practices by banks and supervisors in the governance of a cyber-risk management framework, including roles and responsibilities. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.3 (Management Roles and Responsibilities) and Box 8.1; SchweserNotes 2026 Book 3, Reading 49, LO 49.b

Solution ORR-8 b.5 **Answer: B**

Bank Q194 • BT P2.T7.20.14.3

Step 1 – How regulators use 3LD

"The majority of regulators have adopted the 3LD risk management model to assess cybersecurity risk and controls."

⇒ A is correct.

Step 2 – What they do not do

"Most regulators do not require the implementation of 3LD at regulated entities and do not prescribe precisely how responsibilities should be distributed across the lines"; banks define the split and leave no gaps.

⇒ B is false: the EXCEPT answer.

Step 3 – Where supervisory attention falls

There is "a greater supervisory focus on the first and second lines of defence than on the third line", and "only a few jurisdictions" set expectations on the chief audit executive's independent line to the audit committee.

⇒ C and D are correct.

Interpretation

3LD is the supervisor's lens, not its mandate. The weak spot the report names is the third line: lighter supervision of internal audit could hamper the model's checks and balances.

Why the other options are wrong

A is incorrect. A correct statement of the report's finding, so it is not the exception.

C is incorrect. A correct statement: line 3 receives less supervisory attention.

D is incorrect. A correct statement: few jurisdictions address the chief audit executive's independent reporting line.

LO: ORR-8 b: Describe current practices by banks and supervisors in the governance of a cyber-risk management framework, including roles and responsibilities. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.3 (Variety of Supervisory Approaches Regarding the Second and Third Lines of Defence); SchweserNotes 2026 Book 3, Reading 49, LO 49.b

Solution ORR-8 b.6 — Answer: C

New • built from GARP Ch.8, Box 8.2

Step 1 – The usual reporting line

"In most cases the CISO reports to the chief risk officer (CRO) or to the chief information officer (CIO), with no independent reporting line to the CEO or board of directors."
⇒ The bank's arrangement is the common one.

Step 2 – Why it is not ideal

"CROs typically place more emphasis on compliance over risk management." The two roles have "inherently conflicting priorities": when the CISO pursues risk-based controls that accommodate technological innovation, the CRO may put compliance first, which can impede the CISO.

Step 3 – The emerging response

"Some global banks are restructuring the CISO role by having the CISO report directly to the CEO or BoD."
⇒ Common, not ideal, and the trend is a direct line to the top.

Interpretation

The CISO is meant to be a "circuit breaker" that balances risk appetite against security before new digital services are launched. A line through a compliance-minded CRO can blunt that role, which is why some banks give the CISO direct access to the CEO or board.

Why the other options are wrong

A is incorrect. Polarity flip: in most cases the CISO has no independent line to the CEO or board, so the bank is typical, not an outlier.
B is incorrect. Polarity flip: the report calls the placement under the CRO "not ideal" precisely because of the CRO's compliance emphasis.
D is incorrect. Polarity flip: SAMA requires a cyber-security function *independent from* the IT function, with its own budget and staff evaluations, reporting to the CEO or managing director or to the senior management of a control function.

LO: ORR-8 b: Describe current practices by banks and supervisors in the governance of a cyber-risk management framework, including roles and responsibilities. • **Reference:** BCBS (2018), GARP ORR Ch.8, Box 8.2 (Roles and Responsibilities of CISOs in Cyber-Governance)

Solution ORR-8 b.7 — Answer: D

Workbook A23.1 • S1 • Aug-2026

Step 1 – Strategy expectations (Section 8.3)

"Although most regulators do not require regulated entities to develop a cyber-security strategy, all expect regulated institutions to have a board-approved information security strategy, policy and procedures under the broad remit of effective oversight of technology."
⇒ The board approves an information security strategy; cyber risk lives inside that and the firm-wide risk framework.

Step 2 – Three lines of defence in cyber governance

The majority of regulators have adopted 3LD to assess cyber-security risk and controls, but most do not require its implementation and do not prescribe how responsibilities are distributed; banks are expected to define them and leave no gaps.

Step 3 – Information sharing (Section 8.5)

Among banks and from banks to regulators: 75% of jurisdictions each; with security agencies 68%; regulator to banks 32%; among regulators 29%, the least observed type.

Step 4 – Equifax (ORR-9)

The Apache Struts patch was released on 7 March 2017, an alert reached 400 employees on 8 March, and the attack came on 10 March. The patch was never applied. The weaknesses were IT asset inventory, enforcement of patch management, internal communication, an expired SSL certificate and external crisis communication.

Interpretation

D is correct. The board paper should present the information security strategy as the board's document, then describe how cyber roles are allocated across the lines (the bank's own choice), and cite patch enforcement and asset inventory as the core Equifax lessons.

Why the other options are wrong

A is incorrect. Absolute claim: regulators use 3LD to assess cyber risk; most neither require it nor prescribe the split of responsibilities.

B is incorrect. Polarity flip: sharing among regulators is the least observed type (29%); supervisory colleges and memoranda are the ad hoc channels that explain why.

C is incorrect. Sibling swap (case cross-mapping): describes a zero-day attack; at Equifax the patch had been released three days earlier and the failures were patch enforcement and asset inventory.

LO: ORR-8 b: Describe current practices by banks and supervisors in the governance of a cyber-risk management framework, including roles and responsibilities. ORR-8 d: Explain and assess current practices for the sharing of cybersecurity information between different types of institutions. ORR-9 b: Describe lessons learned from the Equifax case study. • **Reference:** BCBS (2018), GARP ORR Ch.8, Sections 8.3 and 8.5; GARP ORR Ch.9, Equifax case study

ORR-8 • Cyber-resilience: Range of Practices • Vardeez: UNTIERED (crash-course notes)

ORR-8 c

P1 CONCEPT

Explain methods for supervising cyber-resilience, testing and incident response approaches, and cybersecurity and resilience metrics.

Workbook: A23 Cyber Risk and Operational Resilience • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: your August 2026 recall lists "Cyber risk", and the topic map has it at #31 (4 of 16 sources). "Supervisory practice" is named in the reported shape.
Vardeez: untiered; ORR-8 is rank 8 of 55 in the consolidated volume. Under "LO 47.c" (consolidated volume p.39) his crash-course notes give four headings: supervision (complexity and business model; reviews triggered by the bank's own risk assessments, inspection findings or incident analyses; engagement with industry), information security controls (map critical assets and services, monitor threats, control hardware and software), incident response and recovery (frameworks; threat analysis and information sharing to cut reporting delays; joint public-private exercises) and metrics (surveys, incident reports, tests, inspections; the bank's own management information).

Reported exam shapes

- **S1** (A23) Cyber risk framework, "the one cyber risk question": supervisory practice, frameworks and the Equifax lessons. Here: how supervisors review and test, what TIBER-EU and joint exercises are (and are not), and why cyber metrics are immature.

What the questions look like: "which statement is correct" or "all EXCEPT" items. The distractors make tests mandatory or pass-or-fail, turn exercises into tests of firms, or invent a mature quantitative metric. Bank question Q202 (GARP PE2 Q64), on information sharing, is re-filed here from ORR-8 d (P4) because incident reporting and sharing are part of the response approaches.

Recap: the definition of cyber-resilience and the report's structure are in ORR-8 b, Section 1.

1. Four areas of Section 8.4

Section 8.4 of the report has four parts, which map one to one onto the LO wording: (1) **methods for supervising cyber-resilience**; (2) **information security controls testing and independent assurance**; (3) **response and recovery testing and exercising**; (4) **cyber-security and resilience metrics**. Do not confuse this list with the five governance areas of Section 8.3 (strategy, roles, awareness, architecture and standards, workforce: ORR-8 b).

2. Methods for supervising cyber-resilience

- **Risk-based scoping.** Most supervisors focus on key risks such as cyber "in the context of the scale, complexity, business model and previous findings", often placing banks in categories to decide who is in scope for which initiative.
- **Triggers.** Half of the EU jurisdictions have internal guidance on when to run a cyber review: the bank's **own risk assessments**, **findings from on-site inspections or questionnaires**, and **incidents** (for example cyber-incident trend analysis).
- **Evidence and reviews.** Risk specialists use survey responses, physical inspections, incident reports and meetings; expectations align with COBIT and NIST, but approach, depth and breadth

vary. Most jurisdictions review both **off-site** (desk review) and **on-site** (at the bank's premises).

- **Front-line triage and third-party reports.** Australia, Brazil and Singapore equip front-line supervisors with tools to triage IT risk; Australia and the UK can appoint an auditor or other third party to report to them on the bank's cyber risk management.
- **Industry engagement**, to influence behaviour or gather views: discussion papers (France's ACPR, the UK PRA, both 2018), conferences, EU FinTech Lab and EBA FinTech Knowledge Hub events, sometimes with third-party providers.

3. Testing: from evidence review to exercises

Mapping comes first. Most jurisdictions (Australia, the EU, Hong Kong, Singapore, the US) treat mapping and classifying business services and supporting assets (by criticality and sensitivity) as the basis for resilience: it lets testing cover end-to-end services and feeds business impact analysis, recovery planning, third-party dependency reviews and scoping. Several also assess real-time detection of adversaries before they move between systems.

Controls testing and assurance. Banks test controls on hardware, software and data; supervisors *review and challenge* that testing and its remediation, using threat and vulnerability assessments, audit reports and control-testing reports (penetration tests, health checks). Some regulators keep **taxonomies of controls** to find gaps in their coverage; these are jurisdiction-specific and **not harmonised**.

Penetration tests. Five EU jurisdictions run regulator-led penetration-test programmes, and three (the ECB, the Netherlands and the UK) have issued guidance on how to test. Tests are typically **voluntary, funded by the bank and aimed at larger, more systemic institutions**. Threat-led red-team tests by third-party threat-intelligence providers and testers are spreading. Most directed tests probe **protective and detective** capabilities; only a few test response and recovery.

TIBER-EU (ECB, May 2018): the first Europe-wide framework for controlled, bespoke ethical red teaming based on threat intelligence, which also serves cross-border entities overseen by several authorities. The authorities and the entity decide **if and when** to test; tests are **tailor-made** and give **no pass or fail**, only insight into strengths and weaknesses to raise cyber maturity.

Exercises are not tests. Exercises train and rehearse the response. **Exercise Resilient Shield** (UK and US, 2015, with leading global firms) improved understanding across governments and industry of information sharing, incident handling and public communications. It was *not* a test of individual firms or systems, not a "cyber war game" with live play, and did not test law enforcement or intelligence agencies. Others: the UK Sector Exercising Group's annual regime with cyber scenarios; JFSA tabletop exercises (2017: over 100 institutions, two cyber scenarios, summary published).

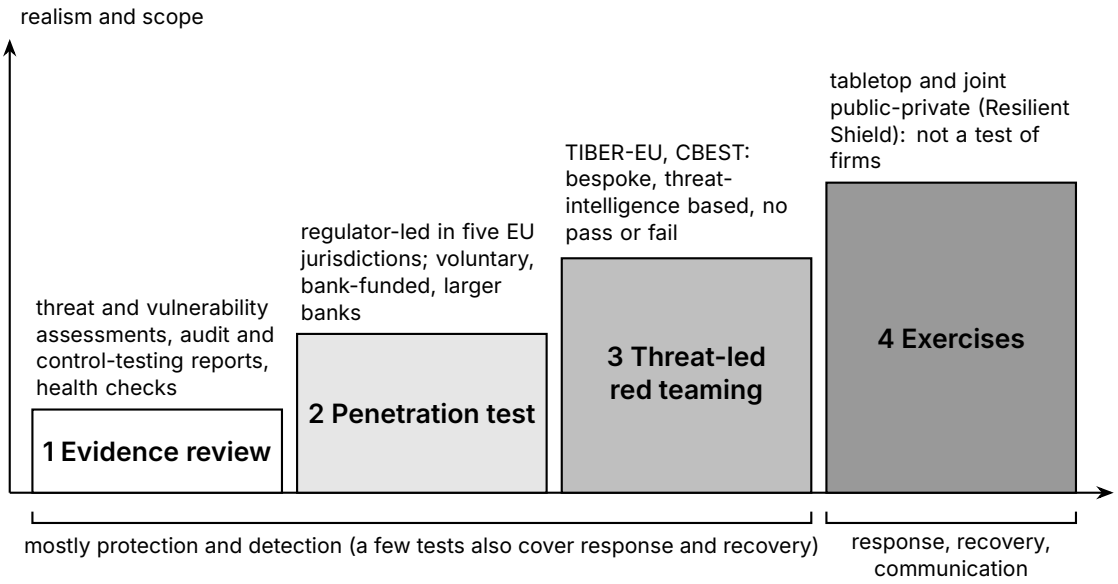


Figure 1. The testing ladder (schematic). Left to right runs from checking controls to rehearsing the response; darker fill means a more realistic, wider-scope activity. Steps 1 to 3 test controls, mostly protection and detection; step 4 rehearses response and coordination and is not a test of individual firms.

4. Incident response and recovery

- **Framework required, rarely cyber-specific.** The majority of regulators require a framework or policy for prevention, detection, response and recovery, including incident reporting, but most requirements are not cyber-specific. China and India prescribe a cyber-incident response framework as part of cyber-governance; US guidance covers indicators of compromise, classification, escalation and reporting; the JFSA and Bank of Japan focus on threats and information sharing to **minimise delays in incident reporting**. Continuity plans are checked against the risk framework, IT disaster recovery and data-centre strategy.
- **What supervisors check in a response plan:** how plans are **triggered**, the bank's **ability to implement** them, **preservation of data**, and specific actions for **critical technology**. Canada checks that communication plans include all relevant stakeholders, to avoid contagion.
- **Post-incident learning** is reviewed in Australia, Belgium, Hong Kong, Japan and the US, through the bank's response and root-cause analysis; no further standard practice was observed.

5. Incident reporting and information sharing (ORR-8 d, P4)

Most Basel jurisdictions have sharing mechanisms, mandatory or voluntary, among banks, regulators and security agencies, in five types (Figure 2).

- **What flows where.** Cyber-threat intelligence is the most common content shared *among banks*; incident information flows mainly *to regulators and security agencies*.
- **Among banks** sharing depends on the industry's culture and the **level of trust**; a two-level structure (a close group first, then a wider one) builds trust. Regulators mostly facilitate rather than take part; Brazil, Japan and Saudi Arabia mandate it. FS-ISAC is a member-driven, anonymised example.
- **Bank to regulator** is mostly mandatory incident reporting. Requirements differ in **taxonomy, time**

frame (immediately, two hours, four hours, 72 hours), **templates and thresholds**, which fragments reporting for cross-border banks; the flow is one-directional.

- **Among regulators** is the least observed type: ad hoc, bilateral or through supervisory colleges and memoranda of understanding (HKMA and MAS, 2018). **Regulator to banks** is rarer where peer sharing among banks already works.

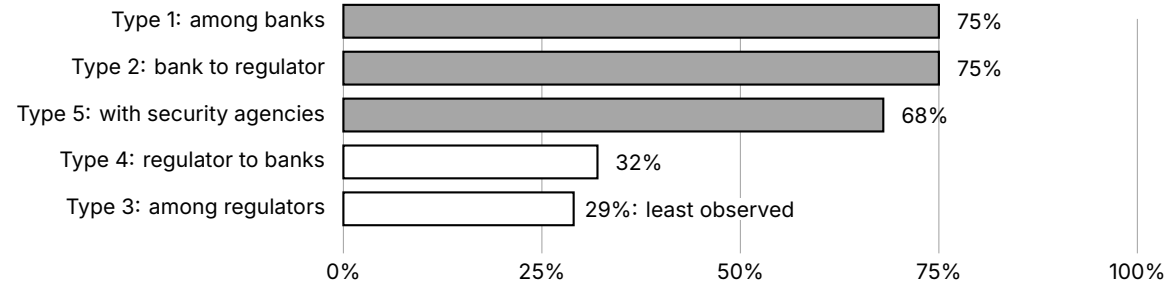


Figure 2. GARP Figure 8.2 redrawn: share of jurisdictions with a sharing arrangement (mandatory, voluntary or both). The three most common types are shaded grey; the two least common are open bars.

6. Cyber-security and resilience metrics: not yet mature

- Assessments rely on **reported incidents, surveys, penetration tests and on-site inspections**; none produce quantitative metrics comparable to those for financial risks. Indicators describe the bank's *approach* to resilience, and supervisors lean on the bank's own management information, which is not yet mature.
- **Backward-looking** indicators of the technology function are reasonable when operations and the risk environment are stable. Cyber breaks that assumption: adversaries adapt to the bank's defences, even within one incident (DDoS is the example). Hence the push for **forward-looking** indicators of whether a bank is likely to be more or less resilient when a risk crystallises.
- Bank-collated metrics allow **trend** reading (better or worse); some track compliance with internal policy, others inherent risk. **Patch ageing** is widespread and comparable. But **no single item is sufficient** and **no standard set** exists to serve as a benchmark.
- **Surveys** yield bank-specific findings, remediation plans and thematic trends; Australia publishes results to influence industry behaviour, the UK shares them with participating firms.

Area (8.4)	Observed practice	Trap to reject
Supervision	Risk-based scope; triggers: own risk assessments, inspection findings, incidents; on- and off-site; triage tools; appointed third parties	One harmonised method; off-site only
Controls testing	Mapping of business services first; review and challenge of the bank's tests; voluntary, bank-funded penetration tests for larger banks, mostly protection and detection	Mandatory, supervisor-funded tests of all banks; TIBER-EU pass or fail
Response and recovery	Framework required (rarely cyber-specific); plan triggers, implementation, data preservation, critical technology; post-incident learning; joint exercises	Exercises as tests of individual firms or live war games
Metrics	Incidents, surveys, tests, inspections; banks' own MI; patch ageing; trends; forward-looking indicators wanted	Mature, standard, quantitative benchmarks like financial-risk metrics

Correction to the source notes. SchweserNotes (Reading 49) says that "China and Japan" require cyber-specific response frameworks within cyber-governance. GARP names **China and India** ("A few jurisdictions, like China and India, have prescribed cyber-incident response framework to be a key component of cyber-governance"). Japan appears in the next sentence for a different practice: threat analysis and information sharing to minimise reporting delays.

Exam traps

- **Sibling lists.** The four areas of 8.4 do not include "architecture and standards", which is a governance area (8.3).
- **Mandatory tests.** Regulator-led penetration tests are typically voluntary, funded by the bank and aimed at larger, more systemic banks.
- **Pass or fail.** TIBER-EU tests are tailor-made and give no pass or fail; authorities and the entity decide if and when to test.
- **What tests cover.** Most directed tests probe protection and detection; only a few test response and recovery.
- **Exercise versus test.** Resilient Shield rehearsed communication and coordination; it did not test firms, use live play or test law enforcement.
- **Metric maturity.** No quantitative cyber metrics comparable to financial-risk metrics; no standard benchmark; no single metric suffices. Patch ageing is widespread and comparable.
- **Backward versus forward.** Backward-looking indicators are reasonable only in a stable environment; adaptive adversaries call for forward-looking ones.
- **Sharing polarity.** Among banks and bank to regulator are the most common types (75%); among regulators is the least (29%).

Practice questions: ORR-8 c

Question ORR-8 c.1

Bank Q197 • Schweser Module Quiz 49.1 Q2

Which of the following is NOT one of the four areas of cyber risk management and incident response and recovery that supervisors review?

A. Architecture and standards

B. Incident response and recovery

C. Supervision of cyber-resilience

D. Cybersecurity and resilience metrics

Question ORR-8 c.2 New • built from GARP Ch.8, Section 8.4

A supervisor at a European national competent authority is redesigning how the authority supervises banks' cyber-resilience and wants each design choice to reflect the range of practices observed by the Basel Committee. Which of the following design choices is consistent with those practices?

A. Rely on one harmonised international taxonomy of cyber-risk controls to find gaps in supervisory coverage, as jurisdiction-specific taxonomies have been phased out.

B. Limit assessments of information security controls to off-site desk reviews, since most jurisdictions no longer inspect these controls on site.

C. Leave all IT risk assessment to specialist risk teams, since no jurisdiction equips front-line supervisors with tools to triage IT risk issues.

D. Scope reviews by each bank's scale, complexity, business model and past findings, and trigger them from its own risk assessments, inspection findings and incidents.

Question ORR-8 c.3 Bank Q200 • AnalystPrep Q.4265 (rebuilt)

Under the ECB's TIBER-EU framework (2018) for controlled testing of cross-border financial entities, which statement is correct?

A. Tests are mandatory for every entity and results are reported as pass or fail.

B. Relevant authorities and entities decide if and when tests are performed; tests are tailor-made and give insight into strengths and weaknesses rather than a pass/fail result.

C. Tests are conducted and funded solely by the supervisory authority without involving the entity.

D. Tests focus exclusively on recovery capability rather than protection and detection.

Question ORR-8 c.4 New • built from GARP Ch.8, Section 8.4 and Box 8.4

The head of cyber-resilience at a large UK bank is briefing the board on two forthcoming supervisory initiatives: a regulator-led, threat-led red-team penetration test, and a joint UK/US public-private exercise modelled on Exercise Resilient Shield. Which of the following statements should the briefing include?

A. Like most regulator-led penetration tests, the test will be mandatory for all banks, funded by the supervisor and focused on response and recovery.

B. The exercise will be scored bank by bank, and a bank that fails it will be placed on a supervisory remediation plan.

C. The test will most likely probe the bank's protective and detective capabilities; the exercise rehearses information sharing, incident handling and public communication rather than testing the bank.

D. The exercise will include live play against the bank's systems, so that the responses of law enforcement and intelligence agencies can be tested.

Question ORR-8 c.5 Bank Q199 • AnalystPrep Q.4271 (rebuilt)

Under the BCBS (2018) review of cyber-resilience practices, which of the following best describes the focus of supervisory evaluation of regulated institutions' incident response and recovery plans?

A. A standardized quantitative score that ranks institutions' recovery capability against financial-risk benchmarks

B. How plans are triggered, the institution's ability to implement them, preservation of data, and specific actions for critical technology

C. Only whether the institution has a written plan, with no assessment of implementation

D. Solely the volume of cyber-incidents experienced in the prior year

Question ORR-8 c.6 Bank Q198 • BT P2.T7.20.14.1 • BT Mock Q38

According to the Basel Committee on Banking Supervision (BCBS, 2018), no jurisdiction's methodology for assessing cyber-security produces quantitative metrics comparable to those for financial risks; instead, indicators describe an institution's approach to building cyber-resilience, and supervisors also rely on entities' own (not yet mature) management information. With respect to current cyber-security and resilience metrics, each of the following statements is true EXCEPT which is inaccurate?

A. No single cyber-security or resilience metric in isolation is sufficient.

B. Patch ageing (days to patch) is a widespread and comparable metric.

C. Backward-looking metrics are helpful but insufficient; forward-looking metrics are necessary because adversaries dynamically adapt.

D. The penetration ratio, the percentage of banks in a jurisdiction that can be penetrated, is a useful metric that compares a supervisor's effectiveness with other jurisdictions.

Question ORR-8 c.7 Bank Q202 • GARP PE2 Q64 • Mock 4 Q65 • filed under ORR-8 d

The CRO at a bank wants to strengthen the bank's capability to defend itself against emerging cyber-threats. To help achieve this goal, the CRO is assessing the current range of practices regarding the sharing of cybersecurity information between different types of institutions. Which of the following statements would be most appropriate for the CRO to make?

A. The sharing of cybersecurity information among banks is less frequently observed and generally considered to be less effective than other cyber-security information-sharing practices.

B. The scope and depth of information-sharing practices among banks may significantly vary between financial markets, depending on the level of trust among participating banks.

C. Information-sharing among different national regulators has evolved significantly over the past several years and is now a widespread practice at a large majority of jurisdictions.

D. Existing peer-sharing mechanisms among banks focus on the exchange of information related to cyber-security incidents, but such information is generally not shared from banks to regulators.

Solutions • ORR-8 c

Solution ORR-8 c.1

Answer: A

Bank Q197 • Schweser Module Quiz 49.1 Q2

Step 1 – List the four areas of Section 8.4

Methods for supervising cyber-resilience; information security controls testing and independent assurance; response and recovery testing and exercising; cyber-security and resilience metrics.

Step 2 – Place "architecture and standards"

It is one of the five *governance* areas of Section 8.3 (strategy, roles, awareness, architecture and standards, workforce).

$\Rightarrow$ A is the exception.

Interpretation

GARP likes to test the two lists against each other. Governance (8.3) is who decides and how the framework is organised; Section 8.4 is how the framework is supervised, tested and measured.

Why the other options are wrong

B is incorrect. Incident response and recovery is the third area.

C is incorrect. Supervision of cyber-resilience is the first area.

D is incorrect. Cyber-security and resilience metrics is the fourth area.

LO: ORR-8 c: Explain methods for supervising cyber-resilience, testing and incident response approaches, and cybersecurity and resilience metrics. • **Reference:** BCBS (2018), GARP ORR Ch.8, Sections 8.3 and 8.4; SchweserNotes 2026 Book 3, Reading 49, LO 49.c

Solution ORR-8 c.2

Answer: D

New • built from GARP Ch.8, Section 8.4

Step 1 – How supervisors set scope

Most supervisors focus on key risks such as cyber "in the context of the scale, complexity, business model and previous findings", often assigning institutions to categories to decide which initiatives cover them.

Step 2 – What triggers a review

Half of the EU jurisdictions have internal guidance on when to review: "institutions' own risk assessments, findings from on-site inspections or questionnaires, and incidents (eg cyber incident trend analysis)".

$\Rightarrow$ D describes both steps.

Step 3 – Check the tools in the other options

Most jurisdictions run both off-site and on-site reviews; Australia, Brazil and Singapore give front-line supervisors triage tools; control taxonomies remain jurisdiction-specific.

Interpretation

Cyber supervision is risk-based and draws on many sources (surveys, inspections, incident reports, meetings), aligned with standards such as COBIT and NIST, while approach, depth and breadth still vary between jurisdictions.

Why the other options are wrong

A is incorrect. False fact: "Currently the taxonomies are jurisdiction-specific and do not rely on harmonised concepts and definitions."

B is incorrect. False fact: "Most jurisdictions undertake off- and on-site reviews and inspections of regulated institutions' information security controls."

C is incorrect. False fact: Australia, Brazil and Singapore have equipped front-line supervisors with guidelines, questionnaires and tools to triage IT risk issues.

LO: ORR-8 c: Explain methods for supervising cyber-resilience, testing and incident response approaches, and cybersecurity and resilience metrics. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.4 (Methods for Supervising Cyber-Resilience; Taxonomy of Cyber-Risk Controls)

Solution ORR-8 c.3 — Answer: B

Bank Q200 • AnalystPrep Q.4265

Step 1 – What TIBER-EU is

Published by the ECB in May 2018, it is "the first Europe-wide framework for controlled and bespoke tests against cyber-attacks in the financial market", and it facilitates testing of cross-border entities overseen by several authorities.

Step 2 – Who decides, and what comes out

"It is up to the relevant authorities and the entities themselves to determine if and when TIBER-EU based tests are performed. Tests will be tailor-made and will not result in a pass or fail."
⇒ B restates both sentences.

Interpretation

The purpose is learning: insight into strengths and weaknesses so the entity can raise its cyber maturity. A pass-or-fail grade would push entities to game the test rather than learn from it.

Why the other options are wrong

A is incorrect. Absolute claim on both counts: not mandatory for every entity, and no pass or fail.
C is incorrect. Authorities and entities decide jointly; regulator-led tests are typically funded by the regulated institution, not the supervisor.
D is incorrect. Most directed tests focus on protective and detective capabilities; only a few also test response and recovery.

LO: ORR-8 c: Explain methods for supervising cyber-resilience, testing and incident response approaches, and cybersecurity and resilience metrics. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.4 (Penetration Testing); SchweserNotes 2026 Book 3, Reading 49, LO 49.c

Solution ORR-8 c.4 — Answer: C

New • built from GARP Ch.8, Section 8.4 and Box 8.4

Step 1 – The penetration test

Regulator-led tests "are typically voluntary, funded by the regulated institution and targeted at larger, more systemic institutions". "The majority of directed penetration tests focus on regulated institutions' protective and detective cyber-resilience capabilities, while a few also test response and recovery capabilities."
⇒ Expect the test to probe protection and detection.

Step 2 – The exercise

Resilient Shield "was not a test of individual financial firms or financial systems, but was designed to improve understanding across governments and industry of information-sharing, incident response handling and public communications".
⇒ C describes both initiatives correctly.

Interpretation

Testing checks controls; exercising rehearses the response and the coordination between firms,

authorities and governments. The board should prepare for the test as a control assessment and for the exercise as a rehearsal of communication and escalation.

Why the other options are wrong

A is incorrect. Three errors: such tests are typically voluntary, bank-funded and aimed at larger banks, and they focus mostly on protection and detection.
B is incorrect. The exercise was explicitly not a test of individual firms, so there is no bank-by-bank score.
D is incorrect. The exercise did not "amount to a cyber war game or include live play" and did not test law enforcement or the security and intelligence agencies.

LO: ORR-8 c: Explain methods for supervising cyber-resilience, testing and incident response approaches, and cybersecurity and resilience metrics. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.4 (Penetration Testing; Joint Public-Private Exercising) and Box 8.4

Solution ORR-8 c.5 Answer: B

Bank Q199 • AnalystPrep Q.4271

Step 1 – Recall the evaluation focus

"Evaluation of regulated institutions' incident response and recovery plans focuses on how plans are triggered, institutions' ability to implement plans, preservation of data and specific actions for 'critical' technology."
⇒ B quotes it.

Step 2 – Related practices

Canada also checks that communication plans include all relevant stakeholders, to avoid contagion; several jurisdictions review post-incident learning through the bank's response and root-cause analysis.

Interpretation

Supervisors judge whether a plan works in practice: can it be triggered, can the bank execute it, does it keep the data needed for investigation and recovery, and does it cover the critical technology.

Why the other options are wrong

A is incorrect. No jurisdiction has quantitative cyber metrics comparable to financial-risk metrics, so no such standardised score exists.
C is incorrect. Supervisors assess the ability to implement the plan, not just its existence on paper.
D is incorrect. Incident counts are a backward-looking indicator, not the focus of plan evaluation.

LO: ORR-8 c: Explain methods for supervising cyber-resilience, testing and incident response approaches, and cybersecurity and resilience metrics. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.4 (Response and Recovery Testing and Exercising); SchweserNotes 2026 Book 3, Reading 49, LO 49.c

Solution ORR-8 c.6 Answer: D

Bank Q198 • BT P2.T7.20.14.1

Step 1 – Check A and B against the report

"No single item taken in isolation is seen as a sufficient metric." "Patch ageing in particular is a widespread and comparable metric."
⇒ A and B are true.

Step 2 – Check C

Backward-looking indicators are reasonable when the operating and risk environment is stable, but adversaries adapt (DDoS is the example), so jurisdictions increasingly recognise the need for forward-looking indicators.
⇒ C is true.

Step 3 – Check D

The report describes no "penetration ratio" and no metric that benchmarks supervisors' effectiveness across jurisdictions; penetration tests assess a bank's controls.
⇒ D is the inaccurate statement.

Interpretation

The theme of the metrics section is immaturity: indicators describe an approach rather than measure resilience, no standard set of indicators exists, and the bank's own management information is uneven.

Why the other options are wrong

A is incorrect. True: no single item in isolation is a sufficient metric.
B is incorrect. True: patch ageing is cited as widespread and comparable (an exception to the general lack of comparable metrics, not a contradiction of it).
C is incorrect. True: adaptive adversaries make forward-looking indicators necessary.

LO: ORR-8 c: Explain methods for supervising cyber-resilience, testing and incident response approaches, and cybersecurity and resilience metrics. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.4 (Cyber-Security and Resilience Metrics); SchweserNotes 2026 Book 3, Reading 49, LO 49.c

Solution ORR-8 c.7 — Answer: B

Bank Q202 • GARP PE2 Q64 • filed under ORR-8 d

Step 1 – How often each type occurs

Sharing among banks (75% of jurisdictions), from banks to regulators (75%) and with security agencies (68%) are the most common types; regulator to banks (32%) and among regulators (29%) are the least common.
⇒ A and C invert the ranking.

Step 2 – What drives sharing among banks

"Sharing of information and collaboration among banks depend on the financial industry's culture and level of trust among participants"; a two-level structure, a close group first and then a broader one, helps build trust.
⇒ Scope and depth vary across markets with trust: B.

Step 3 – What is shared

Threat intelligence is the most common content shared among banks; incident information is shared mostly with regulators (often by mandate) and security agencies.
⇒ D swaps the two.

Interpretation

For a CRO, the practical message is to join or build trusted peer channels (such as an ISAC) for threat intelligence, while meeting mandatory incident reporting to the regulator. Re-filed from ORR-8 d (P4) because incident reporting and sharing are part of the response approaches of this LO; the same five-type ranking appears in workbook A23.1.

Why the other options are wrong

A is incorrect. Polarity flip: sharing among banks is one of the most common types (75%).
C is incorrect. Polarity flip: sharing among regulators is the least observed type (29%), mostly ad hoc through supervisory colleges or memoranda of understanding.

D is incorrect. Sibling swap: peer sharing centres on cyber-threat information, and incident information is widely shared from banks to regulators, usually under mandatory reporting.

LO: ORR-8 d: Explain and assess current practices for the sharing of cybersecurity information between different types of institutions. ORR-8 c: Explain methods for supervising cyber-resilience, testing and incident response approaches, and cybersecurity and resilience metrics. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.5 and Figure 8.2; SchweserNotes 2026 Book 3, Reading 49, LO 49.d

ORR-9 • Cyberthreats and Information Security Risks • Vardeez: UNTIERED (crash-course notes)

ORR-9 a

P1 CONCEPT

Provide examples of cyber threats and information security risks, and describe frameworks and best practices for managing cyber risks.

Workbook: A23 Cyber Risk and Operational Resilience • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: your August 2026 recall lists "Cyber risk", and the topic map has it at #31 (4 of 16 sources); the reported shape names "frameworks" explicitly.
Vardeez: untiered; ORR-9 is rank 9 of 55 in the consolidated volume, and his crash-course notes are the primary notes. Under "LO 48.a" (consolidated volume p.42) he stresses: information security risk is wider than cyber (intentional and unintentional, digital and paper); the four-quadrant typology; the three frameworks (NIST CSF and its five functions, CIS controls, ISO 27001 with its ISMS); CIA; behavioural against technical controls (preventive, detective, mitigating); monitoring.

Reported exam shapes

- **S1** (A23) Cyber risk framework, "the one cyber risk question": supervisory practice, frameworks and the Equifax lessons. Here: the frameworks and controls.

What the questions look like: classify an incident in the four quadrants; place an action in the right NIST function; pick NIST, CIS or ISO 27001 for a stated need; tell a behavioural control from a technical one. Distractors swap siblings (Identify for Protect, ISO for CIS) or classify an incident by where the data ended up instead of by its cause.

See also: Equifax is ORR-9 b; the Basel cyber-resilience report is ORR-8 b and c.

1. Information security risk is wider than cyber risk

Information can be **stolen, lost or unintentionally disclosed**: an e-mail account hacked by an outsider, an autofill error that sends private data to the wrong address, a leak by a disgruntled employee, an audit report left on a train. Causes and controls differ, so GARP (after Chapelle, Table 9.1) sorts data incidents on two axes: **cause** (internal, including on-site contractors and consultants, against external, including third parties) and **nature** (theft or corruption, which is deliberate, against loss or involuntary disclosure). Paper documents and archives are in scope too. A McAfee study (2017) found that **43% of data leaks are initiated by insiders, half of them unintentionally**.

	Theft or corruption (intentional)	Loss or involuntary disclosure (unintentional)
External causes or third parties	1. Digital: hacking, virus infection, phishing and other cyberattacks. 2. Physical: theft, social engineering	3. Disaster, systems disruptions, third-party failure
Internal causes	4. Theft and transfer of digital or physical information by an infiltrated employee or contractor. 5. Departing employees take proprietary information or intellectual property (mishandled exits)	Digital: 6. database or back-up loss; 7. loss of devices by staff; 8. errors when sending documents (e-mail recipients or attachments). Physical: 9. loss of printed documents; 10. accidental mentions of confidential information to outsiders; 11. loss of archives

Classify by cause, not by destination. An employee who mis-addresses an e-mail to an outsider is

an *internal*, unintentional incident (item 8). A power outage that destroys a server is *external* and unintentional (item 3).

> **Correction to the source notes.** Vardeez's Figure 48.1 places "sending sensitive information externally" in the *external*, unintentional quadrant. In GARP Table 9.1, errors when sending documents to the wrong recipients are an **internal** cause (item 8): the employee causes the incident, wherever the data lands. The external, unintentional quadrant holds disasters, systems disruptions and third-party failures. Schweser-Notes' Module Quiz 50.1 (Q2 and Q3) keys agree with GARP; Question ORR-9 a.2 tests this.

2. Examples that made the news

The financial industry is particularly exposed "given the value of the transactions it facilitates". Leaks by malicious insiders look more like internal fraud than cyberattacks, but they are still information security risk. COVID-19 changed the threat landscape (remote work, faster digitalisation, QR codes, social media, disrupted supply chains).

Case	What happened	Quadrant
Paradise Papers (Nov 2017)	1.4 terabytes stolen from offshore law firm Appleby (Bermuda), passed to the press and the ICIJ; reputational damage to clients	External, theft
Equifax (2017)	External intrusion through an unpatched, known vulnerability; 147 million US customers; about USD 5bn of USD 15.5bn market value lost in a week (ORR-9 b)	External, theft
UK insurer (July 2017)	An employee copied 500,000 customers' data and offered it on the dark web; dismissed; GBP 175,000 fine	Internal, theft
IRS and ProPublica	Tax data of the wealthiest Americans (2013 to 2018) published; a suspected IRS employee leak, never firmly established	Internal (suspected)
bZx (Nov 2021)	A developer's private keys stolen in a phishing attack; USD 55 million lost	External, theft
BXH Exchange (Nov 2021)	Hacker exploited an administrator's private key; USD 139.2 million; possibly an inside job	Hybrid

3. Three frameworks dominate

Frameworks give security managers "a systematic way to mitigate cyberthreats and benchmark themselves to good market practice"; they are often mandatory, or strongly encouraged, for firms subject to industry regulation.

NIST Cybersecurity Framework (NIST CSF). Built by the US National Institute of Standards and Technology (Department of Commerce), **voluntary**, first meant for critical infrastructure (power plants, dams) and widely adopted by financial firms. It guides the analysis of threats and vulnerabilities, response and recovery, and promotes root-cause analysis and lessons learned. Its organisation mirrors an operational risk framework (identify, assess, mitigate, monitor), and its core is five functions (Figure 1). In a financial firm it starts with an **asset inventory**.

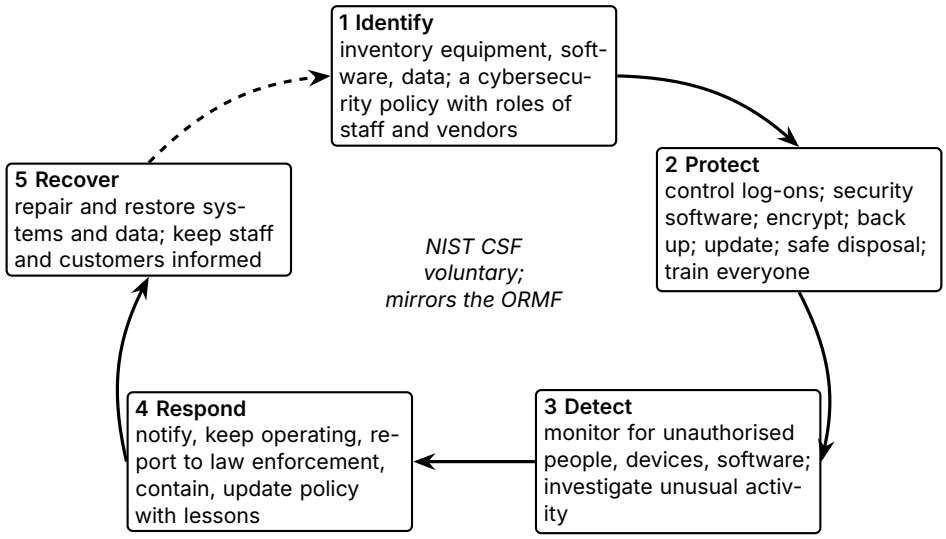


Figure 1. The five NIST CSF functions with GARP's key actions (solid arrows run in order; the dashed arrow closes the loop, as lessons feed the next inventory and policy). "Mitigate" is not a NIST function.

CIS Critical Security Controls. Built in the late 2000s by a volunteer coalition of experts; version 8 has **18 controls**, each split into about ten specific safeguards, prioritised against the most prevalent attacks and refreshed for cloud, virtualisation, mobility, outsourcing and work from home. It is the **detailed, implementable** one: good for establishing or reviewing controls, and it coexists with NIST or supports an ISO 27001 certification.

1 Inventory and control of enterprise assets
2 Inventory and control of software assets
3 Data protection
4 Secure configuration of assets, software
5 Account management
6 Access control management
7 Continuous vulnerability management
8 Audit log management
9 E-mail and web browser protections
10 Malware defenses
11 Data recovery
12 Network infrastructure management
13 Network monitoring and defense
14 Security awareness and skills training
15 Service provider management
16 Application software security
17 Incident response management
18 Penetration testing

ISO/IEC 27001 (2013). The internationally recognised standard: governance, policies, support, communication and awareness, operational planning and control, risk assessment and risk treatment, audit and management review. It does **not** give implementable guidance; it is an **evaluation grid for certification**. To be certified a firm needs an **Information Security Management System (ISMS)** that identifies threats and vulnerabilities, comprehensive controls, and an ongoing improvement process shown to the auditor through the PDCA (plan-do-check-act) cycle.

	NIST CSF	CIS Controls (v8)	ISO/IEC 27001
Nature	Voluntary framework of five functions	18 prioritised controls, detailed	Certification standard, evaluation grid
Gives you	Structure for the whole cycle, including response and recovery	Concrete safeguards to implement	A certificate, if the ISMS and controls pass audit
Key words	Identify, protect, detect, respond, recover	E-mail and browser protections, vulnerability management	ISMS, PDCA, audit, management review
Trap	"Mitigate" is not a function	Not a certification	Not implementable guidance

4. Protection and monitoring: controls, KRIs, lines

CIA. Information protection has three dimensions: **confidentiality and integrity** relate to information security; **availability** relates to business continuity and uptime, now within resilience.

Controls combine technical protection with appropriate human behaviour (GARP Table 9.3):

- **Behavioural** controls address human behaviour and fallibility, for every kind of information security risk, not only cyberattacks: awareness campaigns, training, fake phishing tests, password-cracking attempts by IT, rules of confidentiality, code of conduct, sanctions, data transfer rules, supervision.
- **Technical** controls: **preventive** (architecture and network partitioning, access management, firewalls, encryption, passwords, patching; aimed mainly at external threats); **detective** (early warning of leaks, internal or external: data loss prevention and detection (DLPD) and the **honeypot**, a virtual trap to lure attackers); **mitigating** (redundancies and back-ups kept offline). Penetration testing tests them.

Appetite and cost. Every firm claims zero tolerance for breaches, but commitment differs; controls cost time, money and convenience, so firms categorise information by sensitivity and scale protection to it.

KRIs and lines of defence. Monitoring focuses on control effectiveness and unexpected deviations (exposure, traffic, staff behaviour). Technical monitoring sits almost entirely in the **IT department** (**first line**). The **information security department** is often separate from IT and is most often **second line**: it designs, maintains and monitors the behavioural and technical controls, and their deviations and failings are the KRIs (GARP Table 9.4): overdue vulnerability patching; overdue penetration tests or unresolved recommendations; overdue replacement of obsolete software; phishing-test and password-cracking results; computers with inadequate access or overdue access reviews; vacancies in IT and cyber teams; staff failing more than one phishing test in sensitive areas; devices or access cards lost or stolen.

Exam traps

- **Cause, not destination.** A mis-sent e-mail is internal and unintentional; a power outage is external and unintentional; a virus infection is external theft or corruption.
- **Wider than cyber.** Paper, archives, lost devices and careless conversation are information security risks too.
- **NIST sibling swaps.** The policy with roles is Identify, not Protect; training and safe disposal are Protect; investigating unusual activity is Detect; reporting to law enforcement and updating the policy with lessons are Respond, not Recover. "Mitigate" is not a function.

- **Framework swaps.** ISO 27001 certifies (ISMS, PDCA) but gives no implementable fixes; CIS gives the detailed controls; NIST is voluntary and covers the whole cycle.
- **CIA.** Availability is the continuity and resilience dimension, not an information security one.
- **Behavioural against technical.** Phishing tests, awareness and data transfer rules are behavioural; DLPD and honeypots are technical detective controls; offline back-ups are mitigating.
- **Lines of defence.** Technical monitoring is first line (IT); the information security department is most often second line.

Practice questions: ORR-9 a

Question ORR-9 a.1

Bank Q207 • AnalystPrep Q.4482 (rebuilt)

A risk manager at a bank operates in a country with no cybersecurity regulation. Which course of action is MOST appropriate for protecting the bank against cyber threats?

A. Adopt a globally recognized cybersecurity standard or framework, such as NIST CSF, CIS Critical Security Controls or ISO 27001

B. Draft the bank's own bespoke cybersecurity framework from scratch and apply it internally

C. Wait for the national regulator to issue rules and meanwhile rely on the IT department's existing practices

D. Adopt only a cyber-awareness training program for staff, since behavioral controls are the main defense

Question ORR-9 a.2

Bank Q223 • Schweser Module Quiz 50.1 Q2

An employee inadvertently emails a sensitive and confidential file to a third-party recipient. The employee's action would most likely be categorized as:

A. internal and intentional.

B. external and unintentional.

C. internal and unintentional.

D. external and intentional.

Question ORR-9 a.3

Bank Q208 • AnalystPrep Q.5110

Under the four-quadrant taxonomy of information security risks, which of the following is NOT an example of an involuntary disclosure (loss) incident?

A. Database loss

B. Virus infection

C. System disruptions

D. Loss of printed documents

Question ORR-9 a.4 Bank Q217 • AnalystPrep Q.5119

Which of the following actions does NOT fall under the "protect" step of the NIST cybersecurity framework?

A. Controlling who logs onto a company's network

B. Updating security software regularly

C. Creating a company cybersecurity policy that covers roles and responsibilities of employees

D. Having formal policies for safely disposing of electronic files

Question ORR-9 a.5 Bank Q221 • BT P2.T7.24.6.2 (rebuilt)

A financial services company wants to strengthen its behavioral controls after lapses that allowed unauthorized access to client data due to human error and non-compliance with data governance rules. Which action would be most effective in enhancing behavioral controls?

A. Implementing more robust firewalls and upgrading encryption protocols.

B. Launching a comprehensive awareness campaign, conducting regular fake phishing tests, and enforcing stricter data transfer rules.

C. Increasing the use of honeypots and deploying data loss prevention and detection (DLPD) technologies.

D. Introducing network partitioning and penetration testing of systems.

Question ORR-9 a.6 Bank Q214 • AnalystPrep Q.5116

Which of the following is NOT a requirement for an organization to be certified as ISO 27001 compliant?

A. Having an Information Security Management System (ISMS) that manages its information security risks

B. Designing and implementing effective and comprehensive information security controls

C. Adopting an ongoing risk management process

D. Providing guidance on responding to and recovering from cybersecurity incidents

Question ORR-9 a.7 Bank Q220 • BT P2.T7.24.6.1 (rebuilt)

Minance Exchange, a cryptocurrency trading firm, has suffered data breaches from employee errors, including sensitive documents sent to wrong email addresses and misplaced physical files. A consultant is asked to recommend an existing framework that provides detailed, actionable control guidance (including email and web browser protections) that the firm can implement directly. Which framework is most appropriate?

A. CIS Critical Security Controls

B. ISO 27001, which sets a checklist of requirements for certification and provides no directly implementable advice

C. NIST CSF, used solely as a one-time asset inventory exercise

D. A framework limited to external, intentional threats such as hacking

Solutions • ORR-9 a

Solution ORR-9 a.1 — Answer: A

Bank Q207 • AnalystPrep Q.4482

Step 1 – What frameworks are for

Frameworks "give security managers a systematic way to mitigate cyberthreats and benchmark themselves to good market practice". They are refreshed regularly by experts and serve as quality benchmarks.

Step 2 – Which ones

"Three cybersecurity standards dominate the market": NIST CSF, the CIS Critical Security Controls and ISO/IEC 27001 and 27002.

$\Rightarrow$ Adopt one (or combine them: CIS coexists with NIST and supports ISO certification).

Interpretation

The threats do not wait for a regulator. Where regulation exists, these frameworks are often mandatory or strongly encouraged; where it does not, they are the obvious benchmark.

Why the other options are wrong

B is incorrect. A framework built from scratch forgoes the benchmark to market practice and the expert-maintained, regularly refreshed controls.

C is incorrect. Waiting leaves the bank exposed; the frameworks exist precisely so that firms can act on their own.

D is incorrect. Behavioural controls matter, but "effective risk mitigation emerges from a combination of technical protection measures and appropriate human behaviors".

LO: ORR-9 a: Provide examples of cyber threats and information security risks, and describe frameworks and best practices for managing cyber risks. • **Reference:** GARP ORR Ch.9, Cyber Risk Management: Frameworks and Standards; SchweserNotes 2026 Book 3, Reading 50, LO 50.a

Solution ORR-9 a.2 — Answer: C

Bank Q223 • Schweser Module Quiz 50.1 Q2

Step 1 – Cause

The incident is caused by the firm's own employee, so it is **internal**. That the recipient is a third party describes where the data went, not what caused the incident.

Step 2 – Intent

"Inadvertently" means no deliberate act: loss or involuntary disclosure, the **unintentional** column.

$\Rightarrow$ Internal and unintentional: item 8 of Table 9.1, "errors when sending documents (e-mail recipients or attachments)".

Interpretation

This is the most common leak of all: McAfee found that 43% of data leaks are initiated by insiders, half of them unintentionally. Behavioural controls (awareness, data transfer rules) and detective controls (DLPD) target it. Vardeez's figure places this case in the external quadrant; see the correction box in Section 1.

Why the other options are wrong

A is incorrect. Ignores "inadvertently"; intentional internal incidents are theft or transfer of information by staff.

B is incorrect. Classifies by the recipient; the external, unintentional quadrant holds disasters,

systems disruptions and third-party failures.
D is incorrect. Wrong on both axes: external and intentional describes hacking or phishing by outsiders.

LO: ORR-9 a: Provide examples of cyber threats and information security risks, and describe frameworks and best practices for managing cyber risks. • **Reference:** GARP ORR Ch.9, Table 9.1 (A Typology of Information Security Risks); SchweserNotes 2026 Book 3, Reading 50, LO 50.a

Solution ORR-9 a.3 Answer: B

Bank Q208 • AnalystPrep Q.5110

Step 1 – What sits in the loss column

External: disaster, systems disruptions, third-party failure. Internal: database or back-up loss, loss of devices, sending errors, loss of printed documents, accidental mentions, loss of archives.

Step 2 – Place the virus infection

Item 1 of Table 9.1: "Digital: hacking, virus infection, phishing and other cyberattacks", an external **theft or corruption** incident.
⇒ B is the exception.

Interpretation

The second axis separates deliberate incidents (theft or corruption) from accidental ones (loss or involuntary disclosure); controls differ accordingly.

Why the other options are wrong

A is incorrect. Database loss is item 6, an internal loss incident.
C is incorrect. Systems disruptions are item 3, an external loss incident.
D is incorrect. Loss of printed documents is item 9, an internal loss of non-digital information.

LO: ORR-9 a: Provide examples of cyber threats and information security risks, and describe frameworks and best practices for managing cyber risks. • **Reference:** GARP ORR Ch.9, Table 9.1

Solution ORR-9 a.4 Answer: C

Bank Q217 • AnalystPrep Q.5119

Step 1 – List the Protect actions

Control who logs on to the network and uses devices; use security software; encrypt sensitive data at rest and in transit; back up regularly; update security software, automatically if possible; have formal policies for safely disposing of electronic files and old devices; train everyone.
⇒ A, B and D are Protect actions.

Step 2 – Place the policy

"Create and share a company cybersecurity policy that covers 1) roles and responsibilities for employees, vendors, and anyone else with access to sensitive data" is part of **Identify**, with the asset inventory.
⇒ C is the exception.

Interpretation

Identify sets the scope (what to protect) and the rules (who is responsible); Protect puts the safeguards in place. The sibling swap Identify against Protect is the classic NIST trap.

Why the other options are wrong

A is incorrect. Access control is a Protect action.
B is incorrect. Regular, ideally automated, updating of security software is a Protect action.
D is incorrect. Formal policies for safe disposal of electronic files and old devices are a Protect

action.

LO: ORR-9 a: Provide examples of cyber threats and information security risks, and describe frameworks and best practices for managing cyber risks. • **Reference:** GARP ORR Ch.9, The NIST Framework for Improving Critical Infrastructure Cybersecurity

Solution ORR-9 a.5 — Answer: B

Bank Q221 • BT P2.T7.24.6.2

Step 1 – Define behavioural controls

They "address human behaviors and fallibility when it comes to handling and protecting information": awareness campaigns, rules of conduct, training, password management, supervision and sanctions.

Step 2 – Match Table 9.3

Awareness campaign and fake phishing tests (awareness and prudence) and data transfer rules (data governance) are all behavioural.
$\Rightarrow$ B is wholly behavioural.

Interpretation

The lapses were human error and non-compliance with data governance rules, so the fix has to change behaviour. Technical controls would help as a second layer, but they are not what the question asks for.

Why the other options are wrong

A is incorrect. Firewalls and encryption are technical preventive controls (access management).
C is incorrect. Honeypots and DLPD are technical detective controls.
D is incorrect. Network partitioning is technical architecture and penetration testing is a technical test.

LO: ORR-9 a: Provide examples of cyber threats and information security risks, and describe frameworks and best practices for managing cyber risks. • **Reference:** GARP ORR Ch.9, Essentials of Cybersecurity Protection and Monitoring and Table 9.3

Solution ORR-9 a.6 — Answer: D

Bank Q214 • AnalystPrep Q.5116

Step 1 – What ISO 27001 certification requires

The firm must "have an Information Security Management System (ISMS) that systematically manages the organization's information security risks"; it must "design and implement information security, including effective and comprehensive controls"; and it should "adopt an ongoing risk management process, continuously striving to update and improve", shown through the PDCA cycle.
$\Rightarrow$ A, B and C are requirements.

Step 2 – Where response and recovery guidance comes from

It is a feature of the NIST framework (Respond and Recover). ISO standards "do not provide implementable guidance to firms per se, but rather act as evaluation grids".
$\Rightarrow$ D is not a certification requirement.

Interpretation

ISO certifies a management system; NIST structures the cycle of activities; CIS lists the controls.

Why the other options are wrong

A is incorrect. The ISMS is the core certification requirement.

B is incorrect. Comprehensive, effective controls are required.
C is incorrect. An ongoing, improving risk management process is required.

LO: ORR-9 a: Provide examples of cyber threats and information security risks, and describe frameworks and best practices for managing cyber risks. • **Reference:** GARP ORR Ch.9, ISO/IEC 27001; SchweserNotes 2026 Book 3, Reading 50, LO 50.a

Solution ORR-9 a.7 Answer: A

Bank Q220 • BT P2.T7.24.6.1

Step 1 – Read the need

The firm wants detailed, actionable controls it can implement directly, including e-mail and web browser protections.

Step 2 – Match the framework

CIS guidance "is detailed and works well for companies establishing or reviewing their cybersecurity measures"; Control 9 is "E-mail and Web Browser Protections", with Control 3 (data protection) and Control 14 (security awareness and skills training) relevant too.
$\Rightarrow$ CIS.

Interpretation

The incidents are internal and unintentional (items 8 and 9 of Table 9.1), so the firm needs concrete safeguards plus behavioural training. CIS can also coexist with NIST and support a later ISO 27001 certification.

Why the other options are wrong

B is incorrect. The description of ISO 27001 is accurate, and that is why it does not fit: a certification checklist gives no directly implementable advice.
C is incorrect. Mischaracterises NIST CSF: it covers all five functions, not a one-time inventory, and it is higher-level than CIS's control list.
D is incorrect. The firm's incidents are internal and unintentional, so a framework limited to external, intentional threats misses them.

LO: ORR-9 a: Provide examples of cyber threats and information security risks, and describe frameworks and best practices for managing cyber risks. • **Reference:** GARP ORR Ch.9, CIS Center for Internet Security and Table 9.2

ORR-9 • Cyberthreats and Information Security Risks • Vardeez: UNTIERED (crash-course notes)

ORR-9 b

P1 CONCEPT

Describe lessons learned from the Equifax case study.

Workbook: A23 Cyber Risk and Operational Resilience • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: your August 2026 recall lists "Cyber risk", and the topic map has it at #31 (4 of 16 sources); the reported shape names "the Equifax lessons".
Vardeez: untiered; ORR-9 is rank 9 of 55 in the consolidated volume. Under "LO 48.b" (consolidated volume p.43) his crash-course notes give the 2017 breach (147 million customers, undetected for three months), five weaknesses and the USD 700 million settlement. His list of weaknesses differs from GARP's; use GARP's five (Section 3 and the correction box).

Reported exam shapes

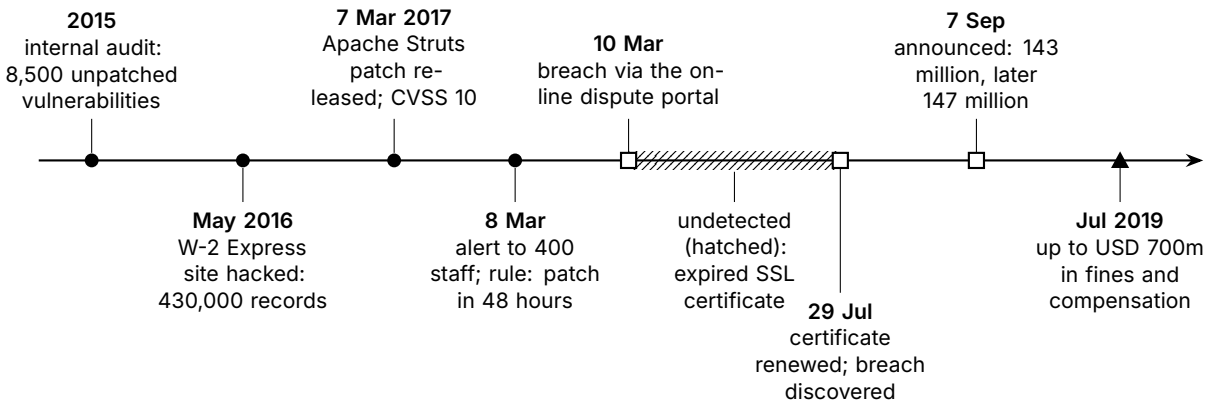
- **S1** (A23) Cyber risk framework, "the one cyber risk question": supervisory practice, frameworks and the Equifax lessons. Here: which weakness caused which failure, and what would have prevented or limited it.

What the questions look like: cause-and-lesson matching. The distractors turn the breach into a zero-day attack, a phishing case or a deliberate decision, or misplace a weakness (the expired certificate stopped detection, not patching).

See also: workbook A23.1 also tags this LO; it is worked under ORR-8 b (option C there is the zero-day trap). The controls and NIST functions used below are in ORR-9 a.

1. The breach on one line

Equifax, one of the largest US credit reporting agencies, was breached through a known, patchable flaw in Apache Struts on its online dispute portal; the attackers moved through the network for months and took the personal data of 147 million customers.



Gaps: 7 to 10 Mar, 3 days; 10 Mar to 29 Jul, 141 days; 29 Jul to 7 Sep, 40 days (about six weeks).

Figure 1. The Equifax timeline (schematic, not to scale). Filled circles: warnings before the attack; open squares: the breach, its discovery and its disclosure; filled triangle: the settlement. The hatched band is the period the attackers went undetected.

2. A breach that "should not have come as a surprise"

- **Before 2017.** Frameworks, policies and tools were "outdated and poorly maintained". A 2015 internal audit found a backlog of **8,500 unpatched vulnerabilities** caused by severe weaknesses in patch management, while the CSO was still developing the firm's first patch-management policy. In May 2016 the W-2 Express website was hacked (430,000 names, addresses, social security numbers). By 2017 most deficiencies were unremediated.
- **The attack.** The Apache Struts patch was released on **7 March 2017**; an alert reached Equifax on 8 March and the Global Threats and Vulnerability Management (GTVM) team sent it to **400 employees**. NIST had given the flaw the highest Common Vulnerability Scoring System score, **10**. The patch "was never implemented". On **10 March** attackers entered through the online dispute portal, moved to other parts of the network and extracted names, addresses, dates of birth, social security numbers and credit card accounts.
- **Not a zero-day.** A patch existed three days before the attack, and policy required critical vulnerabilities to be patched within 48 hours: by 10 March, the day of the breach.

3. The five weaknesses and their lessons

Compared with market standards in information security management, the analysis found five key weaknesses:

Weakness (GARP order)	What happened	Lesson, control type
1 No comprehensive inventory of IT assets	GTVM could not locate Apache Struts to patch it within 48 hours of the critical alert	Identify: keep a complete asset inventory
2 Failure to enforce risk policy, above all patch management	"Failing to patch a system is equivalent to leaving a door unlocked"; the 2015 backlog stayed	Protect: enforce patching; KRI on overdue patches
3 Inconsistent internal communication on remediation	An employee who knew Struts was in use was not on the distribution list; his manager received the alert and did not relay it	Governance: escalation and prioritisation of alerts
4 Expired SSL certificate on the tool that inspects encrypted traffic	For months Equifax could not monitor encrypted traffic; only after renewing it on 29 July did it see the suspicious activity	Detect: maintain detective controls
5 Poor external communication in the crisis	Public announcement only on 7 September, six weeks after discovery; the three Rs of crisis communication (regret, reason, remedy) were not applied	Respond: notify fast and transparently

Fallout. About USD 5bn of a USD 15.5bn market capitalisation was lost in the week after the announcement; several federal investigations, fines and lawsuits followed, and the CEO, CSO and CIO resigned. In July 2019 Equifax agreed to pay up to **USD 700 million** in fines and compensation, **USD 300 million** of it for the individuals affected (each could choose up to USD 125 or free credit monitoring at Equifax, Experian and TransUnion). Equifax then overhauled its IT security system and management.

The lesson GARP draws. "Such large operational risk events do not have a single cause; they emerge in weak operating environments, characterized by multiple deficiencies in governance and procedures, breakdowns in communication, and lack of prioritization in alerts and actions." Each weak-

ness on its own might have been survivable; together they turned a three-day-old patch into one of the largest breaches on record.

Correction to the source notes. (1) Vardeez says the internal audit "revealed a backlog of unpatched vulnerabilities, *including the exploited one*". It could not have: the audit was in 2015 and the Apache Struts patch was released on 7 March 2017. (2) Vardeez's five weaknesses (outdated practices, unpatched vulnerabilities, patch-policy failure, ineffective communication, weak monitoring) are not GARP's five. GARP lists **no comprehensive IT asset inventory** and **poor external communication**, both of which Vardeez omits; outdated practices and the 8,500 backlog are background, not separate weaknesses. Use GARP's list (Questions ORR-9 b.1 and b.2 test the two he omits). (3) SchweserNotes says the attack came "a few days after Equifax applied a patch" and exploited "a vulnerability in the patch". GARP: the patch was released by Apache and **never applied** by Equifax; the attackers exploited the unpatched flaw. (4) GARP is inconsistent across chapters: Box 1.1 (Ch.1) says Equifax took two months to reveal a hack of 145 million customers and lost USD 3.5 billion of market value; Ch.4 says it took three months to identify the leak. Use the Ch.9 figures: discovery on 29 July, disclosure six weeks later, 143 million rising to 147 million, about USD 5bn of USD 15.5bn. The sources' "three months" undetected understates GARP's own dates (10 March to 29 July is 141 days, about four and a half months); expect the exam wording "three months" or "over three months".

Exam traps

- **Zero-day.** It was not one: the patch existed three days before the attack.
- **Patch applied.** It was never applied (the SchweserNotes slip above).
- **Weakness to failure.** The missing asset inventory is why the team could not patch; the expired certificate is why the breach went undetected; external communication is why the damage grew.
- **Phishing.** Neither a phishing attack nor a lack of phishing exercises is part of the case.
- **Deliberate.** Nobody chose to ignore the patch or disable alerts; the failures were process, communication and maintenance.
- **Single cause.** GARP's lesson is multiple deficiencies in a weak control environment.
- **Numbers.** 147 million (first announced as 143 million); USD 700 million (USD 300 million to individuals); 8,500 unpatched vulnerabilities in 2015; 400 employees alerted; 48-hour rule; CVSS 10.

Practice questions: ORR-9 b

Question ORR-9 b.1

Bank Q231 • Schweser Module Quiz 50.1 Q4

Which of the following issues was not identified as a key weakness in Equifax's information security management?

A. Poor public communication.

B. Using an expired digital certificate.

C. Lack of a comprehensive list of its IT assets.

D. Lack of sufficient internal phishing exercises.

Question ORR-9 b.2

Bank Q230 • BT P2.T7.24.6.3 (rebuilt)

Equifax's Global Threats and Vulnerability Management team was expected to patch a critical vulnerability within 48 hours but could not patch Apache Struts. Which Equifax weakness most directly explains this failure?

A. A lack of a comprehensive inventory of IT assets, so the team could not locate where Apache Struts was used.

B. The use of an expired SSL certificate, which blocked inspection of encrypted traffic.

C. Poor public communication, with the announcement delayed until September 7, 2017.

D. The absence of any vendor patch for the vulnerability at the time of the alert.

Question ORR-9 b.3

Bank Q225 • AP Mock 1 Q32

Following the Equifax data breach in 2017, which measure would have been most effective in preventing the incident?

A. Implementing stronger encryption methods for stored data.

B. Regular audits and compliance checks to ensure security protocols are followed.

C. Conducting regular employee training on data security and phishing attacks.

D. Updating and patching security software immediately upon availability of fixes.

Question ORR-9 b.4

Bank Q228 • AnalystPrep Q.6533

Which of the following best describes how ineffective internal controls at Equifax contributed to the breach?

A. Equifax lacked a cybersecurity framework, making it impossible to detect threats.

B. Equifax's monitoring system failed to detect and prevent unauthorized access to sensitive data.

C. Equifax employees intentionally disabled security alerts, allowing hackers to remain undetected.

D. Equifax lacked sufficient financial resources to invest in cybersecurity controls.

Question ORR-9 b.5 Bank Q229 • AnalystPrep Q.6534, Q.6535

Which of the following best explains how poor breach disclosure practices worsened the impact of the Equifax data breach?

A. Equifax immediately informed the public and regulators, minimizing reputational damage.

B. Equifax delayed disclosing the breach, leading to increased regulatory scrutiny and public backlash.

C. Equifax disclosed the breach before understanding its full impact, which helped reduce penalties.

D. Equifax fully complied with disclosure regulations, avoiding any negative consequences.

Question ORR-9 b.6 Bank Q226 • AnalystPrep Q.6531

Which of the following lessons from the Equifax case study is most likely applicable to financial institutions seeking to enhance their cybersecurity risk management framework?

A. A well-developed incident response plan can significantly reduce reputational and financial damage from cyber breaches.

B. Outsourcing cybersecurity functions reduces the risk exposure of financial institutions.

C. Prioritizing cost reduction over cybersecurity investments leads to stronger operational resilience.

D. Delaying disclosure of a cybersecurity breach allows financial institutions to manage public relations better and minimize regulatory penalties.

Solutions • ORR-9 b

Solution ORR-9 b.1

Answer: D

Bank Q231 • Schweser Module Quiz 50.1 Q4

Step 1 – List GARP's five weaknesses

No comprehensive IT asset inventory; failure to enforce the patch management policy; inconsistent internal communication on remediation; an expired SSL certificate; poor external communication.

⇒ A is the fifth, B the fourth, C the first.

Step 2 – Check D

Phishing exercises appear nowhere in the case: the attack was a technical exploit of an unpatched web application, not a phishing campaign.

⇒ D is the exception.

Interpretation

Read the five as a chain: no inventory and no enforcement left the door open; poor internal communication meant nobody closed it; the expired certificate meant nobody saw the intruder; poor external communication multiplied the damage.

Why the other options are wrong

A is incorrect. Poor public (external) communication is weakness 5.

B is incorrect. The expired SSL certificate is weakness 4.

C is incorrect. The lack of a comprehensive IT asset inventory is weakness 1.

LO: ORR-9 b: Describe lessons learned from the Equifax case study. • **Reference:** GARP ORR Ch.9, Case Study of a Cyberattack: Equifax; SchweserNotes 2026 Book 3, Reading 50, LO 50.b

Solution ORR-9 b.2

Answer: A

Bank Q230 • BT P2.T7.24.6.3

Step 1 – Was a patch available?

Yes: released on 7 March 2017 and alerted to Equifax on 8 March, two days before the 10 March attack.

⇒ D is out.

Step 2 – Why the team could not apply it

The lack of a comprehensive inventory of IT assets "made the Equifax GTVM teams unable to locate and patch Apache Struts, as they should have done within the 48 hours of a critical vulnerability alerted".

⇒ A.

Interpretation

You cannot patch what you cannot find: asset inventory is the first NIST function (Identify) and the first two CIS controls. The other weaknesses explain later stages of the failure, not the missed patch.

Why the other options are wrong

B is incorrect. The expired certificate explains why the intrusion went undetected for months; it did not stop the patching.

C is incorrect. The late announcement came after discovery and had nothing to do with the patch.

D is incorrect. A patch had been released three days before the attack; this was not a zero-day.

LO: ORR-9 b: Describe lessons learned from the Equifax case study. • **Reference:** GARP ORR Ch.9, Case Study of a Cyberattack: Equifax (weakness 1)

Solution ORR-9 b.3 — Answer: D

Bank Q225 • AP Mock 1 Q32

Step 1 – Identify the attack vector

An external intrusion through a known Apache Struts vulnerability in the online dispute portal, for which a patch existed from 7 March 2017.

Step 2 – The control that closes the vector

Patch management: Equifax's own rule was to patch critical vulnerabilities within 48 hours. "Failing to patch a system is equivalent to leaving a door unlocked in the physical world."
⇒ Timely patching would have prevented the intrusion itself.

Interpretation

Prevention is the question, so the answer is the preventive control that was missing on the exploited system. Detective (the SSL certificate) and response (disclosure) failures made the damage worse but did not let the attackers in.

Why the other options are wrong

A is incorrect. Encryption of stored data limits what stolen data is worth; it does not stop an intrusion through an unpatched system.
B is incorrect. The 2015 internal audit had already found 8,500 unpatched vulnerabilities; the failure was enforcing remediation, not auditing.
C is incorrect. Phishing was not the attack vector; training addresses a different threat.

LO: ORR-9 b: Describe lessons learned from the Equifax case study. • **Reference:** GARP ORR Ch.9, Case Study of a Cyberattack: Equifax (weakness 2)

Solution ORR-9 b.4 — Answer: B

Bank Q228 • AnalystPrep Q.6533

Step 1 – The detective control that failed

An expired SSL certificate on the tool designed to inspect encrypted network traffic meant that "for months" Equifax could not monitor that traffic, "including the hacking activity".

Step 2 – The consequence

Only on 29 July, after updating the certificate, did Equifax notice the suspicious activity and discover the breach, over three months after it started.
⇒ Monitoring failed to detect and stop the access: B.

Interpretation

A detective control is only as good as its maintenance. A KRI such as "overdue renewal of security certificates" or "monitoring coverage of encrypted traffic" would have flagged the gap.

Why the other options are wrong

A is incorrect. Equifax had frameworks; they were outdated and poorly maintained, not absent.
C is incorrect. No deliberate disabling is reported; the certificate had simply expired.
D is incorrect. The case attributes the failures to governance, procedures and communication, not to a lack of funds.

LO: ORR-9 b: Describe lessons learned from the Equifax case study. • **Reference:** GARP ORR Ch.9, Case Study of a Cyberattack: Equifax (weakness 4)

Solution ORR-9 b.5 — Answer: B

Bank Q229 • AnalystPrep Q.6534, Q.6535

Step 1 – The timing

Breach discovered on 29 July 2017; public announcement only on 7 September, "six weeks after its discovery".

Step 2 – The consequence

"As much as for the breach, Equifax has been blamed for its lack of transparency to its customers." The three Rs of crisis communication (regret, reason, remedy) "were not applied here". Investigations, fines and lawsuits followed.

$\Rightarrow$ B.

Interpretation

Disclosure is part of the Respond function: notifying the people whose data is at risk. Delay turns an operational loss into a reputational one.

Why the other options are wrong

A is incorrect. Contradicts the facts: disclosure was six weeks late.

C is incorrect. Disclosure was late, not premature, and penalties were large (up to USD 700 million).

D is incorrect. Equifax faced federal investigations, fines, lawsuits and senior resignations.

LO: ORR-9 b: Describe lessons learned from the Equifax case study. • **Reference:** GARP ORR Ch.9, Case Study of a Cyberattack: Equifax (weakness 5); GARP ORR Ch.5 (three Rs of crisis communication)

Solution ORR-9 b.6 — Answer: A

Bank Q226 • AnalystPrep Q.6531

Step 1 – Recall the response failure

Equifax disclosed six weeks after discovery and without the three Rs, and was blamed for its lack of transparency as much as for the breach.

Step 2 – Turn it into a lesson

A tested response plan (NIST Respond: notify stakeholders, keep operations running, report, contain, learn) with a crisis-communication protocol limits reputational and financial damage.

$\Rightarrow$ A.

Interpretation

The broader lesson is GARP's: large events have multiple causes in a weak environment. Prevention (inventory, patching), detection (maintained monitoring) and response (fast, transparent disclosure) all failed; fixing any one would have reduced the loss.

Why the other options are wrong

B is incorrect. The case contains no outsourcing angle; the failures were Equifax's own processes, and outsourcing never transfers accountability (ORR-8 e).

C is incorrect. Outdated, under-maintained controls were the root of the problem; cutting security spending weakens resilience.

D is incorrect. The six-week delay drew blame and worsened the damage.

LO: ORR-9 b: Describe lessons learned from the Equifax case study. • **Reference:** GARP ORR Ch.9, Case Study of a Cyberattack: Equifax

ORR-10 • Sound Management of Risks related to Money Laundering and Financing of Terrorism • Vardeez: VERY IMPORTANT

ORR-10 a

P1 CONCEPT

Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks.

Workbook: A29 Money Laundering and Financing of Terrorism • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: your August 2026 recall lists "ML AFT" (read as ML/FT), one question, and the topic map has it at #50 (2 of 16 sources).
Vardeez: ORR-10 sits in theme 1 of his ORR list (TPRM, AML and outsourcing) and is rank 33 of 55 in the consolidated volume, tagged a quick win. His notes label this LO "LO 49.a" (consolidated volume p.140) and build it in four steps: risk assessment, risk management (board and chief AML/CFT officer), risk mitigation (three lines of defence) and risk monitoring (IT systems and STRs).

Reported exam shapes

- **S1** Governance role trap: who files suspicious transaction reports and is the contact point for supervisors and FIUs, and what the chief AML/CFT officer may and may not combine.
- **S4** The three stages of laundering: placement, layering, integration (tested inside workbook Q1).

What the questions look like: a bank reviews or redesigns its AML/CFT programme and you pick the arrangement the Basel guidelines support. The distractor is almost always a real duty given to the wrong actor: the CRO as such filing STRs, the front office reporting straight to the FIU, the chief AML/CFT officer auditing his own framework.

See also: workbook A29.1 is worked here (Question ORR-10 a.8); it also tags ORR-10 b, ORR-10 c and ORR-11 a. Customer due diligence is ORR-10 b; group-wide and cross-border practice is ORR-10 c. The stages of laundering come from GARP Ch.11; they are set out here (Section 6) and recapped under ORR-11 a.

1. What the guidelines are and why they matter

The Basel Committee's guidelines (BCBS, revised July 2020; GARP Ch.10 reprints paragraphs 1 to 83) show how banks should fold money laundering (ML) and financing of terrorism (FT) risks into their *overall* risk management. They support national implementation of the FATF standards and "in no way" modify them, either by strengthening or by weakening them. Core Principle 29 asks for "adequate policies and processes, including strict customer due diligence (CDD) rules", so that the bank is not used, intentionally or unintentionally, for criminal activities.

- **Why a prudential body cares:** sound ML/FT risk management serves the **safety and soundness** of banks and protects the reputation of banks and national banking systems; it preserves the **integrity of the international financial system**.
- **What weak management costs:** reputational, operational, compliance and concentration risks, all interrelated; fines and sanctions, terminated wholesale funding, claims, investigation costs, asset seizures and freezes, loan losses, diverted management time.
- **How:** every measure is **proportional and risk-based**, informed by the bank's own ML/FT risk

assessment. The guidelines apply to all banks; small or specialised banks may adapt them.

2. Assessment: understand the inherent risk first

The bank identifies inherent and residual risk at the **country, sectoral, bank and business-relationship** level, across its **customer base, products, delivery channels and services** (including products under development) and the **jurisdictions** where it or its customers do business. It uses internal data (operational and transaction data) and external sources (**national risk assessments, country reports** from international organisations). Policies for acceptance, CDD and monitoring are then set to control that risk, and the residual risk must fit the bank's risk profile and be **demonstrable to the supervisor** (paras 15 and 16).

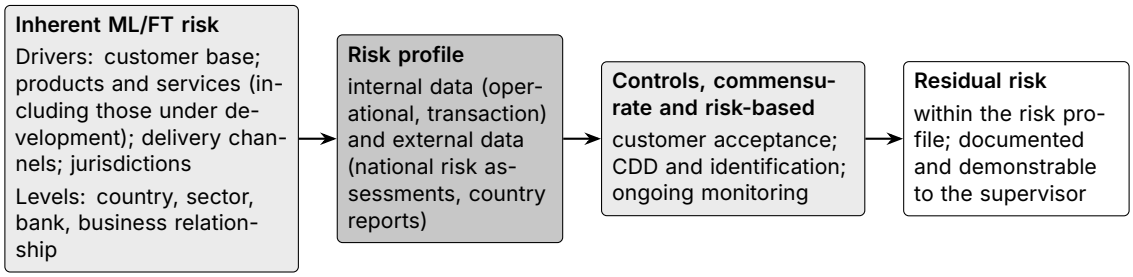


Figure 1. The assessment drives everything else (paras 15 and 16). The risk profile (mid grey) sets the controls; the residual risk the controls leave (open box) must fit the profile.

3. Management: the board and the chief AML/CFT officer (shape S1)

The **board** approves and oversees ML/FT policy, must understand ML/FT risk and receives timely, complete, understandable and accurate information on it. The **board and senior management appoint a qualified chief AML/CFT officer** with overall responsibility for the AML/CFT function and the stature to be heard by the board, senior management and business lines (paras 17 and 18). The officer:

- runs **ongoing monitoring** of the fulfilment of all AML/CFT duties (sample testing, exception reports, alerting senior management or the board) (para 22);
- is the **contact point for all AML/CFT issues** for internal and external authorities, **including supervisors and FIUs** (para 22);
- is **responsible for reporting suspicious transactions** (para 25), assesses the alerts of the IT monitoring system (para 30) and ensures prompt disclosure where suspected proceeds of crime remain in an account (para 57).

The role MAY (para 24)	The role may NOT (para 23)
also be the **chief risk officer** or the **chief compliance officer** or equivalent, with a **direct reporting line to senior management or the board**; if duties are separated, the officers' relationship must be clearly defined	hold **business line** responsibilities, or be entrusted with **data protection** or the **internal audit** function (conflicts of interest, whatever the bank's size)

The role trap, stated precisely. STR filing and FIU contact attach to the *role*, not to a title. A CRO acting only as CRO does neither; a CRO appointed chief AML/CFT officer does both, because the duties come with the role. The front office *detects* and escalates internally; internal audit *evaluates*. Neither reports to the FIU.

4. Mitigation: the three lines of defence

Line 1 (business units) owns the risk, works to written policies with procedures to detect and report suspicious transactions, screens prospective and existing staff, and gets **ongoing training** tailored by function, responsibility, length of service and risk, with refreshers (paras 19 to 21). Line 2 is the chief AML/CFT officer and compliance, "but also human resources or technology". Line 3, internal audit, reports to the board's **audit committee** and audits (i) the adequacy of policies, (ii) staff implementation, (iii) compliance oversight and quality control **including alert parameters**, and (iv) training, at a risk-based frequency, and also evaluates the IT system (paras 26 and 31). External auditors may also evaluate controls and compliance (para 27).

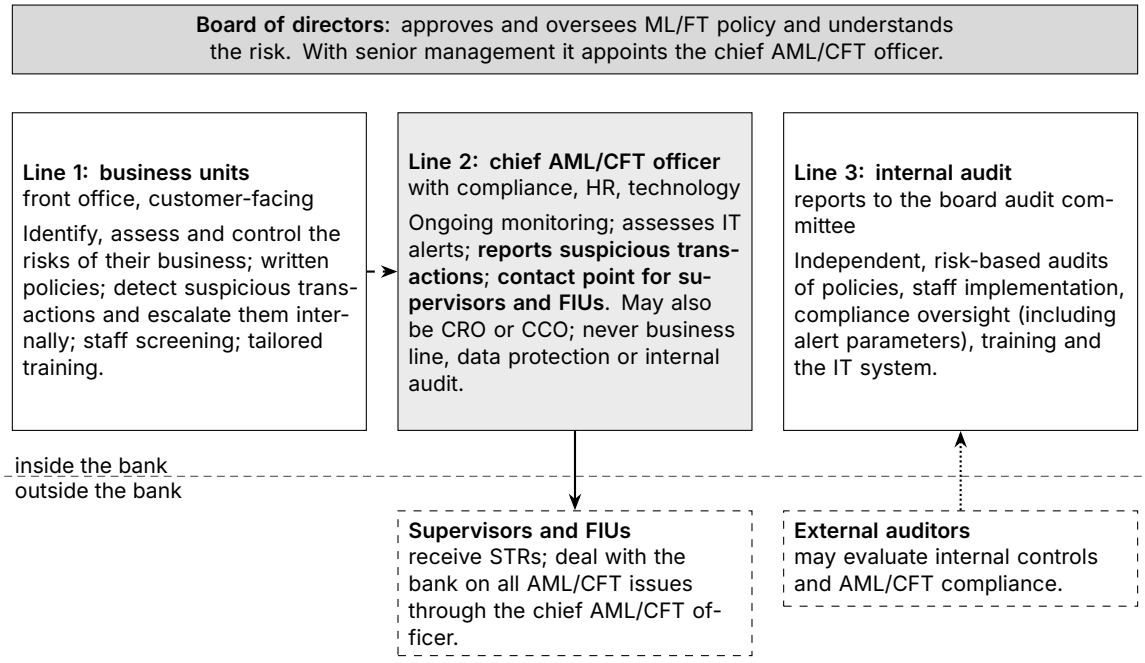


Figure 2. The three lines inside the bank (solid boxes) and the parties outside it (dashed boxes). Dashed arrow: internal escalation from the front office. Solid arrow: the only reporting channel to supervisors and the FIU, through the chief AML/CFT officer (shaded). Dotted arrow: external audit's review.

Correction to the source notes. The question bank's explanation for Bank Q247 (GARP PE1 Q40) says staff screening "belongs to human resources within the second line". GARP's own key for PE2 Q65 (Bank Q248, Question ORR-10 a.4) gives screening of potential employees to the **business units, as part of the first line**, which is where the guidelines discuss it (paras 20 and 21), and the workbook (A29) agrees. Use the first-line reading.

5. Monitoring and suspicious transaction reports

- **Scale and automation.** The system fits the bank's size, activities, complexity and risks; for most banks, especially internationally active ones, it is automated. A bank that decides it needs no IT system must **document** that decision and show its supervisor or external auditors an **effective alternative** (para 28).
- **Coverage and parameters.** It covers **all** customer accounts and transactions, supports trend analysis and tracks changes in customers' transactional profiles. Vendor default parameters are allowed only if they reflect **the bank's own risk**; the bank sets its own criteria for extra monitoring or an STR, and alerts go to the chief AML/CFT officer (paras 28 to 30).
- **Reporting.** Monitoring lets the bank eliminate false positives and report genuine suspicious trans-

actions **promptly to the FIU**, through a written, trained, confidential process; it then reviews the customer's risk classification and escalates the relationship (paras 56 to 58). The customer is never told (no tipping off, para 41).

6. The three stages of laundering (shape S4)

GARP Ch.11 describes how criminals turn proceeds into apparently legitimate funds: **placement, layering and integration** (also called extraction). The August workbook question (Question ORR-10 a.8) tests which stage a technique belongs to.

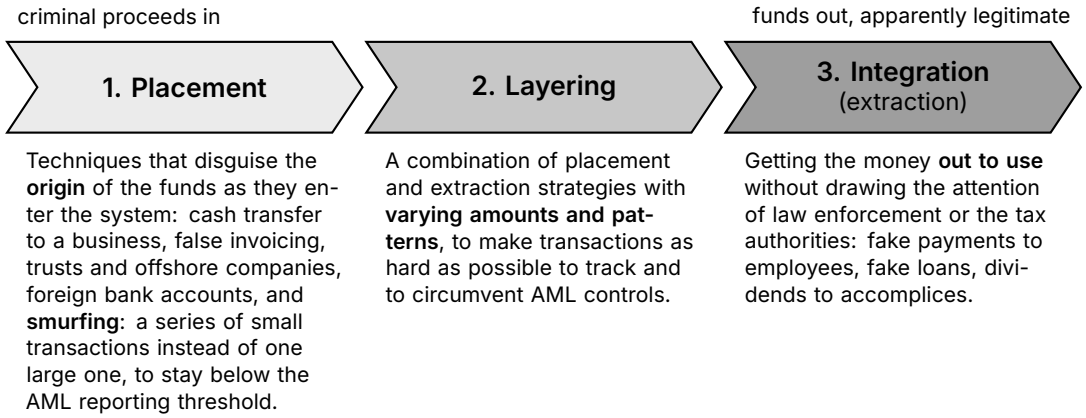


Figure 3. The three stages of laundering (GARP Ch.11, AML Risk Management). Shading deepens as the funds move away from their criminal origin. Smurfing is placement; layering mixes amounts and patterns; integration takes the money out for use.

Comparison card: ORR-10 a, who does what

Actor	Does	Does not
Board	approves and oversees ML/FT policy; understands the risk; with senior management appoints the chief AML/CFT officer	review individual customer files
Business units (line 1)	own the risk of their business; CDD; detect and escalate suspicious transactions; staff screening and training	report directly to the FIU
Chief AML/CFT officer (line 2)	ongoing monitoring; assesses alerts; **files STRs**; **contact point for supervisors and FIUs**	hold business line, data protection or internal audit duties
Internal audit (line 3)	independent, risk-based audit of policies, staff, oversight (alert parameters), training, IT system; reports to the audit committee	write or amend policy; run monitoring
External auditors	may evaluate controls and compliance	replace internal audit
Supervisors, FIUs	receive STRs; deal with the bank via the chief AML/CFT officer	form one of the bank's three lines

Exam traps

- **Role misassignment.** STRs and the supervisor and FIU contact point belong to the chief AML/CFT officer, not to the CRO as such, the front office or internal audit. If the CRO holds the role, the duties come with it.

- **Forbidden combinations.** Business line, data protection or internal audit duties are out; combining with the CRO or chief compliance officer is allowed.
- **Supervisors as a line of defence.** The three lines are all inside the bank.
- **Internal data only.** The assessment also uses national risk assessments and country reports.
- **Threshold monitoring and vendor defaults.** Monitoring covers all transactions; standard parameters must reflect the bank's own risk; no IT system only with a documented, effective alternative.
- **Stage swap.** Smurfing is placement, not layering.

Practice questions: ORR-10 a

Question ORR-10 a.1

Bank Q249 • Mock 1 Q20

Banks have three lines of defense for mitigating money laundering (ML) and the financing of terrorism (FT) risks. Which of the following is NOT one of these lines of defense?

A. Business units.

B. Regulatory authorities.

C. The chief ML/FT officer.

D. Internal and external audits.

Question ORR-10 a.2

Bank Q253 • AP Mock 3 Q15 (rebuilt)

Which of the following best describes the primary reason the Basel Committee is committed to sound anti-money laundering and countering the financing of terrorism (AML/CFT) policies in banks?

A. To enforce the Financial Action Task Force recommendations as binding law on banks

B. To strengthen the safety and soundness of banks and preserve the integrity of the international financial system

C. To protect customers from the cost and inconvenience of identification procedures

D. To protect the integrity of securities and capital markets as a whole

Question ORR-10 a.3

Bank Q251 • Schweser Module Quiz 51.1 Q1

Which of the following is an example of external data that the chief Anti-Money Laundering and Countering Financing of Terrorism (AML/CFT) officer should analyze and understand in order to manage and mitigate ML/FT risks?

A. Transaction data.

B. Payment message streams.

C. Country reports.

D. Customer passports and identity cards.

Question ORR-10 a.4 Bank Q248 • GARP PE2 Q65 • Mock 4 Q66

The board of directors at a large bank wants to improve the bank's practices for managing money laundering and financing of terrorism (ML/FT) risk. The risk committee meets to discuss ways to achieve this objective that conform to best practices. Which of the following actions would be most appropriate for the bank to recommend?

A. Require the bank's business units to screen potential employees as part of the first line of defense in managing ML/FT risk.

B. Establish a threshold transaction value and review all transactions above this threshold for evidence of ML/FT.

C. Exclude politically exposed persons (PEPs) from screening for ML/FT risk due to their much lower ML/FT risk.

D. Give the compliance and legal functions the primary responsibility for managing ML/FT risk.

Question ORR-10 a.5 Bank Q240 • AnalystPrep Q.3130 (rebuilt)

A large banking group's AML programme covers suspicious transaction reporting, customer identification, information sharing, account monitoring and red-flag identification. Staff in all 12 branches attend mandatory AML/CFT training twice a year, delivered online, and the board is trained separately by an outside expert. The programme appoints a chief AML/CFT officer, who personally audits the AML/CFT framework twice a year. In what respect does the programme need improvement?

A. The AML/CFT framework should be audited more than twice a year.

B. Employees should be trained in a classroom, not online.

C. The group should consolidate training across branches into a single event.

D. The audit should be performed independently (internal audit), not by the chief AML/CFT officer.

Question ORR-10 a.6

Bank Q247 • GARP PE1 Q40

A regional bank follows the three lines of defense approach for managing its operational risk. The CRO of the bank is concerned that several competing banks have recently received regulatory fines resulting from poor management of risks related to money laundering and financing of terrorism (ML/FT), and wants to improve the bank's management of these risks. The CRO reviews the Basel Committee guidelines for the management of ML/FT risks and suggests that the bank adopt industry best practices for different business functions in each line of defense. Which of the following would be most appropriate for the CRO to recommend addressing ML/FT risks?

A. The chief officer in charge of ML/FT risk should be responsible for monitoring and managing these risks within each of the business lines on a daily basis.

B. The CRO should serve as the primary point of contact with regulatory supervisors and financial intelligence units on any issues related to ML/FT risk.

C. Internal and external auditors should evaluate the bank's risk controls to ensure that they are effective in managing ML/FT risk as well as compliant with regulations.

D. The corporate operational risk function should screen current and prospective employees as part of the second line of defense in managing ML/FT risk.

Question ORR-10 a.7

Bank Q245 • BT P2.T7.20.5.3

After reviewing and updating its money laundering and financing of terrorism (ML/FT) policies, an international bank circulates the following five policies to its staff:

(i) We classify ML/FT risk as an operational risk but, owing to the intensity of the issues and risks, ML/FT risks will receive special attention (and resources) as an emergent sub-field of operational risk.

(ii) With respect to ML/FT risk, we will maintain three lines of defense: the business units; the chief ML/FT officer, who reports to the CRO; and internal audit.

(iii) For each customer or business relationship, a profile of normal activity should be built to support the identification of abnormal activity.

(iv) Because we have a presence in multiple countries, we should understand and abide by laws and regulations in each country. If a country's laws and regulations prevent adequate management of ML/FT risks, we should consider the cessation of business in that country.

(v) Subsequent to the KYC process, our customers are entitled to absolute confidentiality and privacy, so that neither can their activity be monitored nor can we proactively report suspicious activity to law enforcement authorities (we can only respond reactively, case by case, to specific queries).

Which of these five policies is a problem and needs to be revised; that is, which of the following statements is TRUE?

A. None are a problem: all five of these policies are sound

B. The bank cannot generate profiles of customers due to discrimination laws

C. The three lines of defense do not apply to ML/FT risks because only two can effectively play a role

D. Absolute confidentiality is incorrect because the bank must monitor (and document) activity and should report suspicious activity

Question ORR-10 a.8 Workbook A29.1 • S1, S2, S3, S4 • Aug-2026 • Map #50

The board of a mid-size Singapore bank has appointed the bank's CRO as its chief AML/CFT officer, with a direct reporting line to the board. An internal auditor is reviewing the bank's revised AML/CFT manual, which covers governance, customer onboarding, correspondent banking and staff training. Which of the following statements in the manual is correct?

A. The training module classifies smurfing, splitting a large cash sum into many small deposits below the reporting threshold, as layering, the stage that mixes amounts and patterns.

B. In the combined role, the CRO as chief AML/CFT officer is responsible for reporting suspicious transactions and is the contact point for supervisors and the FIU on AML/CFT issues.

C. Where a new customer's first deposit comes from her own account at another bank subject to the same CDD standard, the bank may rely on that bank's due diligence instead of its own.

D. Because every correspondent banking relationship carries the same level of ML/FT risk, the manual applies identical enhanced due diligence to every respondent bank.

Solutions • ORR-10 a

Solution ORR-10 a.1

Answer: B

Bank Q249 • Mock 1 Q20

Step 1 – Name the three lines (para 19)

First line: the business units (front office, customer-facing activity). Second line: the chief AML/CFT officer and the compliance function, with human resources and technology. Third line: internal audit, reporting to the board's audit committee; external auditors may also evaluate controls (para 27).

⇒ Every line sits inside the bank.

Step 2 – Place the regulators

Supervisors and FIUs are external authorities. The bank deals with them through the chief AML/CFT officer, its contact point for all AML/CFT issues (para 22).

⇒ Regulators oversee the three lines; they are not one of them.

Interpretation

The lines of defence are a division of labour within the bank: own the risk, oversee it, assure it. Supervisors judge the whole arrangement from outside. A question that lists "the supervisor" or "regulatory authorities" next to the three internal functions is testing exactly this boundary.

Why the other options are wrong

A is incorrect. Business units are the first line of defence.

C is incorrect. The chief ML/FT (AML/CFT) officer heads the second line.

D is incorrect. Internal audit is the third line, and the guidelines give external auditors a role in evaluating controls and AML/CFT compliance, so the option describes the assurance line.

LO: ORR-10 a: Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 19 to 27; SchweserNotes 2026 Book 3, Reading 51, LO 51.a

Solution ORR-10 a.2

Answer: B

Bank Q253 • AP Mock 3 Q15

Step 1 – Start from the Committee's mandate

Para 5: the Committee's commitment is fully aligned with its mandate "to strengthen the regulation, supervision and practices of banks worldwide with the purpose of enhancing financial stability". Sound ML/FT risk management is relevant to safety and soundness: it protects the reputation of banks and national banking systems, and preserves the integrity of the international financial system.

⇒ The motive is prudential: safe banks and a sound international system.

Step 2 – Place the FATF

The guidelines support national implementation of the FATF standards and are consistent with them; they "in no way" modify them, "either by strengthening or weakening them" (para 3).

⇒ The Committee issues supervisory guidance; it neither legislates nor enforces FATF rules.

Interpretation

Para 6 lists what is at stake for a bank without sound ML/FT risk management: reputational, operational, compliance and concentration risks, and the costs of fines, lost wholesale funding, claims, investigations, asset seizures and freezes.

Why the other options are wrong

A is incorrect. The Committee supports and supplements the FATF standards; it does not enforce them, and its guidelines are not binding law.
C is incorrect. CDD adds steps for customers. The only customer-side concern in the guidelines is that the acceptance policy should not deny banking to the financially or socially disadvantaged (para 33).
D is incorrect. Securities and capital markets are the business of securities regulators; the Committee's mandate is banks and banking systems.

LO: ORR-10 a: Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 1 to 7

Solution ORR-10 a.3 — Answer: C

Bank Q251 • Schweser Module Quiz 51.1 Q1

Step 1 – What the understanding must rest on (para 16)

Internal: "specific operational and transaction data and other internal information collected by the bank". External: "national risk assessments and country reports from international organisations".

Step 2 – Classify each option

Transaction data and payment message streams are generated by the bank's own processing; passports and identity cards are collected by the bank during CDD. All three are internal. Country reports come from outside the bank.
⇒ Only C is external data.

Interpretation

The assessment needs both views. Internal data shows what the bank's own customers do; external sources show the jurisdiction and sector risk that no single bank sees on its own.

Why the other options are wrong

A is incorrect. Transaction data is internal operational data.
B is incorrect. Payment message streams come from the bank's own payment processing: internal.
D is incorrect. Identity documents are internal records gathered for CDD.

LO: ORR-10 a: Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 15 and 16; SchweserNotes 2026 Book 3, Reading 51, LO 51.a

Solution ORR-10 a.4 — Answer: A

Bank Q248 • GARP PE2 Q65

Step 1 – What the first line does (paras 19 to 21)

Business units identify, assess and control the risks of their business, under written policies with procedures for detecting and reporting suspicious transactions. The same paragraphs require "adequate policies and processes for screening prospective and existing staff to ensure high ethical and professional standards" and ongoing training.
⇒ Screening potential employees is a first-line practice, and GARP keys it that way.

Step 2 – Test the threshold idea

The monitoring system covers *all* accounts and transactions (para 28), with intensity set by risk (para 45). FT transactions "may be conducted in very small amounts" (para 59), and smurfing

is designed to stay under thresholds.
⇒ A value cut-off is the opposite of risk-based monitoring.

Step 3 – Test the PEP idea
Enhanced due diligence may be essential for a PEP and is *required* for foreign PEPs (para 34).

Interpretation
The guidelines list human resources in the second line as a support function (para 19), but the screening duty itself sits in the first-line paragraphs. That is the reading GARP uses here (see the correction box in Section 4).

Why the other options are wrong
B is incorrect. Monitoring only above a value threshold leaves smaller transactions unseen, invites structuring below it and misses FT, which can run in very small amounts.
C is incorrect. Polarity flip: PEPs are higher-risk customers who call for enhanced due diligence, not exclusion from screening.
D is incorrect. Compliance belongs to the second line. Primary responsibility for the risk lies with the business units that generate it.

LO: ORR-10 a: Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 19 to 21, 28, 34, 45 and 59

Solution ORR-10 a.5 **Answer: D**

Bank Q240 • AnalystPrep Q.3130

Step 1 – Look for a forbidden combination
Para 23: to avoid conflicts of interest the chief AML/CFT officer should not have business line responsibilities and "should not be entrusted with responsibilities in the context of data protection or the function of internal audit". Para 26: internal audit, the third line, independently evaluates the AML/CFT risk management and controls.
⇒ An officer who audits the framework he runs is reviewing his own work.

Step 2 – Check the training
Training must be ongoing and tailored to staff function, responsibility, length of service and the bank's risk, with refreshers (para 21). The guidelines do not prescribe a delivery format.

Step 3 – Check the audit frequency
The frequency of AML/CFT audits is "based on risk" (para 26); no fixed number is required.

Interpretation
The programme's content is sound; its structure is not. The fix is to move the audit to internal audit (reporting to the audit committee) and keep the chief AML/CFT officer on ongoing second-line monitoring.

Why the other options are wrong
A is incorrect. Audit frequency is risk-based; nothing shows that twice a year is too little. Frequency is not the defect, independence is.
B is incorrect. The guidelines require tailored, ongoing training but say nothing about classroom versus online delivery.
C is incorrect. Training should be tailored to function and risk, so a single consolidated event would move away from the guidance, not towards it.

LO: ORR-10 a: Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 21, 23 and 26

Solution ORR-10 a.6 Answer: C

Bank Q247 • GARP PE1 Q40

Step 1 – The third line

Internal audit independently evaluates risk management and controls and the effectiveness of compliance with AML/CFT policies (para 26). External auditors also evaluate internal controls and confirm compliance with AML/CFT regulations and supervisory practice (para 27).
⇒ C describes the assurance role of internal and external audit.

Step 2 – The contact point (shape S1)

Para 22: the chief AML/CFT officer "should be the contact point regarding all AML/CFT issues for internal and external authorities, including supervisory authorities or financial intelligence units". Nothing in the stem makes the CRO the chief AML/CFT officer.
⇒ The CRO as such is the wrong actor.

Step 3 – Day-to-day management

The business units manage the risk of their business (para 19). The chief AML/CFT officer monitors the fulfilment of AML/CFT duties and must not hold business line responsibilities (para 23).

Interpretation

This is the map's role trap. The CRO would carry the contact-point duty only if appointed chief AML/CFT officer, which para 24 allows (that is the set-up in Question ORR-10 a.8). As written, B gives a second-line duty to the wrong officer.

Why the other options are wrong

A is incorrect. Managing the risk within each business line daily is first-line work; giving it to the chief officer would also hand him business line responsibilities, which para 23 forbids.
B is incorrect. Role misassignment: the chief AML/CFT officer, not the CRO as such, is the contact point for supervisors and FIUs.
D is incorrect. Staff screening appears in the first-line paragraphs (paras 20 and 21; GARP's key to Question ORR-10 a.4), and the corporate operational risk function is not the actor the guidelines name.

LO: ORR-10 a: Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 19 to 27

Solution ORR-10 a.7 Answer: D

Bank Q245 • BT P2.T7.20.5.3

Step 1 – Policies (i) to (iv) against the guidelines

(i) GARP Ch.11 places ML and TF in the Basel "Clients, Products and Business Practices" event type, so treating ML/FT as an operational risk with special attention is sound. (ii) Three lines with a chief officer reporting to the CRO: the CRO is senior management, and para 24 asks for a direct reporting line to senior management or the board. (iii) Profiles of normal activity are what para 38 asks for. (iv) If a host country does not permit proper implementation of the FATF standards, closing operations there may be considered (para 65).
⇒ The first four policies are consistent with the guidelines.

Step 2 – Policy (v)

Ongoing monitoring is "an essential aspect" of ML/FT risk management (para 45); banks must have internal procedures for detecting and reporting suspicious transactions (para 20) and report genuine suspicious transactions promptly to the FIU (para 56).

⇒ Absolute confidentiality that blocks monitoring and proactive reporting contradicts the guidelines.

Interpretation

Confidentiality in the guidelines protects the *report*, not the customer from scrutiny: investigations are confidential and the customer must not be tipped off (paras 41 and 57). Even a numbered account, which offers extra confidentiality, gets exactly the same CDD, with full access for the chief AML/CFT officer and supervisors (para 44).

Why the other options are wrong

A is incorrect. Policy (v) is a clear problem, so not all five are sound.
B is incorrect. Building profiles of normal activity is expressly recommended (para 38); nothing in the guidelines bars it.
C is incorrect. All three lines apply to ML/FT risk: business units, the chief AML/CFT officer and compliance, internal audit (para 19).

LO: ORR-10 a: Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 20, 24, 38, 44, 45, 56, 57 and 65; GARP ORR Ch.11, Context and Scope

Solution ORR-10 a.8 Answer: B

Workbook A29.1 • S1, S2, S3, S4 • Aug-2026

Step 1 – Is the CRO allowed to hold the role?

Para 24: "The chief AML/CFT officer may also perform the function of the chief risk officer or the chief compliance officer or equivalent. He/she should have a direct reporting line to senior management or the board." What is forbidden (para 23) is business line responsibilities, data protection and internal audit.
⇒ The appointment is permitted, and the board reporting line meets the requirement.

Step 2 – Which duties come with the role

Para 22: the chief AML/CFT officer "should be the contact point regarding all AML/CFT issues for internal and external authorities, including supervisory authorities or financial intelligence units (FIUs)". Para 25: the officer "should also have the responsibility for reporting suspicious transactions".
⇒ The map's trap ("the chief AML officer, not the CRO, files reports and contacts regulators") is about the role: a CRO acting only as CRO does not carry these duties; a CRO appointed chief AML/CFT officer does.

Step 3 – Customer due diligence and reliance

Para 43: a transfer from an account in the customer's name at another bank subject to the same CDD standard "may provide some comfort", but the bank "should nevertheless conduct its own due diligence" and consider whether the previous bank closed the account over concerns about illicit activity.

Step 4 – Correspondent banking

Para 9: the June 2017 revision of Annex 2 guides banks in applying the risk-based approach to correspondent banking, "recognising that not all correspondent banking relationships bear the same level of risk", with a list of risk indicators.

Step 5 – Stages of laundering (ORR-11)

Placement covers techniques that disguise the origin of funds, including smurfing (a series of small transactions instead of a single large one, to stay below the reporting threshold). Layering combines placement and extraction strategies with varying amounts and patterns. Integration

or extraction gets the money out for use.

Interpretation

B is correct. The auditor should confirm the combined role is documented, that STR filing and FIU contact sit with the CRO in that capacity, that onboarding requires the bank's own CDD whatever the source of funds, that correspondent relationships are risk-rated individually, and that the training module places smurfing under placement.

Why the other options are wrong

A is incorrect. Sibling swap: smurfing is a placement technique; the definition of layering is correct but the technique is assigned to the neighbouring stage.

C is incorrect. Scope/condition error: the same-CDD-standard condition gives comfort only; it does not remove the bank's obligation to conduct its own due diligence.

D is incorrect. Absolute claim: the guidelines recognise that not all correspondent banking relationships bear the same level of risk, so due diligence is risk-based, not uniform.

LO: ORR-10 a: Explain best practices recommended by the Basel committee for the assessment, management, mitigation, and monitoring of money laundering and financing of terrorism (ML/FT) risks. ORR-10 b: Describe recommended practices for the acceptance, verification, and identification of customers at a bank. ORR-10 c: Explain practices for managing ML/FT risks in a group-wide and cross-border context. ORR-11 a: Describe elements of a control framework to manage financial fraud risk and money laundering risk. • **Reference:** BCBS (July 2020), GARP ORR Ch.10, paras 9, 22 to 25, 43; GARP ORR Ch.11, AML Risk Management

ORR-10 • Sound Management of Risks related to Money Laundering and Financing of Terrorism • Vardeez: VERY IMPORTANT

ORR-10 b

P1 CONCEPT

Describe recommended practices for the acceptance, verification, and identification of customers at a bank.

Workbook: A29 Money Laundering and Financing of Terrorism • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: the same A29 section as ORR-10 a (August 2026 recall "ML AFT", one question; map #50, 2 of 16 sources).
Vardeez: his notes label this LO "LO 49.b" (consolidated volume p.141) and split it into customer acceptance (risk-based, simplified for low risk, enhanced for large cross-border balances and PEPs), customer verification (FATF-based, reliable documents, never a written declaration alone, non-face-to-face cases) and customer identification (risk profiles, STRs, numbered accounts).

Reported exam shapes

- **S2** Customer due diligence, including reliance on another bank's CDD.

What the questions look like: onboarding cases. Which customer needs enhanced due diligence; what the bank does when verification cannot be completed; whether a prior account elsewhere, or funds arriving from another bank, lets the bank skip its own CDD; how numbered accounts, beneficial owners and non-face-to-face customers are handled.

See also: workbook A29.1 (option C tests reliance on another bank's CDD) is worked under ORR-10 a, Question ORR-10 a.8. Governance and the three lines of defence: ORR-10 a. Group-wide reliance on introducers: ORR-10 c.

1. Customer acceptance: a risk-based policy

The acceptance policy identifies the customers likely to pose a higher ML/FT risk (para 32), weighing the customer's **background, occupation** (including a public or high-profile position), **source of income and wealth**, country of origin and of residence, products used, nature and purpose of the accounts, linked accounts and business activities. Then (paras 33 and 34):

- **basic due diligence for every customer**, rising with risk; **simplified measures** only for *proven* lower risk and only if the law allows;
- the policy must not be so restrictive that it denies banking to the general public, especially the **financially or socially disadvantaged** (FATF Financial Inclusion Guidance);
- **enhanced due diligence (EDD)** where risk is higher: it "may be essential" for a large balance with regular cross-border wires or for a PEP, and **is required for foreign PEPs**; **senior management** decides whether to enter or continue such relationships; the policy also says when the bank refuses or ends a relationship.

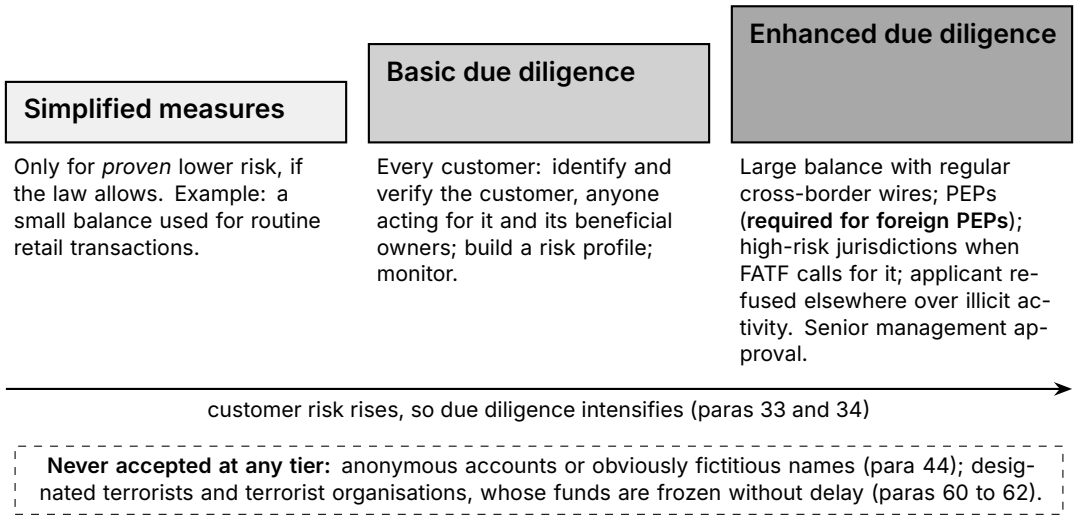


Figure 1. Risk-based customer due diligence. Bar height and shading rise with the intensity of due diligence; basic due diligence is the floor for everyone. The dashed box lists customers no tier can accept.

2. Identification and verification

A **customer** is any person (natural, legal or a legal arrangement) who enters into a business relationship or carries out an occasional financial transaction with the bank (FATF Recommendation 10). CDD covers the customer, **persons acting on its behalf** and **beneficial owners**: the natural persons who ultimately own or control a customer, or on whose behalf a transaction is conducted (para 35).

- **Verify first.** Generally, **no relationship and no transaction until identity is established and verified**; verify that anyone acting for the customer is authorised, and verify that person too (para 36).
- **Reliable, independent sources.** The best documents are those **most difficult to obtain illicitly or to counterfeit**. A written declaration of the beneficial owner's identity may be requested but **never relied on alone**. "In no case" is verification dropped because a customer cannot attend an interview (non-face-to-face); ask why the customer opened an account so far away, and apply EDD for jurisdictions with strategic AML/CFT deficiencies when FATF calls for it (para 37).
- **Risk profile.** Purpose of the relationship, level of assets, size and type of transactions, expected activity, regularity or duration and, where necessary, sources of funds or wealth define "normal" behaviour; deviations are unusual or suspicious and show whether EDD is needed (para 38). The extent of verification depends on risk, type of applicant and expected size and use of the account (para 40).

3. When CDD cannot be completed

> **Correction to the source notes.** Vardeez writes that banks "file an STR (Suspicious Transaction Report) if verification fails". GARP (para 41) is more precise: when CDD cannot be completed, the bank does not open the account (or closes or blocks it if already open) and **should consider** filing an STR; it **files** one where CDD raises suspicion that the funds are proceeds of crime or linked to ML/FT. Options often turn on "consider" versus "must file".

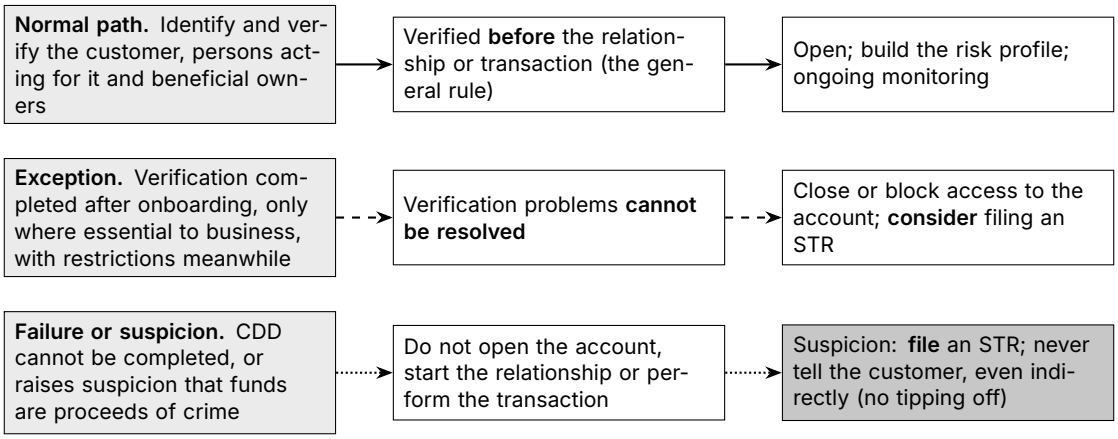


Figure 2. Three CDD paths (para 41): the normal path (solid arrows), the after-onboarding exception (dashed) and failure or suspicion (dotted). "Consider" an STR when verification fails; "file" one when CDD raises suspicion.

4. Special cases, including reliance on another bank (shape S2)

- **Funds from another bank (para 43).** A transfer from an account in the customer's own name at a bank subject to the same CDD standard "may provide some comfort", but the bank "should nevertheless conduct its own due diligence" and consider that the previous bank may have closed the account over illicit activity. An applicant **refused elsewhere** over illicit activity points to higher risk: EDD, an STR and/or rejection.
- **Anonymous or obviously fictitious names:** no account (para 44).
- **Numbered accounts (para 44):** names are known to the bank but replaced by a number or code in later documents. They get **exactly the same CDD** as other accounts, even if selected staff do it; the verified identity is known to enough staff, and the chief AML/CFT officer and supervisors have full access.

5. After onboarding: monitoring, records, FT screening

Monitoring covers *all* relationships, its intensity set by risk and enhanced for higher risk, and flags transactions without economic sense, large cash deposits and activity outside the customer's normal pattern (paras 45 to 47). The customer database is screened **whenever sanction lists change**, and periodically for **foreign PEPs** (para 50). CDD records are kept **at least five years** after the relationship or occasional transaction ends, and until case closure if under investigation or litigation (para 52). **FT differs from ML**: funds may come from **legal** sources and move in **very small amounts**. Screen against terrorist lists before onboarding and on an ongoing basis; **terrorist screening is not risk-sensitive**; freeze **without delay and without prior notice** (paras 59 to 62).

Comparison card: ORR-10 b, situation and rule

Situation	What the bank does	Para
Proven lower risk	simplified measures, only if the law allows	33
Large cross-border balance; PEP	EDD may be essential; **required** for foreign PEPs; senior management approval	34
Identity not yet verified	generally no relationship and no transaction	36
Beneficial owner declaration	may be requested; never relied on alone	37
Non-face-to-face customer	verification still required	37
CDD cannot be completed	do not open; close or block if open; **consider** an STR	41
CDD raises suspicion of proceeds of crime	do not open; **file** an STR; no tipping off	41
Funds from own account at a bank with the same CDD standard	some comfort; still do own due diligence	43
Numbered account	exactly the same CDD; identity known to enough staff	44
Relationship ends	keep records at least five years	52
Terrorist list match	not risk-sensitive; freeze without delay and without prior notice	62

Exam traps

- **Reliance on another bank.** Funds from the customer's account at a bank with the same CDD standard give comfort only; a prior account elsewhere never makes a customer low risk or verified.
- **High risk is not "reject".** Higher-risk customers can be accepted with EDD and senior management approval.
- **EDD for everyone.** Over-restrictive; it breaches the risk-based approach and financial inclusion.
- **"Must file" versus "consider".** Failed verification: consider an STR. Suspicion of proceeds of crime: file one. Never tell the customer.
- **Shortcuts.** No written-declaration-only verification, no non-face-to-face exemption, no anonymous numbered accounts.
- **Terrorist screening.** The one check that is not risk-sensitive.

Practice questions: ORR-10 b

Question ORR-10 b.1

Bank Q258 • Schweser Module Quiz 51.1 Q3 (rebuilt)

The risk manager of a large U.S. multinational bank is attempting to put in greater risk controls. In keeping with recommendations from the Basel Committee on the sound management of risks related to money laundering and the financing of terrorism (ML/FT), she requires enhanced customer due diligence (CDD) for:

A. all accounts from customers initiated in countries outside the United States.

B. accounts with large balances and regular cross-border wire transfers.

C. individual accounts with balances less than the USD 250,000 Federal Deposit Insurance Corporation (FDIC) insurance limit.

D. accounts of persons who reside in countries other than their countries of birth.

Question ORR-10 b.2

Bank Q255 • AnalystPrep Q.5457

During the development of its Customer Acceptance Policy (CAP), MetroBank is focusing on aligning with best practices for the acceptance of new clients while also adhering to the principles of financial inclusion. Based on the recommendations by the Basel Committee, which of the following approaches should MetroBank prioritize to ensure both compliance and inclusivity in its CAP?

A. Implement a universal policy that restricts the opening of accounts to only those customers who can provide a comprehensive financial profile, thereby minimizing the risk of money laundering and terrorist financing.

B. Enforce a stringent CAP that mandates enhanced due diligence for all new customers, irrespective of their risk profile, to maintain a consistent level of scrutiny across all customer interactions.

C. Develop a CAP that incorporates differentiated due diligence measures, considering factors such as the customer's geographical location, type of product desired, and the level of risk associated with their profile, to balance risk management with non-discrimination.

D. Establish a CAP that exclusively targets high-risk individuals, such as politically exposed persons (PEPs) and individuals from high-risk countries, with enhanced due diligence, while simplifying the process for all other customers.

Question ORR-10 b.3 New • built from GARP Ch.10

The head of client onboarding at a Luxembourg private bank is rewriting the identification and verification chapter of the bank's CDD manual. Which of the following provisions is consistent with the Basel Committee guidelines?

A. Clients who cannot attend an interview in person are exempt from identity verification, provided their accounts are placed under closer ongoing monitoring.

B. For corporate clients, a signed written declaration of the beneficial owner's identity is accepted as sufficient verification, with no further evidence sought.

C. Confidential numbered accounts go through exactly the same CDD as all other accounts, and the holder's verified identity is known to enough staff for effective due diligence.

D. Identity is verified with whichever documents the client finds easiest to supply, because the most widely available documents give the most reliable evidence.

Question ORR-10 b.4 Bank Q234 • AnalystPrep Q.3123 (rebuilt) • re-filed from LO 51.a

A bank in Italy holds a business account for an Italian company that sells suits in Europe and North America. At opening, the stated purpose of the account was to receive payment for sales. A year-long review shows regular wire transfers received from accounts of unrelated third parties with no apparent link to the company's customers, alongside purchases of cotton and garments from China and India. Which factor is MOST important in assessing whether money laundering is a threat?

A. The account is used for both sales receipts and supplier purchases.

B. Incoming payments come from unrelated third-party accounts, inconsistent with the stated purpose of the account.

C. The company buys raw materials rather than finished clothing.

D. Most transactions are wire transfers rather than cash deposits.

Question ORR-10 b.5 Bank Q254 • AnalystPrep Q.5125 (rebuilt)

A bank processed a first transaction for a new customer before identity verification was complete, to avoid disrupting business. Verification subsequently cannot confirm the customer's identity. According to Basel Committee recommendations, what should the bank do?

A. Treat the matter as closed, since the transaction was completed before the verification failed

B. Reclassify the customer as low risk because no adverse information was found

C. Notify the customer that a suspicious transaction report (STR) is being filed so the customer can supply documents

D. Consider filing an STR, without informing the customer, directly or indirectly, that it has been or will be filed

Question ORR-10 b.6 Bank Q256 • BT P2.T7.20.5.1 (rebuilt)

A person named Jack Ryan has applied to open a new account at Quadstreet International Bank. The bank has a modern, well-established and compliant customer acceptance policy. Immediately the bank is able to determine two facts: Jack is a high-risk customer, and he previously had an account at another large bank. Quadstreet does business with Jack's previous bank and considers it reputable. With respect to money laundering and terrorism financing (ML/FT), which of the following statements is TRUE about Jack Ryan's application?

A. As a general rule, Jack's identity should be established and verified before the bank opens the account or carries out any transactions

B. Because Jack is a high-risk customer, the bank is required to avoid him like any high-risk customer

C. Because Jack already has an account at a reputable bank, he can be classified as low-risk and well-identified

D. If Jack is a politically exposed person (PEP), he can be classified as low-risk on the assumption that the media already vets him and he cannot evade scrutiny

Solutions • ORR-10 b

Solution ORR-10 b.1

Answer: B

Bank Q258 • Schweser Module Quiz 51.1 Q3

Step 1 – Find GARP's EDD examples (para 34)

"Enhanced due diligence may be essential for an individual planning to maintain a large account balance and conduct regular cross-border wire transfers or an individual who is a politically exposed person (PEP)." It is required for foreign PEPs.
⇒ Option B is GARP's own example.

Step 2 – Treat the others as risk factors, not triggers

Country of origin and country of residence are factors the acceptance policy weighs (para 32); none of them makes EDD automatic.

Interpretation

EDD is targeted at features that raise the risk, not applied to whole populations. A small balance used for routine banking points the other way, towards simplified measures (para 33).

Why the other options are wrong

A is incorrect. Too broad: a foreign customer is a risk factor to assess, not an automatic EDD case.
C is incorrect. Small balances used routinely fit simplified procedures, the opposite of EDD; the deposit insurance limit has nothing to do with ML/FT risk.
D is incorrect. Residence different from country of origin is a factor to weigh (para 32), not an EDD trigger by itself.

LO: ORR-10 b: Describe recommended practices for the acceptance, verification, and identification of customers at a bank. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 32 to 34; SchweserNotes 2026 Book 3, Reading 51, LO 51.b

Solution ORR-10 b.2

Answer: C

Bank Q255 • AnalystPrep Q.5457

Step 1 – The risk-based structure (para 33)

Basic due diligence for all customers, commensurate due diligence as risk varies, simplified measures for proven lower risk if the law allows.

Step 2 – The inclusion constraint (para 33)

The policy must not be so restrictive that it denies access to banking to the general public, "especially for people who are financially or socially disadvantaged".
⇒ Only a differentiated, risk-based CAP meets both requirements.

Interpretation

The two halves of para 33 pull in different directions, and the risk-based approach reconciles them: the bank spends its scrutiny where the risk is and keeps the door open for low-risk, low-balance customers.

Why the other options are wrong

A is incorrect. Demanding a comprehensive financial profile from everyone shuts out low-balance and disadvantaged customers, against financial inclusion.
B is incorrect. EDD for all ignores the risk-based approach and is exactly the over-restrictive policy para 33 warns against.

D is incorrect. Basic due diligence still applies to every customer, and the risk assessment uses many factors (products, purpose, linked accounts, occupation), not only PEP status and country.

LO: ORR-10 b: Describe recommended practices for the acceptance, verification, and identification of customers at a bank. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 32 to 34

Solution ORR-10 b.3 — Answer: C

New • built from GARP Ch.10

Step 1 – Numbered accounts (para 44)

Confidential numbered accounts must not function as anonymous accounts: they "should be subject to exactly the same CDD procedures as all other customers' accounts, even if the procedures are carried out by selected staff". The holder's identity "must be verified by the bank and known to a sufficient number of staff".
⇒ C restates para 44.

Step 2 – Beneficial owner declarations (para 37)

A bank may require a written declaration of the identity of the beneficial owner, "although the bank should not rely solely on such declarations"; it takes reasonable measures to verify the beneficial owner (para 36).

Step 3 – Non-face-to-face customers (para 37)

"In no case should a bank disregard its customer identification and verification procedures just because the customer is unable to be present for an interview."

Step 4 – Which documents (para 37)

"The best documents for the verification of identity are those most difficult to obtain illicitly or to counterfeit."

Interpretation

Every wrong option offers a shortcut the guidelines close explicitly. Confidentiality (numbered accounts) is allowed; anonymity and shortcuts in verification are not.

Why the other options are wrong

A is incorrect. Scope error: there is no exemption for non-face-to-face customers. Closer monitoring is a complement to verification, not a substitute.
B is incorrect. Absolute reliance: a declaration may be requested but never relied on alone.
D is incorrect. Polarity flip: the best documents are the hardest to obtain illicitly or forge, not the most convenient or widely available.

LO: ORR-10 b: Describe recommended practices for the acceptance, verification, and identification of customers at a bank. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 35 to 37 and 44

Solution ORR-10 b.4 — Answer: B

Bank Q234 • AnalystPrep Q.3123

Step 1 – Recall what the risk profile records (para 38)

The purpose of the relationship, expected level of activity, type of transactions and, where necessary, sources of funds. Activity that deviates from the profile is unusual, or even suspicious. Monitoring should identify transactions "not consistent with the customer's normal and expected transactions" (para 47).

Step 2 – Compare each feature with the stated purpose

Receiving sales proceeds and paying suppliers: normal for a clothing business. Buying cotton and garments: consistent with making and selling suits. Wire transfers: the normal channel for

international trade. Regular receipts from unrelated third parties with no link to the company's customers: inconsistent with an account opened "to receive payment for sales".
⇒ Only B deviates from the profile.

Interpretation

The red flag is not any single transaction type but the mismatch between the profile built at onboarding and the activity seen later. Unexplained third-party payments into a trading account are a classic way to pass unrelated funds through a legitimate business.

Why the other options are wrong

A is incorrect. Sales receipts and supplier payments together are what a trading business does.
C is incorrect. Raw-material purchases are consistent with a clothing manufacturer's business model.
D is incorrect. Wires are the normal channel for cross-border trade; they are not suspicious in themselves (cash is not required for laundering).

LO: ORR-10 b: Describe recommended practices for the acceptance, verification, and identification of customers at a bank. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 38, 45 to 47

Solution ORR-10 b.5 Answer: D

Bank Q254 • AnalystPrep Q.5125

Step 1 – Was proceeding before verification allowed?

Yes, exceptionally: verification may be completed after the relationship starts where "essential not to interrupt the normal conduct of business", with restrictions on use meanwhile (para 41).

Step 2 – Verification then fails

"In situations where an account has been opened but problems of verification arise ... that cannot be resolved, the bank should close or otherwise block access to the account. In any event, the bank should consider filing a STR" (para 41).

Step 3 – Who may be told

The bank must ensure the customer is not informed, even indirectly, that an STR has been, is being or will be filed.
⇒ Consider an STR, block or close the account, tell no one outside the reporting chain.

Interpretation

The wording "consider filing" is deliberate: failed verification is a ground to weigh a report, while positive suspicion that funds are criminal proceeds requires one (see the correction box in Section 3).

Why the other options are wrong

A is incorrect. The CDD failure is unresolved; the bank must act on the account and consider an STR.
B is incorrect. The absence of adverse information is not evidence of low risk; an unverifiable identity is itself a red flag.
C is incorrect. That is tipping off, which the guidelines prohibit.

LO: ORR-10 b: Describe recommended practices for the acceptance, verification, and identification of customers at a bank. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), para 41; SchweserNotes 2026 Book 3, Reading 51, LO 51.b

Solution ORR-10 b.6 **Answer: A**

Bank Q256 • BT P2.T7.20.5.1

Step 1 – The general rule (para 36)

"Generally, a bank should not establish a banking relationship, or carry out any transactions, until the identity of the customer has been satisfactorily established and verified."
⇒ A states the rule.

Step 2 – What a previous account elsewhere is worth (shape S2)

Funds from an account in the customer's name at a bank with the same CDD standard "may provide some comfort", but the bank "should nevertheless conduct its own due diligence" and consider that the previous bank may have closed the account over illicit activity (para 43).
⇒ Another bank's CDD never replaces the bank's own.

Step 3 – What high risk means

Higher-risk customers get EDD, with senior management deciding whether to enter or continue the relationship (para 34). Refusal is for the circumstances the policy defines.

Interpretation

The S2 trap is reliance: a reputable previous bank sounds reassuring, but the guidelines treat it as comfort at most, and a reason to ask why the customer is moving.

Why the other options are wrong

B is incorrect. Absolute claim: high-risk customers may be accepted with EDD and senior management approval; avoidance is not required.
C is incorrect. Reliance error: a prior account is neither proof of low risk nor verification of identity, and the customer may have been asked to leave over illicit activity.
D is incorrect. Polarity flip: PEPs are higher risk, and EDD is required for foreign PEPs; media attention does not lower the risk.

LO: ORR-10 b: Describe recommended practices for the acceptance, verification, and identification of customers at a bank. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 34, 36 and 43

ORR-10 • Sound Management of Risks related to Money Laundering and Financing of Terrorism • Vardeez: VERY IMPORTANT

ORR-10 c

P1 CONCEPT

Explain practices for managing ML/FT risks in a group-wide and cross-border context.

Workbook: A29 Money Laundering and Financing of Terrorism • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: the same A29 section as ORR-10 a (August 2026 recall "ML AFT", one question; map #50, 2 of 16 sources).
Vardeez: his notes label this LO "LO 49.c" (consolidated volume p.141): unified group policies adjusted for stricter local laws, cross-border data sharing within legal limits, group risk assessments and audits, own standards for referred business, consolidated monitoring, a group chief AML/CFT officer, centralised systems. He adds the role of supervisors (see the scope note in Section 5).

Reported exam shapes

- **S3** Correspondent banking risk.

What the questions look like: a group with branches or subsidiaries abroad meets a conflict between home and host rules, a data-transfer restriction, an introducer it wants to rely on, or a correspondent relationship to rate. You pick the arrangement the guidelines allow; the traps are polarity (which standard wins) and absolute claims.

See also: workbook A29.1 (option D tests correspondent banking) is worked under ORR-10 a, Question ORR-10 a.8. CDD itself is ORR-10 b.

1. Why the group view matters

Customers often hold several relationships with the same banking group, in offices in different countries (para 10). **Consolidated risk management** coordinates and applies policies group-wide, giving a consistent baseline across all international operations; policies should not merely comply with each local law but identify, monitor and mitigate **group-wide** risks (para 64). A "group" is one or more banks with their branches and subsidiaries.

2. Home versus host: which standard wins

- **Group-wide policies** are consistently applied and supervised; local policies may reflect host requirements but stay consistent with group policy (para 63).
- **Host stricter than group:** the branch or subsidiary adopts the host rules (para 63). **Home and host minimums differ:** host offices **apply the higher standard of the two** (para 64).
- **Host blocks the FATF standards:** the chief AML/CFT officer **informs the home supervisors**; additional measures may include **closing the host operations** (para 65).
- **Information barriers.** Some jurisdictions restrict sending customer names and balances abroad. It is still essential that branches *and* subsidiaries be authorised to share customer information, subject to adequate legal protection, with head office or the parent bank (para 66).

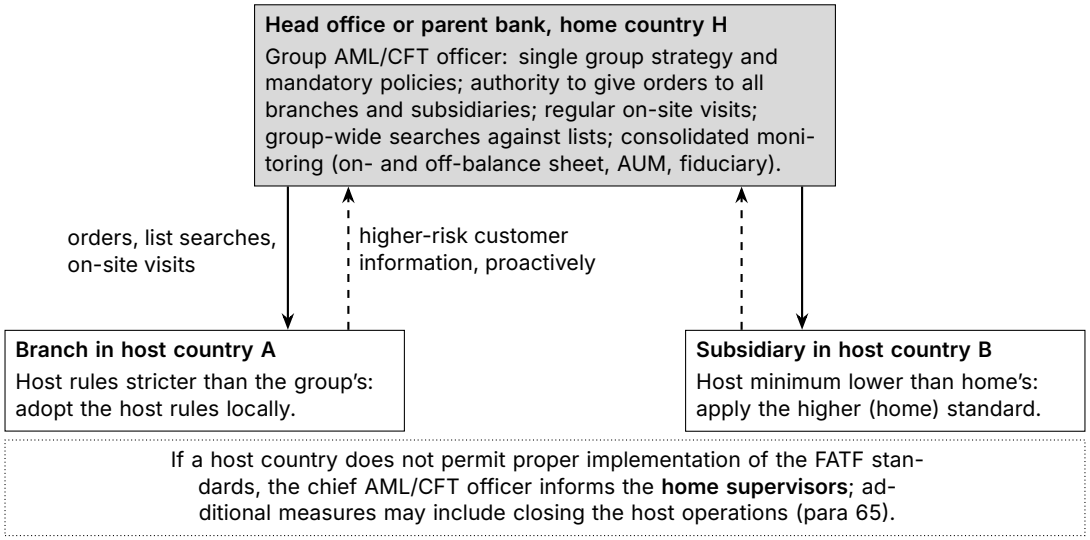


Figure 1. Group-wide AML/CFT (paras 63 to 80). Solid arrows carry authority from head office; dashed arrows carry information back, proactively for higher-risk customers (same pair on the right). Each host office applies the higher of home and host standards; the dotted box is the escalation when a host blocks the FATF standards.

3. Group officer, reliance and consolidated monitoring

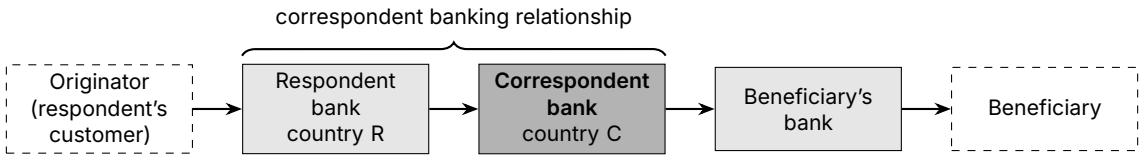
- **Group risk assessment** (paras 67 and 68): customer risk is understood across the group, with common criteria for higher-risk customers applied in branches, subsidiaries and outsourced activities; customers in the **same category may pose different risks in different jurisdictions**. Internationally active groups need strong internal audit and a **global compliance function**.
- **Group AML/CFT officer** (paras 75 and 76): appointed by a bank operating nationally and abroad; creates and coordinates a **single AML/CFT strategy**, with **authority to give orders** to all branches, subsidiaries and subordinated entities, and checks group-wide compliance, including through **regular on-site visits**.
- **Introducers** (para 69): never rely on introducers subject to **less strict standards** than the bank's own. Higher reliance on a **same-group** introducer is possible if it follows the same standards, supervised at group level; even then the bank **obtains the customer information**, which an FIU may need.
- **Consolidated monitoring** (paras 72 to 74): each office monitors locally and shares heightened-risk information with head office; significant relationships, balances and activity are monitored **on a**

consolidated basis, on- or off-balance sheet, as assets under management or fiduciary, wherever held. Centralised systems in large banks must integrate local and central monitoring.

- **Information flows** (paras 77 to 80): branches and subsidiaries **proactively** send head office information on higher-risk customers and answer its requests promptly, within data protection laws; head office checks whether other offices hold accounts for the same customer and can **require group-wide file searches** against specified lists.
- **Mixed financial groups** (paras 82 and 83): banking, securities and insurance arms share customer information across the group, watch for customers using several sectors, and apply **sector-appropriate** requirements when cross-selling (sector differences "may require or justify variations").

4. Correspondent banking (shape S3)

A **correspondent** bank provides accounts and payment services to a **respondent** bank, so it processes transactions for the respondent's customers, whom it does not know directly, usually across borders. When the Committee merged its earlier CDD (2001) and consolidated KYC (2004) papers into these guidelines, it increased its focus on correspondent banking (Annex 2) alongside third-party introducers (Annex 1). GARP's text (para 9) says the **June 2017 revisions to Annex 2** guide banks in applying the **risk-based approach**, "recognising that **not all correspondent banking relationships bear the same level of risk**", with an **updated list of risk indicators** for the correspondent's risk assessment. Annex 2 itself is not reprinted, so apply the chapter's general rules: rate each respondent; enhanced measures with senior management approval for higher risk (para 34); another bank's checks never replace the bank's own (paras 43 and 69); monitor all transactions, small ones included (paras 28 and 59).



The correspondent sees the payment message, not the originator: it depends on the respondent's CDD of its own customers. Hence the risk-based approach of Annex 2 (revised June 2017): rate each respondent with risk indicators, because not all correspondent relationships bear the same risk; higher-risk relationships get enhanced measures and senior management approval.

Figure 2. A correspondent banking chain. Dashed boxes are the parties the correspondent (darkest box) never onboards; the brace marks the relationship the correspondent must risk-rate.

5. Scope note: the supervisors' role

GARP Ch.10 reprints the guidelines through para 83. Part IV, on supervisors, is not in the GARP text; Schweser and Vardeez summarise it under this LO. Headlines: supervisors apply FATF Recommendation 26 and the Core Principles and supervise **risk-based**; they evaluate the bank's risk assessment and the effectiveness of its controls, make sure the **stricter of the two jurisdictions' requirements** applies, verify group-wide compliance on site, cooperate with home supervisors and keep customer information confidential. Expect at most a distractor from this list.

Comparison card: ORR-10 c, situation and rule

Situation	Rule	Para
Host rules stricter than the group's	branch or subsidiary adopts the host rules	63
Home and host minimums differ	host office applies the higher of the two	64
Host blocks proper FATF implementation	inform home supervisors; closure may be considered	65
Host restricts sending customer data	share with head office within legal protection	66
Introducer with less strict standards	never rely on it	69
Same-group introducer, same standards	higher reliance; still obtain the customer information	69
Significant relationships	consolidated: on- and off-balance sheet, AUM, fiduciary	73
Higher-risk customers abroad	branches and subsidiaries inform head office proactively	77
Securities and insurance arms	share group-wide; sector-appropriate requirements	82, 83
Correspondent banking	risk-based; not all relationships bear the same risk	9

Exam traps

- **Which standard wins.** The higher of home and host: group consistency never overrides stricter host rules, and a lower host minimum never lowers the group standard.
- **Consistent is not identical.** Uniform global CDD with no local adaptation fails the guidelines.
- **Data restrictions** make sharing harder, not optional; closing host operations comes only after informing home supervisors.
- **Introducers.** Never less strict standards; same-group reliance still requires obtaining the customer information.
- **Consolidated means everything:** on- and off-balance sheet, AUM and fiduciary holdings.
- **Correspondent banking.** "Every relationship is equally risky" is the absolute claim GARP rejects.

Practice questions: ORR-10 c

Question ORR-10 c.1

Bank Q260 • BT P2.T7.24.1.1

A compliance officer at RevoWise, a fintech company recently granted a UK banking license, is reviewing the company's compliance framework. The review focuses on the implementation of "Borderless Monitor", RevoWise's proprietary software, within expanded services that now include multicurrency accounts and business banking. The officer is evaluating whether RevoWise's practices adhere to the Basel Committee's recommendations on combating money laundering (ML) and financing of terrorism (FT). Which of the following practices at RevoWise does NOT align with the Basel Committee's recommended best practices?

A. The "QuickVerify" system streamlines customer due diligence with a uniform global approach, eliminating duplication by forgoing country-specific adaptations.

B. "Borderless Monitor" flags atypical transactions in high-risk accounts for further review.

C. The chief compliance officer reports directly to the board and executive management.

D. All wire transfers include detailed sender and recipient information, reviewed manually and automatically.

Question ORR-10 c.2

Bank Q261 • Schweser Module Quiz 51.1 Q4 (rebuilt)

A banking group headquartered in Country H operates a subsidiary in Country F. Country F's customer due diligence requirements are stricter than the group's AML/CFT policy, and Country F's law restricts transmitting customer names and balances abroad. Which of the following is the most appropriate action for the group under Basel Committee guidance on managing ML/FT risk in a group-wide and cross-border context?

A. Apply the group policy at the subsidiary to keep procedures uniform, since group-wide consistency takes precedence over local rules.

B. Allow the subsidiary to adopt Country F's stricter requirements, and have the group chief AML/CFT officer coordinate information sharing with the head office within legal protections, informing home supervisors if FATF standards cannot be properly implemented.

C. Let the subsidiary adopt Country F's requirements and withhold all customer information from the head office, so the group assesses risk only on a consolidated-balance-sheet basis.

D. Close the subsidiary immediately, because information-sharing restrictions make group-wide risk management impossible.

Question ORR-10 c.3 Bank Q259 • AP Mock 3 Q68 • AnalystPrep Q.3122 (rebuilt)

A bank is considering relying on customer due diligence performed by an introducer in another jurisdiction. Which of the following is consistent with Basel Committee recommendations?

A. Rely on any introducer that is a licensed bank, since it is a regulated institution, and treat the introducer as responsible for any CDD failures

B. Rely on an introducer subject to less strict AML/CFT standards than the bank's own, provided the introducer has a strong written AML policy

C. Rely on an introducer in the same financial group that is subject to the same standards as the bank, with application of those standards supervised at group level, while the bank still obtains the customer information

D. Rely on an introducer in any jurisdiction, because the bank's responsibility for CDD ends once the introducer confirms identification was completed

Question ORR-10 c.4 New • built from GARP Ch.10

A banking group headquartered in Country H has branches and subsidiaries in six countries. Its newly appointed group AML/CFT officer is setting out how information and authority will flow across the group. Which of the following arrangements is consistent with the Basel Committee guidelines?

A. Branches and subsidiaries send head office information on higher-risk customers only in response to a specific head-office request, to limit cross-border data flows.

B. Significant customer relationships are monitored on a consolidated basis for on-balance-sheet accounts only; assets under management and fiduciary holdings stay with each local office.

C. To respect local autonomy, the group officer coordinates the strategy but cannot give orders to foreign subsidiaries, relying on their annual self-certification instead of on-site visits.

D. Head office can require every branch and subsidiary to search its files against specified lists of persons suspected of aiding ML or FT, and to report any matches.

Question ORR-10 c.5 New • built from GARP Ch.10

A financial group based in Country H runs banking, securities and insurance businesses. Its insurance subsidiary in Country L, where the legal minimum CDD requirements are less demanding than Country H's, plans to cross-sell the group's private banking products to its policyholders. Which of the following approaches is consistent with the Basel Committee guidelines?

A. The group monitors and shares customer identity and account activity across all three businesses, watches for customers who use services in more than one sector, and applies sector-appropriate AML/CFT requirements when cross-selling.

B. Each business monitors only its own customers, and information walls between banking, securities and insurance prevent customer data from being shared anywhere within the group.

C. Because Country L's legal minimum is lower, the insurance subsidiary applies Country L's minimum CDD requirements, since a host office must always follow host-country law and practice.

D. Because the three businesses belong to one group, identical AML/CFT requirements must be applied in every sector, whatever the differences in their activities and customer relationships.

Question ORR-10 c.6 New • built from GARP Ch.10

The head of financial institutions at a London correspondent bank provides US dollar clearing and payment accounts to 40 respondent banks in 25 countries. After a regulatory review she is redrafting the bank's correspondent banking policy. Which of the following provisions is consistent with the Basel Committee guidelines?

A. Respondents licensed and supervised in their home country are treated as low risk by default, so the bank relies on that licence instead of its own assessment of each respondent.

B. Each respondent is risk-rated individually against a set of risk indicators, and the intensity of due diligence and monitoring follows the rating, since relationships differ in risk.

C. All respondents receive identical due diligence, because correspondent banking is classed as uniformly high risk and differentiated treatment would breach group-wide consistency.

D. Payments routed through respondents are monitored only above a fixed value threshold, because the respondents' own CDD already covers their customers' smaller transactions.

Solutions • ORR-10 c

Solution ORR-10 c.1 — Answer: A

Bank Q260 • BT P2.T7.24.1.1

Step 1 – Consistent is not identical

Group-wide policies are consistently applied, but local policies reflect local business and host requirements (para 63), and acceptance, CDD and record-keeping policies are adjusted "as necessary to address variations in risk according to specific business lines or geographical areas"; different approaches to information collection may be needed to meet local rules (para 71).

Step 2 – Stricter local rules must be met

Where host requirements are stricter, the branch or subsidiary adopts them (para 63); where minimums differ, the higher standard applies (para 64).

$\Rightarrow$ A uniform global CDD process that forgoes country-specific adaptation cannot meet stricter local rules.

Step 3 – Check the other three

Flagging atypical transactions in high-risk accounts is risk-based monitoring (paras 45 and 46). A compliance chief reporting directly to the board fits para 24 (the chief AML/CFT officer may also be the chief compliance officer). Full sender and recipient information on wires matches the transparency sought in the Committee's paper on cover payment messages for cross-border wire transfers (listed in para 8).

Interpretation

Eliminating duplication is a fair efficiency goal, but the guidelines trade it off against local risk and law. The correct reading of "group-wide" is a common baseline with local adaptation upward.

Why the other options are wrong

B is incorrect. Aligned: enhanced monitoring of higher-risk accounts with review of unusual activity is the risk-based approach.

C is incorrect. Aligned: a direct reporting line to the board and senior management is what para 24 requires.

D is incorrect. Aligned: transparent originator and beneficiary information, with monitoring, supports detection of unusual cross-border payments.

LO: ORR-10 c: Explain practices for managing ML/FT risks in a group-wide and cross-border context. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 8, 24, 45, 63, 64 and 71

Solution ORR-10 c.2 — Answer: B

Bank Q261 • Schweser Module Quiz 51.1 Q4

Step 1 – Stricter host rules

"In cases where the host jurisdiction requirements are stricter than the group's, group policy should allow the relevant branch or subsidiary to adopt and implement the host jurisdiction local requirements" (para 63).

$\Rightarrow$ Uniformity does not override the stricter local rule.

Step 2 – Data-transfer restrictions

Some jurisdictions restrict the transmission of customer names and balances; still, "it is essential that banks be authorised to share information about their customers, subject to adequate legal protection, with their head offices or parent bank" (para 66). The group AML/CFT officer coordinates group-wide compliance (paras 75 and 76).

Step 3 – Escalation

If the host country does not permit proper implementation of the FATF standards, the chief AML/CFT officer informs the home supervisors; additional measures, including closure, may then be considered (para 65).

⇒ B assembles all three rules in the right order.

Interpretation

The question rewards the sequence: adopt the stricter rule, share within legal protection, escalate to home supervisors, and only then consider leaving.

Why the other options are wrong

A is incorrect. Polarity flip: group consistency does not override stricter host requirements, which must be adopted.

C is incorrect. Over-correction: head office needs information on customers, especially higher-risk ones, and monitoring is consolidated across on- and off-balance-sheet activity, not a balance-sheet view only.

D is incorrect. Premature: closure is a possible step after the home supervisors are informed that FATF standards cannot be implemented, not the first response.

LO: ORR-10 c: Explain practices for managing ML/FT risks in a group-wide and cross-border context. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 63 to 66, 73, 75 and 76; SchweserNotes 2026 Book 3, Reading 51, LO 51.c

Solution ORR-10 c.3 **Answer: C**

Bank Q259 • AP Mock 3 Q68

Step 1 – The floor on reliance

"A bank should not rely on introducers that are subject to standards that are less strict than those governing the bank's own AML/CFT procedures" (para 69). The bank monitors and evaluates the standards in the referring jurisdiction.

Step 2 – The case for higher reliance

A bank "may rely on an introducer that is part of the same financial group and could consider placing a higher level of reliance" on it, "provided this introducer is subject to the same standards as the bank, and the application of these requirements is supervised at the group level". It must still obtain the customer information from the referring bank, because the information may have to be reported to FIUs (para 69).

⇒ C is the guidelines' own case.

Interpretation

Reliance changes how much work the bank repeats; it never changes who is responsible. That is the same logic as para 43 for funds arriving from another bank (ORR-10 b).

Why the other options are wrong

A is incorrect. A banking licence does not show the introducer's standards are as strict as the bank's, and responsibility for CDD cannot be shifted to the introducer.

B is incorrect. Reliance on introducers with less strict standards is ruled out; a written policy does not cure the gap.

D is incorrect. Responsibility does not end with the introducer's confirmation, and the jurisdiction's standards matter.

LO: ORR-10 c: Explain practices for managing ML/FT risks in a group-wide and cross-border context. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 9 and 69 (Annex 1 on introducers)

Solution ORR-10 c.4 — Answer: D

New • built from GARP Ch.10

Step 1 – Group-wide list searches (para 80)

"A bank's head office should be able to require all branches and subsidiaries to search their files against specified lists or requests for individuals or organisations suspected of aiding and abetting ML and FT, and report matches."

⇒ D restates para 80.

Step 2 – Direction of information (para 77)

Subsidiaries and branches "should be required to *proactively* provide the head office with information concerning higher-risk customers and activities", and respond to head-office requests in a timely manner.

Step 3 – Scope of consolidation (para 73)

Significant relationships, balances and activity are monitored on a consolidated basis, "regardless of whether the accounts are held on-balance sheet, off-balance sheet, as assets under management or on a fiduciary basis, and regardless of where they are held".

Step 4 – Powers of the group officer (paras 75 and 76)

The group AML/CFT officer has "the authorisation to give orders for all branches, subsidiaries and subordinated entities nationally and abroad" and checks group-wide compliance "including through on-site visits on a regular basis".

Interpretation

The group officer is built to see and act across borders: information flows up without being asked for, orders flow down, and monitoring covers every way a customer can hold assets with the group.

Why the other options are wrong

A is incorrect. Polarity flip: higher-risk information is sent proactively, not only on request.

B is incorrect. Scope error: consolidated monitoring includes off-balance-sheet, AUM and fiduciary holdings.

C is incorrect. Polarity flip: the group officer is empowered to give orders group-wide and verifies compliance through regular on-site visits.

LO: ORR-10 c: Explain practices for managing ML/FT risks in a group-wide and cross-border context. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 73, 75 to 77 and 80

Solution ORR-10 c.5 — Answer: A

New • built from GARP Ch.10

Step 1 – Mixed financial groups (para 82)

Groups with securities and insurance businesses "should have the ability to monitor and share information on the identity of customers and their transaction and account activities across the entire group, and be alert to customers that use their services in different sectors".

Step 2 – Sector differences (para 83)

Differences between sectors "may require or justify variations in the AML/CFT requirements imposed on each sector"; when cross-selling, "the appropriate AML/CFT requirements for the relevant sectors should be applied".

⇒ A combines both paragraphs.

Step 3 – Home versus host (para 64)

"Where the minimum regulatory or legal requirements of the home and host countries differ, offices in host jurisdictions should apply the higher standard of the two."

Interpretation

Two traps run in opposite directions: one says the group must be identical everywhere, the other that the host minimum is enough. The guidelines ask for a shared view of the customer, sector-appropriate rules, and never less than the higher of home and host.

Why the other options are wrong

B is incorrect. Polarity flip: the group must monitor and share customer information across banking, securities and insurance.

C is incorrect. Polarity flip: a lower host minimum does not lower the standard; the host office applies the higher one, here Country H's.

D is incorrect. Absolute claim: sector differences may justify variations in the requirements.

LO: ORR-10 c: Explain practices for managing ML/FT risks in a group-wide and cross-border context. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 64, 82 and 83

Solution ORR-10 c.6 Answer: B

New • built from GARP Ch.10

Step 1 – What GARP says about correspondent banking (para 9)

The June 2017 revisions to Annex 2 "guide the banks in the application of the risk-based approach for correspondent banking relationships, recognising that not all correspondent banking relationships bear the same level of risk and including an updated list of risk indicators that correspondent banks should consider in their risk assessment".

$\Rightarrow$ Individual risk rating against risk indicators, with measures to match, is the guidelines' approach.

Step 2 – Apply the general rules on reliance

Another institution's checks give comfort at most; the bank "should nevertheless conduct its own due diligence" (para 43), and it never relies on standards less strict than its own (para 69).

Step 3 – Apply the general rules on monitoring

Monitoring covers all accounts and transactions (para 28), and FT can move in very small amounts (para 59).

Interpretation

Correspondent banking is risky because the correspondent processes payments for the respondent's customers without knowing them, usually across borders, so it leans on the respondent's own controls. The answer is not to treat every respondent the same but to rate each one and scale the due diligence: the risk-based approach.

Why the other options are wrong

A is incorrect. Scope error: a licence says nothing about whether the respondent's AML/CFT standards are as strict as the bank's, and reliance never replaces the bank's own assessment.

C is incorrect. Absolute claim: the guidelines state that not all correspondent relationships bear the same risk; group consistency means consistent policy, not identical treatment of different risks.

D is incorrect. Threshold error: monitoring covers all transactions, and small FT payments are exactly what a threshold misses.

LO: ORR-10 c: Explain practices for managing ML/FT risks in a group-wide and cross-border context. • **Reference:** GARP ORR Ch.10 (BCBS, July 2020), paras 9, 28, 43, 59 and 69 (Annex 2 on correspondent banking)

ORR-11 • Financial Crime and Fraud • Vardeez: VERY IMPORTANT

ORR-11 a

P1 CONCEPT

Describe elements of a control framework to manage financial fraud risk and money laundering risk.

Workbook: A29 Money Laundering and Financing of Terrorism • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: section A29 covers this LO together with ORR-10 (August 2026 recall "ML AFT", one question; map #50, 2 of 16 sources).
Vardeez: ORR-11 sits in theme 1 of his ORR list (TPRM, AML and outsourcing) and is rank 34 of 55 in the consolidated volume, tagged a quick win. His notes label this LO "LO 50.a" (consolidated volume p.142): the scope of financial crime (internal and external fraud, ML, TF), the four control steps for internal fraud and for AML (selection, prevention, detection, deterrence), external fraud management, and the three phases of laundering (his Figure 50.1). RegTech and OFAC screening are his "also worth knowing".

Reported exam shapes

- **S4** The three stages of laundering: placement, layering, integration (tested inside workbook Q1).

What the questions look like: definitions (the FCA's financial crime, Basel internal and external fraud, the EU's money laundering), classifying a control as selection, prevention, detection or deterrent, and naming the laundering stage a technique belongs to.

See also: workbook A29.1 (option A, smurfing) is worked under ORR-10 a, Question ORR-10 a.8. The three stages are drawn under ORR-10 a (Figure 3) and recapped here. The USAA case is ORR-11 b (P2).

1. What financial crime covers

The UK Financial Conduct Authority (FCA) Handbook defines financial crime as "any kind of criminal conduct relating to money or to financial services or markets, including any offence involving: (a) fraud or dishonesty; or (b) misconduct in, or misuse of information relating to, a financial market; or (c) handling the proceeds of crime; or (d) the financing of terrorism". So financial crime spans internal and external fraud (a, b), money laundering (c) and terrorism financing (d).

The pandemic multiplied exposure: American Bankers Association studies found fraud attempts had **tripled** in 2021 since the March 2020 lockdown, and phishing e-mails multiplied **six- to seven-fold** over the first year, with wire transfer and e-mail scams rising as staff worked from home.

- **Internal fraud** (Basel event type 1): losses due to acts of a type intended to defraud, misappropriate property or circumvent regulations, the law or company policy, excluding diversity/discrimination events, which involve **at least one internal party**. Two subcategories. *Unauthorised activities*, now usually called misconduct: intentional non-reporting of transactions, mismarking positions, unauthorised transaction types, password sharing, disclosing confidential information, mis-selling to vulnerable clients; they **need not cause a loss**. *Theft and fraud*: extortion, embezzlement, malicious destruction of assets, bribery, tax evasion.
- **External fraud** (Basel event type 2): the same acts (to defraud, misappropriate property or circumvent the law) committed **by a third party**. Subcategories: *theft and fraud* (robbery, check kiting, fraudulent wires, card fraud, identity theft, misstated income or collateral in loan applications)

and *systems security* (hacking damage, theft of information). There is no "unauthorised activities" subcategory.

- **Money laundering and terrorism financing**: handling the proceeds of crime and funding terrorism (Section 2). They fall in the Basel **Clients, Products and Business Practices** (CPBP) category, because taking part in handling criminal proceeds or terrorist funds is itself a breach.

2. Money laundering and terrorism financing defined

The **EU Directive of 20 May 2015** treats as money laundering: (a) the **conversion or transfer** of property, knowing it derives from criminal activity, to conceal or disguise its illicit origin or to help someone evade the legal consequences; (b) the **concealment or disguise** of the true nature, source, location, disposition, movement, rights or ownership of such property; (c) the **acquisition, possession or use** of such property, knowing its origin at the time of receipt; (d) participating in, attempting, aiding, abetting, facilitating or counselling any of these. **Terrorism financing** (IMF) is the provision or collection of funds, by any means, directly or indirectly, with the intention or knowledge that they will be used, in full or in part, to carry out a terrorist act. Banks that cannot demonstrate effective AML and CTF controls face fines, business restrictions and possibly prosecution.

> **Corrections to the source notes.** (1) GARP's text cites the Directive as "EU 2015/949"; its own footnote link, like the Official Journal, gives **(EU) 2015/849**, the Directive of 20 May 2015. Only the date and content are examinable. (2) Schweser describes AML oversight as "often delegated to a dedicated money laundering risk officer". GARP is firmer: a dedicated **MLRO accountable for AML is mandatory** for most institutions in most jurisdictions (Section 4).

3. The fraud control framework

Fraud management in banks long sat with internal audit (at ING, an "inspection" unit for detecting and reporting fraud), often staffed with former police officers and forensic specialists. When firms state **"zero tolerance" for internal fraud**, they mean every perpetrator caught will be sanctioned, *not* that the risk cannot materialise. GARP's framework (Figure 11.1, from a trading firm) has **four components**:

- **Selection**: screening employees, contractors and third parties who operate within or close to the firm; the tone from the top, culture and alignment of values also live here.
- **Prevention**: clearly delimiting the rights, authority and access of each function (segregation of duties, access rights, delegation of authority), "the cornerstone of fraud risk management".
- **Detection**: time to detection is critical; team supervision, monitoring for abnormal patterns, reconciliations; managers watch for resentment or disengagement. Detection also *deters*: the incentive to commit fraud falls when the chance of being caught is high.
- **Deterrents**: announced sanctions and actions (disciplinary action, legal pursuits) that tip the risk-reward balance.

The **fraud triangle** names what raises fraud risk: opportunity, incentive, rationalisation. **External fraud** uses the same components aimed at outsiders (professional criminals, customers and business partners), split into first-party fraud (by the customer or partner for its own benefit) and third-party fraud; it needs special teams: company security for branches and ATMs working with law enforcement, and teams for deposit, check and card fraud.

	Selection who gets in	**Prevention** built into processes	**Detection** while it happens	**Deterrents** after the event
Internal fraud GARP Fig. 11.1	screening at onboarding due diligence on employees and third parties tone and culture, alignment of values	segregation of duties access rights and authorisations delegation of authorities	team supervision monitoring for abnormal patterns and behaviours reconciliations	sanctions and disciplinary actions legal pursuits
AML GARP Fig. 11.2	customer due diligence (KYC) verification of identity and origin of funds ethos and values	risk-based approach on risk-driving factors staff information and training allocation of responsibilities	transaction monitoring system alerts on abnormal behaviour or transactions reconciliation with external lists (OFAC, PEP)	escalation to the financial intelligence unit (FIU) legal pursuits closure of accounts

Figure 1. One framework, two risks: the four components for internal fraud (top row) and for AML (bottom row), redrawn from GARP Figures 11.1 and 11.2. Header shading deepens from the first control a person meets to the last. GARP's internal-fraud figure also shows a whistleblowing policy and forensic analysis on the detection and deterrence side.

4. AML risk management

GARP reproduces the fraud structure for AML (Figure 1, bottom row) to show how similar the organisation of the two is.

- **Selection is first, and "arguably the most important"**: profiling and selecting customers through **KYC** (verifying identity documents at account opening) and verifying the **origin of funds** for any significant deposit, to show the funds are not linked to crime.
- **Risk-based approach**: the higher the risk, the tighter the controls. Retail and business customers are rated **low, medium or high** on factors such as country of operation, industry, history with the bank, corporate structure, location of subsidiaries, third parties and clients, traceability of funds, and volume and frequency of transactions; these factors become the main **monitoring criteria**. For retail clients: PEP lists, occupation, volume and types of transactions, history with the bank, documentation on the origin of funds.
- **Governance**: a dedicated **money laundering risk officer** (**MLRO**) accountable for AML is **mandatory** for most institutions in most jurisdictions, with written policies, employee training and systematic reviews that keep customer data and monitoring systems up to date.
- **The three stages** (shape S4, Figure 3 under ORR-10 a): **placement** disguises the origin of the funds (cash transfer to a business, false invoicing, trusts and offshore companies, foreign accounts, **smurfing**: many small transactions below the reporting threshold); **layering** combines placement and extraction strategies with varying amounts and patterns to defeat tracking; **integration** (**extraction**) gets the money out to use (fake payments to employees, fake loans, dividends to accomplices).

5. Technology, sanctions lists and the challenger banks

RegTech firms use machine learning to automate customer profiling, speed up due diligence through automated scanning, validate identities and photos, detect anomalies or unexplained changes in behaviour early, and check customers and related businesses against sanctions and PEP lists. In the US, **OFAC** (US Treasury) publishes a sanctions list of individuals and companies owned or controlled by, or acting for, targeted countries, plus designated terrorists and narcotics traffickers; every company doing business with or in the US must ensure its clients are not on it.

FCA review of challenger banks (Box 11.1, 2022 update). Fully digital banks that open accounts very quickly risk gathering too little information at onboarding to identify higher-risk customers. The FCA found good practice (innovative technology to identify and verify customers quickly) but also weaknesses at onboarding and during the customer's tenure: weak CDD, **inconsistent EDD** (for example for PEPs), and inconsistent or inadequate rationale for **ignoring monitoring alerts**. It recommends a risk-based approach with continuous monitoring that controls stay fit for purpose, and oversight that keeps up with growth and changing business models.

Comparison card: ORR-11 a, classify the clue

Clue in the stem	Answer
Screening at onboarding; KYC; origin of funds; due diligence on staff and third parties; tone, culture, ethos and values	Selection
Segregation of duties; access rights; delegation of authority; risk-based customer rating; staff training; allocation of responsibilities	Prevention
Team supervision; transaction monitoring; alerts on abnormal behaviour; reconciliations, including against OFAC and PEP lists	Detection
Sanctions and disciplinary action; legal pursuits; escalation to the FIU; closing accounts	Deterrents
Many small deposits under the reporting threshold; false invoicing; trusts, offshore companies	Placement
Varying amounts and patterns across accounts to defeat tracking	Layering
Fake payroll, fake loans, dividends to accomplices	Integration (extraction)
Conversion or transfer of property known to be criminal, to disguise its origin	EU definition of ML, limb (a)

Exam traps

- **Zero tolerance** means every caught perpetrator is sanctioned, not that internal fraud cannot happen.
- **Unauthorised activities** need not cause a loss; external fraud has no unauthorised-activities subcategory (its second one is systems security).
- **ML and TF** sit in the CPBP event type, not in internal or external fraud.
- **Detection versus deterrent.** Detection also deters, but a monitoring or alert control is detection; deterrents are the sanctions announced after the event.
- **Sibling swaps in the grid.** Ethos and values is selection; training is prevention; reconciliation with OFAC or PEP lists is detection; FIU escalation is a deterrent.
- **Stage names.** Placement, layering, integration (extraction). "Conversion" is a limb of the EU definition, not a stage; smurfing is placement.

- **MLRO.** Mandatory in most jurisdictions, not optional.

Practice questions: ORR-11 a

Question ORR-11 a.1

Bank Q263 • AnalystPrep Q.5120

An operational risk manager at a bank is presenting on financial crimes and fraud. He starts his presentation by defining financial crime. Which of the following is the correct definition of a financial crime?

A. Any criminal conduct relating to money or to financial services or markets

B. Losses due to acts intended to defraud, misappropriate property or circumvent regulations, the law, or company policy excluding diversity/discrimination events involving at least one internal party

C. Losses due to acts of a type intended to defraud, misappropriate property or circumvent the law by a third party

D. Misappropriation of assets, such as extortion, embezzlement, malicious destruction of assets, bribery, and tax evasion

Question ORR-11 a.2

Bank Q262 • AP Mock 3 Q69

On 20 May 2015 the European Parliament and Council issued a directive to prevent the use of the financial system for money laundering or terrorist financing. According to the European Union, which of the following activities constitutes money laundering?

A. Knowingly converting or transferring property derived from criminal activity in order to disguise the illicit origin of the property.

B. The provision or collection of funds to be used, partly or in full, to facilitate any offense considered by the authorities as a terrorism act.

C. Any intentional violation of the law or of internal policies perpetrated by the firm's employees.

D. Getting the money out to use while evading taxes and law enforcement through activities such as fake payments to employees, fake loans, or dividends to accomplices.

Question ORR-11 a.3

Bank Q265 • AnalystPrep Q.5123

An operational risk manager at a bank has asked a junior analyst to prepare a presentation on AML risk management to be presented to the board's risk committee. Which of the following controls falls under the "deterrents" step of AML controls?

A. Transaction monitoring system

B. Staff information and training

C. Ethos and values

D. Legal pursuits

Question ORR-11 a.4 Bank Q268 • BT P2.T7.24.2.1 (rebuilt)

HSBS Bank Plc has implemented a data analytics system that automatically monitors customer transactions for patterns that could indicate fraudulent activity. The system triggers alerts for transactions exceeding a threshold of 5,000 per day to or from high-risk jurisdictions. The alerts are then reviewed by a dedicated team trained to investigate potential financial crimes. What is the most relevant type of control covered in this instance?

A. Selection

B. Prevention

C. Detection

D. Deterrents

Question ORR-11 a.5 Bank Q267 • AnalystPrep Q.5126 (rebuilt)

In its 2022 report, the FCA examined financial crime controls at challenger banks, which are fully digital and offer customers the ability to open accounts very quickly. Which of the following was a key finding of the FCA review?

A. Rapid digital onboarding gives challenger banks more information on new customers than traditional banks hold, so higher-risk customers are identified more reliably.

B. Information gathered at account opening may be insufficient to identify higher-risk customers, so customer identification, verification and risk assessment need to be strengthened.

C. Because challenger banks rely on machine-learning KYC tools, they are exempt from enhanced due diligence for politically exposed persons.

D. Transaction monitoring alerts at challenger banks were consistently well documented, so no changes to oversight frameworks were required.

Question ORR-11 a.6 Bank Q270 • Schweser Module Quiz 52.1 Q2

Which of the following steps is not one of the phases in money laundering?

A. Conversion.

B. Integration.

C. Layering.

D. Placement.

Question ORR-11 a.7 Bank Q269 • Schweser Module Quiz 52.1 Q1

The risk manager of a regional U.S. commercial bank flags one of the business accounts for potential smurfing. Which of the following descriptions most likely reflects the activity that the manager flagged?

A. The account holder made a series of large withdrawals from the account.

B. The account holder made a series of frequent small deposits into the account.

C. The account was closed and reopened multiple times in a short period of time.

D. The account holder made a very large deposit into the account, well above the anti-money laundering (AML) reporting threshold.

Solutions • ORR-11 a

Solution ORR-11 a.1

Answer: A

Bank Q263 • AnalystPrep Q.5120

Step 1 – The FCA definition

Financial crime is "any kind of criminal conduct relating to money or to financial services or markets", including offences of fraud or dishonesty, market misconduct or misuse of information, handling the proceeds of crime, and financing of terrorism.
⇒ A is the opening clause of the definition.

Step 2 – Identify the other three

B is the Basel definition of internal fraud ("at least one internal party"); C is the Basel definition of external fraud ("by a third party"); D lists examples of the "theft and fraud" subcategory.

Interpretation

Financial crime is the umbrella; internal fraud, external fraud, ML and TF sit under it. GARP's distractors are the definitions of the parts.

Why the other options are wrong

B is incorrect. The Basel definition of internal fraud, only one component of financial crime.
C is incorrect. The Basel definition of external fraud, another single component.
D is incorrect. Examples from the theft and fraud subcategory: far too narrow to define financial crime.

LO: ORR-11 a: Describe elements of a control framework to manage financial fraud risk and money laundering risk.
• **Reference:** GARP ORR Ch.11, Context and Scope; SchweserNotes 2026 Book 3, Reading 52, LO 52.a

Solution ORR-11 a.2

Answer: A

Bank Q262 • AP Mock 3 Q69

Step 1 – Recall the Directive's four limbs

(a) conversion or transfer of property known to derive from criminal activity, to conceal or disguise its illicit origin; (b) concealment or disguise of its nature, source, location, movement or ownership; (c) acquisition, possession or use, knowing its origin at receipt; (d) participation, attempt, aiding and abetting.
⇒ A restates limb (a) almost word for word.

Step 2 – Place the other options

B is the IMF definition of terrorism financing. C is the Basel "unauthorised activities" subcategory of internal fraud. D is GARP's description of the integration (extraction) stage of laundering.

Interpretation

The question asks for the *legal* definition. D describes how launderers extract funds, a technique from the stages of laundering (Figure 3 under ORR-10 a), not what the Directive defines as the offence.

Why the other options are wrong

B is incorrect. Terrorism financing (IMF): a separate offence, and the funds may even be legal.
C is incorrect. Unauthorised activities by employees: internal fraud, not money laundering.
D is incorrect. The integration stage, a laundering technique, not the Directive's definition.

LO: ORR-11 a: Describe elements of a control framework to manage financial fraud risk and money laundering risk.
• **Reference:** GARP ORR Ch.11, Definition of Anti-Money Laundering (AML) and Terrorism Financing (TF)

Solution ORR-11 a.3 Answer: D

Bank Q265 • AnalystPrep Q.5123

Step 1 – The AML deterrents (GARP Figure 11.2)

Escalation to the relevant financial intelligence unit, legal pursuits, closure of accounts.
⇒ Legal pursuits is a deterrent.

Step 2 – Classify the others

A transaction monitoring system is detection. Staff information and training is prevention. Ethos and values is selection.

Interpretation

Each option is a real control from the same figure; the question tests the column, not the existence of the control. Deterrents act after the event and change the launderer's risk-reward balance.

Why the other options are wrong

A is incorrect. Detection: it finds abnormal transactions as they happen.
B is incorrect. Prevention: it builds the controls into staff behaviour before anything happens.
C is incorrect. Selection: it shapes who is taken on, alongside KYC and origin-of-funds checks.

LO: ORR-11 a: Describe elements of a control framework to manage financial fraud risk and money laundering risk.
• **Reference:** GARP ORR Ch.11, AML Risk Management and Figure 11.2

Solution ORR-11 a.4 Answer: C

Bank Q268 • BT P2.T7.24.2.1

Step 1 – What the control does

The system monitors transactions and raises alerts on abnormal patterns; a trained team then investigates them.

Step 2 – Match to the framework

Transaction monitoring systems and alerts on abnormal behaviour or transactions sit in the **detection** column (GARP Figure 11.2).
⇒ It is a detection control.

Interpretation

Two features tempt a different answer. The threshold and the high-risk-jurisdiction rule reflect the risk-based approach, but they are parameters of the monitoring, not a separate preventive control; the investigating team's training supports detection rather than being the control itself. (The bank question gives the threshold without a currency; it does not affect the answer.)

Why the other options are wrong

A is incorrect. Selection is screening and KYC at onboarding, not monitoring of live transactions.
B is incorrect. Prevention covers segregation of duties, access rights, the risk-based rating of customers, training and allocation of responsibilities: controls that limit opportunity before activity occurs.
D is incorrect. Deterrents are actions after the event: FIU escalation, legal pursuits, account closure.

LO: ORR-11 a: Describe elements of a control framework to manage financial fraud risk and money laundering risk.
• **Reference:** GARP ORR Ch.11, AML Risk Management and Figure 11.2

Solution ORR-11 a.5 — Answer: B

Bank Q267 • AnalystPrep Q.5126

Step 1 – The FCA's concern

Challenger banks open accounts very quickly, and the FCA "sees a risk that information gathered at the account opening stage is insufficient to identify higher risk customers" (Box 11.1).

Step 2 – The findings

Some good practice (innovative technology to identify and verify customers quickly), but weaknesses in CDD, inconsistent EDD (for example for PEPs), and inconsistent or inadequate rationale for ignoring transaction monitoring alerts. Recommendation: a risk-based approach with continuous monitoring of controls, and oversight that keeps up with growth.

$\Rightarrow$ Only B matches.

Interpretation

Speed and automation are not the problem in themselves; the problem is controls that do not keep pace with fast growth. That is the same lesson GARP draws from USAA (ORR-11 b).

Why the other options are wrong

A is incorrect. Reverses the finding: fast onboarding risks gathering too little information.
C is incorrect. No exemption exists; the FCA found EDD for PEPs applied inconsistently.
D is incorrect. The FCA found inconsistent or inadequate rationale for ignoring alerts and asked for stronger oversight.

LO: ORR-11 a: Describe elements of a control framework to manage financial fraud risk and money laundering risk.

- **Reference:** GARP ORR Ch.11, Box 11.1 Financial Crime Controls at UK Challenger Banks

Solution ORR-11 a.6 — Answer: A

Bank Q270 • Schweser Module Quiz 52.1 Q2

Step 1 – Name the stages

"The three phases in money laundering are placement, layering, and integration or extraction."

Step 2 – Locate "conversion"

Conversion appears in the EU Directive's definition of the offence ("the conversion or transfer of property"), not among the stages.

$\Rightarrow$ Conversion is not a phase.

Interpretation

The distractor borrows a word from the legal definition (Question ORR-11 a.2). Keep the definition (what the law forbids) apart from the stages (how launderers operate).

Why the other options are wrong

B is incorrect. Integration (extraction) is the third stage: getting the money out to use.
C is incorrect. Layering is the second stage: varying amounts and patterns to defeat tracking.
D is incorrect. Placement is the first stage: disguising the origin of the funds as they enter the system.

LO: ORR-11 a: Describe elements of a control framework to manage financial fraud risk and money laundering risk.

- **Reference:** GARP ORR Ch.11, AML Risk Management; SchweserNotes 2026 Book 3, Reading 52, LO 52.a

Solution ORR-11 a.7 — Answer: B

Bank Q269 • Schweser Module Quiz 52.1 Q1

Step 1 – Define smurfing

Smurfing "is making a series of small transactions instead of a single large transaction in order to remain below the AML reporting threshold for bank accounts or credit cards".

Step 2 – Place it

GARP lists smurfing among the **placement** techniques, which disguise the origin of funds as they enter the system.

$\Rightarrow$ Frequent small deposits are the signature.

Interpretation

This is shape S4: a technique mapped to its stage. The August workbook question (Question ORR-10 a.8, option A) planted smurfing under layering; the definition of layering in that option was right, the assignment wrong.

Why the other options are wrong

A is incorrect. Large withdrawals are not a way of slipping under a reporting threshold on the way in.

C is incorrect. Closing and reopening an account is not smurfing.

D is incorrect. One very large deposit is the opposite of smurfing: it would trigger the reporting the launderer wants to avoid.

LO: ORR-11 a: Describe elements of a control framework to manage financial fraud risk and money laundering risk.

• **Reference:** GARP ORR Ch.11, AML Risk Management

ORR-18 • Risk Capital Attribution and Risk-Adjusted Performance Measurement • Vardeez: VERY IMPORTANT

ORR-18 c

P1 CALC

Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance.

Workbook: A2 RAROC, Adjusted RAROC and Hurdle Rate • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: your August 2026 recall lists "RAROC – 1", and the topic map has it at #3 (9 of 16 sources).
Vardeez: RAROC calculations (theme 8 of his ORR list); ORR-18 is rank 1 of 55 in the consolidated volume. His notes label this LO "LO 57.c" (consolidated volume p.2).

Reported exam shapes

- **S1** Compute after-tax RAROC, in plain form and with red-herring inputs (regulatory capital, a trading VaR, multi-year totals).
- **S3** Direction of the effect on RAROC of a change in one component: economic capital, income or expense. A polarity question, not a plug-in.

What the questions look like: a loan or portfolio described by principal, yield, funding rate, expected loss, operating cost, economic capital, risk-free rate and tax rate, all as percentages of principal. You compute after-tax RAROC, then compare it with a hurdle rate or with another unit. Expect one input that does not belong in the formula.

See also: workbook A2.3 and A2.8 also tag this LO; they are worked under ORR-18 e (hurdle rate). Adjusted RAROC is ORR-18 f.

1. RAROC in one line

RAROC (risk-adjusted return on capital), proposed by Bankers Trust in the late 1970s, prices the trade-off between reward and risk for a business unit, a deal or a loan:

$$\text{RAROC} = \frac{\text{after-tax expected risk-adjusted net income}}{\text{economic capital}}$$

It fixes the two weaknesses of accounting ratios such as ROE and ROA:

- **Numerator:** it subtracts a risk factor from the return, chiefly the **expected loss**.
- **Denominator:** it replaces book (accounting) capital with **economic capital**, the capital the activity's risk actually consumes.

RORAC adjusts only the denominator (net income over economic capital). RAROC adjusts both. Unlike an NPV built on the CAPM beta, which prices only systematic risk, the RAROC denominator captures the *full* volatility of earnings, systematic and specific (GARP Box 18.2). That is why ORR-18 f later strips out the systematic part.

2. The capital-budgeting numerator, term by term

For capital budgeting, industry practice expands the generic form into GARP's equation (Section 18.4):

$$\text{RAROC} = \frac{\text{expected revenues} - \text{costs} - \text{expected losses} - \text{taxes} + \text{return on risk capital} \pm \text{transfers}}{\text{economic capital}}$$

Term	Sign	What it is, and how GARP sets it up
Expected revenues	$+$	What the activity is expected to earn *assuming no losses*: yield $\times$ principal, plus fees.
Costs	$-$	Direct operating expenses: salaries, bonuses, infrastructure.
Expected losses	$-$	Mainly expected default losses (the loan loss reserve), plus EL from market and operational risk. EL is priced into the spread over funding cost, so **no capital is held for it, but it is still deducted**.
Taxes	$-$	Effective tax rate on the whole pre-tax bracket, so the return on capital is taxed too: multiply by $(1-t)$.
Return on risk capital	$+$	The economic capital is assumed invested in risk-free securities (government bonds), so it earns $r_f \times$ EC. Added, never subtracted.
Transfers	$\pm$	Transfer pricing with treasury (the funding charge on deposits, hedging costs) and head-office overhead. In most questions the only transfer is the funding charge.

Written compactly, the form every calculation question uses is

$$\boxed{\text{RAROC} = \frac{\left(\text{Rev} - \text{Cost} - \text{Funding} - \text{EL} + r_f\,\text{EC}\right)(1-t)}{\text{EC}}}$$

3. The denominator: economic capital

Economic capital = risk capital + strategic risk capital.

- **Risk capital** covers the *worst-case loss minus the expected loss* from market, credit, operational and other risks, at the firm's confidence level, over one year. It is essentially a one-year VaR of unexpected loss (Figure 1).
- **Strategic risk capital** = **goodwill** (the premium paid above the replacement value of net assets in an acquisition) + **burned-out capital** (capital spent starting up a venture that may never be launched). Both are amortised as the risk of strategic failure fades.
- Some banks also allocate capital to **unused risk limits**, because a business unit can draw on that capacity at any moment.

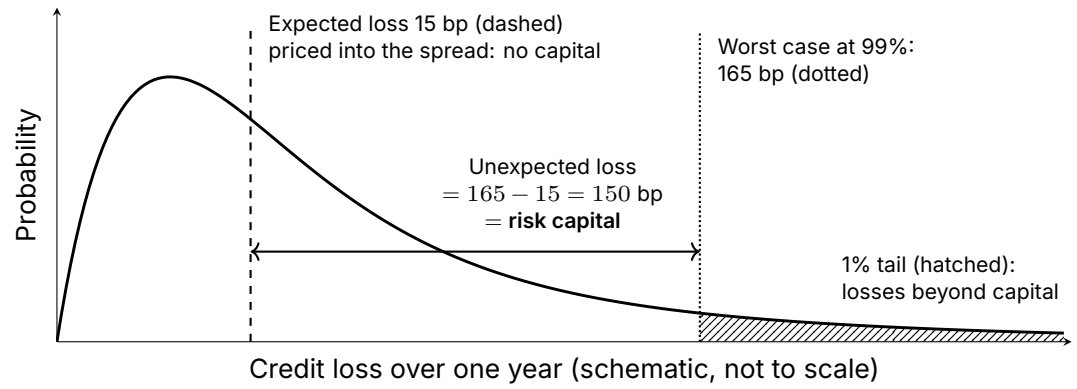


Figure 1. GARP Figure 18.1 redrawn. Revenues absorb the expected loss (dashed line); risk capital covers the gap between EL and the worst case at the confidence level (dotted line). Economic capital adds strategic risk capital on top.

Which capital goes in the denominator? Economic capital, in full. Regulatory capital is the wrong twin: an industry-wide minimum set by formula that rarely captures the activity's true risk. A short-horizon trading VaR is already inside the one-year economic capital (Box 18.3). EL never goes in the denominator.

4. Worked example: GARP's USD 1 billion loan portfolio

A corporate loan portfolio of USD 1 billion yields 9%. Direct operating cost USD 9 million, tax rate 30%. It is funded by USD 1 billion of retail deposits at a transfer-priced 6%. Economic capital is USD 75 million (7.5% of the loans), invested in government securities at 5%. Expected loss is 1% a year. No other transfers.

$$\text{Revenue} = 9\% \times 1{,}000 = 90 \qquad \text{Funding} = 6\% \times 1{,}000 = 60$$

$$\text{EL} = 1\% \times 1{,}000 = 10 \qquad r_f\,\text{EC} = 5\% \times 75 = 3.75$$

$$\text{Pre-tax} = 90 - 9 - 60 - 10 + 3.75 = 14.75 \qquad \text{After-tax} = 14.75 \times 0.70 = 10.325$$

$$\text{RAROC} = \frac{10.325}{75} = 13.77\%$$

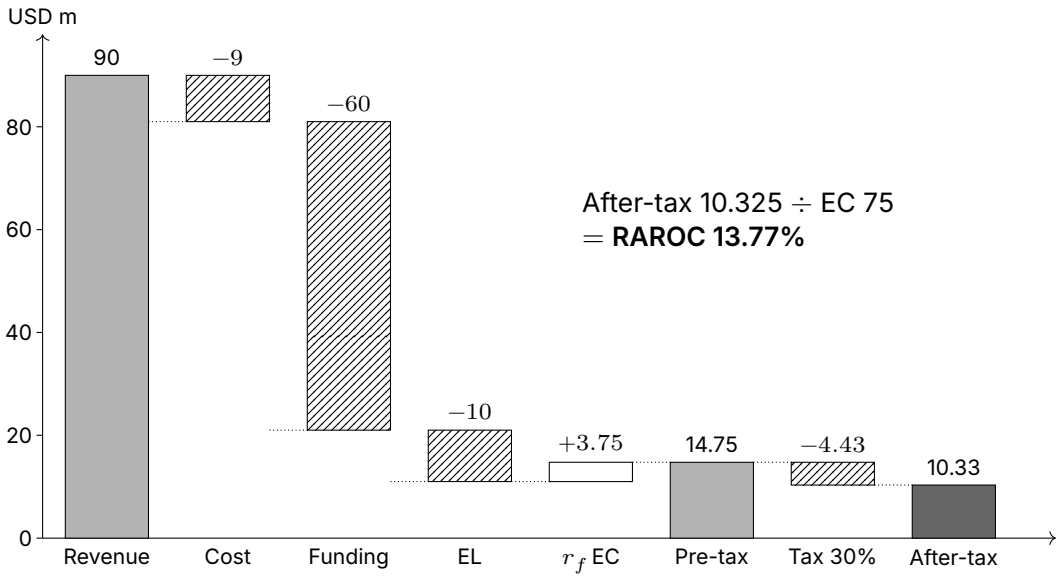


Figure 2. From revenue to after-tax risk-adjusted income. Totals are shaded grey (darkest for the after-tax result), deductions are hatched, and the one addition, the return on economic capital, is the open bar. Funding, not EL, is the largest deduction for a lending book.

> **Correction to the source notes.** GARP prints this result as "$= 0.14 = 14\%$". The exact value is $10.325/75 = 13.77\%$; 14% is a rounding. When options sit close together (13.8% against 14.0%), use the exact figure.

How GARP reads the number. 13.77% is "the annual after-tax expected rate of return on equity needed to support this loan portfolio": each dollar of economic capital earns about 13.8 cents a year after tax. Vardeez and Schweser use the same reading for their own example (USD 1.5 billion portfolio: $(105-10-75-7.5+1.2)(0.75)/120 = 8.56\%$). Whether that is good or bad depends on the hurdle rate (Section 5).

5. Interpreting RAROC and comparing business units

The decision rule

A business unit or deal **adds shareholder value when its RAROC exceeds the hurdle rate**, the bank's after-tax cost of equity capital (how to compute it: ORR-18 e). The same test can be written in currency as EVA, or NIACC (net income after capital charge):

$$\text{NIACC} = \text{after-tax risk-adjusted income} - \text{EC} \times h_{AT} \iff \text{NIACC} > 0 \iff \text{RAROC} > h_{AT}$$

In the GARP example at a 12% hurdle: NIACC $= 10.325 - 75 \times 12\% = +1.325$, so the portfolio adds about USD 1.3 million of value a year. The hurdle is the full cost of equity; the risk-free return on capital is already credited in the numerator, so do not net it off again.

Compare by RAROC, not by income

Rank units by return *per unit of economic capital*. A large unit can earn the most money and still destroy value:

Unit (hurdle 12%)	After-tax RANI	Economic capital	RAROC	NIACC
Cards	30	200	15.00%	+6.0
Corporate lending	45	400	11.25%	−3.0
Trade finance	12	80	15.00%	+2.4

Corporate lending earns the most (45) but returns 11.25% on its capital, below the 12% hurdle: it destroys USD 3 million of value. Cards and trade finance tie on RAROC; NIACC is larger for cards only because it is bigger. RAROC answers "which unit uses capital best"; NIACC answers "how much value does each create".

Ex ante and ex post

RAROC was first an **anticipatory** (ex ante) capital-budgeting tool: plug in *expected* revenues and losses. For **ex post** performance evaluation, use *realized* revenues and losses. When realized RAROC falls short of the projection, the variance is explained by comparing the two numerators item by item (Question ORR-18 c.7).

One horizon for every input

All inputs must be on the same horizon, normally one year (the business-planning cycle and the time to raise new capital after a large loss). A deal described by totals over its whole life must be **annualised** before it is divided by one year of capital (Question ORR-18 c.6).

6. What moves RAROC (shape S3)

Split the bracket into the part that depends on the business and the part earned on the capital itself:

$$\text{RAROC} = \underbrace{\frac{(\text{Rev} - \text{Cost} - \text{Funding} - \text{EL})(1-t)}{\text{EC}}}_{\text{business return}} + \underbrace{r_f(1-t)}_{\text{return on the capital}}$$

GARP example: $11 \times 0.7/75 + 5\% \times 0.7 = 10.27\% + 3.50\% = 13.77\%$.

- **Revenue, cost, funding charge, EL:** each moves RAROC by $(1-t)/\text{EC}$ per unit, revenue up, the other three down. In the example, $0.7/75 = 0.93$ points per USD 1 million. A one-million cost rise and a one-million revenue fall have *identical* effects.
- **Economic capital:** only the first term depends on it. For a unit whose business return is positive, *less* capital means a *higher* RAROC: cutting EC from 75 to 60 lifts RAROC to $11 \times 0.7/60 + 3.5\% = 16.33\%$. A lower confidence level (say 99.5% instead of 99.97%) cuts risk capital and so raises RAROC; the book warns it "can materially affect" allocation decisions.
- **EL:** "no risk capital is held against EL" is a statement about the denominator. EL is still deducted in the numerator, so a higher EL lowers RAROC.

7. Inputs that change the answer

- **EL built from credit parameters.** If the stem gives PD, LGD and EAD, then EL $=$ PD $\times$ LGD $\times$ EAD (CR-4). Forgetting LGD is a planted distractor.
- **What each percentage applies to.** Yield, funding rate, EL, operating cost and EC are usually percentages of the *loan*; the risk-free rate applies to *economic capital* only. Applying r_f to the whole loan inflates the numerator.
- **Transfers and one-off costs** ("other transfer costs", transaction costs) are deducted before tax unless the stem says otherwise.
- **Red herrings to recognise:** regulatory capital, a 10-day trading VaR, the hurdle rate (needed only for the decision, never for the RAROC itself), share or book values, and the loan amount as a tempting denominator.
- **Two RAROC formulas in the syllabus.** The loan RAROC of CR-5 g (Doumpos) is revenues over capital at risk with *no* return-on-capital term. For ORR-18 always use the GARP form above.

Formula card: ORR-18 c

Generic RAROC	$\text{RAROC} = \dfrac{\text{after-tax expected risk-adjusted net income}}{\text{economic capital}}$
Capital budgeting form	$\text{RAROC} = \dfrac{(\text{Rev} - \text{Cost} - \text{Funding} - \text{EL} + r_f\,\text{EC} \pm \text{transfers})(1-t)}{\text{EC}}$
Economic capital	EC $=$ risk capital (worst-case loss $-$ EL) $+$ strategic risk capital (goodwill $+$ burned-out capital)
Expected loss	$\text{EL} = \text{PD} \times \text{LGD} \times \text{EAD}$
Decomposition	$\text{RAROC} = (\text{Rev} - \text{Cost} - \text{Funding} - \text{EL})(1-t)/\text{EC} + r_f(1-t)$
Sensitivity	each USD 1 of revenue, cost, funding or EL moves RAROC by $(1-t)/\text{EC}$
Decision rule	add value if RAROC $> h_{AT}$; equivalently NIACC $=$ after-tax income $-$ EC $\times\, h_{AT} > 0$

Exam traps

- **Return on economic capital dropped or subtracted.** It is added. Each slip moves the answer by one option.
- **Wrong denominator.** Regulatory capital, the loan amount, risk capital without goodwill and burned-out capital, or EC plus a trading VaR. The denominator is economic capital in full.
- **Pre-tax answer.** Forgetting $(1-t)$. GARP always places the pre-tax figure among the options.
- **EL left out** because "no capital is held for it". It is deducted in the numerator.
- **EL as PD $\times$ EAD.** The LGD is missing.
- **r_f applied to the loan.** The risk-free return is earned on economic capital only.
- **Horizon mismatch.** Lifetime totals over one year of capital. Annualise first.
- **Polarity.** Higher costs, funding charges or EL lower RAROC; less capital raises it for a profitable unit.
- **Ranking by income.** The unit with the largest income need not have the highest RAROC, or clear the hurdle.

Practice questions: ORR-18 c

Question ORR-18 c.1

Bank Q406 • AnalystPrep Q.2207

A Catalonian bank will invest only in the activity with the highest RAROC, provided that RAROC exceeds its cost of equity of 6.2%. Two activities are proposed:

Activity	Expected risk-adjusted net income	Economic capital
I. Tarragona Construcciones	EUR 3,000,000 per year	EUR 50,000,000
II. Valencia Bonos	EUR 1,500,000 per year	EUR 22,000,000

Based on RAROC, the bank would most likely invest in:

A. Tarragona Construcciones

B. Valencia Bonos

C. Both activities

D. Neither activity

Question ORR-18 c.2

Bank Q405 • AP Mock 2 Q38 (rebuilt)

Smart Bank is reviewing the Small and Medium Businesses Lending division (SMBL) of AC Bank, which holds a USD 150 million loan portfolio funded by deposits. The portfolio has PD $= 7\%$, LGD $= 60\%$ and EAD equal to 100% of exposure. Over a one-year horizon:

Economic capital	USD 120 million
Operating direct costs	USD 1.25 million
Interest costs	USD 6 million
Return on risk capital (on economic capital)	2%
Return on the loan portfolio	12%
Hurdle rate	4.6%

Ignore taxes and transfers. What is the division's RAROC, and what should management do?

A. RAROC $= 2.21\%$; close the division because RAROC is below the hurdle rate

B. RAROC $= 3.71\%$; close the division because RAROC is below the hurdle rate

C. RAROC $= 5.71\%$; keep the division because RAROC exceeds the hurdle rate

D. RAROC $= 10.96\%$; keep the division because RAROC exceeds the hurdle rate

Question ORR-18 c.3

Bank Q417 • GARP PE1 Q73 • Mock 3 Q8

A regional commercial bank is considering a 1-year loan fully funded by deposits, with the following parameters:

Loan amount	JPY 4.2 billion
Average annual interest rate paid on deposits	0.4%
Annual interest rate received on loan	3.2%
Expected loss	2.0% of face value of loan
Annual operating costs	0.5% of face value of loan
Economic capital required to support the loan	10.0% of the loan
Average pre-tax return on economic capital	1.4%
Effective tax rate	38%
Other transfer costs	JPY 0

What is the after-tax RAROC for this loan?

A. 0.27%

B. 2.73%

C. 4.40%

D. 15.13%

Question ORR-18 c.4

Workbook A2.2 • S1 • Aug-2026 • Map #3

A risk consultant at a Japanese trust bank is reviewing the performance-measurement pack of the bank's structured-lending unit. For the coming year the unit reports (JPY billion):

Expected revenues	14.0
Direct operating costs	2.5
Funding transfer charge from treasury	8.0
Expected credit loss	1.2
Economic capital allocated	12.0
Regulatory capital requirement	16.0
10-day 99% trading VaR of the unit's hedge book	0.9

The risk-free rate on JGBs is 1.0% and the effective tax rate is 30%. Which of the following is closest to the unit's after-tax RAROC?

A. 10.6%

B. 13.1%

C. 13.4%

D. 14.1%

Question ORR-18 c.5

Workbook A2.1 • S1 • Aug-2026 • Map #3

A senior risk analyst at a Singapore commercial bank is preparing the capital-budgeting committee's review of a corporate loan portfolio. The committee wants both the after-tax RAROC and the economic value added (NIACC) of the portfolio. The data are:

- Loan portfolio: SGD 800 million, headline yield 8.5% per year; direct operating cost: SGD 7 million per year
- Funding: SGD 800 million of deposits, transfer-priced at 5.5% per year
- Expected loss: 0.8% of the portfolio per year
- Economic capital: 6% of the portfolio, invested in government securities yielding 4%
- Effective tax rate: 25%; the bank's after-tax hurdle rate: 12%

Which of the following is closest to the portfolio's after-tax RAROC and its NIACC?

A. RAROC 13.6%; NIACC SGD 0.75 million

B. RAROC 16.6%; NIACC SGD 2.19 million

C. RAROC 19.6%; NIACC SGD 3.63 million

D. RAROC 19.6%; NIACC SGD 5.55 million

Question ORR-18 c.6

Workbook A2.4 • S1 • Map #3

The head of performance measurement at a eurozone bank is evaluating a two-year acquisition-finance deal. Totals over the full two-year life are: revenues EUR 104 million, direct costs EUR 36 million, expected losses EUR 12 million and funding transfer charges EUR 30 million, all accruing evenly. Economic capital is held constant over the life and comprises risk capital of EUR 60 million (measured at the bank's 99.97% target confidence level), goodwill of EUR 8 million from the acquired origination team, and burned-out capital of EUR 4 million. Capital is invested at a risk-free rate of 3% per year and the tax rate is 25%. Using a one-year horizon, which of the following is closest to the deal's annual after-tax RAROC?

A. 15.8%

B. 18.5%

C. 21.1%

D. 29.3%

Question ORR-18 c.7

Bank Q415 • BT P2.T7.24.11.3 (rebuilt)

A bank's Audit and Risk Committee (ARC) is reviewing the performance of USD 100 million of new loans. The after-tax RAROC projected at initiation was 8.23%; by year-end the realized RAROC was -1.40%. The ARC asks internal audit and finance to explain the variance, giving both the following information:

Economic capital	40% of the loans
Expected revenue	7% of the loans
Return earned on economic capital	0.5% of the economic capital
Expected credit loss	3% of the loans
Operating costs (budgeted)	2.5% of the loans
Tax rate	30%
Sector-wide credit spreads	narrowed during the year

Finance: "The RAROC was miscalculated because the initial estimate did not include expected losses. In addition, actual operating costs were double the budget."
Internal audit: "The initial RAROC was accurate; the variance was mainly due to macroeconomic and sector-wide factors, not budgeting errors."
Which statement is most likely correct?

A. Finance's statement

B. Internal audit's statement

C. Both statements

D. Neither statement

Question ORR-18 c.8

Workbook A2.9 • S3 • Map #3

The head of the RAROC group at an Australian bank is presenting to business heads how a unit's after-tax RAROC responds to changes in its inputs. The unit's current figures (AUD million) are: expected revenues 14.0, direct costs 2.5, funding transfer charge 8.0, expected loss 1.2, economic capital 12.0 invested at a risk-free rate of 1%, tax rate 30%, giving a RAROC of 14.1%. Each change below is considered alone, all else equal. Which of the following statements should the head include?

A. Lowering the confidence level for economic capital from 99.97% to 99.5% would lower RAROC, because a smaller capital allocation earns less return on risk capital.

B. A higher funding charge transferred from treasury would raise RAROC, because transfer-pricing charges enter the numerator alongside the return on risk capital.

C. A one-million rise in direct costs would lower RAROC by exactly as much as a one-million fall in expected revenues, both effects reduced by the factor $(1 - t)$.

D. A one-million rise in expected loss would leave RAROC unchanged, because expected loss is priced into the spread and no risk capital is held against it.

Solutions • ORR-18 c

Solution ORR-18 c.1

Answer: B

Bank Q406 • AnalystPrep Q.2207

Step 1 – RAROC of each activity

$$\text{RAROC}_{\text{I}} = \frac{3.0}{50} = 6.00\% \qquad \text{RAROC}_{\text{II}} = \frac{1.5}{22} = 6.82\%$$

$\Rightarrow$ The income given is already after-tax and risk-adjusted, so each RAROC is a single division.

Step 2 – Apply the hurdle

Only Valencia's 6.82% exceeds the 6.2% cost of equity; Tarragona's 6.00% falls short.
$\Rightarrow$ Valencia is both the highest RAROC and the only one that adds value.

Interpretation

Tarragona earns twice the income but needs more than twice the capital. Ranking by income would pick the activity that destroys value: its NIACC is $3.0 - 50 \times 6.2\% = -\text{EUR } 0.10$ million, against $+\text{EUR } 0.14$ million for Valencia.

Why the other options are wrong

A is incorrect. Ranked by absolute income (EUR 3.0 million) instead of income per unit of capital; 6.00% is below the hurdle.

C is incorrect. Ignored the hurdle for Tarragona, and the rule allows only one activity in any case.

D is incorrect. Valencia's 6.82% clears the 6.2% hurdle.

LO: ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.2 and Box 18.2; Schweser-Notes 2026 Book 3, Reading 59, LO 59.c

Solution ORR-18 c.2

Answer: C

Bank Q405 • AP Mock 2 Q38

Step 1 – Revenue and expected loss

$$\text{Rev} = 12\% \times 150 = 18.00, \qquad \text{EL} = \text{PD} \times \text{LGD} \times \text{EAD} = 7\% \times 60\% \times 150 = 6.30$$

$\Rightarrow$ EL is the average default cost, which needs the loss given default, not just the PD.

Step 2 – Return on economic capital

$$r \times \text{EC} = 2\% \times 120 = 2.40$$

Step 3 – Risk-adjusted income and RAROC (no tax)

$$18.00 - 1.25 - 6.00 - 6.30 + 2.40 = 6.85, \qquad \text{RAROC} = \frac{6.85}{120} = 5.71\%$$

Step 4 – Decision

$5.71\% > 4.6\%$: the division adds value. Keep it.

Interpretation

The economic capital here is large relative to the book (80%), so the return earned on it carries real weight: without it RAROC falls below the hurdle and the decision flips.

Why the other options are wrong

A is incorrect. EL as PD $\times$ EAD $=$ 10.5, dropping LGD: $2.65/120 = 2.21\%$, and a wrong "close".

B is incorrect. Dropped the return on economic capital: $4.45/120 = 3.71\%$, and a wrong "close".

D is incorrect. Left out expected loss altogether: $13.15/120 = 10.96\%$. The decision happens to be right, the RAROC is not.

LO: ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.4

Solution ORR-18 c.3

Answer: B

Bank Q417 • GARP PE1 Q73

Step 1 – Components in JPY million

Revenue $3.2\% \times 4{,}200 = 134.4$; deposit interest $0.4\% \times 4{,}200 = 16.8$; EL $2.0\% \times 4{,}200 = 84.0$; operating costs $0.5\% \times 4{,}200 = 21.0$; EC $= 10\% \times 4{,}200 = 420$; return on EC $1.4\% \times 420 = 5.88$.

$\Rightarrow$ The 1.4% applies to the capital (420), not to the loan.

Step 2 – Pre-tax and after-tax income

$$134.4 - 16.8 - 84.0 - 21.0 + 5.88 = 18.48, \qquad 18.48 \times (1 - 0.38) = 11.4576$$

Step 3 – RAROC

$$\text{RAROC} = \frac{11.4576}{420} = 2.73\%$$

$\Rightarrow$ The loan barely earns more than the risk-free rate on its capital: the 2% EL eats most of the 2.8% spread.

Interpretation

This is GARP's standard template: every input is a percentage of the loan except the return on capital. A thin spread over a high expected loss gives a low RAROC even though the loan is profitable before risk adjustment.

Why the other options are wrong

A is incorrect. Divided by the loan amount instead of economic capital: $11.4576/4{,}200 = 0.27\%$.

C is incorrect. Pre-tax RAROC: $18.48/420 = 4.40\%$; the 38% tax is forgotten.

D is incorrect. Left out the expected loss: $(18.48 + 84) \times 0.62/420 = 15.13\%$.

LO: ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.4

Solution ORR-18 c.4

Answer: D

Workbook A2.2 • S1 • Aug-2026

Step 1 – Return on economic capital

$$r_f \,\text{EC} = 1.0\% \times 12.0 = \text{JPY } 0.12 \text{ bn}$$

Step 2 – Pre-tax and after-tax risk-adjusted income

$$14.0 - 2.5 - 8.0 - 1.2 + 0.12 = 2.42, \qquad 2.42 \times (1 - 0.30) = \text{JPY } 1.694 \text{ bn}$$

Step 3 – RAROC on economic capital

$$\text{RAROC} = \frac{1.694}{12.0} = 14.1\%$$

$\Rightarrow$ The unit returns about 14.1% after tax on the economic capital it consumes.

Interpretation

The denominator is economic capital. Regulatory capital is the wrong twin (an industry-wide minimum that rarely captures true risk), and the hedge book's 10-day VaR is a short-horizon market-risk number already reflected in the unit's one-year economic capital (Box 18.3). Both are red herrings.

Why the other options are wrong

A is incorrect. Used regulatory capital as the denominator: $1.694/16.0 = 10.6\%$.
B is incorrect. Added the 10-day trading VaR to economic capital: $1.694/(12.0 + 0.9) = 13.1\%$, double counting a risk already inside EC.
C is incorrect. Dropped the return on economic capital: $(14 - 2.5 - 8 - 1.2)(0.7)/12 = 13.4\%$.

LO: ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. ORR-18 a: Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.1, 18.4 and Box 18.3

Solution ORR-18 c.5 **Answer: C**

Workbook A2.1 • S1 • Aug-2026

Step 1 – Revenue, funding charge and expected loss

$$\text{Rev} = 8.5\% \times 800 = 68.0, \qquad \text{Funding} = 5.5\% \times 800 = 44.0, \qquad \text{EL} = 0.8\% \times 800 = 6.4$$

$\Rightarrow$ EL is the average annual default cost, priced into the spread; no capital is held for it, but it is still deducted.

Step 2 – Economic capital and its return

$$\text{EC} = 6\% \times 800 = 48.0, \qquad r_f \,\text{EC} = 4\% \times 48 = 1.92$$

$\Rightarrow$ The capital buffer sits in government securities and earns SGD 1.92 million, which is added to the numerator.

Step 3 – After-tax risk-adjusted income

$$(68.0 - 7.0 - 44.0 - 6.4 + 1.92)(1 - 0.25) = 12.52 \times 0.75 = \text{SGD } 9.39 \text{ million}$$

Step 4 – RAROC

$$\text{RAROC} = \frac{9.39}{48.0} = 19.6\%$$

$\Rightarrow$ Each SGD of economic capital earns about 19.6 cents a year after tax.

Step 5 – NIACC (EVA)

$$\text{NIACC} = 9.39 - 48.0 \times 12\% = 9.39 - 5.76 = \text{SGD } 3.63 \text{ million}$$

$\Rightarrow$ After charging shareholders' required return on the capital tied up, the portfolio creates SGD 3.63 million of value a year.

Interpretation

The two measures agree, as Box 18.2 says they must: RAROC of 19.6% is above the 12% hurdle, so the portfolio is EVA positive. The hurdle is the full after-tax cost of equity; the risk-free return on capital is already credited in the numerator.

Why the other options are wrong

A is incorrect. Subtracted the return on economic capital as a cost: $(68 - 7 - 44 - 6.4 - 1.92)(0.75) = 6.51$, RAROC 13.6%, NIACC $6.51 - 5.76 = 0.75$.

B is incorrect. Dropped the return on economic capital: $(68 - 7 - 44 - 6.4)(0.75) = 7.95$, RAROC 16.6%, NIACC $7.95 - 5.76 = 2.19$.

D is incorrect. Correct RAROC, but charged capital at the hurdle net of the risk-free rate, $48 \times (12\% - 4\%) = 3.84$, giving $9.39 - 3.84 = 5.55$. This credits the risk-free return twice.

LO: ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. ORR-18 b: Describe the RAROC (risk-adjusted return on capital) methodology and its use in capital budgeting. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.4 and Box 18.2

Solution ORR-18 c.6

Answer: A

Workbook A2.4 • S1

Step 1 – Economic capital

$$\text{EC} = \text{risk capital} + \text{goodwill} + \text{burned-out capital} = 60 + 8 + 4 = \text{EUR } 72 \text{ million}$$

$\Rightarrow$ Strategic risk capital is part of economic capital, not an optional extra.

Step 2 – Annualise the deal quantities

Rev $= 52$, Cost $= 18$, EL $= 6$, Funding $= 15$ (EUR million per year).

Step 3 – Annual after-tax risk-adjusted income

$$(52 - 18 - 6 - 15 + 3\% \times 72)(1 - 0.25) = 15.16 \times 0.75 = 11.37$$

Step 4 – RAROC

$$\text{RAROC} = \frac{11.37}{72} = 15.8\%$$

Interpretation

The deal earns 15.8% a year after tax on the full economic capital it ties up. The 99.97% confidence level is already embedded in the risk capital figure; it is not a further input.

Why the other options are wrong

B is incorrect. Used risk capital alone, in both the denominator and the capital return: $(13 + 1.8)(0.75)/60 = 18.5\%$.

C is incorrect. Forgot taxes: $15.16/72 = 21.1\%$, a pre-tax figure.

D is incorrect. Horizon mismatch: two-year totals over one year of capital, $(104 - 36 - 12 - 30 + 2.16)(0.75)/72 = 29.3\%$.

LO: ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. ORR-18 d: Explain challenges that arise when using RAROC for performance measurement, including choosing a time horizon, measuring default probability, and choosing a confidence level. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.4 and 18.5 (RAROC Horizon)

Solution ORR-18 c.7

Answer: A

Bank Q415 • BT P2.T7.24.11.3

Step 1 – Rebuild the projection

EC $= 40$, return on EC $= 0.5\% \times 40 = 0.2$ (USD million). Leaving EL out:

$$\frac{(7 + 0.2 - 2.5)(1 - 0.3)}{40} = \frac{3.29}{40} = 8.23\%$$

$\Rightarrow$ This reproduces the projected 8.23% exactly: the projection omitted expected loss.

Step 2 – What the projection should have been

$$\frac{(7 + 0.2 - 2.5 - 3)(0.7)}{40} = \frac{1.19}{40} = 2.98\%$$

Step 3 – Realized RAROC with costs doubled to 5

$$\frac{(7 + 0.2 - 5 - 3)(0.7)}{40} = \frac{-0.56}{40} = -1.40\%$$

$\Rightarrow$ This reproduces the realized -1.40% exactly.

Interpretation

An ex post RAROC uses realized figures, so the variance against the ex ante projection is explained item by item. Here two internal errors (EL left out of the projection, and a cost overrun) account for all of it, so there is nothing left for sector-wide factors to explain. The narrowing of credit spreads is a red herring. (The bank's version listed every input as "a percentage of the loans"; the return on capital only reproduces 8.23% as a rate on economic capital, so the stem has been clarified.)

Why the other options are wrong

B is incorrect. The initial RAROC was not accurate (8.23% against 2.98% with EL), and the realized figure is explained by an internal cost overrun.

C is incorrect. Internal audit's statement is false, so both cannot be correct.

D is incorrect. Both of finance's claims are confirmed by the numbers.

LO: ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.4 and 18.5 (ex ante and ex post RAROC)

Solution ORR-18 c.8

Answer: C

Workbook A2.9 • S3

Step 1 – Write RAROC as a function of its components

$$\text{RAROC} = \frac{(\text{Rev} - \text{Cost} - \text{Funding} - \text{EL})(1 - t)}{\text{EC}} + r_f(1 - t) = \frac{2.3 \times 0.7}{12} + 0.7\% = 14.1\%$$

$\Rightarrow$ Every pre-tax item in the bracket moves RAROC by $(1 - t)/\text{EC}$ per unit; economic capital moves only the first term.

Step 2 – Costs against revenues

$$\text{Cost} + 1: \quad \frac{(14 - 3.5 - 8 - 1.2 + 0.12)(0.7)}{12} = 8.3\%$$

$$\text{Rev} - 1: \quad \frac{(13 - 2.5 - 8 - 1.2 + 0.12)(0.7)}{12} = 8.3\%$$

$\Rightarrow$ Both cut RAROC by $1 \times 0.7/12 = 5.8$ points: identical, and scaled by $(1 - t)$.

Step 3 – The other components

Funding $+1$ and EL $+1$ give the same 8.3%. Lowering the confidence level cuts economic capital; for example EC of 9.0 gives $(2.3 + 0.09)(0.7)/9 = 18.6\%$, a higher RAROC.

Interpretation

Direction is the whole question: costs, funding charges and EL lower RAROC; less capital raises it for a profitable unit. The book stresses that the choice of confidence level "can materially affect risk-adjusted performance measures and the resulting capital allocation decisions".

Why the other options are wrong

A is incorrect. Polarity flip. A lower confidence level significantly reduces risk capital (18.5, Confidence Level). For a unit with positive risk-adjusted income the smaller denominator outweighs the lost risk-free return, so RAROC rises (14.1% to 18.6% in the illustration).

B is incorrect. Polarity flip on a transfer. The funding charge from treasury is a cost charged to the business unit; it is subtracted, so a higher charge lowers RAROC (to 8.3%).

D is incorrect. Scope error. "No risk capital for EL" is a statement about the denominator; EL is still subtracted in the numerator, so a higher EL lowers RAROC (to 8.3%).

LO: ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. ORR-18 d: Explain challenges that arise when using RAROC for performance measurement, including choosing a time horizon, measuring default probability, and choosing a confidence level. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.4 and 18.5 (Confidence Level)

ORR-18 • Risk Capital Attribution and Risk-Adjusted Performance Measurement • Vardeez: VERY IMPORTANT

ORR-18 e

P1 CALC

Calculate the hurdle rate and apply this rate in making business decisions using RAROC.

Workbook: A2 RAROC, Adjusted RAROC and Hurdle Rate • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: your August 2026 recall lists one hurdle-rate question, and the topic map has A2 at #3 (9 of 16 sources), with "find hurdle rate" and "weighted cost of capital given break-even cost" among the reported variants.
Vardeez: Hurdle rate, one of his three ORR-18 focus pointers (with RAROC calculations and adjusted RAROC); ORR-18 is theme 8 of his ORR list and rank 1 of 55 in the consolidated volume. His notes label this LO "LO 57.e" (consolidated volume p.4): the weighted formula, CAPM for common equity, and the accept/reject rule.

Reported exam shapes

- **S4** Find the hurdle rate: market-value-weighted cost of common equity (CAPM) and preferred equity.
- **S5** Weighted cost of capital given a break-even cost: back out the cost of common equity (and its beta) from a unit sitting exactly at the hurdle, or find the revenue at which RAROC just equals the hurdle.

What the questions look like: a capital-structure table (market and book values of common and preferred equity, preferred yield or dividend, equity beta, risk-free rate, market return, often a tax rate). You build h_{AT}, then compare it with a RAROC to accept or reject. The harder ones run the chain backwards. Expect red herrings: book values, the tax rate, the preferred coupon on par.

See also: the decision rule and NIACC are set up in ORR-18 c (Section 5). Workbook A2.3 and A2.8 also tag ORR-18 c and are worked here; A2.7 also tags this LO and is worked under ORR-18 f (break-even beta).

1. Where the hurdle rate sits

RAROC (ORR-18 c) says what each unit of economic capital *earns* after tax. The hurdle rate says what it *must* earn: the minimum rate of return on equity required by the shareholders. GARP's decision rule (18.5, "Hurdle Rate and Capital Budgeting Decision Rule"):

- If RAROC is greater than the hurdle rate, the activity is deemed to **add value** to the firm.
- In the opposite case the activity is deemed to **destroy value**, and it should be closed down or the project rejected.

In currency the same test is NIACC $=$ after-tax risk-adjusted income $-$ EC $\times$ h_{AT}, positive exactly when RAROC $>$ h_{AT} (ORR-18 c, Section 5). This LO is about the number on the right-hand side.

2. Building the hurdle rate (GARP Box 18.4)

Most firms use a **single hurdle rate for all business activities**: the **after-tax weighted-average cost of equity capital**,

$$h_{AT} = \frac{CE \times r_{CE} + PE \times r_{PE}}{CE + PE} \qquad r_{CE} = r_f + \beta_{CE}\,(R_M - r_f)$$

where CE and PE are the **market values** of common and preferred equity, r_{CE} comes from the CAPM (β_{CE} is the beta of the firm's common equity, R_M the expected market return) and r_{PE} is "simply the yield on the firm's preferred shares".

- **Equity only, so not a WACC.** There is no debt term. Deposits and other borrowing are already charged to the unit in the RAROC numerator through the funding transfer price; the denominator, economic capital, is equity.
- **Market values for the weights.** Book equity is a red herring.
- **The premium, not the market return.** β_{CE} multiplies $(R_M - r_f)$. If the stem gives correlation and volatilities instead of beta, $\beta_{CE} = \rho\,\sigma_{CE}/\sigma_M$.
- **Preferred: the current yield.** Annual preferred dividend divided by the market value of the preferred shares. A coupon quoted on par is not the yield.
- **Already after tax.** The cost of equity is a return to shareholders, paid out of after-tax income, and it is compared with *after-tax* RAROC. Do not gross it up and do not use the tax rate.
- **Reset rule.** The hurdle "should be reset periodically, say every six months, or when it has changed by more than 10 percent" (read as a relative change: a 10.0% hurdle is reset once it passes 11.0%).

3. Worked example: one bank, one hurdle

A bank's capital structure and market data (USD billion unless stated):

Market value of common equity	12.0	Equity beta β_{CE}	1.1
Book value of common equity	8.0	Risk-free rate	3.5%
Market value of preferred equity	3.0	Expected market return	9.0%
Preferred dividend (5% coupon on par of 3.6)	0.18	Effective tax rate	25%

$$r_{CE} = 3.5\% + 1.1 \times (9.0\% - 3.5\%) = 3.5\% + 6.05\% = 9.55\% \qquad r_{PE} = 0.18/3.0 = 6.0\%$$

$$h_{AT} = \frac{12.0 \times 9.55\% + 3.0 \times 6.0\%}{12.0 + 3.0} = \frac{1.146 + 0.180}{15.0} = \mathbf{8.84\%} \qquad \text{weights} = 80\% \,/\, 20\%$$

Book equity (8.0), the 5% coupon and the 25% tax rate play no part. Each of them is one slip away from a wrong option:

Slip	Hurdle it produces
Simple average of 9.55% and 6.0%	7.78%
Book value of common (8.0) as its weight	8.58%
Preferred coupon (5%) instead of the current yield (6%)	8.64%
Correct: market-value weights, current yield, CAPM on the premium	**8.84%**
Cost of common equity alone	9.55%
Grossed up for tax, $8.84\%/(1-0.25)$	11.79%
$\beta_{CE} \times R_M$ instead of $\beta_{CE} \times (R_M - r_f)$: $r_{CE} = 13.4\%$	11.92%

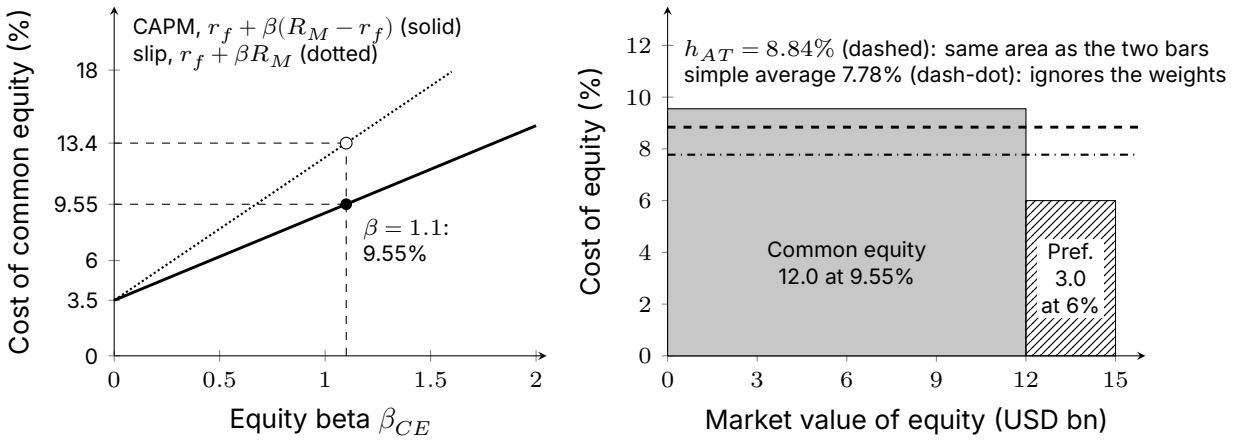


Figure 1. The worked example. Left: the CAPM line (solid) gives the cost of common equity, 9.55% at $\beta_{CE} = 1.1$; multiplying beta by the market return instead of the premium (dotted) gives 13.4%. Right: the hurdle is a market-value-weighted average, so the dashed line at 8.84% encloses the same area as the common-equity bar (grey) and the preferred bar (hatched) together.

4. Applying the hurdle: accept, reject, reset

Two loan portfolios against the bank's 8.84% hurdle

Take the two portfolios met in ORR-18 c: GARP's USD 1 billion portfolio and the Vardeez/Schweser USD 1.5 billion portfolio. NIACC charges each unit 8.84% on its economic capital (USD million).

Portfolio	After-tax income	EC	RAROC	Charge	NIACC	Decision
GARP, USD 1 bn	10.325	75	13.77%	6.630	+3.695	adds value
Vardeez/Schweser, USD 1.5 bn	10.275	120	8.56%	10.608	−0.333	destroys value

The two portfolios earn almost the same income, but the second ties up 60% more capital. Its 8.56% falls 0.28 points short of the hurdle, so the slips in Section 3 matter: against the simple average (7.78%) it would be accepted, a wrong decision; against the book-weighted (8.58%) or coupon-based (8.64%) figure it is still rejected. When RAROC sits close to the hurdle, the weighting decides the answer.

Resetting the hurdle

Suppose the bank's equity beta rises from 1.1 to 1.4. Then $r_{CE} = 3.5\% + 1.4 \times 5.5\% = 11.2\%$ and

$$h_{AT} = \frac{12.0 \times 11.2\% + 3.0 \times 6.0\%}{15.0} = 10.16\%, \qquad \frac{10.16\%}{8.84\%} - 1 = +14.9\% > 10\%$$

so the hurdle is reset now rather than at the next six-month review. GARP's portfolio still adds value (13.77%); the Vardeez/Schweser portfolio is now further below.

5. Running the chain backwards (shape S5)

Break-even revenue: RAROC used for pricing

Set RAROC equal to the hurdle and solve the capital-budgeting form of ORR-18 c for revenue:

$$\frac{(\text{Rev}^* - \text{Cost} - \text{Funding} - \text{EL} + r_f\,\text{EC})(1-t)}{\text{EC}} = h_{AT}$$

$$\Longrightarrow \qquad \boxed{\text{Rev}^* = \frac{h_{AT}\,\text{EC}}{1-t} + \text{Cost} + \text{Funding} + \text{EL} - r_f\,\text{EC}}$$

Three moves: the required after-tax income $h_{AT} \times \text{EC}$; gross it up for tax; add back every deduction and take off the return on capital, which the activity earns anyway. For GARP's portfolio at the 8.84% hurdle:

$$75 \times 8.84\% = 6.63, \qquad \frac{6.63}{0.70} = 9.471, \qquad \text{Rev}^* = 9.471 + 9 + 60 + 10 - 3.75 = 84.72$$

A break-even yield of 8.47% against the 9% offered: the pre-tax cushion $90 - 84.72 = 5.28$ is worth $5.28 \times 0.70 = 3.695$ after tax, which is exactly the NIACC in Section 4.

Weighted cost of capital given a break-even cost

If a unit sits *exactly* at break-even, its RAROC *is* the hurdle rate, the bank's weighted cost of equity. Invert the weighted average for the cost of common equity, then the CAPM for its beta:

$$\boxed{r_{CE} = \frac{h_{AT}(CE + PE) - PE \times r_{PE}}{CE}} \qquad \boxed{\beta_{CE} = \frac{r_{CE} - r_f}{R_M - r_f}}$$

Example: with the bank of Section 3 (CE 12.0, PE 3.0 at 6%), a trade-finance unit at break-even with RAROC 9.40% implies

$$r_{CE} = \frac{9.40\% \times 15.0 - 3.0 \times 6.0\%}{12.0} = \frac{1.41 - 0.18}{12.0} = 10.25\%, \qquad \beta_{CE} = \frac{10.25\% - 3.5\%}{9.0\% - 3.5\%} = 1.23$$

Check: $(12.0 \times 10.25\% + 3.0 \times 6.0\%)/15.0 = 9.40\%$. Because preferred equity is cheaper, common equity must cost *more* than the 9.40% average. Two traps: the break-even RAROC is after tax (do not use the pre-tax figure), and it is the *blended* cost, not r_{CE} itself.

6. The flaw in a single hurdle

GARP warns that applying the simple rule "can lead to a firm's accepting high-risk projects that will lower the value of the firm and rejecting low-risk projects that will increase the value of the firm". High-risk projects such as oil exploration have very volatile returns; low-risk ones such as properly risk-managed retail banking produce steady revenues. One hurdle charges both the same price for equity. The fix is the adjusted RAROC of Box 18.5: ORR-18 f.

Formula card: ORR-18 e

Hurdle rate	$h_{AT} = \dfrac{CE \times r_{CE} + PE \times r_{PE}}{CE + PE}$, CE, PE at market value
Common equity cost	$r_{CE} = r_f + \beta_{CE}(R_M - r_f)$; $\beta_{CE} = \rho\,\sigma_{CE}/\sigma_M$ if not given
Preferred cost	r_{PE} = yield on the preferred shares = annual dividend / market value
Decision rule	RAROC $>$ h_{AT}: adds value, accept; RAROC $<$ h_{AT}: destroys value, reject or close down
NIACC	after-tax risk-adjusted income $-$ EC $\times$ h_{AT} (> 0 exactly when RAROC $> h_{AT}$)
Break-even revenue	$\text{Rev}^* = h_{AT}\,\text{EC}/(1-t) + \text{Cost} + \text{Funding} + \text{EL} - r_f\,\text{EC}$
Implied common cost	$r_{CE} = [h_{AT}(CE + PE) - PE\,r_{PE}]/CE$, then $\beta_{CE} = (r_{CE} - r_f)/(R_M - r_f)$
Reset	every six months or so, or when h_{AT} has changed by more than 10%

Exam traps

- **Simple average.** The weights are market values; an unweighted mean of the two costs is a planted option.
- **Book weights.** Book equity is listed to be ignored.
- **Cost of common alone, or preferred alone.** Each one-cost answer is an option.
- **$\beta \times R_M$.** Beta multiplies the premium $R_M - r_f$, not the market return.
- **Coupon instead of yield.** The cost of preferred is its current market yield, not the dividend rate on par.
- **Tax gross-up.** The hurdle is already after tax and is compared with after-tax RAROC.
- **Adding debt.** The hurdle is a cost of equity, not a WACC.
- **Reversed rule.** Below the hurdle means value destruction, however small the gap.
- **Break-even run backwards.** Use the after-tax RAROC as the hurdle, and remember it is the blended cost: common equity costs more when preferred is cheaper.

Practice questions: ORR-18 e

Question ORR-18 e.1

Bank Q432 • Mock 1 Q36

Following the calculation of a business line's RAROC, a risk analyst must determine the hurdle rate against which it should be compared. The bank's capital structure and market data are:

Common equity (market value)	USD 800 million
Preferred equity (market value)	USD 200 million
Risk-free rate	3.0%
Expected market return	9.0%
Equity beta	1.30
Preferred dividend yield	6.0%

What is the bank's hurdle rate?

A. 6.00%

B. 8.40%

C. 9.84%

D. 10.80%

Question ORR-18 e.2

Workbook A2.5 • S4 • Aug-2026 • Map #3

The CFO of a Canadian bank is resetting the single firm-wide hurdle rate used in RAROC-based capital budgeting. The data are:

Item	Value
Market value of common equity	CAD 6.0 billion
Book value of common equity	CAD 3.0 billion
Market value of preferred equity	CAD 1.5 billion
Yield on the bank's preferred shares	7.0%
Beta of the bank's common equity	1.2
Risk-free rate	4.0%
Expected return on the market portfolio	10.0%
Effective tax rate	25%

Which of the following is closest to the bank's hurdle rate?

A. 10.36%

B. 11.20%

C. 13.81%

D. 14.20%

Question ORR-18 e.3

Bank Q431 • GARP PE2 Q17

A risk analyst in the RAROC group at Firm QZK is calculating the hurdle rate to be used in assessing whether some of the firm's business units are adding value. Firm QZK is funded only with common equity and preferred equity.

Market value of common equity	GBP 20 billion
Market value of preferred equity	GBP 8 billion
Dividend on preferred equity as a percentage of par value	6.0%
Current yield on preferred equity	4.5%
Expected return of the market portfolio	8%
Volatility of market returns	20%
Volatility of Firm QZK's common equity returns	14%
Correlation between market return and QZK common equity return	0.65

The analyst uses the CAPM to determine the cost of common equity and assumes the risk-free rate remains constant at 3%. What is the correct hurdle rate?

A. 5.05%

B. 5.28%

C. 5.48%

D. 7.64%

Question ORR-18 e.4

Bank Q430 • BT P2.T5.507.1 (rebuilt)

A bank is funded by common equity with a market value of USD 600 million and preferred equity with a market value of USD 400 million. The risk-free rate is 4%, the expected market return is 9%, the bank's equity beta is 1.2, and the preferred shares yield 5%. A business unit proposes to continue an activity whose after-tax RAROC is 7.8%. What is the bank's hurdle rate, and what should the bank do with the activity?

A. 7.5%; continue the activity because RAROC exceeds the hurdle rate

B. 8.0%; discontinue or reject the activity because RAROC is below the hurdle rate

C. 8.0%; continue the activity because RAROC exceeds the hurdle rate

D. 10.0%; discontinue or reject the activity because RAROC is below the hurdle rate

Question ORR-18 e.5

Bank Q429 • BT P2.T7.24.12.3

The CFO of Avenues Lending has requested the calculation of the hurdle rate for loan portfolio managers as part of the Loan Portfolio department's annual appraisal. The department's RAROC is 6.8%. The market value of common equity is USD 200 million and the market value of preferred equity is USD 800 million. A market study provides: equity beta 1.25; market return 8%; risk-free rate 5%; dividend on preferred shares USD 48 million. The Board is evaluating whether performance fees should be based on meeting the risk-adjusted hurdle rate. What is the hurdle rate, and what is the implication?

A. 6.55%; the department is generating sufficient returns to cover the cost of capital

B. 6.55%; the department is not generating sufficient returns to cover the cost of capital

C. 8.75%; the department is generating sufficient returns to cover the cost of capital

D. 8.75%; the department is not generating sufficient returns to cover the cost of capital

Question ORR-18 e.6

Workbook A2.3 • S1, S5 • Map #3

A treasury analyst at a Canadian bank is pricing a new CAD 500 million mid-market loan book. The book will incur direct costs of CAD 4 million per year, will be funded at a transfer price of 4.5%, carries an expected loss of 0.6% per year, and requires economic capital of CAD 40 million invested in Government of Canada bonds yielding 3.5%. The effective tax rate is 28% and the bank's hurdle rate is 12%. Which of the following is closest to the minimum annual expected revenue at which the book's after-tax RAROC just equals the hurdle rate?

A. CAD 32.90 million

B. CAD 34.77 million

C. CAD 36.17 million

D. CAD 37.57 million

Question ORR-18 e.7

Workbook A2.8 • S4, S5 • Map #3

The CFO of a US bank is explaining the firm-wide hurdle rate to the board. She notes that the bank's trade-finance unit is exactly at break-even: its expected after-tax RAROC equals the bank's single hurdle rate. Data (USD):

- Unit, per year: expected revenues 42 million; direct costs 9 million; funding transfer charge 24 million; expected loss 3 million
- Unit economic capital: 60 million, invested at the risk-free rate of 4%; effective tax rate 25%
- Bank: market value of common equity 9 billion; market value of preferred equity 3 billion; yield on preferred shares 6%
- Expected return on the market portfolio: 9%

Which of the following is closest to the cost of common equity implied by the break-even, and to the common equity beta consistent with it under the CAPM?

A. Cost of common equity 10.5%; beta 1.30

B. Cost of common equity 12.0%; beta 1.60

C. Cost of common equity 12.0%; beta 1.33

D. Cost of common equity 16.7%; beta 2.53

Solutions • ORR-18 e

Solution ORR-18 e.1

Answer: C

Bank Q432 • Mock 1 Q36

Step 1 – Cost of common equity (CAPM)

$$r_{CE} = 3.0\% + 1.30 \times (9.0\% - 3.0\%) = 3.0\% + 7.80\% = 10.80\%$$

Step 2 – Market-value weights

$$\frac{800}{1{,}000} = 80\% \text{ common}, \qquad \frac{200}{1{,}000} = 20\% \text{ preferred}$$

Step 3 – Hurdle rate

$$h_{AT} = 0.80 \times 10.80\% + 0.20 \times 6.0\% = 8.64\% + 1.20\% = 9.84\%$$

$\Rightarrow$ A business line adds value only if its after-tax RAROC exceeds 9.84%.

Interpretation

Preferred equity is cheaper than common, so it pulls the hurdle below the 10.80% cost of common equity, but only by its 20% market-value weight.

Why the other options are wrong

A is incorrect. The preferred yield alone (6.00%), ignoring the 80% common weight.
B is incorrect. A simple average, $(10.80\% + 6.0\%)/2 = 8.40\%$, ignoring the market-value weights.
D is incorrect. The cost of common equity alone (10.80%), ignoring the preferred equity.

LO: ORR-18 e: Calculate the hurdle rate and apply this rate in making business decisions using RAROC. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.4

Solution ORR-18 e.2

Answer: A

Workbook A2.5 • S4 • Aug-2026

Step 1 – Cost of common equity (CAPM)

$$r_{CE} = r_f + \beta_{CE}(R_M - r_f) = 4.0\% + 1.2 \times 6.0\% = 11.2\%$$

$\Rightarrow$ Shareholders require 11.2% a year for holding the bank's common stock.

Step 2 – Cost of preferred equity

$$r_{PE} = \text{yield on preferred shares} = 7.0\%$$

Step 3 – Market-value weights

$$CE + PE = 6.0 + 1.5 = 7.5: \quad 80\% \text{ common}, \ 20\% \text{ preferred}$$

Step 4 – Hurdle rate

$$h_{AT} = \frac{6.0 \times 11.2\% + 1.5 \times 7.0\%}{7.5} = \frac{0.672 + 0.105}{7.5} = 10.36\%$$

⇒ Any activity with after-tax RAROC above 10.36% is deemed to add value under the traditional rule.

Interpretation

Book equity and the tax rate are red herrings: Box 18.4 weights by market values, and the cost of equity is already an after-tax return to shareholders. (Weighting by book value would give 9.80%, which is not even among the options.)

Why the other options are wrong

B is incorrect. Reported the cost of common equity alone, ignoring the preferred equity in the weighted average: 11.20%.

C is incorrect. Grossed the hurdle up for tax: $10.36\%/(1-0.25) = 13.81\%$. The hurdle is the after-tax cost of equity and is compared with after-tax RAROC.

D is incorrect. Multiplied beta by the market return instead of the premium: $r_{CE} = 4\% + 1.2 \times 10\% = 16\%$, giving $(6 \times 16\% + 1.5 \times 7\%)/7.5 = 14.20\%$.

LO: ORR-18 e: Calculate the hurdle rate and apply this rate in making business decisions using RAROC. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.4

Solution ORR-18 e.3

Answer: A

Bank Q431 • GARP PE2 Q17

Step 1 – Beta from correlation and volatilities

$$\beta_{CE} = \frac{\text{Cov}(r_{CE}, R_M)}{\sigma_M^2} = \frac{\rho\,\sigma_{CE}\,\sigma_M}{\sigma_M^2} = \rho\,\frac{\sigma_{CE}}{\sigma_M} = 0.65 \times \frac{14\%}{20\%} = 0.455$$

⇒ QZK's equity is less volatile than the market and only moderately correlated with it, so its beta is well below 1.

Step 2 – Cost of common equity (CAPM)

$$r_{CE} = 3\% + 0.455 \times (8\% - 3\%) = 5.275\%$$

Step 3 – Cost of preferred equity

The current yield, 4.5%. The 6.0% is the dividend as a percentage of *par*, not the yield an investor earns at today's price.

Step 4 – Hurdle rate

$$h_{AT} = \frac{20 \times 5.275\% + 8 \times 4.5\%}{28} = \frac{1.055 + 0.360}{28} = 5.05\%$$

Interpretation

GARP builds two traps into one table: beta has to be derived, and two preferred rates are offered. Box 18.4 says the cost of preferred equity is "simply the yield on the firm's preferred shares", which is the current market yield.

Why the other options are wrong

B is incorrect. The cost of common equity alone (5.28%), ignoring the preferred weight of $8/28$.

C is incorrect. Used the 6.0% dividend on par as the cost of preferred: $(20 \times 5.275\% + 8 \times 6.0\%)/28 = 5.48\%$.

D is incorrect. Inverted the volatility ratio, $\beta = 0.65 \times 20\%/14\% = 0.929$, giving $r_{CE} = 3\% + 0.929 \times 5\% = 7.64\%$, and then ignored the preferred equity.

LO: ORR-18 e: Calculate the hurdle rate and apply this rate in making business decisions using RAROC. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.4

Solution ORR-18 e.4 — Answer: B

Bank Q430 • BT P2.T5.507.1

Step 1 – Costs of common and preferred equity

$$r_{CE} = 4\% + 1.2 \times (9\% - 4\%) = 10.0\%, \qquad r_{PE} = 5.0\%$$

Step 2 – Hurdle rate

$$h_{AT} = \frac{600 \times 10.0\% + 400 \times 5.0\%}{1{,}000} = \frac{60 + 20}{1{,}000} = 8.0\%$$

Step 3 – Decision

$7.8\% < 8.0\%$: the activity destroys value. Discontinue or reject it.
$\Rightarrow$ NIACC is negative: $(7.8\% - 8.0\%) \times \text{EC} = -0.2\%$ of the capital it ties up.

Interpretation

A gap of 0.2 points is still value destruction; the rule has no tolerance band. The weighting is what decides here: with 40% preferred equity the market-value weights matter a lot.

Why the other options are wrong

A is incorrect. A simple average, $(10\% + 5\%)/2 = 7.5\%$, which flips the decision to "continue".
C is incorrect. Correct hurdle, reversed rule: 7.8% is below 8.0%.
D is incorrect. The cost of common equity alone (10.0%). The decision happens to be right, the hurdle is not.

LO: ORR-18 e: Calculate the hurdle rate and apply this rate in making business decisions using RAROC. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.4 and Hurdle Rate and Capital Budgeting Decision Rule

Solution ORR-18 e.5 — Answer: A

Bank Q429 • BT P2.T7.24.12.3

Step 1 – Cost of common equity (CAPM)

$$r_{CE} = 5\% + 1.25 \times (8\% - 5\%) = 8.75\%$$

Step 2 – Cost of preferred equity: dividend over market value

$$r_{PE} = \frac{48}{800} = 6.0\%$$

Step 3 – Hurdle rate

$$h_{AT} = \frac{200 \times 8.75\% + 800 \times 6.0\%}{1{,}000} = \frac{17.5 + 48.0}{1{,}000} = 6.55\%$$

Step 4 – Decision

$6.8\% > 6.55\%$: the department covers the cost of capital and adds value.

Interpretation

Preferred equity is 80% of the market value of equity, so the hurdle sits close to the 6% preferred cost. The board's question about performance fees is context; it does not change the calculation.

Why the other options are wrong

B is incorrect. Correct hurdle, wrong implication: 6.8% exceeds 6.55%.
C is incorrect. The cost of common equity alone (8.75%), and the conclusion contradicts it: 6.8% is below 8.75%.

D is incorrect. The cost of common equity alone (8.75%), ignoring the 80% preferred weight, which turns a value-adding department into a value-destroying one.

LO: ORR-18 e: Calculate the hurdle rate and apply this rate in making business decisions using RAROC. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.4 and Hurdle Rate and Capital Budgeting Decision Rule

Solution ORR-18 e.6

Answer: B

Workbook A2.3 • S1, S5

Step 1 – Required after-tax income

$$h \times \text{EC} = 12\% \times 40 = \text{CAD } 4.80 \text{ million}$$

Step 2 – Gross up to pre-tax income

$$\frac{4.80}{1 - 0.28} = \text{CAD } 6.667 \text{ million}$$

$\Rightarrow$ Tax takes 28%, so the book must earn CAD 6.667 million before tax to keep CAD 4.8 million after tax.

Step 3 – Components to add back

$$\text{Funding} = 4.5\% \times 500 = 22.50, \qquad \text{EL} = 0.6\% \times 500 = 3.00, \qquad r_f\,\text{EC} = 3.5\% \times 40 = 1.40$$

Step 4 – Solve for revenue

$$\text{Rev} - 4 - 22.5 - 3.0 + 1.4 = 6.667 \quad \Longrightarrow \quad \text{Rev} = \text{CAD } 34.77 \text{ million}$$

$\Rightarrow$ The book must yield at least $34.77/500 = 6.95\%$ to be value-neutral.

Interpretation

This is RAROC used for risk-based pricing: the break-even yield at which the activity neither creates nor destroys shareholder value under the traditional rule.

Why the other options are wrong

A is incorrect. No tax gross-up: $4.8 + 4 + 22.5 + 3 - 1.4 = 32.90$.
C is incorrect. Forgot the return on economic capital: $6.667 + 4 + 22.5 + 3 = 36.17$.
D is incorrect. Treated the return on economic capital as a cost to recover: $6.667 + 4 + 22.5 + 3 + 1.4 = 37.57$.

LO: ORR-18 e: Calculate the hurdle rate and apply this rate in making business decisions using RAROC. ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.4 and Hurdle Rate and Capital Budgeting Decision Rule

Solution ORR-18 e.7

Answer: B

Workbook A2.8 • S4, S5

Step 1 – The unit's RAROC (the break-even cost of capital)

$$\text{RAROC} = \frac{(42 - 9 - 24 - 3 + 4\% \times 60)(1 - 0.25)}{60} = \frac{8.4 \times 0.75}{60} = \frac{6.3}{60} = 10.5\%$$

$\Rightarrow$ At break-even, the hurdle rate h_{AT} is 10.5%: this is the bank's after-tax weighted cost of equity capital.

Step 2 – Back out the cost of common equity from the weighted hurdle

$$h_{AT} = \frac{CE\, r_{CE} + PE\, r_{PE}}{CE + PE} \quad \Longrightarrow \quad r_{CE} = \frac{10.5\% \times 12 - 3 \times 6\%}{9} = \frac{1.26 - 0.18}{9} = 12.0\%$$

$\Rightarrow$ Preferred equity is cheaper (6%), so common equity must cost more than the 10.5% average.

Step 3 – Implied CAPM beta

$$r_{CE} = r_f + \beta_{CE}(R_M - r_f) \quad \Longrightarrow \quad \beta_{CE} = \frac{12.0\% - 4\%}{9\% - 4\%} = \frac{8.0\%}{5.0\%} = 1.60$$

Interpretation

The unit just covers a 10.5% value-weighted cost of equity. Check: $(9 \times 12\% + 3 \times 6\%)/12 = 10.5\%$. Any rise in the bank's beta would lift the hurdle and push the unit into value destruction under the traditional rule.

Why the other options are wrong

A is incorrect. Treated the break-even RAROC as the cost of common equity, ignoring the preferred weight: $r_{CE} = 10.5\%$, $\beta = (10.5\% - 4\%)/5\% = 1.30$.

C is incorrect. Correct cost of equity, but divided by the market return instead of the premium: $\beta = 12\%/9\% = 1.33$.

D is incorrect. Used the pre-tax RAROC $(8.4/60 = 14\%)$ as the hurdle: $r_{CE} = (14\% \times 12 - 0.18)/9 = 16.7\%$, $\beta = 2.53$. The hurdle is an after-tax rate.

LO: ORR-18 e: Calculate the hurdle rate and apply this rate in making business decisions using RAROC. ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.4 and Box 18.4

ORR-18 • Risk Capital Attribution and Risk-Adjusted Performance Measurement • Vardeez: VERY IMPORTANT

ORR-18 f

P1 CALC

Calculate the adjusted RAROC for a project to determine its viability.

Workbook: A2 RAROC, Adjusted RAROC and Hurdle Rate • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: the topic map has A2 at #3 (9 of 16 sources), and its reported variants include "2 on adjusted RAROC".

Vardeez: Adjusted RAROC, one of his three ORR-18 focus pointers. His notes label this LO "LO 57.f" (consolidated volume p.4): the formula, the new decision rule (accept if ARAROC $>$ r_f) and one worked example (RAROC 12%, r_f 5%, R_M 11%, β_E 1.5: ARAROC 3%, reject).

Reported exam shapes

- **S2** Two on adjusted RAROC: (i) the value plus the accept/reject decision; (ii) the break-even beta, the highest beta at which the project still passes.

What the questions look like: a RAROC (given, or built from a loan's data as in ORR-18 c), an equity beta, the expected market return and the risk-free rate. You compute ARAROC and decide against r_f. Options pair a number with a decision and a reason, so the benchmark matters as much as the arithmetic. Red herrings: the traditional hurdle rate, a "required return on equity".

See also: RAROC from data is ORR-18 c; the single hurdle rate and its flaw are ORR-18 e (Sections 2 and 6). Workbook A2.7 also tags ORR-18 e and is worked here.

1. Why RAROC needs adjusting

Two facts from the earlier LOs collide here:

- The RAROC denominator, economic capital, captures the *full* volatility of earnings, systematic and specific (ORR-18 c, Section 1; GARP Box 18.2). Shareholders who hold a well-diversified portfolio are paid only for the *systematic* part.
- Most firms judge every activity against one hurdle rate (ORR-18 e). GARP: this simple rule "can lead to a firm's accepting high-risk projects that will lower the value of the firm and rejecting low-risk projects that will increase the value of the firm". Oil exploration is the high-risk example; properly risk-managed retail banking the low-risk one.

Box 18.5 therefore adjusts RAROC for the systematic riskiness of returns, so that "the hurdle rate (the critical benchmark above which a business adds value) is the same across all business lines".

2. The adjusted RAROC (GARP Box 18.5)

$$\boxed{\text{ARAROC} = \text{RAROC} - \beta_E\,(R_M - r_f)}$$

$$\boxed{\text{accept if ARAROC} > r_f} \qquad \boxed{\text{reject if ARAROC} < r_f}$$

- R_M: expected rate of return on the market portfolio. r_f: the risk-free rate, "say, the interest rate paid on three-month Treasury bills". β_E: the beta of the firm's equity.
- $\beta_E(R_M - r_f)$ is "the excess return above the risk-free rate required to compensate the shareholders of the firm for the nondiversifiable systematic risk they bear when investing in the activity". Once

it is taken off, what is left must beat the risk-free rate: "the hurdle rate becomes the risk-free rate", for every business line.

- Three equivalent ways to state the same test:

$$\text{ARAROC} > r_f \iff \text{RAROC} > \underbrace{r_f + \beta_E(R_M - r_f)}_{\text{CAPM required return}} \iff \text{RAROC} - r_{\text{CAPM}} > 0$$

Subtracting the *whole* CAPM return (not just the premium) gives a number that must be compared with **zero**, not with r_f. Mixing the two is the commonest wrong option.

> **Correction to the source notes.** GARP's Box 18.5 opens by asking for a measure that reflects "the *systemic* riskiness of returns", and Vardeez copies the word. The risk meant is **systematic** (nondiversifiable market) risk, measured by beta, as the same box says a few lines later. Systemic risk is the risk to the financial system as a whole, which is a different idea. If an option says ARAROC adjusts for systemic risk, read it as systematic.

Which beta? GARP writes β_E and calls it the beta of the firm's equity, while describing the charge as the one shareholders require "when investing in the activity". Exam stems give a single beta (the firm's, or a project's said to share it): use it. Note what this implies. If the beta used is the firm's own equity beta and the firm has no preferred equity, the adjusted rule and the single-hurdle rule give the *same* decision, because $r_f + \beta_E(R_M - r_f)$ is then exactly the hurdle. The two rules part company when the activity's systematic risk differs from the firm's, or when cheaper preferred equity pulls the blended hurdle below the CAPM cost of common equity.

3. Worked examples

Vardeez and Schweser: a project that fails

RAROC 12%, $r_f = 5\%$, $R_M = 11\%$, $\beta_E = 1.5$:

$$\text{ARAROC} = 12\% - 1.5 \times (11\% - 5\%) = 12\% - 9\% = 3\% < 5\% \implies \text{reject}$$

The project clears any single hurdle below 12%, yet its beta of 1.5 calls for $5\% + 9\% = 14\%$. It is the "high-risk project that lowers the value of the firm".

GARP's loan portfolio: the full chain

Start from the USD 1 billion portfolio of ORR-18 c (RAROC 13.77%, risk-free rate 5%) and add market data: $\beta_E = 1.2$, $R_M = 10\%$.

$$\text{ARAROC} = 13.77\% - 1.2 \times (10\% - 5\%) = 13.77\% - 6.00\% = 7.77\% > 5\% \implies \text{accept}$$

Equivalently, RAROC of 13.77% beats the CAPM required return $5\% + 6\% = 11\%$ by 2.77 points, which is also ARAROC $- r_f$.

4. The break-even beta and the minimum RAROC (shape S2)

Set ARAROC equal to r_f and solve for whichever input is missing:

$$\boxed{\beta^* = \frac{\text{RAROC} - r_f}{R_M - r_f}} \qquad \boxed{\text{RAROC}_{\text{min}} = r_f + \beta_E\,(R_M - r_f)}$$

- **Break-even beta:** the most systematic risk the activity can carry and still pass. Accept if $\beta_E < \beta^*$. Vardeez's project: $\beta^* = (12\% - 5\%)/6\% = 1.17$, below its actual 1.5, so reject. GARP's portfolio: $\beta^* = (13.77\% - 5\%)/5\% = 1.75$, above 1.2, so accept.

- **Minimum RAROC:** the beta-specific hurdle. Vardeez's project needs at least $5\% + 1.5 \times 6\% = 14\%$.
- **Two slips to avoid:** dividing by R_M instead of the premium, and setting ARAROC to zero instead of r_f (which gives RAROC$/(R_M - r_f)$, too high a beta).

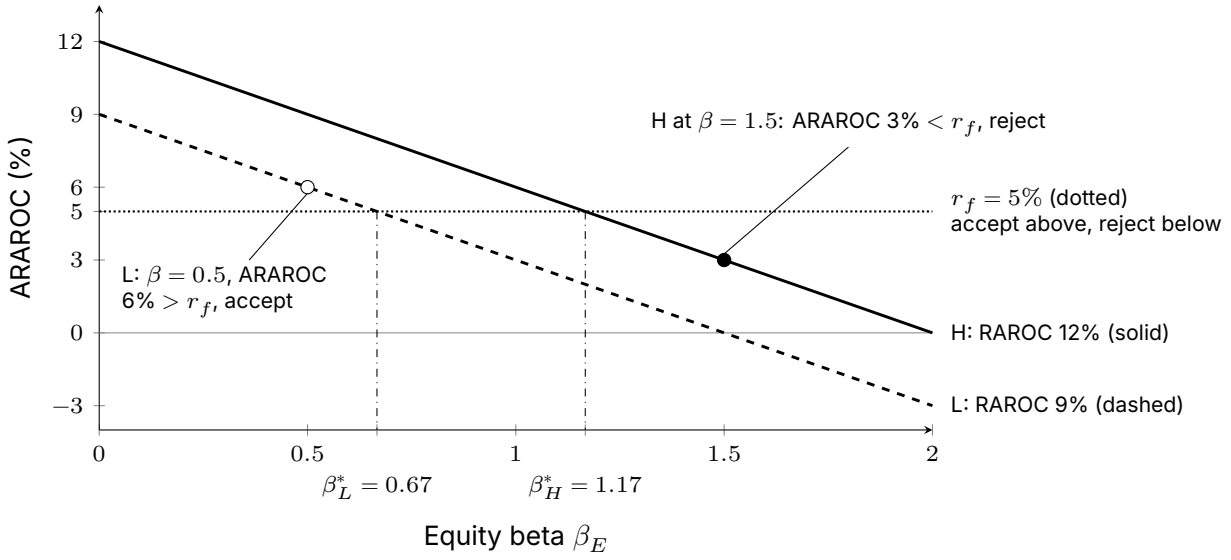


Figure 1. ARAROC against beta, with $r_f = 5\%$ and $R_M = 11\%$, for a high-risk project H (Vardeez's example, solid line) and a low-risk project L (dashed line). Each line falls by the 6% premium per unit of beta and crosses the risk-free acceptance line (dotted) at its break-even beta (dash-dot drops). A single 11% hurdle (a firm beta of 1.0, all common equity) would accept H (12%) and reject L (9%): the adjusted rule reverses both.

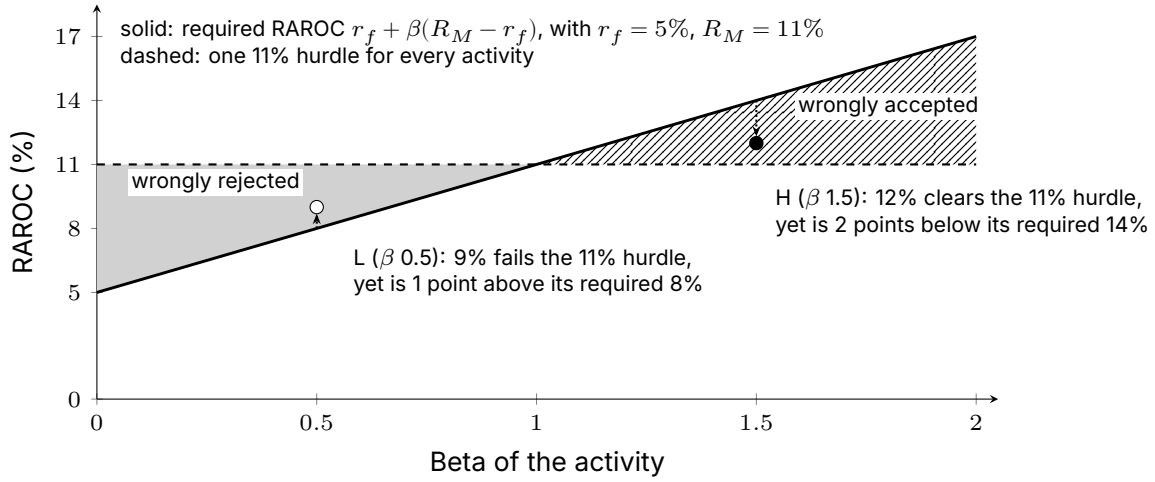


Figure 2. The same two projects in RAROC terms. The solid line is the CAPM return each activity must earn for its beta; the dashed line is one 11% hurdle for all. Above the hurdle but below the solid line (hatched), a single hurdle accepts value-destroying high-beta projects; below the hurdle but above the solid line (grey), it rejects value-creating low-beta ones. Dotted arrows run from each project's required return to its RAROC.

5. Compare with the right benchmark

Measure	Compare with	Source
RAROC	the single hurdle h_{AT}	ORR-18 e, traditional rule
NIACC	zero	ORR-18 c, Box 18.2
ARAROC $=$ RAROC $-\beta_E(R_M - r_f)$	**the risk-free rate** r_f	Box 18.5
RAROC $-[r_f + \beta_E(R_M - r_f)]$	zero	same test, rearranged

Wrong benchmarks GARP plants for ARAROC: zero ("ARAROC is positive, so accept"), the old hurdle rate, the cost of equity, and the market excess return $R_M - r_f$.

Formula card: ORR-18 f

Adjusted RAROC	$\text{ARAROC} = \text{RAROC} - \beta_E(R_M - r_f)$
Decision rule	accept if ARAROC $> r_f$; reject if ARAROC $< r_f$
Same test	$\text{RAROC} > r_f + \beta_E(R_M - r_f)$, or $\text{RAROC} - r_{\text{CAPM}} > 0$
Break-even beta	$\beta^* = (\text{RAROC} - r_f)/(R_M - r_f)$; accept if $\beta_E < \beta^*$
Minimum RAROC	$\text{RAROC}_{\text{min}} = r_f + \beta_E(R_M - r_f)$
RAROC from data	(Rev $-$ Cost $-$ Funding $-$ EL $+ r_f$ EC $\pm$ transfers)$(1-t)$/EC (ORR-18 c)

Exam traps

- $\beta \times R_M$. The charge is beta times the *premium*; βR_M over-charges by βr_f.
- **Beta dropped.** Subtracting $R_M - r_f$ alone, or r_f alone, is a planted option.
- **Wrong benchmark.** ARAROC is compared with r_f: not zero, not the old hurdle, not the cost of equity, not $R_M - r_f$.
- **Full CAPM return subtracted, then compared with r_f.** RAROC $- r_{\text{CAPM}}$ belongs against zero.
- **Ratio forms.** $(\text{RAROC} - r_f)/\beta$ is not ARAROC.
- **Red-herring hurdle.** A stated hurdle rate or "required return on equity" plays no part in the adjusted rule.
- **Break-even beta.** Divide by the premium, and set ARAROC to r_f, not to zero.
- **Full chain.** When RAROC must be built first, every ORR-18 c trap applies: transfer costs, taxes, the return on economic capital.

Practice questions: ORR-18 f

Question ORR-18 f.1

Bank Q442 • BT P2.T7.3.4 (rebuilt)

Which of the following best describes the advantage of adjusted RAROC (ARAROC) over unadjusted RAROC when evaluating projects?

A. ARAROC is computed from market values, whereas RAROC relies on book values.

B. ARAROC is a multi-period measure, whereas RAROC is a single-period measure.

C. ARAROC deducts a charge for the project's systematic risk, so that the same hurdle rate (the risk-free rate) applies across all projects and business lines.

D. ARAROC replaces economic capital in the denominator with regulatory capital.

Question ORR-18 f.2

Bank Q434 • GARP PE2 Q80 • Mock 4 Q81

A packaging materials manufacturer is considering a project that has an estimated RAROC of 12%. Suppose that the risk-free rate is 4% per year, the expected market rate of return is 10% per year, and the company's equity beta is 1.6. The manufacturer uses the adjusted RAROC metric as the criterion to decide whether or not to accept the project. Which of the following correctly describes the decision the company should make and the rationale for making that decision?

A. Reject the project because the adjusted RAROC is higher than the market expected excess return.

B. Accept the project because the adjusted RAROC is higher than the market expected excess return.

C. Reject the project because the adjusted RAROC is lower than the risk-free rate.

D. Accept the project because the adjusted RAROC is lower than the risk-free rate.

Question ORR-18 f.3

Workbook A2.6 • S2 • Map #3

A senior risk analyst at a UK bank is reviewing a proposed GBP trade-finance business line for the risk committee. Its expected after-tax risk-adjusted net income is GBP 21 million per year and it requires economic capital of GBP 150 million. The bank's equity beta is 1.3, the expected return on the market portfolio is 9.0%, and the three-month Treasury bill rate is 3.5%. Using the adjusted RAROC, which of the following is the correct value and decision?

A. ARAROC of 2.30%; reject, because it is below the risk-free rate

B. ARAROC of 3.35%; reject, because it is below the risk-free rate

C. ARAROC of 6.85%; reject, because it is below the bank's cost of equity of 10.65%

D. ARAROC of 6.85%; accept, because it is above the risk-free rate

Question ORR-18 f.4 Bank Q438 • AnalystPrep Q.3209 (rebuilt)

Henry Campbell is analyzing a new market-expansion project. The project's RAROC is 13%, the risk-free rate is 6%, the market return is 14%, the firm's required return on equity is 12%, and the firm's beta is 1.5. What is the ARAROC and should the project be accepted?

A. 1.0%; accept

B. 1.0%; reject

C. 4.7%; reject

D. 7.0%; accept

Question ORR-18 f.5 Bank Q436 • AnalystPrep Q.3136 (rebuilt)

Sigma Inc. has an equity beta of 1.18. The risk-free rate is 2% and the expected market return is 7.932%. A proposed project has the same beta as Sigma Inc. What is the minimum RAROC the project must offer for it to be accepted under the adjusted RAROC criterion?

A. 2.00%

B. 5.93%

C. 7.00%

D. 9.00%

Question ORR-18 f.6 Workbook A2.7 • S2 • Map #3

A risk consultant at an Australian bank is advising on a new AUD equipment-leasing activity. The activity's expected after-tax RAROC is 12.4%. The bank's traditional single hurdle rate is 10.5%, the risk-free rate is 3.0%, and the expected return on the market portfolio is 8.0%. The consultant wants to know how much systematic risk the activity can carry before it fails the adjusted-RAROC test. Which of the following is closest to the maximum equity beta at which the activity would still be accepted?

A. 1.18

B. 1.55

C. 1.88

D. 2.48

Question ORR-18 f.7 Bank Q441 • BT P2.T7.24.12.3 (rebuilt)

A bank is considering a USD 200 million investment in a loan portfolio and will judge it using adjusted RAROC (ARAROC). Economic capital (EC) is 50% of the loan amount, and the board is concerned with systematic risk. The internal hurdle rate for the unadjusted RAROC is 6%.

Forecast data	Value	Market data	Value
Interest earned from loans	10%	Equity market return	7%
Pre-tax return on economic capital	5.0%	Risk-free rate	3%
Interest paid on deposits	4%	Equity beta	1.05
Operating direct costs	0.8%		
Transfer costs	1%		
Expected loss	2.00%		
Effective tax rate	32%		

All percentages other than the return on EC and the tax rate are on the USD 200 million loan amount; transfer costs are a charge against the activity. Which of the following is the correct conclusion?

A. Reject; ARAROC is 2.19%, below the 3% risk-free rate

B. Reject; ARAROC is 2.39%, below the 3% risk-free rate

C. Accept; ARAROC is 3.55%, above the 3% risk-free rate

D. Accept; RAROC is 6.39%, above the 6% hurdle rate

Solutions • ORR-18 f

Solution ORR-18 f.1

Answer: C

Bank Q442 • BT P2.T7.3.4

Step 1 – What the traditional rule gets wrong

Unadjusted RAROC is judged against one hurdle for every activity, while its denominator reflects total volatility. High-return, high-risk projects tend to pass and low-risk projects tend to fail, whatever their systematic risk.

Step 2 – What the adjustment does

ARAROC subtracts $\beta_E(R_M - r_f)$, the excess return shareholders need for the nondiversifiable risk of the activity. What remains is compared with r_f, the same benchmark for every project and business line.

$\Rightarrow$ Only C describes the change: a systematic-risk charge in the numerator and a common risk-free hurdle.

Interpretation

Box 18.5 states the goal in exactly these terms: a RAROC that reflects the systematic riskiness of returns and "for which the hurdle rate ... is the same across all business lines".

Why the other options are wrong

A is incorrect. Market against book value is not the issue. RAROC already uses economic capital rather than book capital, and the market values belong to the hurdle-rate calculation (ORR-18 e).

B is incorrect. Both are single-period measures in this chapter. Multi-period RAROC is a separate extension whose methodological issues GARP calls unresolved.

D is incorrect. The denominator stays economic capital. The adjustment changes the return side, not the capital definition.

LO: ORR-18 f: Calculate the adjusted RAROC for a project to determine its viability. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.5 (Hurdle Rate and Capital Budgeting Decision Rule) and Box 18.5

Solution ORR-18 f.2

Answer: C

Bank Q434 • GARP PE2 Q80

Step 1 – Systematic risk charge

$$\beta_E(R_M - r_f) = 1.6 \times (10\% - 4\%) = 1.6 \times 6\% = 9.6\%$$

Step 2 – Adjusted RAROC

$$\text{ARAROC} = 12\% - 9.6\% = 2.4\%$$

Step 3 – Decision against the risk-free rate

$2.4\% < r_f = 4\%$: reject.

$\Rightarrow$ With a beta of 1.6 the project would need a RAROC of $4\% + 9.6\% = 13.6\%$; it offers 12%.

Interpretation

The options test the benchmark as much as the arithmetic. After the adjustment the hurdle is the risk-free rate; the market excess return (6%) is an input, not a benchmark.

Why the other options are wrong

A is incorrect. Wrong benchmark, and the comparison is false as well: 2.4% is below, not above, the 6% market excess return.

B is incorrect. Wrong benchmark and a false comparison, leading to the wrong decision.
D is incorrect. Finds ARAROC below the risk-free rate and accepts anyway, which reverses the rule.

LO: ORR-18 f: Calculate the adjusted RAROC for a project to determine its viability. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.5

Solution ORR-18 f.3

Answer: D

Workbook A2.6 • S2

Step 1 – Traditional RAROC

$$\text{RAROC} = \frac{21}{150} = 14.0\%$$

Step 2 – Systematic risk adjustment

$$\beta_E(R_M - r_f) = 1.3 \times (9.0\% - 3.5\%) = 1.3 \times 5.5\% = 7.15\%$$

$\Rightarrow$ Shareholders need 7.15% above the risk-free rate for the nondiversifiable risk of this activity.

Step 3 – Adjusted RAROC

$$\text{ARAROC} = 14.0\% - 7.15\% = 6.85\%$$

Step 4 – Decision rule

$6.85\% > r_f = 3.5\%$: accept.

Interpretation

After the adjustment the hurdle is the risk-free rate, the same for every business line. Equivalently, RAROC of 14.0% beats the beta-specific cost of equity $3.5\% + 7.15\% = 10.65\%$.

Why the other options are wrong

A is incorrect. Multiplied beta by the market return instead of the premium: $14.0\% - 1.3 \times 9.0\% = 2.30\%$.
B is incorrect. Subtracted the full CAPM cost of equity (10.65%) rather than only the risk premium: $14.0\% - 10.65\% = 3.35\%$, then compared it with r_f. That figure is RAROC minus the hurdle and belongs against zero.
C is incorrect. Correct value, wrong benchmark: once returns are adjusted for systematic risk, ARAROC is compared with r_f, not with the cost of equity, which would remove the risk premium twice.

LO: ORR-18 f: Calculate the adjusted RAROC for a project to determine its viability. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.5

Solution ORR-18 f.4

Answer: B

Bank Q438 • AnalystPrep Q.3209

Step 1 – Systematic risk charge

$$\beta_E(R_M - r_f) = 1.5 \times (14\% - 6\%) = 1.5 \times 8\% = 12\%$$

Step 2 – Adjusted RAROC

$$\text{ARAROC} = 13\% - 12\% = 1.0\%$$

Step 3 – Decision

$1.0\% < r_f = 6\%$: reject.

$\Rightarrow$ A positive ARAROC is not enough; it has to beat the risk-free rate.

Interpretation

The 12% "required return on equity" is a red herring. The adjusted rule never uses it, and it is not even the CAPM return implied by the data ($6\% + 1.5 \times 8\% = 18\%$). Against that 12% the traditional rule would accept the project (13%): this is exactly the high-beta project the single hurdle wrongly lets through.

Why the other options are wrong

A is incorrect. Correct value, but accepted because it is positive: the benchmark is r_f, not zero.
C is incorrect. A ratio form, $(13\% - 6\%)/1.5 = 4.7\%$, which is not ARAROC.
D is incorrect. Subtracted the risk-free rate instead of the systematic charge, $13\% - 6\% = 7\%$, then accepted because $7\% > 6\%$.

LO: ORR-18 f: Calculate the adjusted RAROC for a project to determine its viability. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.5

Solution ORR-18 f.5

Answer: D

Bank Q436 • AnalystPrep Q.3136

Step 1 – Acceptance condition

$$\text{RAROC} - \beta_E(R_M - r_f) > r_f \quad \Longleftrightarrow \quad \text{RAROC} > r_f + \beta_E(R_M - r_f)$$

Step 2 – Systematic risk charge

$$R_M - r_f = 7.932\% - 2\% = 5.932\%, \qquad 1.18 \times 5.932\% = 7.00\%$$

Step 3 – Minimum RAROC

$$\text{RAROC}_{\text{min}} = 2\% + 7.00\% = 9.00\%$$

$\Rightarrow$ At 9.00% the project's ARAROC exactly equals the risk-free rate; any higher RAROC passes.

Interpretation

The minimum RAROC is the project's own CAPM required return: a beta-specific hurdle. The odd market return (7.932%) is chosen so that the charge comes out at a round 7.00%.

Why the other options are wrong

A is incorrect. The risk-free rate alone, as if no charge for systematic risk were needed.
B is incorrect. The market premium (5.93%), without multiplying by beta and without adding r_f.
C is incorrect. The systematic charge alone (7.00%), forgetting to add the risk-free rate.

LO: ORR-18 f: Calculate the adjusted RAROC for a project to determine its viability. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.5

Solution ORR-18 f.6

Answer: C

Workbook A2.7 • S2

Step 1 – Acceptance condition

$$\text{ARAROC} = \text{RAROC} - \beta_E(R_M - r_f) > r_f$$

Step 2 – Market risk premium

$$R_M - r_f = 8.0\% - 3.0\% = 5.0\%$$

Step 3 – Break-even beta

$$12.4\% - \beta_E \times 5.0\% = 3.0\% \quad \Longrightarrow \quad \beta_E = \frac{9.4\%}{5.0\%} = 1.88$$

$\Rightarrow$ At a beta of 1.88 the activity earns exactly r_f after compensating shareholders for systematic risk; any higher beta fails.

Interpretation

The traditional rule accepts the activity ($12.4\% > 10.5\%$) whatever its beta; the adjusted rule accepts it only if $\beta_E < 1.88$. The 10.5% hurdle is irrelevant once ARAROC is used.

Why the other options are wrong

A is incorrect. Divided by the market return instead of the premium: $9.4\%/8.0\% = 1.18$.
B is incorrect. Used $\beta_E R_M$ and compared ARAROC with zero: $12.4\%/8.0\% = 1.55$.
D is incorrect. Compared ARAROC with zero instead of r_f: $12.4\%/5.0\% = 2.48$.

LO: ORR-18 f: Calculate the adjusted RAROC for a project to determine its viability. ORR-18 e: Calculate the hurdle rate and apply this rate in making business decisions using RAROC. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, Box 18.5

Solution ORR-18 f.7 **Answer: A**

Bank Q441 • BT P2.T7.24.12.3

Step 1 – Amounts on the USD 200 million loan

Revenue $10\% \times 200 = 20.0$; deposit interest $4\% \times 200 = 8.0$; operating costs $0.8\% \times 200 = 1.6$; transfer costs $1\% \times 200 = 2.0$; EL $2\% \times 200 = 4.0$.

Step 2 – Economic capital and its return

$$\text{EC} = 50\% \times 200 = 100, \qquad 5\% \times 100 = 5.0$$

Step 3 – After-tax income and RAROC

$$20 - 8 - 1.6 - 2 - 4 + 5 = 9.4, \qquad 9.4 \times (1 - 0.32) = 6.392, \qquad \text{RAROC} = \frac{6.392}{100} = 6.39\%$$

Step 4 – Adjusted RAROC

$$\text{ARAROC} = 6.392\% - 1.05 \times (7\% - 3\%) = 6.392\% - 4.20\% = 2.19\%$$

Step 5 – Decision

$2.19\% < r_f = 3\%$: reject.
$\Rightarrow$ The project clears the 6% hurdle on the unadjusted measure but fails once its systematic risk is charged; with a beta of 1.05 it would need a RAROC of $3\% + 4.2\% = 7.2\%$.

Interpretation

The two rules conflict, and the board's concern with systematic risk settles it: the adjusted rule decides, so the 6% hurdle is a red herring. Note the two different rates: economic capital earns

5% in the numerator (as GARP sets it up, invested in government securities), while the ARAROC benchmark is the 3% risk-free rate (GARP: "say, the interest rate paid on three-month Treasury bills"). The break-even beta is $(6.39\% - 3\%)/4\% = 0.85$, below the actual 1.05.

Why the other options are wrong

B is incorrect. Subtracted the market premium without beta: $6.392\% - 4\% = 2.39\%$. The decision happens to be right, the value is not.

C is incorrect. Omitted the transfer cost: $(9.4 + 2) \times 0.68/100 = 7.75\%$, ARAROC $7.75\% - 4.20\% = 3.55\%$, and a wrong accept.

D is incorrect. Judged the unadjusted RAROC against the 6% hurdle, skipping the systematic-risk adjustment the board asked for.

LO: ORR-18 f: Calculate the adjusted RAROC for a project to determine its viability. ORR-18 c: Calculate and interpret the RAROC for a project, loan, or loan portfolio and use RAROC to compare business unit performance. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.4 and Box 18.5

ORR-21 • Capital Regulation Before the Global Financial Crisis • Vardeez: UNTIERED

ORR-21 c

P1 CONCEPT

Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book.

Workbook: A4 Fundamental Review of the Trading Book (FRTB) • Tier A • August 2026 recall C5 Basel III Post-Crisis Reforms and Stress-Test Regimes • Tier C D4 Stressed VaR and Market Risk Capital • Tier D

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: A4 (FRTB) is in your August 2026 recall ("FRTB: 2Q") and #5 on the topic map (8 of 16 sources); its shape S5 sets FRTB against the 1996 Amendment. The 1996 charge also anchors D4 (Tier D, #73), and the Basel progression is C5 (Tier C, #30).

Vardeez: ORR-21 is untiered in his sheet, but his theme 3, "Basel III: three components and comparison with Basel I and II", draws on it; the reading is rank 10 of 55 in the consolidated volume. His notes label this LO "LO 60.c" (consolidated volume p.46): netting and the NRR formula, the two 1996 methods, total capital $= 0.08 \times$ (credit RWA + market RWA), and the backtesting multiplier.

Reported exam shapes

- **A4·S5** FRTB against Basel I (1996 Amendment), Basel II and Basel 2.5: overall changes.
- **C5·S4** The Basel I / 1996 / II / 2.5 / III progression, each change attached to the right accord.
- **D4·S2** Market risk capital charge: $\max(\text{VaR}_{t-1}, m \times \text{VaR}_{avg})$, $\sqrt{10}$ scaling, multiplier from backtesting.

What the questions look like: statement questions ("which is correct", "all EXCEPT") on netting, the two 1996 methods, the trading and banking books, specific risk, backtesting, and which accord made which change. TYPE CONCEPT: NRR arithmetic and the market risk charge are tested as calculations under ORR-22 a. The one calculation kept here is workbook C2.1 (multiplier from backtesting, then the charge), as the workbook sets it.

See also: workbook D4.1 also tags this LO; it is worked under ORR-22 a (Basel 2.5 charge). This block carries the shared background for the whole reading (Section 1, Figure 1); ORR-21 a, b and d (P3) point back to it.

1. Shared background: the Basel accords at a glance

The Basel Committee on Banking Supervision (BCBS) was created in 1974, after the failure of Herstatt Bank. Its first accord, Basel I (1988), set capital against credit risk only. Two amendments followed: netting in 1995 and market risk in 1996. Basel II (2004) rebuilt the credit risk weights and added operational risk and two new pillars. Basel 2.5 and Basel III are the post-crisis repairs (ORR-22 to ORR-24).

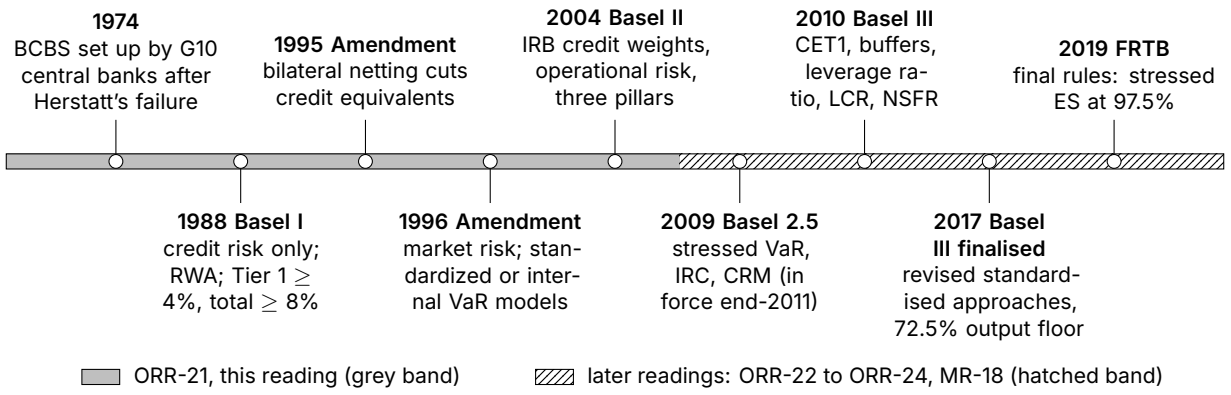


Figure 1. The Basel timeline, events evenly spaced (not to scale). This reading covers 1974 to 2004 (grey band); the hatched band is the post-crisis framework of later readings. Basel I was published in December 1987, agreed in July 1988 and fully implemented by the end of 1992.

Accord	Capital covers	What changed	Why (GARP)
Basel I (1988)	Credit risk, on and off balance sheet	Risk-based ratio: Tier 1 $\geq 4\%$, total $\geq 8\%$ of RWA; four risk weights; credit equivalents for off-balance-sheet items and derivatives	Cross-border banking: equity to absorb large losses; a level playing field instead of a race to the bottom
1995 Amendment	Credit risk of derivatives	Bilateral netting cuts credit equivalent amounts; add-ons for equity and commodity derivatives; a bucket for maturities over five years	Master agreements now trusted in bankruptcy; the 1988 rule penalised hedging
1996 Amendment	+ market risk (trading book)	Standardized method or internal VaR models; $\max(\text{VaR}_{t-1}, m\,\text{VaR}_{avg})$; Tier 3 capital; daily backtesting	Trading book market risk was not captured; the 1987 crash; VaR in wide use
Basel II (2004)	+ operational risk	Standardized, Foundation and Advanced IRB for credit; three approaches for operational risk; Pillars 2 and 3; repeated QIS	Basel I "not risk-based enough"; Nordic crises; better risk measurement; Barings
Basel 2.5 (2009)	Market risk recalibrated	Stressed VaR, incremental risk charge, comprehensive risk measure (in force end-2011)	VaR too low after calm years; trading-book arbitrage (ORR-22)
Basel III (2010, finalised 2017)	+ liquidity and leverage	CET1 and buffers, leverage ratio, LCR, NSFR; in 2017 revised standardised approaches and a 72.5% output floor	The 2007 to 2009 crisis (ORR-22 to ORR-24)

2. The starting point: Basel I credit equivalents for derivatives

A derivative has no balance-sheet principal at risk, so Basel I converted it into a **credit equivalent amount (CEA)**. Under the **current exposure method**:

$$\boxed{\text{CEA} = \max(V, 0) + D \times L}$$

V is the contract's current market value and L its notional. The first term is the *current exposure*, the replacement cost if the counterparty defaulted today; it is zero when $V < 0$, because the bank then owes rather than is owed. The second term is the add-on for *potential future exposure*: the value can still turn positive before maturity.

Remaining maturity	Interest rate swaps	Foreign exchange swaps
Less than one year	0.0%	1.0%
One to five years	0.5%	5.0%
More than five years (bucket added in 1995)	1.5%	7.5%

The CEA is then multiplied by the counterparty's risk weight to give RWA (ORR-21 b, which also covers the original exposure method). Equity and commodity derivatives were not covered by Basel I; the 1995 Amendment added add-on factors for them (GARP's Example 21.3 uses 10%).

3. The 1995 Amendment: netting of credit exposures

Why netting had been blocked

OTC derivatives are signed under an ISDA master agreement: if a counterparty defaults, all its transactions with the bank are treated as *a single transaction*, so positive and negative values offset. The original Basel I allowed almost no capital credit for this. If Bank A bought rate protection from Bank B and later sold the same notional back to B, the two swaps offset exactly, yet each drew its own add-on: **Basel I disincentivized hedging**. The rationale was that, as of 1988, master agreements had not been sufficiently tested in bankruptcy courts. By 1995 the BCBS was confident they would work, and the Amendment allowed **reductions in credit equivalent amounts where enforceable bilateral netting agreements were in place**.

The netted credit equivalent amount

$$\text{CEA} = \sum_{\text{counterparties}} \max\Big(\sum_i V_i,\, 0\Big) + \sum_j \big(0.4\, D_j + 0.6\, D_j \times \text{NRR}\big)$$

$$\text{NRR} = \frac{\text{current exposure with netting}}{\text{current exposure without netting}} = \frac{\max(\sum_i V_i, 0)}{\sum_i \max(V_i, 0)}$$

- **Netting is bilateral.** Market values are netted completely, but only *within* each counterparty; a net negative value with one counterparty never offsets exposure to another. The net figure per counterparty is floored at zero.
- **Add-ons by derivative type.** D_j is the add-on factor times the total notional of derivative type j. The NRR is a single average across all positions: GARP notes that differences in the effect of netting across derivative types are ignored.
- **The NRR lies between 0 and 1.** It is net over gross, never the inverse. NRR $= 1$ means no netting benefit; NRR $= 0$ means the positions fully offset today.
- **40% of the add-on always stays.** The factor $0.4 + 0.6\,\text{NRR}$ falls to 0.4 at best, because positions that offset today can drift apart before they mature.

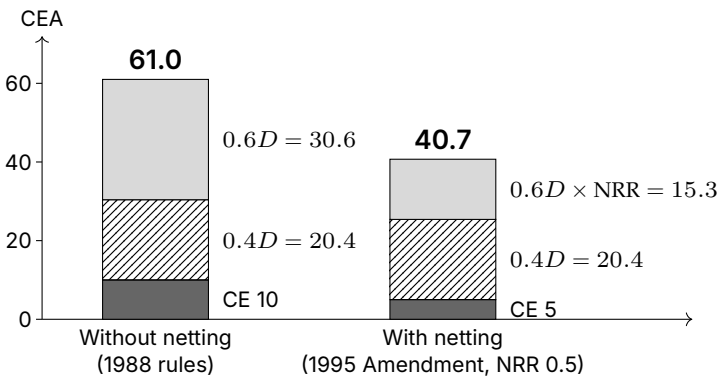
Worked example: GARP Example 21.3

Counterparty	Type	Notional	Market value	Add-on factor	D
1	Interest rate (2 years)	100	-5	0.5%	0.5
1	Interest rate (3 years)	100	0	0.5%	0.5
1	Foreign exchange (2 years)	200	10	5%	10
2	Equity option (6 years)	100	0	10%	10
2	Wheat option	300	-10	10%	30

- **Current exposure with netting:** counterparty 1: $\max(-5+0+10, 0) = 5$; counterparty 2: $\max(0-10, 0) = 0$; total 5. The -10 wheat option may be netted only against counterparty 2.
- **Without netting** only positive values count: 10. So NRR $= 5/10 = 0.5$ and the add-on factor is $0.4 + 0.6 \times 0.5 = 0.7$.
- **Add-ons by type:** interest rate $200 \times 0.5\% = 1$, FX 10, equity 10, wheat 30; total 51.

$$\text{CEA} = 5 + 0.7 \times (1 + 10 + 10 + 30) = 5 + 0.7 + 7 + 7 + 21 = 40.7$$

- **Without netting** the CEA would be $10 + 51 = 61$: netting saves 20.3, a third.



Netting shrinks two pieces: the current exposure (dark grey: 10 to 5) and the part of the add-on scaled by the NRR (light grey: 30.6 to 15.3).

The hatched 40% of the gross add-on ($0.4 \times 51 = 20.4$) never shrinks, however well the positions offset.

Figure 2. GARP Example 21.3 with and without netting. Current exposure is dark grey, the fixed 40% of the add-on is hatched, and the NRR-scaled 60% is light grey.

4. The 1996 Amendment: market risk capital for the trading book

Why a second charge

Market risk, the risk of changes in the market value of trading book assets, is the primary risk of the trading book, and the credit RWA of Basel I did not capture it. By 1995 the 1987 crash had happened, VaR was in widespread use and quantitative market risk management had matured. The 1996 Amendment (the "Market Risk Amendment") required banks to **measure the market risk of their trading activities and hold capital against it**.

- **Trading book:** instruments held for trading and marked to market daily (bonds, marketable equities, commodities, foreign exchange, most derivatives). **Banking book:** loans and debt held to maturity, not marked to market daily.
- The 1988 credit charge kept applying to the banking book and to counterparty exposures; traded debt and equity securities, commodity and FX positions moved to the new market risk charge.

- Both charges are expressed as RWA by multiplying the market risk capital by $12.5 = 1/8\%$:

$$\text{total capital} = 0.08 \times (\text{credit RWA} + \text{market RWA}), \qquad \text{market RWA} = 12.5 \times \sum_{j=1}^{5} (\text{MR}_j + \text{SR}_j)$$

Two methods

	Standardized measurement method	Internal model-based approach
How the charge is set	Regulators specify the details from observable characteristics (for example remaining maturity)	The bank's own risk measure (VaR) is the input to a regulatory formula
Categories	Five: fixed income and interest rate derivatives (not options); equities and equity derivatives (not options); FX; commodities; all options	Same five categories; specific risk (SR) and general market risk (MR) charged separately in both methods
Correlation	Ignored: positions assumed perfectly correlated	Within a category by the model; across categories at the supervisor's discretion
Capital level	Higher	Generally smaller; preferred by banks with material trading books
Conditions	None beyond the rules	Qualitative criteria (sound risk management, independent risk unit, limits, board involvement) and daily backtesting

GARP calls the internal models approach "a major change in philosophy": for the first time, banks' internally developed risk measures set regulatory capital, with monitoring built in to limit manipulation.

The internal models charge

- **VaR standard:** 10-day horizon, 99% confidence, at least one year of daily data; usually a one-day VaR scaled by $\sqrt{10} = 3.1623$ (a one-day VaR of 3.2 gives a 10-day VaR of 10.12).
- **The charge**

$$\boxed{\text{MR} = \max\left(\text{VaR}_{t-1},\ m \times \text{VaR}_{avg}\right)}$$

  where VaR_{avg} is the average over the past 60 days and the multiplier m is **never less than 3**. Supervisors raise it for model or system deficiencies. With $m = 3$ the second term is usually larger; the previous day's VaR binds only after a sharp jump (Figure 3).
- **Vardeez's example:** $\text{VaR}_{t-1} = 10$, 60-day average 8, $m = 3$: $\max(10, 24) = 24$. Market risk capital 24, market RWA $12.5 \times 24 = 300$.
- **Specific risk** (fixed income, equities, derivatives) uses the standardized rules or an internal model. With a model the multiplier is **4, not 3**, and SR capital cannot be below **half** of the standardized SR charge, so an internal-models bank must compute the standardized charge as well.
- **Tier 3 capital**, a new class: mainly unsecured subordinated debt with an original maturity of **at least two years**. It may meet only about **70%** of the market risk requirement, and nothing else. Basel III later abolished it.

Backtesting and the multiplier

Every day, for each model, the bank uses its current model to compute the **one-day 99% VaR for each of the most recent 250 days** and compares it with that day's actual loss. A loss larger than VaR is an **exception**; a correct model expects $250 \times 1\% = 2.5$. GARP: five or fewer exceptions allow $m = 3$;

more can raise m at the supervisor's discretion; **10 or more require** $m = 4$. The Basel traffic light used in Jorion (MR-4) fixes the steps in between:

Exceptions in 250 days	0 to 4	5	6	7	8	9	10 or more
Zone	green	yellow	yellow	yellow	yellow	yellow	red
Multiplier m	3.00	3.40	3.50	3.65	3.75	3.85	4.00

Correction to the source notes. GARP's text says "five or less exceptions enabled the multiplier m to be 3", and the D4 revision notes repeat it. In the Basel traffic light (Jorion, MR-4 f), **five exceptions are already yellow**: $m = 3.40$. Zero to four is green. Under a correct model, five or more exceptions still occur 10.8% of the time. Schweser states "greater than 10, m is set equal to four"; the rule is **10 or more**. Its example also averages VaR over "the preceding 62 trading days"; the rule is 60. Use 0 to 4: 3.00; 5 to 9: 3.40 to 3.85; 10 or more: 4.00.

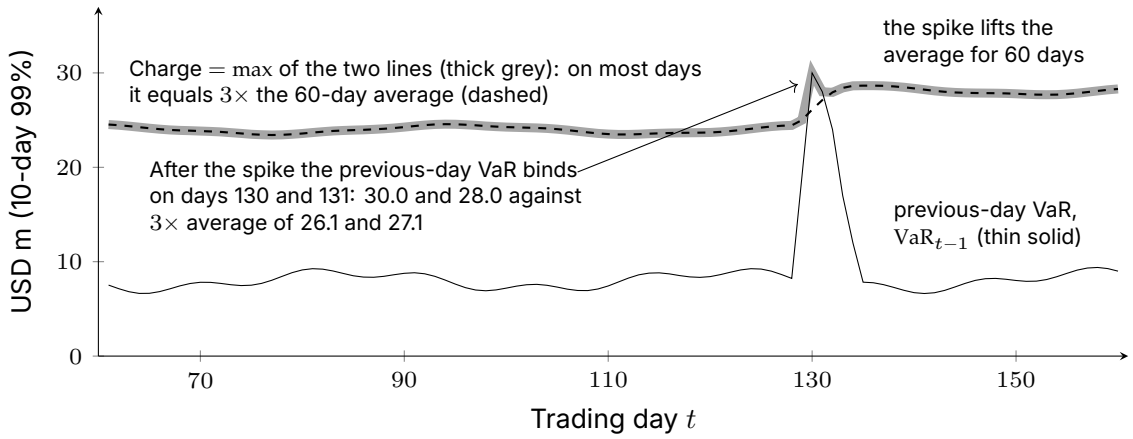


Figure 3. An illustrative path of the 1996 internal models charge with $m = 3$. The thin solid line is the previous day's 10-day VaR, the dashed line is three times its 60-day average, and the thick grey line is the charge, the larger of the two.

5. Where the 1996 rules went next (workbook shape A4, S5)

	1996 Amendment	Basel II	Basel 2.5	FRTB
Measure	10-day 99% VaR, current data (past one to four years)	Unchanged	VaR plus stressed VaR (a stressed 250-day period); IRC; CRM	Stressed ES at 97.5%
Horizon	10 days, usually one-day VaR $\times\sqrt{10}$	Unchanged	10 days, $\sqrt{10}$ scaling	Liquidity horizons 10 to 120 days; overlapping 10-day changes, no $\sqrt{10}$
Multiplier	$m \geq 3$; 4 for specific risk	Unchanged	$m_c, m_s \geq 3$ on each term	$m_c \geq 1.5$
Approval and tests	Bank-wide; one-day 99% VaR backtest over 250 days	Unchanged	Unchanged	Desk by desk; backtest one-day VaR at 99% and 97.5%; P&L attribution
Standardized approach	An alternative	An alternative	An alternative	Always computed; acts as a floor

Basel II left market risk on the 1996 basis: its innovations were credit risk weights, operational risk capital, the three pillars and repeated QIS. Stressed VaR, the IRC and the CRM are Basel 2.5 (ORR-22 a to c); the FRTB is MR-18.

Comparison card: ORR-21 c

Credit equivalent (Basel I)	CEA $= \max(V, 0) + D \times L$; then $\times$ counterparty risk weight
Netted CEA (1995)	CEA $= \sum_{\text{cpty}} \max(\sum V_i, 0) + \sum_j (0.4D_j + 0.6D_j \,\text{NRR})$, NRR $=$ net/gross current exposure
Netting rules	bilateral only; net value floored at 0; $0 \le \text{NRR} \le 1$; 40% of the add-on never shrinks
Market risk charge (1996)	MR $= \max(\text{VaR}_{t-1}, m\,\text{VaR}_{avg})$, 60-day average, $m \ge 3$; 10-day 99%, usually $\times\sqrt{10}$
Capital and RWA	total capital $= 0.08 \times (\text{credit RWA} + 12.5 \times \sum(\text{MR}_j + \text{SR}_j))$
Specific risk	internal model: multiplier 4; at least half the standardized SR charge
Backtest	one-day 99% VaR, 250 days; 0 to 4: 3.00; 5 to 9: 3.40 to 3.85; 10 or more: 4.00
Tier 3	subordinated debt, original maturity ≥ 2 years; up to about 70% of market risk capital
Standardized vs internal	five categories, no correlation, higher capital vs own VaR, diversification, lower capital, conditions

Exam traps

- **Netting across counterparties.** Netting works only inside one counterparty's master agreement; a negative value elsewhere offsets nothing.
- **NRR inverted or misread.** It is net over gross, at most 1, and it scales only 60% of the add-on; 40% always stays.
- **Wrong accord.** Netting 1995; market risk and Tier 3 1996; operational risk and the pillars Basel II; stressed VaR Basel 2.5; ES and liquidity horizons FRTB.
- **Correlation polarity.** The standardized method ignores correlation and gives *more* capital; internal models recognise diversification and give less.
- **The max is a decision.** After a spike VaR_{t-1} can exceed $m \times \text{VaR}_{avg}$; always multiplying the average understates the charge.
- **Two VaRs.** Capital uses the 10-day 99% VaR; the backtest uses the one-day 99% VaR over 250 days. Scale one-day figures by $\sqrt{10}$, never 10-day figures again.
- **Multiplier.** Never below 3; 10 or more exceptions force 4; the specific risk multiplier is 4, not 3.
- **No exemptions.** Historical simulation does not excuse a model from backtesting, and internal models do not excuse the standardized calculation.

Practice questions: ORR-21 c

Question ORR-21 c.1

New • built from GARP Ch.21

The head of counterparty risk at a Dutch bank is briefing the board on how the 1995 Amendment to Basel I changed the capital treatment of the bank's OTC derivatives book, which is documented under an ISDA master agreement with each counterparty. Which of the following statements should the head include?

A. Before 1995, two offsetting swaps with the same counterparty each attracted an add-on, which discouraged hedging; once master agreements were judged enforceable, bilateral netting could reduce credit equivalent amounts.

B. A net negative market value with one counterparty may be offset against positive exposures to other counterparties, provided each relationship is covered by its own master agreement.

C. The net replacement ratio divides current exposure without netting by current exposure with netting, so it is at least one and scales the add-ons up.

D. When the net replacement ratio is zero, the add-on for potential future exposure falls to zero, because fully offsetting positions cannot create exposure later.

Question ORR-21 c.2

Bank Q556 • BT P2.T7.20.7.3

The 1995 Amendment to Basel I allowed reductions in credit equivalent amounts when enforceable bilateral netting agreements were in place. Shortly afterwards the 1996 Amendment added capital for market risk. Which of the following statements about the 1996 Amendment is TRUE?

A. It introduced the third pillar, which was praised for giving supervisors a consistent rule-enforcing playbook.

B. Conditional on meeting several criteria, including daily backtesting, banks could now employ their own internal value at risk (VaR) model to determine capital requirements for market risk.

C. To reduce regulatory arbitrage, it removed all internal approaches so that only standardized approaches could be applied to credit, market, and operational risk.

D. It removed Tier 2 capital so that only Tier 1 capital remained, with Tier 1 split into common equity and non-common equity.

Question ORR-21 c.3 Bank Q558 • BT P2.T7.515.2

The 1996 Amendment to the 1988 Basel Accord (implemented in 1998) required capital for the market risks of trading activities and distinguishes between the banking book and the trading book. About these books, each of the following is true EXCEPT, which is false?

A. The trading book consists of instruments that are actively traded and marked to market daily; the banking book consists primarily of loans that are held to maturity and not marked to market daily.

B. The 1996 Amendment introduced a capital charge for the market risk associated with all items in the trading book.

C. Under the 1996 Amendment, the credit risk capital charge in the 1988 Accord continued to apply to all on-balance-sheet and off-balance-sheet items in the trading and banking book, except positions in the trading book that consisted of (i) debt and equity traded securities and/or (ii) positions in commodities and foreign exchange.

D. The 1996 Amendment eliminated the standardized measurement method for the calculation of market risk and abolished the distinction between the banking and trading books due to widespread regulatory arbitrage between the two.

Question ORR-21 c.4 Bank Q559 • BT P2.T7.515.3

About the calculation of market risk under the 1996 Amendment, each of the following is true EXCEPT, which is false?

A. The standardized approach assigns capital separately to each of debt securities, equity securities, foreign exchange risk, commodities risk, and options; but no account is taken for correlations between different types of instruments.

B. If a bank elects to use the historical simulation (HS) approach to calculating its value-at-risk (VaR), then a backtest is not required because an HS is effectively already a backtest.

C. In the internal model-based approach (IMA), the value-at-risk (VaR) measure used is calculated with a 10-day time horizon and a 99.0% confidence level.

D. Most large banks preferred to use the internal model-based approach because it better reflected the benefits of diversification and led to lower capital requirements.

Question ORR-21 c.5 Bank Q561 • BT L2.T5.62.3 (rebuilt)

Under the 1996 Amendment to Basel I, for which of the following trading book positions is a capital charge for specific risk required?

A. Only fixed income positions measured under the standardized method

B. Only equity positions measured under the standardized method

C. Only positions measured under the internal model-based approach

D. Fixed income and equity positions under the standardized method, and positions under the internal model-based approach

Question ORR-21 c.6

Workbook C2.1 • S1, S5 • Map #21

A regulatory analyst at a German bank is computing the market risk capital charge for a trading book under the internal models approach. Over the last 250 trading days the one-day 99% VaR was exceeded on 8 days, with the following causes identified:

- 4 days: markets were particularly volatile and correlations changed
- 2 days: the model uses too few maturity buckets for the yield curve
- 1 day: positions changed materially during the day through intraday trading
- 1 day: a major earthquake caused large losses across local markets

The supervisor will exclude any exception that the Basel rules allow to be excluded. The 10-day 99% VaR for the previous day is EUR 52 million and the average 10-day 99% VaR over the last 60 days is EUR 40 million. Which of the following is closest to the multiplier k and the market risk capital charge?

A. $k = 3.00$; EUR 120 million

B. $k = 3.50$; EUR 140 million

C. $k = 3.65$; EUR 146 million

D. $k = 3.75$; EUR 150 million

Question ORR-21 c.7

Workbook A4.4 • S3, S5, S6 • Map #5

A risk consultant is preparing a one-page comparison of market risk capital under the 1996 Amendment to Basel I, Basel II, Basel 2.5 and FRTB for the chief compliance officer of a UK bank. The FRTB section discusses two GBP options desks under the standardized approach: one is short a book of at-the-money options and the other is long a similar book. Which of the following statements is correct to include?

A. FRTB moves from 99% to 97.5% confidence and from one 10-day horizon to liquidity horizons, but still lets banks scale one-day changes to 10 days with a square-root-of-10 multiplier.

B. Basel II overhauled market risk capital by adding a stressed VaR term to the current VaR term, alongside the introduction of its three pillars.

C. Under FRTB's standardized approach, the long-option desk attracts the curvature risk charge, because its gamma raises value relative to delta for both up and down moves.

D. Under FRTB's standardized approach, the short-option desk's curvature charge is the larger of its two shocked losses net of the delta effect, with negative results set to zero.

Solutions • ORR-21 c

Solution ORR-21 c.1

Answer: A

New • built from GARP Ch.21

Step 1 – Why netting was blocked in 1988

The original Basel I gave almost no capital credit for netting: each swap took its own add-on, so a hedge with the same counterparty *raised* capital. The reason was that master agreements had not been sufficiently tested in bankruptcy courts.

$\Rightarrow$ By 1995 the BCBS trusted them, and enforceable bilateral netting could reduce credit equivalent amounts. That is statement A.

Step 2 – What the 1995 formula allows

$$\text{CEA} = \sum_{\text{cpty}} \max\Big(\sum_i V_i, 0\Big) + \sum_j (0.4D_j + 0.6D_j\,\text{NRR}), \qquad \text{NRR} = \frac{\text{net}}{\text{gross}} \in [0,1]$$

$\Rightarrow$ Values are netted only within a counterparty, and only 60% of each add-on is scaled by the NRR.

Interpretation

In GARP Example 21.3, netting cuts the CEA from 61 to 40.7 (NRR $= 5/10 = 0.5$). The 40% of the add-on that never shrinks reflects that positions offsetting today can diverge before they mature.

Why the other options are wrong

B is incorrect. Scope error. Netting is bilateral: in Example 21.3 the -10 wheat option "may only be netted against positive exposures at the second counterparty, not at the first". Separate agreements with separate counterparties do not net against each other.

C is incorrect. Inverted ratio. The NRR is current exposure *with* netting over current exposure *without* netting, so it is at most 1 and scales the add-ons down (0.5 in Example 21.3).

D is incorrect. Absolute claim. The $0.4D_j$ term is never reduced: at NRR $= 0$ the add-on is still 40% of its gross amount.

LO: ORR-21 c: Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Netting; Example 21.3)

Solution ORR-21 c.2

Answer: B

Bank Q556 • BT P2.T7.20.7.3

Step 1 – What the 1996 Amendment did

It added capital for the market risk of trading activities, measured by either a standardized method or an internal model-based approach. The internal approach let banks use their own VaR models, subject to qualitative criteria, a multiplier of at least 3, and daily backtesting of one-day 99% VaR over the last 250 days.

$\Rightarrow$ Statement B describes exactly this.

Step 2 – Place each distractor in its own accord

Pillar 3: Basel II (2004). Removing internal models: the opposite of 1996 (the December 2017 reforms removed internal models only for CVA and operational risk). Tier 1 split into common equity and other Tier 1: Basel III.

Interpretation

GARP calls the internal models approach "a major change in philosophy": for the first time internally developed risk measures fed regulatory capital, with monitoring built in to limit manipulation.

Why the other options are wrong

A is incorrect. Wrong accord. The three pillars came with Basel II, and Pillar 3 is market discipline through disclosure, not a supervisory rulebook.

C is incorrect. Polarity flip. The 1996 Amendment added an internal approach for market risk. Operational risk had no capital charge at all until Basel II.

D is incorrect. Wrong accord and wrong content. The 1996 Amendment created a new class, Tier 3 capital; it removed nothing. Basel III, not 1996, split Tier 1 into common equity and additional Tier 1, kept Tier 2 and abolished Tier 3.

LO: ORR-21 c: Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Capital for Market Risks Associated with Trading Activities) and 21.2

Solution ORR-21 c.3 Answer: D

Bank Q558 • BT P2.T7.515.2

Step 1 – The two books

The trading book holds positions held for trading and marked to market daily; the banking book holds loans and debt held to maturity, not marked daily. A is true.

Step 2 – Which charge applies where

The new charge covers the market risk of all trading book items (B true). The 1988 credit charge stays on everything else, including counterparty exposures on trading book derivatives, but not on traded securities, commodity and FX positions, which now carry the market risk charge (C true).

Step 3 – Test D

The Amendment *introduced* two methods, the standardized measurement method and the internal model-based approach, and it rests on the banking book and trading book boundary.
$\Rightarrow$ D is the false statement.

Interpretation

The boundary created by the 1996 Amendment later became an arbitrage target: illiquid credit placed in the trading book drew less capital than in the banking book. Basel 2.5 answered with the incremental risk charge (ORR-22 b) and the FRTB tightened the boundary itself (MR-18 c).

Why the other options are wrong

A is incorrect. A true statement of the two books, so not the exception.

B is incorrect. True: the market risk charge applies to the trading book.

C is incorrect. True: the 1988 credit charge kept applying except to the listed trading book positions.

LO: ORR-21 c: Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1; SchweserNotes 2026 Book 3, Reading 62, LO 62.c

Solution ORR-21 c.4 Answer: B

Bank Q559 • BT P2.T7.515.3

Step 1 – Check the true statements

A: the standardized approach charges each category separately and ignores correlation between them. C: the internal models VaR is 10-day, 99%. D: internal models recognise diversification and give lower capital, so banks with material trading books preferred them.

Step 2 – Test B

The Amendment requires daily backtesting of *every* model: the one-day 99% VaR for each of the last 250 days against the actual loss. The VaR method does not matter.
⇒ B is false.

Interpretation

A historical simulation VaR is built from past data, but that is not a backtest. A backtest compares each day's VaR forecast with the loss that actually followed, out of sample, and the count of exceptions sets the multiplier.

Why the other options are wrong

A is incorrect. True statement; choosing it means thinking the standardized method recognises cross-category correlation.
C is incorrect. True statement; it confuses the 10-day capital VaR with the one-day VaR used for backtesting.
D is incorrect. True statement; the diversification benefit is why internal models give smaller charges.

LO: ORR-21 c: Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Capital for Market Risks Associated with Trading Activities)

Solution ORR-21 c.5 Answer: D

Bank Q561 • BT L2.T5.62.3

Step 1 – Specific against general market risk

General market risk comes from general movements in market prices; specific risk from idiosyncratic changes in one position's value (an issuer's spread, a single stock).

Step 2 – Where GARP requires a specific risk charge

Under both approaches, charges are calculated separately for specific risk and general market risk in each of the five categories. Specific risk capital, "required for fixed income, equity instruments, and derivatives, could be determined using either the standardized approach or the bank's internal models".

Step 3 – The internal models version

Multiplier 4 rather than 3, and no less than half of the standardized specific risk charge.
⇒ A specific risk charge applies under every method: D.

Interpretation

The 50% floor means an internal-models bank must compute standardized specific risk capital anyway. The VaR model captures general movements; the specific risk charge captures the company-specific part.

Why the other options are wrong

A is incorrect. Incomplete: equities and internal-model positions also carry the charge.
B is incorrect. Incomplete: fixed income and internal-model positions also carry the charge.
C is incorrect. Reversed: banks on the standardized method also pay a specific risk charge;

internal-model banks pay it with a multiplier of 4 and a floor.

LO: ORR-21 c: Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Capital for Market Risks Associated with Trading Activities)

Solution ORR-21 c.6 — Answer: C

Workbook C2.1 • S1, S5

Step 1 – Count the exceptions that remain

Exceptions "may be excluded if they are the result of such occurrences as sudden abnormal changes in interest rates or exchange rates, major political events, or natural disasters". Only the earthquake qualifies. Volatile markets and changed correlations are bad luck that should "be expected to occur at least some of the time"; model accuracy and intraday trading exceptions are penalised.

$$N = 8 - 1 = 7$$

Step 2 – Zone and plus factor

Seven exceptions fall in the yellow zone (5 to 9); Jorion's Table 4.3 gives an increase in k of 0.65:

$$k = 3 + 0.65 = 3.65$$

$\Rightarrow$ With a correct 99% model the expected count is $0.01 \times 250 = 2.5$; under a correct model the probability of seven or more exceptions is only 1.4% (Table 4.4), so a penalty is appropriate.

Step 3 – Capital charge

$$\text{MR} = \max\left(\text{VaR}_{t-1},\, k \times \text{VaR}_{avg}\right) = \max(52,\, 3.65 \times 40) = \max(52,\, 146) = 146$$

Interpretation

The bank holds EUR 146 million, EUR 26 million more than with $k = 3$. Fixing the maturity buckets ("model accuracy could be improved") is the actionable item: those exceptions carry a penalty that "should" apply.

Why the other options are wrong

A is incorrect. Excluded every "bad luck" exception as well as the earthquake: $8 - 1 - 4 = 3$ exceptions, green zone, $k = 3$, $3 \times 40 = 120$.

B is incorrect. Read the plus factor one row too high in the table (0.50 belongs to 6 exceptions): $3.50 \times 40 = 140$.

D is incorrect. Did not exclude the earthquake: 8 exceptions, $k = 3.75$, $3.75 \times 40 = 150$.

LO: MR-4 f: Describe the Basel rules for backtesting. ORR-21 c: Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book. • **Reference:** Jorion, Value at Risk 3e, Ch.6, The Basel Rules, Tables 4.3 and 4.4; Carey, Capital Regulation Before the Global Financial Crisis, 21.1

Solution ORR-21 c.7 — Answer: D

Workbook A4.4 • S3, S5, S6

Step 1 – Curvature mechanics (Section 18.2.2)

Shock risk factor i up and down by its risk weight W_i. Compute $W_i\delta_i - \Delta V_i^{+}$ and $-W_i\delta_i - \Delta V_i^{-}$; the charge is the greater, and a negative result counts as zero.

$\Rightarrow$ Each term is the extra loss from curvature after the linear (delta) effect has been removed.

Step 2 – Apply to the two desks

Short options (Figure 18.1a): both moves are worse than delta predicts, so both terms are positive and the charge is the larger (AB in the figure). Long options (Figure 18.1b): curvature increases value relative to delta for both moves, both terms are negative, so the charge is zero.
$\Rightarrow$ Illustration from the formula box: short book terms 21,500 and 26,200 give USD 26,200; long book terms $-17{,}300$ and $-14{,}700$ give 0.

Step 3 – Place the accords

1996 Amendment: 10-day 99% VaR, usually one-day VaR $\times\sqrt{10}$, $m \geq 3$. Basel II: IRB credit risk, operational risk capital, three pillars; market risk retained. Basel 2.5: stressed VaR, IRC, CRM. FRTB: stressed 97.5% ES from overlapping 10-day changes, liquidity horizons, desk-level approval, standardized approach with delta, vega and curvature.

Interpretation

D is correct. The curvature charge is the standardized approach's gamma charge, and it falls on the short-gamma desk.

Why the other options are wrong

A is incorrect. Sibling swap: $\sqrt{10}$ scaling of one-day changes is the Basel I / Basel 2.5 practice; FRTB requires actual overlapping 10-day changes from the stressed period.
B is incorrect. Sibling swap (wrong accord): stressed VaR is a Basel 2.5 change (implemented by end-2011); Basel II's innovations were credit risk weights, operational risk capital and the three pillars.
C is incorrect. Polarity flip: the reason given is why a long option book receives a zero curvature charge; it is the short book that attracts it.

LO: MR-18 a: Describe the changes to the Basel framework for calculating market risk capital under the Fundamental Review of the Trading Book (FRTB) and the motivations for these changes. ORR-21 c: Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book. ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. • **Reference:** Hull, RMFI 6e, Ch.18, Sections 18.1, 18.2.2, 18.3; Carey (GARP), Ch.21 (1996 Amendment, Basel II) and Ch.22 (Section 22.2 Basel 2.5)

ORR-21 • Capital Regulation Before the Global Financial Crisis • Vardeez: UNTIERED

ORR-21 e

P1 CONCEPT

Compare the standardized internal ratings-based (IRB) approach, the foundation IRB approach, and the advanced IRB approach for the calculation of credit risk capital under Basel II.

Workbook: A31 Basel IRB Capital • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: A31 (Basel IRB Capital) is in your August 2026 recall ("Credit risk IRB").

Vardeez: his notes label this LO "LO 60.e" (consolidated volume p.48, shared with LO 60.f): the standardized approach with its two collateral examples, and Figure 60.6, Foundation against Advanced IRB parameter by parameter.

Reported exam shapes

- **A31·S3** Foundation versus Advanced IRB inputs: supervisory LGD and the PD floor.

What the questions look like: statement questions on who supplies PD, LGD, EAD and maturity under each approach, which banks each approach was meant for, the US choice, retail exposures and the maturity adjustment. TYPE CONCEPT: the one calculation is workbook A31.3, which feeds Foundation inputs into the IRB formula; it stays as the workbook sets it, and the formula itself is ORR-21 f.

The LO wording: GARP's "standardized internal ratings-based (IRB) approach" is the Basel II *standardized approach*. It uses external ratings, not internal ones, and is not an IRB variant.

See also: workbook C5.1 also tags this LO; it is worked under ORR-21 a. The IRB formula and its calculations are ORR-21 f.

1. Three options, and why there were three

As Basel II was developed, supporting data and analysis were limited, and many supervisors feared that banks would manipulate internal risk measures to reduce capital. The negotiators answered with three options, each more risk-sensitive and more demanding than the last:

1. **Standardized approach.** Like Basel I, a table of risk weights, but more sensitive to credit quality for borrowers with external ratings.
2. **Foundation IRB (F-IRB).** Risk weights driven by the bank's internal PD; LGD (and EAD) set by the regulator.
3. **Advanced IRB (A-IRB).** Risk weights driven by the bank's internal PD, LGD and EAD.

Most large US banks already had internal rating systems that yield a PD for each loan, so supervisors expected F-IRB to be feasible for most large banks. The limited data on EAD and LGD meant fewer banks would qualify for A-IRB. The **United States chose not to implement the standardized approach**: internationally active banks had to use IRB, and all other banks an updated version of Basel I.

2. The standardized approach

It was meant for banks whose internal risk measures and risk management practices were *insufficient to support the IRB approaches*. Under Basel I the headline weight depended on asset type and the obligor's nationality (OECD or not). Under the Basel II standardized approach it depends on **obligor type and external rating** for countries, banks and corporates, and on **asset type** for the rest (GARP Table 21.3, %):

Obligation of	AAA to AA−	A+ to A−	BBB+ to BBB−	BB+ to BB−	B+ to B−	Unrated
Countries	0	20	50	100	150	100
Banks	20	50	50	100	150	50
Corporations	20	50	100	100	150	100
By obligation type: retail 75, residential mortgage 35, cash 0, other 100						

- **National discretion restored much of Basel I's generosity.** A supervisor could set a 0% weight on its own sovereign's debt in the national currency (widely used, and other nations' banks could follow). Claims on banks took one category less favourable than their sovereign (capped at 100%) or the bank's own rating, one category more favourable for an original maturity of three months or less (floor 20%).
- **Unrated is cheaper than weak.** An unrated corporate carries 100%, a B-rated one 150%: an incentive to lend to poor-quality unrated borrowers (Question ORR-21 e.6).
- **Collateral, simple approach** (similar to Basel I): the collateral's risk weight replaces the counterparty's for the covered part; minimum 20% unless the collateral is sovereign debt in the exposure's currency.
- **Collateral, comprehensive approach:** the exposure is adjusted up and the collateral down for possible changes in value. GARP: the collateral's weight applies to the *reduced* collateral and the counterparty's weight to the remaining exposure. Netting is applied separately to exposures and collateral, with Basel or approved internal haircuts.

Example (Vardeez's numbers). USD 100 million to a B-rated borrower (150%), secured by USD 80 million of AAA bonds (20%). Simple approach: $0.2 \times 80 + 1.5 \times 20 = 46$. Comprehensive approach with exposure $+15\%$ and collateral -20%: exposure 115, collateral 64, remaining exposure 51, so RWA $= 0.2 \times 64 + 1.5 \times 51 = 12.8 + 76.5 = 89.3$.

> **Correction to the source notes.** Vardeez (following Schweser) stops the comprehensive example at $1.5 \times 51 =$ USD 76.5 million, leaving out the risk weight of the collateral. GARP's rule applies "the risk weight of the collateral ... to the reduced amount of collateral, and the counterparty's risk weight ... to the remaining exposure": $12.8 + 76.5 =$ USD 89.3 million. Bank question Q582 keys on GARP's version. Use GARP's form unless a stem says otherwise.

3. IRB: the shared core

Both IRB variants use the same formula (ORR-21 f): capital covers **unexpected loss up to the 99.9th percentile over one year**, net of expected loss. Four inputs describe each exposure: PD, LGD, EAD and maturity M. The **asset correlation and the confidence level are set by the Basel Committee, never by the bank**, so each exposure's capital depends only on its own inputs. The two variants differ only in *who supplies the inputs*.

4. Foundation against Advanced IRB, input by input (workbook shape A31, S3)

Input	Foundation IRB	Advanced IRB
PD	Bank's estimate; floor **0.03%** (0.0003) for bank and corporate exposures, implicitly zero for sovereigns	Bank's estimate, same floor; may be reduced by credit mitigants such as credit triggers
LGD	Supervisory: **45% senior, 75% subordinated**; collateral reduces LGD through the comprehensive approach (by the ratio of adjusted collateral to adjusted exposure)	Bank's estimate, driven mainly by seniority and collateral
EAD	Supervisory: calculated like the Basel I credit equivalent amount, including netting	Bank's estimate; own credit conversion factors with supervisory approval
Maturity M	Set to **2.5** in most cases	Bank's own (actual remaining maturity)
Used by	Most large banks with internal rating systems	Banks with enough EAD and LGD data

- **Retail exposures:** the two variants merge. Only an A-IRB-like treatment exists (the bank estimates PD, LGD and EAD), there is **no maturity adjustment**, and correlations are lower than for wholesale: 0.15 residential mortgages, 0.04 qualifying revolving (credit cards), 0.03 to 0.16 by formula for other retail.
- **Maturity adjustment:** MA $= 1$ at $M = 1$ and rises with M; it is **larger for low-PD borrowers**, which have more room to be downgraded. At $M = 5$: PD 0.1% gives MA 2.57, PD 5% gives 1.36. F-IRB fixes $M = 2.5$, so differences in maturity between loans show up only under A-IRB.

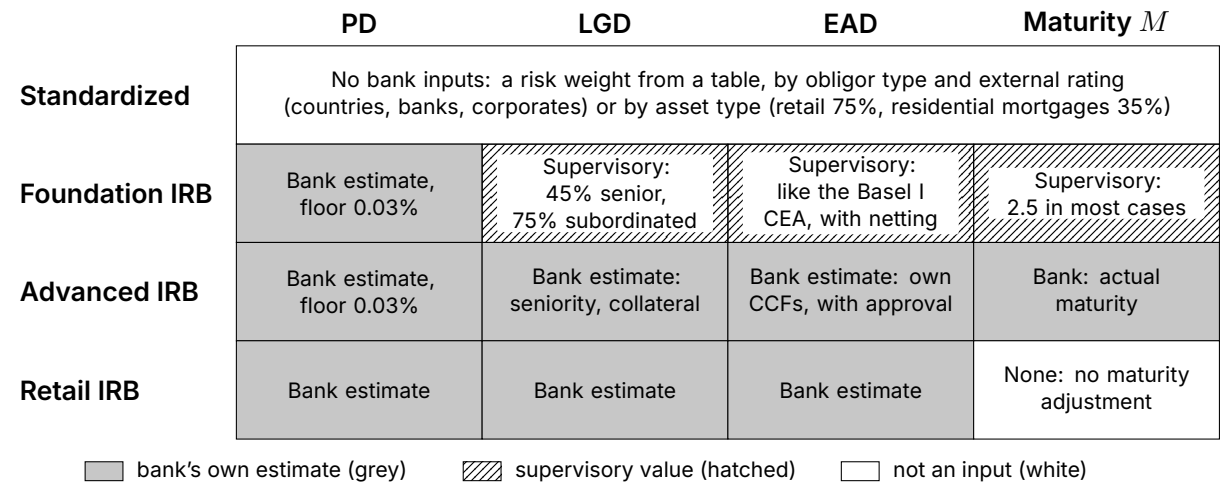


Figure 1. Who supplies each input. Grey cells are the bank's own estimates, hatched cells supervisory values, white cells not inputs. In every IRB row the correlation and the 99.9% confidence level come from the formula, not from the bank.

Comparison card: ORR-21 e

	Standardized	Foundation IRB	Advanced IRB
Meant for	Banks whose internal measures cannot support IRB (not implemented in the US)	Most large banks with internal ratings	Banks with EAD and LGD data
Risk weight from	External rating or asset type	Basel formula with bank PD	Basel formula with bank PD, LGD, EAD, M
PD	not used	bank, floor 0.03%	bank, floor 0.03%
LGD	not used	45% senior, 75% subordinated	bank
EAD	exposure (CCFs for off-balance sheet)	supervisory, with netting	bank, own CCFs
Maturity	short claims on banks may get a better weight	$M = 2.5$	bank's M
Collateral	simple or comprehensive approach	lowers LGD (comprehensive)	in the bank's LGD
Retail	75%; mortgages 35%	merged: bank PD, LGD, EAD; no MA; $\rho = 0.15$, 0.04, 0.03 to 0.16	

Exam traps

- **Role swap.** The standardized approach is for banks whose internal measures are *insufficient*; the US required IRB for internationally active banks and never implemented the standardized approach.
- **Foundation inputs.** Under F-IRB the bank supplies PD only; its own LGD is used only under A-IRB. Supervisors never set PD in either variant.
- **The PD floor.** 0.03% for bank and corporate exposures under *both* IRB variants; not for sovereigns.
- **LGD values.** 45% senior, 75% subordinated (the 40% figure belongs to the 2017 reforms, ORR-23).
- **Maturity.** F-IRB uses $M = 2.5$; A-IRB the actual M. MA rises with M and is larger for *low*-PD borrowers. Retail has no MA.
- **Correlation is never a bank input.** It comes from the Basel formula in every IRB variant; correlation for mortgages (0.15) is higher than for credit cards (0.04).
- **Unrated against weak.** An unrated corporate carries 100%, below the 150% of a B-rated one.
- **Wording trap.** The "standardized internal ratings-based approach" in the LO is the standardized approach: external ratings, no internal model.

Practice questions: ORR-21 e

Question ORR-21 e.1

Bank Q574 • AnalystPrep Q.2343 (rebuilt)

PSV Bank, a small regional bank, has relatively unsophisticated risk management and no internal rating system. Under Basel II, which approach for credit risk capital is designed for such a bank, and how are its risk weights determined?

A. Standardized approach; risk weights depend on asset class and external credit ratings.

B. Standardized approach; risk weights depend on the bank's own estimates of PD, LGD and EAD.

C. Foundation IRB approach; the bank supplies LGD and EAD, regulators supply PD.

D. Advanced IRB approach; the bank supplies all inputs, with no supervisory approval needed.

Question ORR-21 e.2

Bank Q573 • AnalystPrep Q.2342 (rebuilt)

NYC Bank is a large, internationally active US bank. When Basel II was implemented in the United States, which statement best describes the credit risk capital approaches that applied to such a bank?

A. It could freely choose among the standardized, foundation IRB and advanced IRB approaches.

B. It was required to use IRB approaches, because the US chose not to implement the Basel II standardized approach.

C. It could only use the standardized approach, with risk weights based on external ratings.

D. It continued to use the Basel I risk weights, because the US did not adopt Basel II at all.

Question ORR-21 e.3

Bank Q581 • BT P2.T7.519.1

Under the Basel II internal ratings-based (IRB) approach, the capital required is the excess of the 99.9% worst-case loss over the expected loss. The key parameters are the one-year probability of default (PD), the exposure at default (EAD), the loss given default (LGD), and the worst-case probability of default (WCDR), defined so that the bank is 99.9% certain it will not be exceeded next year for the counterparty. Consider the following three statements:

I. For corporate, sovereign, and bank exposures under the Foundation IRB approach, banks supply PD while LGD, EAD, and maturity (M) are supervisory values set by the Basel Committee. PD is subject to a floor of 0.03% for bank and corporate exposures. LGD is 45% for senior claims and 75% for subordinated claims. M is set at 2.5 in most circumstances.

II. For corporate, sovereign, and bank exposures under the Advanced IRB approach, banks supply their own estimates of PD, LGD, EAD, and M. PD can be reduced by credit mitigants such as credit triggers. The two main factors influencing LGD are the seniority of the debt and the collateral. In calculating EAD, banks can, with regulatory approval, use their own estimates of credit conversion factors.

III. For retail exposures, the Foundation and Advanced IRB approaches are merged, and all banks using the IRB approach provide their own estimates of PD, EAD, and LGD. There is no maturity adjustment.

Which of the above statements is (are) true?

A. None are true

B. Only I is true

C. Only II is true

D. All are true

Question ORR-21 e.4

Bank Q587 • BT P2.T6.605.2 (rebuilt)

Which of the following is TRUE about the Basel regulatory approach to retail exposures?

A. Retail exposures must use the standardized approach to credit risk.

B. Retail exposures must use the foundation IRB approach, with supervisory LGD and EAD.

C. Under the standardized approach, “regulatory retail” exposures are assigned a risk weight of 25%.

D. Under the IRB approach for retail exposures, residential mortgages are assigned a higher asset correlation than qualifying revolving retail exposures.

Question ORR-21 e.5

Bank Q579 • AnalystPrep Q.5971

A regional bank applying the advanced IRB approach under Basel II examines the maturity adjustment in its capital calculation for corporate exposures. Which statement is correct?

A. Capital requirements decrease with longer loan maturities and are higher for high-PD borrowers.

B. Maturity adjustments are unrelated to PD and depend solely on the loan term.

C. Capital requirements increase with longer loan maturities, and the maturity adjustment is larger for low-PD borrowers.

D. Maturity adjustments are the same for all borrowers regardless of loan term and PD.

Question ORR-21 e.6

Bank Q583 • GARP book PE2 Q47 • Mock 4 Q48

A researcher at a national regulatory agency is examining the use of the standardized approach (SA) and the advanced internal ratings-based (A-IRB) approach in determining credit risk capital. The researcher evaluates the implications of applying these approaches to two banks, Global Bank and Resource Bank.

- Global Bank lends to large global corporations that have highly diverse business lines by providing sizable, long-dated unsecured credit facilities.
- Resource Bank lends to oil and gas producers in its region, most of which have small-scale operations.

Which of the following is the most appropriate conclusion for the researcher to reach?

A. The A-IRB approach does not adjust for maturity, which means that A-IRB could undercapitalize the long-dated exposures at Global Bank.

B. The SA gives lower risk weights to unrated credits than to credits rated B+ or lower, which may incentivize Resource Bank to lend to unrated companies with poor credit quality.

C. Model parameters used in the SA effectively capture the high default correlation that is likely to exist between Resource Bank's lending counterparties.

D. The A-IRB approach would require Global Bank to model the exposure at default while using a probability of default specified by the Basel Committee.

Question ORR-21 e.7 Workbook A31.3 • S3 • self-generated

A regulatory reporting manager at a Japanese bank that uses the Basel II Foundation IRB approach is computing the capital for a senior unsecured loan to a highly rated domestic corporate. The data are:

- EAD: JPY 50 billion
- Bank's internal one-year PD estimate: 0.01%
- Bank's internal LGD estimate: 30%
- Maturity treatment: the Foundation IRB default

Which of the following is closest to the required capital?

A. JPY 0.30 billion

B. JPY 0.39 billion

C. JPY 0.58 billion

D. JPY 7.22 billion

Solutions • ORR-21 e

Solution ORR-21 e.1

Answer: A

Bank Q574 • AnalystPrep Q.2343

Step 1 – Match the bank to the approach

GARP: the standardized approach "was intended for banks with internal risk measures and risk management practices that were insufficient to support the IRB approaches". A bank with no internal rating system has no PD to feed an IRB formula.

Step 2 – How its weights are set

By obligor type and external rating for countries, banks and corporates, and by asset type for the rest (retail 75%, residential mortgages 35%).
$\Rightarrow$ No internal model and no supervisory approval are needed: the bank maps exposures to the table.

Interpretation

The standardized approach still differs from Basel I: OECD membership no longer matters, and ratings move the weight from 0% to 150%.

Why the other options are wrong

B is incorrect. Own PD, LGD and EAD estimates are IRB inputs, not standardized ones.
C is incorrect. Reversed split: under F-IRB the bank supplies PD and supervisors set LGD and EAD; and the bank has no rating system to produce a PD.
D is incorrect. A-IRB is the most demanding approach and requires supervisory approval and loss data.

LO: ORR-21 e: Compare the standardized internal ratings-based (IRB) approach, the foundation IRB approach, and the advanced IRB approach for the calculation of credit risk capital under Basel II. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Capital for Credit Risk; The Standardized Approach)

Solution ORR-21 e.2

Answer: B

Bank Q573 • AnalystPrep Q.2342

Step 1 – The US implementation choice

GARP (footnote 7): "The United States chose not to implement the Standardized Approach. Internationally active banks were required to use IRB approaches, while all other banks were required to use an updated version of the Basel I requirements."
$\Rightarrow$ A large, internationally active US bank had to use IRB.

Interpretation

This is the opposite of the intuitive menu: elsewhere a bank could choose; in the US the large banks had no standardized option and the small ones stayed on an updated Basel I.

Why the other options are wrong

A is incorrect. The generic Basel II menu; the US removed the standardized option.
C is incorrect. Reversed: the standardized approach is the one the US did not implement.
D is incorrect. The US did adopt Basel II for internationally active banks; only the other banks stayed on updated Basel I rules.

LO: ORR-21 e: Compare the standardized internal ratings-based (IRB) approach, the foundation IRB approach, and the advanced IRB approach for the calculation of credit risk capital under Basel II. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Capital for Credit Risk, footnote 7)

Solution ORR-21 e.3 Answer: D

Bank Q581 • BT P2.T7.519.1

Step 1 – Statement I (Foundation)

Bank supplies PD (floor 0.03% for bank and corporate exposures); LGD 45% senior, 75% subordinated; EAD and M supervisory, $M = 2.5$ in most cases. True.

Step 2 – Statement II (Advanced)

Bank supplies PD, LGD, EAD and M; PD can be reduced by credit mitigants such as credit triggers (same floor); LGD driven by seniority and collateral; own credit conversion factors with approval. True.

Step 3 – Statement III (Retail)

The two variants merge into an advanced-style treatment: bank estimates of PD, LGD and EAD, and no maturity adjustment. True.

$\Rightarrow$ All three statements are accurate.

Interpretation

The whole comparison reduces to one line: Foundation means the bank supplies PD only; Advanced means the bank supplies everything; retail is always "advanced" and never has a maturity adjustment.

Why the other options are wrong

A is incorrect. Every statement is accurate; choosing this usually comes from believing supervisors set PD under Foundation IRB.

B is incorrect. Rejects II and III, doubting the Advanced own estimates or the retail treatment.

C is incorrect. Rejects I and III, doubting the supervisory 45%/75% LGD and $M = 2.5$.

LO: ORR-21 e: Compare the standardized internal ratings-based (IRB) approach, the foundation IRB approach, and the advanced IRB approach for the calculation of credit risk capital under Basel II. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Bank, Corporate, and Sovereign Exposures Under IRB; Retail Exposures Under IRB); SchweserNotes 2026 Book 3, Reading 62, LO 62.e

Solution ORR-21 e.4 Answer: D

Bank Q587 • BT P2.T6.605.2

Step 1 – Retail under IRB

Only an Advanced-like treatment: the bank estimates PD, LGD and EAD; no maturity adjustment.

Step 2 – Retail correlations

0.15 for residential mortgages; 0.04 for qualifying revolving exposures (mostly credit cards); 0.03 to 0.16 by formula for other retail.

$\Rightarrow 0.15 > 0.04$: statement D is true.

Step 3 – Retail under the standardized approach

75% for retail, 35% for residential mortgages.

Interpretation

Mortgage defaults cluster when house prices fall together, so they get the higher systematic correlation; card balances default for more individual reasons. Both are still below the wholesale range of 0.12 to 0.24.

Why the other options are wrong

A is incorrect. False: banks with approval may use IRB for retail.

B is incorrect. False: retail has no Foundation variant; the bank estimates LGD and EAD itself.

C is incorrect. False: the standardized retail weight is 75%, not 25%.

LO: ORR-21 e: Compare the standardized internal ratings-based (IRB) approach, the foundation IRB approach, and the advanced IRB approach for the calculation of credit risk capital under Basel II. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Retail Exposures Under IRB; Table 21.3)

Solution ORR-21 e.5 — Answer: C

Bank Q579 • AnalystPrep Q.5971

Step 1 – The maturity adjustment

$$\text{MA} = \frac{1 + (M - 2.5)\, b}{1 - 1.5\, b}, \qquad b = \left[0.11852 - 0.05478 \ln(\text{PD})\right]^2$$

At $M = 1$ the numerator equals the denominator, so MA $= 1$; above that MA rises with M.

Step 2 – The role of PD

b falls as PD rises. At $M = 5$: PD 0.1% gives $b = 0.2469$ and MA $= 2.57$; PD 5% gives $b = 0.0799$ and MA $= 1.36$.

$\Rightarrow$ Capital rises with maturity, and the adjustment is larger for low-PD borrowers.

Interpretation

A long-dated loan can lose value through downgrades without defaulting, and a highly rated borrower has the most room to fall. Under F-IRB M is fixed at 2.5, so this maturity effect is visible only under A-IRB.

Why the other options are wrong

A is incorrect. Both parts reversed: capital rises with maturity, and the adjustment is larger for low PD.

B is incorrect. MA depends on PD through b, not only on the term.

D is incorrect. MA varies with both M and PD; it equals 1 only at $M = 1$.

LO: ORR-21 e: Compare the standardized internal ratings-based (IRB) approach, the foundation IRB approach, and the advanced IRB approach for the calculation of credit risk capital under Basel II. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Bank, Corporate, and Sovereign Exposures Under IRB)

Solution ORR-21 e.6 — Answer: B

Bank Q583 • GARP book PE2 Q47

Step 1 – Standardized weights for corporates

Table 21.3: unrated corporates 100%; B+ to B− 150%.

$\Rightarrow$ A poor-quality but unrated borrower costs less capital than a rated weak one: B is the perverse incentive.

Step 2 – Test the other statements

A-IRB includes an explicit maturity adjustment (A false). The SA is a table of weights with no correlation parameter (C false). Under A-IRB the bank estimates PD itself, along with LGD, EAD and M (D false).

Interpretation

Resource Bank's small regional producers are likely to be unrated and to share one driver, the oil price. The SA prices neither their quality (unrated at 100%) nor their correlation. Global Bank's long-dated facilities are exactly what the A-IRB maturity adjustment is for.

Why the other options are wrong

A is incorrect. The IRB formula includes a maturity adjustment that raises capital for long-dated

exposures.

C is incorrect. The SA has no model parameters or correlations; correlation appears only in the IRB formula.

D is incorrect. Mixes up the variants: under A-IRB the bank estimates PD too; a supervisory LGD and EAD with a bank PD is Foundation IRB, and the Committee never specifies PD.

LO: ORR-21 e: Compare the standardized internal ratings-based (IRB) approach, the foundation IRB approach, and the advanced IRB approach for the calculation of credit risk capital under Basel II. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (The Standardized Approach, Table 21.3; The IRB Approach)

Solution ORR-21 e.7 — Answer: C

Workbook A31.3 • S3

Step 1 – Foundation IRB inputs

PD is floored at 0.0003 for corporates, so PD $= 0.03\%$, not 0.01%. LGD is the supervisory 45% for senior claims; the internal 30% is not used. MA uses $M = 2.5$.

Step 2 – Correlation

$$w = \frac{1 - \mathrm{e}^{-50\times 0.0003}}{1 - \mathrm{e}^{-50}} = 0.01489, \qquad \rho = 0.12(0.01489) + 0.24(0.98511) = 0.2382$$

$\Rightarrow$ A very safe obligor gets close to the maximum correlation of 0.24.

Step 3 – WCDR

$$z = \frac{-3.4316 + \sqrt{0.2382} \times 3.0902}{\sqrt{0.7618}} = \frac{-3.4316 + 1.5083}{0.8728} = -2.2037$$

$$\text{WCDR} = N(-2.2037) = 0.01377$$

Step 4 – Maturity adjustment at $M = 2.5$

$$b = [0.11852 - 0.05478 \ln(0.0003)]^2 = 0.5629^2 = 0.3168$$

$$\text{MA} = \frac{1}{1 - 1.5(0.3168)} = 1.9057$$

Step 5 – Capital

$$\text{Capital} = 50 \times 0.45 \times (0.01377 - 0.0003) \times 1.9057 = \text{JPY } 0.58 \text{ billion}$$

Interpretation

About 1.2% of EAD. Under the December 2017 revisions the corporate PD floor rises to 5 bp and F-IRB senior unsecured LGD to non-financial corporates falls to 40%; holding $M = 2.5$, capital would be about JPY 0.70 billion.

Why the other options are wrong

A is incorrect. Ignored the PD floor and used 0.01%: $\rho = 0.2394$, WCDR $= 0.00569$, MA $= 2.394$, capital $= 50 \times 0.45 \times 0.00559 \times 2.394 = 0.30$.

B is incorrect. Used the bank's own LGD of 30%, which only Advanced IRB permits: $50 \times 0.30 \times 0.01347 \times 1.9057 = 0.39$.

D is incorrect. Reported RWA instead of capital: $12.5 \times 0.578 = 7.22$.

LO: ORR-21 e: Compare the standardized internal ratings-based (IRB) approach, the foundation IRB approach, and the advanced IRB approach for the calculation of credit risk capital under Basel II. ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. • **Reference:** Carey, Capital Regulation Before the Global Financial Crisis, The IRB Approach and Bank, Corporate, and Sovereign Exposures Under IRB

ORR-21 • Capital Regulation Before the Global Financial Crisis • Vardeez: UNTIERED

ORR-21 f

P1 CALC

Calculate credit risk capital under Basel II utilizing the IRB approach.

Workbook: A31 Basel IRB Capital • Tier A • August 2026 recall D4 Stressed VaR and Market Risk Capital • Tier D

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: A31 (Basel IRB Capital) is in your August 2026 recall ("Credit risk IRB"). D4 (Tier D, #73) adds the mixed vignette that pairs a market risk charge with IRB credit capital.

Vardeez: his notes label this LO "LO 60.f" (consolidated volume pp.48 to 49): his three formulas (capital $= \sum \text{EAD} \times \text{LGD} \times \text{DR}_{99.9} - \text{EL}$; capital $= \text{EAD} \times \text{LGD} \times (\text{DR}_{99.9} - \text{PD}) \times \text{MA}$; RWA $= 12.5\times$ capital), the maturity adjustment, and his Blue Star example (RWA USD 49.19 million against USD 150 million under Basel I).

Reported exam shapes

- **A31·S1** IRB capital for a single corporate loan under Advanced IRB, with the correlation formula and maturity adjustment: the plain form.
- **A31·S2** Retail IRB: fixed correlation, no maturity adjustment, reported as RWA.
- **D4·S3** Mixed vignette: market risk charge plus credit capital given the 99.9th percentile default rate, one error per option.

What the questions look like: EAD, PD, LGD (or a recovery rate) and either the 99.9th percentile default rate or the correlation, sometimes the maturity. You compute the worst-case default rate, then capital or RWA. One distractor per slip: EL not subtracted, MA left out (or put on retail), correlation weights swapped, RWA reported as capital, recovery used as LGD, the 95th percentile used.

See also: workbook A31.3 (Foundation inputs) is worked under ORR-21 e; D4.2 (Basel 2.5 charge with stressed VaR, plus IRB capital) under ORR-22 a. The vignette here, Question ORR-21 f.8, uses the 1996 charge of ORR-21 c.

1. What IRB capital covers

The Basel Committee chose a **one-year horizon** and wanted capital to absorb credit losses up to the **99.9th percentile** of the loss distribution. The model behind the formula is Gordy's (2003) asymptotic single risk factor model, a one-factor Gaussian copula:

$$\text{Capital} = \sum_i \text{EAD}_i \times \text{LGD}_i \times \text{DR}_{99.9,i} \; - \; \text{EL}, \qquad \text{EL} = \sum_i \text{EAD}_i \times \text{LGD}_i \times \text{PD}_i$$

- EAD_i: the amount owed at default; LGD_i: the fraction of EAD expected to be lost ($1-$ recovery rate); $\text{DR}_{99.9,i}$: the default rate at the 99.9th percentile for a large portfolio of assets like i, the *worst-case default rate* (WCDR).
- **Why net of EL.** The Committee did not count loan loss reserves as Tier 1, but thought them roughly equal to expected losses. So capital is a function of **unexpected loss only**. Where reserves fall short of EL, the shortfall reduces capital.
- Losses beyond the 99.9th percentile are **stress losses**: no capital is held for them (Figure 1).

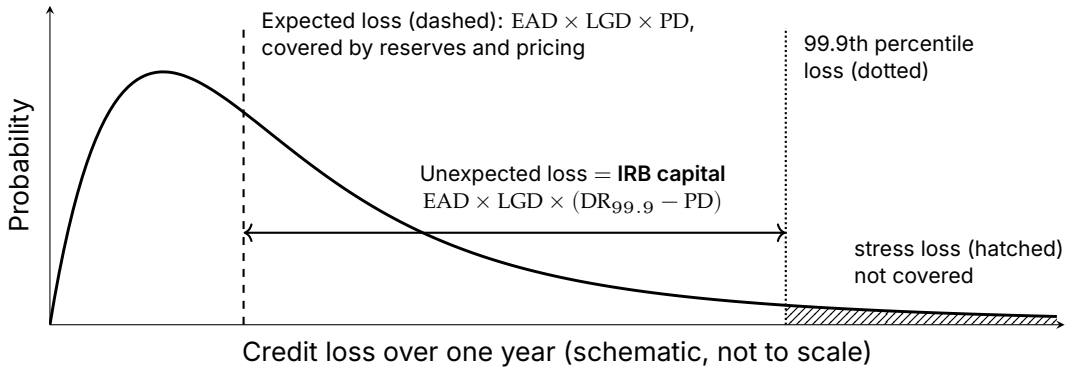


Figure 1. GARP Figure 21.1 redrawn. Expected loss (dashed line) is met by reserves and pricing; capital covers the gap up to the 99.9th percentile (dotted line); the hatched tail beyond it is stress loss.

2. The worst-case default rate

$$\mathrm{DR}_{99.9} = N\left[\frac{N^{-1}(\mathrm{PD}) + \sqrt{\rho}\, N^{-1}(0.999)}{\sqrt{1-\rho}}\right], \qquad N^{-1}(0.999) = 3.0902$$

ρ is the asset (copula) correlation between each obligor and the single systematic factor. With $\rho = 0$ defaults are independent and $\mathrm{DR}_{99.9} = \mathrm{PD}$. The worst-case rate rises with both PD and ρ (GARP Table 21.4, exact values):

	PD $= 0.001$	PD $= 0.005$	PD $= 0.01$	PD $= 0.02$
$\rho = 0.0$	0.001	0.005	0.010	0.020
$\rho = 0.2$	0.028	0.091	0.146	0.226
$\rho = 0.4$	0.071	0.211	0.316	0.449
$\rho = 0.6$	0.135	0.387	0.542	0.705

GARP prints 0.092 for PD 0.005 and $\rho = 0.2$; the exact value is 0.0910. The Committee fixes the percentile and ρ for each asset class, so each asset's contribution to capital depends only on the bank's EAD, LGD and PD for that asset (**portfolio invariance**). The model assumes infinitely granular portfolios with no single-name concentration; the 2014 Large Exposures Framework was needed because real banks held sizable single-counterparty exposures.

3. Correlation by asset class

Bank, corporate and sovereign exposures (Lopez, 2004):

$$\rho = 0.12\, w + 0.24\,(1-w), \qquad w = \frac{1-\mathrm{e}^{-50\,\mathrm{PD}}}{1-\mathrm{e}^{-50}} \qquad (\approx 0.12\,(1+\mathrm{e}^{-50\,\mathrm{PD}}))$$

ρ falls from 0.24 (PD near zero) towards 0.12 as PD rises: very risky borrowers tend to default for idiosyncratic reasons, while middle-risk borrowers default together when the macroeconomy is distressed. The effect is that DR rises somewhat less quickly with PD than at a constant ρ. At PD $= 1\%$: $w = 1 - \mathrm{e}^{-0.5} = 0.3935$ and $\rho = 0.0472 + 0.1456 = 0.1928$.

Retail exposures: $\rho = 0.15$ for residential mortgages; $\rho = 0.04$ for qualifying revolving exposures (mostly credit cards); for other retail $\rho = 0.03\, w_{35} + 0.16\,(1 - w_{35})$, with $w_{35} = (1-\mathrm{e}^{-35\,\mathrm{PD}})/(1-\mathrm{e}^{-35})$, which gives 0.1216 at PD $= 1\%$.

4. Maturity adjustment, capital and RWA

Bank, corporate and sovereign exposures with more than one year to run can deteriorate in credit quality before the year ends, so their capital carries a maturity adjustment:

$$\text{MA} = \frac{1 + (M - 2.5)\, b}{1 - 1.5\, b}, \qquad b = \left[0.11852 - 0.05478 \ln(\text{PD})\right]^2$$

M is remaining maturity in years. MA $= 1$ at $M = 1$; at $M = 2.5$ it reduces to $1/(1 - 1.5b)$. Low PD means a larger b and a larger MA. Retail exposures have **no** maturity adjustment.

$$\boxed{K = \text{EAD} \times \text{LGD} \times (\text{DR}_{99.9} - \text{PD}) \times \text{MA}, \qquad \text{RWA} = 12.5 \times K}$$

Capital is K itself, which equals $8\% \times$ RWA.

Credit mitigants other than collateral. Guarantees and credit default swaps use credit substitution: the guarantor's rating replaces the obligor's up to the amount covered. Since 2005 a bank may instead multiply the capital without the mitigant by $0.15 + 160\,\text{PD}_g$, where PD_g is the guarantor's one-year PD (0.31 for $\text{PD}_g = 0.1\%$).

5. Worked examples

Vardeez's Blue Star loan (Advanced IRB, $M = 2.5$)

USD 150 million to an A-rated corporate: PD 0.1%, LGD 50%, $\text{DR}_{99.9} = 3.4\%$ (the corporate formula gives $\rho = 0.234$ and DR $= 0.0342$).

$$b = \left[0.11852 - 0.05478 \ln(0.001)\right]^2 = 0.4969^2 = 0.2469, \qquad \text{MA} = \frac{1}{1 - 1.5 \times 0.2469} = 1.588$$

$$\text{RWA} = 12.5 \times 150 \times 0.50 \times (0.034 - 0.001) \times 1.588 = \text{USD } 49.14 \text{ million}$$

Vardeez rounds MA to 1.59 and prints 49.19. The risk weight is about 33%, against 100% (USD 150 million) under Basel I: IRB lowers RWA for highly rated corporates.

GARP's BB-rated loans ($M = 3$)

USD 100 million of drawn BB loans: PD 0.01, LGD 30%, remaining maturity 3 years. The corporate formula gives $\rho = 0.1928$ and DR $= 0.140$; $b = 0.1375$.

$$\text{MA} = \frac{1 + (3 - 2.5) \times 0.1375}{1 - 1.5 \times 0.1375} = \frac{1.0687}{0.7938} = 1.346$$

$$\text{RWA} = 12.5 \times 100 \times 0.30 \times (0.14 - 0.01) \times 1.346 = \text{USD } 65.6 \text{ million}$$

Basel I and the Basel II standardized approach would both give USD 100 million.

GARP's residential mortgages (retail, no MA)

USD 100 million of mortgages, PD 0.01, LGD 30%, $\rho = 0.15$:

$$\text{DR} = N\left[\frac{-2.3263 + \sqrt{0.15} \times 3.0902}{\sqrt{0.85}}\right] = N(-1.2251) = 0.110$$

$$\text{RWA} = 12.5 \times 100 \times 0.30 \times (0.110 - 0.01) = \text{USD } 37.6 \text{ million}$$

Basel I would give USD 50 million (50% weight) and the Basel II standardized approach USD 35 million (35%).

Correction to the source notes (GARP Section 21.2).

- **BB-loan example.** GARP computes MA $= 1/(1 - 1.5 \times 0.137) = 1.26$, the $M = 2.5$ form, although the loans have 3 years to run. With $M = 3$ the formula gives MA $= 1.346$ and RWA $=$ USD 65.6 million, not 61.4. The A31 book check flags the same point. When a stem gives MA directly (Question ORR-21 f.4), use the MA given.
- **Mortgage example.** GARP states DR $= 0.09$ and RWA $= 30$, and concludes that IRB is below the standardized USD 35 million. With the mortgage correlation of 0.15 the formula gives DR $= 0.110$ and RWA $= 37.6$, *above* the standardized 35 though still below Basel I's 50. GARP's 0.09 is the value for the other-retail correlation ($\rho = 0.1216$ at PD 1% gives 0.0914). The A31 revision notes repeat GARP's figures.
- **Table 21.4.** PD 0.005 with $\rho = 0.2$ gives 0.091, not 0.092 (a rounding slip).

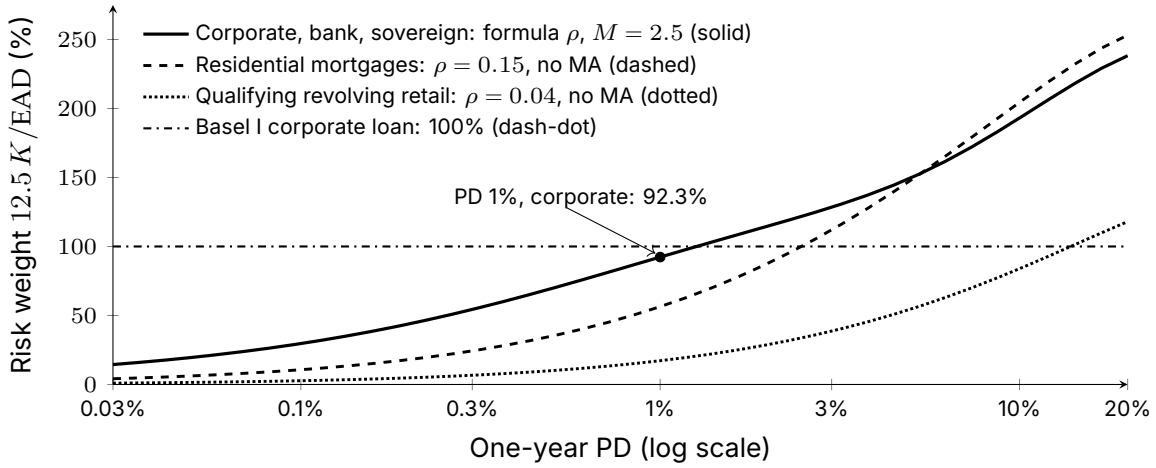


Figure 2. IRB risk weight against PD with LGD 45%, from the Vasicek formula. Corporate (solid line) at the Foundation default $M = 2.5$; residential mortgages (dashed) and credit cards (dotted) with their fixed retail correlations and no maturity adjustment. The dash-dot line is the flat Basel I weight. A corporate at the 0.03% PD floor gets 14.4%; at PD 1% the weight is close to Basel I's 100%.

6. Mixed vignettes (workbook shape D4, S3)

Some questions ask for a trading book charge and a banking book charge together. Compute each on its own conventions, then add:

- **Market risk (1996, ORR-21 c):** 10-day 99% VaR; $\max(\text{VaR}_{t-1}, m\,\text{VaR}_{avg})$ with m from backtesting; one-day figures $\times\sqrt{10}$. (Basel 2.5 adds a stressed VaR term: ORR-22 a.)
- **Credit risk (Basel II IRB):** one-year 99.9th percentile loss *minus* EL; MA for wholesale, none for retail.
- The two charges are capital; $12.5\times$ their sum is the RWA equivalent. The usual design puts exactly one slip in each wrong option.

Formula card: ORR-21 f

Worst-case default rate	$\mathrm{DR}_{99.9} = N\left[\left(N^{-1}(\mathrm{PD}) + \sqrt{\rho}\, N^{-1}(0.999)\right) / \sqrt{1-\rho}\right]$, $N^{-1}(0.999) = 3.0902$
Carey's capital	$\sum \mathrm{EAD} \times \mathrm{LGD} \times \mathrm{DR}_{99.9} - \mathrm{EL}$, $\mathrm{EL} = \sum \mathrm{EAD} \times \mathrm{LGD} \times \mathrm{PD}$
Capital per exposure	$K = \mathrm{EAD} \times \mathrm{LGD} \times (\mathrm{DR}_{99.9} - \mathrm{PD}) \times \mathrm{MA}$ (retail: no MA)
RWA	$\mathrm{RWA} = 12.5 \times K$; capital $= 8\% \times \mathrm{RWA}$
Wholesale correlation	$\rho = 0.12\, w + 0.24\,(1-w)$, $w = (1-\mathrm{e}^{-50\mathrm{PD}})/(1-\mathrm{e}^{-50}) \approx 1-\mathrm{e}^{-50\mathrm{PD}}$
Retail correlation	0.15 mortgages; 0.04 qualifying revolving; other: $0.03\, w_{35} + 0.16\,(1 - w_{35})$
Maturity adjustment	$\mathrm{MA} = \dfrac{1 + (M-2.5)\, b}{1 - 1.5\, b}$, $b = [0.11852 - 0.05478 \ln \mathrm{PD}]^2$; $M = 2.5$: $1/(1-1.5b)$
Foundation defaults	$\mathrm{PD} \geq 0.03\%$ (bank, corporate); LGD 45% senior, 75% subordinated; $M = 2.5$
Double default (2005)	capital without mitigant $\times (0.15 + 160\, \mathrm{PD}_g)$

Exam traps

- **EL not subtracted.** $\mathrm{EAD} \times \mathrm{LGD} \times \mathrm{DR}_{99.9}$ is the 99.9th percentile loss (Hull's credit VaR), not capital. Subtract EL, or use DR − PD.
- **Capital against RWA.** $\mathrm{RWA} = 12.5\times$ capital; read which one the stem asks for.
- **Maturity adjustment misapplied.** Omitted for a corporate loan; $M = 2.5$ used when an A-IRB stem gives the maturity; or applied to retail, which has none.
- **Correlation slips.** Weights swapped so that ρ rises with PD; the corporate formula used on mortgages; 0.04 used on mortgages.
- **Recovery rate as LGD.** LGD $= 1-$ recovery.
- **Wrong percentile.** The 95th or 99th percentile default rate in place of the 99.9th; $N^{-1}(0.999) = 3.0902$, not 2.326.
- **Sign of z.** The argument of $N(\cdot)$ is negative for realistic PDs; $N(+z)$ gives $1 -$ DR.
- **EL without LGD.** $\mathrm{EL} = \mathrm{EAD} \times \mathrm{LGD} \times \mathrm{PD}$, not $\mathrm{EAD} \times \mathrm{PD}$.
- **Mixed vignettes.** Each side keeps its own horizon and percentile; do not net EL from the market charge or apply $\sqrt{10}$ to credit.

Practice questions: ORR-21 f

Question ORR-21 f.1

Bank Q599 • AnalystPrep Q.4406 (rebuilt)

Under Basel II, the asset correlation for bank, corporate and sovereign exposures is

$$\rho = 0.12\,\frac{1-\mathrm{e}^{-50\,\mathrm{PD}}}{1-\mathrm{e}^{-50}} + 0.24\left(1-\frac{1-\mathrm{e}^{-50\,\mathrm{PD}}}{1-\mathrm{e}^{-50}}\right).$$

For a borrower with $\mathrm{PD} = 0.01$, what is the approximate asset correlation?

A. 0.1673

B. 0.1800

C. 0.1928

D. 0.2400

Question ORR-21 f.2

Bank Q588 • AnalystPrep Q.3238 and Q.3239 (rebuilt)

Kimpala Leasing Bank holds USD 690 million of retail loans. The bank's analysts estimate PD $= 1\%$ and LGD $= 40\%$, and the Basel II copula correlation is $\rho = 0.1216$. Under the Basel II IRB approach, what are the worst-case default rate at the 99.9% confidence level ($\mathrm{DR}_{99.9}$) and the expected loss (EL)?

A. $\mathrm{DR}_{99.9} = 9.14\%$; EL = USD 2.76 million

B. $\mathrm{DR}_{99.9} = 9.14\%$; EL = USD 6.90 million

C. $\mathrm{DR}_{99.9} = 9.14\%$; EL = USD 22.46 million

D. $\mathrm{DR}_{99.9} = 90.86\%$; EL = USD 2.76 million

Question ORR-21 f.3

Bank Q598 • GARP PE1 Q19 • Mock 3 Q61

A regulatory analyst at a large bank is preparing a report of the bank's credit risk capital and uses the Basel II IRB approach. The analyst identifies a portfolio of credit exposures of equal size held by borrowers with the same probability of default, with the following data:

Exposure at default	EUR 200 million
1-year expected loss on the portfolio	EUR 4.2 million
Expected recovery rate on a defaulted credit	30.00%
1-year portfolio default rate at the 95th percentile	5.66%
1-year portfolio default rate at the 99.9th percentile	9.87%

What is the correct estimate of the Basel II credit risk capital that the bank should reserve for this portfolio?

A. EUR 3.72 million

B. EUR 5.92 million

C. EUR 9.62 million

D. EUR 13.82 million

Question ORR-21 f.4 Bank Q596 • AnalystPrep Q.4405 (rebuilt)

A Canadian bank has assets consisting of CAD 300 million of BB-rated drawn corporate loans. Under the Basel II IRB approach the one-year probability of default is PD $= 0.01$, LGD $= 30\%$, the 99.9th percentile default rate is DR $= 0.14$, and the maturity adjustment factor is MA $= 1.26$. What are the risk-weighted assets (RWA) for these loans?

A. CAD 14.74 million

B. CAD 146.25 million

C. CAD 184.28 million

D. CAD 198.45 million

Question ORR-21 f.5 Bank Q593 • AP Mock 3 Q65 (option A rebuilt)

A financial institution holds USD 120 million of commercial loans. The average probability of default is 2%, the average recovery rate is 40%, and the copula correlation is 0.25. Assume a maturity adjustment of 1. What is the IRB capital requirement (USD million) at the 99.9% confidence level?

A. 12.41

B. 18.61

C. 20.05

D. 33.42

Question ORR-21 f.6 Workbook A31.2 • S2 • Aug-2026

A model validation analyst at a UK building society is checking the IRB risk-weighted assets reported for its residential mortgage book. The data are:

- EAD: GBP 400 million
- Average one-year PD: 1.50%; average LGD: 25%
- Average remaining contractual maturity: 18 years
- Confidence level 99.9%; Basel II retail treatment applies

Which of the following is closest to the risk-weighted assets for this book?

A. GBP 163.2 million

B. GBP 182.0 million

C. GBP 191.9 million

D. GBP 575.5 million

Question ORR-21 f.7 Workbook A31.1 • S1 • Aug-2026

A credit risk analyst at a German universal bank using the Advanced IRB approach is computing the Basel II capital for a single corporate term loan. The data are:

- EAD: EUR 250 million
- One-year PD: 0.80%; LGD: 40%
- Remaining maturity: 4 years
- Correlation from the Basel corporate formula; confidence level 99.9%

Which of the following is closest to the required capital for this loan?

A. EUR 11.8 million

B. EUR 14.4 million

C. EUR 15.1 million

D. EUR 18.4 million

Question ORR-21 f.8 New • built from GARP Ch.21

The CRO of a South African bank asks a senior risk analyst for two figures for the board risk committee: the market risk capital charge for the trading book under the 1996 Amendment internal models approach, and the Basel II IRB credit risk capital for a large, homogeneous book of unsecured personal loans in the banking book (a retail exposure class). Data (ZAR million):

- Trading book, one-day 99% VaR: previous day 17.0; average over the last 60 trading days 5.0. The bank scales one-day VaR to 10 days with the square-root-of-time rule.
- Backtesting: 11 exceptions over the last 250 trading days.
- Loan book: EAD 2,000; LGD 40%; PD 1.5%; one-year default rate at the 99.9th percentile 11%; average remaining maturity 3 years.

Which of the following pairs is closest to the market risk capital charge and the credit risk capital?

A. Market risk ZAR 20.0 million; credit risk ZAR 76.0 million

B. Market risk ZAR 53.8 million; credit risk ZAR 76.0 million

C. Market risk ZAR 63.2 million; credit risk ZAR 76.0 million

D. Market risk ZAR 63.2 million; credit risk ZAR 88.0 million

Solutions • ORR-21 f

Solution ORR-21 f.1

Answer: C

Bank Q599 • AnalystPrep Q.4406

Step 1 – The weight on 0.12

$$w = \frac{1 - e^{-50 \times 0.01}}{1 - e^{-50}} = 1 - e^{-0.5} = 1 - 0.6065 = 0.3935$$

$\Rightarrow e^{-50}$ is effectively zero, so the denominator is 1.

Step 2 – Correlation

$$\rho = 0.12 \times 0.3935 + 0.24 \times 0.6065 = 0.0472 + 0.1456 = 0.1928$$

Interpretation

At PD 1% the correlation sits about a third of the way down from 0.24 to 0.12. It falls further as PD rises: riskier borrowers default for more idiosyncratic reasons.

Why the other options are wrong

A is incorrect. Swapped the weights: $0.24 \times 0.3935 + 0.12 \times 0.6065 = 0.1673$, which would make ρ rise with PD.

B is incorrect. The simple average of 0.12 and 0.24, ignoring PD.

D is incorrect. The upper bound 0.24, the limit as PD approaches zero.

LO: ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Bank, Corporate, and Sovereign Exposures Under IRB)

Solution ORR-21 f.2

Answer: A

Bank Q588 • AnalystPrep Q.3238 and Q.3239

Step 1 – The ingredients

$$N^{-1}(0.01) = -2.3263, \quad N^{-1}(0.999) = 3.0902$$
$$\sqrt{0.1216} = 0.3487, \quad \sqrt{1 - 0.1216} = 0.9372$$

Step 2 – Worst-case default rate

$$\text{DR}_{99.9} = N\left[\frac{-2.3263 + 0.3487 \times 3.0902}{0.9372}\right] = N(-1.3324) = 0.0914 = 9.14\%$$

$\Rightarrow$ In the one-in-a-thousand bad year, 9.14% of these loans default against 1% on average.

Step 3 – Expected loss

$$\text{EL} = \text{EAD} \times \text{LGD} \times \text{PD} = 690 \times 0.40 \times 0.01 = \text{USD } 2.76 \text{ million}$$

Interpretation

EL uses the unstressed PD and is covered by reserves and pricing; capital covers the stressed part, $690 \times 0.40 \times (0.0914 - 0.01) = \text{USD } 22.46$ million. The correlation 0.1216 is the other-retail formula value at PD 1%.

Why the other options are wrong

B is incorrect. EL without LGD: $690 \times 0.01 = 6.90$.

C is incorrect. Reported the IRB capital, EAD $\times$ LGD $\times$ (DR $-$ PD) $=$ 22.46, as the expected loss.
D is incorrect. Took $N(+1.3324) = 0.9086$ instead of $N(-1.3324)$: the left-tail probability is the small one.

LO: ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (The IRB Approach; Retail Exposures Under IRB)

Solution ORR-21 f.3 — Answer: C

Bank Q598 • GARP PE1 Q19

Step 1 – LGD from the recovery rate

$$\text{LGD} = 1 - 30\% = 70\%$$

Step 2 – Loss at the 99.9th percentile

$$200 \times 0.70 \times 0.0987 = \text{EUR } 13.818 \text{ million}$$

Step 3 – Capital: subtract expected loss

$$13.818 - 4.2 = \text{EUR } 9.62 \text{ million}$$

$\Rightarrow$ IRB capital covers unexpected loss only.

Interpretation

The EL of 4.2 implies PD $= 4.2/(200 \times 0.70) = 3\%$. The 95th percentile default rate is a red herring: Basel II calibrates to the 99.9th percentile.

Why the other options are wrong

A is incorrect. Used the 95th percentile rate: $200 \times 0.70 \times 0.0566 - 4.2 = 3.72$.
B is incorrect. Used the recovery rate as LGD and did not subtract EL: $200 \times 0.30 \times 0.0987 = 5.92$.
D is incorrect. The 99.9th percentile loss without subtracting EL: 13.82.

LO: ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (The IRB Approach)

Solution ORR-21 f.4 — Answer: C

Bank Q596 • AnalystPrep Q.4405

Step 1 – Unexpected default rate

$$\text{DR} - \text{PD} = 0.14 - 0.01 = 0.13$$

Step 2 – Capital

$$K = 300 \times 0.30 \times 0.13 \times 1.26 = \text{CAD } 14.742 \text{ million}$$

Step 3 – RWA

$$\text{RWA} = 12.5 \times 14.742 = \text{CAD } 184.28 \text{ million}$$

$\Rightarrow$ A risk weight of $184.28/300 = 61.4\%$, against 100% (CAD 300 million) under Basel I.

Interpretation

This is GARP's BB-loan example scaled to CAD 300 million. MA $= 1.26$ is the $M = 2.5$ value for PD 1% ($b = 0.1375$); GARP's own version gives the loans 3 years, for which MA would be 1.346 (see the correction box in Section 5). The stem here gives MA, so use it.

Why the other options are wrong

A is incorrect. Omitted the 12.5 multiplier: $300 \times 0.30 \times 0.13 \times 1.26 = 14.74$ is capital, not RWA.

B is incorrect. Forgot the maturity adjustment: $12.5 \times 300 \times 0.30 \times 0.13 = 146.25$.

D is incorrect. Used DR instead of DR − PD: $1125 \times 0.14 \times 1.26 = 198.45$.

LO: ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Bank, Corporate, and Sovereign Exposures Under IRB)

Solution ORR-21 f.5

Answer: B

Bank Q593 • AP Mock 3 Q65

Step 1 – LGD and the quantiles

$$\text{LGD} = 1 - 0.40 = 0.60, \qquad N^{-1}(0.02) = -2.0537, \qquad N^{-1}(0.999) = 3.0902$$

Step 2 – Worst-case default rate

$$\text{WCDR} = N\left[\frac{-2.0537 + \sqrt{0.25} \times 3.0902}{\sqrt{0.75}}\right] = N(-0.5873) = 0.2785$$

$\Rightarrow$ A correlation of 0.25 pushes the bad-year default rate to 27.9%, about 14 times the PD.

Step 3 – Capital

$$\text{Capital} = 120 \times 0.60 \times (0.2785 - 0.02) \times 1 = \text{USD } 18.61 \text{ million}$$

Interpretation

Expected loss is only $120 \times 0.60 \times 0.02 = 1.44$; the capital is driven by the correlation. (The bank version's option of 43.2, $120 \times 0.6 \times 0.6$, matched no single error; it is replaced by the recovery-as-LGD slip.)

Why the other options are wrong

A is incorrect. Used the recovery rate as LGD: $120 \times 0.40 \times (0.2785 - 0.02) = 12.41$.

C is incorrect. Did not subtract expected loss: $120 \times 0.60 \times 0.2785 = 20.05$.

D is incorrect. Dropped both LGD and the EL subtraction: $120 \times 0.2785 = 33.42$.

LO: ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (The IRB Approach)

Solution ORR-21 f.6

Answer: A

Workbook A31.2 • S2 • Aug-2026

Step 1 – Correlation

Residential mortgages use the fixed retail correlation $\rho = 0.15$.

Step 2 – WCDR

$$z = \frac{N^{-1}(0.015) + \sqrt{0.15} \times 3.0902}{\sqrt{0.85}} = \frac{-2.1701 + 1.1968}{0.9220} = -1.0556$$

$$\text{WCDR} = N(-1.0556) = 0.1456$$

$\Rightarrow$ In the 99.9th percentile year, 14.56% of the mortgage pool defaults.

Step 3 – Capital (no maturity adjustment for retail)

$$\text{Capital} = 400 \times 0.25 \times (0.1456 - 0.0150) = \text{GBP } 13.06 \text{ million}$$

Step 4 – RWA

$$\text{RWA} = 12.5 \times 13.06 = \text{GBP } 163.2 \text{ million}$$

Interpretation

A risk weight of $163.2/400 = 40.8\%$. The 18-year maturity is a red herring: retail exposures carry no maturity adjustment.

Why the other options are wrong

B is incorrect. Dropped the $-$PD term: $12.5 \times 400 \times 0.25 \times 0.1456 = 182.0$.

C is incorrect. Applied the corporate correlation formula ($\rho = 0.1767$): WCDR $= 0.1685$, RWA $= 12.5 \times 100 \times (0.1685 - 0.015) = 191.9$.

D is incorrect. Applied a maturity adjustment with $M = 18$ ($b = 0.1215$, MA $= 3.526$), which retail does not have: $163.2 \times 3.526 = 575.5$.

LO: ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. CR-10 d: Describe the application of the Vasicek's model to estimate capital requirements under the Basel II internal-ratings-based (IRB) approach. • **Reference:** Carey, Capital Regulation Before the Global Financial Crisis, Retail Exposures Under IRB; Hull, RMFI 6e, Ch.19, 10.2

Solution ORR-21 f.7 **Answer: D**

Workbook A31.1 • S1 • Aug-2026

Step 1 – Correlation weight and corporate correlation

$$w = \frac{1 - \mathrm{e}^{-50 \times 0.008}}{1 - \mathrm{e}^{-50}} = 0.3297, \qquad \rho = 0.12(0.3297) + 0.24(0.6703) = 0.2004$$

$\Rightarrow$ About 20% of each obligor's asset variance comes from the single systematic factor.

Step 2 – Argument of $N(\cdot)$

$$z = \frac{N^{-1}(0.008) + \sqrt{0.2004} \times 3.0902}{\sqrt{1 - 0.2004}} = \frac{-2.4089 + 1.3835}{0.8942} = -1.1468$$

Step 3 – WCDR

$$\text{WCDR} = N(-1.1468) = 0.1257$$

$\Rightarrow$ In the 1-in-1,000-year bad year, 12.57% of loans like this default, versus 0.80% on average.

Step 4 – Maturity adjustment

$$b = [0.11852 - 0.05478 \ln(0.008)]^2 = 0.3830^2 = 0.1467$$

$$\text{MA} = \frac{1 + (4 - 2.5)(0.1467)}{1 - 1.5(0.1467)} = \frac{1.2201}{0.7799} = 1.5643$$

⇒ A 4-year loan can be downgraded without defaulting, so capital is scaled up by about 56%.

Step 5 – Capital

$$\text{Capital} = 250 \times 0.40 \times (0.1257 - 0.0080) \times 1.5643 = \text{EUR } 18.4 \text{ million}$$

Interpretation

RWA $= 12.5 \times 18.4 =$ EUR 230.2 million. Expected loss $250 \times 0.40 \times 0.008 =$ EUR 0.8 million is covered by reserves and pricing, not capital.

Why the other options are wrong

A is incorrect. Omitted the maturity adjustment: $250 \times 0.40 \times 0.1177 = 11.8$.
B is incorrect. Swapped the correlation weights so ρ rises with PD: $\rho = 0.24(0.3297) + 0.12(0.6703) = 0.1596$, WCDR $= 0.1001$, capital $= 100 \times 0.0921 \times 1.5643 = 14.4$.
C is incorrect. Used the Foundation default $M = 2.5$ (MA $= 1.2821$) although the A-IRB stem gives 4 years: $100 \times 0.1177 \times 1.2821 = 15.1$.

LO: CR-10 d: Describe the application of the Vasicek's model to estimate capital requirements under the Basel II internal-ratings-based (IRB) approach. ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. • **Reference:** Hull, RMFI 6e, Ch.19, 10.2 eq. 10.1; Carey, Capital Regulation Before the Global Financial Crisis, Bank, Corporate, and Sovereign Exposures Under IRB

Solution ORR-21 f.8 **Answer: C**

New • built from GARP Ch.21

Step 1 – Multiplier from backtesting

11 exceptions in 250 days is "10 or more", so $m = 4$.

Step 2 – The max decision (one-day figures)

$$\max(\text{VaR}_{t-1},\ m \times \text{VaR}_{avg}) = \max(17.0,\ 4 \times 5.0) = \max(17.0,\ 20.0) = 20.0$$

⇒ With the correct multiplier the averaged term binds; with $m = 3$ the previous day's 17.0 would have bound instead.

Step 3 – Scale to 10 days

$$\text{MR} = 20.0 \times \sqrt{10} = 20.0 \times 3.1623 = \text{ZAR } 63.2 \text{ million}$$

Step 4 – Credit capital

$$\text{EAD} \times \text{LGD} \times \text{DR}_{99.9} = 2{,}000 \times 0.40 \times 0.11 = 88.0, \qquad \text{EL} = 2{,}000 \times 0.40 \times 0.015 = 12.0$$

$$\text{Capital} = 88.0 - 12.0 = \text{ZAR } 76.0 \text{ million}$$

⇒ Personal loans are retail: no maturity adjustment.

Interpretation

Total capital is about ZAR 139.2 million, an RWA equivalent of $12.5 \times 139.25 =$ ZAR 1,740.6 million. The 3-year maturity is a red herring, because retail exposures carry no maturity adjustment. The Basel 2.5 version of this vignette, with a stressed VaR term added, is workbook D4.2 under ORR-22 a.

Why the other options are wrong

A is incorrect. Market side: forgot the $\sqrt{10}$ scaling and reported the one-day figure 20.0; the credit figure is correct.

B is incorrect. Market side: used $m = 3$ despite 11 exceptions, so $\max(17.0, 15.0) = 17.0$ and $17.0 \times \sqrt{10} = 53.8$; the credit figure is correct.
D is incorrect. Credit side: reported the 99.9th percentile loss, 88.0, without subtracting EL; the market figure is correct.

LO: ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. ORR-21 c: Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Capital for Market Risks Associated with Trading Activities) and 21.2 (The IRB Approach; Retail Exposures Under IRB)

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis • Vardeez: UNTIERED

ORR-22 a

P1 CALC

Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge.

Workbook: A4 Fundamental Review of the Trading Book (FRTB) • Tier A • August 2026 recall C5 Basel III Post-Crisis Reforms and Stress-Test Regimes • Tier C D4 Stressed VaR and Market Risk Capital • Tier D

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: A4 (FRTB) is on your August 2026 recall ("FRTB - 2Q") and at #5 of the topic map (8 of 16 sources); its shape S5 sets FRTB against Basel I, II and 2.5, which is this LO. The stressed VaR charge itself is D4 (map #73, 3 of 16 sources), and the accord progression is C5 (map #30).

Vardeez: two of his nine ORR themes land here: theme 7 "Stressed market VaR (calculations)" and theme 9 "Basel 2.5 market risk calculation". The tier cell of the reading reads "0", but the map treats it as high priority. His notes label this LO "LO 61.a" (consolidated volume p.227) and work the Spartan State Bank example (Section 4).

Reported exam shapes

- **A4·S5** FRTB versus Basel I (1996 Amendment), Basel II and Basel 2.5: the overall changes.
- **C5·S4** The Basel I / 1996 / II / 2.5 / III progression, each change attached to the right accord.
- **D4·S1** Stressed VaR calculation: the SVaR term with its own maximum and multiplier.
- **D4·S2** Market risk capital charge: $\max(\text{VaR}_{t-1}, m \times \text{VaR}_{avg})$, $\sqrt{10}$ scaling, the multiplier from backtesting.
- **D4·S3** Mixed vignette: the stressed VaR charge plus IRB credit capital from a 99.9th percentile default rate, one error per option.

What the questions look like: a table of previous-day and 60-day average VaR and stressed VaR, sometimes at three confidence levels or as one-day figures, with the multipliers given or implied by a backtest. You take two separate maxima and add them. Concept questions ask which change belongs to which accord.

See also: workbook A4.4 also tags this LO; it is worked under ORR-21 c. The incremental risk charge is ORR-22 b and the comprehensive risk charge ORR-22 c; this block carries the background for both.

1. Basel 2.5 in one page

The 2007 to 2009 crisis showed that the market risk capital set by the 1996 Amendment was far too small for trading-book risks: asset prices fell sharply, many assets became illiquid, securitizations were doubted and hedges failed. Critics also blamed Basel II for letting IRB banks use their own PD, LGD and EAD estimates (Schweser, Vardeez). The Basel Committee answered with three changes to trading-book capital, implemented by the end of 2011 and known as **Basel 2.5**:

1. a **stressed VaR** (SVaR) term added to the VaR calculation (this LO);
2. an **incremental risk charge** (IRC), roughly capturing jump-to-default and rating-migration risk of credit positions in the trading book (ORR-22 b);
3. a **comprehensive risk** (CR) charge for securitizations and other correlation-sensitive instruments

(ORR-22 c).

Basel 2.5 is a trading-book reform. Capital definitions, buffers, the leverage ratio, the LCR and the NSFR are Basel III (ORR-22 d to f). Table 1 places every change on the accord that introduced it; this is shape C5·S4.

Accord	What it added (market risk items in italics)
Basel I (1988)	Credit risk only: risk weights, Tier 1 $\geq 4\%$ and total capital $\geq 8\%$ of RWA.
1996 Amendment	*Market risk capital: standardized approach or internal models; 10-day 99% VaR from at least one year of data, usually one-day VaR* $\times\sqrt{10}$*;* $\text{MR} = \max(\text{VaR}_{t-1}, m\,\text{VaR}_{avg})$*,* $m \geq 3$*; daily backtesting; Tier 3 capital.*
Basel II (2004)	IRB credit risk weights, operational risk capital, the three pillars, repeated QISs. *Market risk stayed on the 1996 basis.*
Basel 2.5 (end 2011)	*Stressed VaR, the IRC and the CR charge.*
Basel III (2010 to 2011, finalised 2017)	Tighter capital definition (CET1, AT1, Tier 2; Tier 3 eliminated), buffers, leverage ratio, LCR, NSFR, counterparty credit risk, large exposures, output floor.
FRTB (rules January 2019)	*One stressed expected shortfall at 97.5% with liquidity horizons replaces VaR plus stressed VaR; desk-level model approval; standardized approach always computed (MR-18).*

Table 1. The progression. The usual trap is the wrong accord: stressed VaR, the IRC and the CR charge are Basel 2.5, never Basel II or Basel III.

2. Why a stressed VaR

Most banks computed 1996-Amendment VaR by **historical simulation**: tomorrow's change in value is drawn from the daily changes of the recent past (the previous one to four years). Two consequences followed (Figure 1):

- **In calm periods VaR drifts down**, because nearly all historical observations show small changes. The years 2003 to 2006 were calm, so measured VaR and capital were low going into the crisis.
- **When volatility returns, VaR is slow to follow**, because most of the window still comes from the calm period. In 2007 VaR lagged the risk banks were actually running.

Definition. The bank identifies the **one-year (250-day) period, within the most recent seven years, that was most stressful for its current portfolio**, and computes a VaR by drawing daily observations from that period. Regulators first thought of using 2008 for everyone; the rule is bank-specific, so stressed periods differ across banks. Because it is the most stressful sub-period, the resulting one-day VaR is **large**, and it **changes little** over time (unless calm persists for seven years). Like the ordinary VaR it is a 10-day, 99% measure, usually scaled from one day by $\sqrt{10}$.

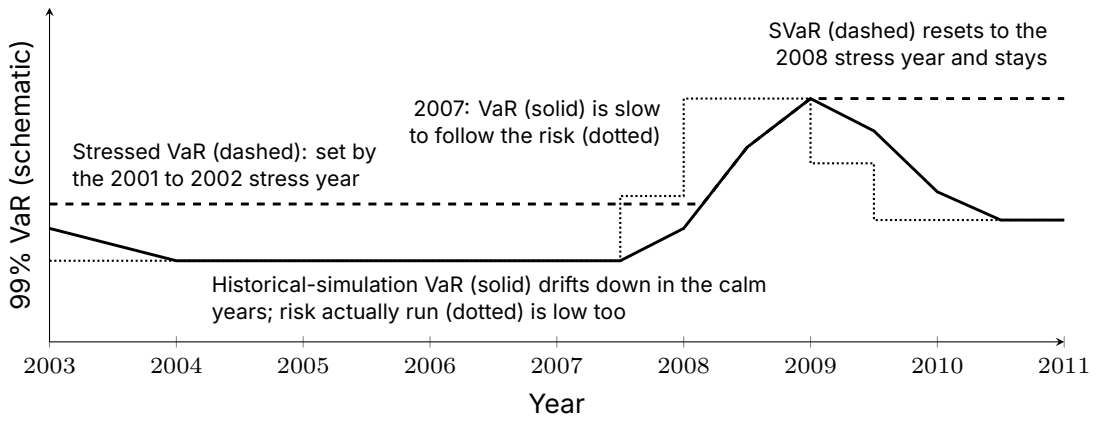


Figure 1. Schematic, not data. The dotted step line is the risk actually run, the solid line a VaR drawn from the previous year of history, the dashed line the stressed VaR (the worst one-year window of the last seven). The ordinary VaR lags in both directions; the stressed VaR is high and stable, which is why Basel 2.5 adds it.

3. The Basel 2.5 market risk capital charge

GARP's expanded formula keeps the 1996 term and adds a stressed term built the same way:

$$\boxed{\text{MR}_{2.5} = \max\big(\text{VaR}_{t-1},\ m_c\,\text{VaR}_{avg}\big) + \max\big(\text{SVaR}_{t-1},\ m_s\,\text{SVaR}_{avg}\big)}$$

- VaR_{t-1} and VaR_{avg}: the traditional 10-day 99% VaR for the **previous day** and the **average of the 60 most recent days**. SVaR_{t-1} and SVaR_{avg}: the same, drawing from the stressed period.
- **Multipliers** $m_c,\ m_s \geq 3$, as under the 1996 Amendment. They rise with poor backtesting: the bank compares the actual loss with one-day 99% VaR on each of the most recent 250 days; a loss above VaR is an **exception**. Four or fewer exceptions (the green zone) keep $m = 3$; five to nine (yellow) add a plus factor, giving 3.40 to 3.85; 10 or more require $m = 4$. GARP's text says "five or less" for $m = 3$; see the correction under ORR-21 c.
- **Each max is a separate decision.** With $m = 3$ the multiplied average usually binds, but after a sharp build-up of positions the previous day's figure can be larger (Spartan State Bank, Section 4).
- **At least twice the 1996 charge.** The recent period cannot be more stressed than the stressed period, so each SVaR is at least the matching VaR. The terms are summed, so with equal multipliers $\text{MR}_{2.5} \geq 2 \times \text{MR}_{1996}$. In practice the ratio is often far larger.
- **From capital to RWA:** multiply by 12.5, the inverse of 8%.

Correction to the source notes. Schweser's Module Quiz 63.1 (answer C) says Basel 2.5 market risk capital "should be close to double" the Basel II charge. GARP's statement is a floor: the charge "must be at least twice as large" as the 1996-Amendment charge when the multipliers are equal. In Spartan State Bank's case it is 4.5 times; in workbook D4.1 it is 4.2 times. The quiz is worked, with the wording fixed, as Question ORR-22 a.1.

4. Worked examples

Spartan State Bank (Vardeez and Schweser)

Previous-day VaR USD 15.6 million, 60-day average VaR 4.8; previous-day stressed VaR 17.7, average stressed VaR 18.4; two backtesting exceptions, so $m_c = m_s = 3$. All figures are 10-day 99%.

$$\text{VaR term} = \max(15.6,\ 3 \times 4.8 = 14.4) = 15.6 \qquad \text{MR}_{2.5} = 15.6 + 55.2 = 70.8$$
$$\text{SVaR term} = \max(17.7,\ 3 \times 18.4 = 55.2) = 55.2 \qquad \text{MR}_{1996} = 15.6 \ \text{(ratio } 4.5)$$

Vardeez and Schweser write the answer as "$15.6 + 18.4 \times 3$". That is right, but it hides the two decisions: the previous-day VaR beats three times its average (a position build-up), while the multiplied average beats the previous-day SVaR (Figure 2).

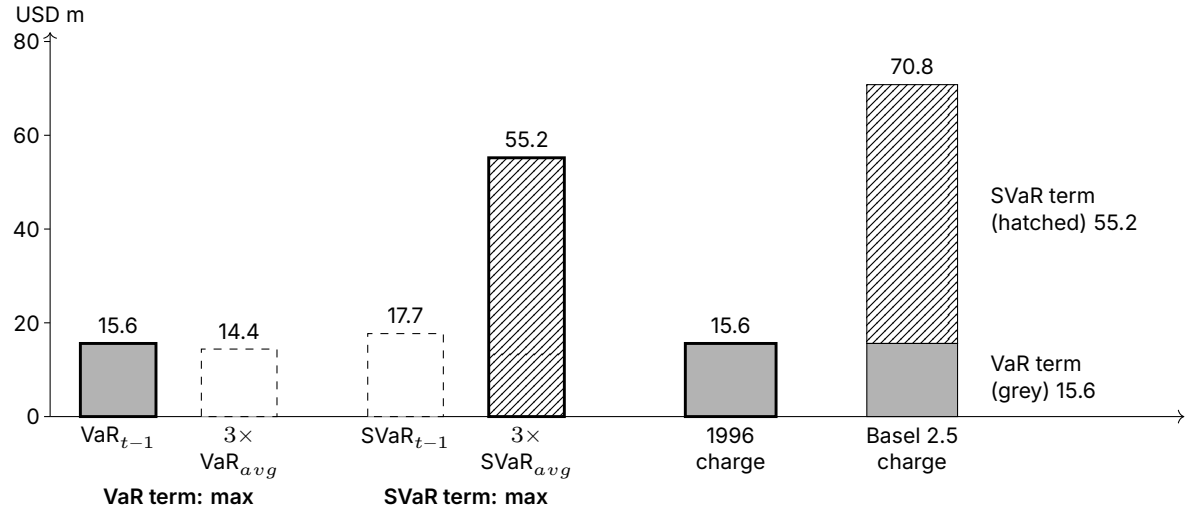


Figure 2. Spartan State Bank. Left: the four candidates; the selected value in each pair has a thick border (grey for the VaR term, hatched for the SVaR term), the rejected one is open with a dashed border. Right: the 1996 charge against the Basel 2.5 charge. The stressed term supplies 78% of the total.

One-day inputs and the backtesting multiplier

A bank reports one-day 99% figures (EUR million): $\text{VaR}_{t-1} = 3.1$, $\text{VaR}_{avg} = 2.8$, $\text{SVaR}_{t-1} = 6.0$, $\text{SVaR}_{avg} = 5.5$. Scale the sum of the two terms by $\sqrt{10} = 3.1623$.

Backtest over 250 days	VaR term	SVaR term	$\text{MR}_{2.5}$ (10-day)
3 exceptions: $m = 3$	$\max(3.1,\ 8.4) = 8.4$	$\max(6.0,\ 16.5) = 16.5$	$24.9 \times 3.1623 = 78.74$
11 exceptions: $m = 4$	$\max(3.1,\ 11.2) = 11.2$	$\max(6.0,\ 22.0) = 22.0$	$33.2 \times 3.1623 = 104.99$

A poor backtest costs EUR 26.25 million of capital (RWA $12.5 \times 26.25 = 328$ million). Forgetting $\sqrt{10}$ gives 24.9; dropping the SVaR term gives the 1996 charge, $8.4 \times 3.1623 = 26.56$.

5. Inputs that change the answer

- **Horizon.** One-day figures need $\sqrt{10}$; figures already stated as 10-day must not be scaled again. Taking the max on one-day figures and scaling afterwards gives the same answer, since scaling does not change which value is larger.
- **Confidence level.** Only the 99% figures enter. When a table gives 95%, 99% and 99.9% rows, the other rows are red herrings. If only 95% one-day figures are given and returns are normal, convert: $\text{VaR}_{99,\text{10-day}} = \text{VaR}_{95,\text{1-day}} \times \frac{2.326}{1.645} \times \sqrt{10}$ (Question ORR-22 a.7).

- **Two multipliers.** m_c applies to the VaR average only, m_s to the SVaR average only. They need not be equal.
- **Multiplier from a backtest.** Count the exceptions: four or fewer, $m = 3$; five to nine, 3.40 to 3.85; ten or more, $m = 4$. Never apply 4 to a clean backtest.
- **Mixed vignettes (D4·S3).** Trading-book and banking-book charges are computed on their own conventions and only then added. The IRB side (ORR-21 f) is one-year 99.9% *net of expected loss*: capital $=$ EAD $\times$ LGD $\times$ $(\text{DR}_{99.9} - \text{PD})$. The undeducted EAD $\times$ LGD $\times$ $\text{DR}_{99.9}$ is Hull's credit VaR, a planted intermediate.

6. From VaR plus stressed VaR to FRTB (shape A4·S5)

	1996 Amendment (kept by Basel II)	Basel 2.5	FRTB
Measure	VaR	VaR + stressed VaR	One stressed ES
Confidence	99%	99%	97.5%
Horizon	10 days	10 days	Liquidity horizons 10 to 120 days
Data	Previous 1 to 4 years ("current")	Current, plus worst 250 days of last 7 years	Stressed period (back to 2007)
Scaling	One-day $\times\sqrt{10}$	One-day $\times\sqrt{10}$	Overlapping 10-day changes, no $\sqrt{10}$
Capital	$\max(\text{VaR}_{t-1}, m\text{VaR}_{avg})$, $m \geq 3$	Two maxima summed, $m_c, m_s \geq 3$	60-day averages, $m_c \geq 1.5$; SA always computed
Credit in trading book	Specific risk charge	IRC and CR charge added	Default risk charge; securitizations on SA only

Table 2. The market risk measure across accords. FRTB details are MR-18 (Hull, RMFI Ch.18) and workbook A4; Basel II changed nothing in market risk.

Formula card: ORR-22 a

1996 Amendment	$\text{MR} = \max\left(\text{VaR}_{t-1},\ m\,\text{VaR}_{avg}\right)$, 10-day 99%, 60-day average, $m \geq 3$
Basel 2.5	$\text{MR}_{2.5} = \max\left(\text{VaR}_{t-1},\ m_c\text{VaR}_{avg}\right) + \max\left(\text{SVaR}_{t-1},\ m_s\text{SVaR}_{avg}\right)$, $m_c, m_s \geq 3$
Stressed period	the 250-day period in the most recent seven years most stressful for the current portfolio
Horizon and level	$\text{VaR}_{\text{10-day}} = \text{VaR}_{\text{1-day}}\sqrt{10}$; normal returns: $\text{VaR}_{99} = \text{VaR}_{95} \times 2.326/1.645$
Backtest multiplier	250 days of one-day 99% VaR: ≤ 5 exceptions $m = 3$; 6 to 9 supervisor's discretion; ≥ 10 $m = 4$
Floor	equal multipliers $\Rightarrow \text{MR}_{2.5} \geq 2 \times \text{MR}_{1996}$; RWA $= 12.5\times$ capital
Mixed vignette (ORR-21 f)	IRB capital $=$ EAD $\times$ LGD $\times$ $(\text{DR}_{99.9} - \text{PD})$

Exam traps

- **The max is a decision.** Always multiplying the average understates the charge after a spike in the previous day's VaR; always taking the previous day understates it otherwise.
- **Intermediate result.** The VaR term alone is the 1996 charge; Basel 2.5 adds the SVaR term.
- **Unit conversion.** One-day figures need $\sqrt{10}$; 10-day figures must not be scaled twice.
- **Wrong row.** Only the 99% figures count; 95% and 99.9% rows are decoys (99.9% is the IRB and IRC level).
- **Multiplier swap.** m_c on the VaR average, m_s on the SVaR average; not one multiplier on both, not a multiplier on the previous-day figures.
- **Wrong accord.** Stressed VaR, IRC and CR are Basel 2.5; LCR, NSFR and buffers are Basel III; FRTB replaces VaR and SVaR with stressed ES.
- **Fixed stress year.** The stressed period is bank-specific (worst year of the last seven for the current portfolio), not 2008 for everyone.
- **Credit side.** Subtract EL from the 99.9th percentile loss; the undeducted figure is a planted intermediate.

Practice questions: ORR-22 a

Question ORR-22 a.1

Bank Q632 • Schweser Module Quiz 63.1 Q1 (rebuilt)

Which of the following statements about the stressed value at risk (SVaR) required under Basel 2.5 is correct?

A. Basel 2.5 fixed 2008 as the stress period, so every bank draws its stressed VaR observations from the year 2008.

B. The stressed VaR replaces the ordinary VaR, and the resulting figure is used to calculate capital for credit risk.

C. With equal multipliers, Basel 2.5 market risk capital is at least double the 1996-Amendment charge, because the stressed term is added.

D. The stressed VaR must be calculated at a 99.9% confidence level over a one-year horizon, as for banking-book credit risk.

Question ORR-22 a.2

Bank Q620 • AnalystPrep Q.4285

After the global financial crisis it was recognized that minimum capital charges under the market risk amendment were insufficient for trading book risks. Which of the following was a significant change implemented by 2011 to address this, later known as Basel 2.5?

A. VaR computation was expanded to include a stressed VaR component.

B. A portion of operational risk capital was required on top of credit and market risk.

C. Credit risk weights were to be based on modern credit risk models and banks' internal measures.

D. Tier 1 capital was designated for going-concern loss absorption, while Tier 2 capital was to be used for recapitalizing an institution in resolution.

Question ORR-22 a.3 New • built from GARP Ch.21 and Ch.22, with MR-18 (Hull, RMFI Ch.18)

A risk consultant is drafting a one-page history of market risk capital, from the 1996 Amendment to the Fundamental Review of the Trading Book (FRTB), for the board risk committee of a Dutch bank. Which of the following statements is correct for the consultant to include?

A. Basel II replaced the 1996 internal-models VaR with a stressed VaR calibrated to the most stressful year of the previous seven, alongside its three pillars.

B. Basel 2.5 kept the 1996 VaR term and added a stressed VaR term with its own maximum and multiplier, so with equal multipliers the charge at least doubled.

C. FRTB keeps both the 10-day 99% VaR and the stressed VaR, scaled from one-day changes with the square-root-of-10 rule, and adds liquidity horizons.

D. Basel III added the incremental risk charge, a one-year 99.9% VaR that replaced the stressed VaR for all positions held in the trading book.

Question ORR-22 a.4 Bank Q631 • GARP Mock 2 Q17

Bank XYZ has calculated a market risk VaR for the previous day equal to USD 25 million. The average VaR over the last 60 days is USD 6 million. The stressed VaR for the previous day is USD 28 million and the average stressed VaR over the last 60 days is USD 31 million. What is the total market risk capital charge, assuming both multiplicative factors are 3?

A. USD 43 million

B. USD 75 million

C. USD 109 million

D. USD 118 million

Question ORR-22 a.5 Bank Q622 • AP Mock 2 Q60 (rebuilt; options in ascending order)

An American bank reports the following measures for its trading book (all 10-day, 99% confidence):

Previous-day VaR	USD 1,000
Average VaR over the recent 60 days	USD 480
Most stressful previous-day-equivalent VaR over the past seven years	USD 1,100
Most stressful 60-day average VaR over the past seven years	USD 500
Multiplier on the recent 60-day average VaR	3.9
Multiplier on the stressed 60-day average VaR	3.4

What is the market risk capital charge under Basel 2.5?

A. USD 2,700

B. USD 2,972

C. USD 3,572

D. USD 3,822

Question ORR-22 a.6

Bank Q633 • GARP Mock 3 Q11 (rebuilt; options in ascending order)

A bank uses the VaR and stressed VaR framework of Basel 2.5 for its trading book. Its internal models produced the following 10-day risk measures (USD million):

Confidence	Latest VaR	Latest SVaR	60-day avg. VaR	60-day avg. SVaR
95.0%	238	484	252	546
99.0%	451	995	413	1,106
99.9%	578	1,281	528	1,372

The supervisor has set the multiplication factors for both VaR and stressed VaR at 3. (SVaR denotes stressed VaR.) Using the confidence level required by Basel 2.5, what is the market risk capital requirement?

A. USD 1,446 million

B. USD 2,234 million

C. USD 3,769 million

D. USD 4,557 million

Question ORR-22 a.7

Bank Q630 • BT P2.T7.520.1 (option C restated)

A risk manager must compute the Basel 2.5 market risk capital requirement for a bank's trading book. The 95% one-day VaR on the previous day is USD 20,000; the average 95% one-day VaR over the last 60 trading days is USD 12,000; the 95% one-day stressed VaR on the previous day is USD 188,000; the average 95% one-day stressed VaR over the last 60 days is USD 50,000. Both multiplication factors are 3.0, and returns are assumed normal, so a one-day 95% VaR converts to a 10-day 99% VaR by multiplying by $2.326/1.645 \times \sqrt{10}$. Which is nearest to the market risk capital requirement?

A. USD 161,000

B. USD 188,000

C. USD 840,600

D. USD 1.0 million

Question ORR-22 a.8

Workbook D4.1 • S1, S2 • Map #73

A market risk analyst at a Canadian bank is calculating the bank's Basel 2.5 market risk capital charge for the trading book. The bank computes one-day 99% figures by historical simulation and scales them to 10 days with the square-root-of-time rule. A large position was added to the book two days ago. Data (CAD million, one-day 99%):

- VaR on the previous day: 6.5; average VaR over the last 60 trading days: 1.6
- Stressed VaR on the previous day: 7.4; average stressed VaR over the last 60 trading days: 6.9
- Backtesting exceptions over the last 250 trading days: 4

The supervisor applies, to both terms, the multiplier that this backtesting result permits under the 1996 Amendment. Which of the following is closest to the market risk capital charge?

A. CAD 20.6 million

B. CAD 27.2 million

C. CAD 80.6 million

D. CAD 86.0 million

Question ORR-22 a.9

Workbook D4.2 • S1, S2, S3 • Map #73

The CRO of a Singapore bank asks a senior risk analyst for two numbers for the risk committee pack: the Basel 2.5 market risk capital charge for the trading book and the Basel II IRB credit risk capital for a large, homogeneous corporate loan portfolio in the banking book. Data (SGD million):

- Trading book, 10-day 99%: VaR on the previous day 12; 60-day average VaR 10; stressed VaR on the previous day 26; 60-day average stressed VaR 24; multipliers $m_c = m_s = 3$
- Loan portfolio: EAD 400; LGD 45%; PD 2%; one-year default rate at the 99.9th percentile 12%

Which of the following pairs is closest to the market risk capital charge and the credit risk capital?

A. Market risk SGD 38.0 million; credit risk SGD 18.0 million

B. Market risk SGD 30.0 million; credit risk SGD 18.0 million

C. Market risk SGD 102.0 million; credit risk SGD 21.6 million

D. Market risk SGD 102.0 million; credit risk SGD 18.0 million

Solutions • ORR-22 a

Solution ORR-22 a.1 — Answer: C

Bank Q632 • Schweser Module Quiz 63.1 Q1

Step 1 – What the stressed VaR is

A 10-day 99% VaR drawn from the 250-day period, within the most recent seven years, that was most stressful for the bank's current portfolio.

$\Rightarrow$ It is bank-specific, market risk, 99%: A and D fail on the definition.

Step 2 – How it enters capital

It is *added* as a second term: $\text{MR}_{2.5} = \max(\text{VaR}_{t-1}, m_c\text{VaR}_{avg}) + \max(\text{SVaR}_{t-1}, m_s\text{SVaR}_{avg})$.

$\Rightarrow$ Each SVaR is at least the matching VaR, so with equal multipliers the charge is at least twice the 1996 charge.

Interpretation

The 1996 rules are the market risk rules Basel II retained, so "the Basel II charge" and "the 1996 charge" are the same thing. Schweser's original option read "should be close to double"; GARP's statement is a floor ("at least twice"), and the ratio is often much larger (4.5 for Spartan State Bank), so the option has been reworded. The key is unchanged.

Why the other options are wrong

A is incorrect. 2008 was only an early idea; the rule makes each bank find its own worst year in the last seven.

B is incorrect. Two errors: SVaR is added to the ordinary VaR, not substituted for it, and it is a market risk charge, not credit risk capital.

D is incorrect. Both VaRs are 10-day 99%. The one-year 99.9% calibration belongs to IRB credit capital and to the IRC (ORR-22 b).

LO: ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Stressed VaR; SchweserNotes 2026 Book 3, Reading 63, LO 63.a

Solution ORR-22 a.2 — Answer: A

Bank Q620 • AnalystPrep Q.4285

Step 1 – The three Basel 2.5 changes

Stressed VaR added to the VaR calculation; the incremental risk charge; comprehensive risk capital for securitizations and related instruments. All implemented by the end of 2011.

Step 2 – Attach each option to its accord

Operational risk capital and IRB credit risk weights are Basel II (2004). The going-concern/gone-concern split of Tier 1 and Tier 2 is the Basel III definition of capital.

$\Rightarrow$ Only A is a Basel 2.5 change.

Interpretation

This is shape C5·S4: the options are all real reforms, each from a different accord. Basel 2.5 touched the trading book only.

Why the other options are wrong

B is incorrect. Operational risk capital was one of the four Basel II innovations.

C is incorrect. Risk weights from banks' internal measures (IRB) were the first Basel II innovation.

D is incorrect. The tightened capital definition (Core Tier 1, Additional Tier 1, Tier 2 absorbing

losses after failure) is Basel III (ORR-22 d).

LO: ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Basel II) and Ch.22, 22.2 and 22.3

Solution ORR-22 a.3 — Answer: B

New • built from GARP Ch.21 and Ch.22, with MR-18

Step 1 – What Basel II did to market risk

Nothing: its innovations were IRB credit risk weights, operational risk capital, the three pillars and the QISs; market risk capital stayed on the 1996 basis.
⇒ A is the wrong-accord trap.

Step 2 – What Basel 2.5 did

It kept $\max(\text{VaR}_{t-1}, m_c\text{VaR}_{avg})$ and added $\max(\text{SVaR}_{t-1}, m_s\text{SVaR}_{avg})$, each with its own max and multiplier; with equal multipliers the charge is at least twice the 1996 charge.
⇒ B is correct.

Step 3 – What FRTB did

It replaced VaR plus stressed VaR with a single stressed expected shortfall at 97.5%, computed from overlapping 10-day changes with liquidity horizons of 10 to 120 days; the $\sqrt{10}$ scaling of one-day changes is the Basel I and Basel 2.5 practice it abandons.

Interpretation

Shape A4·S5 in one question: each accord changed one thing about the market risk measure. 1996: VaR enters capital. Basel II: no change. Basel 2.5: stressed VaR added (plus IRC and CR). FRTB: VaR and SVaR replaced by stressed ES.

Why the other options are wrong

A is incorrect. Wrong accord: stressed VaR is Basel 2.5 (end 2011); Basel II left the 1996 market risk rules in place.
C is incorrect. FRTB does not keep VaR or SVaR, and it uses overlapping 10-day changes rather than $\sqrt{10}$ scaling.
D is incorrect. Wrong accord and wrong scope: the IRC is Basel 2.5, applies to credit-sensitive trading-book positions, and is added to, not substituted for, the stressed VaR.

LO: ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. MR-18 a: Describe the changes to the Basel framework for calculating market risk capital under the Fundamental Review of the Trading Book (FRTB) and the motivations for these changes. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 and 21.2; Ch.22, 22.2; Hull, RMFI 6e, Ch.18, 18.1 and 18.3

Solution ORR-22 a.4 — Answer: D

Bank Q631 • GARP Mock 2 Q17

Step 1 – VaR term

$$\max(\text{VaR}_{t-1},\ 3\,\text{VaR}_{avg}) = \max(25,\ 3\times 6 = 18) = 25$$

⇒ The previous day's VaR binds: the book grew sharply yesterday.

Step 2 – Stressed VaR term

$$\max(\text{SVaR}_{t-1},\ 3\,\text{SVaR}_{avg}) = \max(28,\ 3\times 31 = 93) = 93$$

Step 3 – Total

$$\text{MR}_{2.5} = 25 + 93 = \text{USD } 118 \text{ million}$$

Interpretation

The two maxima resolve in opposite directions, which is the point of the question. The 1996-style charge would be 25; the stressed term more than quadruples it.

Why the other options are wrong

A is incorrect. Dropped the stressed term and added the two VaR candidates instead of taking their max: $25 + 18 = 43$.

B is incorrect. Multiplied the previous-day VaR by 3 and ignored the stressed term: $3 \times 25 = 75$.

C is incorrect. Multiplied the previous-day SVaR instead of its 60-day average: $25 + 3 \times 28 = 109$.

LO: ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Stressed VaR

Solution ORR-22 a.5

Answer: C

Bank Q622 • AP Mock 2 Q60

Step 1 – VaR term with $m_c = 3.9$

$$\max(1{,}000,\ 3.9 \times 480 = 1{,}872) = 1{,}872$$

Step 2 – Stressed VaR term with $m_s = 3.4$

$$\max(1{,}100,\ 3.4 \times 500 = 1{,}700) = 1{,}700$$

$\Rightarrow$ Each multiplier goes with its own average.

Step 3 – Total

$$\text{MR}_{2.5} = 1{,}872 + 1{,}700 = \text{USD } 3{,}572$$

Interpretation

A multiplier of 3.9 on the ordinary VaR signals a weak backtest; the stressed multiplier is set separately. Both multiplied averages exceed the previous-day figures here, so both bind.

Why the other options are wrong

A is incorrect. Used the previous-day VaR instead of the larger multiplied average: $1{,}000 + 1{,}700 = 2{,}700$.

B is incorrect. Did not multiply the stressed average, taking the previous-day SVaR: $1{,}872 + 1{,}100 = 2{,}972$.

D is incorrect. Applied $m_c = 3.9$ to both averages: $3.9 \times (480 + 500) = 3{,}822$.

LO: ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Stressed VaR

Solution ORR-22 a.6

Answer: D

Bank Q633 • GARP Mock 3 Q11

Step 1 – Pick the regulatory row

Basel 2.5 uses 10-day 99% VaR and SVaR: latest VaR 451, average VaR 413, latest SVaR 995, average SVaR 1,106.

Step 2 – The two maxima

$$\max(451,\ 3 \times 413 = 1{,}239) = 1{,}239 \qquad \max(995,\ 3 \times 1{,}106 = 3{,}318) = 3{,}318$$

Step 3 – Total

$$\text{MR}_{2.5} = 1{,}239 + 3{,}318 = \text{USD } 4{,}557 \text{ million}$$

Interpretation

The 95% and 99.9% rows are red herrings. Used in full they would give 2,394 and 5,700, which is why GARP leaves them out of the options and tests the multiplier slips instead.

Why the other options are wrong

A is incorrect. Latest values only, no multiplied averages: $451 + 995 = 1{,}446$.
B is incorrect. Multiplier on the VaR average only: $1{,}239 + 995 = 2{,}234$.
C is incorrect. Multiplier on the stressed average only: $451 + 3{,}318 = 3{,}769$.

LO: ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Stressed VaR

Solution ORR-22 a.7 **Answer: D**

Bank Q630 • BT P2.T7.520.1

Step 1 – Conversion factor

$$k = \frac{2.326}{1.645} \times \sqrt{10} = 1.41398 \times 3.16228 = 4.4714$$

$\Rightarrow$ It turns a one-day 95% VaR into a 10-day 99% VaR under normality.

Step 2 – The two maxima (one-day 95%)

$$\text{VaR term} = \max(20{,}000,\ 3 \times 12{,}000 = 36{,}000) = 36{,}000$$
$$\text{SVaR term} = \max(188{,}000,\ 3 \times 50{,}000 = 150{,}000) = 188{,}000$$

$\Rightarrow$ The VaR term takes the multiplied average; the SVaR term takes the previous day.

Step 3 – Scale and add

$$\text{MR}_{2.5} = (36{,}000 + 188{,}000) \times 4.4714 = 160{,}971 + 840{,}624 = 1{,}001{,}594 \approx \text{USD } 1.0 \text{ million}$$

Interpretation

Taking the max before or after scaling gives the same result, since k multiplies both candidates. The stressed term is 84% of the charge. (The bank's option C read USD 840,800; with the stated factor the scaled stressed term is USD 840,600, so the option was restated. The key is unchanged.)

Why the other options are wrong

A is incorrect. Reported only the scaled VaR term: $36{,}000 \times 4.4714 = 160{,}971$.
B is incorrect. Reported the unscaled previous-day stressed VaR, with no VaR term and no conversion: 188,000.
C is incorrect. Reported only the scaled stressed term: $188{,}000 \times 4.4714 = 840{,}624$.

LO: ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Stressed VaR; Ch.21, 21.1 (10-day 99% VaR, $\sqrt{10}$ scaling)

Solution ORR-22 a.8

Answer: D

Workbook D4.1 • S1, S2

Step 1 – Multiplier

Four exceptions is in the green zone (four or fewer), so $m_c = m_s = 3$.
$\Rightarrow$ The backtest is clean; a multiplier of 4 is required only at 10 or more exceptions.

Step 2 – VaR term (one-day)

$$\max(\text{VaR}_{t-1},\ m_c\text{VaR}_{avg}) = \max(6.5,\ 3 \times 1.6) = \max(6.5,\ 4.8) = 6.5$$

$\Rightarrow$ After the position build-up, yesterday's VaR exceeds three times the 60-day average, so the previous-day term binds.

Step 3 – Stressed VaR term (one-day)

$$\max(\text{SVaR}_{t-1},\ m_s\text{SVaR}_{avg}) = \max(7.4,\ 3 \times 6.9) = \max(7.4,\ 20.7) = 20.7$$

$\Rightarrow$ Stressed VaR is stable, so the multiplied average binds as usual.

Step 4 – Scale to 10 days and add

$$\text{MR}_{2.5} = (6.5 + 20.7) \times \sqrt{10} = 27.2 \times 3.1623 = 86.01$$

Interpretation

The charge is CAD 86.0 million, an RWA equivalent of $12.5 \times 86.01 =$ CAD 1,075 million. The 1996 charge would have been only $6.5 \times \sqrt{10} = 20.55$; the SVaR term makes the Basel 2.5 charge about 4.2 times larger, well above the "at least twice" minimum.

Why the other options are wrong

A is incorrect. Omitted the stressed VaR term (the 1996 charge, an intermediate result): $6.5 \times \sqrt{10} = 20.55$.
B is incorrect. Forgot the $\sqrt{10}$ scaling to a 10-day horizon: $6.5 + 20.7 = 27.2$.
C is incorrect. Skipped the max decision on the VaR term and always used $m \times \text{VaR}_{avg}$: $(4.8 + 20.7) \times \sqrt{10} = 80.64$.

LO: ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. ORR-21 c: Describe measures introduced in the 1995 and 1996 amendments, including guidelines for netting of credit exposures and methods for calculating market risk capital for assets in the trading book. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 (Stressed VaR); Ch.21, 21.1 (Capital for Market Risks Associated with Trading Activities)

Solution ORR-22 a.9

Answer: D

Workbook D4.2 • S1, S2, S3

Step 1 – Market risk: VaR term (already 10-day)

$$\max(\text{VaR}_{t-1},\ m_c\text{VaR}_{avg}) = \max(12,\ 3 \times 10) = 30$$

Step 2 – Market risk: stressed VaR term

$$\max(\text{SVaR}_{t-1},\ m_s\text{SVaR}_{avg}) = \max(26,\ 3 \times 24) = 72$$

Step 3 – Market risk capital charge

$$\text{MR}_{2.5} = 30 + 72 = 102.0$$

$\Rightarrow$ The figures are already 10-day, so no $\sqrt{10}$ is applied. The stressed term supplies about 70% of the charge.

Step 4 – Credit: loss at the 99.9th percentile default rate

$$\text{EAD} \times \text{LGD} \times \text{DR}_{99.9} = 400 \times 0.45 \times 0.12 = 21.6$$

$\Rightarrow$ SGD 21.6 million is the one-year 99.9% loss, which is Hull's credit VaR; it is not yet IRB capital.

Step 5 – Credit: subtract expected loss

$$\text{EL} = 400 \times 0.45 \times 0.02 = 3.6, \qquad \text{Capital} = 21.6 - 3.6 = 18.0$$

$\Rightarrow$ IRB capital covers unexpected loss only, because loan loss reserves are taken to cover EL.

Interpretation

Market risk SGD 102.0 million and credit risk SGD 18.0 million: SGD 120.0 million in total, an RWA equivalent of SGD 1,500 million. Each wrong option contains exactly one error, so the pair can be checked line by line.

Why the other options are wrong

A is incorrect. Market side: used the previous-day values without the multiplied averages, $12 + 26 = 38$; the credit figure is correct.

B is incorrect. Market side: omitted the stressed VaR term, leaving the 1996-style charge $\max(12, 30) = 30$ (intermediate result); the credit figure is correct.

C is incorrect. Credit side: did not subtract EL, reporting the 99.9th percentile loss (credit VaR) of 21.6 as capital; the market figure is correct.

LO: ORR-22 a: Describe and calculate the stressed VaR introduced in Basel 2.5 and calculate the market risk capital charge. ORR-21 f: Calculate credit risk capital under Basel II utilizing the IRB approach. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2; Ch.21, 21.2 (The IRB Approach); Hull, Credit VaR (CR-10)

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis • Vardeez: UNTIERED

ORR-22 f

P1 CALC

Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio.

Workbook: A32 Net Stable Funding Ratio, LCR and Leverage Ratio • Tier A • August 2026 recall

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: your August 2026 recall reports an "NSFR numerical with factors given". The topic is not in the map's ranked list; the recall alone puts it in Tier A.
Vardeez: Basel III liquidity and leverage ratios, his "LO 61.f" (consolidated volume p.229). He gives the three formulas and works Schweser's Bank of the Bluegrass balance sheet for both the LCR (150%) and the NSFR (107.66%); both are checked in Section 5.

Reported exam shapes

- **A32·S1** NSFR from a balance sheet with ASF and RSF factors given: the plain form.
- **A32·S2** NSFR shortfall: new funding needed to reach 100%, with both the funding leg and the deployment leg.
- **A32·S3** NSFR versus LCR with both parameter sets in one table: pick the right factors.

What the questions look like: a balance sheet with the factors in the stem; you weight each line and divide. Expect the other ratio's parameters in the same table, an inverted-ratio distractor, and a stable-funding line (equity, long bonds) that is easy to drop. Leverage-ratio and LCR questions are shorter: capital over unweighted exposure, HQLA over net 30-day outflows.

See also: the capital definitions behind the leverage ratio are ORR-22 d; the G-SIB leverage buffer is ORR-22 e and ORR-23 b. Liquidity stress testing (TSECF, TSAA) is the LTR readings (workbook A26).

1. Why Basel III adds a leverage ratio and two liquidity ratios

Leverage. Before Basel III every minimum was a percentage of RWA. During and after the crisis many observers felt RWA had understated risk and left banks over-leveraged, and market participants judged banks on simple ratios of equity to *unweighted* assets. Basel III added a "simple" leverage ratio as a **supplement** (a backstop), not a replacement.

Liquidity. Solvent institutions can fail because depositors and counterparties withdraw faster than assets can be sold. Northern Rock financed its mortgage pipeline through securitization; when that market closed it could not find enough wholesale funding. News on Thursday 13 September 2007 that the Bank of England would provide liquidity support set off a retail run, wholesale funding fell further, and by the following Monday the government guaranteed all UK deposits. The lesson: central bank funding can make a funding stress worse and can destabilize a whole system, so banks must survive stress **with their own resources**. The new ratios therefore constrain the balance sheet: a smaller share of illiquid assets, a larger share of stable (hard to withdraw) liabilities.

2. The leverage ratio

$$\text{Leverage ratio} = \frac{\text{Tier 1 capital}}{\text{leverage exposure}} \geq 3\%$$

- **Exposure** is *not* risk-weighted: all on-balance-sheet assets in full, plus fractions of off-balance-sheet items (derivatives and their potential future exposure, loan commitments). The Committee specifies the measure in detail so that it is comparable across IFRS and GAAP.
- **G-SIBs** hold a leverage ratio buffer of one-half of their risk-based G-SIB buffer, met with Tier 1 capital (a 2% G-SIB surcharge gives $3\% + 1\% = 4\%$). The US had earlier imposed 2 and 3 point buffers (5% for G-SIB holding companies, 6% for their banks).

Example. Tier 1 capital EUR 14 billion (CET1 11, AT1 3); on-balance-sheet assets 380; off-balance-sheet exposure measure 20. Leverage ratio $= 14/(380 + 20) = 3.50\%$: compliant. On CET1 alone it would be $11/400 = 2.75\%$, a breach, so the numerator matters (correction box).

> **Correction to the source notes.** GARP Ch.22 defines the requirement as a ratio of "Core Tier 1 Capital to Leverage Exposure of 3 percent", and workbook sections A32 and D25 repeat it. The Basel III leverage ratio uses **Tier 1 capital** (CET1 plus Additional Tier 1): GARP's own Ch.23 calls it the "Tier 1 leverage ratio requirement (defined as a 3% leverage ratio minimum requirement and the G-SIB leverage ratio buffer)" and says the G-SIB buffer "must be met with Tier 1 capital". Use Tier 1 unless the stem says otherwise; the bank questions in this block state the measure explicitly.

3. The liquidity coverage ratio (30 days)

$$\text{LCR} = \frac{\text{high-quality liquid assets (HQLA)}}{\text{net cash outflows over a 30-day stress period}} \geq 100\%$$

The LCR gives the bank and the authorities **a month** to manage a crisis by selling liquid assets while the bank tries to restore confidence. Schweser lists the stresses in mind: a three-notch downgrade, a partial loss of deposits, a complete loss of wholesale funding, larger haircuts on secured funding, and drawdowns on credit lines.

- **HQLA.** "Liquid" means a high likelihood of a quick sale with little price reduction. Assets are placed in categories and haircut. No haircut: deposits at central banks, central-government securities with a 0% risk weight. 50% haircut: corporate debt and equity. Excluded: individual mortgage loans (and loans and fixed assets generally). Level 2 assets such as BBB corporate bonds may not exceed 40% of HQLA after haircuts.
- **Net cash outflows.** Stress run-off rates on liabilities and draw-down rates on commitments, less inflows. GARP's examples: 3% of insured retail deposits; 100% of most non-operational wholesale deposits (only the part that matures within the 30 days); 30% of undrawn credit lines to nonfinancial wholesale customers. Capital and long-dated bonds run off at 0%.
- "The definition of the LCR is simple but the implementation is complicated": exam questions give the haircuts and run-off rates.

4. The net stable funding ratio (one year)

$$\text{NSFR} = \frac{\text{available stable funding (ASF)}}{\text{required stable funding (RSF)}} = \frac{\sum_{\text{liabilities, equity}} \text{amount} \times \text{ASF factor}}{\sum_{\text{assets}} \text{amount} \times \text{RSF factor}} \geq 100\%$$

The NSFR is "conceptually slightly different": it looks not at what can be sold within a month but at **what funding would remain after a stressful year**. ASF factors weight the funding side and are "similar to haircuts": the more stable the source, the higher the factor. RSF factors weight the asset side: the more illiquid the asset, the higher the factor, since it cannot be sold easily when funding runs off. The NSFR categories differ from the LCR's. Two factor sets appear in exam questions:

Funding (ASF)	Factor	Asset (RSF)	Factor
GARP's example			
Stable retail deposits (≤ 9 months)	95%	Vault cash	0%
3-month wholesale CDs	0%	Debt of own sovereign	5%
10-year senior bonds (none maturing in a year)	100%	BBB corporate debt in the trading account	50%
Common equity	100%	Business loans > 1 year, risk weight $\geq 50\%$	85%
Schweser's figures (used by Vardeez and bank Q684)			
Tier 1 and Tier 2 capital, preferred stock, debt > 1 year	100%	Cash, short-term instruments (central bank reserves)	0%
Stable deposits < 1 year	95%	Marketable sovereign securities > 1 year, 0% RW	5%
Less stable deposits < 1 year	90%	Corporate bonds AA− or better / A+ to A−	15% / 50%
Wholesale funding < 1 year	50%	Residential mortgages	65%
All other liabilities and equity	0%	Loans to small business or retail < 1 year / all other	85% / 100%

Table 1. The two sets differ (short wholesale funding is 0% in GARP's example and 50% in Schweser's). Use the factors the question gives.

5. Worked example: GARP's bank, both ratios

Liabilities: USD 500 of stable retail deposits (≤ 9 months), 200 of 3-month wholesale CDs (one-third maturing each month), 200 of 10-year senior bonds, 100 of common equity. Assets: 100 vault cash, 100 own-sovereign debt, 100 BBB corporate debt (trading account), 700 business loans over one year.

$$\begin{aligned} \text{ASF} &= 500(0.95) + 200(0) + 200(1) + 100(1) = 475 + 0 + 200 + 100 = 775 \\ \text{RSF} &= 100(0) + 100(0.05) + 100(0.50) + 700(0.85) = 0 + 5 + 50 + 595 = 650 \\ \text{NSFR} &= 775/650 = 1.19 \end{aligned}$$

For the LCR, HQLA factors are 100%, 100%, 50% and 0%, and the run-off rates 5% (stable retail), 100% on the third of the CDs maturing within the month, 0% on bonds and equity:

$$\begin{aligned} \text{HQLA} &= 100 + 100 + 0.5(100) = 250 \\ \text{Outflows} &= 0.05(500) + \tfrac{1}{3}(200) = 25 + 66.67 = 91.67 \\ \text{LCR} &= 250/91.67 = 2.73 \end{aligned}$$

The corporate debt contributes 50 of the 250, or 20%, inside the 40% Level 2 cap. The bank meets both ratios (Figure 1).

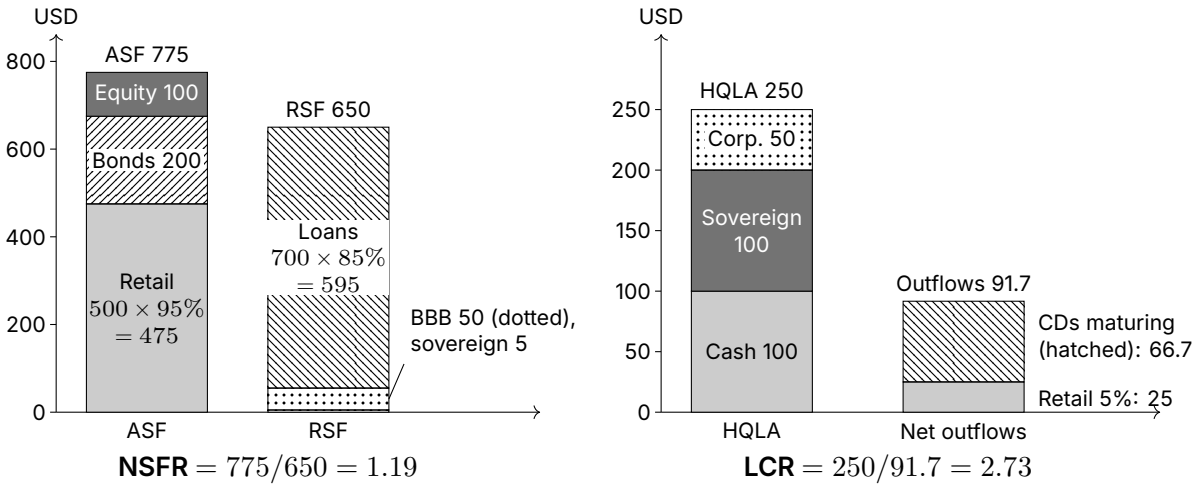


Figure 1. GARP's example as two ratio diagrams (the panels have different scales). Left: the NSFR weights the funding side (ASF: grey, hatched and dark blocks for retail, bonds and equity; the CDs add nothing) against the asset side (RSF, mostly the hatched loans). Right: the LCR sets the stock of HQLA after haircuts (the dotted block is the corporate debt, $100 \times 50\%$) against 30-day stressed outflows. The same balance sheet gives 1.19 and 2.73: the two ratios answer different questions.

Correction to the source notes. GARP rounds the outflows to 92 and prints LCR $= 250/92 = 2.72$. The maturing third of the CDs is $200/3 = 66.67$, so outflows are 91.67 and the LCR is $250/91.67 = 2.73$. The conclusion (compliant) is unchanged.

Vardeez's example (Schweser's Bank of the Bluegrass), checked. HQLA $= 10 + 10 + 10 = 30$ (cash, central bank reserves, Treasuries $>$ 1 year; loans and fixed assets 0%); outflows $= 100(5\%) + 75(20\% \times 100\%) = 5 + 15 = 20$; LCR $= 150\%$. ASF $= 100(0.90) + 75(0.50) + 2 + 18 = 147.50$; RSF $= 10(0.05) + 30(0.65) + 30(0.85) + 90(0.85) + 15(1.00) = 137.00$ (cash and reserves at 0%); NSFR $= 107.66\%$. Both figures are correct.

6. Closing an NSFR shortfall (shape S2)

Every remedy has **two legs**: the new funding adds a of ASF per unit, and wherever the money is deployed adds r of RSF per unit. For new funding x:

$$\text{ASF} + a\,x = \text{RSF} + r\,x \quad \Longrightarrow \quad \boxed{x = \frac{\text{RSF} - \text{ASF}}{a - r}}$$

A bank with ASF 620 and RSF 700 (NSFR 88.6%) is 80 short:

Remedy	a	r	Amount needed
Issue 10-year bonds, hold the proceeds as cash	100%	0%	$80/1.00 = 80.0$
Raise stable retail deposits, buy own-sovereign debt	95%	5%	$80/0.90 = 88.9$
Replace 3-month CDs with 10-year bonds (no new assets)	+100%		$80/1.00 = 80.0$
Run down business loans into cash (asset side only)		−85%	$80/0.85 = 94.1$

Dividing the gap by the ASF factor alone, or reporting the raw gap of 80 for the deposit route, ignores one leg.

7. The three ratios side by side

	Leverage ratio	LCR	NSFR
Question	Is capital enough against unweighted exposure?	Can the bank survive a 30-day run by selling liquid assets?	Is the balance sheet funded stably for a year?
Numerator	Tier 1 capital	HQLA after haircuts (assets)	ASF (liabilities and equity)
Denominator	On-balance-sheet assets plus some off-balance-sheet items	Net cash outflows in 30 days	RSF (assets)
Minimum	3% (plus G-SIB buffer)	100%	100%
Capital counts?	Numerator	No (a funding source, not an asset)	Yes, ASF 100%
Cash counts?	In exposure	HQLA factor 100%	RSF factor 0%

What moves the ratios. Selling 0%-risk-weight government bonds to make corporate loans lowers HQLA (the LCR falls) and raises RSF (the NSFR falls). Replacing retail deposits with short wholesale deposits lowers ASF and raises run-off, so both ratios fall. Replacing short funding with long-term debt or equity raises the NSFR. Adding unweighted assets of any kind lowers the leverage ratio, however safe they are.

Formula card: ORR-22 f

Leverage ratio	$\dfrac{\text{Tier 1 capital}}{\text{on-B/S assets} + \text{off-B/S exposure}} \geq 3\%$; G-SIB leverage buffer $= \frac{1}{2}\times$ G-SIB risk-based buffer
LCR (30 days)	$\dfrac{\sum \text{asset} \times \text{HQLA factor}}{\sum \text{liability} \times \text{run-off} - \text{inflows}} \geq 100\%$; HQLA factor $= 1 -$ haircut
HQLA haircuts	0% central bank deposits, 0%-RW sovereigns; 50% corporate debt and equity; mortgages excluded; Level 2 $\leq 40\%$ of HQLA
NSFR (one year)	$\dfrac{\sum \text{funding} \times \text{ASF factor}}{\sum \text{asset} \times \text{RSF factor}} \geq 100\%$
Shortfall remedy	$x = (\text{RSF} - \text{ASF})/(a - r)$, a the ASF factor of the new funding, r the RSF factor of its use

Exam traps

- **Inversion.** NSFR is ASF/RSF and LCR is HQLA/outflows; the inverted ratio is always an option.
- **Sibling swap of factors.** HQLA factors are not RSF factors (cash: HQLA 100%, RSF 0%); LCR run-off rates are not ASF factors; "one-third of CDs maturing this month" matters only for the LCR.
- **Dropped funding line.** Equity and long bonds carry ASF 100%; leaving them out, or using total funding or total assets as a denominator, is a planted error.
- **Wrong deposit class.** Stable (95%) versus less stable (90%) retail deposits when both rows are in the factor table.
- **Gross outflows.** The LCR denominator is *net* of inflows; corporate debt counts at 50%, not in full and not at zero.
- **One-leg remedies.** New funding adds ASF *and* its deployment adds RSF.

- **Leverage numerator and denominator.** Tier 1, not total capital; exposure includes off-balance-sheet items and is not risk-weighted.
- **Horizons.** LCR 30 days, NSFR one year; the leverage ratio is a capital ratio, not a liquidity ratio, though it sits in this LO.

Practice questions: ORR-22 f

Question ORR-22 f.1

Bank Q682 • BT P2.T7.522.2 (rebuilt)

Regarding the leverage ratio, liquidity coverage ratio (LCR) and net stable funding ratio (NSFR), each of the following is true EXCEPT which is not accurate?

A. The LCR is the ratio of high-quality liquid assets to net cash outflows over a stressed 30-day period.

B. The NSFR is the ratio of weighted stable funding sources (liabilities and equity) to weighted assets requiring stable funding.

C. The NSFR will increase if retail deposits are replaced by wholesale deposits and marketable securities are replaced by residential mortgages.

D. The Basel III leverage ratio is capital divided by total exposure, which includes unweighted balance sheet items and some off-balance-sheet items, with a 3% minimum.

Question ORR-22 f.2

Bank Q686 • GARP Mock 4 Q74 (rebuilt)

A bank sells a large portion of its holdings of zero-risk-weight government bonds and uses all the proceeds to extend new corporate loans, with no change in its funding. Which of the following statements about the effect on its liquidity ratios is most accurate?

A. The LCR will increase because loans earn a higher return than government bonds.

B. The LCR will decrease because government bonds count as HQLA without a haircut, whereas corporate loans do not count as HQLA.

C. The NSFR will improve because loans are short-term assets that need little stable funding.

D. Neither ratio is affected because total assets are unchanged.

Question ORR-22 f.3 Bank Q688 • AnalystPrep Q.3245 (rebuilt, key corrected in the bank)

Bank ABC is subject to Basel III. Balance sheet information (USD million):

Tier 1 capital	250
Tier 2 capital	150
Total on-balance-sheet assets (all items, not risk-weighted)	2,000
Off-balance-sheet loan commitments	300

Assume the loan commitments enter the leverage exposure measure at full face value (100% conversion factor) and Tier 1 capital is the capital measure. What is the bank's Basel III leverage ratio?

A. 10.87%

B. 12.50%

C. 17.39%

D. 20.00%

Question ORR-22 f.4 Bank Q685 • GARP Mock 1 Q50 (rebuilt, key corrected in the bank)

A bank is calculating its liquidity coverage ratio (LCR) using Basel III conventions as presented in the reading. Data (USD million):

Treasury securities (zero risk weight)	90
Corporate debt (50% haircut for HQLA)	40
Stable retail deposits	500
Unsecured wholesale funding from non-financial corporates	300
Expected cash inflows over 30 days	60

Assume a 5% run-off rate on stable retail deposits and a 40% run-off rate on the wholesale funding. What is the bank's LCR?

A. 75.9%

B. 105.9%

C. 129.4%

D. 152.9%

Question ORR-22 f.5 Workbook A32.1 • S1 • Aug-2026

A treasury analyst at a Canadian regional bank is computing the bank's Basel III net stable funding ratio for the ALCO pack. Balance sheet (CAD million) and the applicable factors are:

Funding	Amount	ASF	Asset	Amount	RSF
Stable retail deposits	620	95%	Vault cash	90	0%
3-month wholesale CDs	240	0%	Own-sovereign debt	150	5%
10-year senior bonds	180	100%	BBB corporate bonds	160	50%
Common equity	110	100%	Business loans (>1 yr)	750	85%

Which of the following is closest to the bank's NSFR?

A. 82%

B. 106%

C. 121%

D. 154%

Question ORR-22 f.6 Bank Q684 • GARP Mock 1 Q10 (rebuilt; options in ascending order)

Bank BCCA has the following balance sheet:

Assets	Amount	Liabilities and equity	Amount
Cash	15	Retail deposits (less stable)	130
Central bank reserves	12	Wholesale deposits	65
Treasury bonds >1 year	15	Tier 2 capital	5
Mortgages	30	Tier 1 capital	20
Retail loans <1 year	32		
Small-business loans <1 year	94		
Fixed assets	22		
Total assets	220	Total liabilities and equity	220

Available stable funding (ASF) factors: 100% Tier 1 and Tier 2 capital, preferred stock, debt >1 year; 95% "stable" demand and term deposits from individuals and businesses <1 year; 90% "less stable" demand and term deposits from individuals and businesses <1 year; 50% wholesale funding (demand and term deposits) <1 year; 0% all other liability and equity categories. Required stable funding (RSF) factors: 0% cash and short-term instruments; 5% marketable securities (>1 year, sovereign 0% risk weight); 15% corporate bonds rated AA$-$ or higher; 50% bonds rated A$+$ to A$-$; 65% residential mortgages; 85% loans to small businesses or retail customers <1 year; 100% all other assets.
What is Bank BCCA's net stable funding ratio (NSFR)?

A. 85.6%

B. 95.1%

C. 116.8%

D. 121.2%

Question ORR-22 f.7 Workbook A32.3 • S3 • self-generated

An internal auditor at a US bank is checking the NSFR figure in a regulatory filing. The bank's balance sheet (USD million), with both NSFR and LCR parameters, is:

Item	Amount	ASF / RSF factor	LCR parameter
Stable retail deposits	800	ASF 95%	5% run-off
3-month wholesale CDs (1/3 mature each month)	300	ASF 0%	100% run-off on the maturing third
10-year senior bonds	250	ASF 100%	0% run-off
Common equity	150	ASF 100%	0% run-off
Vault cash	150	RSF 0%	HQLA factor 100%
Own-sovereign debt	200	RSF 5%	HQLA factor 100%
BBB corporate bonds	250	RSF 50%	HQLA factor 50%
Business loans (>1 yr)	900	RSF 85%	HQLA factor 0%

Which of the following is closest to the bank's NSFR?

A. 129%

B. 150%

C. 162%

D. 339%

Question ORR-22 f.8 Workbook A32.2 • S2 • self-generated

The head of balance sheet management at a Singapore bank finds that its NSFR is below the minimum. Balance sheet (SGD million) and factors are:

Funding	Amount	ASF	Asset	Amount	RSF
Stable retail deposits	400	95%	Vault cash	50	0%
3-month wholesale CDs	350	0%	Own-sovereign debt	100	5%
10-year senior bonds	150	100%	BBB corporate bonds	150	50%
Common equity	100	100%	Business loans (>1 yr)	700	85%

For its LCR, the bank applies a 5% run-off rate to stable retail deposits. The bank plans to raise additional stable retail deposits and invest all the proceeds in own-sovereign debt. Which of the following is closest to the minimum amount of new deposits needed to bring the NSFR to exactly 100%?

A. SGD 45.0 million

B. SGD 50.0 million

C. SGD 52.9 million

D. SGD 161.1 million

Solutions • ORR-22 f

Solution ORR-22 f.1

Answer: C

Bank Q682 • BT P2.T7.522.2

Step 1 – Check the definitions (A, B, D)

LCR = HQLA over stressed 30-day net outflows; NSFR = ASF (liability and equity side) over RSF (asset side); leverage ratio = capital over unweighted exposure including some off-balance-sheet items, minimum 3%. All three statements are true.

Step 2 – Trace the two substitutions in C

Retail deposits carry a higher ASF factor than wholesale deposits (for example 90% against 50%), so ASF falls. Residential mortgages carry a higher RSF factor than marketable securities (65% against 5%), so RSF rises.

$\Rightarrow$ Numerator down, denominator up: the NSFR *decreases*.

Interpretation

A polarity question. Both substitutions make the balance sheet less stable on each side, so they reinforce each other.

Why the other options are wrong

A is incorrect. True: this is the LCR definition.

B is incorrect. True: ASF weights the funding side, RSF the asset side.

D is incorrect. True: the leverage ratio is a non-risk-based backstop with a 3% minimum (Tier 1 is the capital measure; see the correction box in Section 2).

LO: ORR-22 f: Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 (Leverage Ratio Capital Requirements; Liquidity Requirements); SchweserNotes 2026 Book 3, Reading 63, LO 63.f

Solution ORR-22 f.2

Answer: B

Bank Q686 • GARP Mock 4 Q74

Step 1 – LCR numerator

Zero-risk-weight government bonds are HQLA with no haircut; corporate loans are not HQLA (factor 0%). The swap removes HQLA.

Step 2 – LCR denominator

Funding is unchanged, so stressed 30-day net outflows are unchanged.

$\Rightarrow$ HQLA down, outflows unchanged: the LCR falls.

Step 3 – NSFR

Loans need much more stable funding than government bonds (RSF 85% against 5% in the usual tables), so RSF rises and the NSFR also worsens.

Interpretation

Liquidity ratios depend on the composition of the balance sheet, not its size or its yield. The same trade raises return and lowers both liquidity ratios.

Why the other options are wrong

A is incorrect. Confuses yield with liquidity; the LCR counts HQLA, and loans are not HQLA.

C is incorrect. Polarity flip: loans are illiquid and carry a high RSF factor, so the NSFR deteriorates.

D is incorrect. Treats the ratios as size measures; the haircuts and RSF factors differ by asset.

LO: ORR-22 f: Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 (Liquidity Requirements)

Solution ORR-22 f.3

Answer: A

Bank Q688 • AnalystPrep Q.3245

Step 1 – Exposure measure

$$\text{Exposure} = 2{,}000 + 300 \times 100\% = 2{,}300$$

$\Rightarrow$ Not risk-weighted, and the off-balance-sheet commitments are included.

Step 2 – Leverage ratio

$$\frac{\text{Tier 1}}{\text{Exposure}} = \frac{250}{2{,}300} = 10.87\%$$

Interpretation

Well above the 3% minimum. Tier 2 capital is a red herring: it counts toward the risk-based total capital ratio, not the leverage ratio.

Why the other options are wrong

B is incorrect. Left out the off-balance-sheet commitments: $250/2{,}000 = 12.50\%$.
C is incorrect. Used total capital (Tier 1 + Tier 2): $400/2{,}300 = 17.39\%$.
D is incorrect. Both errors: $400/2{,}000 = 20.00\%$.

LO: ORR-22 f: Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 (Leverage Ratio Capital Requirements); BCBS, High-Level Summary of Basel III Reforms (Ch.23, Leverage Ratio Framework)

Solution ORR-22 f.4

Answer: C

Bank Q685 • GARP Mock 1 Q50

Step 1 – HQLA after haircuts

$$\text{HQLA} = 90 + 40 \times (1 - 0.50) = 90 + 20 = 110$$

$\Rightarrow$ The corporate debt is Level 2: $20/110 = 18\%$ of HQLA, inside the 40% cap.

Step 2 – Net 30-day outflows

$$\text{Outflows} = 500 \times 5\% + 300 \times 40\% = 25 + 120 = 145, \qquad \text{net} = 145 - 60 = 85$$

Step 3 – LCR

$$\text{LCR} = 110/85 = 129.4\%$$

Interpretation

Compliant. Both sides are adjusted before dividing: haircuts on the numerator, run-off rates and inflows on the denominator.

Why the other options are wrong

A is incorrect. Used gross outflows, ignoring the 60 of inflows: $110/145 = 75.9\%$.

B is incorrect. Left the corporate debt out of HQLA entirely: $90/85 = 105.9\%$.
D is incorrect. Counted the corporate debt at face value, forgetting the 50% haircut: $130/85 = 152.9\%$.

LO: ORR-22 f: Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 (Liquidity Requirements; Example of LCR and NSFR)

Solution ORR-22 f.5 — Answer: C

Workbook A32.1 • S1 • Aug-2026

Step 1 – Available stable funding

$$\text{ASF} = 620(0.95) + 240(0) + 180(1.00) + 110(1.00) = 589 + 0 + 180 + 110 = \text{CAD } 879 \text{ million}$$

$\Rightarrow$ Of CAD 1,150 million of funding, CAD 879 million is expected to remain through a stressful year.

Step 2 – Required stable funding

$$\text{RSF} = 90(0) + 150(0.05) + 160(0.50) + 750(0.85) = 0 + 7.5 + 80 + 637.5 = \text{CAD } 725 \text{ million}$$

$\Rightarrow$ The less liquid assets need CAD 725 million of stable funding behind them.

Step 3 – NSFR

$$\text{NSFR} = \frac{879}{725} = 1.212 = 121\%$$

Interpretation

The bank complies with a cushion of CAD 154 million of ASF. The 3-month CDs contribute nothing, so replacing CDs with term bonds would raise the ratio.

Why the other options are wrong

A is incorrect. Inverted the ratio: $725/879 = 82\%$.
B is incorrect. Omitted common equity from ASF: $(879 - 110)/725 = 106\%$.
D is incorrect. Gave the 3-month wholesale CDs a 100% ASF factor, treating them as stable funding: $(879 + 240)/725 = 154\%$.

LO: ORR-22 f: Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio. • **Reference:** Carey (GARP Risk Institute), Ch.22, Liquidity Requirements and Example of LCR and NSFR

Solution ORR-22 f.6 — Answer: C

Bank Q684 • GARP Mock 1 Q10

Step 1 – ASF: pick the factor for each funding line

Tier 1 and Tier 2 capital 100%; retail deposits are "less stable", so 90%, not 95%; wholesale deposits 50%.

$$\text{ASF} = 20 + 5 + 130(0.90) + 65(0.50) = 20 + 5 + 117 + 32.5 = 174.5$$

Step 2 – RSF

Cash and central bank reserves 0%; Treasuries $>$ 1 year 5%; mortgages 65%; retail and small-business loans $<$ 1 year 85%; fixed assets ("all other") 100%.

$$\text{RSF} = 15(0.05) + 30(0.65) + (32+94)(0.85) + 22(1.00) = 0.75 + 19.5 + 107.1 + 22 = 149.35$$

Step 3 – NSFR

$$\text{NSFR} = 174.5/149.35 = 116.8\%$$

Interpretation

The long factor list is the test: each balance-sheet line has exactly one matching row, and two of the rows (95% and 90% deposits) are a deliberate near-twin. This is the Schweser factor set used in Vardeez's Bluegrass example.

Why the other options are wrong

A is incorrect. Inverted the ratio: $149.35/174.5 = 85.6\%$.
B is incorrect. Omitted the wholesale deposits' 50% ASF: $142/149.35 = 95.1\%$.
D is incorrect. Applied the stable-deposit factor of 95% to the less stable retail deposits: $181/149.35 = 121.2\%$.

LO: ORR-22 f: Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 (Liquidity Requirements); SchweserNotes 2026 Book 3, Reading 63, Figures 63.2 and 63.3

Solution ORR-22 f.7

Answer: A

Workbook A32.3 • S3

Step 1 – ASF

$$\text{ASF} = 800(0.95) + 300(0) + 250(1.00) + 150(1.00) = 760 + 0 + 250 + 150 = \text{USD } 1{,}160 \text{ million}$$

Step 2 – RSF

$$\text{RSF} = 150(0) + 200(0.05) + 250(0.50) + 900(0.85) = 0 + 10 + 125 + 765 = \text{USD } 900 \text{ million}$$

Step 3 – NSFR

$$\text{NSFR} = \frac{1{,}160}{900} = 1.289 = 129\%$$

$\Rightarrow$ The bank has 29% more stable funding than its one-year requirement.

Interpretation

The LCR column answers a different, 30-day question about what can be sold; the NSFR asks what funding remains after a stressful year, and its categories differ from the LCR's.

Why the other options are wrong

B is incorrect. Treated the BBB bonds as liquid because they count as Level 2 HQLA and gave them a 0% RSF factor: RSF $= 10 + 765 = 775$, NSFR $= 1{,}160/775 = 150\%$.
C is incorrect. Gave the 3-month CDs a 100% ASF factor: $(1{,}160 + 300)/900 = 162\%$.
D is incorrect. Computed the LCR instead: HQLA $= 150 + 200 + 125 = 475$; outflows $= 0.05(800) + 300/3 = 140$; LCR $= 475/140 = 339\%$.

LO: ORR-22 f: Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio. • **Reference:** Carey (GARP Risk Institute), Ch.22, Liquidity Requirements and Example of LCR and NSFR

Solution ORR-22 f.8

Answer: B

Workbook A32.2 • S2

Step 1 – Current ASF and RSF

$$\text{ASF} = 400(0.95) + 350(0) + 150(1.00) + 100(1.00) = 380 + 0 + 150 + 100 = 630$$

$$\text{RSF} = 50(0) + 100(0.05) + 150(0.50) + 700(0.85) = 0 + 5 + 75 + 595 = 675$$

Step 2 – Current NSFR and gap

$$\text{NSFR} = 630/675 = 93.3\%, \qquad \text{gap} = 675 - 630 = \text{SGD } 45 \text{ million}$$

Step 3 – Solve for new deposits x

Each SGD 1 of new deposits adds 0.95 of ASF and, once invested in sovereign debt, 0.05 of RSF:

$$630 + 0.95x = 675 + 0.05x \;\Rightarrow\; 0.90x = 45 \;\Rightarrow\; x = \text{SGD } 50.0 \text{ million}$$

Step 4 – Check

$$\frac{630 + 47.5}{675 + 2.5} = \frac{677.5}{677.5} = 100\%$$

Interpretation

Every remedy has two legs: where the funding comes from (ASF factor) and where it is deployed (RSF factor). The LCR run-off rate is a red herring: it belongs to the 30-day test.

Why the other options are wrong

A is incorrect. Reported the raw ASF gap, ignoring that deposits earn only 95% credit and that the new asset adds RSF: $675 - 630 = 45.0$.

C is incorrect. Added the 5% LCR run-off on the new deposits as a further stable funding requirement: $0.95x - 0.05x - 0.05x = 45$, $x = 45/0.85 = 52.9$.

D is incorrect. Omitted common equity from current ASF: gap $= 675 - 530 = 145$, $x = 145/0.90 = 161.1$.

LO: ORR-22 f: Describe and calculate ratios intended to improve the management of liquidity risk, including the required leverage ratio, the liquidity coverage ratio, and the net stable funding ratio. • **Reference:** Carey (GARP Risk Institute), Ch.22, Liquidity Requirements and Example of LCR and NSFR

ORR-23 • High-level Summary of Basel III Reforms • Vardeez: VERY IMPORTANT

ORR-23 b

P1 CONCEPT

Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework

Workbook: A31 Basel IRB Capital • Tier A • August 2026 recall C5 Basel III Post-Crisis Reforms and Stress-Test Regimes • Tier C

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: section A31 carries your August 2026 recall "Credit risk IRB", and its shape S4 is the December 2017 IRB revisions. C5 (Tier C, map #30, 4 of 16 sources) adds the standardised versus internal-models split.
Vardeez: theme 3 of his ORR list ("Basel III: three components and comparison with Basel I and II"); ORR-23 is rank 11 of 55 in the consolidated volume. His notes label this LO "LO 62.b" (consolidated volume p.51) and give two or three bullets per area.

Reported exam shapes

- **A31·S4** December 2017 IRB revisions: A-IRB removed for certain asset classes, equities out of IRB, input floors.
- **C5·S2** The standardised versus internal-models split across accords: who uses which, and where the December 2017 reforms removed models.

What the questions look like: "which statement is correct" or "which action complies", across one or several of the five areas. Distractors reverse a direction (models extended instead of restricted, floors removed instead of added), swap siblings (F-IRB for A-IRB, CET1 for Tier 1, all banks for G-SIBs) or attach a change to the wrong area. No calculations.

See also: workbook A31.4 also tags this LO; it is worked under ORR-23 a. A31.5 is worked under ORR-23 c, and C5.1 under ORR-21 a. Motivations and goals: ORR-23 a. The output floor: ORR-23 c. The new operational risk approach in detail: ORR-24.

1. The December 2017 package at a glance

The first phase of Basel III (published 2010 to 2011, ORR-22) raised the quality and quantity of capital, added buffers, a leverage ratio and two liquidity ratios. The December 2017 reforms *finalise* the framework. Their purpose is to restore credibility in the calculation of risk-weighted assets (RWAs) and to improve the comparability of banks' capital ratios, through four levers (the motivations behind each: ORR-23 a):

1. more robust and risk-sensitive **standardised approaches** for credit risk, CVA risk and operational risk;
2. **constrained internal models**: limits on IRB inputs, and internal models *removed* for CVA risk and operational risk;
3. a **leverage ratio buffer for G-SIBs**;
4. a revised **output floor** built on the revised standardised approaches (ORR-23 c).

GARP's Table 23.5 dates all five areas of this LO from 1 January 2022 (the existing leverage exposure definition from 1 January 2018); the output floor phases in from 50% in 2022 to 72.5% in 2027.

2. Standardised approach to credit risk

Credit risk is the bulk of most banks' risk taking, and the standardised approach (SA) is used by the majority of banks in the world, including outside Basel Committee jurisdictions. The revisions do three things:

- **More granularity and risk sensitivity.** Basel II gives every residential mortgage one flat risk weight; the revised SA makes it depend on the **loan-to-value (LTV) ratio**. Granular treatments also for rated and unrated banks and corporates (with a separate SME weight), covered bonds, project, object and commodities finance, retail (transactors versus revolvers), commercial real estate, subordinated debt and equity, and off-balance-sheet items (credit conversion factors).
- **Less mechanistic reliance on external ratings.** Banks must do sufficient due diligence, and a granular non-ratings approach exists for jurisdictions that cannot or will not use ratings (the SCRA grades for bank exposures).
- **The foundation for the revised output floor** (ORR-23 c) and its disclosure, which restore comparability and a level playing field.

Exposure	Revised SA risk weight (GARP Table 23.1, selected rows)
Banks, rated	AAA to AA−: 20%; A: 30%; BBB: 50%; BB to B: 100%; below B−: 150%
Banks, unrated (SCRA)	Grade A 40% (30% if also CET1 $\geq$ 14% and Tier 1 leverage $\geq$ 5%); Grade B 75%; Grade C 150%
Corporates	rated 20% to 150%; unrated 100% (SME 85%); where ratings are not permitted, investment grade 65%, other 100%
Residential mortgages	whole loan: rises with LTV, from 20% in the lowest band to 70% above 100% LTV
Regulatory retail	transactors 45%; revolvers 75%; other retail 100%
Subordinated debt; equity	150%; 250% (speculative unlisted equity 400%)
Off-balance sheet	a positive CCF of 10% for unconditionally cancellable commitments

3. IRB approaches for credit risk (shape A31 S4)

The crisis exposed three shortcomings of the IRB approaches: **excessive complexity**, **lack of comparability** of internally modelled requirements across banks, and **lack of robustness** in modelling certain asset classes. Three revisions answer them.

(i) A-IRB removed for asset classes that cannot be modelled robustly

The A-IRB lets the bank estimate PD, LGD, EAD and maturity. Where it is removed, banks with supervisory approval use the **F-IRB**, which fixes LGD and EAD and so removes the two largest sources of RWA variability.

Portfolio (GARP Table 23.2)	Basel II	Basel III, December 2017
Large and mid-sized corporates (revenues > EUR 500m)	A-IRB, F-IRB, SA	F-IRB, SA
Banks and other financial institutions	A-IRB, F-IRB, SA	F-IRB, SA
Equities	various IRB approaches	**SA only**
Specialised lending	A-IRB, F-IRB, slotting, SA	unchanged

Losing A-IRB is not losing IRB: those corporates and banks go to F-IRB (or SA). Equities lose *every* IRB approach; they are typically a small part of banks' credit risk. Retail is not on the list: banks still estimate retail parameters, subject to the floors below.

(ii) Input floors on bank estimates

Floors guarantee a minimum of conservatism in the parameters of the asset classes that stay on IRB.

GARP Table 23.3	PD	LGD, unsecured	LGD, secured
Corporate	5 bp	25%	0% to 15% by collateral type
Mortgages	5 bp	n/a	5%
QRRE transactors	5 bp	50%	n/a
QRRE revolvers	10 bp	50%	n/a
Other retail	5 bp	30%	0% to 15% by collateral type
EAD floor (all classes): on-balance-sheet exposure + 50% of the off-balance-sheet exposure, using the SA CCF			

- **PD floors bind under both F-IRB and A-IRB. LGD and EAD floors bind only under A-IRB** (under F-IRB those parameters are supervisory anyway), and EAD floors only where EAD modelling is still permitted.
- Secured LGD floors (0% financial, 10% receivables, 10% real estate, 15% other physical collateral) apply to fully secured exposures; a partially secured exposure gets a weighted average of the unsecured and secured floors.

(iii) Estimation practices and recalibration

Greater specification of parameter estimation practices reduces unwarranted RWA variability. F-IRB supervisory parameters change: **higher haircuts** and **lower LGDs** for exposures secured by non-financial collateral, and the unsecured LGD for non-financial corporates is **cut from 45% to 40%**. Given these changes and the aggregate output floor, the **1.06 scaling factor** on IRB credit RWA is removed.

4. CVA risk framework

CVA risk is the risk of mark-to-market losses on derivatives when counterparties' creditworthiness deteriorates. It was a major source of crisis losses, in some instances larger than losses from outright defaults. The revision has three aims:

- **Risk sensitivity:** capture the **exposure component** of CVA (driven by market risk factors through the derivatives' prices) together with its hedges; the old framework missed it.
- **Robustness:** CVA is too complex to be modelled robustly, so the **internal model approach is removed**. What remains: a standardised approach (**SA-CVA**) and a basic approach (**BA-CVA**). A bank with non-centrally cleared derivatives of EUR 100 billion notional or less may instead set CVA capital as a simple multiplier of its counterparty credit risk charge.
- **Consistency:** CVA risk is a form of market risk, so SA-CVA is built, like the revised market risk approaches, on **fair value sensitivities** to market risk factors; BA-CVA is benchmarked to SA-CVA.

5. Operational risk framework

Two crisis lessons: operational risk capital **proved insufficient** to cover some banks' losses, and losses from misconduct and inadequate systems and controls showed how hard it is to **model** operational risk internally. So the **AMA and the three existing standardised approaches are replaced by one risk-sensitive standardised approach for all banks**. Capital uses two inputs, a measure of **income** (the business indicator) and a measure of **historical losses**:

$$\text{Operational risk capital} = \text{BIC} \times \text{ILM}$$

It rests on two assumptions: operational risk rises **at an increasing rate with income** (the marginal coefficients climb 12%, 15%, 18% with size), and banks with **larger past losses are more likely to suffer future losses**. The ILM rises with the ratio of the loss component to the BIC, but at a *decreasing* rate. At national discretion, supervisors may set ILM $= 1$ for all banks, so capital depends on the BIC alone; historical losses must still be disclosed. Full mechanics: ORR-24.

6. Leverage ratio framework

The leverage ratio complements the risk-weighted requirements: it guards against unsustainable leverage and mitigates gaming and model risk in both internal models and standardised approaches.

- **G-SIB leverage ratio buffer**, met with **Tier 1** capital and set at **50% of the G-SIB's risk-weighted higher-loss absorbency (HLA) requirement**: a 2% HLA means a 1% leverage buffer, on top of the 3% minimum. It mirrors the risk-weighted G-SIB buffer, which targets the externalities G-SIBs create.
- Like the risk-weighted buffers it is divided into **five ranges**; a G-SIB inside the buffer faces **capital distribution constraints**. Meeting both the CET1 risk-weighted requirement (4.5% + 2.5% conservation buffer + HLA) and the Tier 1 leverage requirement (3% + buffer): no constraint. Missing one: that requirement's constraint. Missing both: the **higher** of the two.
- **Exposure measure refinements:** derivatives, and off-balance-sheet items made consistent with the SA credit conversion factors.
- At national discretion, in exceptional macroeconomic circumstances, **central bank reserves** may be exempted temporarily, with the minimum recalibrated to offset the exemption and its impact disclosed.

7. Where internal models stand (shape C5 S2)

Who used which, accord by accord. Basel I (1988) had fixed weights and no models. The 1996 amendment let banks choose between a standardised approach and internal models for market risk. Basel II brought models into credit risk (F-IRB, A-IRB) and operational risk (AMA); its standardised approach for credit risk was *intended for banks whose internal risk measures could not support IRB*, and the United States did not implement it at all, requiring IRB for internationally active banks. December 2017 reverses the drift towards models: it **constrains IRB**, **removes** the internal models for **CVA** and **operational risk**, and puts an **aggregate floor** under whatever models remain (Figure 1).

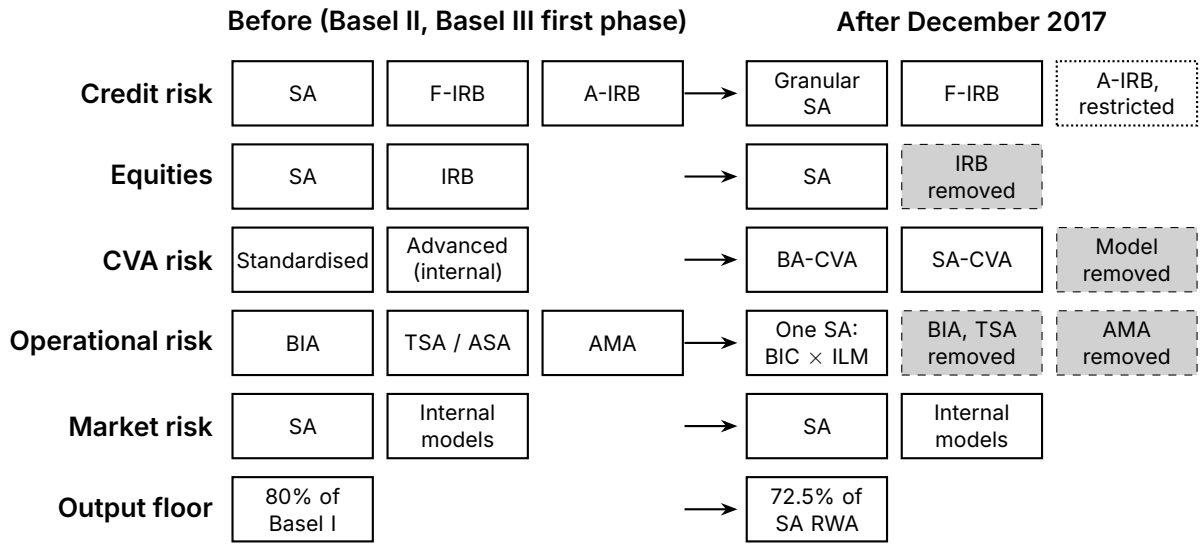


Figure 1. Approaches before and after the December 2017 reforms. Solid boxes: available; dotted box: still available with a narrower scope; grey dashed boxes: removed. Market risk models come from the separate revised market risk framework (January 2016) and are not removed in December 2017, but every surviving model is now subject to the aggregate output floor.

Summary card: ORR-23 b

Area	What changed	Why
SA credit risk	LTV-based mortgage weights; more granular weights for banks, corporates (SME), retail, real estate, sub debt, equity, CCFs; due diligence and a non-ratings route	flat weights and mechanistic reliance on ratings; base for the output floor
IRB	A-IRB removed for large and mid-sized corporates and banks/FIs (to F-IRB or SA); equities SA only; PD floors (both) and LGD, EAD floors (A-IRB); F-IRB LGD 45% to 40%; 1.06 factor removed	complexity, no comparability, models not robust for some asset classes
CVA	exposure component and hedges captured; internal model removed; SA-CVA (fair value sensitivities) or BA-CVA; small-bank multiplier of the CCR charge	big crisis losses; too complex to model
Operational risk	one SA for all banks: BIC × ILM, from income and past losses; AMA and three standardised approaches removed	capital too low; misconduct hard to model
Leverage ratio	G-SIB buffer of 50% of the risk-weighted HLA, in Tier 1, five ranges, distribution constraints; refined exposure measure	limit G-SIB leverage, gaming and model risk

Exam traps

- **Polarity of the reforms.** Internal models were restricted (IRB) or removed (CVA, operational risk), never extended. Input floors were added, not removed.
- **A-IRB versus IRB.** Large corporates and banks lose A-IRB but keep F-IRB. Equities lose all IRB. Specialised lending and retail keep their models.
- **Which floor binds where.** PD floors under F-IRB and A-IRB; LGD and EAD floors only under A-IRB. QRRE revolvers have a 10 bp PD floor, not 5 bp.
- **Two LGD numbers.** 40% is the new F-IRB supervisory LGD for unsecured non-financial corporates; 25% is the A-IRB floor on a bank's own unsecured corporate LGD.
- **CVA threshold.** EUR 100 billion of non-centrally cleared notional opens a simple multiplier of the CCR charge, not an internal model.
- **Operational risk rate.** Risk rises at an *increasing* rate with income; the ILM rises at a *decreasing* rate with losses.
- **Leverage buffer.** G-SIBs only; Tier 1, not CET1; 50% of the HLA, not the full HLA; missing both requirements triggers the higher constraint, not the sum.

Practice questions: ORR-23 b

Question ORR-23 b.1

Bank Q718 • Schweser Module Quiz 64.1 Q3

The advanced internal ratings-based (A-IRB) approach for credit risk will no longer be permissible to use under the Basel III reforms for each of the following except:

A. large corporate exposures.

B. mid-size corporate exposures.

C. banks and other financial institutions.

D. residential and commercial real estate.

Question ORR-23 b.2

Bank Q720 • AnalystPrep Q.3106

The Basel Committee has agreed on various additional enhancements to the IRB approaches to further reduce unwarranted RWA variability. Which of the following correctly outlines a measure that has been put forth for adoption by banks?

A. Secured exposures: increasing the haircuts that apply to the collateral; Unsecured exposures: reducing the LGD parameter from 45% to 40% for exposures to non-financial corporates.

B. Secured exposures: reducing the LGD parameters; Unsecured exposures: reducing the LGD parameter from 25% to 20% for exposures to non-financial corporates.

C. Secured exposures: decreasing the haircuts that apply to the collateral; Unsecured exposures: reducing the LGD parameter from 45% to 40% for exposures to non-financial corporates.

D. Secured exposures: increasing the LGD parameters; Unsecured exposures: increasing the LGD parameter from 40% to 50% for exposures to non-financial corporates.

Question ORR-23 b.3 New • built from GARP Ch.23

A model validation manager at a eurozone bank is reviewing how the December 2017 input floors apply to the bank's IRB portfolios. The bank uses the foundation IRB approach for its exposures to large corporates and the advanced IRB approach for its retail portfolios, including qualifying revolving retail exposures (QRRE). Which of the following statements should the manager include in the review?

A. The LGD floors apply under both the foundation and the advanced IRB approach, and a partially secured exposure takes the secured LGD floor on its whole amount.

B. QRRE revolvers face the same 5 bp PD floor as QRRE transactors, and unsecured QRRE exposures face a 30% LGD floor.

C. The 5 bp PD floor applies to the large corporates under the foundation IRB approach, whereas LGD and EAD floors bind only on the advanced IRB portfolios.

D. The EAD floor equals the on-balance-sheet exposure plus 100% of the off-balance-sheet exposure, so no credit conversion factor below one may be applied.

Question ORR-23 b.4 Bank Q713 • BT Mock Q3 • BT P2.T7.20.11.1

In December 2017 the Basel Committee revised the Basel III framework, including the standardized approach (SA) and the internal ratings-based (IRB) approaches for credit risk. Which of the following statements regarding these revisions is TRUE?

A. In the SA for residential real estate exposures, risk weights are lower when the loan-to-value (LTV) ratio falls into a lower band.

B. The SA eliminated the treatment of unrated exposures because all exposures are now required to have an external credit rating.

C. The IRB framework removed the foundation IRB (F-IRB) option because the advanced IRB (A-IRB) must be used for all asset classes.

D. The IRB framework removed the parameter input floors (PD, LGD, EAD) to increase RWA variability across banks.

Question ORR-23 b.5 Bank Q709 • AnalystPrep Q.3097 (rebuilt)

Which of the following best describes the December 2017 revisions to the CVA risk framework?

A. The internal model approach was removed; banks must use the standardized approach (SA-CVA) or the basic approach (BA-CVA).

B. The internal model approach was retained as the primary method, with the standardized approach as a fallback.

C. All banks must use a single basic approach (BA-CVA) regardless of size or sophistication.

D. CVA risk is no longer capitalized because it is already covered by the market risk framework.

Question ORR-23 b.6 Bank Q710 • AnalystPrep Q.3098

The new standardized approach for determining a bank's operational risk capital requirement assumes that:

I. Operational risk increases at a decreasing rate with a bank's income.

II. Banks that have experienced greater operational risk losses historically are more likely to experience operational risk losses in the future.

A. I only

B. II only

C. Both I and II

D. Neither I nor II

Question ORR-23 b.7 Bank Q717 • Schweser Module Quiz 64.1 Q2 (rebuilt)

The December 2017 Basel III reforms introduced a leverage ratio buffer. Which of the following statements correctly describes this buffer?

A. It applies to all internationally active banks, and it must be met with Common Equity Tier 1 capital.

B. It applies to global systemically important banks (G-SIBs), is set at 50% of the bank's risk-weighted higher-loss absorbency requirement, and must be met with Tier 1 capital.

C. It applies to G-SIBs and equals the bank's full risk-weighted higher-loss absorbency requirement, so a 2% requirement gives a 2% buffer.

D. It applies to banks regulated by the U.S. Federal Reserve and the European Banking Authority, and it replaces the 3% minimum leverage ratio.

Question ORR-23 b.8 Bank Q715 • GARP PE2 Q35 • Mock 4 Q36

The CRO of a large bank has asked a group of risk managers to prepare a plan to implement the revisions to the Basel III guidelines finalized in December 2017. The bank expects to qualify as a global systemically important bank (G-SIB) by the time the revisions are implemented. Which of the following actions is most appropriate for the bank to take to comply with the revised Basel III guidelines?

A. Introduce an internally created model to determine the bank's operational risk capital.

B. Assign different credit risk weights for residential mortgages based on each mortgage's loan-to-value ratio.

C. Apply the advanced internal rating-based approach for certain types of credit exposures, such as exposures to banks and large corporations.

D. Decrease the bank's target level of its countercyclical buffer and its Basel III Tier 1 leverage ratio.

Question ORR-23 b.9 New • built from GARP Ch.23 and Ch.21

A risk manager at a large European bank is mapping which of its internal models survive the December 2017 reforms. The bank currently uses the advanced IRB approach for all of its credit exposures (including equities), an internally modelled (advanced) approach for CVA risk, the internal models approach for market risk and the AMA for operational risk. Which of the following conclusions is correct?

A. The AMA may be retained for operational risk, since the bank holds more than ten years of high-quality internal loss data.

B. The internal CVA model may be retained, provided the bank's non-centrally cleared derivatives notional is EUR 100 billion or less.

C. Internal ratings remain available for some exposures, such as retail and specialised lending, but no longer for equities; all remaining models face the output floor.

D. The A-IRB approach may be retained for exposures to banks and large corporates, provided the new PD, LGD and EAD input floors are applied.

Solutions • ORR-23 b

Solution ORR-23 b.1 — Answer: D

Bank Q718 • Schweser Module Quiz 64.1 Q3

Step 1 – Read Table 23.2

A-IRB is removed for large and mid-sized corporates (consolidated revenues above EUR 500 million) and for banks and other financial institutions. Those exposures move to F-IRB, or to the SA.

⇒ A, B and C all lose the A-IRB.

Step 2 – Where real estate sits

Residential mortgages are retail exposures, where banks still estimate their own parameters subject to input floors (mortgage PD 5 bp, secured LGD 5%). Income-producing real estate is specialised lending, which keeps A-IRB, F-IRB and slotting.

⇒ Real estate is the exception.

Interpretation

A-IRB is removed only where exposures "cannot be modelled in a robust and prudent manner". The F-IRB fixes LGD and EAD, the two parameters that drove most of the RWA variability between banks.

Why the other options are wrong

A is incorrect. Large corporates lose the A-IRB option.

B is incorrect. Mid-sized corporates (revenues above EUR 500 million) lose it as well.

C is incorrect. Banks and other financial institutions lose it too: they are treated like large corporates.

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, IRB Approaches, Tables 23.2 and 23.3; SchweserNotes 2026 Book 3, Reading 64, LO 64.b

Solution ORR-23 b.2 — Answer: A

Bank Q720 • AnalystPrep Q.3106

Step 1 – Secured exposures

For exposures secured by non-financial collateral the F-IRB supervisory parameters change in two ways: the **haircuts on the collateral increase** and the **LGD parameters fall**.

Step 2 – Unsecured exposures

The F-IRB LGD for unsecured exposures to non-financial corporates is **reduced from 45% to 40%**.

⇒ Only A has both halves right.

Interpretation

These are recalibrations of the F-IRB, where the supervisor sets LGD. Keep them apart from the A-IRB input floors: 25% is the minimum on a bank's *own* unsecured corporate LGD estimate, not a supervisory value.

Why the other options are wrong

B is incorrect. The unsecured change is 45% to 40%. "25% to 20%" borrows the 25% A-IRB floor and invents a cut to it.

C is incorrect. Haircuts on non-financial collateral were increased, not decreased.

D is incorrect. Both directions reversed: the secured LGDs fell, and the unsecured LGD fell to 40% rather than rising to 50%.

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Additional Enhancements (IRB)

Solution ORR-23 b.3 — Answer: C

New • built from GARP Ch.23

Step 1 – Which approach each floor constrains

Table 23.3, footnote 4: PD floors apply under **both** F-IRB and A-IRB; "the LGD and EAD floors are only applicable in A-IRB approaches".
⇒ The large corporates on F-IRB face the 5 bp corporate PD floor; their LGD and EAD are supervisory values.

Step 2 – Check the retail values

QRRE transactors 5 bp, QRRE revolvers **10 bp**; unsecured LGD floor **50%** for QRRE (30% is other retail). EAD floor: on-balance-sheet exposure plus **50%** of the off-balance-sheet exposure using the SA credit conversion factor.

Interpretation

Input floors act on parameters inside the model; they constrain a bank's own estimates where it still makes them. That is why the LGD and EAD floors have nothing to bite on under F-IRB.

Why the other options are wrong

A is incorrect. Sibling swap: LGD floors are A-IRB only. A partially secured exposure takes a weighted average of the unsecured floor (on the unsecured part) and the secured floor (on the secured part).
B is incorrect. Two wrong values: QRRE revolvers have a 10 bp PD floor, and the QRRE unsecured LGD floor is 50%; 30% belongs to other retail.
D is incorrect. The EAD floor adds 50% of the off-balance-sheet exposure (using the SA CCF), not 100%.

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Specification of Input Floors, Table 23.3 and footnote 4

Solution ORR-23 b.4 — Answer: A

Bank Q713 • BT Mock Q3

Step 1 – Standardised approach

Residential mortgage risk weights now depend on the LTV band: under the whole-loan approach they rise from 20% in the lowest band to 70% above 100% LTV. A lower band means a lower weight, so A is true. Reliance on ratings was *reduced*, and a more granular treatment of unrated exposures was kept (the SCRA grades), so B is false.

Step 2 – IRB approaches

The A-IRB was removed for some asset classes and the F-IRB retained (C reversed). Input floors were *introduced*, to reduce RWA variability (D reversed).

Interpretation

Every false statement here is a polarity flip of a real reform. In this LO, check the direction first: more granularity, less reliance on ratings, fewer models, more floors.

Why the other options are wrong

B is incorrect. Unrated exposures keep a (more granular) treatment; the reform reduces mechanistic reliance on ratings rather than requiring them.

C is incorrect. Reversed: the A-IRB lost asset classes; the F-IRB remains.

D is incorrect. Reversed twice: floors were added, and their purpose is to reduce RWA variability.

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Standardised Approach for Credit Risk, Table 23.1; IRB Approaches

Solution ORR-23 b.5 Answer: A

Bank Q709 • AnalystPrep Q.3097

Step 1 – The three aims of the CVA revision

Risk sensitivity (capture the exposure component and its hedges), robustness and consistency with the revised market risk framework (fair value sensitivities).

Step 2 – What robustness means here

CVA is a complex risk that "cannot be modelled by banks in a robust and prudent manner", so the internal model approach is removed. Two approaches remain: SA-CVA and BA-CVA.

$\Rightarrow$ A describes the revision.

Interpretation

Small derivatives users (non-centrally cleared notional of EUR 100 billion or less) may also use a simple multiplier of their counterparty credit risk charge, which is another simplification, not a model.

Why the other options are wrong

B is incorrect. Reversed: the internal model option was removed, not kept as the primary method.

C is incorrect. Two approaches remain, SA-CVA and BA-CVA, not one.

D is incorrect. CVA risk is still capitalised separately; the revision made it *consistent* with the market risk framework, not absorbed by it.

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, CVA Risk Framework

Solution ORR-23 b.6 Answer: B

Bank Q710 • AnalystPrep Q.3098

Step 1 – Statement I

GARP: the approach "assumes (i) that operational risk increases at an *increasing* rate with a bank's income". The rising marginal coefficients (12%, 15%, 18%) are that assumption in numbers. Statement I is false.

Step 2 – Statement II

GARP: "(ii) banks which have experienced greater operational risk losses historically are assumed to be more likely to experience operational risk losses in the future". That is why the ILM rises with the loss component. Statement II is true.

Interpretation

A "decreasing rate" does appear in the chapter, but for the ILM: it rises with the ratio of the loss component to the BIC "although at a decreasing rate". Statement I moves that phrase to the wrong relationship.

Why the other options are wrong

A is incorrect. Accepts the false statement I and rejects the true statement II.
C is incorrect. Statement I reverses the rate: increasing, not decreasing.
D is incorrect. Statement II is exactly the second assumption of the approach.

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Operational Risk Framework and footnote 5

Solution ORR-23 b.7 **Answer: B**

Bank Q717 • Schweser Module Quiz 64.1 Q2

Step 1 – Who

The buffer is for G-SIBs only, consistent with the risk-weighted G-SIB buffer that targets the externalities G-SIBs create.

Step 2 – How much, and in what capital

"The leverage ratio G-SIB buffer must be met with Tier 1 capital and is set at 50% of a G-SIB's risk-weighted higher-loss absorbency requirements"; GARP's example: a 2% requirement gives a 1% buffer.
⇒ B matches on all three attributes.

Interpretation

The buffer sits on top of the 3% minimum and works like the other buffers: five ranges, with capital distribution constraints for a G-SIB that falls into it. (Schweser's version offered only the population as the answer; the options were extended to test the calibration and the capital that meets it.)

Why the other options are wrong

A is incorrect. Wrong population and wrong capital: G-SIBs only, and Tier 1 rather than CET1.
C is incorrect. Right population, wrong calibration: 50% of the requirement, so a 2% requirement gives a 1% buffer.
D is incorrect. The population is defined by G-SIB status, not by the regulator; and the buffer adds to the 3% minimum rather than replacing it.

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Leverage Ratio Framework, Table 23.4

Solution ORR-23 b.8 — Answer: B

Bank Q715 • GARP PE2 Q35

Step 1 – Test each action against its area

SA credit risk: the revised approach makes residential mortgage weights depend on LTV, so B complies. Operational risk: internal models are removed (A fails). IRB: the A-IRB is withdrawn for banks and large corporates (C fails). Leverage: as a G-SIB the bank faces an *additional* leverage ratio buffer (D fails).

⇒ Only B is an action the revisions require.

Interpretation

GARP's question mixes four of the five areas; each wrong action reverses one reform. For a G-SIB the leverage requirement goes up, never down.

Why the other options are wrong

A is incorrect. The AMA and all internal models for operational risk are replaced by one standardised approach based on income and historical losses.

C is incorrect. A-IRB is no longer available for exposures to banks, other financial institutions and large and mid-sized corporates; F-IRB or SA must be used.

D is incorrect. The reforms add a G-SIB leverage ratio buffer met with Tier 1 capital, so lowering the leverage target would not comply.

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, all five sections

Solution ORR-23 b.9 — Answer: C

New • built from GARP Ch.23 and Ch.21

Step 1 – Credit risk

A-IRB is removed for banks, other financial institutions and large and mid-sized corporates (F-IRB or SA instead), and every IRB approach is removed for equities. Retail and specialised lending keep their internal estimates, subject to input floors.

Step 2 – CVA and operational risk

The internal model for CVA is removed (SA-CVA or BA-CVA). The AMA is replaced by one standardised approach for all banks.

Step 3 – What constrains the survivors

The output floor applies to total RWA, so any model still in use (IRB, market risk internal models) can lower total RWA to no less than 72.5% of the standardised-only figure (ORR-23 c).

⇒ C is the only conclusion consistent with all three steps.

Interpretation

This is the C5 S2 shape: the standardised versus internal-models split. In Basel II models spread to credit and operational risk; December 2017 pulls them back, area by area, and floors what remains.

Why the other options are wrong

A is incorrect. Polarity flip: no amount of loss data keeps the AMA; it is replaced for all banks. (Ten years is the window for the loss component of the new approach.)

B is incorrect. Scope error: the EUR 100 billion threshold allows a simple multiplier of the CCR charge, not an internal model.

D is incorrect. Input floors constrain models that remain; they do not restore the A-IRB for banks and large corporates.

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Table 23.2, CVA and Operational Risk Frameworks, Output Floor; Carey, Capital Regulation Before the Global Financial Crisis, GARP ORR Ch.21 (Basel II)

ORR-23 • High-level Summary of Basel III Reforms • Vardeez: VERY IMPORTANT

ORR-23 c

P1 CALC

Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor.

Workbook: A31 Basel IRB Capital • Tier A • August 2026 recall C5 Basel III Post-Crisis Reforms and Stress-Test Regimes • Tier C

WHAT IS TESTED HERE

Why P1. Tier A workbook topic: shape S5 of section A31 (the 72.5% output floor and how input floors and the output floor bind) sits in the section that carries your August 2026 recall; C5 (Tier C, map #30) reports output floors as an examinable comparison.
Type: the verb is "describe", but the LO covers calculating the floor (72.5% of standardised RWA) and workbook A31.5 is numerical, so this block is CALC (approved).
Vardeez: his notes label this LO "LO 62.c" (consolidated volume p.52): the floor as the higher of two RWA measures (his Figure 62.1) and the standardised approach used for each risk type (Figure 62.2). ORR-23 is rank 11 of 55.

Reported exam shapes

- **A31·S5** The 72.5% output floor, and how input floors and the output floor bind.
- **C5·S3** Output floors: the Basel II floor on Basel I, and the Basel III floor on the revised standardised approaches.

What the questions look like: RWA under the bank's approved approaches and RWA under standardised approaches only; take 72.5% of the second and the higher of the two. Twists: which approaches build the standardised figure, the phase-in percentage, the transitional cap, input floors against the output floor, and the old Basel II floor. Distractors: 72.5% of the *modelled* RWA, 80% or 100% of standardised RWA, a floor applied risk type by risk type.

See also: workbook C5.1 also tags this LO; it is worked under ORR-21 a. The input floors themselves: ORR-23 b, Section 3.

1. Why an output floor

Before the crisis, banks using internal models could cut their capital requirements far below what the standardised approaches would require, an advantage that standardised banks did not have. The output floor is a **risk-based backstop** that limits the regulatory capital benefit a bank can derive from internal models relative to the standardised approaches. GARP gives it three jobs:

- maintain a **level playing field** between banks on internal models and banks on the standardised approaches;
- support the **credibility** of banks' risk-weighted calculations;
- improve **comparability**, through the related disclosure of RWA under the standardised approaches.

The floor it replaces. Basel II introduced an output floor based on Basel I: **80% of the relevant Basel I capital requirements**. It was implemented inconsistently across countries, partly because of differing interpretations, and partly because it rested on Basel I standards that many banks and jurisdictions no longer applied. The Basel III floor is built instead on the **revised Basel III standardised approaches** (ORR-23 b), which is why the revised credit SA is called "the foundation for a revised output floor".

2. The rule

$$\text{RWA} = \max\left(\underbrace{\text{RWA}_{\text{approved}}}_{\substack{\text{approaches the bank has} \\ \text{supervisory approval to use}}} \;,\; 72.5\% \times \underbrace{\text{RWA}_{\text{SA only}}}_{\substack{\text{the same book, every risk} \\ \text{type on its standardised approach}}} \right)$$

- The first leg mixes models (where approved) with standardised approaches (everywhere else). The second recomputes *every* risk type, modelled or not, with standardised approaches only.
- It is a **floor, never a cap**: RWA can sit anywhere above 72.5% of the standardised figure, including above 100% of it.
- **Maximum benefit of models:** total RWA can fall no more than 27.5% $(= 1 - 72.5\%)$ below the standardised-only RWA.
- **Binding test:** the floor binds when the ratio $\text{RWA}_{\text{approved}}/\text{RWA}_{\text{SA only}}$ is below 72.5%.
- It is an **aggregate** floor on *total* RWA, not a floor applied risk type by risk type (Question ORR-23 c.6). A bank that uses only standardised approaches is unaffected: its two legs are equal.
- It floors RWA, so it moves every risk-based ratio (CET1, Tier 1, total capital). The leverage ratio, built on an exposure measure, is untouched.

3. The standardised approaches that build the floor

Vardeez's Figure 62.2 condensed, with GARP's detail:

Risk type	Approach used in the floor calculation
Credit risk	The revised SA for credit risk. For credit risk mitigation, carrying values with the simple approach, or the comprehensive approach with standard supervisory haircuts; also failed trades and non-DvP transactions.
Counterparty credit risk	SA-CCR to measure the derivative exposure, then multiplied by the borrower's risk weight under the SA for credit risk.
CVA risk	SA-CVA, BA-CVA, or 100% of the bank's counterparty credit risk capital requirement (depending on which approach the bank is eligible for and uses).
Securitisation	SEC-ERBA, SEC-SA, or a 1,250% risk weight.
Market risk	The standardised (or simplified standardised) approach of the revised market risk framework; SEC-ERBA, SEC-SA or 1,250% also for the default risk charge on trading-book securitisations.
Operational risk	The standardised approach for operational risk (the only approach left; ORR-24).

Nothing internally modelled enters the second leg: no IRB, no internal model method for counterparty exposure, no internal models for market risk. Banks must also **disclose** their RWA calculated on the revised standardised approaches.

4. Input floors and the output floor (shape S5)

The two floors work at different levels:

- **Input floors** (ORR-23 b) act *inside* the IRB model, on parameters: PD under F-IRB and A-IRB, LGD and EAD under A-IRB only. A modelled LGD of 20% on unsecured corporate loans is raised to 25% before RWA are computed.
- The **output floor** acts *after* all models, on the bank's total RWA. It compares the floored modelled total with 72.5% of the standardised total.

A bank can be bound by both: input floors push modelled RWA up first, then the output floor may push the total up again. Because the package adds input floors and the aggregate output floor, the Committee removed the 1.06 scaling factor on IRB credit RWA.

5. Phase-in and the transitional cap

The floor reaches 72.5% in steps (GARP Table 23.5):

From 1 January	2022	2023	2024	2025	2026	2027
Floor (% of SA-only RWA)	50%	55%	60%	65%	70%	72.5%

Transitional cap (national discretion). During the phase-in, supervisors may cap the *increase* in total RWA caused by the floor at **25% of the bank's RWA before the floor**: RWA are then at most $1.25 \times \text{RWA}_{\text{approved}}$. The cap is removed on 1 January 2027. With phase-in percentage p_t:

$$\text{RWA}_t = \min\Big(\max\left(\text{RWA}_{\text{approved}},\ p_t\,\text{RWA}_{\text{SA only}}\right),\ 1.25\,\text{RWA}_{\text{approved}}\Big)$$

The Basel framework is a minimum: a jurisdiction may implement more conservative requirements or accelerate the transition, and one that implements only the standardised approaches is compliant.

Dates in practice. In March 2020 the Basel Committee deferred the package by one year because of COVID-19 (GARP Ch.2 notes the 1 January 2023 start for operational risk), which moved the floor's phase-in to 2023 to 2028. GARP's Chapter 23 reprints the original December 2017 table, and exam questions follow it: 50% in 2022 to 72.5% in 2027.

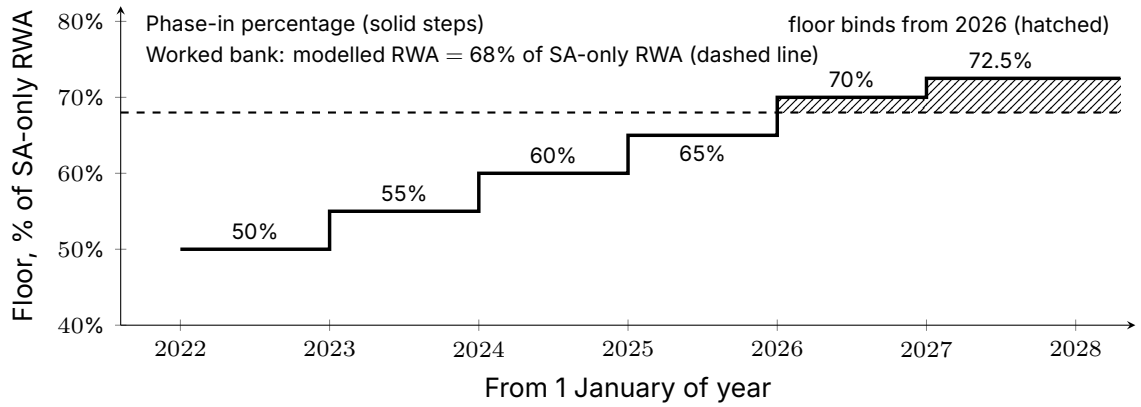


Figure 1. Output floor phase-in (GARP Table 23.5). The floor binds in any year in which the phase-in percentage exceeds the bank's ratio of modelled to standardised-only RWA. For the worked bank of Section 6 (ratio 68%) that happens from 2026.

6. Worked example

A bank's RWA under its approved approaches are EUR 340 billion; under standardised approaches only they are EUR 500 billion. Its CET1 capital is EUR 40 billion.

$$\begin{aligned}
\text{Modelled over SA-only RWA} &= 340/500 = 68\% < 72.5\% \quad \text{(the floor will bind)} \\
\text{Fully phased-in floor} &= 72.5\% \times 500 = 362.5 \\
\text{RWA} &= \max(340,\ 362.5) = \text{EUR } 362.5 \text{ billion} \\
\text{CET1 ratio} &= 40/340 = 11.76\% \text{ before the floor;} \qquad 40/362.5 = 11.03\% \text{ after}
\end{aligned}$$

The floor adds EUR 22.5 billion (6.62%) to RWA. Phase-in: $65\% \times 500 = 325 < 340$ in 2025, so no effect; $70\% \times 500 = 350 > 340$ in 2026, so RWA become 350 (CET1 ratio 11.43%). A transitional cap at $1.25 \times 340 = 425$ never bites here.

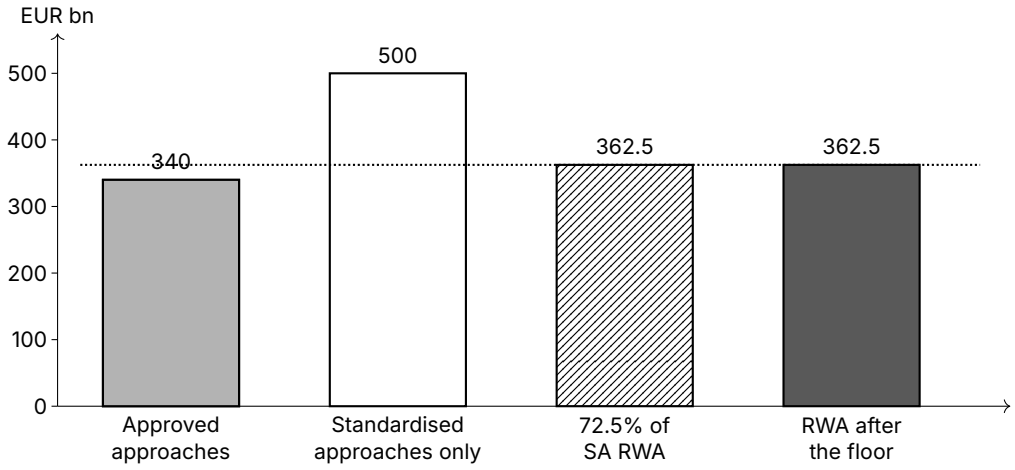


Figure 2. The worked example. Modelled RWA (light grey) sit 32% below the standardised-only RWA (open bar). The floor (hatched, and the dotted line) is 72.5% of the open bar; the bank reports the higher of the light grey bar and the floor (dark grey).

Formula card: ORR-23 c

Output floor	$\text{RWA} = \max\left(\text{RWA}_{\text{approved}},\ 72.5\% \times \text{RWA}_{\text{SA only}}\right)$, on total RWA
Binding test	binds if $\text{RWA}_{\text{approved}}/\text{RWA}_{\text{SA only}} < 72.5\%$; maximum benefit of models 27.5%
Phase-in	50%, 55%, 60%, 65%, 70% from 1 January 2022 to 2026; 72.5% from 1 January 2027
Transitional cap	national discretion: $\text{RWA}_t \le 1.25 \times \text{RWA}_{\text{approved}}$ during the phase-in
With the cap	$\text{RWA}_t = \min\left(\max(\text{RWA}_{\text{approved}},\ p_t\,\text{RWA}_{\text{SA only}}),\ 1.25\,\text{RWA}_{\text{approved}}\right)$
Capital ratio	CET1 ratio = CET1/RWA after the floor
Old floor	Basel II: 80% of Basel I capital requirements
SA inputs	SA credit; SA-CCR × SA weight; SA-CVA, BA-CVA or 100% of CCR capital; SEC-ERBA, SEC-SA or 1,250%; SA market risk; SA operational risk

Exam traps

- **Wrong base.** 72.5% of the *standardised-only* RWA, never of the modelled RWA (which makes the floor bind never).
- **Floor, not cap.** The rule is a higher-of. RWA above 72.5% of the standardised figure are perfectly allowed.
- **Not the full standardised amount.** When the floor binds, RWA become 72.5% of the standardised figure, not 100%.
- **Two calibrations.** 80% belongs to the old Basel II floor on Basel I; 72.5% to the new floor on the revised standardised approaches.

- **Aggregate, not line by line.** Apply 72.5% to the total standardised RWA and compare with the total modelled RWA.
- **Phase-in year.** Use the percentage of the year asked (70% in 2026), not the end-point.
- **The cap limits the increase.** During the phase-in RWA cannot exceed 1.25 times pre-floor RWA where the supervisor uses the cap; it does not switch the floor off.
- **No model in the second leg.** There is no IRB-based or internally modelled CVA option in the floor calculation.
- **Input versus output floor.** Input floors act on PD, LGD and EAD inside the model; the output floor acts on total RWA.

Practice questions: ORR-23 c

Question ORR-23 c.1

Bank Q721 • Schweser Module Quiz 64.1 Q5

The Basel III output floor sets the minimum level of:

A. leverage.

B. functional capital.

C. credit valuation adjustment (CVA) risk exposure.

D. risk-weighted assets.

Question ORR-23 c.2

New • built from GARP Ch.23

A regulatory policy analyst at a Nordic bank is explaining to the board how the output floor in the December 2017 Basel III reforms differs from the floor it replaces. Which of the following statements is correct?

A. The Basel II floor was set at 72.5% of Basel I capital requirements; the new floor raises the calibration to 80% of the RWA under the revised standardised approaches.

B. The new floor limits a bank's RWA to no more than 72.5% of the RWA calculated using only the standardised approaches.

C. The Basel II floor was set at 80% of Basel I capital requirements and was applied inconsistently across countries; the new floor is based on the revised Basel III standardised approaches.

D. The new floor applies only to banks using the advanced IRB approach, since banks on the foundation IRB approach already use supervisory LGD and EAD values.

Question ORR-23 c.3

Bank Q722 • Schweser Module Quiz 64.1 Q6

Under the Basel III reforms, the approaches that can be used when calculating the output floor for CVA risk include all of the following EXCEPT:

A. the basic (BA-CVA) approach.

B. the standardized (SA-CVA) approach.

C. the internal ratings-based (IRB-CVA) approach.

D. 100% of the bank's counterparty credit risk capital requirement.

Question ORR-23 c.4

Bank Q723 • bank-written, GARP style

A large bank's regulator has fully phased in the Basel III revised output floor. A risk analyst at the bank calculates total risk-weighted assets (RWA) of USD 600 billion using the internal models the bank has supervisory approval to use (combined with standardized approaches where models are not approved). The same exposures would produce total RWA of USD 900 billion if only the standardized approaches were applied. Which of the following is the bank's RWA for regulatory capital purposes?

A. USD 600.0 billion

B. USD 652.5 billion

C. USD 720.0 billion

D. USD 900.0 billion

Question ORR-23 c.5

Workbook A31.5 • S5 • self-generated

A capital manager at a eurozone bank is reporting under the fully phased-in December 2017 framework. The bank's A-IRB model estimates an LGD of 20% for unsecured loans to corporates with consolidated revenues below EUR 500 million. After all input floors are applied, the bank's total RWA under its approved approaches is EUR 60 billion; its total RWA calculated using only the standardised approaches is EUR 90 billion. Which of the following statements is correct?

A. The modelled LGD is raised to the 25% floor; the output floor does not bind, because EUR 60 billion exceeds 72.5% of the modelled RWA, EUR 43.5 billion.

B. The modelled LGD is raised to the 25% floor; the output floor binds, because 72.5% of standardised RWA is EUR 65.25 billion, so RWA become EUR 65.25 billion.

C. The modelled LGD of 20% stands, because LGD floors apply only under F-IRB; the output floor binds, so RWA become EUR 65.25 billion.

D. The modelled LGD is raised to the 25% floor; the output floor binds, so RWA become EUR 90 billion, the full standardised amount.

Question ORR-23 c.6

New • built from GARP Ch.23

The head of capital management at a eurozone G-SIB is preparing the fully phased-in output floor calculation. The bank's risk-weighted assets by risk type are (EUR billion):

Risk type	Approach approved	RWA, approved	RWA, SA only
Credit risk	A-IRB and F-IRB	480	760
Counterparty credit risk	internal model method	60	90
CVA risk	SA-CVA	30	30
Market risk	internal models approach	62	80
Operational risk	standardised approach	70	70

The "SA only" column uses the SA for credit risk, SA-CCR exposures with SA risk weights, SA-CVA, the SA for market risk and the SA for operational risk. The bank's leverage ratio exposure measure is EUR 2,400 billion. Which of the following is closest to the bank's total RWA after applying the output floor?

A. EUR 702.00 billion

B. EUR 721.00 billion

C. EUR 746.75 billion

D. EUR 778.25 billion

Question ORR-23 c.7

New • built from GARP Ch.23

A eurozone bank's supervisor uses the national discretion to cap the increase in risk-weighted assets caused by the output floor during its phase-in. Using the transitional schedule in the Basel Committee's December 2017 summary (Table 23.5), the bank's capital manager is computing the RWA that apply from 1 January 2026. The bank's RWA under its approved approaches are EUR 80 billion, its RWA using only the standardised approaches are EUR 150 billion, and its CET1 capital is EUR 9 billion. Which of the following is closest to the bank's RWA for 2026?

A. EUR 80.00 billion

B. EUR 100.00 billion

C. EUR 105.00 billion

D. EUR 108.75 billion

Solutions • ORR-23 c

Solution ORR-23 c.1

Answer: D

Bank Q721 • Schweser Module Quiz 64.1 Q5

Step 1 – What the floor compares

RWA must be the higher of (i) total RWA under the approaches the bank has approval to use and (ii) 72.5% of total RWA under the standardised approaches only.
⇒ Both legs are RWA, so the floor is a lower bound on risk-weighted assets.

Interpretation

Capital then follows from the ratio requirements applied to the floored RWA. The floor limits how far internal models can push RWA, and so capital, below the standardised level.

Why the other options are wrong

A is incorrect. Leverage is governed by the leverage ratio and the G-SIB leverage buffer, which use an exposure measure, not RWA.
B is incorrect. "Functional capital" is not a Basel concept.
C is incorrect. CVA risk is one of the risk types whose standardised approach feeds the floor; the floor itself applies to total RWA.

LO: ORR-23 c: Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Output Floor; SchweserNotes 2026 Book 3, Reading 64, LO 64.c

Solution ORR-23 c.2

Answer: C

New • built from GARP Ch.23

Step 1 – The Basel II floor

"The Basel II framework introduced an output floor based on Basel I capital requirements. That floor was calibrated at 80% of the relevant Basel I capital requirements." Its implementation "has been inconsistent across countries", because of differing interpretations and because it is based on Basel I standards that many banks and jurisdictions no longer apply.

Step 2 – The Basel III floor

It is "based on the revised Basel III standardised approaches": RWA are the higher of RWA under approved approaches and 72.5% of RWA under the standardised approaches only, phased in from 50%.
⇒ C states both halves correctly.

Interpretation

This is the C5 S3 comparison: two floors, two bases (Basel I against the revised standardised approaches), two calibrations (80% against 72.5%).

Why the other options are wrong

A is incorrect. The calibrations are swapped: 80% was the Basel II floor on Basel I; 72.5% is the new floor.
B is incorrect. Polarity flip: it is a floor, not a cap. RWA cannot fall *below* 72.5% of the standardised-only RWA.
D is incorrect. Scope error: the floor applies to total RWA of any bank using internal models. F-IRB banks still estimate PD themselves (and market risk models also count), so their modelled RWA can be well below the standardised figure.

LO: ORR-23 c: Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Output Floor and Table 23.5

Solution ORR-23 c.3 — Answer: C

Bank Q722 • Schweser Module Quiz 64.1 Q6

Step 1 – The floor uses standardised approaches only

For CVA risk GARP lists three options: "the standardised approach for CVA (SA-CVA), the Basic Approach (BA-CVA) or 100% of a bank's counterparty credit risk capital requirement (depending on which approach the bank is eligible for and uses for CVA risk)".

Step 2 – The odd one out

An IRB-type approach is internally modelled, so it cannot enter the second leg of the floor. In any case the December 2017 reforms removed internal modelling of CVA altogether.

Interpretation

The same logic covers every risk type: the floor's second leg never contains a model (Section 3).

Why the other options are wrong

A is incorrect. BA-CVA is a permitted approach for the floor calculation.
B is incorrect. SA-CVA is a permitted approach.
D is incorrect. 100% of the counterparty credit risk capital requirement is an explicitly permitted alternative.

LO: ORR-23 c: Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Output Floor (approaches); SchweserNotes 2026 Book 3, Reading 64, LO 64.c

Solution ORR-23 c.4 — Answer: B

Bank Q723 • bank-written, GARP style

Step 1 – The floor

$$72.5\% \times 900 = \text{USD } 652.5 \text{ billion}$$

Step 2 – The higher of the two

$$\text{RWA} = \max(600,\ 652.5) = \text{USD } 652.5 \text{ billion}$$

$\Rightarrow$ The floor binds: modelled RWA are only $600/900 = 66.7\%$ of the standardised figure, below 72.5%.

Interpretation

The models still save the bank USD 247.5 billion of RWA against the standardised approaches, but no more than 27.5% of the standardised figure.

Why the other options are wrong

A is incorrect. Ignores the floor; it exists to stop models taking RWA below 72.5% of the standardised result.
C is incorrect. Uses the 80% calibration of the old Basel II floor: $0.80 \times 900 = 720$.
D is incorrect. Treats the floor as 100% of standardised RWA.

LO: ORR-23 c: Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Output Floor

Solution ORR-23 c.5 **Answer: B**

Workbook A31.5 • S5

Step 1 – Input floor (parameter level)

Table 23.3: the unsecured corporate LGD floor is 25% under A-IRB. The bank's 20% estimate is raised to 25% before modelled RWA are computed.

Step 2 – Output floor (aggregate level)

$$72.5\% \times 90 = \text{EUR } 65.25 \text{ billion}, \qquad \text{RWA} = \max(60,\ 65.25) = \text{EUR } 65.25 \text{ billion}$$

$\Rightarrow$ The floor adds EUR 5.25 billion of RWA: the modelled approaches may lower RWA by at most 27.5% relative to the standardised approaches.

Interpretation

The two floors act at different levels: input floors constrain individual parameters inside the model; the output floor limits the total benefit of modelling. During the phase-in the floor would bind in 2026 ($70\% \times 90 = 63 > 60$) but not in 2025 ($65\% \times 90 = 58.5 < 60$); a supervisor using the transitional cap would limit RWA to $1.25 \times 60 = 75$, which does not bite here.

Why the other options are wrong

A is incorrect. Sibling swap of the base: 72.5% is applied to RWA under the standardised approaches, not to the bank's own modelled RWA ($72.5\% \times 60 = 43.5$).

C is incorrect. Sibling swap (F-IRB for A-IRB): LGD and EAD floors apply only under A-IRB (under F-IRB, LGD is supervisory anyway).

D is incorrect. Absolute claim: the floor does not require the full standardised amount; RWA are the higher of modelled RWA and 72.5% of standardised RWA.

LO: ORR-23 c: Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor. ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Specification of Input Floors, Output Floor, Transitional Arrangements, Tables 23.3 and 23.5

Solution ORR-23 c.6 **Answer: C**

New • built from GARP Ch.23

Step 1 – Total RWA under the approved approaches

$$480 + 60 + 30 + 62 + 70 = \text{EUR } 702 \text{ billion}$$

Step 2 – Total RWA under standardised approaches only

$$760 + 90 + 30 + 80 + 70 = \text{EUR } 1{,}030 \text{ billion}$$

$\Rightarrow$ Every line is recomputed on its standardised approach: SA credit, SA-CCR with SA weights, SA-CVA, SA market risk, SA operational risk.

Step 3 – Apply the aggregate floor

$$72.5\% \times 1{,}030 = 746.75, \qquad \text{RWA} = \max(702,\ 746.75) = \text{EUR } 746.75 \text{ billion}$$

$\Rightarrow$ Modelled RWA are $702/1{,}030 = 68.2\%$ of the standardised figure, so the floor binds and adds EUR 44.75 billion.

Interpretation

The floor is "aggregate": it compares totals. Applied line by line, each line is floored on its own, which can only give a higher number because a sum of maxima is never below the maximum of the sums. The leverage exposure measure is a red herring: it drives the leverage ratio, not RWA.

Why the other options are wrong

A is incorrect. Applied 72.5% to the modelled RWA: $72.5\% \times 702 = 508.95 < 702$, so the floor seems never to bind and RWA stay at 702.

B is incorrect. Used the 2026 phase-in percentage instead of the fully phased-in 72.5%: $\max(702,\ 70\% \times 1{,}030) = 721$.

D is incorrect. Floored each risk type separately: $\max(480, 551) + \max(60, 65.25) + 30 + \max(62, 58) + 70 = 551 + 65.25 + 30 + 62 + 70 = 778.25$.

LO: ORR-23 c: Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Output Floor (approaches to be used); Additional Enhancements (aggregate output floor)

Solution ORR-23 c.7 **Answer: B**

New • built from GARP Ch.23

Step 1 – Phase-in floor for 2026

Table 23.5 gives 70% from 1 January 2026:

$$70\% \times 150 = \text{EUR } 105 \text{ billion}, \qquad \max(80,\ 105) = 105$$

$\Rightarrow$ Without the cap the floor would lift RWA by 25, which is 31.25% of the pre-floor RWA.

Step 2 – Transitional cap

The increase is capped at 25% of RWA before the floor:

$$1.25 \times 80 = \text{EUR } 100 \text{ billion}$$

Step 3 – RWA for 2026

$$\text{RWA}_{2026} = \min(105,\ 100) = \text{EUR } 100 \text{ billion}$$

$\Rightarrow$ The cap binds: RWA rise by EUR 20 billion instead of 25.

Interpretation

The CET1 figure is a red herring for the RWA, but it shows the effect: the CET1 ratio falls from $9/80 = 11.25\%$ to $9/100 = 9.00\%$. The cap is removed on 1 January 2027, when the floor of $72.5\% \times 150 = 108.75$ applies in full.

Why the other options are wrong

A is incorrect. Treated the cap as switching the floor off: the cap limits the *increase* to 25%, it does not remove it.

C is incorrect. Ignored the transitional cap the supervisor has chosen to apply: $70\% \times 150 = 105$.

D is incorrect. Used the fully phased-in 72.5% and no cap: $72.5\% \times 150 = 108.75$, the 2027 figure.

LO: ORR-23 c: Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Output Floor, Transitional Arrangements, Table 23.5

OPERATIONAL RISK AND RESILIENCE • PART

P2

Second priority

Tier B topics, or LOs Vardeez flags inside a Very Important chapter. 16 LOs from 7 readings.

ORR-11 • Financial Crime and Fraud • Vardeez: VERY IMPORTANT

ORR-11 b

P2 CONCEPT

Summarize the regulatory findings and describe the lessons learned from the USAA case study.

Workbook: *none*

WHAT IS TESTED HERE

Why P2. No workbook section; Vardeez flags it in a Very Important chapter (ORR-11 is rated VERY IMPORTANT on the map). His notes label this LO "LO 50.b" (consolidated volume p.143): a weak AML programme for at least five years (2016 to 2021) that failed the Bank Secrecy Act minimums, with suspicious activity poorly monitored and reported; lessons on strong controls, trained AML staff, effective monitoring without unmanageable alerts, and the pandemic's remote transactions.

Reported exam shapes: none reported. The questions are built from the LO wording and Vardeez's points: why USAA was fined, what the regulators found, and which lessons follow.

What the questions look like: "which best explains the fine", with distractors borrowed from other scandals; "which lesson does this feature of the case support"; "which remedy would *not* address the findings". GARP PE1 Q44 is the model (Question ORR-11 b.2).

See also: the AML control framework and the risk-based approach are ORR-11 a; the chief AML/CFT officer and transaction monitoring under the Basel guidelines are ORR-10 a.

1. The case (GARP Box 11.2)

In March 2022 **USAA Federal Savings Bank** (FSB) was fined **USD 140 million** under two separate consent orders, with the **Financial Crimes Enforcement Network** (**FinCEN**) and the **Office of the Comptroller of the Currency** (**OCC**), for its "willful" failure to implement and maintain a Bank Secrecy Act/anti-money laundering (BSA/AML) compliance programme.

- **Period and admission.** From **January 2016 through April 2021** the bank admitted it failed to implement and maintain an AML programme that met the **minimum requirements of the BSA**.
- **Deficiencies** (OCC consent order): "inadequate internal controls and risk management practices; suspicious activity identification, evaluation, and reporting; staffing; training; and third-party risk management, among others".
- **Staffing** (FinCEN): the BSA/AML compliance department was "significantly understaffed", with shortages filled by **third-party contractors**. That practice is not unusual, especially under remediation deadlines; the failure was that the bank did not properly train them or ensure they had satisfactory qualifications and expertise.
- **Monitoring system.** A new transaction monitoring system introduced in the first quarter of 2021 proved "too sensitive" and created "an unmanageable number of alerts and cases": by the end of 2021 a backlog of about **90,000 unreviewed alerts and 6,900 unreviewed cases**, leading to "unreasonable delays in the detection and reporting of potentially suspicious activity".
- **The basis of the fine.** A **lack of control over AML risk**, not demonstrated laundering cases: a weak control environment is enough to warrant fines.

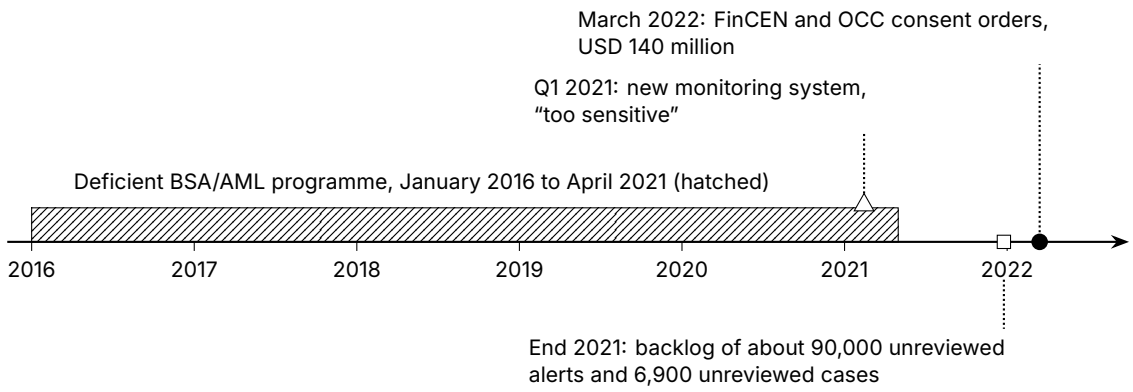


Figure 1. The USAA timeline. The hatched bar is the admitted deficiency period; the open triangle marks the new monitoring system, the open square the year-end backlog, the filled circle the consent orders. The fine came after years of weakness, not after a single event.

2. The wider picture GARP draws

- **Not only the US.** Banks in the EU, the UK and Asia have been fined, sometimes heavily, for being unable to demonstrate that their AML controls are properly designed and operate effectively. In 2020 Asia-Pacific authorities issued fines totalling **USD 5.1 billion** for breaches of AML laws and related misconduct, a **seven-fold** increase from 2019.
- **Lookbacks.** Regulatory findings and sanctions bring costly AML remediation programmes in which the bank must **review all client files for a specified period**, verify client information, file suspicious activity reports (the US term) and even close suspicious accounts.
- **Calibrating automation.** Automated detection and alerts are most useful in AML, but they need proper **parametrisation** and a **feedback loop on false positives and false negatives**, so that the institution and its models learn; without it, institutions fall behind their legal requirements.
- **The pandemic.** COVID-19 brought a rise in **remote transactions**, making anomalies *harder* to identify. AML and fraud controls must keep adapting to changing criminal tactics.

3. Lessons learned

Lesson	Evidence in the case	Control it maps to (ORR-11 a)
"Ignore regulatory findings at one's own peril"	Heavy fines "do not come out of the blue": they follow years of accumulated failings and procrastination; firms postpone uncomfortable changes until the last minute, which for USAA was too late.	Governance; deterrents work both ways
A weak control environment is enough	Fined for inadequate AML controls, not for any proven laundering or theft.	All four components
Staff the AML function and train it	Significant understaffing; contractors used without proper training or qualifications.	Prevention (training, allocation of responsibilities)
Calibrate monitoring to capacity	A "too sensitive" system left about 90,000 alerts and 6,900 cases unreviewed, delaying detection and reporting.	Detection
Oversee third parties	Third-party risk management cited among the deficiencies.	Selection and prevention
Adapt to the environment	Remote transactions since the pandemic make anomalies harder to spot.	Risk-based approach

Comparison card: ORR-11 b, the case in numbers and names

Who	USAA Federal Savings Bank (the banking arm of USAA)
Regulators	FinCEN and the OCC, two separate consent orders (not the Federal Reserve, not the SEC)
When and how much	March 2022; USD 140 million
Charge	"willful" failure to implement and maintain a BSA/AML compliance programme
Admitted period	January 2016 to April 2021: AML programme below BSA minimum requirements
Findings	internal controls and risk management; suspicious activity identification, evaluation and reporting; staffing; training; third-party risk management
Monitoring system	introduced Q1 2021, "too sensitive"; end-2021 backlog about 90,000 alerts and 6,900 cases
Basis	weak control environment, not demonstrated laundering
Headline lesson	"Ignore regulatory findings at one's own peril"

Exam traps

- **Borrowed scandals.** Options describing accounts opened without consent to meet sales targets, derivatives mis-sold to municipalities, or a group laundering for cartels are not USAA.
- **Proven laundering.** No theft or laundering case was the basis of the fine; the control failure was.
- **Polarity on the system.** It was too sensitive (too many alerts), not too lax; more alerts are not automatically better.
- **Contractors.** Using them was not the breach; failing to train and qualify them was.
- **Scope.** The deficiencies ran from 2016 to 2021 and went well beyond the 2021 system.
- **Pandemic.** Remote transactions made anomalies harder, not easier, to detect.

Practice questions: ORR-11 b

Question ORR-11 b.1

New • built from GARP Ch.11

A compliance analyst is summarising for her bank's audit committee the regulatory findings in the USAA Federal Savings Bank case of March 2022. Which of the following statements in her summary is correct?

A. FinCEN and the Federal Reserve fined the bank after finding that its retail accounts had been used to launder funds for a criminal network over several years.

B. The deficiencies were confined to a monitoring system introduced in 2021, which generated too few alerts for staff to detect the suspicious activity in time.

C. The bank admitted that from January 2016 to April 2021 its AML programme failed the BSA minimums, and its understaffed compliance team relied on untrained contractors.

D. The OCC judged the programme adequate in design; the fine related only to delays in filing suspicious activity reports caused by pandemic-era remote working.

Question ORR-11 b.2

Bank Q275 • GARP PE1 Q44 • Mock 3 Q36

A risk consultant is meeting with the senior management of a midsize bank to discuss ways in which the bank can improve its management of financial crime and fraud risk. The consultant uses the example of USAA Bank to explain how weaknesses in controls and processes can result in large losses as well as regulatory fines. Which of the following best explains the fine imposed by regulators on USAA Bank?

A. USAA Bank was fined after many retail bankers were found to have opened unwanted accounts for existing customers in order to meet performance incentives.

B. USAA Bank was fined for failing to correct deficiencies identified by regulators in its management and reporting of suspicious transactions after an extended period of time.

C. USAA Bank was fined after several subsidiaries were found to have laundered over USD 1 billion in funds belonging to large criminal organizations.

D. USAA Bank was fined after fraudulently marketing complex interest rate derivatives to large municipal clients by significantly understating their risk.

Question ORR-11 b.3

Bank Q273 • BT P2.T7.24.2.2 (rebuilt)

In March 2022, USAA Federal Savings Bank (FSB) was fined USD 140 million by FinCEN and the OCC for failing to implement and maintain a BSA/AML compliance program. Which of the following represents a key lesson learned from this case study?

A. Outsourcing risk management functions without proper oversight can improve compliance efficiency.

B. Training and staffing are secondary to the technology used in monitoring transactions.

C. Heavy regulatory fines are typically the result of years of accumulated failings and delay in acting on regulatory findings.

D. Regulatory fines are typically unpredictable and not linked to accumulated failings in AML programs.

Question ORR-11 b.4 Bank Q272 • AnalystPrep Q.5127 (rebuilt)

USAA Federal Savings Bank was fined USD 140 million by FinCEN and the OCC in March 2022 for an ineffective Bank Secrecy Act/anti-money laundering (BSA/AML) program. In 2021 the bank introduced a new transaction monitoring system that left roughly 90,000 unreviewed alerts and about 6,900 unreviewed cases by year-end. Which lesson from the case is most directly supported by this feature?

A. A more sensitive monitoring system is always preferable because more alerts mean better detection.

B. Automated monitoring should be calibrated so that alert volumes are manageable and can be reviewed and assessed in a timely way.

C. Regulators impose AML fines only after a specific theft or laundering case has been proven at the institution.

D. Using third-party contractors to review alerts removes the need to train staff in AML matters.

Question ORR-11 b.5 Bank Q274 • BT P2.T7.24.2.3 (rebuilt)

In response to the USAA FSB case, where the bank was fined USD 140 million by FinCEN and the OCC due to deficiencies in its BSA/AML compliance program, the board of Nicklewood Trustees is considering enhancing its control environment. Which of the following is NOT an appropriate solution to address the problems identified in the USAA case?

A. Conduct SOC (Service Organization Control) audits of third-party providers on an annual basis.

B. Provide AML training to any third-party contractors and verify their qualifications before they review alerts.

C. Increase the headcount of the compliance department from 2 staff to a team of 5.

D. Procure a transaction monitoring system that is highly sensitive, accepting a backlog of unreviewed alerts.

Question ORR-11 b.6 New • built from GARP Ch.11

After presenting the USAA case, the CRO of a Singapore bank asks the risk committee which conclusion GARP's case study supports. Which of the following conclusions is correct?

A. Regulatory findings often lead to costly lookbacks, in which the bank reviews all client files for a set period, verifies client data, files suspicious activity reports and may close accounts.

B. Fines of this kind are a US phenomenon; regulators in the EU, the UK and Asia act only once laundering through a bank has actually been demonstrated.

C. The use of third-party contractors to clear compliance workloads was itself the breach; banks facing alert backlogs should never use contractors for AML reviews.

D. The pandemic shift to remote transactions made anomalies easier to identify, because digital channels leave a fuller data trail than branch activity does.

Solutions • ORR-11 b

Solution ORR-11 b.1

Answer: C

New • built from GARP Ch.11

Step 1 – Who fined, and for what

FinCEN and the OCC, under two separate consent orders, fined USAA FSB USD 140 million in March 2022 for its "willful" failure to implement and maintain a BSA/AML compliance programme.

Step 2 – Period and admission

"From January 2016 through April 2021, USAA FSB admitted it failed to implement and maintain an AML program that met the minimum requirements of the BSA."

Step 3 – Staffing

FinCEN: the compliance department was "significantly understaffed", with shortages supplemented by third-party contractors whom the bank "failed to properly train".
$\Rightarrow$ C combines the admission and the staffing finding.

Step 4 – The 2021 system

The new system was "too sensitive" and created an unmanageable number of alerts and cases: about 90,000 unreviewed alerts and 6,900 unreviewed cases by the end of 2021.

Interpretation

The findings describe a programme-wide failure over more than five years: controls, suspicious activity reporting, staffing, training and third-party risk management. The 2021 system made a long-standing problem worse.

Why the other options are wrong

A is incorrect. Wrong regulator (the OCC, not the Federal Reserve) and wrong basis: the fine was for control failures, not for proven laundering.
B is incorrect. Polarity and scope: the system generated too *many* alerts, and the deficiencies ran from 2016, well before it.
D is incorrect. The OCC cited inadequate internal controls and risk management practices among other deficiencies; the pandemic point is GARP's wider context, not a finding against USAA.

LO: ORR-11 b: Summarize the regulatory findings and describe the lessons learned from the USAA case study. • **Reference:** GARP ORR Ch.11, Box 11.2

Solution ORR-11 b.2

Answer: B

Bank Q275 • GARP PE1 Q44

Step 1 – What the fine was for

A "willful" failure, from January 2016 through April 2021, to maintain a BSA/AML programme, with deficiencies including "suspicious activity identification, evaluation, and reporting". The fines were due to a lack of control over AML risk, "not because of demonstrated AML cases".

Step 2 – The time dimension

GARP's lesson: heavy fines "result from years of accumulated failings and procrastination about implementing the necessary changes and improvements required by regulators".
$\Rightarrow$ B, persistent uncorrected weaknesses in suspicious transaction management, is GARP's answer.

Interpretation

Every distractor is a real kind of scandal, just not this one. Hold on to two facts: the problem was AML controls, and it persisted for years.

Why the other options are wrong

A is incorrect. Unwanted accounts opened to meet sales incentives is a different (retail conduct) scandal.

C is incorrect. No laundering by subsidiaries was alleged; the fine was for control failures.

D is incorrect. Mis-selling derivatives to municipalities is unrelated to USAA.

LO: ORR-11 b: Summarize the regulatory findings and describe the lessons learned from the USAA case study. •
Reference: GARP ORR Ch.11, Case Study and Box 11.2; SchweserNotes 2026 Book 3, Reading 52, LO 52.b

Solution ORR-11 b.3 Answer: C

Bank Q273 • BT P2.T7.24.2.2

Step 1 – GARP's headline lesson

"Ignore regulatory findings at one's own peril." Heavy regulatory fines "do not come out of the blue: they result from years of accumulated failings and procrastination".

Step 2 – Why firms delay

Transformations are effortful and uncomfortable, so most firms postpone changes until the last minute, and "often this is too late, as in the case of USAA".

⇒ C states the lesson.

Interpretation

The deficiencies ran for more than five years before the 2022 consent orders. The practical lesson for a board: track regulatory findings to closure, because delay itself raises the eventual penalty.

Why the other options are wrong

A is incorrect. Unsupervised outsourcing made USAA's problems worse: its contractors were not properly trained.

B is incorrect. Staffing and training were cited deficiencies, and the new technology itself created the backlog.

D is incorrect. The opposite of the case: the fine was the predictable result of accumulated failings.

LO: ORR-11 b: Summarize the regulatory findings and describe the lessons learned from the USAA case study. •
Reference: GARP ORR Ch.11, Box 11.2

Solution ORR-11 b.4 Answer: B

Bank Q272 • AnalystPrep Q.5127

Step 1 – What the feature shows

The 2021 system was "too sensitive" and created "an unmanageable number of alerts and cases"; the backlog led "to unreasonable delays in the detection and reporting of potentially suspicious activity".

Step 2 – The general lesson

Detection systems need proper parametrisation and a feedback loop on false positives and false negatives; the number of alerts must be manageable, with adequate monitoring, assessment and feedback.

⇒ B is the lesson this feature supports.

Interpretation

An alert nobody reviews is not a control. Sensitivity without review capacity weakens detection,

because genuine suspicious activity waits in the queue with the false positives.

Why the other options are wrong

A is incorrect. The opposite of the lesson: excess sensitivity created the backlog.
C is incorrect. The fine was for an inadequate AML programme, not a proven theft or laundering case.
D is incorrect. USAA used contractors because it was understaffed and failed to train them; that made matters worse.

LO: ORR-11 b: Summarize the regulatory findings and describe the lessons learned from the USAA case study. •
Reference: GARP ORR Ch.11, Case Study and Box 11.2

Solution ORR-11 b.5 — Answer: D

Bank Q274 • BT P2.T7.24.2.3

Step 1 – List the findings to remedy

Understaffed compliance; untrained, unqualified contractors; weak third-party risk management; a monitoring system producing about 90,000 unreviewed alerts.

Step 2 – Test each option

SOC audits of third-party providers address third-party risk management (A). Training and qualifying contractors addresses the contractor failure (B). More compliance staff addresses understaffing (C). A highly sensitive system with an accepted backlog repeats the failure (D).
⇒ D is not an appropriate solution.

Interpretation

A "NOT" question built from the findings list: three options fix a finding, one reproduces it. The giveaway is "accepting a backlog".

Why the other options are wrong

A is incorrect. Appropriate: third-party risk management was among the deficiencies the OCC cited.
B is incorrect. Appropriate: USAA failed to train its contractors or ensure their qualifications.
C is incorrect. Appropriate: the compliance department was significantly understaffed.

LO: ORR-11 b: Summarize the regulatory findings and describe the lessons learned from the USAA case study. •
Reference: GARP ORR Ch.11, Box 11.2

Solution ORR-11 b.6 — Answer: A

New • built from GARP Ch.11

Step 1 – Lookbacks

"Regulatory findings and sanctions mean costly AML remediation programs, often called lookbacks, in which the bank must review all client files for a specified period, verify client information, file suspicious activity reports ... and even close suspicious accounts."
⇒ A restates GARP.

Step 2 – Beyond the US

"Banks in the EU, the UK, and Asia have been fined, sometimes heavily, for being unable to demonstrate that their AML controls have been properly designed and operate effectively." Asia-Pacific fines reached USD 5.1 billion in 2020, seven times the 2019 level.

Step 3 – Contractors and the pandemic

Supplementing staff with contractors "is not unusual in banking", especially under remediation deadlines; USAA's failure was not training them. The rise in remote transactions made anomalies

harder to identify.

Interpretation

The case sits inside a global trend: regulators everywhere fine banks that cannot *demonstrate* effective controls, and the remediation that follows is often costlier than the fine.

Why the other options are wrong

B is incorrect. Polarity flip: regulators in the EU, the UK and Asia also fine for undemonstrated controls, without proven laundering.

C is incorrect. Absolute claim: the use of contractors was not the breach; the lack of training and qualifications was.

D is incorrect. Polarity flip: remote transactions made anomalies more difficult to identify.

LO: ORR-11 b: Summarize the regulatory findings and describe the lessons learned from the USAA case study. • **Reference:** GARP ORR Ch.11, Case Study and Box 11.2

ORR-12 • Guidance on Managing Outsourcing Risk • Vardeez: VERY IMPORTANT

ORR-12 a

P2 CONCEPT

Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk.

Workbook: D2 Outsourcing and Third-Party Risk • Tier D

WHAT IS TESTED HERE

Why P2. Vardeez rates ORR-12 VERY IMPORTANT: it is theme 1 of his ORR list (TPRM, AML and outsourcing), ROI rank 18 of 55 in the consolidated volume. The best workbook coverage is Tier D (D2, topic map #51, 3 of 16 sources).

Vardeez: his notes label this LO "LO 51.a" (consolidated volume p.82): a table of the six risks that outsourcing opens, then the first two programme elements (risk assessment, due diligence). His notes stop there; the rest of the programme below comes from GARP Ch.12 (Federal Reserve SR 13-19).

Reported exam shapes

- **S1** Outsource the activity, never the accountability, applied to a vendor and subcontractor failure.

What the questions look like: short scenarios that ask you to name one of the six risks, to order or scale the programme elements (what comes first, what is proportionate), to judge an incentive scheme in an outsourced sales contract, and the standing trap: a contract clause or indemnity said to move the board's accountability to the provider.

See also: workbook D2.2 also tags this LO; it is worked under ORR-4 g (concentration in a critical provider and resilience). Due diligence is ORR-12 b, contract provisions ORR-12 c, the TPRM life cycle and the case studies ORR-13.

1. What outsourcing changes

The reading is the Federal Reserve's supervisory letter SR 13-19/CA 13-21 (December 2013). Banks outsource far more than core processing and IT: accounting, appraisal management, internal audit, human resources, sales and marketing, loan review, asset and wealth management, procurement and loan servicing. A **service provider** is any entity with a contract to provide business functions or activities: bank or nonbank, affiliated or not, regulated or not, domestic or foreign.

Some risks are *inherent to the activity*; others are *introduced by the provider*. Unmanaged, they lead to regulatory action, financial loss, litigation and loss of reputation. ORR-5 gives the net view: handing a process to a better-controlled specialist (payments, a cloud data centre) can lower operational risk at a higher cost, while outsourcing to cut cost tends to add risk. Either way the firm takes on **third-party risk**, the risk of failed controls at the provider. Outsourcing is increasingly seen as **risk sharing** rather than risk transfer, and reputational damage cannot really be outsourced.

2. Six risks a service provider brings

The guidance asks institutions to consider six risks before entering into, and while managing, an outsourcing arrangement:

Risk	Arises when (SR 13-19)	Cue in a stem
Compliance	the provider's services, products or activities fail to comply with applicable U.S. laws and regulations	provider breaks a labour, privacy or consumer law
Concentration	outsourced services are provided by a limited number of providers, or are concentrated in limited geographic locations	one provider or one region behind several critical services
Reputational	the provider's actions or poor performance lead the public to form a negative opinion of the institution	public criticism, substandard service
Country	a foreign-based provider exposes the institution to economic, social and political conditions and events in its country	unrest, crisis or law change where the provider sits
Operational	the provider causes losses through inadequate or failed internal processes or systems, external events or human error	glitch, processing error, failed control
Legal	the provider exposes the institution to legal expenses and possible lawsuits	customers sue after the provider's negligence

Classify by *how the risk arises*, not by what follows. A systems glitch at a French provider is operational risk; it becomes country risk only if conditions in France cause the loss. Credit, market and counterparty risk are not on the list (a common distractor), and "outsourcing risk" is the umbrella, not one of the six.

3. The activity moves, the accountability does not (shape S1)

> "The use of service providers does not relieve a financial institution's board of directors and senior management of their responsibility to ensure that outsourced activities are conducted in a safe-and-sound manner and in compliance with applicable laws and regulations."

- **Board of directors** (or an executive committee of the board): establishes and approves the policies that set up the service provider risk management programme (risk assessments and due diligence, standards for contract provisions, ongoing monitoring, business continuity and contingency planning).
- **Senior management**: makes sure the board-approved policies are executed, builds the risk management and reporting framework, and reports regularly to the board on adherence.
- **Contracts allocate duties, not accountability.** The subcontracting provision (ORR-12 c) makes the primary provider accountable *to the institution* for its subcontractors. It does not move the institution's accountability to its customers and supervisors. The Morgan Stanley case (ORR-13 b) is the textbook illustration: the OCC fined the bank, not its decommissioning vendors.

4. The programme: risk-focused, six core elements

The programme should provide oversight and controls **commensurate with the level of risk**. It concentrates on outsourced activities that have a substantial impact on financial condition, are critical to ongoing operations, involve sensitive customer information or new products or services, or pose material compliance risk. Its depth and formality depend on the **criticality, complexity and number** of material activities outsourced: a community bank with a few critical activities placed with highly

reputable providers may run a simpler programme with fewer elements; an institution with hundreds or thousands of providers needs many more.

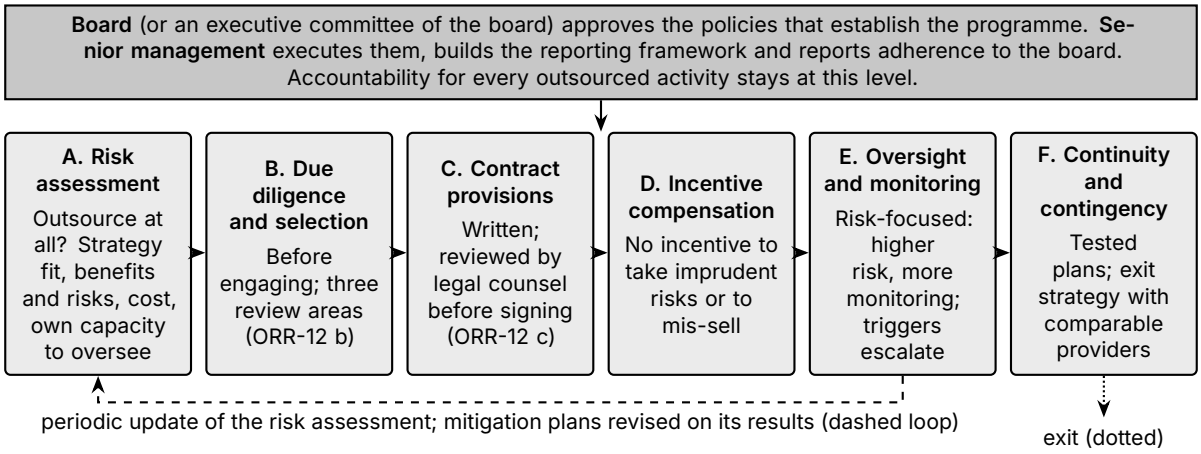


Figure 1. The SR 13-19 programme in the order a relationship meets its elements, under board and senior management governance (dark bar). The dashed loop is the periodic update of the risk assessment; the dotted arrow is the exit path. The risks managed are the six of Section 2.

- **A. Risk assessment, first.** It is "fundamental to the decision of whether or not to outsource". First decide whether outsourcing fits the strategic direction; then weigh the benefits and risks of the activity, the service provider risk and the cost; check that qualified, experienced providers exist; and judge whether the institution has the expertise to oversee the relationship. Update the assessment at appropriate intervals and revise the risk mitigation plans on its results (assessment drives mitigation, not the reverse).
- **D. Incentive compensation review.** An effective process to review and approve incentives embedded in provider contracts. A provider that sells on the institution's behalf represents it, so variable fees or commissions that steer customers to higher-margin products without regard to suitability are inappropriate: they bring reputational damage and litigation (link: ORR-14, suitability).
- **E. Oversight and monitoring.** Performance metrics set by the business line or relationship management; overseers with the expertise and stature to manage the arrangement. Higher-risk providers, and those showing performance, financial, compliance or control concerns, get more frequent and stringent monitoring, a designated point of contact and tailored mitigation plans; lower-risk providers get less. Monitor financial condition (and the provider's controls over subcontractors it relies on) and, for significant relationships, the control environment (SOC 2 report; FFIEC report for technology providers). Escalation triggers lead to more stringent monitoring, on-site reviews, use of the right to audit, and criteria for alternative arrangements and termination.
- **F. Business continuity and contingency.** Focus on critical services: ensure a disaster recovery and business continuity plan exists for the contracted service, assess its adequacy and its alignment with the institution's own plan, document who maintains and tests it, test it periodically, and keep an **exit strategy** with a pool of comparable providers.

5. Additional risk considerations

- **Suspicious activity reporting (SAR):** the confidentiality required by the Bank Secrecy Act makes outsourcing any SAR function more complex; identify and monitor those risks.
- **Foreign-based providers:** must comply with applicable U.S. laws; consider the institution's ability to perform on-site reviews and the access home-country supervisors may gain to its customer information.
- **Internal audit:** the Sarbanes-Oxley Act of 2002 bars a registered public accounting firm from certain non-audit services for a public company it audits.
- **Risk management activities** (aspects of interest rate risk and model risk management) *may* be outsourced; require developmental evidence on design and intended use, and validation services consistent with SR 11-7 (ORR-15).

Summary card: ORR-12 a

Six risks	compliance, concentration, reputational, country, operational, legal
Governance	board approves policies; senior management executes and reports; neither is relieved of responsibility
Risk focus	activities with substantial financial impact, critical to operations, involving sensitive customer data or new products, or with material compliance risk
Proportionality	depth and formality scale with criticality, complexity and number of material outsourced activities
Six elements	A risk assessment; B due diligence and selection; C contract provisions; D incentive compensation review; E oversight and monitoring; F business continuity and contingency
Order	risk assessment first; due diligence before engagement; mitigation revised after each updated assessment

Exam traps

- **Role misassignment.** A contract, indemnity or subcontracting clause never moves the board's and senior management's accountability to the provider, the subcontractor or the supervisor.
- **Absolute claim.** Outsourcing does not eliminate or fully mitigate operational risk; it adds third-party risk and is better seen as risk sharing.
- **Wrong risk family.** Credit, market and counterparty risk are not among the six.
- **Cause versus consequence.** A glitch at a foreign provider is operational; country risk needs conditions in the provider's country.
- **Sequence.** Risk assessment comes first; mitigation plans follow updated assessments, not the other way round.
- **Polarity on oversight.** Higher-risk or critical providers get more frequent and stringent monitoring, whatever their reputation.
- **Absolute ban.** Risk management activities may be outsourced, under SR 11-7 standards.
- **Who owns the plan.** The provider keeps its own continuity plan; the institution assesses and tests it and plans alternatives and an exit.

Practice questions: ORR-12 a

Question ORR-12 a.1

Bank Q277 • AP Mock 3 Q4

A bank based in Texas, USA, is considering outsourcing its human resource activities to an HR agency. Its risk management team is considering all potential risks that could arise from this arrangement, particularly compliance risks. Which of the following would qualify as a compliance risk?

A. Advertising jobs without regard to existing labor laws.

B. Negative public opinion because of poor performance of outsourced activities.

C. Acceptance of fake academic documents.

D. Delays in service delivery.

Question ORR-12 a.2

Bank Q284 • Schweser Module Quiz 53.1 Q1

Bank, Inc. (Bank) operates in the United States and has a service contract in place with Service Co. (Service), which operates in France. Service manages a significant amount of confidential customer data for Bank, and recently a computer glitch at Service resulted in the accidental public disclosure of confidential customer data. As a result of the data breach, which of the following risks is Bank least likely to face?

A. Compliance risk.

B. Country risk.

C. Legal risk.

D. Operational risk.

Question ORR-12 a.3

Bank Q285 • Schweser Module Quiz 53.1 Q2 (rebuilt)

Which of the following statements regarding a financial institution's risk management program for outsourcing to third-party service providers is most accurate?

A. The program should focus primarily on business continuity and contingency plans, because service provider failure is the dominant risk.

B. The program should apply the same level of oversight and controls to every outsourced activity, regardless of its materiality.

C. The depth and complexity of the program can be relatively low when there are few outsourced activities and the service providers are established and reliable.

D. Risk assessments should be updated as a result of updated risk mitigation techniques on a sufficiently regular basis.

Question ORR-12 a.4 Bank Q281 • AnalystPrep Q.2327 (rebuilt)

Fort Worth Bank is considering outsourcing its retail loan collection process to ICAP, a service provider in Mexico. Which of the following should the bank's risk management team do *first*?

A. Perform due diligence on ICAP's financial condition and internal controls.

B. Negotiate contract provisions on confidentiality, audit rights and termination.

C. Perform a risk assessment to decide whether the activity is best executed in-house or by a third party.

D. Establish ongoing monitoring of ICAP's performance and its business continuity plan.

Question ORR-12 a.5 Bank Q282 • BT P2.T7.811.2

Cityace Bank is a financial institution that is outsourcing a vital customer-facing function to a third-party service provider. Cityace wants to follow the Board's Guidance on Managing Outsourcing Risk. If Cityace follows the guidance, each of the following is true EXCEPT which one?

A. Cityace should avoid outsourcing risk management activities, especially interest rate risk and model risk, because these are core competencies.

B. If the service provider is foreign-based, Cityace should ensure the provider is in compliance with applicable U.S. laws, regulations, and regulatory guidance.

C. Cityace should ensure an effective process is in place to review and approve any incentive compensation that may be embedded in service provider contracts.

D. Cityace should consider especially the following risks in outsourcing: compliance risks, concentration risks, reputational risks, country risks, operational risks, and legal risks.

Question ORR-12 a.6 Bank Q283 • GARP PE1 Q49 (rebuilt)

The senior management team of a small regional bank has established a committee to review procedures related to entering into significant contracts with third-party vendors. The committee is reviewing one proposed relationship with a vendor who would have significant responsibility for marketing the bank's financial products to potential customers. In establishing policies to reduce the operational risk associated with this vendor contract, which of the following recommendations would be most appropriate?

A. The bank should ensure an effective process exists to review and approve any incentive compensation embedded in the vendor contract, considering whether it could encourage imprudent selling.

B. The bank should ensure that the vendor's sales representatives are compensated mainly with commissions from the sale of the bank's products.

C. The bank should prevent the third-party vendor from having access to any of its critical processes.

D. The bank should be responsible for developing the vendor's contingency planning process to mitigate risk exposure to the vendor.

Question ORR-12 a.7 Workbook D2.1 • S1 • Map #51

The chief compliance officer of an Australian wealth manager is briefing the board after a vendor engaged to decommission two client data servers passed the work to a subcontractor, and the hardware was later resold with client data still on it. The firm had not assessed the subcontractor and kept no inventory of the client data held on the servers. The CEO argues that because the master services agreement transferred the decommissioning task, and states that the vendor has overall accountability for its subcontractors, the regulatory exposure now sits with the vendor. Which of the following statements should the CCO include in the briefing?

A. Because the agreement gives the vendor overall accountability for its subcontractors, the firm's own accountability to its clients and its regulator for the breach passes to the vendor.

B. Outsourcing the decommissioning to a specialist eliminated the operational risk of the activity for the firm, leaving only the vendor's performance against the contract to be managed.

C. As decommissioning is infrequent and done by a specialist, lighter oversight than for routine processes was appropriate, so not reviewing the subcontractor was a proportionate choice.

D. Outsourcing can transfer the task and some of its operational risk, but the board and senior management remain responsible for its safe and lawful conduct; the accountability is not transferable.

Solutions • ORR-12 a

Solution ORR-12 a.1

Answer: A

Bank Q277 • AP Mock 3 Q4

Step 1 – The definition

SR 13-19: compliance risks arise when the services, products or activities of a service provider fail to comply with applicable U.S. laws and regulations.
⇒ The test is whether the provider's own conduct breaks a law or regulation.

Step 2 – Classify each option

Advertising jobs in disregard of labour laws is a breach of law by the provider: compliance. Negative public opinion is reputational. Accepting fake documents and delivery delays are failed processes or human error: operational.

Interpretation

Name a risk by how it arises, not by what follows. The labour-law breach may later bring lawsuits (legal) and bad press (reputational), but what defines it is non-compliance with law, and the bank answers for it even though the HR agency committed it.

Why the other options are wrong

B is incorrect. Reputational risk: the provider's poor performance leads the public to form a negative opinion of the bank.
C is incorrect. Operational risk: a failed screening process or human error at the provider, not a breach of law.
D is incorrect. Operational risk: an execution failure through inadequate processes, not a regulatory breach.

LO: ORR-12 a: Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.2 Risks from the Use of Service Providers); SchweserNotes 2026 Book 3, Reading 53, LO 53.a

Solution ORR-12 a.2

Answer: B

Bank Q284 • Schweser Module Quiz 53.1 Q1

Step 1 – What caused the loss

A computer glitch at Service disclosed the data: a failed system at the provider.
⇒ Operational risk has materialised.

Step 2 – What follows from it

Disclosing confidential customer data can breach privacy rules (compliance risk) and invites lawsuits from affected customers (legal risk).

Step 3 – Test country risk

Country risk arises from the economic, social and political conditions and events in the provider's country. Nothing in the stem comes from conditions in France.
⇒ Country risk is the least likely of the four.

Interpretation

Using a French provider creates a standing country-risk exposure that the bank's risk assessment must cover, but this loss did not arise through it. Had the stem described unrest in France disrupting Service, or French rules blocking the bank's access to its data, country risk would be the answer to look for.

Why the other options are wrong

A is incorrect. Likely: disclosure of confidential customer data can breach privacy laws and regulations.
C is incorrect. Likely: affected customers may sue the bank, creating legal expense.
D is incorrect. Likely: the glitch is a failed system at the provider, the definition of operational risk.

LO: ORR-12 a: Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.2); SchweserNotes 2026 Book 3, Reading 53, Module Quiz 53.1

Solution ORR-12 a.3 Answer: C

Bank Q285 • Schweser Module Quiz 53.1 Q2

Step 1 – The programme is risk-focused

Oversight and controls are commensurate with the level of risk, concentrated on activities with a substantial impact on financial condition, critical to operations, involving sensitive customer information or new products, or posing material compliance risk.

Step 2 – Depth scales with exposure

Depth and formality depend on the criticality, complexity and number of material activities outsourced. A community bank with a few critical activities placed with highly reputable providers may use a simpler programme with fewer elements.
⇒ Statement C is the guidance's own example.

Step 3 – Direction of updates

The risk assessment is updated at appropriate intervals; mitigation plans are revised on the results of the updated assessment.

Interpretation

Proportionality cuts both ways: a bank with hundreds or thousands of material providers needs many more elements and considerations. (The original bank key was corrected to C when the question was rebuilt; the original option A is not the guidance's emphasis.)

Why the other options are wrong

A is incorrect. Business continuity is one of six elements. The programme covers all six, and the risk assessment is the fundamental first step.
B is incorrect. Ignores the risk focus: oversight is concentrated on material, critical or sensitive activities, not applied uniformly.
D is incorrect. Reverses the causality: mitigation plans are revised as a result of updated risk assessments.

LO: ORR-12 a: Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 Service Provider Risk Management Programs and 12.4 A); SchweserNotes 2026 Book 3, Reading 53, LO 53.a

Solution ORR-12 a.4 Answer: C

Bank Q281 • AnalystPrep Q.2327

Step 1 – Which element comes first

Risk assessment of the activity, and of doing it in-house against outsourcing it, is "fundamental to the decision of whether or not to outsource". The bank first checks consistency with its strategy, then weighs benefits, risks, provider risk and cost, the availability of qualified providers and its

own capacity to oversee the relationship.
⇒ Until outsourcing is judged appropriate, there is no provider to vet, contract with or monitor.

Step 2 – The rest follows

Due diligence and selection (B), contract provisions (C), oversight (E) and continuity planning (F) presuppose the decision to outsource and a chosen provider.

Interpretation

A Mexican provider adds country risk, and U.S. laws (debt-collection and privacy rules among them) still apply to the collection activity. That is exactly what the initial risk assessment must weigh before ICAP is even shortlisted.

Why the other options are wrong

A is incorrect. Due diligence is the second element, performed on a prospective provider after the outsourcing decision.
B is incorrect. Contract terms are negotiated only after a provider has been selected.
D is incorrect. Ongoing monitoring and contingency arrangements apply once the relationship is in place.

LO: ORR-12 a: Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 A Risk Assessments); SchweserNotes 2026 Book 3, Reading 53, LO 53.a

Solution ORR-12 a.5 **Answer: A**

Bank Q282 • BT P2.T7.811.2

Step 1 – Risk management activities

Section G of the guidance: institutions *may* outsource risk management activities such as aspects of interest rate risk and model risk management. They should require evidence on the product's components, design and intended use, and ensure that providers of model risk services such as validation follow existing model risk guidance (SR 11-7).
⇒ A prohibition is not in the guidance: statement A is the exception.

Step 2 – Check the other three

B: foreign-based providers must comply with applicable U.S. laws, regulations and guidance (section G). C: element D, incentive compensation review. D: the six risks of section 12.2.

Interpretation

EXCEPT questions on this reading usually plant one absolute prohibition. The guidance manages risk; it does not forbid categories of outsourcing.

Why the other options are wrong

B is incorrect. True: compliance of foreign-based providers with U.S. law is an additional risk consideration.
C is incorrect. True: an effective process to review and approve embedded incentive compensation is a core element.
D is incorrect. True: these are the six risks the guidance lists.

LO: ORR-12 a: Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.2, 12.4 D and G Additional Risk Considerations)

Solution ORR-12 a.6 Answer: A

Bank Q283 • GARP PE1 Q49

Step 1 – What the vendor does

The vendor markets the bank's products: it sells on the bank's behalf and so represents the bank to customers.

⇒ Its incentives shape the bank's conduct risk.

Step 2 – Element D of the programme

The institution should have an effective process to review and approve any incentive compensation embedded in provider contracts, asking whether the incentives might encourage imprudent risk. The guidance's example of an inappropriate incentive: variable fees or commissions that steer customers to higher-margin products without due consideration of suitability.

Interpretation

Mis-selling by the vendor would bring reputational damage, litigation and regulatory action to the bank, which keeps the accountability (Section 3). Reviewing the incentive structure attacks the cause.

Why the other options are wrong

B is incorrect. Commission-heavy pay is the very incentive the guidance warns may drive unsuitable selling.

C is incorrect. A blanket ban is not required: access is managed through due diligence, information limited to what the service needs, and monitoring.

D is incorrect. The provider maintains its own contingency plans; the bank assesses and tests them and plans alternatives for critical services (element F).

LO: ORR-12 a: Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 D Incentive Compensation Review and F)

Solution ORR-12 a.7 Answer: D

Workbook D2.1 • S1

Step 1 – What the contract can and cannot do

The subcontracting provision makes the primary provider accountable to the firm for services delivered by its subcontractors. SR 13-19 is explicit that the use of service providers does not relieve the board and senior management of responsibility for safe-and-sound, lawful conduct of the outsourced activity.

⇒ The clause allocates duties between the two companies; it does not move the firm's accountability to its clients or its regulator.

Step 2 – Compare with the GARP case

The facts mirror the Morgan Stanley case: the OCC fined the bank USD 60 million for failing to assess the risks of decommissioning, to assess vendors including subcontractors, and to keep an inventory of customer data stored on the devices. The case's stated lesson is that outsourcing may transfer some operational risk, but accountability is not transferable.

Step 3 – What the programme required

The activity involved sensitive customer information, which puts it squarely inside the risk-focused part of the programme: due diligence that covers subcontractors, contract terms on data security, return and destruction, and monitoring scaled to the risk.

Interpretation

D is correct. The CCO should tell the board that the firm owns the breach, must remediate

(customer notification, data inventory, subcontractor due diligence standards in vendor contracts), and may pursue the vendor contractually, for example under indemnification, without that changing who answers to the regulator.

Why the other options are wrong

A is incorrect. Role misassignment: the subcontracting clause makes the vendor accountable to the firm for its subcontractors; it does not transfer the firm's accountability to clients and regulators, which remains with its board and senior management.

B is incorrect. Absolute claim: contracting with a third party does not fully mitigate operational risk; it adds third-party risk, and outsourcing is better seen as risk sharing than risk transfer.

C is incorrect. Polarity flip: the programme is risk-focused on activities that involve sensitive customer information or are critical; such activities call for more rigorous due diligence and monitoring, including of subcontractors, not less.

LO: ORR-12 a: Explain how risks can arise through outsourcing activities to third-party service providers and describe elements of an effective program to manage outsourcing risk. ORR-12 c: Describe topics and provisions that should be addressed in a contract with a third-party service provider. ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. ORR-13 b: Describe the lessons learned from the presented case studies. • **Reference:** Federal Reserve SR 13-19 (GARP ORR Ch.12, 12.3 and 12.4 C, Subcontracting); GARP ORR Ch.13, OCC Fines Morgan Stanley; Ch.5, 5.1 Risk Response

ORR-12 • Guidance on Managing Outsourcing Risk • Vardeez: VERY IMPORTANT

ORR-12 b

P2 CONCEPT

Explain how financial institutions should perform due diligence on third-party service providers.

Workbook: *none*

WHAT IS TESTED HERE

Why P2. Vardeez flags it inside a VERY IMPORTANT chapter (ORR-12, theme 1 of his ORR list). Schweser's exam focus for the reading: "focus on the three broad areas of due diligence".
Vardeez: his notes label this LO "LO 51.b" (consolidated volume p.82): a checklist under the three headings (business background and strategy, financial performance, operations and internal controls).

Reported exam shapes: none reported. The questions below are built from the LO wording and Vardeez's checklist.

What the questions look like: file an item under its review area (insurance, sustainability, the business model's resiliency, record keeping); spot the item that is not on the list (ESG performance, the provider's other clients); and judge when and how deep due diligence must go (before engagement, proportionate, never waived).

1. When, and how deep

Due diligence is element B of the programme (ORR-12 a, Figure 1): it follows the risk assessment and comes **before** the institution engages the provider.

- **Depth and formality vary** with the scope, complexity and importance of the planned arrangement, the institution's familiarity with the prospective provider, and the provider's reputation and industry standing. Familiarity and reputation can make the review lighter; they never make it unnecessary.
- **Who takes part:** the institution's technical experts and key stakeholders are engaged in the review and approval process as needed.
- **Why:** the institution remains responsible for ensuring that the provider's services comply with laws and regulations and are consistent with safe-and-sound banking practices.

ORR-13 a reaches the same point from the TPRM side: stage 2 of the life cycle (evaluation, risk rating and due diligence) is proportionate, so a consultant delivering two days of training gets far lighter checks than a cloud company hosting sensitive data, and standard questionnaires (SIG) help.

2. The three review areas

1. Business background, reputation and strategy	2. Financial performance and condition	3. Operations and internal controls
Who are they, and will the model last?	*Can they afford to deliver for the whole contract?*	*How do they run the work day to day?*
Status in the industry, corporate history, qualifications	Provider *and closely related affiliates*	Adequacy of standards, policies and procedures:

1. Business background, reputation and strategy	2. Financial performance and condition	3. Operations and internal controls
Background and reputation of the provider and its principals	Latest financial statements and annual report: outstanding commitments, capital strength, liquidity, operating results	internal controls; facilities management
A background-check programme for its employees	Sustainability: time in business, growth of market share for the service	training, including compliance training
Experience in the proposed service	Impact of *the institution's* business on the provider's financial condition	security of systems (data, equipment); privacy of the institution's confidential information
Business model: strategy and mission, service philosophy, quality initiatives, policies	Commitment of financial and staff resources for the contract's duration	maintenance and retention of records; business resumption and contingency planning
Resiliency and adaptability of the business model (future viability)	Adequacy of **insurance** coverage	systems development and maintenance; service support and delivery
References; required licences and certifications	Adequacy of the provider's review of **subcontractors'** financial condition	employee background checks
Pending legal or compliance issues: litigation, regulatory actions, complaints	Other current issues that could affect future performance	adherence to laws, regulations and supervisory guidance

Sorting rules that settle most questions.

- **Insurance** is financial (area 2). Insurance also appears later as a *contract* provision (ORR-12 c); in due diligence it is part of the financial review.
- **Staying power is split.** Time in business and market-share growth are *financial sustainability* (area 2); the resiliency and adaptability of the *business model* are strategy (area 1).
- **Background checks appear twice**: that a check programme exists (area 1), and that checks are actually performed in operations (area 3).
- **Direction of the impact item:** the effect of *the institution's* business on the provider's finances. The effect of the provider's other clients on the institution is not on the list.
- **Not on the list at all:** ESG or environmental performance, or a country-risk review in place of the financial review.
- **Oversight and monitoring** is a separate programme element (E), not a due diligence area.

Summary card: ORR-12 b

Timing	before engaging the provider (programme element B, after the risk assessment)
Depth	scope, complexity, importance; familiarity with the provider; its reputation and industry standing
People	technical experts and key stakeholders in review and approval
Area 1	business background, reputation and strategy (history, principals, references, licences, litigation, model and its resiliency)
Area 2	financial performance and condition (statements, sustainability, impact of the relationship, commitment, insurance, subcontractor review)
Area 3	operations and internal controls (controls, facilities, training, security, privacy, records, continuity, systems, service, background checks, legal compliance)

Exam traps

- **Timing.** Due diligence is done before engagement, not after signing or during onboarding.
- **Absolute waiver.** A familiar or reputable provider gets a lighter review, never none.
- **Area swap.** Insurance and sustainability are financial; the business model's resiliency is strategy; training and record keeping are operations.
- **Partial scope.** All three areas are reviewed; a strong balance sheet does not excuse the operations review.
- **Reversed direction.** The financial review looks at the institution's effect on the provider, not the provider's other clients' effect on the institution.
- **Element versus area.** Oversight and monitoring is a programme element, not part of due diligence.

Practice questions: ORR-12 b

Question ORR-12 b.1 Bank Q286 • AnalystPrep Q.2325 (rebuilt)

An American bank is considering outsourcing its IT operations to an Indian IT provider. Is it appropriate for the bank's risk management team to analyze the provider's financial condition before making a final decision?

A. No, because the bank should only be concerned with country risk.

B. No, because it is illegal to outsource IT services in the first place.

C. Yes, in order to assess the financial stability and viability of the service provider.

D. Yes, because it is a requirement under Basel II regulation.

Question ORR-12 b.2 Bank Q290 • Schweser Module Quiz 53.1 Q3

When performing due diligence on a service provider, ascertaining the sufficiency of its insurance coverage would most appropriately be covered under which of the following categories?

A. Business background, reputation and strategy.

B. Financial performance and condition.

C. Operations and internal controls.

D. Oversight and monitoring.

Question ORR-12 b.3 Bank Q287 • AnalystPrep Q.2329

A bank in Palermo, Italy is considering outsourcing its IT services and is preparing a review of the financial condition of IAM Systems, a local service provider. Which of the following would *not* form part of the financial review process?

A. The adequacy of the service provider's insurance coverage.

B. The adequacy of the service provider's review of the financial condition of any subcontractors.

C. The potential financial impact of the bank's business on the provider.

D. The potential impact of the provider's past clients on the bank's financial condition.

Question ORR-12 b.4 Bank Q289 • BT Mock Q53 • BT P2.T7.811.1

According to the Federal Reserve's Guidance on Managing Outsourcing Risk, the overall due diligence process for a third-party service provider should at a minimum include a review of each of the following EXCEPT which?

A. Ensuring the service provider has an appropriate background check program for its employees.

B. A financial review of the service provider's most recent annual report and financial statements.

C. An evaluation of the service provider's performance on environmental, social and governance (ESG) factors.

D. An evaluation of the adequacy of standards, policies and procedures, including adherence to applicable laws, regulations and supervisory guidance.

Question ORR-12 b.5 New • built from GARP Ch.12

A vendor-risk analyst at a Canadian bank is writing up the due diligence on a payments-processing provider and must file three findings under the guidance's three review areas:

I. The provider has operated for 14 years and has grown its market share for this service every year.

II. Management showed that the provider's business model can adapt to the market's shift to real-time payments.

III. The provider's record-retention schedule and its systems development process were reviewed.

Which filing is consistent with the guidance?

A. I: business background, reputation and strategy; II: financial performance and condition; III: operations and internal controls.

B. I: financial performance and condition; II: business background, reputation and strategy; III: operations and internal controls.

C. I: financial performance and condition; II: operations and internal controls; III: business background, reputation and strategy.

D. I: operations and internal controls; II: business background, reputation and strategy; III: financial performance and condition.

Question ORR-12 b.6 New • built from GARP Ch.12

The head of procurement at a mid-sized U.S. bank proposes to move the printing and mailing of wealth clients' statements, which carry client names, addresses and balances, to a large print-services firm that the bank has used for years for marketing brochures. Because the bank knows the firm and the firm is a market leader, she suggests signing the contract now and having procurement alone complete a short due diligence questionnaire during onboarding. Which response from the operational risk manager is most consistent with the guidance?

A. Familiarity and reputation remove the need for due diligence on this provider; the bank's effort should go into the indemnification clause of the contract instead.

B. Familiarity and reputation can reduce the depth and formality of the review, but it must be completed before the bank engages the firm, cover all three review areas, and involve technical experts and key stakeholders, as the service now involves sensitive customer information.

C. Due diligence can be completed after signing, because ongoing monitoring under the contract will reveal any weakness the review would have found.

D. As the firm is a market leader, the review need only cover its financial performance and condition; its operations and internal controls are the firm's own responsibility.

Solutions • ORR-12 b

Solution ORR-12 b.1

Answer: C

Bank Q286 • AnalystPrep Q.2325

Step 1 – Where the financial review sits

Due diligence on a prospective provider covers three areas; financial performance and condition is the second.

Step 2 – What it is for

Statements, sustainability, commitment of financial and staff resources and insurance show whether the provider can keep delivering the service for the duration of the contract.
⇒ The review is appropriate wherever the provider is based.

Interpretation

A provider in India adds country risk to the risk assessment; it does not replace the financial review. Both are needed.

Why the other options are wrong

A is incorrect. Country risk is one of six outsourcing risks; it does not narrow due diligence to a single topic.
B is incorrect. Outsourcing IT is lawful and common; the guidance manages the risk, it does not prohibit the activity.
D is incorrect. Right answer, wrong reason: the financial review comes from the outsourcing guidance on due diligence, not from Basel II.

LO: ORR-12 b: Explain how financial institutions should perform due diligence on third-party service providers. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 B Due Diligence and Selection of Service Providers)

Solution ORR-12 b.2

Answer: B

Bank Q290 • Schweser Module Quiz 53.1 Q3

Step 1 – The three areas

Business background, reputation and strategy; financial performance and condition; operations and internal controls.

Step 2 – Find insurance

The financial review lists "the adequacy of the service provider's insurance coverage".
⇒ Insurance belongs to financial performance and condition.

Interpretation

Insurance turns up again in the contract (the provider must carry adequate insurance, show proof and report material changes), but that is ORR-12 c. At the due diligence stage it is a financial question: can the provider absorb a loss?

Why the other options are wrong

A is incorrect. Background and strategy covers history, principals, references, licences, litigation and the business model, not insurance.
C is incorrect. Operations and internal controls covers controls, training, security, privacy, records and continuity, not insurance.
D is incorrect. Oversight and monitoring is a separate programme element (E), not a due diligence category.

LO: ORR-12 b: Explain how financial institutions should perform due diligence on third-party service providers. •

Reference: Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 B.2 Financial Performance and Condition); SchweserNotes 2026 Book 3, Reading 53, LO 53.b

Solution ORR-12 b.3 — Answer: D

Bank Q287 • AnalystPrep Q.2329

Step 1 – The financial review list

Latest statements and annual report; sustainability; the potential impact of the institution's business relationship on the provider's financial condition; commitment of resources; insurance; the provider's review of subcontractors' financial condition; other current issues.

Step 2 – Test each option

A, B and C are on the list. D reverses the direction of the impact item and introduces the provider's past clients.

$\Rightarrow$ D is not part of the review.

Interpretation

The impact item asks whether the bank's business is large enough to strain the provider (for example a small provider that would depend on one large client), not how the provider's other clients affect the bank.

Why the other options are wrong

A is incorrect. Insurance adequacy is an explicit element of the financial review.

B is incorrect. The provider's review of its subcontractors' financial condition is an explicit element.

C is incorrect. The impact of the bank's relationship on the provider's financial condition is an explicit element.

LO: ORR-12 b: Explain how financial institutions should perform due diligence on third-party service providers. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 B.2)

Solution ORR-12 b.4 — Answer: C

Bank Q289 • BT Mock Q53

Step 1 – Place each option in an area

A: background-check programme for employees, area 1. B: most recent annual report and financial statements, area 2. D: adequacy of standards, policies and procedures, including adherence to laws, regulations and guidance, area 3.

Step 2 – The odd one out

No area includes an evaluation of the provider's environmental, social and governance performance.

$\Rightarrow$ C is the exception.

Interpretation

The three areas are built around one question: can this provider deliver the service safely, soundly and lawfully for the life of the contract? ESG scoring may matter to a bank's own policies, but it is not part of the guidance's due diligence.

Why the other options are wrong

A is incorrect. Part of business background, reputation and strategy.

B is incorrect. Part of financial performance and condition.

D is incorrect. Part of operations and internal controls.

LO: ORR-12 b: Explain how financial institutions should perform due diligence on third-party service providers. •

Reference: Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 B.1 to B.3)

Solution ORR-12 b.5 — Answer: B

New • built from GARP Ch.12

Step 1 – Finding I

Time in business and growth of market share for a given service are the guidance's examples of the provider's *sustainability*, listed under financial performance and condition.

Step 2 – Finding II

"The resiliency and adaptability of the service provider's business model" is assessed as a factor in its future viability under business background, reputation and strategy.

Step 3 – Finding III

Maintenance and retention of records, and systems development and maintenance, are on the operations and internal controls list.
⇒ I financial, II strategy, III operations: option B.

Interpretation

The trap is that both I and II sound like "staying power". The guidance splits them: the numbers that show a durable business are financial; whether the model can adapt to change is strategy.

Why the other options are wrong

A is incorrect. Swaps I and II: sustainability (time in business, market share) is financial; the model's adaptability is strategy.
C is incorrect. Puts the business model under operations and record keeping under strategy.
D is incorrect. Files sustainability under operations and record keeping under financial condition.

LO: ORR-12 b: Explain how financial institutions should perform due diligence on third-party service providers. •
Reference: Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 B.1 to B.3)

Solution ORR-12 b.6 — Answer: B

New • built from GARP Ch.12

Step 1 – Timing

The institution should evaluate and perform the necessary due diligence on a prospective provider *prior to engaging* it.
⇒ Signing first and checking during onboarding is out.

Step 2 – Depth

Depth and formality vary with the scope, complexity and importance of the arrangement, the institution's familiarity with the provider, and its reputation and industry standing. Familiarity and reputation can lighten the review.

Step 3 – What has changed

The new service involves sensitive customer information, which the programme treats as a focus area. The review must cover all three areas and draw in technical experts (information security, privacy) and key stakeholders, not procurement alone.

Interpretation

The firm is familiar for a low-risk service (brochures); the new arrangement is a different risk. Proportionality is judged on the planned arrangement, not on the vendor's history with the bank.

Why the other options are wrong

A is incorrect. Absolute waiver: familiarity reduces depth, it does not remove the review; an

indemnity does not replace due diligence or move accountability.
C is incorrect. Timing error: due diligence precedes engagement; monitoring is a later, separate element.
D is incorrect. Partial scope: the review covers all three areas, and the institution is responsible for ensuring the provider's services comply with laws and safe-and-sound practices.

LO: ORR-12 b: Explain how financial institutions should perform due diligence on third-party service providers. •
Reference: Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 and 12.4 B)

ORR-12 • Guidance on Managing Outsourcing Risk • Vardeez: VERY IMPORTANT

ORR-12 c

P2 CONCEPT

Describe topics and provisions that should be addressed in a contract with a third-party service provider.

Workbook: *none*

WHAT IS TESTED HERE

Why P2. Vardeez flags it inside a VERY IMPORTANT chapter (ORR-12, theme 1 of his ORR list). Schweser: "be familiar with the details from the numerous contract provisions".

Vardeez: his notes label this LO "LO 51.c" (consolidated volume pp.82 to 83): a table of 17 provisions, following Schweser's list (see the correction box below for GARP's 15).

Reported exam shapes: none reported. The questions below are built from the LO wording and Vardeez's table.

What the questions look like: which provision a clause belongs to; what a provision should say (default with a chance to cure, breach notification for customer data, who pays which fees); which item is not an outsourcing provision at all; and which provision the guidance makes optional.

See also: workbook D2.1 (the subcontracting clause and accountability) is worked under ORR-12 a.

1. Ground rules

Terms must be set out in **written contracts reviewed by the institution's legal counsel before execution**. The characteristics of the activity and the provider's strategy for delivering it determine the terms. The provisions below are what "well-defined contracts and service agreements usually include".

2. The provisions, one by one

Provision	What the agreement should address
Scope	Rights and responsibilities of each party: support, maintenance and customer service; contract timeframes; compliance with laws, regulations and guidance; training of the institution's staff; **the ability to subcontract**; disclosures to the institution's customers; insurance requirements; use of the institution's property, equipment and staff.
Cost and compensation	Compensation, variable charges, fees for non-recurring items and special requests; **who pays** legal, audit and examination fees; who bears purchase and maintenance of equipment, hardware and software. Incentives (variable fees, commissions) must not encourage imprudent risk on the institution's behalf.
Right to audit	Agreements **may** provide for the institution (or its representatives) to audit the provider and/or receive audit reports; define the types of report and the frequency.
Performance standards	Define **measurable** performance standards for the services or products.
Confidentiality and security	Protect the institution's and its customers' information as if the activity were in-house (FFIEC guidelines, Gramm-Leach-Bliley Act section 501(b)); share only what the service needs. For nonpublic personal information (NPPI): comply with privacy laws, **notify the institution of breaches**, address security, retention and access, and state each party's roles.

Provision	What the agreement should address
Ownership and license	When the provider may use the institution's property (data, hardware, software, intellectual property); ownership and control of information the provider generates; **escrow** of source code for purchased software (access if support stops or the vendor fails).
Indemnification	The provider indemnifies the institution for claims resulting from **the provider's negligence**.
Default and termination	Events of default, acceptable remedies and **opportunities to cure**; termination rights (change in control, merger or acquisition, fee increases, failure to meet performance standards or obligations or to give notices or prevent violations of law, bankruptcy, closure, insolvency); notice that leaves time to **transfer services**; preservation and timely **return of data** and records.
Dispute resolution	A process to expedite resolution, and continuation of the service during the dispute.
Limits on liability	Providers may seek to cap liability; the **board and senior management** decide whether the cap is reasonable against the risk if the provider fails.
Insurance	Adequate cover, proof of insurance, notice of material changes in coverage.
Customer complaints	Who responds; if the provider does, summary reports on status and resolution.
Business resumption	Continuation of service through operational failures; back-ups, disaster recovery and contingency plans; may include testing and sharing results.
Foreign-based providers	Consider an express **choice of law and jurisdiction**: disputes adjudicated under the laws of a single, specific jurisdiction. Foreign courts may still apply local law, so take legal advice on enforceability.
Subcontracting	The **same provisions** apply to the subcontractor; the primary provider has **overall accountability** for all services it and its subcontractors provide; define what may be subcontracted, the provider's due diligence and monitoring of subcontractors, and notice and approval of changes; extra care with foreign subcontractors; the provider's process for assessing a subcontractor's financial condition.

Correction to the source notes. Vardeez (Figure 51.2) and Schweser list 17 contract provisions. GARP's contract list (12.4 C) has the 15 above. The two extras are separate programme elements in GARP: *incentive compensation* is element D (and a sentence inside cost and compensation), and *oversight and monitoring* is element E, where GARP asks the institution to review the provider's most recent financial statements, not to write "annual statements" into the contract. Vardeez and Schweser also write the foreign-provider clause as "the laws of the financial institution's jurisdiction"; GARP asks only for the laws of *a single, specific* jurisdiction, with legal advice on enforceability.

Three links to keep in mind. The subcontracting clause allocates duties between the institution and its provider; it never moves the institution's accountability (ORR-12 a, S1). The right to audit is "may" here, yet ORR-13 calls audit rights on vendors *necessary* to verify standards imposed on fourth parties, and element E escalates to exercising it. Default and termination is where performance standards bite: failure to meet them is a termination right.

Summary card: ORR-12 c

Before signing	written contract, reviewed by the institution's legal counsel
Money	cost and compensation (who pays which fees; no imprudent incentives); insurance; limits on liability judged by the board and senior management
Information	confidentiality and security (NPPI, breach notification, GLBA 501(b)); ownership and license (escrow)
Performance	measurable standards; right to audit ("may"); customer complaints; business resumption
When it goes wrong	indemnification (provider's negligence); default with cure, termination with time to transfer and return of data; dispute resolution with continued service
Reach	foreign-based providers (single jurisdiction); subcontracting (same terms, primary provider accountable)

Exam traps

- **Foreign constructs.** Loss waterfalls, CVA, collateral calls and margin are credit or derivatives terms, not outsourcing provisions.
- **Direction of protections.** The institution audits the provider and the provider indemnifies the institution; no reciprocal rights are required.
- **Cure before termination.** Default provisions list remedies and give the provider a chance to cure.
- **Customer data.** Outsourcing involving NPPI is allowed, under privacy-law compliance and breach notification; it is neither banned nor free.
- **"May" versus "should".** The right to audit is the provision the guidance frames as optional.
- **Subcontracting.** Same terms flow down; the primary provider is accountable to the institution; the institution stays accountable to customers and supervisors.
- **Count.** 15 provisions in GARP; 17 in Schweser and Vardeez (correction box).

Practice questions: ORR-12 c

Question ORR-12 c.1

Bank Q293 • BT P2.T7.811.3

Planetholding International Bank is entering a contract with its third-party service provider, Tristechnology Inc, to outsource the management of its website. Each of the following is a likely contract provision EXCEPT which one?

A. Confidentiality and security of information.

B. Business resumption and contingency plan.

C. Scope of service (including reference to service level agreement and ability to subcontract).

D. Loss waterfall allocation mechanism (including sufficient credit value adjustment for website downtime).

Question ORR-12 c.2

Bank Q292 • AnalystPrep Q.5257 (rebuilt)

Which of the following best describes what a contract with a third-party service provider should address under its cost and compensation provision?

A. A single fixed fee for the service, with all other expenses left to be settled informally as they arise.

B. The compensation, variable charges, and any fees for non-recurring items and special requests, together with which party pays legal, audit and examination fees and equipment-related expenses.

C. The compensation to be paid, with incentive terms left to the provider because the institution should not review how the provider is paid.

D. The compensation and variable charges, with legal and audit fees assumed to be paid by the financial institution without being stated.

Question ORR-12 c.3

Bank Q291 • AnalystPrep Q.2326

Sandero Bank from Carrington, North Dakota, is considering outsourcing part of its IT services to a third party. Such a move will most likely involve sharing some nonpublic personal information about the bank's customers with the third party. Should the bank go ahead with its plan?

A. No, all outsourcing activities that can reasonably be expected to expose nonpublic personal information are forbidden.

B. Yes, but the bank should refrain from sharing all nonpublic personal information.

C. Yes, the bank could outsource an activity which requires usage of nonpublic personal information, but the service provider must comply with applicable privacy laws and regulation.

D. No, because such a move would open doors to possible lawsuits by aggrieved customers.

Question ORR-12 c.4 Bank Q295 • Schweser Module Quiz 53.1 Q4

The use of performance metrics to assist in determining an acceptable level of performance by a service provider would most appropriately be included in which of the following provisions of a contract with a financial institution?

A. Customer complaints.

B. Default and termination.

C. Indemnification.

D. Right to audit.

Question ORR-12 c.5 Bank Q296 • Schweser Module Quiz 53.1 Q5 (rebuilt)

According to the guidance, which of the following contract provisions with a third-party service provider is described as one the agreement "may" provide, rather than one the agreement "should" provide?

A. Establishment and monitoring of performance standards.

B. Indemnification.

C. Ownership and license.

D. Right to audit.

Question ORR-12 c.6 Bank Q294 • GARP PE2 Q41 • Mock 4 Q42

A bank wants to reduce its operating expenses and considers hiring a third-party service provider to offer additional loan origination and credit services to some of the bank's customers. The bank's legal department has begun negotiating the terms of a contract with the provider. Which of the following describes the most appropriate action for the bank to take in the contract?

A. The bank should audit the service provider's operational processes and also give the service provider the similar right to audit the bank's processes.

B. The bank should purchase insurance to cover potential losses resulting from the provider's services and should require that the provider deposit collateral with the bank to mitigate performance risk.

C. The bank should determine the compensation structure for the provider's sales representatives and ensure that it incentivizes their productivity through a high proportion of variable compensation.

D. The bank should define specific events that are considered a default under the contract and give the provider an opportunity to resolve a default before terminating the contract.

Solutions • ORR-12 c

Solution ORR-12 c.1

Answer: D

Bank Q293 • BT P2.T7.811.3

Step 1 – Recall the provisions

Scope (including the ability to subcontract), cost and compensation, right to audit, performance standards, confidentiality and security, ownership and license, indemnification, default and termination, dispute resolution, limits on liability, insurance, customer complaints, business resumption, foreign-based providers, subcontracting.

Step 2 – Test each option

A, B and C are on the list. A loss waterfall and a credit value adjustment belong to clearing, securitisation and derivatives counterparty risk.
$\Rightarrow$ D is the exception.

Interpretation

Website downtime is handled through measurable performance standards (service levels), the provider's business resumption plan, and default and termination rights, not through credit-risk machinery.

Why the other options are wrong

A is incorrect. Standard: the security and confidentiality of the institution's and its customers' information.
B is incorrect. Standard: the provider's business resumption and contingency plan.
C is incorrect. Standard: scope defines rights and responsibilities, service levels and the ability to subcontract.

LO: ORR-12 c: Describe topics and provisions that should be addressed in a contract with a third-party service provider. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 C Contract Provisions and Considerations)

Solution ORR-12 c.2

Answer: B

Bank Q292 • AnalystPrep Q.5257

Step 1 – What the provision covers

Contracts describe the compensation, variable charges and any fees for non-recurring items and special requests; state which party pays legal, audit and examination fees; and, where applicable, who bears the expense, purchase and maintenance of equipment, hardware and software.

Step 2 – The incentive sentence

The institution should ensure that incentives in the contract, such as variable fees or commissions, do not encourage imprudent risk on its behalf.
$\Rightarrow$ Only B is complete and consistent.

Interpretation

The provision exists to prevent disputes and hidden incentives: every charge and every fee-payer is written down.

Why the other options are wrong

A is incorrect. Too narrow: leaves variable and special charges and fee allocation informal, which the provision exists to prevent.
C is incorrect. The institution must be able to review incentives; that is also programme element D.

D is incorrect. The payer of legal and audit fees must be stated, not assumed; non-recurring fees are also missing.

LO: ORR-12 c: Describe topics and provisions that should be addressed in a contract with a third-party service provider. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 C, Cost and compensation)

Solution ORR-12 c.3 — Answer: C

Bank Q291 • AnalystPrep Q.2326

Step 1 – Is it allowed?

The guidance does not prohibit outsourcing that involves customers' nonpublic personal information (NPPI). It says that if providers handle NPPI they must comply with applicable privacy laws and regulations.

Step 2 – What the contract must add

Information shared is limited to what the service needs; the contract addresses the security, retention of and access to NPPI, requires notification of breaches involving NPPI, includes state breach requirements, and sets out each party's roles.
⇒ The bank may proceed under those terms.

Interpretation

Institutions and providers that hold NPPI are both responsible for it and for any disclosure; the contract is where that responsibility is made explicit.

Why the other options are wrong

A is incorrect. There is no blanket prohibition; the guidance sets conditions.
B is incorrect. Sharing no NPPI is not required and would often make the service impossible; the safeguard is need-to-know sharing under privacy-law compliance.
D is incorrect. Litigation risk is managed through contract terms and oversight; it does not make the outsourcing impermissible.

LO: ORR-12 c: Describe topics and provisions that should be addressed in a contract with a third-party service provider. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 C, Confidentiality and security of information)

Solution ORR-12 c.4 — Answer: B

Bank Q295 • Schweser Module Quiz 53.1 Q4

Step 1 – Where performance metrics live

The guidance asks agreements to define measurable performance standards (their own provision), and element E sets the metrics used to judge acceptable performance. Neither is among the options.

Step 2 – Which option uses them

Default and termination lists "failure to meet performance standards" as a termination right; the metrics decide whether that event has occurred.
⇒ Among the four, default and termination is the right home.

Interpretation

Read "most appropriately" as "among those offered". On a GARP question that offered "performance standards" as an option, that would be the answer.

Why the other options are wrong

A is incorrect. Customer complaints sets who handles complaints and how they are reported.
C is incorrect. Indemnification makes the provider hold the institution harmless for claims

arising from its negligence.
D is incorrect. Right to audit gives the institution access to audit the provider or to audit reports; it does not set performance levels.

LO: ORR-12 c: Describe topics and provisions that should be addressed in a contract with a third-party service provider. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 C, Default and termination; 12.4 E); SchweserNotes 2026 Book 3, Reading 53, LO 53.c

Solution ORR-12 c.5 — Answer: D

Bank Q296 • Schweser Module Quiz 53.1 Q5

Step 1 – The wording of each provision

Performance standards: agreements *should* define measurable standards. Indemnification: agreements *should* provide for it. Ownership and license: agreements *should* define use of the institution's property and ownership of information. Right to audit: agreements *may* provide for the right to audit and/or access to audit reports.
⇒ Right to audit is the provision framed as optional.

Interpretation

Optional in SR 13-19 does not mean unimportant. Element E escalates to exercising the right to audit when a provider fails expectations, and ORR-13 treats audit rights on vendors as necessary to verify the standards imposed on fourth parties. For a significant provider, expect it in the contract. (The bank rebuilt this question and corrected its key: the original asked which provision was "least likely" to be included.)

Why the other options are wrong

A is incorrect. A "should" provision: measurable performance standards are needed for monitoring and for termination rights.
B is incorrect. A "should" provision: indemnification for claims arising from the provider's negligence.
C is incorrect. A "should" provision: use of the institution's property and ownership and control of information.

LO: ORR-12 c: Describe topics and provisions that should be addressed in a contract with a third-party service provider. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 C and E); GARP ORR Ch.13, Contracts, SLAs, and Contract Management

Solution ORR-12 c.6 — Answer: D

Bank Q294 • GARP PE2 Q41

Step 1 – The default and termination provision

Agreements should define events of contractual default, list acceptable remedies and provide opportunities for curing default, as well as termination rights and notice periods.
⇒ D restates the guidance.

Step 2 – Test the other actions

Audit rights run from the institution to the provider; insurance is carried by the provider, with proof; incentives must not encourage imprudent risk.

Interpretation

A provider originating credit for the bank's customers sells on the bank's behalf, so a variable-pay push (option C) is the guidance's own example of an inappropriate incentive.

Why the other options are wrong

A is incorrect. The right to audit protects the institution; nothing calls for a reciprocal right for the provider.
B is incorrect. The contract requires the provider to carry adequate insurance and show proof; buying the bank's own cover and demanding collateral are not the guidance's provisions.
C is incorrect. A high proportion of variable pay for sales staff encourages imprudent lending and mis-selling; the bank reviews incentives so that they do not.

LO: ORR-12 c: Describe topics and provisions that should be addressed in a contract with a third-party service provider. • **Reference:** Federal Reserve SR 13-19/CA 13-21 (GARP ORR Ch.12, 12.4 C, Default and termination, Insurance, Cost and compensation; 12.4 D)

ORR-13 • Third-Party Risk Management • Vardeez: VERY IMPORTANT

ORR-13 a

P2 CONCEPT

Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework.

Workbook: D2 Outsourcing and Third-Party Risk • Tier D

WHAT IS TESTED HERE

Why P2. Vardeez rates ORR-13 VERY IMPORTANT: it is theme 1 of his ORR list (TPRM, AML and outsourcing), ROI rank 19 of 55 in the consolidated volume. The best workbook coverage is Tier D (D2, topic map #51, 3 of 16 sources).

Vardeez: his notes label this LO "LO 52.a" (consolidated volume p.84): what TPRM covers, why firms use third parties, the key risks, why reliance has accelerated (IoT, COVID-19, breach statistics), and his Figure 52.1, the five-stage TPRM life cycle.

Reported exam shapes

- **S2** Concentration risk in a critical service provider and its resilience implications.

What the questions look like: map a task to its life-cycle stage (deciding to outsource, limits on fourth parties, trigger events, wind-down); name an incident by the source of the risk; pick the oversight that actually reduces a vendor's risk; and judge concentration on a critical provider.

See also: workbook D2.1 (S1, accountability) is worked under ORR-12 a; workbook D2.2 (S2, one cloud provider behind three important business services) is worked under ORR-4 g and pairs with Question ORR-13 a.8. The SR 13-19 programme behind this framework is ORR-12 a.

1. Who counts as a third party

Third-party risk management (TPRM) is the identification, assessment, mitigation and monitoring of the risks that arise from using third parties: providers of goods and services that are not internal to the firm, such as vendors, suppliers, partners, contractors and service providers. "Outsourcing risk" is used almost interchangeably, but third-party risk is broader: it covers *all* risks from third parties that can affect the client institution, not only those of outsourced activities.

- **Fourth parties** are the third parties of third parties (a provider's subcontractors, a supplier's suppliers); less often, **fifth parties** sit one link further down. TPRM quickly touches the whole supply chain (Figure 1, right).
- **Why firms use third parties:** cost savings, by outsourcing to specialists with a competitive advantage in particular systems, processes and knowledge; and sometimes operational risk mitigation (ORR-5). But contracting out back-office work or cloud data management, even when it cuts process errors or cyber risk, "does not fully mitigate operational risk and, indeed, increases exposure to third-party risk".

2. What can go wrong, and why it has grown

Nearly every operational risk type that can hit a financial institution can also happen at a third party. The common ones: **service disruption**, failings in service quality, **fraud**, accidental data privacy breach or intentional information leak, compliance breaches, **espionage and IP theft**, and reputational damage. Any of them lands on the client institution.

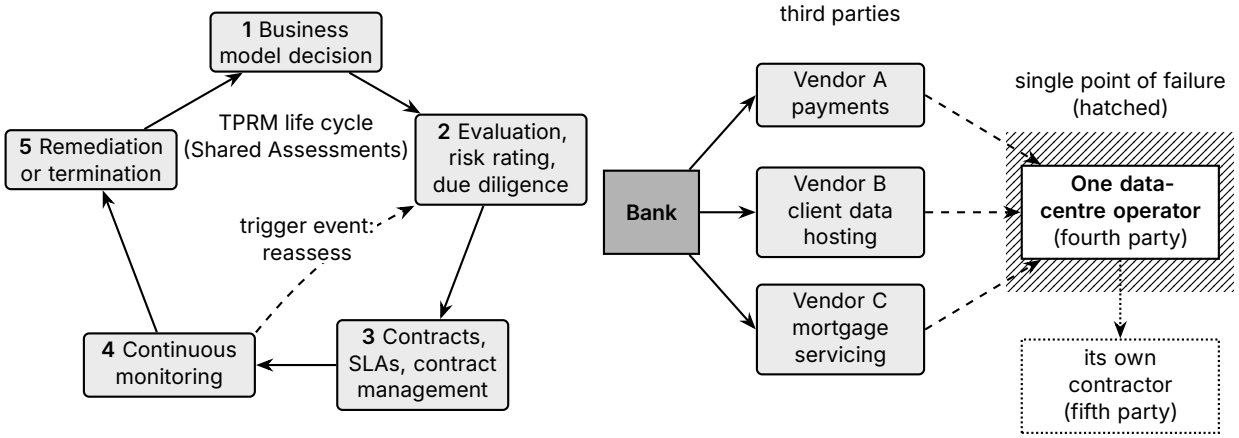
- **Taxonomy.** "Third-party failure" is a Level 2 category of Basel event type 7 (Execution, Delivery and Process Management); its importance has grown so much that many institutions treat TPRM as Level 1, and ORX's revised taxonomy makes third-party risk Level 1 (ORR-3).
- **Core processes outsourced:** loan and deposit processing, electronic funds transfer, payroll, merchant processing, mortgage servicing, treasury management services, call centres; FinTech partners for new applications, bill payment, account aggregation and digital certification.
- **Foreign jurisdictions** add country risk *and* compliance and legal risk: a U.S. bank using a foreign provider must still meet U.S. rules on record retention, sanctions, consumer protection and data privacy, which may conflict with the provider's local law.
- **COVID-19** raised reliance on outsourcing and exposed international supply chains; **IoT** devices add entry points (Avanti Markets was hacked through vending machines linked to staff payment cards). TPRM overlaps with information security, data privacy and business continuity.
- **Survey evidence:** a 2018 Ponemon study found almost 60% of companies had suffered a data breach caused by third parties in the past year; a 2020 survey of over 1,500 CISOs, CIOs and procurement heads found 77% with limited visibility of their vendors, 80% with a third-party breach in the past 12 months, more than two breaches each on average, and only 22.5% monitoring their entire supply chain.

3. The TPRM life cycle

GARP follows the five-stage life cycle of Shared Assessments, the U.S. body that certifies TPRM professionals (CTPRP).

1. **Business model decision.** Whether to outsource or keep the activity in-house, and the choice of a provider's quality and price: a strategic decision tied to the firm's **risk appetite**.
2. **Evaluation, risk rating and due diligence.** Know whom you do business with, as in customer due diligence for AML. **Proportionate:** a consultant delivering two days of training (no dependency, no data sharing) needs far less than an IT cloud company hosting sensitive data. Standard questionnaires (SIG, from Shared Assessments) simplify the work.
3. **Contracts, SLAs and contract management.** Define what can and cannot be done, by whom, when and where; responsibilities, expectations, and service levels with clear, measurable quality measures (ambiguity is a common reason relationships fail). A foreign vendor must understand the domestic laws that apply. Sign only after all open items are assessed and remediated; review contracts periodically. The contract is the place to manage **fourth parties**: set standards or limits on the vendor's own outsourcing (largely a copy of the firm's own vendor rules) and keep **audit rights** to verify them.
4. **Continuous monitoring.** Service provision, quality SLAs and compliance with regulation and contract terms. The more thorough the first four steps, the shorter the reassessment cycle. Reassess on **trigger events**, not only at scheduled reviews: data breaches or incidents; a change in either firm's business (merger, acquisition); legal or regulatory change; changes in services; acts of God (COVID-19); breach of contract or performance failure.

5. **Remediation or termination.** Most relationships end when the service ends. Good practice: a grievance procedure and an **exit strategy or termination clause**. A fair **wind-down** plans the transmission of IP, the transition in-house or to another provider, and evidence of data transfer or destruction.



(a) Solid arrows: the cycle. Dashed: a trigger event sends the relationship back to risk rating.

(b) Three contracts, one dependency: solid = bank's contracts, dashed = subcontracts, dotted = fifth party.

Figure 1. Left: GARP Figure 13.1 redrawn. Right: why fourth parties matter for concentration. The bank's register shows three separate providers, but all three subcontract to the same data-centre operator, so the risk is concentrated where the bank has no contract and, without contract standards and audit rights, no visibility.

4. Risk-based vendor rating

Proportionality needs a rating. GARP's illustration (Figure 13.2) scores each vendor on five criteria; the thresholds and the due diligence and controls attached to each class must match the firm's risk appetite.

Class	Process criticality	Data access	System access	Regulated sector	Substitut-ability
Critical	business operations would halt without the vendor	highly confidential and sensitive	critical systems, admin rights	no	none or very limited
High	capacity to create major disruption	sensitive and confidential	sensitive systems	no	limited
Medium	minor interruption	internal	non-sensitive systems	yes	possible
Low	no interruption	public	none	yes	immediate

5. Concentration on a critical provider (shape S2)

- **Definition (SR 13-19, ORR-12 a):** outsourced services provided by a *limited number of providers* or concentrated in *limited geographic locations*. It is a firm-level risk the board must manage, not only a systemic issue for supervisors.
- **Rating:** a provider that is critical to operations and has little or no substitute sits in the top class: most frequent and stringent monitoring, a designated point of contact, tailored mitigation (ORR-12 a, element E).
- **Resilience link (ORR-4 g):** single points of failure, including key-supplier dependency, low substitutability and high switching costs, are resilience KRIs. Remove them through back-ups and

redundancy where possible; otherwise reflect them in impact tolerances and stress tests of the important business services they support.

- **Contingency (SR 13-19 F):** test the provider's continuity plan against the firm's own and keep an exit strategy with a pool of comparable providers. Check that the alternatives do not share the same point of failure: the same site, the same cloud region or, as in Figure 1(b), the same fourth party.

Summary card: ORR-13 a, SR 13-19 programme against the TPRM life cycle

TPRM stage (ORR-13)	SR 13-19 element (ORR-12)	Keywords that point here
1 Business model decision	A risk assessment	outsource at all, in-house, risk appetite, strategy
2 Evaluation, risk rating, due diligence	B due diligence and selection	proportionality, SIG questionnaire, rating criteria
3 Contracts, SLAs, contract management	C contract provisions; D incentive review	measurable SLAs, open items remediated first, limits on vendors' outsourcing, audit rights
4 Continuous monitoring	E oversight and monitoring	SLAs tracked, trigger events, reassessment
5 Remediation or termination	F continuity and contingency (exit)	grievance procedure, exit strategy, termination clause, wind-down, data destruction evidence

Exam traps

- **Stage swaps.** Limits on vendors' own outsourcing and audit rights: stage 3. Trigger events: stage 4. Exit strategy and wind-down: stage 5. Standard questionnaires: stage 2. Deciding whether to outsource: stage 1.
- **Not a stage.** Shared Assessments is the body behind the model; "fourth-party management", insurance procurement and "shared assessments" are not stages.
- **Trigger versus parameter.** A trigger is an event (breach, merger, regulatory change, act of God, performance failure); risk appetite is a standing parameter.
- **Absolute claim.** Third parties do not fully mitigate operational risk; they add third-party risk.
- **Source versus mechanism.** A breach caused by a vendor's weak protocols is third-party risk by source; cyber is the mechanism, compliance the consequence.
- **Concentration scope.** Firm-level risk from few providers or few locations, including hidden fourth-party overlap; not only a systemic matter for supervisors.
- **Assurance that does not assure.** Self-attestations, indemnities and financial statements do not detect conduct or control failures; monitoring of actual outcomes does.

Practice questions: ORR-13 a

Question ORR-13 a.1

Bank Q304 • AnalystPrep Q.5134 (rebuilt)

Which of the following is *not* identified as a common risk arising from the use of third parties?

A. Service disruption.

B. Espionage and intellectual property theft.

C. Accidental data privacy breach or intentional information leak.

D. A reduction in the firm's own cost of capital.

Question ORR-13 a.2

Bank Q297 • AP Mock 3 Q34 (rebuilt)

A bank outsourced its customer data analysis to a specialised analytics company. Because of inadequate security protocols at that company, there was unauthorised access to the bank's customer data, exposing sensitive personal and financial information. Classifying the incident by the *source* (root cause) of the risk, which risk category does it most closely represent?

A. Operational risk.

B. Third-party risk.

C. Compliance risk.

D. Cyber risk.

Question ORR-13 a.3

Bank Q307 • Mock 2 Q71

The chief risk officer of an Australian bank is evaluating the bank's overall risk appetite and is looking to determine which of the bank's activities should be kept in-house or outsourced to third-party vendors. Within the life cycle stages of third-party risk management (TPRM), these determinations would most likely fall under:

A. business model decisions.

B. contract management.

C. due diligence.

D. evaluation and risk rating.

Question ORR-13 a.4

Bank Q309 • Schweser Module Quiz 54.1 Q1

Establishing limits on third-party and fourth-party vendor outsourcing would be considered under which of the following third-party risk management (TPRM) steps?

A. Business model decision.

B. Remediation or termination.

C. Evaluation, risk rating, and due diligence.

D. Contracts, service level agreements, and contract management.

Question ORR-13 a.5 Bank Q302 • AnalystPrep Q.5132

Which of the following is *not* an example of an event that can trigger the reassessment of contracts with third parties?

A. Data breaches.

B. A merger or acquisition.

C. Regulatory change.

D. Risk appetite.

Question ORR-13 a.6 Bank Q306 • AnalystPrep Q.5136

Which of the following is *not* an action that should be undertaken during the wind-down process of contracts?

A. The transmission of intellectual property.

B. Plan to transition to in-house services.

C. Having audit rights on their vendors.

D. Provide evidence of data transfer or destruction.

Question ORR-13 a.7 Bank Q308 • Mock 3 Q31

A bank has engaged a third-party vendor whose sales representatives market the bank's investment products directly to retail customers under the bank's brand. The vendor was subject to full due diligence at onboarding two years ago. An operational risk manager is designing the ongoing oversight arrangements for the relationship. Which of the following would be most effective in reducing the bank's operational risk?

A. Relying on the vendor's annual attestation that it remains compliant with the terms of the contract.

B. Monitoring customer complaint and product suitability data arising from the vendor's sales and feeding it into the bank's own conduct risk reporting.

C. Requiring the vendor to indemnify the bank against any regulatory penalties arising from its sales activities.

D. Reviewing the vendor's publicly available audited financial statements each year to confirm its financial soundness.

Question ORR-13 a.8 New • built from GARP Ch.13 and Ch.12

An operational risk manager at a Dutch bank is rating its card-authorisation provider, P. The service is critical: card authorisations stop without it. Only two firms in the market offer the service, and the other one, Q, runs its platform from the same data-centre campus as P. P has never had a material outage and its latest SOC 2 report is clean. Which assessment should the manager make?

A. Concentration risk is low: P has a clean record and an alternative provider exists, so a standard annual review of P is sufficient.

B. Concentration risk arises from both the few providers and their shared location; P belongs in the highest rating class, and the exit plan must not rely on an alternative with the same point of failure.

C. Splitting the authorisation volume between P and Q would remove the concentration risk, because the service would no longer depend on a single provider.

D. Substitutability matters only at the remediation or termination stage, so it should not affect P's rating while the contract is running.

Solutions • ORR-13 a

Solution ORR-13 a.1

Answer: D

Bank Q304 • AnalystPrep Q.5134

Step 1 – The common third-party risks

Service disruption, failings in service quality, fraud, accidental data privacy breach or intentional information leak, compliance breaches, espionage and IP theft, and reputational damage.

Step 2 – Test each option

A, B and C are on the list. A lower cost of capital is not a risk event at all.
$\Rightarrow$ D is the exception.

Interpretation

The list is the operational risk catalogue seen through a vendor: nearly every operational risk that can hit the institution can also happen at a third party and then land on the institution.

Why the other options are wrong

A is incorrect. Service disruption is a listed third-party risk.
B is incorrect. Espionage and IP theft are listed.
C is incorrect. Privacy breaches and information leaks are listed.

LO: ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. • **Reference:** GARP ORR Ch.13, Context and Scope, Nature of TPRM

Solution ORR-13 a.2

Answer: B

Bank Q297 • AP Mock 3 Q34

Step 1 – Where did it start?

The loss arose because security protocols failed at the outsourced analytics company, not inside the bank.
$\Rightarrow$ By source, this is third-party (outsourcing) risk: the risk of failed controls at a provider.

Step 2 – Place the other labels

Cyber describes the mechanism of the breach; compliance exposure (privacy rules) is a consequence; operational risk is the parent category that contains third-party risk.

Interpretation

The question asks for the most specific classification by root cause. Third-party failure is a Level 2 category under Basel's EDPM event type and a Level 1 risk in ORX's taxonomy, so "third-party risk" is a recognised category in its own right. The bank stays accountable either way.

Why the other options are wrong

A is incorrect. Too broad: operational risk contains third-party risk, so it is not the most specific answer.
C is incorrect. The privacy breach is an outcome, not the origin.
D is incorrect. Cyber is how the data were reached, not why: the cause was the vendor's inadequate protocols.

LO: ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. • **Reference:** GARP ORR Ch.13, Context and Scope (Nature of TPRM, Evolution in Recent Years)

Solution ORR-13 a.3 — Answer: A

Bank Q307 • Mock 2 Q71

Step 1 – The five stages

Business model decision; evaluation, risk rating and due diligence; contracts, SLAs and contract management; continuous monitoring; remediation or termination.

Step 2 – Match the task

Deciding which activities to keep in-house and which to outsource, in light of risk appetite, is the strategic first stage.

⇒ Business model decision.

Interpretation

Every later stage presupposes a chosen third party. The CRO here has no vendor yet, only a question about the bank's own model and appetite.

Why the other options are wrong

B is incorrect. Contract management formalises responsibilities and SLAs after a vendor is chosen.

C is incorrect. Due diligence vets a specific prospective vendor, in proportion to the relationship's risk.

D is incorrect. Evaluation and risk rating grade a particular candidate; no candidate exists yet.

LO: ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. • **Reference:** GARP ORR Ch.13, Third-Party Risk Management, Business Model Decision

Solution ORR-13 a.4 — Answer: D

Bank Q309 • Schweser Module Quiz 54.1 Q1

Step 1 – Where fourth parties are handled

GARP: contract terms are a good opportunity to address fourth-party risk; good practice is for the contract to establish standards or limits on the outsourcing done by third-party vendors, largely a copy of the firm's own rules for its vendors.

Step 2 – Name the stage

That is stage 3: contracts, SLAs and contract management, together with the audit rights needed to verify the rules.

⇒ D.

Interpretation

Limits written into the contract are what let the firm see and steer the fourth parties of Figure 1(b); audit rights then feed stage 4, monitoring.

Why the other options are wrong

A is incorrect. The business model decision is whether to outsource at all, not the terms imposed on a vendor.

B is incorrect. Remediation or termination covers grievances, exit and wind-down.

C is incorrect. Due diligence assesses a prospective vendor; contractual limits come afterwards.

LO: ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. • **Reference:** GARP ORR Ch.13, Contracts, SLAs, and Contract Management; SchweserNotes 2026 Book 3, Reading 54, LO 54.a

Solution ORR-13 a.5 — Answer: D

Bank Q302 • AnalystPrep Q.5132

Step 1 – GARP's trigger events

Data breaches or incidents; a change in the business circumstances of either firm (merger or acquisition); a legal or regulatory change; changes in the services provided; acts of God; breach of contract or performance failure.

Step 2 – Test each option

A, B and C are listed events. Risk appetite is a standing strategic parameter, not an event.
$\Rightarrow$ D.

Interpretation

Triggers exist so that reassessment does not wait for the end of the contract or the next scheduled review. A *change* in risk appetite might prompt a review, but the option names the parameter, not an event.

Why the other options are wrong

A is incorrect. Data breaches and incidents are listed triggers.
B is incorrect. A merger or acquisition changes business circumstances and is a listed trigger.
C is incorrect. Legal or regulatory change is a listed trigger.

LO: ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. • **Reference:** GARP ORR Ch.13, Continuous Monitoring

Solution ORR-13 a.6 — Answer: C

Bank Q306 • AnalystPrep Q.5136

Step 1 – The wind-down list

When a relationship ends, both parties should plan a wind-down that includes, where necessary, the transmission of IP, a plan to transition to in-house services or to another provider, and evidence of data transfer or destruction if the vendor held sensitive data.

Step 2 – Locate audit rights

Audit rights on vendors are set in the contract (stage 3) and used during monitoring (stage 4) to verify the rules the firm imposes.
$\Rightarrow$ C is not a wind-down action.

Interpretation

Evidence of data destruction is the wind-down item that the Morgan Stanley case (ORR-13 b) makes concrete: disposed hardware still held client data.

Why the other options are wrong

A is incorrect. IP transmission is an explicit wind-down item.
B is incorrect. Transition planning is an explicit wind-down item.
D is incorrect. Evidence of data transfer or destruction is an explicit wind-down item.

LO: ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. • **Reference:** GARP ORR Ch.13, Remediation or Termination; Contracts, SLAs, and Contract Management

Solution ORR-13 a.7 Answer: B

Bank Q308 • Mock 3 Q31

Step 1 – What the risk is

The vendor sells the bank's investment products under the bank's brand, so mis-selling by the vendor is the bank's conduct risk; accountability for outsourced activities is not transferable.

Step 2 – What stage 4 requires

Continuous monitoring covers service quality and compliance with regulation and contract terms, beyond the one-off onboarding due diligence.

Step 3 – Pick the control that sees behaviour

Complaint and suitability data from the vendor's sales are independent, timely indicators of conduct problems, and feeding them into the bank's own reporting puts them in front of the people accountable.

$\Rightarrow$ B.

Interpretation

Two years is long enough for practices to drift. Good monitoring measures what the vendor actually does; the other options measure what it says, how a loss would be paid, or whether it is solvent.

Why the other options are wrong

A is incorrect. A self-attestation is weak assurance from the party being monitored.

C is incorrect. An indemnity shifts some financial loss, not the regulatory and reputational damage or the accountability, and does not prevent mis-selling.

D is incorrect. Financial statements test solvency, not sales conduct.

LO: ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. • **Reference:** GARP ORR Ch.13, Continuous Monitoring; Ch.12, 12.4 D and E

Solution ORR-13 a.8 Answer: B

New • built from GARP Ch.13 and Ch.12

Step 1 – Identify the risk

SR 13-19: concentration risk arises when outsourced services are provided by a limited number of providers or are concentrated in limited geographic locations. Both conditions hold: two providers, one campus.

$\Rightarrow$ This is firm-level concentration risk the bank must manage.

Step 2 – Rate the provider

On GARP's rating criteria, process criticality is at the top level (operations halt without the vendor), and substitutability is "none or very limited": the only alternative fails in the same campus event.

$\Rightarrow$ Highest class: the most frequent and stringent monitoring, a designated point of contact and a tailored mitigation plan.

Step 3 – The resilience response

Key-supplier dependency with low substitutability is a single point of failure and a resilience KRI (ORR-4 g). Remove it where possible (a provider or site outside the campus, an in-house fallback for authorisations); otherwise reflect it in impact tolerances and stress tests. Keep a tested continuity plan and an exit strategy with comparable providers that do not share the failure point.

Interpretation

A clean SOC 2 report and a clean history describe P's controls, not the bank's dependency. The

risk sits in the structure: one campus event removes both options at once.

Why the other options are wrong

A is incorrect. Polarity and false comfort: a nominal alternative in the same location does not reduce concentration, and a critical provider gets more monitoring, not a standard review.

C is incorrect. Half of the definition: dual sourcing answers "a limited number of providers" but not "limited geographic locations". P and Q run from the same campus, so one campus event still stops every authorisation; the point of failure is shared, not removed.

D is incorrect. Stage error: substitutability is a rating criterion that sets the intensity of due diligence and monitoring throughout the relationship, not only at exit.

LO: ORR-13 a: Explain how risks related to the use of third parties can arise and describe characteristics of an effective third-party risk management framework. • **Reference:** GARP ORR Ch.13, Figure 13.2 Risk-based vendor rating; Ch.12, 12.2 and 12.4 E and F; Ch.4, 4.5 KRIs for Resilience

ORR-13 • Third-Party Risk Management • Vardeez: VERY IMPORTANT

ORR-13 b

P2 CONCEPT

Describe the lessons learned from the presented case studies.

Workbook: *none*

WHAT IS TESTED HERE

Why P2. Vardeez flags it inside a VERY IMPORTANT chapter (ORR-13, theme 1 of his ORR list). **Vardeez:** his notes label this LO "LO 52.b" (consolidated volume pp.84 to 85): the two cases side by side (what happened, consequences, failures) and four lessons. His LO line still carries an older wording ("the case study involving a data breach caused by a third-party vendor"); the map wording above is the official one and covers both cases.

Reported exam shapes: none reported. The questions below are built from the LO wording and Vardeez's comparison.

What the questions look like: the circumstances of each case, the regulator's finding and fine, cross-mapping (which failure belongs to which bank), and applying a case's lessons to a new outsourcing plan.

See also: workbook D2.1 (a decommissioning vendor and subcontractor failure, modelled on the Morgan Stanley case) is worked under ORR-12 a. The TPRM life cycle is in ORR-13 a.

1. Capital One and AWS (2019)

- **What happened.** In July 2019 Capital One announced that data on about 100 million people in the United States had been illegally accessed. A former **AWS cloud services employee** was arrested and charged with stealing 140,000 Social Security numbers and 80,000 bank account numbers. The attacker exploited a **misconfigured web application firewall** to reach files in an AWS database.
- **Why it worked.** Capital One and AWS knew their systems were vulnerable to server-side request forgery (SSRF) attacks. Encrypting the data would have made it useless to attackers, but it was **not encrypted**, because of the improper configuration of Capital One's own systems.
- **Response and penalty.** The bank fixed the bug, checked for other misconfigurations and changed its automated scanning to look for the issue regularly. The OCC fined it **USD 80 million** for "failure to establish effective risk assessment processes prior to migrating significant information technology operations to the public cloud environment". Lawsuits were consolidated into a single case in 2020.
- **The deeper finding.** A history of weak control environment: the OCC found unsafe or unsound practices and noncompliance with the Interagency Guidelines Establishing Information Security Standards, and an internal audit four years earlier (2015) had "failed to identify numerous control weaknesses and gaps in the cloud operating environment".

Lesson. "All the major cloud providers offer the controls needed to keep the data in their cloud buckets private, but customers need to use them." Strong built-in security at the provider does not move risk management, monitoring, back-ups and maintenance off the business.

2. Morgan Stanley data-centre decommissioning (2016, 2019)

- **What happened.** Failures in the risk management and oversight of vendors when decommissioning two wealth management data servers in 2016, with similar deficiencies when decommissioning wide-area application service (WAAS) devices in 2019. Hardware the bank had disposed of was found still to contain client data.
- **Penalty and findings.** The OCC fined Morgan Stanley Bank and Morgan Stanley Private Bank **USD 60 million**. The bank failed to (1) effectively assess or address the risks of decommissioning its hardware; (2) adequately assess the risk of using third-party vendors, **including subcontractors**; (3) maintain an appropriate **inventory of customer data** stored on its devices. It did not exercise adequate due diligence in selecting the vendors or adequately monitor their performance.
- **Aftermath.** Customers were notified (for the 2016 incident at the OCC's direction, for 2019 voluntarily) and offered two years of free credit monitoring; the bank also faces a class action.

Lesson. Data security and TPRM are tightly linked, and, as ORR-5 puts it, outsourcing may transfer some of the operational risk of an activity, but **the accountability for these risks is not transferable**.

> **Correction to the source notes.** GARP (and Schweser after it) says Morgan Stanley began notifying wealth management customers "in July 2019". The notification letters went out in **July 2020**, shortly before the OCC's USD 60 million penalty (October 2020). The 2019 in the case is the year of the second (WAAS) decommissioning, not of the notification.

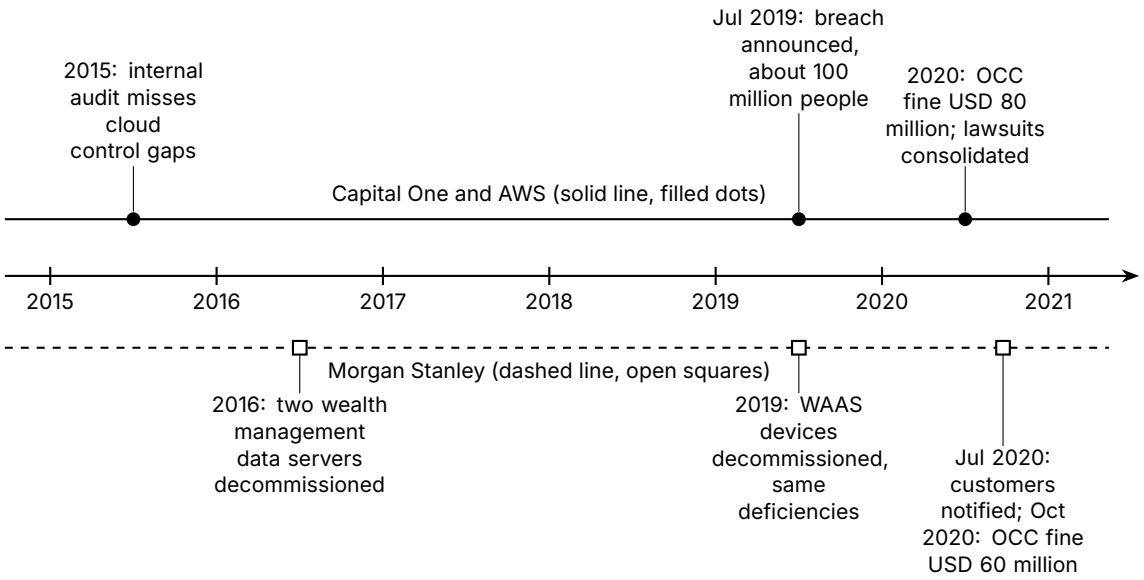


Figure 1. The two cases on one time line (positions within a year are approximate). Capital One events sit above the axis (solid line, filled dots), Morgan Stanley events below it (dashed line, open squares). In both, the weakness existed years before the fine.

3. Lessons, mapped to the TPRM life cycle

Lesson	Case	Life-cycle stage (ORR-13 a)
Assess the risks before migrating critical operations to the cloud	Capital One	1 and 2: decision, risk rating
The provider offers the controls; the customer must configure and use them (encryption, firewall settings, scanning)	Capital One	3 and 4: responsibilities, monitoring
Do due diligence on vendors *and their subcontractors*	Morgan Stanley	2 (and 3: standards on fourth parties)
Monitor vendors' performance, not only select them	Morgan Stanley	4: continuous monitoring
Keep an inventory of customer data; demand evidence of data destruction	Morgan Stanley	5: wind-down
Fines follow long-standing control weaknesses that internal audit missed or that recurred	both	the whole framework
Outsourcing can transfer some risk, never the accountability	both	the whole framework

Summary card: ORR-13 b, the two cases side by side

	Capital One (AWS)	**Morgan Stanley**
Third party	cloud provider; attacker a former AWS employee	decommissioning vendors and subcontractors
Weakness	misconfigured web application firewall (SSRF); unencrypted data	hardware disposed of with client data on it
Regulator, fine	OCC, USD 80 million	OCC, USD 60 million
Cited failure	no effective risk assessment before migrating to the public cloud	no risk assessment of decommissioning or of vendors and subcontractors; no data inventory; weak vendor selection and monitoring
History	2015 internal audit missed cloud control gaps	deficiencies in 2016 and again in 2019
Lesson	customer must use the cloud controls	accountability is not transferable

Exam traps

- **Case cross-mapping.** Firewall, SSRF, encryption, cloud migration: Capital One. Decommissioning, subcontractors, data inventory: Morgan Stanley.
- **Fine swap.** Capital One USD 80 million; Morgan Stanley USD 60 million. Both from the OCC.
- **Who was fined.** The banks, not AWS or the decommissioning vendors.
- **Who the attacker was.** A former employee of the cloud provider, not of Capital One.
- **What the fine was for.** Capital One: the missing pre-migration risk assessment, not the hack itself. Morgan Stanley: vendor and data management failures, not a late notification.
- **Remediation is not absolution.** Capital One fixed the bug at once and was still fined; the

weakness was older than the breach.

- **Dates.** Capital One: breach announced July 2019. Morgan Stanley: decommissionings in 2016 and 2019. Both OCC fines: 2020. The book's "July 2019" for Morgan Stanley's customer notification is a misprint (correction box); no answer turns on it.

Practice questions: ORR-13 b

Question ORR-13 b.1

Bank Q311 • GARP PE2 Q30 • Mock 4 Q31

An enterprise risk consultant is presenting about the management of risk associated with third-party vendor relationships at a financial conference. To emphasize the importance of understanding this risk and to illustrate lessons learned, the consultant describes several past examples of large losses and data breaches incurred by different financial institutions due to deficient or fraudulent third-party vendor practices. One example provided is the large loss incurred by Capital One, a US-based bank holding company, that resulted from its relationship with a third-party vendor. Which of the following best describes the circumstances that led to the loss in this case?

A. The vendor provided an inaccurate loan pricing model to Capital One, which incurred far greater default losses than expected.

B. A bill payment system provided by the vendor failed for an extended period of time, resulting in many Capital One customers canceling their accounts and causing severe reputational damage.

C. The vendor's sales manager established extremely high incentives for its representatives to sell Capital One products, resulting in regulatory fines for selling inappropriate products to consumers.

D. A former staff member of the vendor hacked into a database of Capital One's personal customer information that was stored on the vendor's cloud services platform and stole much of this information.

Question ORR-13 b.2

Bank Q312 • Schweser Module Quiz 54.1 Q3

A key conclusion from the Capital One and Morgan Stanley case studies is that accountability for operational risk:

A. is not transferable.

B. ultimately rests with the third-party vendor.

C. ultimately rests with either the third-party vendor or subcontractor, whichever experienced the risk control problem.

D. is a fully shared responsibility between the company using third-party vendors and the third-party vendors themselves.

Question ORR-13 b.3 New • built from GARP Ch.13

An internal auditor is preparing a slide that pairs each of GARP's two third-party case studies with the regulator's penalty and finding. Which pairing is correct?

A. Capital One: OCC fine of USD 60 million for failing to keep an inventory of customer data stored on decommissioned servers.

B. Morgan Stanley: OCC fine of USD 80 million after a former cloud-provider employee exploited a misconfigured web application firewall.

C. Capital One: OCC fine of USD 80 million for failing to establish effective risk assessment processes before migrating significant IT operations to the public cloud.

D. Morgan Stanley: the penalty was imposed on the decommissioning vendor and its subcontractor, since they handled the hardware that left client data exposed.

Question ORR-13 b.4 New • built from GARP Ch.13

A board risk committee asks what the Capital One and Morgan Stanley enforcement actions show about how such penalties arise. Which statement is best supported by the case facts?

A. Both penalties followed a single, unforeseeable incident at a well-controlled bank, showing that regulators penalise outcomes rather than control weaknesses.

B. Both penalties reflected weaknesses that had persisted or recurred: Capital One's internal audit had earlier failed to identify control gaps in its cloud environment, and Morgan Stanley showed similar decommissioning deficiencies in 2016 and again in 2019.

C. Neither bank had to remediate with customers, because the data exposure occurred at a third party rather than at the bank itself.

D. Both penalties were triggered by the banks' failure to notify customers in time, as the OCC found no deficiency in their risk management.

Question ORR-13 b.5 New • built from GARP Ch.13

A European bank plans to migrate its card-customer database to a public cloud provider. The CIO argues that the provider's platform has strong built-in security and that the provider is therefore responsible for keeping the data safe. Applying the lessons of the Capital One case, which plan should the CRO require?

A. Accept the provider's built-in security as sufficient and focus the bank's effort on negotiating an indemnity for data breaches.

B. Complete a risk assessment of the migration before moving the data, configure and use the cloud controls (including encryption of the data), and scan regularly for misconfigurations.

C. Postpone any review of the cloud configuration to the first annual contract review, since a provider with strong security will flag misconfigurations itself.

D. Keep the data unencrypted so that the bank's fraud teams can query it quickly, relying on the web application firewall as the single line of defence.

Question ORR-13 b.6 Bank Q313 • New (bank, GARP style)

A bank's wealth management division plans to decommission several data servers that hold client records. The bank will hire an IT asset disposal vendor, which in turn will use a subcontractor to wipe and dispose of the hardware. Before approving the arrangement, the CRO asks an operational risk manager to apply the lessons of the OCC's 2020 enforcement action against Morgan Stanley over its weak third-party controls in the decommissioning of data servers. Which of the following actions would best address the deficiencies the OCC identified in that case?

A. Perform due diligence on both the vendor and its subcontractor, monitor their performance during the work, and keep an inventory of the client data stored on each device being decommissioned.

B. Include a contract clause that transfers full liability for any exposure of client data to the vendor, so that the bank is no longer accountable for the risk.

C. Accept the vendor's written certification that all devices have been wiped, given its specialist expertise, and limit oversight of the vendor to the scheduled end-of-contract review.

D. Focus the review on the configuration of the web application firewall protecting the servers, since a misconfigured firewall was the main cause of the data exposure in that case.

Solutions • ORR-13 b

Solution ORR-13 b.1 — Answer: D

Bank Q311 • GARP PE2 Q30

Step 1 – Recall the case

In July 2019 Capital One announced that data on about 100 million people had been illegally accessed. A former employee of AWS, its cloud provider, exploited a misconfigured web application firewall to reach files in an AWS database.

Step 2 – Why the loss was large

The data were not encrypted, because of Capital One's own configuration, so the stolen information was usable at once.
$\Rightarrow$ D describes the circumstances.

Interpretation

The OCC then fined Capital One USD 80 million for failing to establish effective risk assessment processes before migrating significant IT operations to the public cloud: a third-party data security failure for which the bank remained accountable.

Why the other options are wrong

A is incorrect. Describes a model risk event; nothing of the kind happened at Capital One.
B is incorrect. Describes a prolonged service outage; the case was data theft.
C is incorrect. Describes incentive-driven mis-selling, the concern of ORR-12 a element D, not this case.

LO: ORR-13 b: Describe the lessons learned from the presented case studies. • **Reference:** GARP ORR Ch.13, Case Studies, Capital One Data Breach by Former Amazon Web Services (AWS) Employee

Solution ORR-13 b.2 — Answer: A

Bank Q312 • Schweser Module Quiz 54.1 Q3

Step 1 – Who was penalised

In both cases the OCC fined the bank that outsourced (USD 80 million and USD 60 million), citing its own failure to assess and manage vendor risk.

Step 2 – GARP's stated lesson

Outsourcing may transfer some of the operational risks of an activity, but the accountability for these risks is not transferable.
$\Rightarrow$ A.

Interpretation

Vendors and subcontractors may share the blame, and the bank may recover money from them under the contract, but the bank answers to customers and regulators.

Why the other options are wrong

B is incorrect. Reverses the lesson: the fines fell on the banks.
C is incorrect. Accountability does not follow the location of the control failure; it stays with the outsourcing firm.
D is incorrect. Accountability is not divided away; the institution keeps it in full.

LO: ORR-13 b: Describe the lessons learned from the presented case studies. • **Reference:** GARP ORR Ch.13, Case Studies (OCC Fines Morgan Stanley); Ch.5, 5.1 Risk Response

Solution ORR-13 b.3 Answer: C

New • built from GARP Ch.13

Step 1 – Capital One

OCC, USD 80 million, for "failure to establish effective risk assessment processes prior to migrating significant information technology operations to the public cloud environment".
⇒ C matches.

Step 2 – Morgan Stanley

OCC, USD 60 million, for failing to assess the risks of decommissioning, to assess vendors including subcontractors, and to keep an inventory of customer data on its devices.

Interpretation

Two features separate the cases: the technology (cloud configuration against hardware disposal) and the finding (pre-migration risk assessment against vendor oversight and data inventory). Fix those, and the amounts follow.

Why the other options are wrong

A is incorrect. Gives Morgan Stanley's amount and finding to Capital One.
B is incorrect. Gives Capital One's amount and circumstances to Morgan Stanley.
D is incorrect. Role misassignment: the OCC fined the bank; the accountability for vendor oversight stayed with it.

LO: ORR-13 b: Describe the lessons learned from the presented case studies. • **Reference:** GARP ORR Ch.13, Case Studies

Solution ORR-13 b.4 Answer: B

New • built from GARP Ch.13

Step 1 – Capital One's history

"Like in other cases of regulatory fines, the bank had a history of weak control environment, and failures to detect or address it, often for years at a time." The consent order cites an internal audit (2015, four years before the breach) that failed to identify numerous control weaknesses and gaps in the cloud operating environment.

Step 2 – Morgan Stanley's history

Deficiencies in the 2016 decommissioning of two data servers recurred in the 2019 decommissioning of WAAS devices; the OCC's findings cover both.
⇒ B.

Interpretation

Regulators penalise the framework: risk assessment, vendor due diligence and monitoring, data inventories, and the third line's ability to catch gaps. The incident only makes the weakness visible.

Why the other options are wrong

A is incorrect. Polarity: both banks had long-standing weaknesses; the penalties targeted control failures.
C is incorrect. Both banks faced customer remediation and litigation: Morgan Stanley notified customers and offered two years of free credit monitoring and faces a class action; Capital One's lawsuits were consolidated in 2020.
D is incorrect. The OCC found deficient risk management (unsafe or unsound practices); notification timing was not the basis of either penalty.

LO: ORR-13 b: Describe the lessons learned from the presented case studies. • **Reference:** GARP ORR Ch.13, Case Studies (Capital One; OCC Fines Morgan Stanley)

Solution ORR-13 b.5 — Answer: B

New • built from GARP Ch.13

Step 1 – What Capital One got wrong

No effective risk assessment before migrating to the public cloud; a misconfigured firewall; data left unencrypted by its own configuration.

Step 2 – What the case says about cloud providers

"All the major cloud providers offer the controls needed to keep the data in their cloud buckets private, but customers need to use them." Risk management, monitoring, back-ups and maintenance remain the business's responsibility.

Step 3 – Build the plan

Assess before migrating; configure and use the controls, with encryption so that stolen data are useless; scan regularly for misconfigurations (Capital One's own fix after the breach).
$\Rightarrow$ B.

Interpretation

The CIO's argument is the one the case refutes. Strong provider security is a capability the bank must use, not a transfer of responsibility.

Why the other options are wrong

A is incorrect. Role misassignment: an indemnity moves some cost, not the accountability, and does nothing to prevent the breach.
C is incorrect. Timing and polarity: risk assessment must come before migration, and configuration is the customer's job, not the provider's.
D is incorrect. The opposite of the lesson: unencrypted data and a single line of defence are what made the Capital One breach damaging.

LO: ORR-13 b: Describe the lessons learned from the presented case studies. • **Reference:** GARP ORR Ch.13, Case Studies, Capital One Data Breach

Solution ORR-13 b.6 — Answer: A

Bank Q313 • New (bank, GARP style)

Step 1 – The OCC's findings

Morgan Stanley failed to assess or address the risks of decommissioning its hardware, failed to assess the risk of using third-party vendors including subcontractors, and failed to keep an inventory of customer data on its devices. It did not exercise adequate due diligence in selecting the vendors or adequately monitor their performance.

Step 2 – Match the actions

Due diligence on the vendor and the subcontractor, performance monitoring during the work, and a data inventory for each device answer each finding.
$\Rightarrow$ A.

Interpretation

Without the inventory the bank cannot confirm that disposed hardware no longer holds client information; that is also the "evidence of data destruction" that the TPRM wind-down stage asks for (ORR-13 a).

Why the other options are wrong

B is incorrect. Accountability is not transferable; a liability clause does not remove the bank's responsibility to regulators or customers.
C is incorrect. Repeats Morgan Stanley's failure to monitor vendor performance; good practice ties reassessment to events, not only to scheduled reviews.

D is incorrect. Case cross-mapping: the misconfigured firewall belongs to the Capital One breach.

LO: ORR-13 b: Describe the lessons learned from the presented case studies. • **Reference:** GARP ORR Ch.13, Case Studies, OCC Fines Morgan Stanley for Weak Third-Party Controls Over Decommissioning of Data Centers

ORR-14 • Investor Protection and Compliance Risks in Investment Activities • Vardeez: VERY IMPORTANT

ORR-14 a

P2 CONCEPT

Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank.

Workbook: D21 Investor Protection, MiFID and the Volcker Rule • Tier D

WHAT IS TESTED HERE

Why P2. Vardeez rates ORR-14 VERY IMPORTANT: it is theme 2 of his ORR list (Investor Protection: MiFID and the Volcker Rule), ROI rank 35 of 55 in the consolidated volume. The best workbook coverage is Tier D (D21, topic map #52, 2 of 16 sources, revision notes only, no questions).

Vardeez: his notes label this LO "LO 53.a" (consolidated volume p.144): the two aims of investor protection (suitability, disclosure and fiduciary duty; preventing improper business practices), his Figure 53.1 table of MiFID I (2007), MiFID II and MiFIR (2014) and Dodd-Frank with the Volcker Rule, and compliance risk management (worked under ORR-14 b with the cases, as workbook D21 does).

Reported exam shapes

- **S1** Suitability and appropriateness obligations.
- **S3** Conflicts-of-interest management under MiFID II and MiFIR.
- **S4** The Volcker Rule's proprietary-trading prohibition and its market-making and hedging exemptions, notes with scope/condition errors.

What the questions look like: sort a provision into its regime (CFPB, whistleblowers, clearing, Volcker: Dodd-Frank; best execution, independent advice, eligible counterparties: MiFID II and MiFIR); say what MiFID II added to MiFID; place an investor protection failure in the Basel taxonomy; then apply three obligations to a firm's practice: which client test applies, how a conflict must be handled, and whether a desk stays inside a Volcker exemption.

Beyond the book: the GARP chapter names suitability, conflicts of interest and the Volcker Rule but does not set out the suitability and appropriateness tests, the conflicts hierarchy or the Volcker exemptions. Sections 4 to 6 add that detail from the legal texts, marked *outside the GARP text*, because the map reports exam shapes on all three.

See also: best execution and the case studies are ORR-14 b; incentive compensation review in outsourcing is ORR-12 a (element D).

1. What investor protection covers

GARP defines investor protection as legislation and regulation "aimed at ensuring that investors are fully informed about their investments when they enter into financial transactions." The same mechanisms protect investors from **misrepresentation** by intermediaries and institutions, establish **accountability** in case of fraud or insider trading, and support **cross-jurisdictional cooperation** between regulators and law enforcement. The EU and the United States both have comprehensive regimes, and some of the largest settlements ever paid by banks and investment firms come from investor protection violations (ORR-14 b).

- **Taxonomy.** Compliance with financial laws usually falls in Basel event type 4, **Clients, Products and Business Practices** (CPBP); investor protection specifically in **4.1 Suitability, Disclosure & Fiduciary** or **4.2 Improper Business or Market Practices** (ORR-3). Vardeez's two aims map onto

these: products suitable, risks disclosed, advisers acting in the client's best interest (4.1); no misrepresentation, market abuse or unmanaged conflicts of interest (4.2).

- **Link to AML.** Compliance includes strict KYC filings so that money flowing into financial products is not of doubtful origin; investor protection and AML legislation are therefore connected (ORR-10).

2. MiFID, then MiFID II with MiFIR

- **MiFID** is the Markets in Financial Instruments Directive (2004/39/EC), promulgated in 2004, applicable across the EU since November 2007 and in force from 2007 to 2018. It prescribes **conduct of business and organisational requirements** for investment firms and **authorisation requirements for regulated markets**, defines **regulatory reporting and trade transparency** obligations to prevent market abuse, and sets the rules for admitting financial instruments to public trading.
- **MiFID II and MiFIR.** After the 2008 crisis, the EU adopted new rules in June 2014: a revised directive (MiFID II) and a regulation (MiFIR, Markets in Financial Instruments Regulation), to strengthen investor protection and cover new trading platforms and activities. They added requirements on **public disclosure of trading data** and on **disclosure of transaction data to regulators and supervisors**. GARP's list of what the package addresses:
  (1) remuneration of traders and advisors, and conflicts of interest;
  (2) communication to customers that is fair and non-misleading;
  (3) definition and independence of investment advice;
  (4) sales process and product governance;
  (5) best execution of trades for clients;
  (6) dealings with eligible counterparties.
- **Directive versus regulation.** An EU regulation (MiFIR) applies directly in every member state. A directive (MiFID, MiFID II) must be turned into national law, and each country may be more stringent than the directive, but not less.

> **Correction to the source notes.** GARP (and Schweser after it) attributes the six-item list above to MiFIR, the regulation. In the legislation these conduct rules sit in the MiFID II directive: conflicts of interest and staff remuneration (Art. 23, 24), independent advice and inducements (Art. 24), product governance (Art. 16, 24), suitability and appropriateness (Art. 25), best execution (Art. 27) and eligible counterparties (Art. 30). MiFIR carries trade transparency, transaction reporting, trading obligations and product intervention powers. In an exam answer, treat the list as "MiFID II/MiFIR"; the point tested is that none of the six items is a Dodd-Frank provision.

3. Dodd-Frank and its Investor Protection Act

The Investor Protection Act is a component of the **Dodd-Frank Wall Street Reform and Consumer Protection Act**, the U.S. response to the 2007 crisis.

- **Investor Protection Act:** a committee to consult the **SEC** on regulatory priorities around new financial products, fee structures and trading strategies; increased protection for **whistleblowers**.
- **OTC derivatives:** regulation of trading delegated to the **SEC and the CFTC**; firms buying and selling derivatives must use **clearinghouses**.
- **Financial stability:** federal oversight, a financial stability oversight council, and a reorganisation of financial regulation.

- **Volcker Rule:** intends to prevent commercial banks from engaging in speculative activities and proprietary trading for profit, and limits banks' investments in hedge funds and private equity funds (Section 6).
- **Consumer Financial Protection Bureau (CFPB):** an **independent** financial regulator for consumer finance markets: mortgages, student loans, credit cards.

Correction to the source notes. GARP and Schweser date Dodd-Frank "2009". The act was signed into law on 21 July 2010; 2009 is the year the House passed its first version. Use 2010.

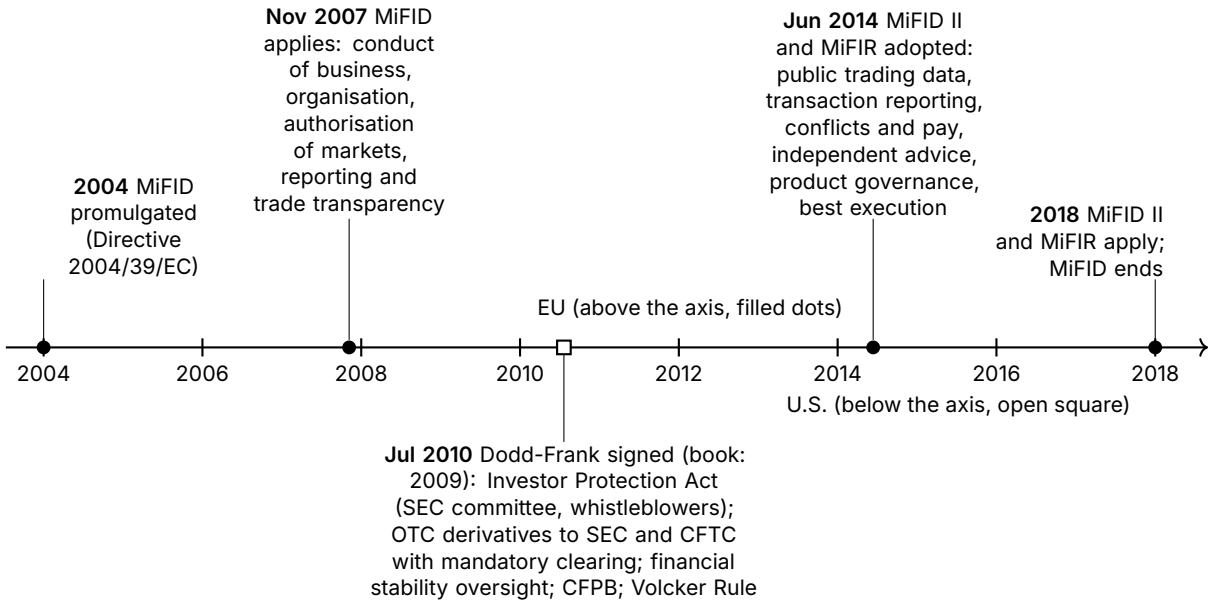


Figure 1. The three regimes on one time line and what each added. EU milestones sit above the axis (filled dots), the U.S. act below it (open square). Positions within a year are approximate.

4. Suitability and appropriateness (shape S1)

In the GARP text, suitability appears three times: as Basel category 4.1 Suitability, Disclosure & Fiduciary; in SR 13-19's example of an inappropriate incentive, variable fees that steer customers to higher-margin products without regard to whether they suit them (ORR-12 a, element D); and behind the UBS case, auction rate securities sold as cash equivalents (ORR-14 b).

Outside the GARP text (MiFID II, Art. 25), the test depends on the *service*, not on the client or the product alone (Figure 2):

- **Suitability** applies to **investment advice and portfolio management**. The firm obtains the client's knowledge and experience, financial situation including the ability to bear losses, and investment objectives including risk tolerance, and recommends or trades only what is suitable. Retail clients receive a suitability statement.
- **Appropriateness** applies to **other (non-advised) services**. The firm checks only knowledge and experience, that is, whether the client can understand the risks. If the product is not appropriate, the firm **warns** the client; the client may still go ahead.
- **Execution only:** no test when the instrument is **non-complex** (for example shares listed on a regulated market), the service is at the **client's own initiative**, and the client has been told that no assessment will be made.

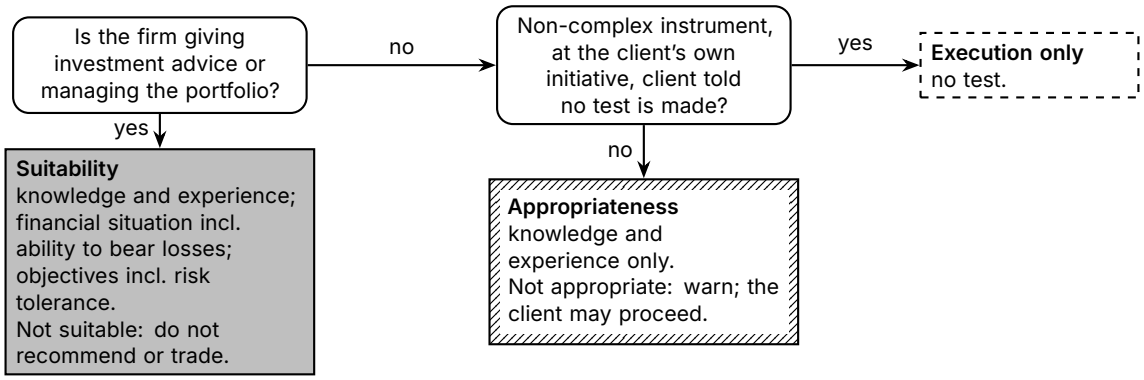


Figure 2. Which client test applies under MiFID II (outside the GARP text). Suitability box: grey fill; appropriateness box: hatched; execution only: dashed outline. The deeper the firm's role in the decision, the more it must know about the client.

5. Conflicts of interest (shape S3)

In the GARP text: the MiFID II/MiFIR package addresses the remuneration of traders and advisors and conflicts of interest, and the definition and independence of investment advice. Among the specific drivers of compliance risk GARP names the conflict of traders who trade both for their clients' books and for the firm's own book, and the information asymmetry between retail investors and the banks and asset managers that sell to them.

Outside the GARP text (MiFID II, Art. 16, 23, 24), conflicts are handled in a fixed order:

1. **Identify** conflicts between the firm (its staff, its own book) and its clients, and between clients.
2. **Prevent or manage** them through organisational and administrative arrangements: information barriers between proprietary and client business, separate supervision, remuneration that does not reward recommending one product when another would better meet the client's needs.
3. **Disclose** to the client, specifically enough for an informed decision, only as a **last resort**, where the arrangements cannot ensure with reasonable confidence that the risk of damage to clients is prevented.

Two hard rules sit on top: a firm that calls its advice **independent** must assess a sufficiently wide range of products and must **not accept and retain** fees or commissions from third parties (any it receives go to the client in full; minor non-monetary benefits excepted and disclosed); the same inducement ban applies to **portfolio management**.

6. The Volcker Rule and its exemptions (shape S4)

In the GARP text: contained in Dodd-Frank, the rule "intends to prevent commercial banks from engaging in speculative activities and proprietary trading for profit" and limits banks' investments in hedge funds and private equity funds. **Outside the GARP text** (implementing regulations, 2013), it applies to banking entities and permits activities that serve clients or reduce the bank's own risk, each under a condition:

Activity	Permitted when	Prohibited proprietary trading when
Market making	inventory is designed not to exceed the **reasonably expected near-term demand** of clients, customers or counterparties	positions build up beyond that demand to profit from price moves, however actively the desk quotes
Underwriting	positions are likewise sized to expected near-term demand	the desk holds unsold paper as a position
Risk-mitigating hedging	the hedge is designed to reduce **specific, identifiable risks** of the bank's own positions and is recalibrated	the "hedge" expresses a market view or creates significant new unhedged risk
Government obligations	trading U.S. government, agency, state or municipal obligations	(exempt)
On behalf of customers	the bank acts as agent, broker or fiduciary	the bank trades for its own account
Covered funds	the bank's ownership of hedge and private equity funds stays within limits, broadly 3% of any one fund and 3% of Tier 1 capital in aggregate	the bank invests beyond the limits

The rule restricts the *bank*; it does not stop the hedge funds themselves, or non-bank asset managers, from trading for profit.

Summary card: ORR-14 a, the regimes side by side

Regime	Form and dates	What it adds
MiFID	EU directive 2004/39/EC; 2004, applied Nov 2007, to 2018	conduct of business and organisational rules; authorisation of regulated markets; reporting and trade transparency against market abuse; admission of instruments to trading
MiFID II and MiFIR	EU directive and regulation; adopted Jun 2014, applied 2018	public trading data; transaction reporting; the six items (pay and conflicts, fair communication, independent advice, product governance, best execution, eligible counterparties)
Investor Protection Act	part of Dodd-Frank; 2010 (book: 2009)	SEC consultation committee on products, fees, strategies; whistleblower protection
Rest of Dodd-Frank	U.S. act, 2010	OTC derivatives to SEC and CFTC with clearinghouses; stability oversight council; CFPB (independent); Volcker Rule
Client tests (S1)	MiFID II, outside GARP	advice and portfolio management: suitability; non-advised: appropriateness (warn); non-complex at client's initiative: none
Conflicts (S3)	MiFID II, outside GARP	identify, prevent or manage, disclose as last resort; no inducements in independent advice
Volcker (S4)	Dodd-Frank, exemptions outside GARP	no prop trading or excess fund stakes; market making within near-term demand; hedges of specific, identifiable risks

Exam traps

- **Regime swap, part for whole.** Whistleblowers, SEC committee, CFPB, clearinghouses, Volcker: Dodd-Frank (the Volcker Rule is one provision of it, and created neither the CFPB nor the whistleblower protections). Best execution, independent advice, product governance, eligible counterparties: MiFID II/MiFIR.
- **Directive versus regulation.** MiFID and MiFID II are directives (national law, stricter allowed, never less); MiFIR is a regulation (direct application).
- **"MiFID had no reporting."** MiFID already set regulatory reporting and trade transparency; MiFID II added public trading data and transaction reporting.
- **Client tests.** The service decides (advice and portfolio management need suitability, whoever the client is); a failed appropriateness test leads to a warning, not a refusal.
- **Disclosure first.** Disclosure is the last resort for a conflict, never the primary control, and it cannot cure inducements in independent advice.
- **Volcker scope and conditions.** Not a ban on all trading; market making only within near-term client demand; hedges must target specific, identifiable risks; the rule binds banks, not the funds they invest in.
- **Date.** Dodd-Frank 2010 (the book prints 2009; correction box).

Practice questions: ORR-14 a

Question ORR-14 a.1

Bank Q322 • AnalystPrep Q.4852 (rebuilt)

A bank is fined for selling a complex product to retail clients without adequate disclosure of its risks and without assessing suitability. Under the Basel operational risk event taxonomy, compliance failures of this kind generally fall into which event type and subcategories?

A. Execution, Delivery and Process Management, covering failed trade settlement and processing errors.

B. Clients, Products and Business Practices, covering Suitability, Disclosure and Fiduciary, and Improper Business or Market Practices.

C. Internal Fraud, covering unauthorized activity by employees.

D. External Fraud, covering systems security breaches and theft by third parties.

Question ORR-14 a.2

Bank Q319 • Mock 1 Q74 (rebuilt)

Which of the following statements about the EU's MiFID and MiFID II is most accurate?

A. MiFID prescribes conduct of business and organizational requirements for investment firms and defines regulatory reporting and trade transparency obligations to prevent market abuse.

B. MiFID contains no regulatory reporting requirements; these were introduced for the first time under MiFID II.

C. MiFID II is a U.S. law enacted as part of the Dodd-Frank Act to restrict commercial banks' proprietary trading.

D. MiFID is an investor protection regulation, whereas MiFID II deals specifically with commercial banks.

Question ORR-14 a.3

Bank Q317 • AnalystPrep Q.5146 (rebuilt)

Which of the following was a key feature of the revision of MiFID into MiFID II (adopted in 2014 together with MiFIR)?

A. Additional requirements on public disclosure of trading data and on disclosure of transaction data to regulators and supervisors.

B. Creation of an independent regulator for consumer finance markets such as mortgages and credit cards.

C. A ban on commercial banks' proprietary trading and investments in hedge funds.

D. A requirement that all OTC derivatives be traded through clearinghouses.

Question ORR-14 a.4 Bank Q315 • AnalystPrep Q.5139

Which of the following is NOT one of the activities addressed by the Markets in Financial Instruments Regulation (MiFIR)?

A. Definition and independence of investment advice.

B. Best execution of trades for clients.

C. Protection for whistleblowers.

D. Dealings with eligible counterparties.

Question ORR-14 a.5 Bank Q314 • AP Mock 3 Q70

Which regulation resulted in the formation of the Consumer Financial Protection Bureau (CFPB) as an independent financial regulator overseeing consumer finance markets?

A. The Markets in Financial Instruments Directive (MiFID).

B. The Dodd-Frank Act.

C. The Financial Industry Regulatory Authority (FINRA).

D. The Volcker Rule.

Question ORR-14 a.6 Bank Q316 • AnalystPrep Q.5144

Which of the following is an effect of the Volcker Rule?

A. Enhanced protection for witnesses and whistleblowers.

B. Requiring derivatives to be bought and sold through clearinghouses.

C. Stopping commercial banks from engaging in speculative and proprietary trading.

D. Establishing the Consumer Financial Protection Bureau.

Question ORR-14 a.7 New • built from GARP Ch.14 and workbook D21 (MiFID II Art. 25)

The head of compliance at a Frankfurt investment firm is checking three retail client files against MiFID II. Client 1 asked the firm's adviser which structured note to buy for her retirement savings. Client 2, using the firm's online platform without advice, wants to buy a complex leveraged certificate. Client 3, on his own initiative, placed an order on the platform for shares listed on a regulated market, after being told that the firm would not assess appropriateness. Which description of the firm's obligations is correct?

A. Suitability for all three clients, because all three are retail clients and the test exists to protect retail investors.

B. Appropriateness for Client 1, since the advice concerns a single product; suitability for Client 2, since the product is complex; no test for Client 3.

C. Suitability for Client 1; appropriateness for Client 2, with the order refused if the certificate is not appropriate; appropriateness for Client 3.

D. Suitability for Client 1; appropriateness for Client 2, with a warning if the certificate is not appropriate; no test for Client 3.

Question ORR-14 a.8 New • built from GARP Ch.14 and workbook D21 (MiFID II Art. 23, 24)

The head of compliance at a Milan bank is reviewing its private bank against the MiFID II and MiFIR conflicts-of-interest rules. The bank markets its advice as independent. Relationship managers earn a bonus tied to sales of the bank's own funds, the bank keeps trail commissions (retrocessions) paid by third-party fund houses whose funds it recommends, and the proprietary trading desk sits next to the client execution desk with no separation. Which plan is consistent with the rules?

A. Keep all three arrangements and disclose each of them in detail to every client, since disclosure is the primary tool for managing conflicts.

B. Stop retaining the retrocessions on independent advice, stop rewarding staff for selling the bank's own funds over better-suited ones, separate the proprietary desk, and disclose only what remains.

C. Keep the retrocessions, since fund houses rather than clients pay them, and fix only the bonus scheme and the separation of the two desks.

D. Leave the bonus scheme unchanged, since staff remuneration is governed by employment law and falls outside the scope of MiFID II and MiFIR.

Question ORR-14 a.9 New • built from GARP Ch.14 and workbook D21 (Volcker exemptions)

A trainee in the Volcker compliance team of a U.S. bank holding company drafts four notes for the bank's trading manual. Which note is correct?

A. The rule bars the bank from all trading for its own account, including market making for clients and hedging of its own positions.

B. The bond desk qualifies for the market-making exemption whenever it quotes two-way prices, however large its inventory is relative to client demand.

C. The rule limits proprietary trading by any fund manager, so the hedge funds in which the bank invests must also stop trading for profit.

D. Market-making inventory must be designed not to exceed clients' reasonably expected near-term demand, and hedges must target specific, identifiable risks of the bank's positions.

Solutions • ORR-14 a

Solution ORR-14 a.1

Answer: B

Bank Q322 • AnalystPrep Q.4852

Step 1 – Name the failure

Risks not disclosed and suitability not assessed when selling to clients: a breach of the firm's duties to its clients, not a processing slip or a theft.

Step 2 – Place it in the taxonomy

GARP: compliance with financial laws usually falls into Basel event type 4, Clients, Products and Business Practices; investor protection in particular into 4.1 Suitability, Disclosure & Fiduciary or 4.2 Improper Business or Market Practices.
$\Rightarrow$ B.

Interpretation

An unsuitable, undisclosed sale is 4.1; market manipulation such as spoofing would be 4.2 (ORR-14 b). GARP's control discussion treats an *intentional* breach as a form of internal fraud (ORR-14 b), but nothing in this stem shows intent, and the question asks for the event classification.

Why the other options are wrong

A is incorrect. EDPM covers transaction capture, execution and settlement errors; the failure here is a conduct duty owed to clients.
C is incorrect. Internal fraud needs an intentional, unauthorised act by staff; no intent is described.
D is incorrect. External fraud is committed by third parties against the firm; here the firm itself harmed its clients.

LO: ORR-14 a: Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank. • **Reference:** GARP ORR Ch.14, Context and Scope; Ch.3 (Basel event types)

Solution ORR-14 a.2

Answer: A

Bank Q319 • Mock 1 Q74

Step 1 – What MiFID does

MiFID (2004, applicable from November 2007) prescribes conduct of business and organisational requirements for investment firms and authorisation requirements for regulated markets, and defines regulatory reporting and trade transparency obligations to prevent market abuse.
$\Rightarrow$ A restates the book.

Step 2 – What MiFID II changed

MiFID II and MiFIR (2014) reinforced investor protection and *added* public disclosure of trading data and transaction reporting to regulators. Both remain EU frameworks for investment firms and markets.

Interpretation

MiFID II builds on MiFID; it does not start reporting from nothing, and it has nothing to do with U.S. bank structure rules. (The bank rebuilt this question and corrected its key to A.)

Why the other options are wrong

B is incorrect. Absolute claim: MiFID already defined regulatory reporting and trade transparency; MiFID II extended them.
C is incorrect. Regime swap: MiFID II is EU legislation; the restriction on proprietary trading is the U.S. Volcker Rule.

D is incorrect. Scope error: both are investor protection frameworks for investment firms and markets; neither is a commercial-bank rule.

LO: ORR-14 a: Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank. • **Reference:** GARP ORR Ch.14, MIFID: Definition; Evolution in Recent Years: MIFID II

Solution ORR-14 a.3 — Answer: A

Bank Q317 • AnalystPrep Q.5146

Step 1 – The 2014 revision

In June 2014 the EU adopted a revised directive (MiFID II) and a regulation (MiFIR). Alongside stronger investor protection, MiFID II set out additional requirements on public disclosure of data on trading activity and on disclosure of transaction data to regulators and supervisors.
⇒ A.

Step 2 – Sort the other options

An independent consumer-finance regulator (the CFPB), the proprietary-trading ban (the Volcker Rule) and mandatory clearing of OTC derivatives are all U.S. Dodd-Frank provisions.

Interpretation

Most regime questions are sorting exercises: EU rules govern how investment firms deal with clients and report trades; Dodd-Frank restructures U.S. oversight, derivatives markets and bank activities.

Why the other options are wrong

B is incorrect. Describes the CFPB, created by Dodd-Frank.
C is incorrect. Describes the Volcker Rule, part of Dodd-Frank.
D is incorrect. Describes Dodd-Frank's clearinghouse requirement for derivatives.

LO: ORR-14 a: Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank. • **Reference:** GARP ORR Ch.14, Evolution in Recent Years: MIFID II; The Investor Protection Act - Dodd-Frank

Solution ORR-14 a.4 — Answer: C

Bank Q315 • AnalystPrep Q.5139

Step 1 – GARP's list

Remuneration of traders and advisors and conflicts of interest; fair and non-misleading communication; definition and independence of investment advice; sales process and product governance; best execution of trades for clients; dealings with eligible counterparties.
⇒ A, B and D are on the list.

Step 2 – Locate whistleblowers

Increased whistleblower protection comes from the Investor Protection Act, part of the U.S. Dodd-Frank Act.
⇒ C is the exception.

Interpretation

GARP attributes the list to MiFIR; in the legislation most of it sits in the MiFID II directive (correction box, Section 2). Either way, whistleblower protection is U.S. law.

Why the other options are wrong

A is incorrect. Definition and independence of investment advice is on the list.
B is incorrect. Best execution of trades for clients is on the list.

D is incorrect. Dealings with eligible counterparties is on the list.

LO: ORR-14 a: Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank. • **Reference:** GARP ORR Ch.14, Evolution in Recent Years: MIFID II; The Investor Protection Act - Dodd-Frank

Solution ORR-14 a.5 — Answer: B

Bank Q314 • AP Mock 3 Q70

Step 1 – What created the CFPB

The Dodd-Frank Act created the Consumer Financial Protection Bureau as an independent financial regulator overseeing consumer finance markets: mortgages, student loans and credit cards.
⇒ B.

Step 2 – Check the near misses

The Volcker Rule is one provision inside Dodd-Frank; FINRA is a self-regulatory organisation for brokerage firms overseen by the SEC (ORR-14 b); MiFID is EU law.

Interpretation

The question rewards knowing the level of each name: an act (Dodd-Frank), a rule inside it (Volcker), a regulator (FINRA), an EU directive (MiFID). Only an act creates an agency.

Why the other options are wrong

A is incorrect. MiFID is an EU directive and created no U.S. agency.
C is incorrect. FINRA is itself a regulator of brokerage firms, not the legislation that created the CFPB.
D is incorrect. Part for whole: the Volcker Rule restricts bank proprietary trading; the CFPB comes from another part of Dodd-Frank.

LO: ORR-14 a: Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank. • **Reference:** GARP ORR Ch.14, The Investor Protection Act - Dodd-Frank

Solution ORR-14 a.6 — Answer: C

Bank Q316 • AnalystPrep Q.5144

Step 1 – The Volcker Rule

Contained in Dodd-Frank, it "intends to prevent commercial banks from engaging in speculative activities and proprietary trading for profit" and limits banks' investments in hedge funds and private equity funds.
⇒ C.

Step 2 – Place the other options

Whistleblower protection: the Investor Protection Act. Clearinghouses for derivatives: Dodd-Frank's OTC derivatives provisions. The CFPB: another part of Dodd-Frank.

Interpretation

All four options are Dodd-Frank; the question tests which provision does what. The rule's purpose (no speculation for the bank's own profit) is also what sets the limits of its exemptions (Question ORR-14 a.9).

Why the other options are wrong

A is incorrect. Whistleblower protection belongs to the Investor Protection Act.
B is incorrect. Mandatory clearing is a separate Dodd-Frank provision on OTC derivatives.
D is incorrect. The CFPB was created by another part of Dodd-Frank.

LO: ORR-14 a: Summarize important regulations designed to protect investors in financial instruments, including

MiFiD, MiFiD II, and Dodd-Frank. • **Reference:** GARP ORR Ch.14, The Investor Protection Act - Dodd-Frank; SchweserNotes 2026 Book 3, Reading 55, LO 55.a

Solution ORR-14 a.7 Answer: D

New • built from GARP Ch.14 and workbook D21

Step 1 – Which test goes with which service

MiFID II (outside the GARP text): suitability for investment advice and portfolio management; appropriateness for other, non-advised services; no test for execution-only dealing in non-complex instruments at the client's initiative, once the client is told.

Step 2 – Client by client

Client 1 receives advice: suitability (knowledge and experience, financial situation including ability to bear losses, objectives including risk tolerance). Client 2 buys a complex product without advice: appropriateness (knowledge and experience only); if it is not appropriate, the firm warns and the client may still proceed. Client 3 buys listed shares, a non-complex instrument, unprompted and informed: execution only.
$\Rightarrow$ D.

Interpretation

The tests scale with the firm's role. When the firm recommends, it takes on the client's whole situation; when the client decides, the firm checks only that the client can understand the risks; for a simple product bought unprompted, no test applies. In GARP's terms this is Basel 4.1 territory, and the same logic condemns incentives that push products regardless of suitability (ORR-12 a, element D).

Why the other options are wrong

A is incorrect. Over-scope: retail status does not trigger suitability; the service does. Clients 2 and 3 receive no advice.
B is incorrect. Sibling swap: advice on one product is still advice (suitability), and complexity without advice calls for appropriateness, not suitability.
C is incorrect. Absolute qualifier and dropped condition: a failed appropriateness test leads to a warning, not a refusal, and Client 3 meets the execution-only conditions.

LO: ORR-14 a: Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank. • **Reference:** GARP ORR Ch.14, Context and Scope (Basel 4.1); MiFID II (Directive 2014/65/EU), Art. 25 (outside the GARP text); workbook D21

Solution ORR-14 a.8 Answer: B

New • built from GARP Ch.14 and workbook D21

Step 1 – What the package targets

GARP: MiFID II and MiFIR address the remuneration of traders and advisors and conflicts of interest, and the definition and independence of investment advice. Traders who deal for clients and for the firm's own book are a named driver of compliance risk.

Step 2 – Independent advice

Outside the GARP text (MiFID II, Art. 24): a firm that calls its advice independent must not accept and retain third-party fees or commissions; any it receives go to the client in full. The retrocessions must stop being retained.

Step 3 – Remuneration and the desks

Staff must not be paid or assessed in a way that rewards recommending one product when an-

other would better meet the client's needs: redesign the bonus. The desk conflict is prevented or managed by organisational separation (information barriers, separate supervision).

Step 4 – Then disclose

Disclosure is the last resort, for whatever the arrangements cannot prevent with reasonable confidence.

⇒ B.

Interpretation

The order is identify, prevent or manage, and only then disclose. Disclosure cannot legitimise a banned practice (inducements in independent advice) or replace sound pay design.

Why the other options are wrong

A is incorrect. Sequence error: disclosure is the last resort, not the primary tool, and it cannot cure retrocessions on advice sold as independent.

C is incorrect. The conflict arises precisely because the fund house pays: the payment rewards recommending its funds. Retrocessions are the inducements the independence rule targets.

D is incorrect. Scope error: GARP lists the remuneration of traders and advisors among the items the MiFID II/MiFIR package addresses.

LO: ORR-14 a: Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank. • **Reference:** GARP ORR Ch.14, Evolution in Recent Years: MIFID II; Compliance Risk Management in Investment Activities; MiFID II, Art. 23 and 24 (outside the GARP text)

Solution ORR-14 a.9 Answer: D

New • built from GARP Ch.14 and workbook D21

Step 1 – The prohibition

GARP: the Volcker Rule intends to prevent commercial banks from speculative activities and proprietary trading for profit, and limits their investments in hedge funds and private equity funds.

Step 2 – The exemptions

Outside the GARP text (implementing regulations, 2013): market making is permitted if inventory is designed not to exceed the reasonably expected near-term demand of clients, customers or counterparties; risk-mitigating hedging is permitted if designed to reduce specific, identifiable risks of the bank's positions. Underwriting, government obligations and trading on behalf of customers are also permitted.

Step 3 – Test each note

A drops the exemptions; B drops the demand condition; C extends the rule beyond banks. D states both conditions.

⇒ D.

Interpretation

Scope and condition errors are the natural distractors. The rule targets a purpose, profit from the bank's own positions, so a permitted activity turns into prohibited proprietary trading when its condition fails: inventory beyond client demand, or a "hedge" tied to no identifiable risk.

Why the other options are wrong

A is incorrect. Scope error: market making for clients and risk-mitigating hedging are permitted activities.

B is incorrect. Dropped condition: quoting two-way prices is not enough; inventory beyond expected near-term client demand is proprietary trading.

C is incorrect. Scope error: the rule binds banking entities; it limits the bank's stake in covered

funds (broadly 3% of any one fund and 3% of Tier 1 capital in aggregate), not the funds' own trading.

LO: ORR-14 a: Summarize important regulations designed to protect investors in financial instruments, including MiFiD, MiFiD II, and Dodd-Frank. • **Reference:** GARP ORR Ch.14, The Investor Protection Act - Dodd-Frank (Volcker Rule); Volcker Rule implementing regulations, 2013 (outside the GARP text); workbook D21

ORR-14 • Investor Protection and Compliance Risks in Investment Activities • Vardeez: VERY IMPORTANT

ORR-14 b

P2 CONCEPT

Describe lessons learned from the case studies involving violations of investor protection or compliance regulations.

Workbook: D21 Investor Protection, MiFID and the Volcker Rule • Tier D

WHAT IS TESTED HERE

Why P2. Vardeez flags it inside a VERY IMPORTANT chapter (ORR-14, theme 2 of his ORR list). **Vardeez:** his notes label this LO "LO 53.b" (consolidated volume pp.144 to 145): the three aims of regulatory fines (punish past misconduct, deter the same firm, push the industry to better compliance), his Figure 53.2 of the three enforcement actions (UBS 2008, JPMorgan 2020, Deutsche Bank 2022) and his takeaway: fines can be massive for misrepresentation, and even small fines matter for non-manipulative order-execution failures. His LO line carries an older wording ("Describe and provide lessons learned"); the map wording above is the official one.

Reported exam shapes

- **S2** Best execution, with the Deutsche Bank Securities case.

What the questions look like: why regulators size fines as they do; the facts of each case and cross-mapping between them; spoofing and how views of it changed; error versus fraud in a compliance breach and the controls that apply; the Deutsche Bank Securities lesson and its use on a firm's own order routing.

See also: compliance risk management (Section 1) sits here with the cases, as in workbook D21; Vardeez and Schweser file it under LO a. The regulations themselves are ORR-14 a.

1. Compliance risk management in investment activities

- **Error or fraud.** When **intentional**, a compliance breach in market activities is a form of **internal fraud**, because it is an unauthorised activity; most of the internal fraud control framework therefore applies. When **unintentional**, breaches are usually due to **human error or faulty policies**. Many controls against internal fraud also prevent errors, **except deterrent controls**: the key difference between an error and a fraud is the intention of the perpetrator.
- **General drivers** (as for internal fraud): poor employee engagement, dissatisfaction or stress, insufficient resources for business units or activities, weak ethics culture.
- **Specific drivers in market activities:** information asymmetry (retail investors know far less about the products than the banks and asset managers selling them); conflicts of interest of traders who trade both for clients' books and for the firm's own book; economic conditions such as volatility spikes, which raise transaction volumes, so errors become more frequent and abnormal transactions or insider trading easier to hide.
- **Effective controls:** monitoring and supervision of employees and trades; strong middle-office and back-office functions; adequate policies and procedures; employee training; a strong ethics culture; consistent processes for onboarding, screening and training employees *and third parties*.

2. Record fines and the three cases

U.S. data show nearly **USD 82 billion** of fines and penalties for investor protection violations between 2000 and 2022, over 6,612 penalty records, an average of about USD 12 million per record. The distribution is dominated by a few cases: the largest alone is about 14% of the total.

Case	Authority, amount	What happened	Lesson
UBS (July 2008)	multi-state litigation; USD 11.15 billion	UBS had to buy back USD 11 billion of securities and pay USD 150 million in penalties for "misrepresenting auction rate securities to investors as safe, cash-equivalent products, when in fact they faced increasing liquidity risk."	the most severe individual penalty in the data; misrepresenting product risk (Basel 4.1) costs the most
JP Morgan (September 2020)	CFTC; USD 920 million	spoofing, "providing a false impression of market demand by rapidly entering and canceling orders", in precious metals and U.S. Treasury markets; conduct over at least eight years and hundreds of thousands of spoof orders	the record spoofing fine; practices once accepted as normal became violations as investor protection evolved
Deutsche Bank Securities (2022)	FINRA; USD 2 million	best execution failures from 2014 to 2018 (Section 3)	small fine, no manipulation or misrepresentation, still penalised

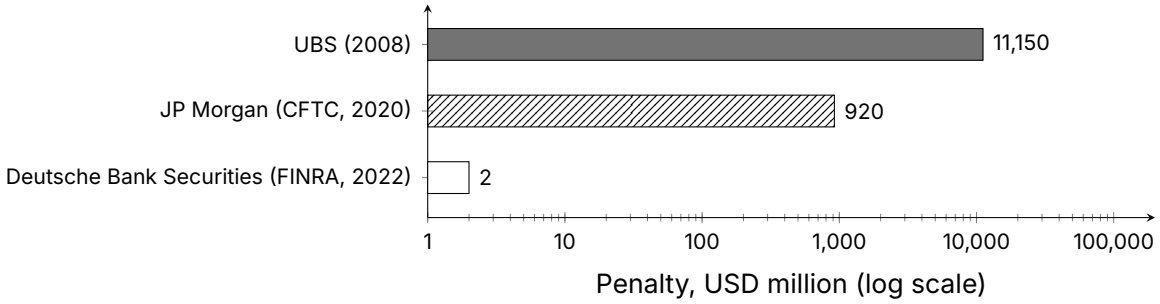


Figure 1. The three penalties on a log scale: UBS dark grey (USD 11,000 million buy-back plus 150 million penalties), JP Morgan hatched, Deutsche Bank Securities open bar. Each step down is a factor of about 12 and then of 460, yet the smallest case carries the reported exam shape.

3. Deutsche Bank Securities and best execution (shape S2)

FINRA is the U.S. self-regulatory organisation for brokerage firms, overseen by the SEC and dedicated to investor protection and market integrity. **FINRA Rule 5310** requires firms to seek the **most favourable terms reasonably available** for a customer's order; the criteria include **price improvement** and **speed of execution**.

- **The routing.** From 2014 to 2018 the firm's smart order router sent customer orders through the "SuperX ping" before any part of the order reached an exchange, unless the customer opted out.
- **The harm.** Execution delays on customers' market orders and **lower fill rates** (a higher share of orders not fully executed or not executed at all).
- **The failure to act.** Knowing this, the firm neither changed the routing nor evaluated the price improvement available from routing orders directly to exchanges.

- **The disclosure.** Its reports said only, vaguely, that it might receive trading rebates from this routing, with no detail such as the amount per share or per order, and no sign that rebates were passed on to the customers entitled to them.
- **The settlement.** The firm settled without admitting or denying FINRA's findings, and paid the USD 2 million.

Outside the GARP text: FINRA's rule also requires firms that route customer orders to review execution quality regularly and rigorously against competing venues, which is exactly the comparison with direct exchange routing the firm did not make; MiFID II's best execution (ORR-14 a) weighs price, costs, speed, likelihood of execution and settlement, and the size and nature of the order.

4. Why fines are set as they are, and the lessons

Where firms keep non-compliant practices going, seemingly for profit, regulators apply **punitive** fines so that the penalty **more than offsets the benefits** accumulated. The fines **deter** further deviations and have **signalling power** to peer firms, pushing them to adjust their processes and monitoring. Recovering the cost of litigation is not among the aims.

- **UBS:** describe product risk truthfully; selling illiquid instruments as cash equivalents produces the largest settlements, mostly as restitution.
- **JP Morgan:** the line between normal practice and violation moves; surveillance must track the rules as they evolve, and a pattern sustained for years points to weak supervision of trades.
- **Deutsche Bank Securities:** best execution is a compliance obligation in its own right; knowing that a practice hurts customers and keeping it is what turns a routing design into a violation, and disclosure must be specific.
- **All three:** the controls of Section 1 (supervision of trades, strong middle and back office, ethics culture) are what prevent the breach; the fine only follows it.

Summary card: ORR-14 b, the cases and the controls

UBS 2008	USD 11.15 billion = 11 billion buy-back + 150 million penalties; auction rate securities sold as safe, cash-equivalent; largest individual penalty
JP Morgan 2020	CFTC USD 920 million; spoofing in precious metals and Treasuries for at least eight years; once accepted as normal
Deutsche Bank Sec. 2022	FINRA USD 2 million; Rule 5310; SuperX ping 2014 to 2018, delays and lower fill rates, no change, no test of direct routing, vague rebates; settled without admitting or denying
Why fines	punish, deter, signal to peers; sized to more than offset the benefits
Error or fraud	intention decides; intentional breach is internal fraud; shared controls except deterrent ones
Drivers	engagement, stress, resources, ethics; information asymmetry, trader conflicts, volatility spikes

Exam traps

- **Case cross-mapping.** Auction rate securities, buy-back, multi-state litigation: UBS. Spoofing, CFTC, precious metals and Treasuries: JP Morgan. SuperX ping, FINRA Rule 5310, rebates: Deutsche Bank Securities.

- **Component swap.** UBS paid USD 11 billion in buy-backs and USD 150 million in penalties, not the reverse.
- **Small fine, no lesson.** The USD 2 million case shows that non-manipulative execution failures are punished.
- **Best execution is price only.** Speed of execution and fill rates count too.
- **Opt-out and settlement.** Letting customers opt out did not discharge the duty; settling without admission did not avoid the fine.
- **Error versus fraud.** Intention decides; deterrent controls are the one group that does nothing against errors.
- **Purpose of fines.** Punish, deter, signal, more than offset benefits; not to recover litigation costs.
- **Direction of change.** Spoofing was accepted as normal before investor protection rules; it is a violation now, not the reverse.

Practice questions: ORR-14 b

Question ORR-14 b.1

Bank Q324 • Schweser Module Quiz 55.1 Q3

Which of the following reasons is least likely a consideration for regulators when imposing fines on financial institutions for investor protection breaches and violations?

A. To cover the cost of litigation.

B. To deter other firms from manipulative banking practices.

C. To ensure that fines cover at least the benefits of breaches.

D. To signal to other firms to change their compliance practices.

Question ORR-14 b.2

Bank Q325 • New (bank, GARP style)

Maria Santos, an operational risk analyst at an investment bank, is preparing a training note on the largest individual penalty in U.S. investor protection enforcement data for 2000 to 2022: the July 2008 resolution with UBS totaling USD 11.15 billion. Which of the following statements best describes the case and the lesson it offers?

A. The resolution was a USD 11.15 billion cash fine imposed by the CFTC for spoofing in precious metals markets, showing that manipulative order entry attracts the largest penalties.

B. The resolution required UBS to buy back USD 11 billion of securities and pay USD 150 million in penalties, after charges that it misrepresented auction rate securities to investors as safe, cash-equivalent products despite rising liquidity risk.

C. The resolution required UBS to pay USD 11 billion in penalties and buy back USD 150 million of securities, after charges of best execution failures caused by indirect order routing.

D. The resolution was a settlement for failing to disclose trading rebates received from routing venues, showing that vague disclosure is the costliest investor protection breach.

Question ORR-14 b.3 New • built from GARP Ch.14

A trading-surveillance analyst at a commodities broker flags a trader who repeatedly places large sell orders in gold futures, cancels them within seconds before they can be filled, and buys at the lower prices that follow. Drawing on GARP's JP Morgan case, which assessment is correct?

A. The pattern is legitimate liquidity provision, because cancelled orders never execute and so cannot move prices or harm other investors.

B. The pattern is spoofing, but it is a matter for the broker's internal policy rather than for regulators, since none of the broker's clients was directly harmed.

C. The pattern is spoofing, a false impression of market demand created by rapidly entering and cancelling orders; JP Morgan paid USD 920 million to the CFTC for such conduct.

D. The pattern was a violation only before investor protection rules were modernised; today's rules accept rapid order cancellation as normal market practice.

Question ORR-14 b.4 New • built from GARP Ch.14

A compliance trainer is building a table of GARP's three investor protection cases. Which row is correct?

A. UBS (2008): CFTC fine of USD 920 million for spoofing in precious metals markets.

B. JP Morgan (2020): FINRA fine of USD 2 million for routing customer orders through the SuperX ping.

C. Deutsche Bank Securities (2022): USD 11.15 billion resolution for misrepresenting auction rate securities as cash equivalents.

D. Deutsche Bank Securities (2022): FINRA fine of USD 2 million for best execution failures between 2014 and 2018.

Question ORR-14 b.5 New • built from GARP Ch.14

During a spike in market volatility, two compliance breaches occur at a broker-dealer. In the first, an overloaded middle-office clerk applies an outdated client-classification policy and books several clients into products they should not have been offered. In the second, a trader deliberately buys ahead of a large client order on the firm's own book. Which statement about classifying and controlling these breaches is correct?

A. Both breaches are internal fraud, because any breach of investor protection rules is an unauthorised activity.

B. Both breaches are human errors, because volatility spikes raise transaction volumes and the frequency of mistakes.

C. The first is an unintentional breach and the second is internal fraud; most internal fraud controls help against both, but deterrent controls work only against the second.

D. The second breach can be prevented only by deterrent controls such as sanctions, while monitoring and supervision of trades address only errors.

Question ORR-14 b.6 Bank Q323 • AnalystPrep Q.5047 (rebuilt)

In 2022, FINRA fined Deutsche Bank Securities Inc. USD 2 million for best execution failures between 2014 and 2018. Which of the following is the most accurate lesson from this case about investor protection and compliance risk?

A. Large fines arise only from deliberate market manipulation such as spoofing, so routing and execution practices carry little regulatory risk.

B. A firm can face regulatory penalties for failing to secure the most favorable execution terms for customers, particularly where it knew of the problems, did not change its order routing, and only vaguely disclosed the rebates it received.

C. The fine was the largest ever imposed on a single organization, showing that best execution breaches are punished more severely than misrepresentation.

D. Because the bank settled without admitting or denying the findings, the case shows that regulators cannot penalize firms absent an admission of responsibility.

Question ORR-14 b.7 New • built from GARP Ch.14

The head of execution quality at a U.S. broker-dealer is reviewing its equity order routing. Customer market orders go first to an affiliated venue for a "ping" before any part reaches an exchange, unless the customer opts out. Internal data show that pinged orders execute more slowly and fill less often than orders sent straight to exchanges. The firm earns trading rebates from some venues, which its reports mention only as rebates it "may receive". Drawing on FINRA's Deutsche Bank Securities case, which response best meets the firm's best execution obligation?

A. Compare execution quality with direct exchange routing, change the routing if speed, fill rates or price improvement are worse, and disclose the rebates in detail.

B. Keep the routing, since customers who prefer direct routing can opt out, and offering an opt-out shifts the best execution duty to the customer.

C. Keep the routing as long as pinged orders receive the same price as direct routing, since best execution is judged on price alone.

D. Keep the routing but pass all rebates on to customers, since passing rebates on is by itself enough to satisfy the best execution obligation.

Solutions • ORR-14 b

Solution ORR-14 b.1

Answer: A

Bank Q324 • Schweser Module Quiz 55.1 Q3

Step 1 – GARP's rationale for fines

Where firms perpetuated non-compliant practices seemingly for profit, regulators apply punitive fines so that the penalty more than offsets the benefits accumulated; the fines deter further deviations and signal to peer firms to adjust their processes and monitoring.

Step 2 – Test each option

B is deterrence, C is offsetting the benefits, D is signalling. Recovering litigation costs is not a stated aim.

$\Rightarrow$ A.

Interpretation

Fines are sized against the gain from the breach, not against the regulator's expenses: that is what makes them punitive and a credible deterrent. Option C's "at least the benefits" is consistent with GARP's "more than offsets".

Why the other options are wrong

B is incorrect. A valid aim: deterring further violations.

C is incorrect. A valid aim: the penalty is set above the benefit of the breach.

D is incorrect. A valid aim: signalling to peers to improve compliance and monitoring.

LO: ORR-14 b: Describe lessons learned from the case studies involving violations of investor protection or compliance regulations. • **Reference:** GARP ORR Ch.14, Case Studies (FINRA Fines Deutsche Bank Securities, closing paragraph); SchweserNotes 2026 Book 3, Reading 55, LO 55.b

Solution ORR-14 b.2

Answer: B

Bank Q325 • New (bank, GARP style)

Step 1 – Place the case

U.S. investor protection data for 2000 to 2022 show nearly USD 82 billion of fines over 6,612 records; the most severe individual penalty was imposed on UBS, USD 11.15 billion, in July 2008.

Step 2 – Split the total

$11{,}000 + 150 = 11{,}150$ (USD million): a buy-back of USD 11 billion of securities plus USD 150 million of penalties.

$\Rightarrow$ About 98.7% of the total is restitution (the buy-back), not penalty.

Step 3 – The charge

The multi-state litigation charged UBS with "misrepresenting auction rate securities to investors as safe, cash-equivalent products, when in fact they faced increasing liquidity risk."

$\Rightarrow$ B.

Interpretation

Misrepresenting product risk is a suitability and disclosure breach (Basel 4.1). The lesson: it produces the largest resolutions because the firm must undo the sales, and the fine sits on top.

Why the other options are wrong

A is incorrect. Gives UBS the JP Morgan facts: the record spoofing fine was USD 920 million, imposed by the CFTC in September 2020.

C is incorrect. Reverses the components (penalties USD 150 million, buy-back USD 11 billion) and borrows the cause from the Deutsche Bank Securities case.

D is incorrect. Borrows the rebate-disclosure finding from the USD 2 million Deutsche Bank Securities case.

LO: ORR-14 b: Describe lessons learned from the case studies involving violations of investor protection or compliance regulations. • **Reference:** GARP ORR Ch.14, Statistics and Record Fines Cases for Investor Protection Violations

Solution ORR-14 b.3 — Answer: C

New • built from GARP Ch.14

Step 1 – Name the pattern

Orders placed with no intention of execution, cancelled within seconds, and a trade on the price move they caused: spoofing, "providing a false impression of market demand by rapidly entering and canceling orders and therefore manipulating prices in one's favor".

Step 2 – The GARP case

JP Morgan holds the record spoofing fine: USD 920 million, imposed by the CFTC in September 2020, for spoofing in precious metals and U.S. Treasury markets over at least eight years, with hundreds of thousands of spoof orders.
⇒ C.

Step 3 – The lesson

Before investor protection regulation, practices like spoofing were accepted as normal; they are now violations that draw large fines.

Interpretation

Spoofing harms everyone who trades at the manipulated prices, not only the firm's own clients, which is why it is an investor protection violation (Basel 4.2, Improper Business or Market Practices). Being intentional, it is also a form of internal fraud for control purposes, and an eight-year pattern points to weak supervision of trades.

Why the other options are wrong

A is incorrect. The cancelled orders are the manipulation: they move prices without ever being meant to execute.
B is incorrect. Scope error: spoofing violates investor protection law and draws regulatory fines whoever the counterparties are.
D is incorrect. Polarity flip of the lesson: practices once accepted as normal became violations, not the reverse.

LO: ORR-14 b: Describe lessons learned from the case studies involving violations of investor protection or compliance regulations. • **Reference:** GARP ORR Ch.14, Statistics and Record Fines Cases for Investor Protection Violations (JP Morgan)

Solution ORR-14 b.4 — Answer: D

New • built from GARP Ch.14

Step 1 – UBS

July 2008; USD 11.15 billion resolution of multi-state litigation over auction rate securities sold as safe, cash-equivalent products.

Step 2 – JP Morgan

CFTC; USD 920 million; September 2020; spoofing in precious metals and Treasuries.

Step 3 – Deutsche Bank Securities

FINRA; USD 2 million (2022); best execution failures from 2014 to 2018.
⇒ Only D matches.

Interpretation

Three anchors separate the cases: the conduct (auction rate securities, spoofing, order routing), the authority (multi-state litigation, CFTC, FINRA) and the scale (billions, hundreds of millions, a few million).

Why the other options are wrong

A is incorrect. Gives JP Morgan's regulator, amount and conduct to UBS.
B is incorrect. Gives Deutsche Bank Securities' regulator, amount and conduct to JP Morgan.
C is incorrect. Gives UBS's resolution and conduct to Deutsche Bank Securities.

LO: ORR-14 b: Describe lessons learned from the case studies involving violations of investor protection or compliance regulations. • **Reference:** GARP ORR Ch.14, Case Studies

Solution ORR-14 b.5 Answer: C

New • built from GARP Ch.14

Step 1 – The first breach

No intention: an overloaded clerk and an outdated policy. GARP: unintentional compliance breaches are often due to human error or faulty policies.

Step 2 – The second breach

A deliberate trade ahead of a client order on the firm's own book: an intentional breach, a form of internal fraud because it is an unauthorised activity. It is driven by the conflict of traders who trade both for clients and for the firm's own book.

Step 3 – The controls

Many controls against internal fraud also prevent errors (monitoring and supervision of employees and trades, middle and back office, policies, training, ethics culture), with the exception of deterrent controls, because the key difference between an error and a fraud is intention.
$\Rightarrow$ C.

Interpretation

The volatility spike drives both breaches (more transactions, more errors, abnormal trades easier to hide), but it does not decide the classification; intention does.

Why the other options are wrong

A is incorrect. Sibling swap: only intentional breaches are internal fraud; unintentional ones come from human error or faulty policies.
B is incorrect. Driver confused with classification: volatility raises the frequency of errors, but the second breach was deliberate.
D is incorrect. Reversed: monitoring and supervision of trades are core controls against fraud as well as errors; deterrent controls are the one group that does not help against errors.

LO: ORR-14 b: Describe lessons learned from the case studies involving violations of investor protection or compliance regulations. • **Reference:** GARP ORR Ch.14, Compliance Risk Management in Investment Activities

Solution ORR-14 b.6 Answer: B

Bank Q323 • AnalystPrep Q.5047

Step 1 – The facts

From 2014 to 2018 customer orders went through the SuperX ping unless customers opted out, causing delays and lower fill rates. The firm knew, yet neither changed the routing nor evaluated price improvement from direct exchange routing; its reports disclosed possible trading rebates only vaguely, with no sign they were passed on. It settled without admitting or denying the

findings.

Step 2 – The lesson

Best execution (FINRA Rule 5310: the most favourable terms reasonably available) is a compliance obligation in its own right. Failing it, and doing nothing about known problems, is penalised even without manipulation or misrepresentation.
⇒ B.

Interpretation

Vardeez's takeaway: even small fines matter for non-manipulative order-execution failures. (The bank rebuilt this question and corrected its key to B.)

Why the other options are wrong

A is incorrect. The case itself refutes it: no manipulation, yet a fine.
C is incorrect. The largest individual penalty was UBS's USD 11.15 billion; USD 2 million is the smallest of the three cases.
D is incorrect. The firm settled without admitting or denying and still paid the fine.

LO: ORR-14 b: Describe lessons learned from the case studies involving violations of investor protection or compliance regulations. • **Reference:** GARP ORR Ch.14, FINRA Fines Deutsche Bank Securities, Inc. $2 Million for Best Execution Violations; SchweserNotes 2026 Book 3, Reading 55, LO 55.b

Solution ORR-14 b.7 Answer: A

New • built from GARP Ch.14

Step 1 – The obligation

FINRA Rule 5310: seek the most favourable terms reasonably available for a customer's order; the criteria include price improvement and speed of execution.

Step 2 – Match the facts

A ping before any part reaches an exchange unless the customer opts out, slower execution, lower fill rates, rebates mentioned only vaguely: the Deutsche Bank Securities pattern.

Step 3 – What the case says was missing

Changing the routing once its effects were known; evaluating the price improvement available from direct exchange routing; disclosing rebate details (amount per share or per order) and whether customers receive them.
⇒ A.

Interpretation

Outside the GARP text, FINRA expects firms that route orders to review execution quality regularly and rigorously against other venues; MiFID II's best execution weighs price, costs, speed, likelihood of execution and settlement, size and nature of the order. Both point to the same remedy.

Why the other options are wrong

B is incorrect. Role misassignment: Deutsche Bank Securities' customers could also opt out, and FINRA still fined the firm; the duty stays with the broker.
C is incorrect. Scope error: speed of execution and fill rates are part of best execution, not price alone.
D is incorrect. Partial fix: passing rebates on answers the disclosure finding, but slower execution and lower fill rates remain a best execution failure.

LO: ORR-14 b: Describe lessons learned from the case studies involving violations of investor protection or compliance regulations. • **Reference:** GARP ORR Ch.14, FINRA Fines Deutsche Bank Securities, Inc. $2 Million for Best Execution Violations; workbook D21

ORR-15 • Supervisory Guidance on Model Risk Management • Vardeez: VERY IMPORTANT

ORR-15 a

P2 CONCEPT

Describe model risk and explain how it can arise in the implementation of a model.

Workbook: *none*

WHAT IS TESTED HERE

Why P2. Vardeez flags ORR-15 as a Very Important chapter (STRIKE FIRST, rank 20 of 55 in his consolidated volume). The recall workbooks place model risk in Tier C only (section C6, map #32, 3 of 16 sources), so the band comes from Vardeez, not from recall.

Vardeez: his notes label this LO "LO 54.a" (consolidated volume p.86). He stresses the definition of model risk, the three components of a model (his Figure 54.1: information inputs, processing, reporting) and the two sources of model risk: model errors and misuse.

Reported exam shapes: none reported for this LO; the questions are built from the LO wording and Vardeez's focus. Workbook C6.1 is homed here; its shape S1 (the investor and rating agency friction labelled model error) is taught under ORR-16 c.

What the questions look like: short recall of the definition and the three components, then scenarios in which you decide whether model risk comes from an error in the model (data, sample design, approximations, coding into systems) or from using a sound model outside its intended scope. Expect absolute distractors ("eliminated", "only coding errors") and polarity flips on what makes model risk larger.

Background for both model risk readings: what a model is, and the two ways model risk arises, are taught here. ORR-16 a recaps them and adds GARP's own vocabulary (execution risk and conceptual errors).

1. What a model is

GARP Chapter 15 reprints the FDIC's guidance (FIL-22-2017), which adopts the Federal Reserve's SR 11-7. It defines a model as

> *"a quantitative method, system, or approach that applies statistical, economic, financial, or mathematical theories, techniques, and assumptions to process input data into quantitative estimates."*

- **Qualitative inputs are allowed.** The definition also covers approaches whose inputs are partly or wholly qualitative or based on expert judgment, *provided the output is quantitative*.
- **Three components** (Figure 1): an **information input** component, which delivers assumptions and data to the model; a **processing** component, which transforms inputs into estimates; and a **reporting** component, which translates the estimates into useful business information.
- **Where banks use them:** underwriting credits, valuing exposures and positions, measuring risk, managing client assets, capital and reserve adequacy, stress testing, compliance with internal limits, financial and regulatory reporting.
- **Always a simplification.** Simplification is both inevitable (real relationships are complex) and intentional (to focus on what matters for the application). Quality can be measured by precision, accuracy, discriminatory power, robustness, stability and reliability: precision and accuracy matter for models that forecast values, discriminatory power for models that rank-order risks. Models are never perfect.

2. Model risk: the definition

> **Model risk** = "the potential for adverse consequences from decisions based on incorrect or misused model outputs and reports."

The consequences GARP names are **financial loss**, **poor business and strategic decision making**, and **damage to the bank's reputation**. Models have a *direct* cost (the resources to develop and implement them properly) and an *indirect* cost (adverse consequences of decisions based on models that are incorrect or misused). Model risk is the indirect cost, and it must be actively managed. It has no upside: the definition is about adverse consequences only.

3. How model risk arises: two reasons

Reason 1: the model has fundamental errors and produces inaccurate outputs when viewed against its design objective and intended business uses. The calculation behind any model involves

$$\text{application of theory} \rightarrow \text{choice of sample design and numerical routines} \rightarrow \text{selection of inputs and estimation} \rightarrow \text{implementation in information systems}$$

and **errors can occur at any point from design through implementation**. Two further routes:

- **Shortcuts, simplifications or approximations** used to manage complicated problems can compromise the integrity and reliability of the outputs.
- **Input quality.** Output quality depends on the quality of input data and assumptions; errors in inputs or incorrect assumptions lead to inaccurate outputs (Schweser: "garbage in, garbage out").

Reason 2: the model is used incorrectly or inappropriately. "Even a fundamentally sound model producing accurate outputs consistent with the design objective of the model may exhibit high model risk if it is misapplied or misused." The risk is greatest when a model is used outside the environment it was designed for, either **intentionally** (existing models applied to new products or markets) or **inadvertently** (market conditions or customer behaviour change). Limitations come from the model's shortcomings, approximations and uncertainties, and from assumptions that restrict it to specific circumstances, so decision makers must understand them.

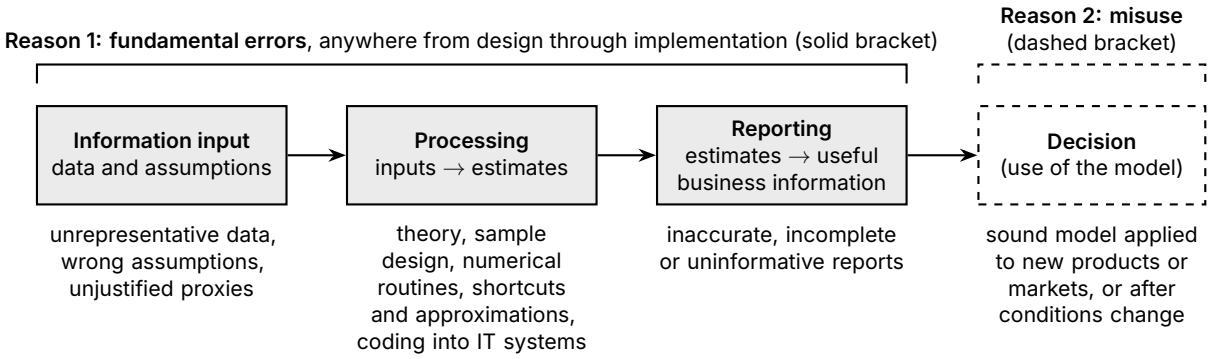


Figure 1. The three components of a model (grey boxes) and where model risk enters. Reason 1 (solid bracket) covers all three components and every stage from design to implementation; Reason 2 (dashed bracket) sits in the decision, and can arise even when every component works as designed.

4. "In the implementation": where models meet systems

The LO asks specifically about implementation. GARP's points, spread over Sections 15.4 and 15.5:

- **Models live inside larger information systems** that bring data in from various sources and aggregate and report the outcomes. Calculations must be coordinated with what the systems can do, and sound model risk management "depends on substantial investment in supporting systems" for data and reporting integrity, with controls and testing for proper implementation, systems integration and appropriate use.
- **System integration deserves special attention:** the processing component often draws on many data sources, processes large amounts of data and feeds several repositories and reporting systems.
- **User-developed applications** (spreadsheets, ad hoc databases that generate quantitative estimates) are "particularly prone to model risk".
- **Code control:** code should be subject to rigorous quality and change control, alterable only by approved parties, with every change logged and auditable.

These are controlled in development (ORR-15 c) and checked by process verification in validation (ORR-15 d).

5. How large is model risk?

- **Drivers:** model risk **increases** with greater model complexity, higher uncertainty about inputs and assumptions, broader use, and larger potential impact. Manage it like any other risk: identify the sources and assess the magnitude.
- **Individual and aggregate.** Aggregate model risk is affected by interaction and dependencies among models; reliance on common assumptions, data or methodologies; and any factor that could hit several models and their outputs at the same time.
- **It cannot be eliminated,** even with skilled modelling and robust validation. Other tools: limits on model use, monitoring model performance, adjusting or revising models over time, and supplementing model results with other analysis. Informed conservatism helps, "though not an excuse to avoid improving models".
- **Taxonomies (ORR-3).** The ORX reference taxonomy elevates model risk to Level 1, with Level 2 design error, implementation error and application error, which lines up with the two reasons above. Basel lists "model errors" only as a Level 3 example under Clients, Products and Business Practices (Product Flaws).

	Reason 1: the model is wrong	Reason 2: the model is used wrongly
GARP wording	fundamental errors; inaccurate outputs against the design objective	incorrect or inappropriate use; misapplied or misused
Is the model sound?	No: an error sits somewhere in the model	It can be: sound and accurate for its design
Where it enters	theory, sample design, numerical routines, inputs and estimation, implementation in IT systems, approximations	the decision: new products or markets (intentional), changed conditions or behaviour (inadvertent)
Typical example	production engine uses an approximation or a wrong data feed	vanilla swap model used for an exotic product
ORX Level 2 (ORR-3)	design error; implementation error	application error

Exam traps

- **"Model risk means coding errors."** It also arises from misuse of a sound model, and from data, sample design and approximations.
- **"A sound, accurate model carries no model risk."** Misapplication outside its intended scope can make model risk high.
- **"Errors in coding the model into production are IT risk."** Implementation in information systems is part of the model calculation; errors there are model risk.
- **Polarity on the drivers.** More complexity, more uncertain inputs, broader use and larger impact all *increase* model risk.
- **Model-by-model only.** Shared data, assumptions or methods create aggregate model risk across models.
- **Absolute claims.** Model risk cannot be eliminated, and it has no upside component.
- **Component swap.** Processing turns inputs into estimates; reporting turns estimates into business information.

Practice questions: ORR-15 a

Question ORR-15 a.1

Bank Q329 • Schweser Module Quiz 56.1 Q1

Which component of a model deals with converting estimates into useful or applied information?

A. Information inputs.

B. Processing.

C. Reporting.

D. Transformational.

Question ORR-15 a.2

Bank Q330 • AnalystPrep Q.4297 (rebuilt)

Which of the following best describes how model risk can lead to adverse outcomes for a financial institution?

A. Decisions are based on inaccurate outputs of a model that is flawed or is misused, leading to financial and reputational losses.

B. The model's development costs exceed the budget, which is the primary financial loss from model risk.

C. A model that is highly accurate on past data eliminates model risk entirely.

D. Model risk arises only when a model contains coding errors and is unrelated to how the model is used.

Question ORR-15 a.3 Bank Q327 • AnalystPrep Q.4305 (rebuilt)

A risk team builds a credit loss model using only data from a prolonged economic expansion. The model's mathematics and implementation are correct, but it produces badly understated loss estimates when conditions deteriorate. Which principle best explains why the model's outputs are unreliable?

A. The model was used for an unintended purpose.

B. The reporting component converts estimates into the wrong format.

C. The quality of a model's output depends on the quality of its inputs and assumptions (garbage in, garbage out).

D. Models never require assumptions, so the loss understatement must come from user error.

Question ORR-15 a.4 Bank Q326 • BT P2.T7.604.2 (rebuilt)

A bank's derivatives desk adopts a pricing model that was built and approved for plain-vanilla interest rate swaps. Without any modification, the desk begins using it to value a new exotic structured product with embedded optionality. The code is error-free and the vanilla swap valuations remain accurate. Which statement best describes the source of model risk here?

A. Model risk arises because the model contains mathematical or coding errors introduced during design.

B. Model risk arises because the model is being used outside the context and purpose for which it was intended.

C. Model risk arises because the model has no reporting component.

D. There is no model risk, because the model produces correct outputs for the products it was designed for.

Question ORR-15 a.5 New • built from GARP Ch.15

A market risk team at a European bank built a full-revaluation VaR model whose theory and code were approved by validation. To meet the overnight batch window, IT re-implements it in the production risk engine, replacing full revaluation of the options book with a delta-gamma approximation and sourcing positions from a new data warehouse. The VaR output also feeds the bank's economic capital model and its limit-setting model. Which of the following statements about the model risk this creates is correct?

A. Because the theory and code were approved before the change, errors introduced when the model is re-coded into the production engine are IT risk, not model risk.

B. Model risk is assessed one model at a time, so the capital and limit models that take the VaR as an input carry no extra model risk from the change.

C. Model risk falls as the VaR output is used more widely across the bank, because broader use exposes errors faster and reduces uncertainty about the model.

D. The approximation and the new data source can compromise the output even though the theory is sound, and the effect can spread to every model that uses the VaR.

Question ORR-15 a.6 Workbook C6.1 • S1 • Map #32

A credit risk consultant is presenting to newly hired analysts at a Japanese trust bank on lessons from the 2007 to 2009 crisis. One slide maps the subprime securitisation chain as a series of frictions between pairs of parties, and labels the friction between CDO investors and the credit rating agencies as model error. An analyst asks how that label connects to the GARP case study on Gaussian copula pricing of CDOs. Which of the following statements should the consultant give as correct?

A. Investors relied on ratings and prices from a Gaussian copula calibrated to a short, benign CDS history; when correlations spiked the assumption failed, yet users kept relying on outputs whose limitations they did not understand.

B. The friction is an execution error: like the hidden rows in the Barclays spreadsheet, the copula failed to do what it was designed to do, so replicating its code would have exposed the problem.

C. The friction would have been removed by a sufficiently rigorous validation of the copula before use, because robust validation of a sound model eliminates its model risk.

D. The copula produced inaccurate CDO prices in all market conditions, so the losses came from a fundamental flaw in Li's formula rather than from how users relied on it.

Solutions • ORR-15 a

Solution ORR-15 a.1

Answer: C

Bank Q329 • Schweser Module Quiz 56.1 Q1

Step 1 – Recall the three components in order

Information input delivers data and assumptions; processing transforms inputs into estimates; reporting translates the estimates into useful business information.
⇒ Turning estimates into applied information is the last stage: reporting.

Interpretation

The order is inputs, then estimates, then information. Reporting is where model output reaches decision makers, which is why GARP asks for clear reports that show a range of outputs rather than one point estimate (ORR-15 c). All three components, reporting included, are subject to validation.

Why the other options are wrong

A is incorrect. Inputs deliver data and assumptions to the model; no estimate exists yet at that stage.
B is incorrect. Processing converts inputs into estimates, the step before reporting.
D is incorrect. "Transformational" is not one of the three components; it borrows the verb GARP uses for processing ("transforms inputs into estimates").

LO: ORR-15 a: Describe model risk and explain how it can arise in the implementation of a model. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.3 Overview of Model Risk Management; SchweserNotes 2026 Book 3, Reading 56, LO 56.a

Solution ORR-15 a.2

Answer: A

Bank Q330 • AnalystPrep Q.4297

Step 1 – The definition

Model risk is the potential for adverse consequences from decisions based on incorrect or misused model outputs and reports.
⇒ It needs a decision, and an output that is wrong or wrongly used.

Step 2 – The consequences

Financial loss, poor business and strategic decision making, and damage to reputation.
⇒ Only A names both sources (flawed or misused) and the losses that follow.

Interpretation

Model risk is the *indirect* cost of models. The direct cost, the resources spent developing and implementing them, is a separate item that GARP mentions alongside it.

Why the other options are wrong

B is incorrect. Development spending is the direct cost of models, not model risk; model risk comes from decisions based on bad or misused outputs.
C is incorrect. Absolute claim. Models are simplifications, can be misused, and model risk cannot be eliminated even with skilled modelling and robust validation.
D is incorrect. Ignores the second source: a sound model that is misapplied or misused can carry high model risk.

LO: ORR-15 a: Describe model risk and explain how it can arise in the implementation of a model. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.1 Introduction and 15.3; SchweserNotes 2026 Book 3, Reading 56, LO 56.a

Solution ORR-15 a.3 — Answer: C

Bank Q327 • AnalystPrep Q.4305

Step 1 – Rule out processing and use

The mathematics and implementation are correct, and the model is used for exactly what it was built to do: estimate credit losses.

⇒ The fault is neither in the processing component nor in how the model is used.

Step 2 – Locate the fault

The model was estimated only on expansion data, which do not represent a downturn. GARP: "the quality of model outputs depends on the quality of input data and assumptions, and errors in inputs or incorrect assumptions will lead to inaccurate outputs."

⇒ Reason 1 of model risk, entering through the input component and the "choice of sample design".

Interpretation

Data relevance and representativeness are checked in development (ORR-15 c) and again when validators evaluate conceptual soundness (ORR-15 d). The purpose of a credit loss model includes bad years, so a sample with no bad years is a design error, not a change of use.

Why the other options are wrong

A is incorrect. The model is used for its intended purpose; the problem is the data it was built on.

B is incorrect. Nothing in the stem concerns presentation; the reporting component only communicates the estimates.

D is incorrect. False premise: every model rests on assumptions (they are part of the information input component).

LO: ORR-15 a: Describe model risk and explain how it can arise in the implementation of a model. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.3; SchweserNotes 2026 Book 3, Reading 56, LO 56.a

Solution ORR-15 a.4 — Answer: B

Bank Q326 • BT P2.T7.604.2

Step 1 – Rule out Reason 1

The code is error-free and vanilla valuations are accurate, so the model has no fundamental error for its design objective.

Step 2 – Identify Reason 2

The desk applies the model to a product it was not built for. GARP: banks may use a model outside its environment "intentionally as they apply existing models to new products or markets".

⇒ A sound model, misapplied: high model risk.

Interpretation

The vanilla model's assumptions restrict its scope to products without optionality; that limitation is invisible in its vanilla results. The new use should be validated before the model is relied on (ORR-15 d). Where that cannot be done in time, GARP asks for documented limitations and compensating controls, noting this is "particularly applicable to new models and to the use of existing models in new applications".

Why the other options are wrong

A is incorrect. The stem rules this out: the code is error-free.

C is incorrect. Every model has a reporting component; nothing in the stem concerns reporting.

D is incorrect. Accuracy within the original scope is not enough; model risk also arises from use outside the intended scope.

LO: ORR-15 a: Describe model risk and explain how it can arise in the implementation of a model. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.3 and 15.5; SchweserNotes 2026 Book 3, Reading 56, LO 56.a

Solution ORR-15 a.5 — Answer: D

New • built from GARP Ch.15

Step 1 – Where errors can enter

GARP's chain runs from theory through sample design and numerical routines, inputs and estimation, to implementation in information systems, and "errors can occur at any point from design through implementation". Shortcuts, simplifications or approximations "could compromise the integrity and reliability of outputs", and output quality depends on input data.
⇒ The delta-gamma shortcut and the new position feed are both implementation-stage sources of model risk.

Step 2 – Size and aggregation

Model risk increases with complexity, uncertain inputs, broader use and larger impact, and must be assessed individually and in aggregate. Aggregate model risk rises with dependencies among models and reliance on common data or assumptions.
⇒ Two downstream models now inherit any VaR error.

Interpretation

A change in technique of this kind is a material change: it should be validated before it goes into production, and process verification (code, data, systems integration) should follow it in ongoing monitoring (ORR-15 d).

Why the other options are wrong

A is incorrect. Scope error. Implementation in information systems is part of the model calculation; errors there are model risk, whatever the earlier approval.
B is incorrect. Ignores aggregate model risk, which arises precisely from dependencies among models and shared inputs.
C is incorrect. Polarity flip. Model risk *increases* with broader use and larger potential impact.

LO: ORR-15 a: Describe model risk and explain how it can arise in the implementation of a model. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.3 and 15.4 (Model Development and Implementation)

Solution ORR-15 a.6 — Answer: A

Workbook C6.1 • S1

Step 1 – Name the friction

In the securitisation-frictions taxonomy, the investor depends on the rating agency's model to judge the credit quality of the tranche it buys; the friction is that the model can be wrong or wrongly used, hence "model error" (outside-source framing).
⇒ The investor's risk sits inside someone else's model, and it is model risk in the ORR-15 sense: adverse consequences from decisions based on incorrect or misused model outputs.

Step 2 – Map it to the GARP case

Li's Gaussian copula inferred correlation from CDS prices. CDSs had only about a decade of history in a benign period, so implied correlations were very low and sensitive to house prices. The method was adopted by investors, banks, rating agencies and regulators. It worked in normal conditions; when house prices reversed, implied correlations shot up, and banks kept pricing with the old assumptions.
⇒ This is a conceptual error (an assumption that held only in one context) combined with misuse (blind reliance on a black box).

Step 3 – The MRM lesson

MRM must replicate the model to rule out coding errors, but its more critical job is to challenge assumptions and explain limitations to non-quantitative users in plain terms.

Interpretation

The investor and rating agency friction is model risk of the conceptual-and-misuse type, exactly the failure in the Gaussian copula case, and the remedy is transparency about assumptions, not just better code.

Why the other options are wrong

B is incorrect. Sibling swap (case cross-mapping): execution error and the Barclays hidden-rows lesson describe an implementation failure in a tool that is not even a model; the copula did what it was designed to do, on an assumption that stopped holding.

C is incorrect. Absolute claim: even with skilled modelling and robust validation, model risk cannot be eliminated; other tools (limits on use, monitoring, revision, supplementary analysis) are still needed.

D is incorrect. Scope/condition error: the copula assumption was valid and accurate in normal market conditions; dropping that condition also reverses the case's verdict that the problem was not the formula itself but its blind use without updating correlations.

LO: ORR-16 a: Define a model and describe different ways that financial institutions can become exposed to model risk. ORR-16 c: Describe lessons learned from the three case studies involving model risk. ORR-15 a: Describe model risk and explain how it can arise in the implementation of a model. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, Model Risks and Gaussian Copula and CDO Pricing; Ch.15, 15.3

ORR-15 • Supervisory Guidance on Model Risk Management • Vardeez: VERY IMPORTANT

ORR-15 b

P2 CONCEPT

Describe elements of an effective model risk management process.

Workbook: C6 Model Risk Management • Tier C

WHAT IS TESTED HERE

Why P2. Vardeez flags ORR-15 as a Very Important chapter (STRIKE FIRST, rank 20 of 55). On its own the recall evidence is Tier C (C6, map #32, 3 of 16 sources).

Vardeez: "LO 54.b" (consolidated volume p.86). His five elements: scale the effort to complexity, uncertainty and impact; an independent, technically strong team that challenges the model; model outputs used together with other information; continuous tracking of performance with management support; restrictions on use, performance analysis and recalibration.

Reported exam shapes

- **S2** The three components of model risk management: development, implementation and use; validation; governance, policies and controls.

What the questions look like: the guiding principle (effective challenge), what sets the intensity of model risk management (materiality), and who does what: board, senior management, model owners, risk-control staff, internal audit. Distractors swap roles or make absolute claims.

See also: the definition of model risk is in ORR-15 a. Workbook C6.2 is homed here and also covers S3 (independence), taught in ORR-15 d.

1. Manage model risk like any other risk

Recap from ORR-15 a: model risk grows with complexity, input and assumption uncertainty, breadth of use and potential impact, and must be seen model by model and in aggregate. The process GARP describes rests on four ideas:

- **Identify and size it.** Identify the sources of model risk and assess their magnitude, individually and in aggregate.
- **Effective challenge is the guiding principle:** "critical analysis by objective, informed parties who can identify model limitations and assumptions and produce appropriate changes." It depends on **incentives** (stronger with greater separation from model development, and with supportive compensation and culture), **competence** (technical knowledge and modelling skill) and **influence** (explicit authority, stature in the organisation, and support from higher levels of management). The detail, for validators, is in ORR-15 d.
- **Use other tools, because model risk cannot be eliminated:** limits on model use, monitoring of model performance, adjusting or revising models over time, and supplementing model results with other analysis and information. Informed conservatism in inputs, design or outputs can help, but is no excuse for not improving the model.
- **Materiality sets the intensity.** Where models have a material impact on business decisions (including risk, capital and liquidity planning) and failure would harm the bank's financial condition, the framework should be "more extensive and rigorous". A bank with few, moderately complex models needs a less involved approach.

2. The three components (shape S2)

"Model risk management begins with robust model development, implementation, and use. Another essential element is a sound model validation process. A third element is governance."

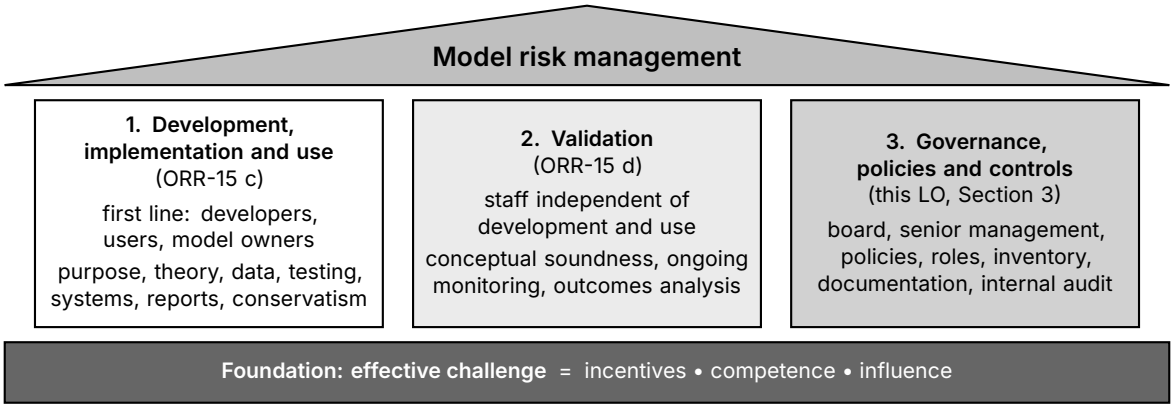


Figure 1. The three components of model risk management as pillars (white, light grey, mid grey), resting on effective challenge (dark base). GARP: even if development, use and validation are satisfactory, "a weak governance function will reduce the effectiveness of overall model risk management".

3. Governance, policies and controls

Board and senior management. The board is **ultimately responsible**; it establishes a bank-wide approach and delegates to senior management the responsibility for executing and maintaining the framework. Senior management sets policies and procedures, assigns competent staff, oversees development and implementation, evaluates results, ensures effective challenge, reviews validation and internal audit findings, takes prompt remedial action, and **reports significant model risk to the board**, individually and in aggregate. The board ensures the level of model risk stays within its tolerance.

Policies and procedures. Approved by the board or its delegates and **reviewed annually**. They cover model and model risk definitions, assessment of model risk, development, implementation and use, validation, and governance; targets for accuracy and standards for acceptable discrepancies; the prioritisation, scope and frequency of validation; vendor-model selection and validation; and documentation, including the model inventory.

Roles: ownership, controls, compliance.

- **Ownership.** Business units are responsible for the model risk of their strategies. The **model owner** has ultimate accountability for model use and performance, ensures models are properly developed, implemented and used, that models in use have been validated and approved, and supplies the information validators need.
- **Controls.** Risk-control staff handle risk measurement, limits and monitoring, manage the independent validation process, and have **the authority to restrict the use of models**. Temporary exceptions they grant must themselves be subject to controls (timelines, limits on use).
- **Compliance** with policy is an obligation of owners and risk-control staff, made transparent by documentation.

Internal audit assesses the overall effectiveness of the framework, for both types of model risk, individually and in aggregate, and reports to the board. It does *not* duplicate model risk management. If some internal audit staff perform validation work, **they must not assess the overall framework**.

It verifies policy compliance, the model inventory, timeliness of validations, data reliability, and the objectivity, competence and standing of validators.

Inventory and documentation. A firm-wide inventory of models in use, under development or recently retired (purpose, usage, restrictions, inputs, outputs, status, owners, validation dates). Documentation detailed enough that "parties unfamiliar with a model can understand how the model operates, its limitations, and its key assumptions"; banks should provide incentives to produce it. External resources may be used, but a designated internal party verifies the scope, tracks issues and integrates the work, and the bank needs a contingency plan.

Party	Role in the model risk management process
Board	Ultimately responsible; approves policies (or delegates) and reviews them annually; keeps model risk within tolerance
Senior management	Executes the framework; ensures effective challenge; reports significant model risk to the board
Model owner (business unit)	Ultimate accountability for use and performance; ensures validation and approval of models in use
Risk-control staff	Limits and monitoring; manage independent validation; authority to restrict model use
Validators	Effective challenge with independence, incentives, competence, influence (ORR-15 d)
Internal audit	Evaluates whether model risk management is comprehensive, rigorous and effective; does not duplicate it

Vardeez's five elements, mapped. His (a) is materiality and model risk sizing; (b) is effective challenge; (c) and (e) are GARP's "other tools" (supplement outputs with other information, limits on use, performance analysis, recalibration); (d) is ongoing monitoring with management support, which governance supplies.

Exam traps

- **Role misassignment.** The model owner is accountable for use and performance; risk-control staff hold the authority to restrict use; the board is ultimately responsible; internal audit evaluates the framework.
- **Board delegates execution, not responsibility.**
- **Internal audit doing validation.** Staff who perform validation work must not assess the overall framework; internal audit does not duplicate model risk management.
- **Intensity driven by the wrong factor.** Materiality (impact on decisions and financial condition), not the model's age, origin or team size.
- **Absolute claims.** Model risk cannot be eliminated; conservatism does not replace model improvement.
- **Incentive polarity.** Challenge is stronger with *greater* separation from development.

Practice questions: ORR-15 b

Question ORR-15 b.1

Bank Q335 • BT P2.T7.20.3.1

Which of the following is the BEST guiding principle for managing model risk?

A. Model development

B. Effective challenge

C. Regulatory compliance

D. Latest and best technology

Question ORR-15 b.2

Bank Q336 • Schweser Module Quiz 56.1 Q2 (rebuilt)

Which of the following statements regarding model risk management is correct?

A. Shortcuts and simplifications adopted to manage complexity cannot affect the accuracy of model outputs.

B. Managing model risk requires proper segregation of duties.

C. With appropriate procedures and tools, model risk can be eliminated.

D. Like many other risks, model risk has both an upside and a downside component.

Question ORR-15 b.3

Bank Q334 • AnalystPrep Q.4450 (rebuilt)

According to the supervisory guidance, which of the following is the key factor that should drive the level and comprehensiveness of a bank's model risk management for a particular model?

A. The potential impact of the model on the firm's profits and financial position

B. The number of staff who developed the model

C. Whether the model was built in-house rather than obtained from a vendor

D. How long the model has been in use

Question ORR-15 b.4

Bank Q331 • AnalystPrep Q.4742

Which of the following parties is primarily responsible for ensuring a model has undergone appropriate validation and approval processes before being deployed?

A. Internal audit function

B. Model owner

C. Senior management

D. Independent validation team

Question ORR-15 b.5 Bank Q332 • AnalystPrep Q.2235

A bank holding company (BHC) is having a supervisory review performed on its modeling practices for capital planning. Following the review, the company receives very positive feedback regarding its model documentation as part of risk management. What could be the reason for the positive feedback?

A. Large-scale collection of relevant historical data for use as input data.

B. Presence of an updated inventory of all models used in the process.

C. Presence of qualified modeling staff.

D. Adoption of large-scale sensitivity testing and stress testing.

Question ORR-15 b.6 Workbook C6.2 • S2, S3 • Map #32

The head of model risk at a Singapore bank is drafting the charter of a newly created model risk management (MRM) function. The charter is organised around the three elements named in the supervisory guidance: model development, implementation and use; model validation; and governance, policies and controls. The validation team has four staff and the bank runs over 300 models, so some testing of lower-tier models is currently performed by the model developers. Which of the following statements is appropriate to include in the charter?

A. Model owners in the business units, who carry ultimate accountability for model use and performance, should hold the authority to restrict a model's use once validation finds significant deficiencies.

B. To preserve independence, no validation work may be performed by developers or users, and any testing they have already done must be discarded and repeated in full by the MRM team.

C. Incentives for effective challenge are strongest when validators sit close to the development process, because that proximity is what gives them the competence to critique a model.

D. Developers may perform some validation work if an independent party critically reviews it and adds further testing; independence may be supported by reporting lines but is judged by actions and outcomes.

Solutions • ORR-15 b

Solution ORR-15 b.1 — Answer: B

Bank Q335 • BT P2.T7.20.3.1

Step 1 – GARP's own words

"A guiding principle for managing model risk is 'effective challenge' of models, that is, critical analysis by objective, informed parties who can identify model limitations and assumptions and produce appropriate changes."

Step 2 – What it rests on

Incentives, competence and influence.

⇒ Effective challenge is named as the guiding principle; the other options are at most activities or constraints.

Interpretation

Each of the three components of the process applies the principle: users challenge during model use, validators challenge in validation, and governance gives challengers authority and stature.

Why the other options are wrong

A is incorrect. Development is one of the three components of the process, not its guiding principle.

C is incorrect. Compliance with regulation does not by itself ensure that models are critically analysed.

D is incorrect. Technology is not mentioned as a principle; new techniques can add model risk.

LO: ORR-15 b: Describe elements of an effective model risk management process. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.3 Overview of Model Risk Management

Solution ORR-15 b.2 — Answer: B

Bank Q336 • Schweser Module Quiz 56.1 Q2

Step 1 – Effective challenge needs separation

Incentives to challenge are stronger "when there is greater separation of that challenge from the model development process". Schweser: the people who challenge should be independent of development, to avoid a self-review threat.

⇒ The builders of a model should not be its only reviewers: segregation of duties.

Step 2 – Test the other statements

Simplifications can compromise outputs; model risk cannot be eliminated; model risk is defined by adverse consequences only.

Interpretation

GARP stops short of total separation: some validation work may be done by developers and users, provided an independent party critically reviews it (ORR-15 d). "Segregation of duties" means the critical review is independent, not that developers do no testing.

Why the other options are wrong

A is incorrect. Polarity flip: shortcuts, simplifications or approximations "could compromise the integrity and reliability of outputs".

C is incorrect. Absolute claim: "model risk cannot be eliminated", even with skilled modelling and robust validation.

D is incorrect. Model risk is the potential for *adverse* consequences; it has no upside.

LO: ORR-15 b: Describe elements of an effective model risk management process. • **Reference:** FDIC FIL-22-2017

(GARP ORR Ch.15), 15.3; SchweserNotes 2026 Book 3, Reading 56, LO 56.b

Solution ORR-15 b.3 Answer: A

Bank Q334 • AnalystPrep Q.4450

Step 1 – Materiality

"As is generally the case with other risks, materiality is an important consideration in model risk management." Where models have a material impact on decisions and model failure would harm the bank's financial condition, the framework "should be more extensive and rigorous".
⇒ The potential impact on profits and financial position sets the intensity.

Interpretation

The same logic reappears in ORR-16 b as model tiering: materiality of output heads the list of tiering criteria, and the tier sets the depth and frequency of validation.

Why the other options are wrong

B is incorrect. The size of the development team says nothing about exposure.
C is incorrect. Vendor models follow the same principles and must also be validated; origin does not set the level of model risk management.
D is incorrect. Age is not a materiality measure; an old model may even have drifted out of the context it was built for.

LO: ORR-15 b: Describe elements of an effective model risk management process. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.3; SchweserNotes 2026 Book 3, Reading 56, LO 56.b

Solution ORR-15 b.4 Answer: B

Bank Q331 • AnalystPrep Q.4742

Step 1 – The model owner's duties

The owner has "ultimate accountability for model use and performance". GARP: "The model owner should also ensure that models in use have undergone appropriate validation and approval processes, promptly identify new or changed models, and provide all necessary information for validation activities."
⇒ Ensuring validation and approval is an ownership duty.

Interpretation

Ownership, controls and compliance are separate roles. The validation team performs the challenge; the owner makes sure the model goes through it before use.

Why the other options are wrong

A is incorrect. Internal audit verifies that validations are timely and policies are followed; it evaluates the framework rather than ensuring each model is validated.
C is incorrect. Senior management sets policies and oversees the framework, but the model-level duty sits with the owner.
D is incorrect. Validators carry out the independent review; they do not own the model or submit it for approval.

LO: ORR-15 b: Describe elements of an effective model risk management process. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.6 Roles and Responsibilities

Solution ORR-15 b.5 Answer: B

Bank Q332 • AnalystPrep Q.2235

Step 1 – What counts as documentation

Policies should "require maintenance of detailed documentation of all aspects of the model risk management framework, including an inventory of models in use, results of the modeling and validation processes, and model issues and their resolution."

Step 2 – Match the options

An up-to-date inventory is documentation; data collection, staff quality and testing are not.
$\Rightarrow$ B.

Interpretation

The inventory lets the bank evaluate model risk in aggregate: it lists each model's purpose, usage, restrictions, inputs, components and validation dates.

Why the other options are wrong

A is incorrect. Data collection is about input quality, not documentation.

C is incorrect. Qualified staff support effective challenge (competence) but are not documentation.

D is incorrect. Sensitivity and stress testing are testing practices; their results would be documented, but the testing itself is not documentation.

LO: ORR-15 b: Describe elements of an effective model risk management process. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.6 Policies and Procedures, Model Inventory, Documentation

Solution ORR-15 b.6 Answer: D

Workbook C6.2 • S2, S3

Step 1 – Place the problem in the three components

Development, implementation and use (first line: developers and model owners); validation (independent effective challenge); governance, policies and controls (board, senior management, policies, roles, inventory, documentation, internal audit). The staffing gap sits in the second component, but the cure is written into the third.

Step 2 – What independence requires

Validation is generally done by people not responsible for development or use. As a practical matter some validation work may be done most effectively by developers and users, provided it is subject to critical review by an independent party who conducts additional activities. Independence may be supported by separate reporting lines but should be judged by actions and outcomes.
$\Rightarrow$ The charter can keep developer testing on lower-tier models, but only with independent review on top, and must evidence independence through results (models changed after validation).

Step 3 – Effective challenge

It needs incentives (stronger with greater separation from development, plus compensation and culture), competence, and influence (authority, stature, senior support).

Interpretation

D is the guidance's own answer to scarce validation resources, combined with tiering so that the full-scope effort goes to the highest-tier models.

Why the other options are wrong

A is incorrect. Role misassignment: the model owner is accountable for use and performance, but the authority to restrict the use of models belongs to risk-control staff, whose temporary

exceptions are themselves subject to other controls.

B is incorrect. Absolute claim: the guidance expressly allows some validation work by developers and users if an independent party critically reviews it; a blanket ban and full repetition is not required.

C is incorrect. Polarity flip: incentives to provide effective challenge are stronger when there is greater separation of that challenge from the model development process; competence comes from technical skill and business familiarity, not proximity.

LO: ORR-15 b: Describe elements of an effective model risk management process. ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process. ORR-16 b: Describe the role of the model risk management function and explain best practices in the model risk management and validation processes. • **Reference:** GARP, Operational Risk and Resilience, Ch.15, 15.3 and 15.5 (Model Validation), 15.6 (Roles and Responsibilities); Ch.16, Model Risk Management

ORR-15 • Supervisory Guidance on Model Risk Management • Vardeez: VERY IMPORTANT

ORR-15 c

P2 CONCEPT

Explain best practices for the development and implementation of models.

Workbook: *none*

WHAT IS TESTED HERE

Why P2. Vardeez flags ORR-15 as a Very Important chapter (STRIKE FIRST, rank 20 of 55); the map attaches no workbook section to this LO.

Vardeez: "LO 54.c" (consolidated volume p.86). His six best practices: a clear statement of purpose aligned with use; sound mathematics and a "reasonability check" against alternative models; relevant, robust data with documented proxies and adjustments; testing for precision, strength and consistency in normal and stressed markets; multiple tests to avoid Type I and Type II errors; robust internal controls over people and technology.

Reported exam shapes: none reported; questions built from the LO wording and Vardeez's focus.

What the questions look like: "which practice is least consistent" items on testing, documentation and data; the GARP practice-exam case of a new loan product and an existing well-performing model; and the trap that conservatism or a single test settles the matter.

See also: ORR-15 b places this LO as the first of the three components of model risk management.

1. Development: purpose, theory, comparison

"Model development is not a straightforward or routine technical process." The experience and judgment of developers, as much as their technical knowledge, drive the choice of inputs and processing components, and modelling is multidisciplinary. Best practice:

- **A clear statement of purpose** at the outset, so that development is aligned with the intended use.
- **Design, theory and logic well documented** and generally supported by published research and sound industry practice; methodologies and processing components (mathematical specification, numerical techniques, approximations) explained in detail, "with particular attention to merits and limitations".
- **Components that work as intended**, appropriate for the business purpose, conceptually sound, and mathematically and statistically correct.
- **Comparison with alternative theories and approaches** is "a fundamental component of a sound modeling process" (Schweser and Vardeez: a "reasonability check").

2. Data and information

- Rigorous assessment of data **quality and relevance**, with documentation. Developers must show the data suit the model and are consistent with its theory and methodology.
- **Data proxies** are carefully identified, justified and documented.
- If data are **not representative** of the bank's portfolio, or assumptions are made to **adjust** them, these are tracked and analysed so users know the limitations. This matters most for **external (vendor) data** and for new products or activities.

3. Testing

Testing is "an integral part of model development": it checks the model's accuracy, shows it is robust and stable, assesses limitations, and evaluates behaviour over a range of input values. Best practice:

- Assess the impact of assumptions and find situations where the model performs poorly or becomes unreliable.
- Test under a variety of market conditions, **including scenarios outside the range of ordinary expectations**, and across the products or applications the model is meant for.
- Evaluate **extreme input values** to find the boundaries of model effectiveness.
- Evaluate the impact on **other models that use this model's results as inputs**.
- Document test plans (purpose, design, execution), summary results with commentary, and detailed analysis of informative samples.
- **Use a variety of tests.** Statistical tests often cannot unambiguously reject false hypotheses or accept true ones from sample data, and each test has strengths and weaknesses, so "any single test is rarely sufficient". (Schweser frames this as avoiding Type I errors, rejecting a true null, and Type II errors, failing to reject a false one.)
- **Judgmental or qualitative adjustments** to statistical output may be appropriate, but must be made in an appropriate and systematic manner and be well documented.

4. Implementation in systems

Models are embedded in larger information systems that move data in and aggregate and report results. Calculations must match the systems' capabilities, and sound model risk management "depends on substantial investment in supporting systems" for data and reporting integrity, plus controls and testing for proper implementation, effective systems integration and appropriate use. (Schweser and Vardeez: a robust internal control system involving both people and technology.)

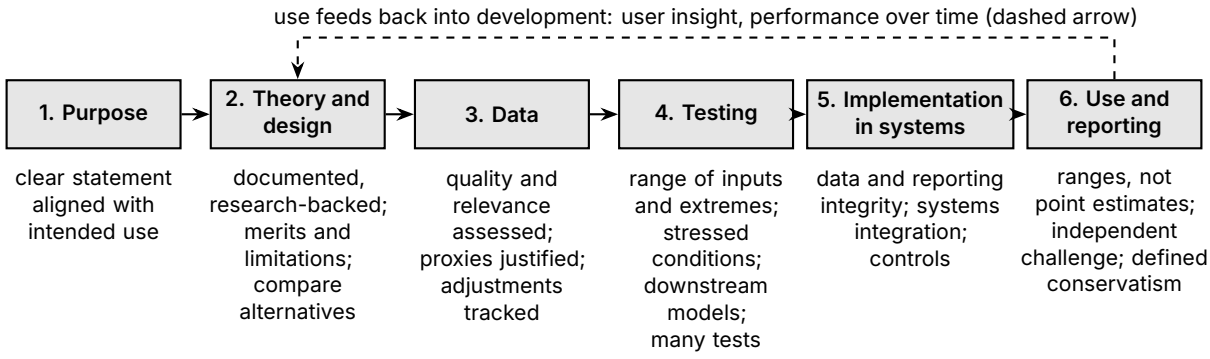


Figure 1. Development, implementation and use as a sequence of six stages (grey boxes, solid arrows), each with its best practice underneath. The dashed arrow is model use acting as a further test and source of feedback.

5. Use: the third part of the first component

- **Use is another test.** It shows whether the model keeps working as conditions and applications change, and users can give valuable business insight during development.
- **User challenge is limited.** It may be weak if the model does not materially affect users' results, if changes are seen as bad for the business line, or if change is expensive; it is not comprehensive (users focus on what drives their measured performance or pay); and it is **asymmetric**, because users rarely challenge outcomes that favour them and may wrongly conclude model risk is low because outcomes look favourable. So banks should also seek challenge from sources independent of the business line.
- **Reports** must be clear to decision makers, who come from different backgrounds than modelers. Reports giving a **range of estimates** for different input and assumption values signal accuracy, robustness, stability and limitations, and avoid spurious precision.
- **Conservatism with care.** Banks may adjust inputs or outputs, give the model less weight, use it only alongside other models, or hold a capital cushion. But an extreme point on a modelled distribution "may not be conservative if the distribution was misestimated or misspecified"; conservative assumptions may not stay conservative; claims must be justified with a defined and measured conservatism communicated to users; and excessive conservatism makes users discount the model and can stop the bank improving it.

Stage	Best practice (GARP)	Statement that fails
Development	clear purpose; documented theory; merits and limitations; compare alternatives	"development is a routine technical process"
Data	quality and relevance assessed; proxies identified, justified, documented	"only the final output needs documenting"
Testing	variety of conditions incl. stress; extreme inputs; downstream models; several tests	"test in normal conditions only"; "one good test suffices"
Adjustments	judgmental adjustments allowed if systematic and documented	"never adjust model output"
Use	independent challenge; ranges; defined, measured conservatism	"pick an extreme percentile and call it conservative"

Exam traps

- **"Routine."** Development is not straightforward or routine; developer judgment matters.
- **Normal conditions only.** Testing must include scenarios outside ordinary expectations and extreme input values.
- **A good track record transfers.** A model that performs well for one product is not thereby fit for a new one (GARP PE2 Q4).
- **"Never" adjust.** Qualitative adjustments are allowed when systematic and documented.
- **Extreme point = conservative.** Not if the distribution is misestimated or misspecified.
- **Favourable outcomes = low model risk.** User challenge is asymmetric.
- **Developers validate.** Developers test; validation needs independence (ORR-15 d).

Practice questions: ORR-15 c

Question ORR-15 c.1

Bank Q337 • AnalystPrep Q.4304

Model development and implementation in risk management requires various best practices to ensure that the models are aligned to their intended use. Which of the following statements about these best practices is MOST accurate?

A. The merits and limitations of the model methodologies and processing components should be well explained.

B. Developers should compare their models with alternative approaches and theories.

C. The quality of data used to develop a model should be assessed and documented.

D. All of the above

Question ORR-15 c.2

Bank Q341 • AnalystPrep Q.4448 (rebuilt)

Which of the following should be clearly documented and made clear to users during model development, so that users can judge the usefulness of the data themselves?

A. The identities of the individual users of the model.

B. The compensation structure of the validation team.

C. Any data proxies, unrepresentative data, and adjustments made to data, such as those from external sources.

D. Only the final model output, since inputs are internal matters.

Question ORR-15 c.3

Bank Q340 • Schweser Module Quiz 56.1 Q3 (rebuilt)

During model development, a bank's model team is designing its testing program. Which of the following practices is LEAST consistent with sound model testing?

A. Documenting potential weaknesses of the model and circumstances in which it does not work.

B. Using inputs over a wide range of values, including extreme values, to find the boundaries of model effectiveness.

C. Restricting testing to normal market conditions, because stressed conditions are too rare to be informative.

D. Analyzing other models that use the subject model's outputs as their inputs.

Question ORR-15 c.4

Bank Q344 • AnalystPrep Q.4303 • re-filed from LO 56.d

TCC Bank has developed a set of models to analyze liquidity risk, market risk and borrower credit risk. Which of the following model risk management functions is LEAST likely to be handled by the developers of these models?

A. Stating a clear purpose so that development is aligned with the intended use

B. Rigorous assessment of data quality and relevance

C. Model testing

D. Independent model validation

Question ORR-15 c.5 Bank Q338 • BT Mock Q33 • BT P2.T7.20.3.2

According to the FDIC, model risk management starts with robust model development, implementation, and use (the first element; the second is a sound validation process, and the third is governance). Which of the following is a TRUE statement about this first element?

A. Model development should be a straightforward and routine technical process.

B. To exercise conservatism, pick an extreme point on a given modeled distribution.

C. Banks should never modify model output with judgmental or qualitative adjustments.

D. Although the nature of testing varies by the context and type of model, testing is an integral part of model development.

Question ORR-15 c.6 Bank Q339 • GARP PE2 Q4 • Mock 4 Q5

A midsize bank specializing in residential mortgages and credit cards is planning to offer a new commercial loan product. The bank has an existing credit rating model for its residential mortgage products which has performed well and has been successfully backtested over several years, but the CRO considers whether the bank should develop and implement a new model for the commercial loan product. In addition, the CRO wants to ensure that the bank follows best practices for the development, validation, and implementation of any models that it uses. Which of the following actions should the CRO recommend that the bank take?

A. Apply the strongly performing existing model to the new commercial loan product given the model's successful track record.

B. Develop a new model for the commercial loan product and avoid the use of qualitative or judgmental adjustments to the model's quantitative output.

C. Make the model development team responsible for validating all of the bank's models that are currently operational.

D. Perform sensitivity analysis on all models used by the bank to identify market conditions under which they might perform poorly.

Solutions • ORR-15 c

Solution ORR-15 c.1 — Answer: D

Bank Q337 • AnalystPrep Q.4304

Step 1 – Check each statement against Section 15.4

A: methodologies and processing components "should be explained in detail with particular attention to merits and limitations". B: "Comparison with alternative theories and approaches is a fundamental component of a sound modeling process." C: "there should be rigorous assessment of data quality and relevance, and appropriate documentation."
⇒ All three are stated best practices.

Interpretation

These three map onto the first three stages of Figure 1: theory and design, comparison, data. The only complete answer is the one that includes them all.

Why the other options are wrong

A is incorrect. True but incomplete: B and C are also best practices.
B is incorrect. True but incomplete: comparison with alternatives is one practice among several.
C is incorrect. True but incomplete: data assessment is one practice among several.

LO: ORR-15 c: Explain best practices for the development and implementation of models. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.4 Model Development and Implementation

Solution ORR-15 c.2 — Answer: C

Bank Q341 • AnalystPrep Q.4448

Step 1 – The data rule

"If data proxies are used, they should be carefully identified, justified, and documented. If data and information are not representative of the bank's portfolio... or if assumptions are made to adjust the data and information, these factors should be properly tracked and analyzed so that users are aware of potential limitations."
⇒ Proxies, unrepresentative data and adjustments are what users need to see.

Interpretation

GARP singles out external (vendor) data and new products, where the risk of unrepresentative data is highest.

Why the other options are wrong

A is incorrect. User identities say nothing about the data's usefulness.
B is incorrect. Validator pay matters for effective challenge (incentives), not for data documentation.
D is incorrect. Hiding the inputs hides the limitations; input quality drives output quality.

LO: ORR-15 c: Explain best practices for the development and implementation of models. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.4; SchweserNotes 2026 Book 3, Reading 56, LO 56.c

Solution ORR-15 c.3 — Answer: C

Bank Q340 • Schweser Module Quiz 56.1 Q3

Step 1 – What testing must cover

"Testing should be applied to actual circumstances under a variety of market conditions, including scenarios that are outside the range of ordinary expectations." Extreme input values identify

the boundaries of model effectiveness; the impact on models that use the results must be evaluated; weaknesses and failure situations must be identified.
⇒ A, B and D are required; C cuts out exactly the conditions in which models fail.

Interpretation

Stressed scenarios are rare, which is why they are tested deliberately rather than waited for. Schweser's wording: test in normal and extreme (stressed) states, including unusual but plausible conditions.

Why the other options are wrong

A is incorrect. Sound: testing should identify situations where the model "performs poorly or becomes unreliable".
B is incorrect. Sound: "Extreme values for inputs should be evaluated to identify any boundaries of model effectiveness."
D is incorrect. Sound: "The impact of model results on other models that rely on those results as inputs should also be evaluated."

LO: ORR-15 c: Explain best practices for the development and implementation of models. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.4; SchweserNotes 2026 Book 3, Reading 56, LO 56.c

Solution ORR-15 c.4 — Answer: D

Bank Q344 • AnalystPrep Q.4303

Step 1 – What developers do

Development begins with a clear statement of purpose, includes rigorous assessment of data quality and relevance, and treats testing as an integral part.
⇒ A, B and C are developer tasks.

Step 2 – What they should not do alone

"Generally, validation should be done by people who are not responsible for development or use and do not have a stake in whether a model is determined to be valid."
⇒ Independent validation is the one function least likely to sit with developers.

Interpretation

Developmental testing and independent validation are different things: the first is part of building the model, the second is effective challenge of it. Developers may do some validation work only if an independent party critically reviews it (ORR-15 d). Re-filed here from the validation LO because three of its four options are development best practices.

Why the other options are wrong

A is incorrect. Stating the purpose is the first step of development.
B is incorrect. Data assessment is a developer responsibility.
C is incorrect. Testing is "an integral part of model development".

LO: ORR-15 c: Explain best practices for the development and implementation of models. ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.4 and 15.5

Solution ORR-15 c.5 — Answer: D

Bank Q338 • BT Mock Q33

Step 1 – Test each statement

A: "Model development is not a straightforward or routine technical process." False. B: an extreme point "may not be conservative if the distribution was misestimated or misspecified". False.

C: judgmental or qualitative adjustments "may be appropriate" if systematic and documented. False. D: testing is integral, and "the nature of testing and analysis will depend on the type of model". True.
⇒ D.

Interpretation

Three of the four options are absolute or mechanical rules; GARP's guidance consistently prefers judgment that is documented and justified. (The bank's option C reads "never model output"; it is re-typeset as "never modify model output", the evident meaning.)

Why the other options are wrong

A is incorrect. Polarity flip: development depends on the experience and judgment of developers.
B is incorrect. Conservatism must be defined and measured; an extreme percentile of a misspecified distribution is not conservative.
C is incorrect. Absolute claim: adjustments are allowed when made systematically and documented.

LO: ORR-15 c: Explain best practices for the development and implementation of models. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.4 (Model Development and Implementation; Model Use)

Solution ORR-15 c.6 Answer: D

Bank Q339 • GARP PE2 Q4

Step 1 – The new product

A mortgage rating model, however well backtested, was built for residential borrowers. Using it for commercial loans is the intentional misuse GARP describes: applying existing models to new products.
⇒ A is out.

Step 2 – Development and validation rules

Qualitative adjustments are allowed if systematic and documented (B out). Validation should be done by people not responsible for development (C out).

Step 3 – Sensitivity analysis

Testing and validation should identify "situations where the model performs poorly or becomes unreliable"; sensitivity analysis checks the impact of input and parameter changes and reveals unstable models.
⇒ D is the recommended practice.

Interpretation

GARP's guidance says sensitivity analysis is used "where appropriate to the particular model"; the key's "all models" should be read in that spirit. GARP's own practice exam tests the point behind option A: a good track record does not transfer to a new product.

Why the other options are wrong

A is incorrect. A track record on one product does not make the model fit for another; this is use outside the intended scope.
B is incorrect. Developing a new model is sensible, but banning judgmental adjustments is not a best practice.
C is incorrect. Developers validating all models removes the independence validation requires.

LO: ORR-15 c: Explain best practices for the development and implementation of models. ORR-15 a: Describe model risk and explain how it can arise in the implementation of a model. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.3, 15.4 and 15.5 (Evaluation of Conceptual Soundness)

ORR-15 • Supervisory Guidance on Model Risk Management • Vardeez: VERY IMPORTANT

ORR-15 d

P2 CONCEPT

Describe elements of a strong model validation process and challenges to an effective validation process.

Workbook: C6 Model Risk Management • Tier C

WHAT IS TESTED HERE

Why P2. Vardeez flags ORR-15 as a Very Important chapter (STRIKE FIRST, rank 20 of 55); the recall evidence alone is Tier C (C6, map #32, 3 of 16 sources).
Vardeez: "LO 54.d" (consolidated volume pp.86 to 87). He lists conceptual soundness (assumptions, data relevance, sensitivity analysis, stress testing, qualitative judgments), ongoing monitoring (process verification, benchmarking), outcomes analysis (precision, parallel outcomes analysis, back-testing, early-warning signals) and vendor products.

Reported exam shapes

- **S3** The independence requirement for validation, with effective challenge (incentives, competence, influence).

What the questions look like: name the three core elements; place an activity (benchmarking, back-testing, process verification, sensitivity analysis) in the right element; spot the statement that breaks independence; diagnose which ingredient of effective challenge is missing; GARP's practice-exam item on improving a deficient validation process.

See also: workbook C6.2 also tags this LO; it is worked under ORR-15 b.

1. What validation is for

Model validation is "the set of processes and activities intended to verify that models are performing as expected, in line with their design objectives and business uses." It identifies model errors, corrective actions and appropriate use; assesses reliability; reveals deterioration over time; and sets thresholds for acceptable error from the distribution of outcomes around predictions. If outcomes fall consistently outside the acceptable range, the model should be redeveloped.

- **Scope:** all components (input, processing, reporting), in-house and vendor models alike; rigor commensurate with the bank's model use, the complexity and materiality of its models, and its size.
- **Before first use:** range and rigor in line with the potential risk. Significant deficiencies: do not allow use, or allow it only under very tight constraints; too severe to fix within the model's framework: **reject**. If validation cannot be completed before use (data paucity), document it, tell users and senior management, and apply compensating controls.
- **After first use:** validation continues on an ongoing basis. It is an important check in **benign periods**, when risk estimates turn optimistic and data do not reflect stress. Periodic review **at least annually**; material changes validated; a full validation at some fixed interval is good practice.

2. Independence and effective challenge (shape S3)

"Validation involves a degree of independence from model development and use. Generally, validation should be done by people who are not responsible for development or use and do not have a stake in whether a model is determined to be valid."

- **Independence is not an end in itself;** it aligns incentives with the goals of validation. Separate reporting lines may support it, but it "should be judged by actions and outcomes".
- **Developers and users may do some validation work,** as a practical matter, but it must be critically reviewed by an independent party who conducts additional activities.
- **Quality of the process** is judged by the extent and clarity of documentation, the issues identified by objective parties, and the actions management takes.

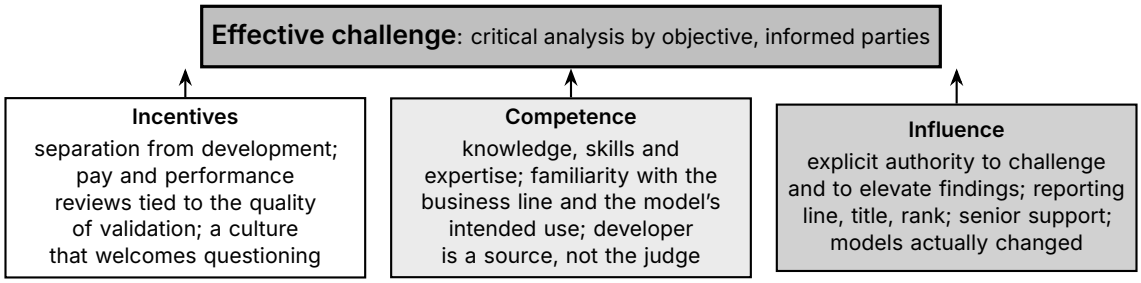


Figure 1. The three ingredients of effective challenge for validators (white, light grey, mid grey boxes), with the evidence GARP looks for under each. Missing any one makes the challenge ineffective: influence is demonstrated by "a pattern of actual instances in which models... have been appropriately changed as a result of validation".

3. The three core elements

"An effective validation framework should include three core elements" (Figure 2):

1. **Evaluation of conceptual soundness, including developmental evidence.** The quality of design and construction: documentation and empirical evidence for methods and variables, judgment consistent with published research and industry practice, comparison with alternative theories, key assumptions and variables, and relevance of data (especially external data or new products). Reviewed before use and whenever there is a material change. Tools: **sensitivity analysis** (small input changes; unexpectedly large output changes signal an unstable model; varying several inputs at once reveals interactions) and **stress testing** over extreme values to find boundaries. Qualitative judgments are evaluated too.
2. **Ongoing monitoring, including process verification and benchmarking.** Confirms the model is appropriately implemented, used and performing as intended, and whether changes in products, exposures, clients or markets need adjustment, redevelopment or replacement. **Monitoring begins when the model is first implemented in production. Process verification**: inputs accurate and complete; code under quality and change control; systems integration; user-developed applications such as spreadsheets "particularly prone to model risk"; reports accurate and informative. Also: repeat development tests, **analyse overrides** (a high override rate, or overrides that consistently improve performance, signal that the model needs revision). **Benchmarking**: compare inputs and outputs with alternative internal or external data or models. A discrepancy triggers investigation but does not prove the model wrong (the benchmark is itself an alternative prediction); a close match is evidence, not proof.
3. **Outcomes analysis, including back-testing.** Compare model outputs with actual outcomes: accuracy, rank-ordering, with a range of quantitative tests and expert judgment. **Parallel outcomes analysis** tests original and adjusted models against realised outcomes; if the adjusted model does not outperform, more changes or a redesign are needed. **Back-testing** compares actual outcomes with forecasts over a sample period *not used in development*, at a frequency matching the forecast

horizon, using confidence intervals; in-sample fit and holdout samples are not substitutes. VaR example: count exceptions, but also check clustering and other percentiles.

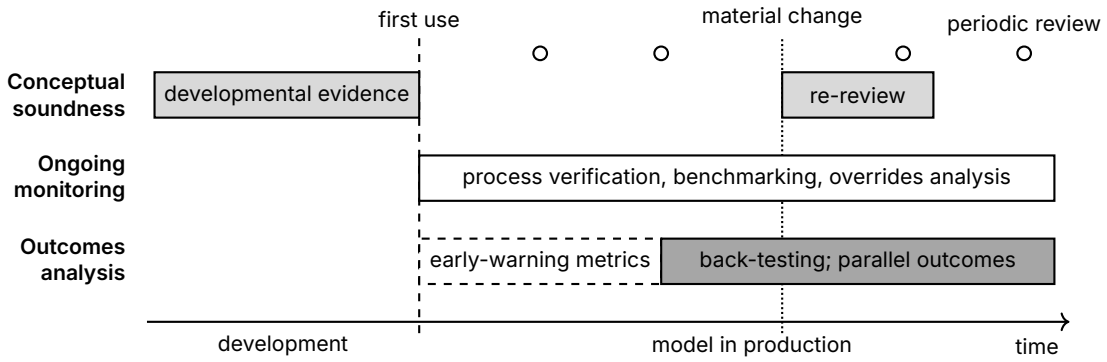


Figure 2. When each core element is active. Conceptual soundness (light grey) is reviewed before first use (dashed line) and again on a material change (dotted line). Ongoing monitoring (white bar) starts at first use. Outcomes analysis begins with early-warning metrics (dashed box) while back-testing data accumulate (dark bar). Open circles: periodic reviews, at least annually.

4. Challenges to an effective validation process

- **Back-testing is not mechanical.** It tests the model, not individual forecasts; choosing statistical tests and interpreting results is hard, so both choices must be supported and documented.
- **Long forecast horizons:** the data take years to accumulate, so supplement back-testing with evaluation over shorter periods, early-warning metrics and trend analysis. These are complements, not substitutes.
- **Limited tools:** lack of data or of price observability can rule out back-testing or sensitivity analysis; then pay more attention to limitations and keep senior management fully informed.
- **Data paucity before first use** and **benign periods** (optimistic estimates).
- **Vendor and third-party products:** modelling expertise is external and components are proprietary. Require developmental evidence, testing results and stated limitations from the vendor; the bank validates its *own use*; it relies more on **sensitivity analysis and benchmarking** where code is not accessible; documents and justifies customisation; checks the relevance of vendor data; monitors outcomes on its own data; keeps knowledge in-house and a contingency plan.
- **Independence under scarce resources** and **asymmetric user challenge** (ORR-15 c).

When outcomes fall outside predetermined thresholds: adjustment, recalibration or redevelopment, governed by conservatism and subject to independent review; material changes and redevelopment are validated before implementation.

> **Correction to the source notes.** Vardeez numbers "Vendor and other third-party products" as item 4 of the model validation process, after the three elements. GARP's framework has exactly **three** core elements (conceptual soundness, ongoing monitoring, outcomes analysis); vendor products are a separate subsection on how to apply them when modelling expertise is external. Bank Q348 uses "vendor validation" as a distractor for the three elements (Question ORR-15 d.1).

	Conceptual soundness	Ongoing monitoring	Outcomes analysis
Question asked	Is the design right?	Is it implemented, used and performing as intended?	Do outputs match what happened?
Named parts	developmental evidence	process verification; benchmarking	back-testing
Other tools	sensitivity analysis; stress testing; review of judgment	overrides analysis; repeated tests	parallel outcomes analysis; early-warning metrics
When	before use; on material change	from first use in production	ongoing, after use

Exam traps

- **Element swap.** Back-testing belongs to outcomes analysis; benchmarking and process verification to ongoing monitoring; sensitivity analysis to conceptual soundness (and is repeated in monitoring).
- **Absolute independence.** Developers may do some validation work if an independent party critically reviews it and adds work.
- **Reporting line = independence.** Independence is judged by actions and outcomes.
- **Influence polarity.** Validators need authority and stature; embedding them in development weakens incentives.
- **Benchmark gap = model error.** Not necessarily; a close match is not proof either.
- **Monitoring timing.** It starts when the model enters production, not after back-testing is complete.
- **Vendor shortcut.** The bank validates its own use; vendor assumptions are not accepted as given.
- **Internal audit validating.** Internal audit staff who validate must not assess the overall framework.

Practice questions: ORR-15 d

Question ORR-15 d.1 Bank Q348 • BT P2.T7.20.3.3

According to the FDIC, an effective model validation framework should include three core elements. What are they?

A. Implementation; ongoing error correction; and reporting

B. Evaluation of sound governance; back-testing; and vendor validation

C. Evaluation of conceptual soundness; ongoing monitoring; and outcomes analysis

D. Evaluation of simulated errors; expert screening; and policy/procedure validation

Question ORR-15 d.2 Bank Q352 • AnalystPrep Q.4298

A risk management team at a bank is implementing a comprehensive validation framework for newly developed credit risk models in preparation for regulatory review. According to best practices in model validation, which of the following validation processes would be MOST appropriate for determining whether the mathematical framework of the model is conceptually well-founded?

A. Qualitative review of model documentation, derivation of formulae, and comparison with established theoretical frameworks

B. Data quality checks focusing on the completeness, accuracy, and appropriateness of input data

C. Systems implementation testing including user acceptance testing and code verification

D. Management oversight involving senior leadership in reviewing model outputs and their application in business decisions

Question ORR-15 d.3 Bank Q351 • Schweser Module Quiz 56.2 Q2

Comparing a model's inputs and outputs to estimates from other data or models is best described as:

A. benchmarking.

B. ongoing monitoring.

C. process verification.

D. sensitivity analysis.

Question ORR-15 d.4 Bank Q350 • Schweser Module Quiz 56.2 Q1

Backtesting is most appropriately classified in which element of the validation process?

A. Evaluation of conceptual soundness

B. Ongoing monitoring

C. Outcomes analysis

D. Post-validation review

Question ORR-15 d.5 Bank Q353 • AnalystPrep Q.2600 (rebuilt)

Which of the following statements about a strong model validation process is most accurate?

A. Developmental evidence, including the documentation of assumptions, inputs and data, should be reviewed before a model is used and again whenever the model undergoes a material change.

B. Once a model has been validated and approved, its inputs and assumptions should be frozen so that results stay comparable over time.

C. To make use of their detailed knowledge, the individuals who developed a model should normally be the ones to validate it.

D. A significant variance between a model's outputs and a benchmark model's outputs proves that the model is faulty.

Question ORR-15 d.6 Bank Q346 • AnalystPrep Q.4449 (rebuilt)

Which of the following is a recognized challenge to an effective model validation process?

A. Use of vendor models, where the modeling is external and parts of it may be confidential

B. Having all models developed in-house

C. Having extensive documentation of model assumptions

D. Having validation performed independently of model developers

Question ORR-15 d.7 Bank Q345 • AnalystPrep Q.4443 (rebuilt)

Which of the following is NOT consistent with supervisory guidance on the model validation process?

A. Documentation should indicate where the model does not work effectively

B. Validation should be conducted by staff with a degree of independence from model development and use

C. Work done by model developers should be accepted as validation without critical review by an independent party

D. The depth of validation should be commensurate with the complexity and materiality of the bank's models

Question ORR-15 d.8 New • built from GARP Ch.15 • S3

The head of internal audit at a US regional bank is assessing the bank's model validation unit. The unit reports to the CRO, separately from all model developers. Its staff hold advanced quantitative degrees and have worked in the business lines whose models they review, and their bonuses are tied to the quality of their validation reports. However, over the past three years the unit has logged a long list of findings on high-tier models, none of which has led to a model being changed or its use restricted. The unit head has no authority to escalate findings to the risk committee, and the unit ranks below the model owners in the bank's hierarchy. Which conclusion should internal audit draw?

A. Effective challenge is weakest on incentives, so validators' bonuses should instead be linked to the number of models they approve each year.

B. Effective challenge is weakest on influence, so the unit needs explicit authority to elevate findings and the stature to get issues addressed, shown by models actually changed.

C. Effective challenge is weakest on competence, so the validators need further technical training before model owners can be expected to act on their findings.

D. Effective challenge is weakest on independence, so validators should be embedded in the development teams, where their findings would be acted upon faster.

Question ORR-15 d.9 Bank Q349 • GARP PE1 Q47

The board of a fast-growing US-based bank is reviewing a regulatory report that identified deficiencies in the bank's model validation process. The CRO consults Federal Reserve guidance to improve validation. Which of the following recommendations is appropriate?

A. Require internal auditors who assess the bank's model risk management framework to also validate and back-test the models

B. Begin monitoring each model's performance only after its backtest has been successfully completed

C. Ensure third-party vendor models are implemented under the assumptions initially provided by the vendor

D. Establish a continuous process of model risk management and validation rather than reviews at specific points in time

Solutions • ORR-15 d

Solution ORR-15 d.1

Answer: C

Bank Q348 • BT P2.T7.20.3.3

Step 1 – The guidance's list

"An effective validation framework should include three core elements: evaluation of conceptual soundness, including developmental evidence; ongoing monitoring, including process verification and benchmarking; outcomes analysis, including back-testing."
⇒ C, word for word.

Interpretation

Each element carries a named part: developmental evidence, process verification and benchmarking, back-testing. Distractors promote a part (back-testing) or a related topic (vendor products, governance) to element status.

Why the other options are wrong

A is incorrect. Implementation and reporting are model components and stages, not validation elements.

B is incorrect. Back-testing is part of outcomes analysis; governance is the third component of model risk management; vendor validation is a challenge handled within the three elements (see the correction box).

D is incorrect. Invented terms; none is a validation element.

LO: ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process.

• **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.5 Key Elements of Comprehensive Validation

Solution ORR-15 d.2

Answer: A

Bank Q352 • AnalystPrep Q.4298

Step 1 – Which element

"Conceptually well-founded" points to the evaluation of conceptual soundness: "assessing the quality of the model design and construction", with review of documentation and empirical evidence, and comparison to alternative theories and approaches.

Step 2 – Match the activity

A qualitative review of documentation and derivations against established theory is exactly that.
⇒ A.

Interpretation

The other three options are real validation or governance activities, but each answers a different question: are the inputs clean, is the code right, is the output used well.

Why the other options are wrong

B is incorrect. Data checks are process verification (ongoing monitoring), or data relevance within soundness; they do not test the mathematics.

C is incorrect. Code and implementation testing checks that the model is built as designed, not that the design is sound.

D is incorrect. Management review of outputs is governance and use, not an evaluation of theory.

LO: ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process.

• **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.5 Evaluation of Conceptual Soundness

Solution ORR-15 d.3 Answer: A

Bank Q351 • Schweser Module Quiz 56.2 Q2

Step 1 – GARP's definition

"Benchmarking is the comparison of a given model's inputs and outputs to estimates from alternative internal or external data or models."
⇒ A.

Interpretation

Benchmarking sits inside ongoing monitoring and can also be used in development. Discrepancies trigger investigation but do not by themselves show the model is wrong, since the benchmark is itself an alternative prediction; a close match should not give "a false degree of comfort".

Why the other options are wrong

B is incorrect. Ongoing monitoring is the umbrella element; benchmarking is one of its named parts.
C is incorrect. Process verification checks that components work as designed: data inputs, code, systems, reports.
D is incorrect. Sensitivity analysis varies inputs and parameters to see how outputs respond; it compares the model with itself, not with alternatives.

LO: ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process.
• **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.5 Ongoing Monitoring; SchweserNotes 2026 Book 3, Reading 56, LO 56.d

Solution ORR-15 d.4 Answer: C

Bank Q350 • Schweser Module Quiz 56.2 Q1

Step 1 – GARP's classification

"Back-testing is one form of outcomes analysis; specifically, it involves the comparison of actual outcomes with model forecasts during a sample time period not used in model development."
⇒ C.

Interpretation

Back-testing is defined by realised outcomes, which is what outcomes analysis compares against. Its hard part is interpretation: it tests the model, not individual forecasts, and long-horizon models need early-warning metrics while data accumulate.

Why the other options are wrong

A is incorrect. Conceptual soundness reviews design, assumptions and developmental evidence; no realised outcomes are involved.
B is incorrect. Ongoing monitoring covers process verification and benchmarking.
D is incorrect. "Post-validation review" is not one of the three elements.

LO: ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process.
• **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.5 Outcomes Analysis

Solution ORR-15 d.5 Answer: A

Bank Q353 • AnalystPrep Q.2600

Step 1 – Developmental evidence

"Developmental evidence should be reviewed before a model goes into use and also as part of the ongoing validation process, in particular whenever there is a material change in the model."
⇒ A is GARP's sentence.

Step 2 – Test the others

Ongoing monitoring exists because products, exposures and markets change (B false). Validation should be done by people not responsible for development (C false). A benchmark gap triggers investigation but "differences do not necessarily indicate that the model is in error" (D false).

Interpretation

The bank's original key was corrected in the rebuild; A is the only statement consistent with the guidance.

Why the other options are wrong

B is incorrect. Reverses the purpose of ongoing monitoring, which checks whether changes call for adjustment, redevelopment or replacement.

C is incorrect. Developers are an important source of information but not an objective or sole basis for judging quality.

D is incorrect. The benchmark is itself an alternative prediction; the gap may come from different data or methods.

LO: ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process.

• **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.5 (Evaluation of Conceptual Soundness; Ongoing Monitoring)

Solution ORR-15 d.6 Answer: A

Bank Q346 • AnalystPrep Q.4449

Step 1 – GARP's challenge

Vendor and third-party products "pose unique challenges for validation... because the modeling expertise is external to the user and because some components are considered proprietary."

⇒ A.

Step 2 – How the bank responds

Require developmental evidence and testing results from the vendor; validate its own use; rely more on sensitivity analysis and benchmarking; monitor outcomes on its own data.

Interpretation

The other options describe conditions that make validation easier: full access to code, rich documentation, independence.

Why the other options are wrong

B is incorrect. In-house development gives validators full access to code and data.

C is incorrect. Documentation is what validators review; it helps validation.

D is incorrect. Independence is a requirement of good validation, not an obstacle.

LO: ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process.

• **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.5 Validation of Vendor and Other Third-Party Products

Solution ORR-15 d.7 Answer: C

Bank Q345 • AnalystPrep Q.4443

Step 1 – The independence rule and its exception

Validation is generally done by people with no stake in the result. "As a practical matter, some validation work may be most effectively done by model developers and users; it is essential, however, that such validation work be subject to critical review by an independent party, who should conduct additional activities."

⇒ Developer work accepted *without* independent review breaks the rule.

Interpretation

This is the S3 shape in its plainest form: independence is required, but the guidance does not ban developer work; it requires an independent critical review on top of it.

Why the other options are wrong

A is incorrect. Consistent: documentation and testing should convey model limitations.

B is incorrect. Consistent: "validation involves a degree of independence from model development and use".

D is incorrect. Consistent: rigor should be commensurate with model use, complexity and materiality.

LO: ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process.

• **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.5 Model Validation

Solution ORR-15 d.8 Answer: B

New • built from GARP Ch.15 • S3

Step 1 – The three ingredients

Validation "should be performed by staff with appropriate incentives, competence, and influence."

Step 2 – Test each against the facts

Incentives: the unit reports separately from developers and is paid on the quality of its work, so present. Competence: advanced degrees and business-line experience, so present. Influence: no authority to escalate, rank below the owners, and no model ever changed, so missing.

$\Rightarrow$ Influence is the gap.

Step 3 – What influence requires

Explicit authority "to challenge developers and users and to elevate their findings"; reporting to someone with "sufficient influence or stature"; reflected in "reporting lines, title, rank, or designated responsibilities"; and "demonstrated by a pattern of actual instances in which models... have been appropriately changed as a result of validation".

Interpretation

The evidence of failure is the outcome: findings with no consequences. GARP judges independence the same way, "by actions and outcomes". Evaluating the objectivity, competence and organisational standing of validators is exactly internal audit's task.

Why the other options are wrong

A is incorrect. Polarity flip on incentives: compensation should be tied to the quality of validations and the degree of critical, unbiased review; paying for approvals rewards bias.

C is incorrect. Competence is already present; more training does not give the unit authority.

D is incorrect. Polarity flip: incentives for challenge are stronger with greater separation from development; embedding validators removes independence.

LO: ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process.

• **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.3 and 15.5 Model Validation; 15.6 Internal Audit

Solution ORR-15 d.9 Answer: D

Bank Q349 • GARP PE1 Q47

Step 1 – Continuous validation

"Validation activities should continue on an ongoing basis after a model goes into use, to track known model limitations and to identify any new ones." ORR-16 b adds that model risk man-

agement should be "a continuous effort rather than a point-in-time exercise".
⇒ D.

Step 2 – Check the other recommendations

Internal audit staff who perform validation "should not be involved in the assessment of the overall model risk management framework" (A). Monitoring "begins when a model is first implemented in production systems" (B). The bank must validate its own use of vendor models; vendor assumptions and data must be checked for relevance and models may need customisation (C).

Interpretation

Each wrong option breaks a different rule: independence (A), timing (B), vendor scrutiny (C). That is GARP's typical construction for this LO.

Why the other options are wrong

A is incorrect. Internal audit evaluating a framework whose validations it performed would be reviewing its own work.

B is incorrect. Monitoring starts at implementation; waiting for a successful back-test leaves the model unmonitored during its early use.

C is incorrect. The vendor's initial assumptions may not fit the bank's portfolio; the bank validates its own use.

LO: ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process. ORR-16 b: Describe the role of the model risk management function and explain best practices in the model risk management and validation processes. • **Reference:** FDIC FIL-22-2017 (GARP ORR Ch.15), 15.5 and 15.6 Internal Audit; GARP ORR Ch.16, Model Risk Management

ORR-16 • Case Study: Model Risk and Model Validation • Vardeez: VERY IMPORTANT

ORR-16 a

P2 CONCEPT

Define a model and describe different ways that financial institutions can become exposed to model risk.

Workbook: *none*

WHAT IS TESTED HERE

Why P2. Vardeez flags ORR-16 as a Very Important chapter (STRIKE FIRST, rank 21 of 55 in his consolidated volume). The recall evidence alone is Tier C (C6, map #32, 3 of 16 sources).
Vardeez: his notes label this LO "LO 55.a" (consolidated volume p.88). He gives the model definition and a two-row table of the types of model risk, execution risk and conceptual errors, summed up in his Figure 55.1: "Execution risk is about the build; conceptual error is about the idea."

Reported exam shapes: none reported for this LO; the questions are built from the LO wording and Vardeez's focus.

What the questions look like: the SR 11-7 definition and what does or does not count as a model; classifying a failure as execution or conceptual; why model risk is so often underestimated.

See also: the FDIC definition, the three components of a model and the two reasons model risk arises are in ORR-15 a. Workbook C6.1 also tags this LO; it is worked under ORR-15 a.

1. Definition and history

Recap from ORR-15 a. SR 11-7 (adopted by the FDIC in GARP Chapter 15) defines a model as "a quantitative method, system, or approach that applies statistical, economic, financial, or mathematical theories, techniques, and assumptions to process input data into quantitative estimates", and extends it to approaches with partly or wholly qualitative or expert-judgment inputs, provided the output is quantitative. Chapter 16 adds the history and the current consensus:

- **Rising use, rising risk.** Model use grew steadily over the past 30 to 40 years. VaR and other techniques in the 1980s and 1990s made models a mainstream risk tool, and Basel II embraced them for regulatory capital. More models meant more model risk, which drove a more professional management of it; over the past decade regulators have raised their expectations.
- **From narrow to broad.** In the early days a model meant a forecasting tool built on complex statistical techniques. As model risk management matured, the definition widened to non-quantitative (so-called qualitative) models. SR 11-7's definition is "purposefully broad" and is used in the United States and adapted in many jurisdictions.
- **Current consensus:** a model is "any estimation method that uses data and relies on a set of assumptions to generate an uncertain estimate/forecast". The emphasis is "more and more on the uncertain nature of the forecast rather than on the method or technique".
- **Why the definition matters:** it is "essential in establishing the right governance for model risk management". What counts as a model is what enters the inventory and gets validated.

A quick test: data, assumptions, and an uncertain estimate.

Tool	Model?	Why
Spreadsheet applying assumed volatilities and correlations to positions to estimate losses	Yes	data + assumptions → uncertain estimate
Expert-judgment scorecard that outputs a numeric rating	Yes	qualitative inputs are allowed; the output is quantitative
Spreadsheet summing desk positions into a firm-wide total	No	no assumptions, no uncertain estimate
Barclays' list of Lehman assets to acquire (ORR-16 c)	No	"there is no uncertainty around the information contained in the spreadsheet"

2. Two ways to be exposed: execution risk and conceptual errors

GARP: "There are two broad risks an institution can be exposed to due to model risk."

- **Execution risk** occurs "when a model does not do what it is intended and designed to do": coding errors, implementation errors, use of the wrong data. Such errors "often seem like trivial errors that cannot result in a material loss", yet paired with bad luck and a confluence of events that make a "perfect storm" they have caused catastrophic losses (the Barclays and NASA cases). They are **also found in tools that are not considered models**.
- **Conceptual errors** occur "when the wrong assumptions or modeling techniques are used". They are **much more difficult to identify**, because they may not be a matter of right or wrong: reasonable modelers can hold different, equally valid views on an assumption. A model can be "right" in one context and "completely wrong if the context were to change". Here the role of model risk management is **transparency**: modelers may know and even document the limitations, but users may not, so MRM makes sure assumptions are communicated so that users know when the model can be safely used and when its use should be discontinued. The CDO example: the Gaussian copula was valid and accurate in normal markets; when correlations spiked the assumption failed, yet many kept using it.

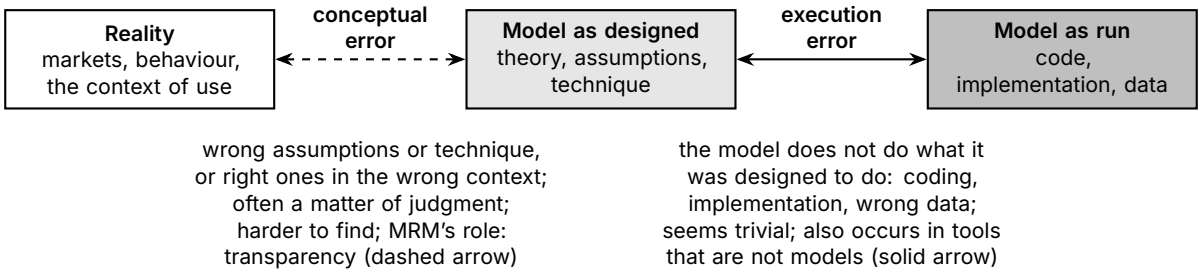


Figure 1. Two gaps, two kinds of model risk. The conceptual gap (dashed arrow) lies between the model's design and reality; the execution gap (solid arrow) lies between the design and what actually runs. Vardeez: "Execution risk is about the build; conceptual error is about the idea."

3. Linking the two chapters

Chapter 15 (FDIC) sorts model risk by *cause*: the model has fundamental errors, or a sound model is misused. Chapter 16 (GARP) sorts it by *nature*: execution or conceptual. They overlap rather than map one to one:

- Coding, implementation and data errors are FDIC errors of the first kind and GARP execution errors.
- Wrong assumptions or techniques chosen at design are FDIC errors of the first kind and GARP conceptual errors.
- A sound model whose assumptions stop holding when the context changes is what the FDIC calls inadvertent misuse ("as market conditions or customer behavior changes") and what GARP files under conceptual errors ("right" in one context, "wrong if the context were to change"). The Gaussian copula is the example of both, which is why workbook C6.1 calls it "conceptual error combined with misuse".

4. Why model risk is underestimated

- **Inherent:** model risk "has been a concern for model builders and users for as long as models have existed". Relying on the best-faith efforts of the development team is not enough; catastrophic losses can be avoided only by luck or "a mature model risk management program".
- **Tail nature:** "Most errors are benign and are either caught early enough or do not lead to material losses," which leaves institutions with **misplaced confidence**. Tail losses materialise under extreme conditions and "often involve a series of mistakes in the development, deployment, and use of models".
- **Cost looks disproportionate:** the rarity of such events makes a modern model risk function seem expensive relative to the risk, because management's horizons and perception rarely align with the reality of the risk and with the horizons of shareholders and regulators.

	Execution risk	Conceptual errors
Definition	the model does not do what it is intended and designed to do	wrong assumptions or modelling techniques are used
Sources	coding errors, implementation errors, wrong data	invalid assumptions; incorrect techniques; a valid assumption in a changed context
Right or wrong?	yes: plainly an error	often a matter of judgment; reasonable modelers differ
How hard to find	easier; but looks trivial, so underrated	much more difficult
MRM response	replicate, test, controls; first-line QA/QC (ORR-16 b)	challenge assumptions; transparency to users
Case studies	Barclays and Lehman; NASA Mars orbiter	Gaussian copula and CDO pricing

Exam traps

- **Narrow definition.** A model need not use complex statistics; qualitative inputs are allowed if the output is quantitative.
- **"Precise output."** The output of a model is an uncertain estimate; that is the consensus test.
- **Type swap.** Wrong data and coding slips are execution; invalid assumptions and wrong techniques are conceptual.
- **Ease polarity.** Conceptual errors are *harder* to identify than execution errors.
- **"Trivial errors cannot hurt."** Execution errors plus bad luck have produced catastrophic losses.
- **Track record as proof.** Most errors are benign, so a quiet record breeds misplaced confidence; model risk is a tail risk.

- **"Right everywhere."** A model valid in normal markets can be completely wrong when the context changes.

Practice questions: ORR-16 a

Question ORR-16 a.1

Bank Q354 • AP Mock 3 Q71 (rebuilt)

Under the U.S. Federal Reserve guidance SR 11-7, which of the following best defines a model?

A. Any forecasting tool that relies on complex statistical techniques

B. A quantitative method, system, or approach that applies statistical, economic, financial, or mathematical theories, techniques, and assumptions to process input data into quantitative estimates

C. Any estimation approach whose output is a qualitative judgment from experts

D. A computer program that reports data without applying assumptions or theory

Question ORR-16 a.2

Bank Q357 • Schweser Module Quiz 57.1 Q1

Which one of the following items is least likely associated with a model?

A. Qualitative inputs.

B. Mathematical theories.

C. Precise output.

D. Assumptions.

Question ORR-16 a.3

Bank Q355 • AnalystPrep Q.4444 (rebuilt)

The current industry consensus defines a model as any estimation method that uses data and relies on assumptions to generate an uncertain estimate or forecast. Which of the following spreadsheets is most clearly a model?

A. A spreadsheet that sums the trading positions reported by each desk into a firmwide total for reporting

B. A spreadsheet that applies assumed volatilities and correlations to portfolio positions to estimate potential losses under different what-if scenarios each day

C. A spreadsheet that stores historical prices for later retrieval without any calculation

D. A spreadsheet that converts reporting currencies at the published spot rate

Question ORR-16 a.4 Bank Q356 • AnalystPrep Q.5149 (rebuilt)

A newly hired risk manager is asked to explain how a financial institution can become exposed to model risk. Which of the following is an example of exposure arising from a conceptual error rather than an execution error?

A. A coding mistake in the model's pricing routine

B. Use of the wrong input data file when the model is run

C. Relying on a correlation assumption estimated in normal markets that no longer holds when markets become volatile

D. An implementation error when the model is moved to a new system

Question ORR-16 a.5 Bank Q358 • BT P2.T7.605.3 (rebuilt)

Which of the following statements about model risk is most accurate?

A. Model risk is inherent to modeling and is often underestimated because its losses are rare and concentrated in the tail

B. Conceptual errors are easier to identify than execution errors because they are always a matter of right or wrong

C. Execution errors are trivial and cannot by themselves contribute to material losses

D. A model that performs well in normal conditions will perform adequately in all economic environments

Question ORR-16 a.6 New • built from GARP Ch.16

At a budget meeting of a mid-sized bank, the CFO proposes halving the model risk management (MRM) budget. Her argument: over the past five years MRM has found many model errors, but none of them would have caused a material loss, so the bank's model risk is evidently small. The CRO is asked to respond. Which response is most consistent with the GARP case study on model risk?

A. Agree: a five-year record in which every error found was benign is good evidence that the bank's model risk is low, so the MRM budget can follow the loss record.

B. Agree in part: keep challenging conceptual assumptions but stop checking for coding and data errors, since execution errors are trivial and cannot cause a material loss.

C. Disagree only for regulatory capital models: other models cannot produce losses large enough to concern shareholders or regulators, so their review can be cut.

D. Disagree: model risk is a tail risk; most errors are benign or caught early, while large losses come rarely, under extreme conditions and often from a series of mistakes.

Solutions • ORR-16 a

Solution ORR-16 a.1

Answer: B

Bank Q354 • AP Mock 3 Q71

Step 1 – The SR 11-7 wording

"The term model refers to a quantitative method, system, or approach that applies statistical, economic, financial, or mathematical theories, techniques, and assumptions to process input data into quantitative estimates."
⇒ B, word for word.

Step 2 – The three conditions in it

Theory or assumptions are applied; input data are processed; the output is a quantitative estimate. Inputs may be qualitative.

Interpretation

GARP stresses that the definition is "purposefully broad". It does not require statistical complexity, and it admits expert-judgment inputs; it does require a quantitative output.

Why the other options are wrong

A is incorrect. The old, narrow view of a model as a complex statistical forecasting tool, which the definition deliberately widened.
C is incorrect. Qualitative *inputs* are allowed, but the *output* must be quantitative.
D is incorrect. A program that only reports data applies no theory or assumptions and produces no estimate.

LO: ORR-16 a: Define a model and describe different ways that financial institutions can become exposed to model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, Definition and History (1. Model Definition); SchweserNotes 2026 Book 3, Reading 57, LO 57.a

Solution ORR-16 a.2

Answer: C

Bank Q357 • Schweser Module Quiz 57.1 Q1

Step 1 – The consensus definition

A model is "any estimation method that uses data and relies on a set of assumptions to generate an uncertain estimate/forecast"; the emphasis is on "the uncertain nature of the forecast".
⇒ Model output is uncertain, never precise.

Step 2 – Check the others

Qualitative inputs (allowed), mathematical theories (in the SR 11-7 wording) and assumptions (in both definitions) are all associated with models.

Interpretation

Schweser: the output "is not definitive, but rather subject to estimation error". Treating model output as precise is itself a route to model risk; ORR-15 c recommends reporting a range of outputs to avoid spurious precision.

Why the other options are wrong

A is incorrect. The definition covers inputs that are partly or wholly qualitative or based on expert judgment.
B is incorrect. Models apply statistical, economic, financial or mathematical theories.
D is incorrect. Every model relies on a set of assumptions; they are where conceptual errors live.

LO: ORR-16 a: Define a model and describe different ways that financial institutions can become exposed to model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, 1. Model Definition; SchweserNotes 2026 Book 3,

Reading 57, LO 57.a

Solution ORR-16 a.3 Answer: B

Bank Q355 • AnalystPrep Q.4444

Step 1 – The three tests

Data, a set of assumptions, and an uncertain estimate or forecast as output.

Step 2 – Apply them

B applies assumed volatilities and correlations (assumptions) to positions (data) to estimate potential losses (an uncertain estimate). A sums, C stores, D converts at a published rate: no assumptions, no uncertain estimate.

$\Rightarrow$ Only B is a model.

Interpretation

A spreadsheet can be a model; the format is irrelevant. GARP's Barclays case makes the reverse point: a spreadsheet listing known assets is not a model, though errors in it can still be costly (ORR-16 c).

Why the other options are wrong

A is incorrect. Aggregating reported figures applies no assumptions and estimates nothing.

C is incorrect. Storage performs no estimation.

D is incorrect. A conversion at a published rate is a deterministic calculation, not an assumption-based estimate.

LO: ORR-16 a: Define a model and describe different ways that financial institutions can become exposed to model risk.

• **Reference:** GARP, Operational Risk and Resilience, Ch.16, 1. Model Definition; Barclays' Acquisition of Lehman Brothers

Solution ORR-16 a.4 Answer: C

Bank Q356 • AnalystPrep Q.5149

Step 1 – The two types

Execution risk: the model does not do what it was designed to do (coding errors, implementation errors, wrong data). Conceptual errors: the wrong assumptions or techniques are used.

Step 2 – Classify

A coding, B data and D implementation are execution errors. C is an assumption that held in one context and fails in another.

$\Rightarrow$ C is the conceptual error.

Interpretation

C is the Gaussian copula pattern in miniature: a correlation assumption that was valid in normal markets became invalid when correlations rose under stress. GARP's remedy is transparency about when the model can be safely used and when its use should be discontinued.

Why the other options are wrong

A is incorrect. A coding mistake is execution risk.

B is incorrect. Running the model on the wrong data is execution risk.

D is incorrect. An implementation error is execution risk; the concept may be perfectly sound.

LO: ORR-16 a: Define a model and describe different ways that financial institutions can become exposed to model risk.

• **Reference:** GARP, Operational Risk and Resilience, Ch.16, 2. Model Risks; SchweserNotes 2026 Book 3, Reading 57, LO 57.a

Solution ORR-16 a.5 Answer: A

Bank Q358 • BT P2.T7.605.3

Step 1 – GARP's statement

"The problem with model risk is that it is often underestimated due to the tail nature of the risk. Most errors are benign and are either caught early enough or do not lead to material losses."
⇒ A.

Step 2 – Check the others

Conceptual errors are *more* difficult to identify; trivial-seeming execution errors have caused catastrophic losses; a model can be right in one context and wrong in another.

Interpretation

Each distractor reverses one sentence of Section 2 of the chapter: ease of identification (B), materiality of execution errors (C), context dependence (D).

Why the other options are wrong

B is incorrect. Polarity flip: conceptual errors are much more difficult to identify, precisely because they may not be a matter of right or wrong.
C is incorrect. The Barclays and NASA cases show trivial-seeming execution errors, with bad luck, causing catastrophic losses.
D is incorrect. The Gaussian copula was accurate in normal markets and failed when correlations spiked.

LO: ORR-16 a: Define a model and describe different ways that financial institutions can become exposed to model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, Definition and History; 2. Model Risks

Solution ORR-16 a.6 Answer: D

New • built from GARP Ch.16

Step 1 – Model risk is a tail risk

"Most errors are benign and are either caught early enough or do not lead to material losses. This often leaves institutions with misplaced confidence in their ability to manage the risk."
⇒ Five benign years are what a tail risk looks like most of the time.

Step 2 – How the large losses arrive

"The tail risks typically materialize under extreme conditions and often involve a series of mistakes in the development, deployment, and use of models."

Step 3 – Why the budget looks too big

The rarity of such events "makes the cost of modern model risk functions seem disproportionate relative to the risk", because management's horizons rarely align with the risk or with those of shareholders and regulators.
⇒ The CRO should disagree, for the reason in D.

Interpretation

The CFO's argument is the misplaced confidence GARP describes. The NASA case adds that it is impossible to tell in advance which benign-looking mistakes will turn out to be catastrophic (ORR-16 c).

Why the other options are wrong

A is incorrect. Treats the absence of tail losses over a short window as evidence that the tail is thin: exactly the misplaced confidence GARP warns about.
B is incorrect. Execution errors "often seem like trivial errors that cannot result in a material loss", yet with bad luck they have caused catastrophic ones (Barclays, NASA).
C is incorrect. Losses are not confined to regulatory models; tiering (ORR-16 b) also weighs ma-

teriality, complexity and client-facing use, and lower tiers are reviewed less often, not dropped.

LO: ORR-16 a: Define a model and describe different ways that financial institutions can become exposed to model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, Definition and History; 2. Model Risks; NASA Mars Orbiter

ORR-16 • Case Study: Model Risk and Model Validation • Vardeez: VERY IMPORTANT

ORR-16 b

P2 CONCEPT

Describe the role of the model risk management function and explain best practices in the model risk management and validation processes.

Workbook: C6 Model Risk Management • Tier C

WHAT IS TESTED HERE

Why P2. Vardeez flags ORR-16 as a Very Important chapter (STRIKE FIRST, rank 21 of 55); the recall evidence alone is Tier C (C6, map #32, 3 of 16 sources).

Vardeez: "LO 55.b" (consolidated volume p.88). The MRM team is independent and sets standards for documentation, data quality and model control; it assigns risk tiers, ensures regular validation ("an ongoing process, not just periodic reviews") and monitors models as conditions change.

Reported exam shapes

- **S3** The independence requirement for validation, with effective challenge (incentives, competence, influence).

What the questions look like: where MRM sits (second line) and what it does; tiering criteria and validation frequency; the first line's ownership of model risk; continuous versus point-in-time model risk management; MRM's role with conceptual errors.

See also: effective challenge and validator independence are taught in ORR-15 d; workbook C6.2 also tags this LO and is worked under ORR-15 b.

1. The model risk management function

- **Where it sits:** "in the second line of defense", staffed with "experts who are independent of model development".
- **Scope:** all aspects of a model throughout its lifecycle. It sets **model documentation standards, data quality expectations and versioning criteria**.
- **Most visible job:** "reviewing and challenging models to minimize the risks" of execution and conceptual errors (ORR-16 a). This is effective challenge (ORR-15 d), and it needs the same three ingredients: **incentives** (independence from development), **competence** (experts) and **influence** (authority and stature to get issues fixed).

2. Tiering: matching effort to risk

To balance the cost and burden of validation against the need to address model risk, MRM assigns models to tiers "according to the risk they pose to the institution". The usual criteria:

1. **materiality of the model output** (how big a loss could an error in the forecast cause?);
2. **complexity** of the model;
3. whether its use is **client facing**;
4. whether it is used for **regulatory purposes**.

"The model tier dictates the thoroughness and the frequency of its validation."

- **Highest tiers:** detailed review, comprehensive back-testing, assessment of replicability of output, and full-scope validation **usually every 2 to 3 years**.
- **Mid tier:** full scope perhaps only **every 4 or 5 years**; **low tier** even more rarely.
- **Every model, whatever its tier, has an annual review** of the environment, the data and other important elements. If no material change is found, the last full-scope results still hold and continued use is approved.
- **Monitoring between validations:** MRM reviews monitoring reports produced by model owners (to MRM standards), at intervals that match how often the model is used: annual or quarterly for capital models, monthly for others, increasingly weekly in fast-moving areas such as fraud monitoring.

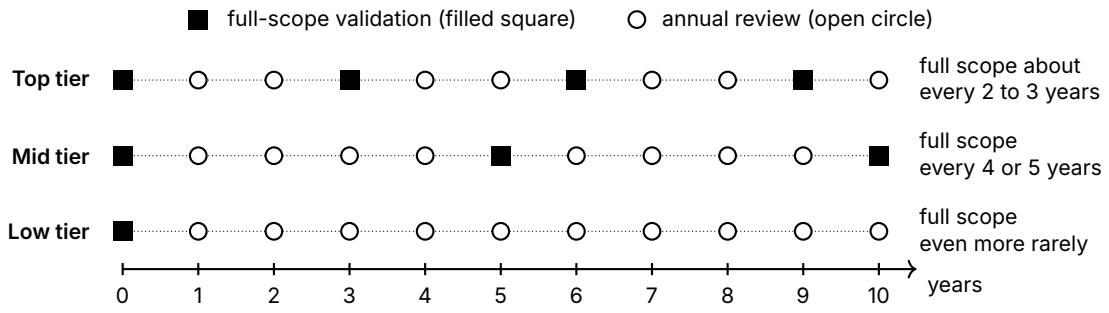


Figure 1. An illustrative validation calendar by tier. Filled squares are full-scope validations (top tier every 3 years here, within GARP's 2 to 3; mid tier every 5, within 4 or 5); open circles are the annual reviews every model receives. Monitoring reports from model owners run in between, at a frequency set by how often the model is used.

3. Continuous, not point-in-time

"Model risk management should be seen as a continuous effort rather than a point-in-time exercise revolving around validations and reviews. This is still one of the biggest challenges faced by many institutions."

- **Why periodic validation persisted:** it is predictable, so staffing needs are predictable, and it lets banks run much smaller validation teams that move on to the next scheduled task. Early on, most material models were regulatory models with very long development and deployment cycles (the US Basel II four-quarter parallel run; stress-testing models used once a year).
- **Why it must change:** reliance on models is growing, the environments they run in are increasingly dynamic, and the need for more frequent recalibration is rising.

4. Three lines of defense in model risk

- **The danger:** large, competent validation teams "can result in modeling teams becoming more complacent".
- **Second line (MRM):** "an independent backstop to 'catch' errors that the first line might have missed". Its existence "should not result in an abdication by the first line of its own responsibilities". It independently assesses the risk and the first line's risk management practices.
- **First line (model developers and owners):** they "generate the risk", "own the risk" and should mitigate it as far as possible. At more mature institutions they form **QA/QC teams**, the first line's risk team, which play "a critical role in mitigating model risk, particularly execution risk".

5. Best practice in the challenge itself

From the copula case (ORR-16 c): MRM "always needs to replicate the model to ensure that no coding errors exist", but its more critical responsibility is "challenging the assumptions upon which the model relies and ensuring that users understand its limitations". "The most important skill required for the MRM function to be successful with this challenge is **effective communication**": most users are not quantitative and can deflect responsibility by saying they cannot understand the model, so MRM explains the limitations in non-technical terms.

Party	Role in model risk (GARP Ch.16)
First line: developers, owners	generate and own the risk; mitigate it; QA/QC teams target execution risk
Second line: MRM	independent of development; sets documentation, data and versioning standards; tiers models; validates and reviews; monitors owners' reports; challenges assumptions; communicates limitations
Tier	set by materiality, complexity, client-facing use, regulatory use; dictates depth and frequency of validation
Every model	annual review; monitoring reports at a frequency matching use

Exam traps

- **Ownership transfer.** The first line owns model risk; MRM is a backstop, not a replacement.
- **QA/QC in the wrong line.** QA/QC teams are first-line; they mainly address execution risk.
- **Uniform validation.** Depth and frequency follow the tier; every model gets an annual review, not an annual full-scope validation.
- **Number swaps.** Top tier about every 2 to 3 years; mid tier 4 or 5; low tier more rarely.
- **Continuous = more frequent full validations.** Continuous means ongoing monitoring and review between validations.
- **Replication is the main job.** Replication is necessary; challenging assumptions and communicating limitations is more critical.
- **Incentive polarity.** MRM's independence from development is what makes the challenge credible.

Practice questions: ORR-16 b

Question ORR-16 b.1

Bank Q362 • AnalystPrep Q.5150

A junior analyst at a bank wishes to understand more about the role of the model risk management function and best practices in model risk management. What is the role of the model risk management (MRM) function in financial institutions, and how is the frequency of model validation determined?

A. MRM function validates models every year, regardless of their tier, to minimize risks.

B. MRM function specifies the frequency of model validation, but the tier of the model is not taken into consideration.

C. MRM function is responsible for reviewing and challenging models to minimize risks, and models are assigned to different tiers based on their risk level.

D. MRM function monitors the performance of models through reports produced by model owners, but they do not conduct validations.

Question ORR-16 b.2

Bank Q363 • AnalystPrep Q.5151

What is the role of the first line of defense in the three lines of defense model in model risk management, and how do first-line QA/QC teams help mitigate model risk?

A. The first line of defense is responsible for independently assessing the risk and risk management practices of the second line, while the first-line QA/QC teams monitor the performance of models.

B. The first line of defense abdicates its own responsibilities to the second line, while the first-line QA/QC teams ensure models are validated at the appropriate frequency.

C. The first line of defense generates the risk to which the organization is exposed and owns the risk. The first-line QA/QC teams play a pivotal role in mitigating model risk, especially execution risk.

D. The first line of defense is responsible for validating models, while the first-line QA/QC teams conduct comprehensive backtesting.

Question ORR-16 b.3

Bank Q364 • AnalystPrep Q.5297

What is the primary role of model risk management in dealing with conceptual errors?

A. To identify and correct all conceptual errors.

B. To ensure transparency and clear communication of assumptions to users.

C. To make models always valid in any context.

D. To prevent market conditions from deteriorating.

Question ORR-16 b.4 Bank Q361 • AnalystPrep Q.4446 (rebuilt)

A bank staffs its model risk management (MRM) function with experts who are independent of model development. Which of the following best describes the purpose of this independence?

A. It lets the first line transfer ownership of model risk to the second line

B. It provides an independent backstop that can catch errors the first line may have missed

C. It removes the need for first-line quality assurance and quality control teams

D. It guarantees that conceptual errors in all models are eliminated

Question ORR-16 b.5 Bank Q360 • AnalystPrep Q.4306 (rebuilt)

According to the chapter on model risk and model validation, which of the following is described as one of the biggest challenges many institutions face in model risk management?

A. Moving from periodic, point-in-time validations to a continuous model risk management approach

B. Persuading regulators to accept tiering of models by risk

C. Reviewing every model with the same depth and frequency regardless of tier

D. Locating validators who are independent of model development

Question ORR-16 b.6 New • built from GARP Ch.16 • S3

The newly appointed head of model risk management at a US bank that runs several hundred models presents a reorganisation plan to the board risk committee. The second-line validation team is to be doubled in size. Which element of the plan is consistent with the best practices described in the GARP case study?

A. Embed each validator within a model development team, so that validators gain the detailed model knowledge they need to challenge models effectively.

B. Let modeling teams scale back their own quality assurance, because the enlarged second-line team now exists to catch the errors the first line misses.

C. Validate every model in full each year, whatever its tier, so that model risk management becomes a continuous rather than a point-in-time exercise.

D. Tier models by materiality, complexity, client-facing use and regulatory use, with full-scope validation of top-tier models about every 2 to 3 years and an annual review of every model.

Solutions • ORR-16 b

Solution ORR-16 b.1

Answer: C

Bank Q362 • AnalystPrep Q.5150

Step 1 – The role

One of MRM's "more visible and important responsibilities is that of reviewing and challenging models to minimize the risks".

Step 2 – How frequency is set

MRM assigns models to tiers "according to the risk they pose to the institution", and "the model tier dictates the thoroughness and the frequency of its validation".

⇒ C.

Interpretation

Tiering is how MRM balances the cost and burden of validation against the risk: top-tier models get full-scope validation about every 2 to 3 years, mid-tier every 4 or 5, low-tier more rarely, and all get an annual review.

Why the other options are wrong

A is incorrect. Every model gets an annual *review*; full validation frequency depends on the tier.

B is incorrect. The tier is precisely what sets validation frequency.

D is incorrect. MRM does review owners' monitoring reports, but it also performs validations and reviews.

LO: ORR-16 b: Describe the role of the model risk management function and explain best practices in the model risk management and validation processes. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, 3. Model Risk Management; SchweserNotes 2026 Book 3, Reading 57, LO 57.b

Solution ORR-16 b.2

Answer: C

Bank Q363 • AnalystPrep Q.5151

Step 1 – The first line

"Model developers and model owners are, in the context of model risk, the first line and thus the actors that generate the risk to which the institution is exposed. As such, they own the risk."

Step 2 – QA/QC teams

At mature institutions the modelling teams form QA/QC teams, "the first line's risk team", which "play a critical role in mitigating model risk, particularly execution risk".

⇒ C.

Interpretation

QA/QC fits execution risk because coding, data and implementation checks are best done close to the build; conceptual challenge needs the independent second line.

Why the other options are wrong

A is incorrect. Reverses the roles: the second line independently assesses the first line's risk and practices.

B is incorrect. GARP says the second line's existence "should not result in an abdication by the first line of its own responsibilities".

D is incorrect. Independent validation and comprehensive back-testing of top-tier models are second-line work.

LO: ORR-16 b: Describe the role of the model risk management function and explain best practices in the model risk management and validation processes. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, 3. Model Risk

Management (three lines of defense)

Solution ORR-16 b.3 Answer: B

Bank Q364 • AnalystPrep Q.5297

Step 1 – Why conceptual errors are different

They "may not be a matter of right or wrong"; reasonable modelers can hold different, equally valid views.

Step 2 – MRM's role

"In those situations, the role of model risk management is to ensure transparency": communicate assumptions and limitations so users know when the model can be safely used and when its use should be discontinued.

$\Rightarrow$ B.

Interpretation

The copula case states the same role in practice: shed light into the black box, challenge assumptions, and make sure non-quantitative users understand the limitations. Effective communication is the key skill.

Why the other options are wrong

A is incorrect. Absolute claim: conceptual errors are hard to identify and are often judgment calls; "all" cannot be corrected.

C is incorrect. No model is valid in every context; the point is to know where it stops being valid.

D is incorrect. Market conditions are outside MRM's control.

LO: ORR-16 b: Describe the role of the model risk management function and explain best practices in the model risk management and validation processes. ORR-16 a: Define a model and describe different ways that financial institutions can become exposed to model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, 2. Model Risks; Gaussian Copula and CDO Pricing

Solution ORR-16 b.4 Answer: B

Bank Q361 • AnalystPrep Q.4446

Step 1 – What the second line is for

"The second line exists as an independent backstop to 'catch' errors that the first line might have missed."

$\Rightarrow$ B.

Step 2 – What it does not do

It does not take over ownership (the first line owns the risk), replace first-line QA/QC, or guarantee error-free models.

Interpretation

This is the S3 shape seen from Chapter 16. Independence supplies the incentive for effective challenge (ORR-15 d: incentives are stronger with greater separation from development); competence comes from MRM's experts; influence from its authority to require changes.

Why the other options are wrong

A is incorrect. The first line "own[s] the risk"; the backstop must not lead to abdication.

C is incorrect. First-line QA/QC teams play a critical role, particularly for execution risk.

D is incorrect. Absolute claim: model risk cannot be eliminated, and conceptual errors are often judgment calls.

LO: ORR-16 b: Describe the role of the model risk management function and explain best practices in the model risk

management and validation processes. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, 3. Model Risk Management; Ch.15, 15.3 (effective challenge)

Solution ORR-16 b.5 — Answer: A

Bank Q360 • AnalystPrep Q.4306

Step 1 – GARP's sentence

"Model risk management should be seen as a continuous effort rather than a point-in-time exercise revolving around validations and reviews. This is still one of the biggest challenges faced by many institutions."
⇒ A.

Step 2 – Why it is hard

Periodic validation is predictable, makes staffing predictable and allows small teams; it suited long-cycle regulatory models. Growing reliance on models and dynamic environments now require the move.

Interpretation

The GARP practice exam tests the same point from the recommendation side (Question ORR-15 d.9: "a continuous process... rather than reviews at specific points in time").

Why the other options are wrong

B is incorrect. Tiering is standard practice; regulator acceptance is not cited as a challenge.
C is incorrect. Uniform depth and frequency is the opposite of best practice.
D is incorrect. MRM is by design staffed with experts independent of development; finding them is not the challenge GARP names.

LO: ORR-16 b: Describe the role of the model risk management function and explain best practices in the model risk management and validation processes. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, 3. Model Risk Management

Solution ORR-16 b.6 — Answer: D

New • built from GARP Ch.16 • S3

Step 1 – Tiering

Tier criteria: materiality of output, complexity, client-facing use, regulatory use. Top tier: full-scope validation "usually every 2 to 3 years"; mid tier every 4 or 5; low tier more rarely; "all models, independently of their tier, undergo an annual review".
⇒ D is GARP's practice.

Step 2 – Independence and the first line

MRM's experts are "independent of model development". A bigger second line "can result in modeling teams becoming more complacent"; the first line owns the risk and its QA/QC teams target execution risk.
⇒ A and B break the independence and ownership rules.

Step 3 – What "continuous" means

Continuous model risk management means monitoring and review between validations (owners' monitoring reports, annual reviews), not full-scope validation of everything every year.

Interpretation

The plan's one sound element spends a scarce validation budget where the risk is. The two independence traps (A and B) are the S3 shape: separation from development drives the incentive to challenge, and the backstop must not let the first line off the hook.

Why the other options are wrong

A is incorrect. Polarity flip: incentives for effective challenge are stronger with greater separation from development; embedding validators removes the independence that defines MRM.

B is incorrect. The first line must not abdicate its responsibilities; this is exactly the complacency GARP warns a large validation team can cause.

C is incorrect. Ignores tiering and the cost-benefit balance; every model gets an annual review, not an annual full-scope validation.

LO: ORR-16 b: Describe the role of the model risk management function and explain best practices in the model risk management and validation processes. ORR-15 d: Describe elements of a strong model validation process and challenges to an effective validation process. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, 3. Model Risk Management; Ch.15, 15.3 and 15.5

ORR-16 • Case Study: Model Risk and Model Validation • Vardeez: VERY IMPORTANT

ORR-16 c

P2 CONCEPT

Describe lessons learned from the three case studies involving model risk.

Workbook: C6 Model Risk Management • Tier C

WHAT IS TESTED HERE

Why P2. Vardeez flags ORR-16 as a Very Important chapter (STRIKE FIRST, rank 21 of 55); the recall evidence alone is Tier C (C6, map #32, 3 of 16 sources), but it includes one specific item, below.

Vardeez: "LO 55.c" (consolidated volume pp.88 to 89). The three cases with a one-line lesson each: MRM would have identified the copula's limitations and promoted better communication; careful data management for Barclays; proper unit conversions for NASA.

Reported exam shapes

- **S1** The friction between investor and rating agency labelled model error, tied to the GARP Gaussian copula case ("I chose model error as the answer").

What the questions look like: match a case to its error type (conceptual, implementation, input assumption) and to its lesson; distractors cross-map one case's lesson onto another. The S1 item asks for the friction label and its link to the copula case.

See also: workbook C6.1 (the S1 link to the copula case) is worked under ORR-15 a; execution versus conceptual errors are in ORR-16 a.

1. Gaussian copula and CDO pricing

What happened. In the early 2000s David X. Li published a way to price pools of assets (CDOs) without observing their correlations: a **Gaussian copula** with correlations **inferred from CDS prices** rather than from historical data, on the logic that efficient market prices should reflect correlation. The CDO market took off.

- **The sample:** CDSs had existed for only about a decade, a short and benign period (house prices rising consistently, defaults at all-time lows). Implied correlations were very low and "extremely sensitive to the trajectory of house prices".
- **The spread:** the method was adopted "by everybody from bond investors and Wall Street banks to ratings agencies and regulators"; it became so entrenched, and was making people so much money, that warnings about its limitations were largely ignored.
- **The break:** when house prices reversed in 2008, CDS-implied correlations shot up, CDO prices swung dramatically and the market collapsed.

Where the blame falls. "While it might be easy to simply blame the formula", the blame falls on those who used it blindly: quants who should have known better and warned users, and users who relied on "prices spat out of a black box that they did not understand". "The problem was not with the formula itself, but with the fact that banks failed to update the copula model with the new correlation estimates implied by the higher CDS prices, and instead continued to price CDOs using the old assumptions." The assumption was valid and accurate in normal markets: a **conceptual error** in GARP's terms (right in one context, wrong when it changed), combined with misuse.

Lesson. MRM's role is "improving transparency by shedding light in the so-called black box". It must replicate the model to rule out coding errors, but its more critical job is challenging the assumptions

and making sure users understand the limitations; the key skill is **effective communication** with non-quantitative users.

> **Correction to the source notes.** Vardeez writes that "the model failed to adequately adjust to rapidly changing market conditions", and Schweser that "the model incorporated changing correlations with a lag" (Schweser also calls the input a "Gaussian constant", a term GARP does not use). GARP places the failure with the users, not the formula: banks "failed to update the copula model with the new correlation estimates... and instead continued to price CDOs using the old assumptions". An option saying "the formula itself was the problem" is wrong; so is "the copula was inaccurate in all conditions". Bank Q365's stem has been aligned with GARP (Question ORR-16 c.5).

Shape S1: the friction labelled "model error". The recall item comes from an outside source carried in the workbook C6 notes (Ashcraft and Schuermann, 2008): the subprime securitisation chain described as frictions between pairs of parties. The investor relies on the rating agency's model to judge a tranche's credit quality, so that friction is labelled **model error**; the GARP text behind it is the copula case, since rating agencies were among the copula's adopters.

Pair of parties (as listed in the workbook notes)	Friction label
Originator and borrower	predatory lending
Arranger and third parties	adverse selection
Servicer and mortgagor, or third parties	moral hazard
Asset manager and investor	principal-agent problem
Investor and credit rating agency	**model error**

2. Barclays, Lehman and the hidden rows

- Lehman Brothers, once the fourth-largest US investment bank, filed for bankruptcy on September 15, 2008. Three days later Barclays Capital offered to buy part of its assets, including trading positions; its law firm, Cleary Gottlieb, had to file the offer on the US Bankruptcy Court (Southern District of New York) website by midnight on September 18.
- Barclays sent the Excel file at 7.50 p.m.: 1,000 rows and 24,000 cells, including **179 trading contracts it did not want**, which were **hidden rather than deleted**. A junior law associate converted the file to PDF under time pressure; the hidden rows became visible.
- The mistake was spotted on October 1, after the deal had been approved; Cleary Gottlieb had to file a motion to exclude the contracts.

Lesson. "A perfect example of a simple implementation error." The spreadsheet "does not fit the definition of a model": there is no uncertainty in it (the assets are known and their values known or agreed; any valuation error would be model risk in the valuation models). Yet a seemingly innocuous error nearly cost Barclays millions; the loss did not materialise, but could have. "Even seemingly simplistic tools or models still need the right review, challenge and controls." (Vardeez's "clear data presentation" is one instance of that broader lesson.)

3. NASA Mars orbiter

- NASA lost a USD 125 million Mars orbiter because a Lockheed Martin engineering team used English units while NASA's team used the metric system for a key spacecraft operation.
- GARP calls it "an error in the 'assumptions' of the model, the choice of the unit"; the financial parallel is the wrong currency, discount factor "or other simple assumptions that are often taken

for granted". Earlier in the chapter GARP lists it, with Barclays, as a prime example of **execution errors**: trivial-seeming mistakes that, with bad luck, become catastrophic.

Lesson. An MRM function that reviews all models and double-checks all work "often upsets executives" because most mistakes it catches are benign. But a small subset could be catastrophic, and "it is impossible to determine which mistakes will lead to catastrophic losses and which ones will not". So everything gets reviewed, inputs and assumptions included.

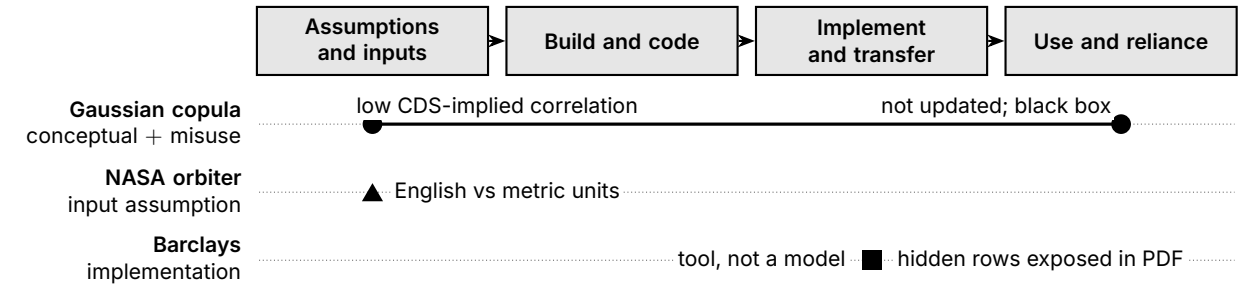


Figure 1. Where each case failed in the model lifecycle. Circles: the copula failed at the assumption and again at use (solid line: the stale assumption carried through to use). Triangle: NASA's unit assumption on the inputs. Square: Barclays' implementation step, in a tool that is not a model. No case failed at "build and code": replication alone would have caught none of them.

	Gaussian copula	Barclays and Lehman	NASA Mars orbiter
What failed	correlation assumption from a short, benign CDS sample; kept in use after it broke	hidden rows (179 contracts) exposed when converted to PDF	English vs metric units between teams
Error type	conceptual (context changed) plus blind use	simple implementation error in a non-model tool	assumption taken for granted; an execution error
Outcome	CDO market collapse	nearly cost millions; motion to exclude	USD 125 million orbiter lost
Lesson	challenge assumptions; transparency; communicate limitations	even simple tools need review, challenge and controls	review everything: cannot tell which small error is catastrophic

Exam traps

- **Case cross-mapping.** Units belong to NASA, hidden rows to Barclays, CDS-implied correlation to the copula. Distractors attach one case's lesson to another.
- **"The formula was the problem."** GARP: the problem was the failure to update and blind use.
- **"Always wrong."** The copula was valid and accurate in normal markets.
- **Barclays as a model.** The spreadsheet is not a model; it is still a lesson for model risk management.
- **Code replication as the cure.** Necessary, but none of the three failures was a coding error.
- **Friction labels.** Investor and rating agency = model error; principal-agent is asset manager and investor; moral hazard is the servicer; adverse selection is the arranger.

Practice questions: ORR-16 c

Question ORR-16 c.1

Bank Q366 • AnalystPrep Q.5154

A bank hires an expert to review a newly developed model as part of good model risk management practice. Which case study illustrates losses suffered because a model was widely adopted and entrenched without assessing its assumptions and limitations?

A. Gaussian copula and CDO pricing

B. Barclays' acquisition of Lehman assets and the spreadsheet error

C. NASA Mars Orbiter

D. Lehman Brothers fraud

Question ORR-16 c.2

Bank Q368 • Schweser Module Quiz 57.1 Q3

What is the most likely reason for the failure of the Gaussian copula function to price CDOs?

A. Model computation error.

B. Inappropriate model for the task.

C. Invalid model assumption.

D. Invalid use of model output.

Question ORR-16 c.3

Bank Q369 • Schweser Module Quiz 57.1 Q4

The Barclays bid for Lehman assets in bankruptcy court most likely suffered from:

A. ongoing monitoring.

B. improper model use.

C. invalid model assumptions.

D. implementation error.

Question ORR-16 c.4

Bank Q370 • Schweser Module Quiz 57.1 Q5 (rebuilt)

NASA lost a $125 million Mars orbiter because a Lockheed Martin engineering team used English units of measurement while NASA's team used the metric system for a key spacecraft operation. Which description of the failure is MOST consistent with the model risk case study?

A. A conceptual error: the modeling approach rested on a debatable assumption on which reasonable modelers could hold different, equally valid views.

B. A simple, taken-for-granted setting, the unit of measurement (English vs. metric) applied to the model's inputs, was never reconciled between teams; a seemingly trivial execution-type mistake produced a catastrophic loss.

C. The model's output was used for a purpose other than the one it was designed for.

D. A model that had become entrenched among users without regard to its limitations stopped reflecting reality in stressed conditions.

Question ORR-16 c.5 Bank Q365 • AnalystPrep Q.5153 (rebuilt)

A risk manager reviews the Gaussian copula and CDO pricing case study. The model used CDS prices to infer asset correlations in the collateral pool. As housing prices fell in 2008, CDS prices rose sharply, but many users kept pricing CDOs with the old, low correlation estimates, and the model's use had become entrenched among market participants. Which lesson from the case is MOST appropriate?

A. Model risk arises mainly from coding errors, so independent replication of the model code is sufficient.

B. Model assumptions and limitations must be challenged and clearly communicated to users, because the model's correlation assumption stopped reflecting reality in stressed markets.

C. Model inputs must be checked for consistency of units of measurement across teams.

D. Simple tools such as spreadsheets are not models and therefore do not need to be reviewed.

Question ORR-16 c.6 Bank Q367 • AnalystPrep Q.5155 (rebuilt)

Barclays Capital nearly bought 179 unwanted Lehman Brothers contracts because rows hidden in a spreadsheet became visible when a junior lawyer converted it to a PDF. Which lesson is MOST directly supported by this incident?

A. Even seemingly simple tools should be reviewed and challenged, because implementation errors can create large potential losses.

B. Users must be told that CDS-implied correlations lag market conditions.

C. Inputs measured in different unit systems (English vs. metric) must be reconciled.

D. A model's correlation assumption must be updated when housing prices fall.

Question ORR-16 c.7 New • built from GARP Ch.16 and workbook C6 notes • S1

A credit risk consultant running a model risk workshop maps the subprime securitisation chain as a set of frictions between pairs of parties (the Ashcraft and Schuermann taxonomy). She asks the class to label the friction between CDO investors and the credit rating agencies, and to state the lesson the GARP Gaussian copula case attaches to it. Which answer should the class give?

A. Principal-agent problem: the investor delegates credit analysis to the agency, so the lesson is to align the agency's fees with the investor's returns.

B. Moral hazard: the agency stops monitoring the collateral once the deal closes, so the lesson is that investors must audit the agency's surveillance.

C. Model error: investors relied on rating models built on correlations inferred from a short, benign CDS history, so assumptions and limitations must be challenged and explained.

D. Adverse selection: the agency knows more about the collateral than the investor, so the lesson is that investors should hold only the most senior tranches.

Solutions • ORR-16 c

Solution ORR-16 c.1

Answer: A

Bank Q366 • AnalystPrep Q.5154

Step 1 – Match the description to a case

"Widely adopted and entrenched without assessing assumptions and limitations": Li's method was adopted "by everybody from bond investors and Wall Street banks to ratings agencies and regulators" and became so entrenched that "warnings about its limitations were largely ignored".
⇒ The Gaussian copula.

Interpretation

The other two cases are execution errors in a single transaction or mission, not entrenched reliance on a model across a market.

Why the other options are wrong

B is incorrect. An implementation error in a spreadsheet that is not even a model.
C is incorrect. A unit-of-measurement error on the inputs, not an entrenched model.
D is incorrect. Not one of the three case studies; Lehman appears only as the seller in the Barclays case.

LO: ORR-16 c: Describe lessons learned from the three case studies involving model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, Gaussian Copula and CDO Pricing

Solution ORR-16 c.2

Answer: C

Bank Q368 • Schweser Module Quiz 57.1 Q3

Step 1 – Why the prices went wrong

The copula priced CDOs with correlations inferred from a short, benign CDS history. "When market conditions deteriorated and the correlation between assets spiked, the Gaussian copula assumption was no longer valid."
⇒ The pricing failed because its correlation assumption stopped holding: an invalid assumption, a conceptual error.

Interpretation

GARP adds that the blame lies with blind use and the failure to update the correlations. That explains why the error was so costly, but the reason the *pricing* failed is the assumption. (Schweser's key speaks of a static "Gaussian constant"; GARP does not use that term; see the correction box.)

Why the other options are wrong

A is incorrect. The model computed what it was designed to compute; there was no coding or computation error.
B is incorrect. The copula was a legitimate technique that "generated accurate values in normal market conditions".
D is incorrect. The output was used for its intended purpose, pricing; misuse made the damage worse but is not why the prices were wrong.

LO: ORR-16 c: Describe lessons learned from the three case studies involving model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, 2. Model Risks; Gaussian Copula and CDO Pricing; SchweserNotes 2026 Book 3, Reading 57, LO 57.c

Solution ORR-16 c.3 — Answer: D

Bank Q369 • Schweser Module Quiz 57.1 Q4

Step 1 – GARP's classification

"The Excel error in this example is a perfect example of a simple implementation error."
⇒ D.

Interpretation

The rows were hidden rather than deleted, and the PDF conversion exposed them. No model, assumption or monitoring was involved; the spreadsheet "does not fit the definition of a model".

Why the other options are wrong

A is incorrect. Ongoing monitoring is a validation activity, not a type of failure.
B is incorrect. The spreadsheet was not a model, and nothing was used outside its purpose.
C is incorrect. No modelling assumptions were involved: the list of assets was known.

LO: ORR-16 c: Describe lessons learned from the three case studies involving model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, Barclays' Acquisition of Lehman Brothers and the Excel Spreadsheet Error

Solution ORR-16 c.4 — Answer: B

Bank Q370 • Schweser Module Quiz 57.1 Q5

Step 1 – The facts

Lockheed Martin used English units; NASA used metric; the mismatch destroyed a USD 125 million orbiter.

Step 2 – GARP's two descriptions

"An error in the 'assumptions' of the model, the choice of the unit"; and, with Barclays, a prime example of execution errors that seem trivial yet become catastrophic. Schweser: a mistake in the measurement of model inputs.
⇒ B covers all three views.

Interpretation

The lesson: "it is impossible to determine which mistakes will lead to catastrophic losses and which ones will not", so MRM reviews everything, including assumptions taken for granted (in finance: currency, discount factors).

Why the other options are wrong

A is incorrect. A conceptual error is a judgment on which reasonable modelers can differ; inconsistent units are simply wrong.
C is incorrect. Nothing suggests the output was used for an unintended purpose; the calculation itself ran on inconsistent units.
D is incorrect. The Gaussian copula lesson (an entrenched model whose assumption failed under stress), not the orbiter.

LO: ORR-16 c: Describe lessons learned from the three case studies involving model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, 2. Model Risks; NASA Mars Orbiter; SchweserNotes 2026 Book 3, Reading 57, LO 57.c

Solution ORR-16 c.5 — Answer: B

Bank Q365 • AnalystPrep Q.5153

Step 1 – What failed

Correlations implied by a short, benign CDS history were very low; when house prices fell they shot up, but banks "continued to price CDOs using the old assumptions" and users relied on a

black box.
⇒ A conceptual error (assumption valid only in one context) plus blind use.

Step 2 – GARP's lesson

MRM must replicate the model, but "its more critical responsibility is that of challenging the assumptions upon which the model relies and ensuring that users understand its limitations".
⇒ B.

Interpretation

The stem has been aligned with GARP: the bank's version said the model "incorporated the changing correlations only with a lag" (Schweser's phrasing). GARP places the failure with the users who did not update, not with the formula; the answer is unchanged.

Why the other options are wrong

A is incorrect. Replication is necessary but the failure was conceptual; execution and conceptual risk are confused.
C is incorrect. The NASA lesson (units), cross-mapped.
D is incorrect. A distortion of the Barclays lesson, which is that simple tools *do* need review.

LO: ORR-16 c: Describe lessons learned from the three case studies involving model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, Gaussian Copula and CDO Pricing

Solution ORR-16 c.6 — Answer: A

Bank Q367 • AnalystPrep Q.5155

Step 1 – Classify the incident

A simple implementation error in a spreadsheet that is not a model.

Step 2 – GARP's lesson

"It is an excellent example of why even seemingly simplistic tools or models still need the right review, challenge and controls."
⇒ A.

Interpretation

The loss did not materialise (a legal motion excluded the contracts), "but under different circumstances, it could have". Model risk management is about tools and processes as well as formal models.

Why the other options are wrong

B is incorrect. A copula lesson, cross-mapped.
C is incorrect. The NASA lesson, cross-mapped.
D is incorrect. A copula lesson about the stale correlation assumption.

LO: ORR-16 c: Describe lessons learned from the three case studies involving model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, Barclays' Acquisition of Lehman Brothers and the Excel Spreadsheet Error

Solution ORR-16 c.7 — Answer: C

New • built from GARP Ch.16 and workbook C6 notes • S1

Step 1 – The label

In the securitisation-frictions taxonomy the investor relies on the rating agency's model to judge the credit quality of a tranche, so that friction is labelled model error.

Step 2 – The GARP case behind it

Li's copula, with correlations inferred from a short, benign CDS history, was adopted by "ratings agencies" among others. When house prices reversed, the implied correlations shot up and users

kept pricing on the old assumptions.
⇒ The lesson: challenge the assumptions and make sure users understand the limitations.

Interpretation

This is the recall item: the exam named the investor and rating agency pair, and the answer was model error. The GARP chapter does not use the frictions taxonomy; the label comes from the outside source in the workbook notes, and the copula case supplies the content.

Why the other options are wrong

A is incorrect. Principal-agent is the friction between the asset manager and the investor.
B is incorrect. Moral hazard is the servicer's friction (with the mortgagor or with third parties).
D is incorrect. Adverse selection is the friction between the arranger and third parties.

LO: ORR-16 c: Describe lessons learned from the three case studies involving model risk. ORR-16 a: Define a model and describe different ways that financial institutions can become exposed to model risk. • **Reference:** GARP, Operational Risk and Resilience, Ch.16, Gaussian Copula and CDO Pricing; workbook C6 revision notes (Ashcraft and Schuermann, 2008)

ORR-23 • High-level Summary of Basel III Reforms • Vardeez: VERY IMPORTANT

ORR-23 a

P2 CONCEPT

Explain the motivations for revising the Basel III framework and the goals and impacts of the December 2017 reforms to the Basel III framework.

Workbook: *none*

WHAT IS TESTED HERE

Why P2. Vardeez flags it in a Very Important chapter: ORR-23 is rank 11 of 55 in the consolidated volume and part of his theme 3 ("Basel III: three components and comparison with Basel I and II"). No workbook section is homed here.

Vardeez: his notes label this LO "LO 62.a" (consolidated volume p.51) and list four goals: more robust and risk-sensitive standardised approaches, restricted internal models, a G-SIB leverage ratio buffer, and a more robust output floor.

Reported exam shapes: none reported; the questions below are built from the LO wording and Vardeez's list.

What the questions look like: "which of the following is (not) a goal, a motivation or an initial-phase measure", and pairings of a shortcoming with the reform that answers it. Distractors flip the direction of a reform (models expanded instead of restricted), move a measure to the wrong phase of Basel III, or misstate a calibration or date.

See also: the five areas in detail are ORR-23 b (Part P1), whose Section 1 sets out the package; the output floor is ORR-23 c. Workbook C5.1 also tags this LO; it is worked under ORR-21 a. Workbook A31.4 is homed here (Question ORR-23 a.7).

1. Two phases of Basel III

The first phase (published 2010 to 2011) answered the shortcomings of the pre-crisis framework by:

- improving the **quality** of capital, with a focus on going-concern loss-absorbing **CET1**;
- **increasing the level** of capital requirements so that banks can withstand losses in stress;
- **enhancing risk capture** where the framework proved acutely miscalibrated: market risk, counterparty credit risk, securitisation;
- adding **macroprudential** elements: buffers built up in good times and drawn down in stress (limiting procyclicality), a **large exposures** regime against interlinkages and concentrations, and a buffer for the externalities of systemically important banks;
- a minimum **leverage ratio**, which constrains excess leverage and *complements* the risk-weighted requirements rather than replacing them;
- an international liquidity framework: the **LCR** and the **NSFR**.

The December 2017 reforms complement these. They target the *denominator* of the capital ratios: they "seek to **restore credibility in the calculation of risk-weighted assets** and **improve the comparability** of banks' capital ratios".

2. Motivations: what had gone wrong

Area	Shortcoming identified (GARP Ch.23)	Reform (detail in ORR-23 b, c)
SA credit risk	flat weights (one weight for all mortgages); mechanistic reliance on external ratings	more granular, risk-sensitive weights; due diligence; base for the floor
IRB	excessive complexity; lack of comparability of modelled requirements; lack of robustness for certain asset classes; unwarranted RWA variability	A-IRB removed for some classes; input floors; tighter estimation practices
CVA	a major crisis loss source, in some instances above default losses; exposure component not captured; too complex to model robustly	internal model removed; SA-CVA and BA-CVA
Operational risk	capital insufficient to cover some banks' losses; misconduct and control failures hard to model	AMA and three SAs replaced by one SA
Leverage	gaming and model risk in both models and SAs; G-SIB externalities	G-SIB leverage ratio buffer
Output floor	Basel II floor (80% of Basel I) applied inconsistently, on Basel I standards many no longer used	floor at 72.5% of revised SA RWA

The common thread: internal models had let RWA, the denominator of every risk-based ratio, drift apart across banks for reasons unrelated to risk. Investors and supervisors could no longer compare a 12% CET1 ratio at one bank with a 12% ratio at another.

3. Goals and impacts

Vardeez and Schweser compress the goals into four (Section 1 of ORR-23 b gives the same list as the four "levers"):

1. **expand** the robustness and risk sensitivity of the **standardised approaches** for credit risk, CVA risk and operational risk;
2. **restrict** the use of **internal model approaches** for credit risk, CVA risk and operational risk;
3. introduce a **leverage ratio buffer for G-SIBs**;
4. create an **output floor** that is more robust and risk-sensitive than the Basel II floor.

Impacts.

- **Less unwarranted RWA variability and more comparable capital ratios**, through fewer and constrained models and the disclosure of standardised RWA.
- **A level playing field**: a bank on internal models can cut total RWA by at most 27.5% against the standardised approaches (ORR-23 c). Banks whose models produced the largest reductions see their RWA rise.
- **Standardised banks** (the majority worldwide, including outside Basel Committee jurisdictions) get more risk-sensitive weights; **G-SIBs** face a higher leverage requirement.
- **Operational risk** capital becomes formula-based for every bank, driven by income and past losses.
- **Minimum standards only**: jurisdictions may be more conservative or accelerate the transition, and one that implements only the standardised approaches is compliant. Several items are left to **national discretion** (ILM set to one, the transitional cap on the floor, temporary exemption of central bank reserves from the leverage exposure).

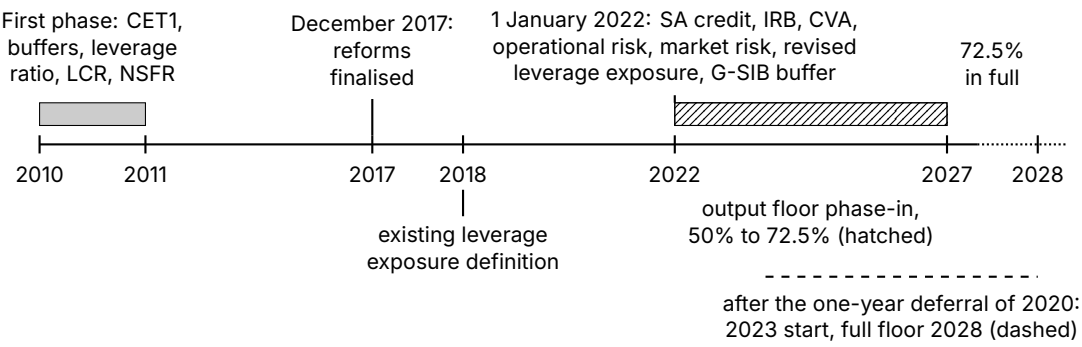


Figure 1. Timeline of the post-crisis reforms (GARP Table 23.5 dates on the solid axis). The grey bar marks the first phase, the hatched bar the output floor phase-in. The dashed line shows the dates after the Basel Committee's one-year deferral; exam questions follow GARP's table.

Dates. GARP's Table 23.5 puts the revised standardised approach, IRB, CVA, operational risk and market risk frameworks, the revised leverage exposure definition and the G-SIB leverage buffer at **1 January 2022**; the existing leverage exposure definition at 1 January 2018; the output floor from 50% (2022) to 72.5% (2027). In March 2020 the Basel Committee deferred implementation by one year because of COVID-19 (GARP Ch.2 notes the 2023 start for operational risk); the book's table is what the exam uses.

Summary card: ORR-23 a

	First phase of Basel III	December 2017 finalisation
Target	numerator of the ratios (capital quality and quantity), liquidity, leverage	denominator: credibility and comparability of RWA
Main tools	CET1 focus, higher minimums, buffers, large exposures, leverage ratio, LCR, NSFR	granular SAs, constrained or removed models, G-SIB leverage buffer, output floor
Models	risk capture improved (market risk, CCR, securitisation)	IRB restricted, CVA and operational risk models removed
Floor	Basel II floor at 80% of Basel I still in place	revised floor at 72.5% of revised SA RWA
Dates	published 2010 to 2011 (ORR-22)	finalised December 2017; 1 January 2022 in GARP's table, floor in full 2027

Exam traps

- **Direction.** The reforms restrict internal models; a statement that they expand them is false.
- **Wrong phase.** CET1, buffers, the minimum leverage ratio, LCR and NSFR are the *first* phase; the G-SIB leverage *buffer*, input floors, the revised output floor and the single operational risk SA are December 2017.
- **Leverage ratio role.** It complements the risk-weighted requirements; it does not replace them.
- **Large exposures.** The regime was introduced to *limit* concentrations; "relaxing" it was never a reform.
- **Systemic risk** is not a modelled risk category; models were restricted for credit, CVA and operational risk.

- **Dates.** 2022 for the main revisions in GARP's table; 2027 is the end of the floor phase-in; 2018 the existing leverage exposure definition.

Practice questions: ORR-23 a

Question ORR-23 a.1

Bank Q704 • AnalystPrep Q.2356 (rebuilt)

Within the initial phase of the Basel III reforms, the Basel Committee specified a minimum leverage ratio requirement. What was its main purpose?

A. To constrain excess leverage in the banking system and complement the risk-weighted capital requirements

B. To replace risk-weighted capital requirements with a simple non-risk-based measure

C. To build up capital in good times that can be drawn down in times of stress

D. To place a floor on the capital benefits banks obtain from internal models

Question ORR-23 a.2

Bank Q705 • AnalystPrep Q.3092 (rebuilt)

The Basel III framework was revised because the pre-crisis framework failed to prevent systemic shocks. Which of the following was NOT among the initial-phase Basel III measures to address those shortcomings?

A. Improving capital quality through a greater focus on Common Equity Tier 1 (CET1) capital

B. Introducing capital buffers built up in good times that can be drawn down in times of stress

C. Specifying a minimum leverage ratio requirement to constrain excess leverage

D. Relaxing the large exposures regime to allow more concentrated exposures to individual counterparties

Question ORR-23 a.3

Bank Q706 • AnalystPrep Q.3109 (rebuilt)

The December 2017 Basel III reforms finalised the post-crisis framework. Most of the revisions (revised standardised approach for credit risk, IRB, CVA, operational risk) are to be implemented beginning in which year?

A. 2018

B. 2020

C. 2022

D. 2027

Question ORR-23 a.4 Bank Q707 • Mock 2 Q49

Revisions to Basel III aim to address the failures in preventing systemic shocks that severely weakened the global economy during the financial crisis of 2007-2009. Which of the following statements is incorrect regarding the main goals and impacts of the December 2017 Basel III reforms?

A. Introduce a leverage ratio buffer for global systemically important banks (G-SIBs).

B. Create an output floor that is more robust and risk sensitive than the current Basel II floor.

C. Expand the use of internal model approaches for credit risk, credit valuation adjustment (CVA) risk, and operational risk.

D. Expand the robustness and sensitivity of the standardized approaches (SA) for measuring credit risk, CVA risk, and operational risk.

Question ORR-23 a.5 Bank Q716 • Schweser Module Quiz 64.1 Q1 • re-filed from LO 64.b

The Basel III reforms restricted the use of internal model approaches for all of the following risk categories except:

A. credit risk.

B. systemic risk.

C. operational risk.

D. credit valuation risk.

Question ORR-23 a.6 New • built from GARP Ch.23

The CRO of an Australian bank asks a regulatory analyst to explain to the board which shortcomings the December 2017 Basel III reforms were designed to fix. Which of the following pairings of a shortcoming with the reform that addresses it is correct?

A. CVA losses were small relative to default losses in the crisis, so the internal CVA model was retained and the standardised approach removed.

B. The Basel II floor was applied too conservatively across countries, so it was replaced by a lower floor of 72.5% of Basel I requirements.

C. IRB capital requirements were too uniform across banks, so the reforms gave banks more freedom to estimate LGD and EAD for large corporates.

D. Operational risk capital proved insufficient for some banks' losses, and misconduct losses were hard to model, so the AMA was replaced by a single standardised approach.

Question ORR-23 a.7 Workbook A31.4 • S4 • self-generated

A regulatory consultant is briefing the credit risk committee of a European bank that currently uses the Advanced IRB approach for its wholesale, specialised lending and equity exposures. The committee wants to know how the December 2017 Basel III reforms change the bank's use of internal ratings. Which of the following statements should the consultant include?

A. Exposures to corporates with consolidated revenues above EUR 500 million must move to the standardised approach, since the advanced IRB option is removed for them.

B. Equity exposures can no longer be treated under any IRB approach, whereas specialised lending may remain on the advanced or foundation IRB approach.

C. Exposures to banks and other financial institutions may stay on the advanced IRB approach, since only corporate exposures lose the advanced option.

D. PD input floors apply only under the advanced IRB approach, so exposures moved to the foundation IRB approach face no PD floor.

Solutions • ORR-23 a

Solution ORR-23 a.1

Answer: A

Bank Q704 • AnalystPrep Q.2356

Step 1 – Find the measure in GARP's list

The initial phase included "specifying a minimum leverage ratio requirement to constrain excess leverage in the banking system and complement the risk-weighted capital requirements".
⇒ Two jobs: limit leverage, and sit alongside (not instead of) the risk-weighted ratios.

Interpretation

A non-risk-based ratio is a backstop: it catches leverage that risk weights understate. The December 2017 reforms later added a G-SIB buffer on top of it.

Why the other options are wrong

B is incorrect. It complements the risk-weighted requirements; it does not replace them.
C is incorrect. That describes the capital buffers that limit procyclicality, a separate macroprudential measure.
D is incorrect. That describes the output floor, a different element (revised in December 2017).

LO: ORR-23 a: Explain the motivations for revising the Basel III framework and the goals and impacts of the December 2017 reforms to the Basel III framework. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, introduction (initial phase of Basel III)

Solution ORR-23 a.2

Answer: D

Bank Q705 • AnalystPrep Q.3092

Step 1 – Recall the initial-phase list

CET1 focus, higher capital levels, better risk capture, macroprudential elements (buffers, a large exposures regime, a buffer for systemically important banks), a minimum leverage ratio, and the LCR and NSFR.

Step 2 – Check the direction of D

The large exposures regime was *established* to mitigate "systemic risks arising from interlinkages across financial institutions and concentrated exposures". Relaxing it is the opposite of the reform.

Interpretation

A, B and C are genuine first-phase measures; D reverses one of them.

Why the other options are wrong

A is incorrect. Genuine measure: a greater focus on going-concern, loss-absorbing CET1.
B is incorrect. Genuine measure: buffers built in good times limit procyclicality.
C is incorrect. Genuine measure: the minimum leverage ratio.

LO: ORR-23 a: Explain the motivations for revising the Basel III framework and the goals and impacts of the December 2017 reforms to the Basel III framework. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, introduction

Solution ORR-23 a.3

Answer: C

Bank Q706 • AnalystPrep Q.3109

Step 1 – Read Table 23.5

The revised standardised approach for credit risk, the revised IRB framework, the revised CVA

framework, the revised operational risk framework and the revised market risk framework: 1 January 2022.

Step 2 – Place the other dates

1 January 2018: the existing leverage ratio exposure definition. 1 January 2027: the output floor reaches 72.5%.

Interpretation

Answer as GARP prints it: 2022. In March 2020 the Basel Committee deferred the package by one year because of COVID-19 (GARP Ch.2 notes the 2023 start for operational risk), but the exam follows the chapter's table.

Why the other options are wrong

A is incorrect. 2018 applies only to the existing leverage ratio exposure definition.
B is incorrect. No Basel III reform milestone in the table falls in 2020.
D is incorrect. 2027 is the end of the output floor phase-in, not the start of the revisions.

LO: ORR-23 a: Explain the motivations for revising the Basel III framework and the goals and impacts of the December 2017 reforms to the Basel III framework. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Transitional Arrangements, Table 23.5; GARP ORR Ch.2, footnote 2

Solution ORR-23 a.4 — Answer: C

Bank Q707 • Mock 2 Q49

Step 1 – List the four goals

Expand the robustness and risk sensitivity of the SAs; **restrict** internal models for credit, CVA and operational risk; a G-SIB leverage ratio buffer; a more robust and risk-sensitive output floor.

Step 2 – Match the options

A, B and D are goals. C turns "restrict" into "expand".

Interpretation

The direction of every element of the package is the same: more weight on standardised measures, less freedom for models.

Why the other options are wrong

A is incorrect. A correct goal: the G-SIB leverage ratio buffer.
B is incorrect. A correct goal: the revised floor replaces the Basel II floor with a more robust one.
D is incorrect. A correct goal: more granular, risk-sensitive standardised approaches.

LO: ORR-23 a: Explain the motivations for revising the Basel III framework and the goals and impacts of the December 2017 reforms to the Basel III framework. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, introduction; SchweserNotes 2026 Book 3, Reading 64, LO 64.a

Solution ORR-23 a.5 — Answer: B

Bank Q716 • Schweser Module Quiz 64.1 Q1

Step 1 – Where models were restricted

Credit risk: A-IRB removed for some asset classes and input floors added. CVA risk: the internal model removed. Operational risk: the AMA removed.

Step 2 – The odd one out

Systemic risk has no internal model approach to restrict; it is addressed through measures such as the G-SIB buffers.

Interpretation

Goal 2 of the package ("restrict the use of internal model approaches") names exactly three risk categories: credit, CVA and operational risk.

Why the other options are wrong

A is incorrect. Credit risk models were restricted (A-IRB scope, input floors).
C is incorrect. Operational risk models were removed (the AMA).
D is incorrect. CVA risk models were removed (only SA-CVA and BA-CVA remain).

LO: ORR-23 a: Explain the motivations for revising the Basel III framework and the goals and impacts of the December 2017 reforms to the Basel III framework. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, introduction; SchweserNotes 2026 Book 3, Reading 64, LO 64.a and 64.b

Solution ORR-23 a.6 — Answer: D

New • built from GARP Ch.23

Step 1 – The operational risk motivation

GARP: "capital requirements for operational risk proved insufficient to cover operational risk losses incurred by some banks", and the nature of the losses (misconduct, inadequate systems and controls) "highlighted the difficulty associated with using internal models". The AMA and the three standardised approaches are replaced by a single standardised approach.
$\Rightarrow$ D pairs the right shortcoming with the right reform.

Step 2 – Test the other pairings

CVA losses were large (in some instances above default losses), and the CVA internal model was *removed*. The Basel II floor was applied inconsistently, not too conservatively, and the new floor is on the revised standardised approaches. IRB requirements lacked comparability, and A-IRB was *removed* for large corporates.

Interpretation

Every motivation in the chapter points the same way: models had produced capital that was too low or too dispersed, so the reforms tightened them.

Why the other options are wrong

A is incorrect. Both halves reversed: CVA losses were a major source of crisis losses, and the internal model was removed, leaving SA-CVA and BA-CVA.
B is incorrect. Wrong shortcoming and wrong base: the Basel II floor was inconsistently implemented and based on Basel I; the new floor is 72.5% of RWA under the revised standardised approaches.
C is incorrect. Reversed: the problem was lack of comparability, and the reforms took the A-IRB away from large corporates (F-IRB fixes LGD and EAD).

LO: ORR-23 a: Explain the motivations for revising the Basel III framework and the goals and impacts of the December 2017 reforms to the Basel III framework. • **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, IRB, CVA, Operational Risk Framework, Output Floor

Solution ORR-23 a.7 — Answer: B

Workbook A31.4 • S4

Step 1 – What the reform targets

The Committee removed the A-IRB option "for asset classes that cannot be modelled in a robust and prudent manner", adopted input floors, and specified estimation practices more tightly, to reduce complexity and unwarranted RWA variability (ORR-23 a).

Step 2 – Table 23.2, revised scope

Large and mid-sized corporates (revenues above EUR 500 million): F-IRB or SA. Banks and other financial institutions: F-IRB or SA. Equities: SA only. Specialised lending: A-IRB, F-IRB, slotting or SA.

Interpretation

B is the only statement consistent with Table 23.2: "all IRB approaches are being removed for exposures to equities, which are typically a small component of the credit risk of banks", while banks "would be permitted to continue using the advanced and foundation IRB approaches" for specialised lending.

Why the other options are wrong

A is incorrect. Scope error. Losing A-IRB does not mean losing IRB: banks with supervisory approval use F-IRB for these corporates, which fixes LGD and EAD and so removes two sources of RWA variability.

C is incorrect. Sibling swap. Banks and other financial institutions are in the same position as large corporates: A-IRB is removed for both.

D is incorrect. Sibling swap. The LGD and EAD floors are A-IRB only; the PD floors apply under both F-IRB and A-IRB (5 bp for corporates).

LO: ORR-23 b: Summarize the December 2017 revisions to the Basel III framework in the following areas: - The standardized approach to credit risk - The internal ratings-based (IRB) approaches for credit risk - The CVA risk framework - The operational risk framework - The leverage ratio framework. ORR-23 a: Explain the motivations for revising the Basel III framework and the goals and impacts of the December 2017 reforms to the Basel III framework.

• **Reference:** BCBS, High-Level Summary of Basel III Reforms (December 2017), GARP ORR Ch.23, Internal Ratings-Based Approaches for Credit Risk, Tables 23.2 and 23.3

OPERATIONAL RISK AND RESILIENCE • PART

P3

Third priority

Tier C and D topics, or LOs Vardeez flags in other chapters. 22 LOs from 10 readings.

ORR-4 • Risk Measurement and Assessment • Vardeez: UNTIERED (crash-course notes)

ORR-4 a

P3 CONCEPT

Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations.

Workbook: D22 Operational Risk Identification, Mitigation and Reporting • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D22 (map #75, 2 of 16 sources, notes only) names "RCSA, KRIs and loss-data collection" as the identification and assessment tools behind the control sibling set. **Vardeez:** his crash-course notes label this LO "LO 43.a" (consolidated volume pp.134 and 135): the regulatory minimum standards (10 years, EUR 20,000, Basel event types, four dates), the collection process, comprehensive data, incident dates, boundary events (his Figure 43.1), the three data quality requirements (Figure 43.2) and the challenges of operational data.

Reported exam shapes

- **D22·S4** Loss-data collection: regulatory criteria, fields, dates, boundary events, completeness.

What the questions look like: short "which is correct" or EXCEPT items on the threshold, the four dates and the gaps between them, gross loss and recoveries, grouped losses, near misses and the sources used to test completeness. No calculation beyond gross minus recovery.

See also: the background to the whole reading (ING's four circles, why operational data are hard to model) is ORR-4 f, Section 1. The BCBS loss-data criteria for the standardized approach are ORR-24 c; reporting of near misses is also in ORR-6.

1. Why loss data, and what regulators require

The loss database is the centre of the ORM framework (ORR-4 f, Figure 1). It shows where losses occur and which controls failed, feeds scenario identification and capital modelling, and good data reduce the occurrence and size of Pillar 2 add-ons. The BCBS lists **eight criteria** for loss-data quality and collection under the standardized approach (BCBS, December 2017). The main ones:

Requirement	What it says
History	At least 10 years of internal loss data
Threshold	Minimum collection threshold of EUR 20,000 (about USD 22,000); many firms use lower ones
Classification	Map internal losses to the Basel event-type categories
Dates and amounts	Gross loss amount and reference dates for each event (occurrence and recovery), any recoveries, and the drivers and causes
Process	"Documented procedures and processes for the identification, collection and treatment of internal loss data"
Comprehensive	Capture "all material activities and exposures from all appropriate subsystems and geographic locations"
Boundary events	Exclude credit-related losses already in credit RWAs; treat market-related losses as operational
Independent review	"Processes to independently review the comprehensiveness and accuracy of loss data"

2. What to record

- **Fields** (GARP Table 4.1, kept to the minimum): unique ID; place of occurrence; event type and cause type (levels 1 and 2); controls that failed; the dates; expected direct loss; impact type (loss, gain, near miss); indirect effects, often on a 1 to 4 scale; recovery (insurance and other); **net loss = gross loss − recovery**; action plans; links to other incidents. Use drop-down labels, not free text, in key fields; large banks now mine old free text with NLP.
- **Threshold.** Commonly 1,000 or 5,000 (USD, GBP or EUR); some use 10,000, rarely the regulatory 20,000. A zero threshold is a fading practice in large firms (too many small incidents for little information). The choice must be justified and must not suggest "cherry-picking" or manipulation of capital.
- **Financial versus non-financial.** Regulators require only losses *directly* identifiable as financial. Good management practice also records non-financial impacts (reputation, customer detriment, service disruption, management time), accidental gains and near misses. **Direct** losses (remediation, compensation, fines, wrongful transactions) are well captured; **indirect** losses (attrition, morale, scrutiny, higher premiums) are usually rated 1 to 4 and monetized only in mature firms.
- **Grouped losses.** Distinct events with a common cause (the same wrong advice to many clients; one IT failure hitting several departments) are recorded as one loss: a regulatory requirement, sound modelling practice and correct management information.

3. Dates, and the gaps between them

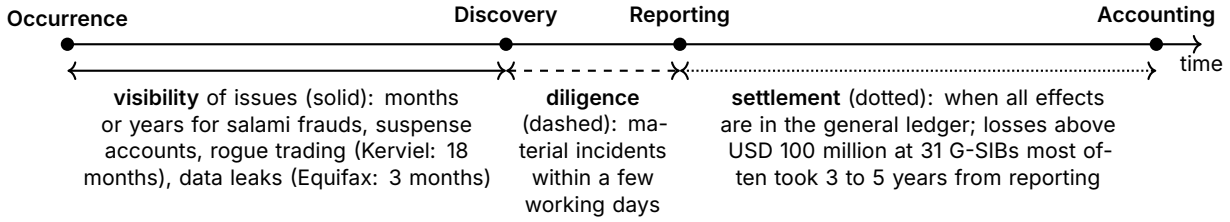


Figure 1. The four dates of an operational incident and what each gap reveals. Solid arrow: occurrence to discovery; dashed: discovery to reporting; dotted: reporting to accounting (settlement). Not to scale.

Regulators do not require a specific date type for *internal* reporting, but each gap carries management information. Time to discovery is the main reason for the years-long gap between occurrence and payment, and it dramatically worsens the impact. Best practice is risk-based: material incidents are reported within a few working days, minor ones in periodic summary reporting. Because losses hitting the accounts today may have occurred years ago in a different business context, their relevance for modelling and for lessons should be questioned.

4. Boundary events and completeness

Boundary events materialize in a different risk class from their cause, for example a credit loss aggravated by wrongly recorded collateral, or a market loss from a booking error.

- **Credit-related, already in credit RWAs:** excluded from the operational loss dataset; left where it materialized and covered by credit capital (point f).
- **Credit-related, not in credit RWAs:** included.
- **Market-related:** included; treated as operational risk for minimum capital, because market risk models do not cover them (point g).

Completeness is the main quality test. Reconcile the database with other sources: the **general ledger** (a good benchmark, but it shows only direct losses and accidental gains, misses indirect effects, and cannot see forgone revenue such as an undercharged client); **IT logs** (Priority 1 and 2 issues are proxies for incidents); provisions for lawsuits; customer complaints and compensation; negative press; back-office issue logs. **Underreporting** remains common, especially at smaller firms (unclear guidance, reluctance to escalate, cumbersome processes). Remedies: mandatory self-reporting with disciplinary action if unreported events surface, risk metrics in managers' balanced scorecards, and internal audit review of the collection process.

Correction to the source notes. (1) SchweserNotes (LO 45.a) says loss events must be reported "in terms of gross loss amounts net of any recoveries". GARP asks for the *gross* loss amount and, separately, any recoveries; the net loss is derived (gross minus recovery). Vardeez's "gross loss, net recoveries" should be read the same way. (2) Vardeez's Figure 43.1 shows credit losses due to operational errors as "included in RWAs". The rule has two halves: they are excluded from the operational loss dataset only when already accounted for in credit RWAs, and included when they are not.

	Required by regulation	Good management practice adds
What counts	Direct financial losses; grouped losses	Non-financial impacts, accidental gains, near misses; monetized indirect losses
Threshold	At most EUR 20,000; justified, not set to cut capital	Lower (1,000 or 5,000), risk-based
Dates	Gross loss, reference dates, recoveries	Use the gaps: visibility, diligence, settlement
Quality	Independent review of comprehensiveness and accuracy	Reconcile with GL, IT logs, complaints, provisions, press

Exam traps

- **Net for gross.** Record gross loss and recoveries separately; net loss is derived.
- **Threshold polarity.** A higher threshold records fewer, not more, losses. Zero thresholds are fading, not dominant.
- **Boundary swap.** Market-related operational losses are *included*; it is credit-related losses already in credit RWAs that are excluded.
- **Regulation versus good practice.** Regulators require direct financial losses only; near misses and non-financial impacts are good practice.
- **Interval swap.** Concealed frauds are slow because of occurrence-to-discovery; long reporting-to-settlement gaps come from legal and regulatory processes.
- **Splitting a common-cause event** to stay under the threshold breaks the grouping requirement.
- **GL as a substitute.** The general ledger benchmarks completeness; it cannot replace the incident database.

Practice questions: ORR-4 a

Question ORR-4 a.1

Bank Q88 • AP Mock 1 Q27

Banks are required to report not only the gross loss amount associated with each operational loss event but also the reference dates of the event. Which of the following is LEAST likely to be an important reference date for an operational loss incident?

A. Date of occurrence

B. Date of accounting

C. Date of reporting

D. Date of assessment

Question ORR-4 a.2

Bank Q83 • Schweser Module Quiz 45.1 Q1 (rebuilt)

A bank employee has been manipulating suspense (transitory) accounts for a prolonged period before the fraud was detected, and the event was classified as a significant operational incident. Which interval between the incident dates is the main reason the settlement of such events typically occurs years after they began?

A. Date of reporting to date of accounting.

B. Date of discovery to date of reporting.

C. Date of occurrence to date of discovery.

D. All intervals contribute equally because each requires manual processing.

Question ORR-4 a.3

Bank Q87 • Mock 3 Q70 (rebuilt)

A severe storm damaged several branches of a regional bank. The bank paid USD 4.0 million in direct repair costs and later received a USD 2.5 million settlement from its property insurer. An operational risk analyst is preparing the loss event record for the internal loss database. Which treatment is most consistent with best practice and Basel loss data guidance?

A. Record a gross loss of USD 4.0 million and record the USD 2.5 million insurance settlement separately as a recovery, so that net loss (USD 1.5 million) can be derived.

B. Record only the net loss of USD 1.5 million, because the insurance payment has already offset the gross amount and a gross figure adds no information.

C. Delay recording the event until the insurer's final payment is received, then record a single loss of USD 1.5 million.

D. Do not record the event as an operational loss, because a natural disaster is an external cause outside the bank's control.

Question ORR-4 a.4 Bank Q85 • BT P2.T7.601.1 (rebuilt)

Which of the following is TRUE about the selection of the threshold for reporting operational losses?

A. The threshold should be set so that only tail events that drive capital are collected.

B. Basel rules prohibit banks from applying any internal loss reporting threshold.

C. Thresholds may differ across firms, but the chosen threshold must be supportable, must not be set to reduce capital requirements, and must still capture all material activities and exposures.

D. A zero threshold is the dominant practice in large institutions because it avoids the effort of estimating losses.

Question ORR-4 a.5 Bank Q84 • AnalystPrep Q.5157 (rebuilt, key corrected in the bank)

Joel and Mark, FRM Part II candidates, are discussing regulatory expectations and best practice for reporting operational loss incidents. Which statement is most likely correct?

A. Setting the loss reporting threshold at zero is now the dominant best practice, especially in large institutions.

B. Regulators require firms to record non-financial impacts such as reputational damage and customer detriment as part of internal loss data.

C. Direct losses are usually poorly captured, whereas indirect losses are almost always monetized by every firm.

D. Different events that materialize from a single failure must be grouped as a single loss to reflect the common underlying cause.

Question ORR-4 a.6 Bank Q86 • GARP PE1 Q10 (rebuilt)

A regional bank's CRO asks an operational risk manager to review the bank's process for reporting operational incidents against best practice. Which of the following statements would be most appropriate for the manager to make?

A. Material incidents should usually be reported within a few working days, while minor incidents can be included in periodic summary reporting.

B. Raising the loss reporting threshold increases the losses recorded and therefore increases operational risk capital.

C. Indirect effects such as reputational damage cannot be assessed in monetary terms because their consequences are non-financial.

D. Events caused by a single IT failure should be recorded as separate unrelated losses so that each stays below the reporting threshold.

Question ORR-4 a.7

Bank Q81 • AP Mock 1 Q46 • AnalystPrep Q.5095

Why are near-miss occurrences included in the reporting of incidents in organizations with strong risk cultures?

A. To assess the cost of close calls.

B. To determine the importance of close calls.

C. To analyze the potential consequence that was unintentionally avoided.

D. To evaluate the frequency of close calls.

Question ORR-4 a.8

Bank Q82 • BT P2.T7.23.4.1 (rebuilt)

Paula is refactoring the operational incident (loss) database as part of an update to her firm's risk and control self-assessment (RCSA) procedure under a new operational risk management framework. One step is an audit of data quality. Regarding her database audit, each of the following statements is true EXCEPT which is false?

A. Each operational incident has (at least) four important dates: occurrence, discovery, reporting, and accounting (settlement).

B. The gap between the discovery date and the settlement date should rarely exceed three months and never exceed one year; otherwise, the IT reporting system itself probably requires an upgrade.

C. A non-zero minimum threshold for loss reporting (e.g., EUR 5,000) is acceptable, provided it is supportable and not set to reduce capital requirements.

D. Although the general ledger is a good source for benchmarking, it is not a perfect substitute for a dedicated operational event database.

Solutions • ORR-4 a

Solution ORR-4 a.1

Answer: D

Bank Q88 • AP Mock 1 Q27

Step 1 – List the four reference dates

Occurrence (when the event first happened), discovery (when it was first identified), reporting (when it enters the database) and accounting (when the financial impact enters the general ledger).

Step 2 – Find the odd one out

Occurrence, accounting and reporting are on the list; "assessment" is not.
⇒ D is the least likely to be an important reference date.

Interpretation

The dates matter as much for the gaps between them as for themselves: occurrence to discovery shows visibility, discovery to reporting shows diligence (Figure 1).

Why the other options are wrong

A is incorrect. The date of occurrence is the first of the four dates.
B is incorrect. The accounting date is when the loss enters the general ledger; it fixes the year to which the loss belongs.
C is incorrect. The reporting date is when the event enters the reporting database.

LO: ORR-4 a: Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.1 Dates of Incidents and Settlement Lags

Solution ORR-4 a.2

Answer: C

Bank Q83 • Schweser Module Quiz 45.1 Q1

Step 1 – Recognize the type of event

Manipulation of suspense accounts, like salami frauds, rogue trading and data leaks, is concealed: it can go undetected for months or years.

Step 2 – Pick the interval

GARP: "Time to discovery is typically the main factor explaining the years-long gap often observed between the occurrence and the payment (settlement date) of operational risk events. It also dramatically worsens the impact."
⇒ Occurrence to discovery is the driver.

Interpretation

The original Schweser quiz asked which interval is "most likely to be the longest" and listed occurrence to reporting as a fourth option, which contains the discovery gap. The bank's rebuilt stem asks for the *main reason*, which removes that overlap.

Why the other options are wrong

A is incorrect. Reporting to accounting can take years for legal cases, but it is not what makes a concealed fraud slow.
B is incorrect. Significant incidents are reported within a few working days of discovery: usually the shortest gap.
D is incorrect. The intervals differ; for concealed fraud the detection gap dominates.

LO: ORR-4 a: Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.1 Dates of

Incidents and Settlement Lags; SchweserNotes 2026 Book 3, Reading 45, LO 45.a

Solution ORR-4 a.3 — Answer: A

Bank Q87 • Mock 3 Q70

Step 1 – What the record must hold

Basel guidance: the gross loss amount for each event, its reference dates, and any recoveries, with the drivers and causes. Table 4.1 has separate fields for recovery and for net loss.

Step 2 – Fill the fields

Gross loss USD 4.0 million; recovery USD 2.5 million (insurance); net loss $= 4.0 - 2.5 =$ USD 1.5 million, derived from the two fields.

$\Rightarrow$ Gross and recovery recorded separately show both the exposure and how well insurance mitigated it.

Interpretation

Damage to physical assets from natural disasters is a Basel event type, so the event belongs in the database however external its cause. Recording only the net figure would hide the gross exposure that modelling and RCSAs need (see the correction box in Section 4).

Why the other options are wrong

B is incorrect. Storing only the net loss hides the gross exposure and the effectiveness of the insurance.

C is incorrect. The event is recorded when it occurs and is discovered; the recovery is added when received. Waiting delays reporting and loses the gross figure.

D is incorrect. An external cause does not exempt an event: damage to physical assets is one of the seven Basel event types.

LO: ORR-4 a: Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.1 Incident Data Collection Process, Table 4.1; Dates of Incidents and Settlement Lags

Solution ORR-4 a.4 — Answer: C

Bank Q85 • BT P2.T7.601.1

Step 1 – What the regulator sets

A minimum collection threshold of EUR 20,000, and the requirement that internal loss data capture all material activities and exposures from all subsystems and locations.

Step 2 – What the firm decides

Firms may set lower thresholds (commonly 1,000 or 5,000); the choice "must be justified and should not suggest cherry-picking or manipulation of capital requirements".

$\Rightarrow$ Discretion within limits: C.

Interpretation

More than the threshold itself, GARP notes, the choice of what counts as a "loss" determines the size and materiality of incidents recorded.

Why the other options are wrong

A is incorrect. Collecting only capital-driving tail events breaks the comprehensiveness requirement and confuses loss collection with modelling.

B is incorrect. Basel sets a minimum threshold; it does not prohibit one.

D is incorrect. Zero thresholds are fading in large institutions because of the burden of reporting many small incidents.

LO: ORR-4 a: Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.1 Comprehensive Data

Solution ORR-4 a.5 Answer: D

Bank Q84 • AnalystPrep Q.5157

Step 1 – Test each claim

A: zero thresholds are a fading practice. B: regulators require only direct financial losses; non-financial impacts are good practice. C: reversed; direct losses are usually well captured, and only mature firms monetize indirect losses.

Step 2 – The grouping rule

"Different events that materialize from a single failure must be grouped as a single loss to reflect the same underlying cause." It is a regulatory requirement, sound modelling practice and needed for correct management information.

$\Rightarrow$ D is correct.

Interpretation

Grouping matters for modelling too: splitting one failure into many small losses would inflate the frequency and shrink the severity.

Why the other options are wrong

A is incorrect. Zero thresholds are becoming rare in large institutions.

B is incorrect. Overstates regulation: only direct financial losses are required.

C is incorrect. Inverts the reading on direct and indirect losses.

LO: ORR-4 a: Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.1 Comprehensive Data (grouped losses)

Solution ORR-4 a.6 Answer: A

Bank Q86 • GARP PE1 Q10

Step 1 – The reporting timetable

Firms set a maximum time for reporting in their collection policy. "Best practice dictates a risk-based approach that will not waste resources by rushing to report immaterial events. Usually, material incidents must be reported within a few working days, while minor incidents can simply be included in periodic summary reporting."

$\Rightarrow$ A is GARP's own wording.

Interpretation

The discovery-to-reporting gap measures how diligently incidents reach the risk function; a risk-based timetable keeps that gap short where it matters.

Why the other options are wrong

B is incorrect. Polarity flip: a higher threshold excludes small losses, so recorded losses fall.

C is incorrect. The "non-financial" label is misleading: indirect consequences have real financial implications, and mature firms monetize them.

D is incorrect. Events from a single failure must be grouped as one loss; splitting them to stay below the threshold is non-compliant.

LO: ORR-4 a: Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.1 Comprehen-

sive Data; Dates of Incidents and Settlement Lags

Solution ORR-4 a.7 Answer: C

Bank Q81 • AP Mock 1 Q46

Step 1 – What a near miss is

An event that follows the causal chain of a loss but where the loss was avoided by chance. Many organizations record operational "incidents" rather than "losses", including near misses, as good management practice.

Step 2 – Why record it

A healthy risk culture includes near misses in incident reporting; their importance is judged by "the materiality of the potential impact avoided by chance". They "provide lessons learned without the pain of actual losses" (GARP Ch.6).

$\Rightarrow$ The purpose is to analyze the consequence that was avoided.

Interpretation

A near miss reveals a control gap and the size of the loss narrowly avoided, so the risk can be mitigated before it materializes.

Why the other options are wrong

A is incorrect. A near miss produces no loss, so there is no cost to assess.

B is incorrect. Importance is judged as a step in the analysis; it is not why near misses are captured.

D is incorrect. Frequency is a secondary statistic; the value lies in the consequence avoided.

LO: ORR-4 a: Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.1 Comprehensive Data; Ch.6, Risk Events and Near Misses

Solution ORR-4 a.8 Answer: B

Bank Q82 • BT P2.T7.23.4.1

Step 1 – Check A, C and D

A: the four dates, as in GARP. C: a non-zero threshold below the EUR 20,000 minimum is acceptable if justified. D: the general ledger benchmarks completeness but captures only direct financial effects, not causes, indirect effects or forgone revenue.

Step 2 – Check B

Long lags are normal: concealed events stay undiscovered for years, and losses above USD 100 million at G-SIBs most often took three to five years from reporting to settlement.

$\Rightarrow$ A hard three-month or one-year cap is not a data-quality standard: B is false.

Interpretation

Long settlement lags are a modelling issue (old losses from a different business context), not a sign of a broken IT system.

Why the other options are wrong

A is incorrect. True: occurrence, discovery, reporting, accounting.

C is incorrect. True: thresholds are a firm's choice within the limits of justification.

D is incorrect. True: the GL is no substitute for a dedicated operational event database.

LO: ORR-4 a: Explain best practices for the collection of operational loss data and reporting of operational loss incidents, including regulatory expectations. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.1 Dates of Incidents and Settlement Lags, Box 4.1; Data Quality Requirements

ORR-4 • Risk Measurement and Assessment • Vardeez: UNTIERED (crash-course notes)

ORR-4 b

P3 CONCEPT

Explain operational risk-assessment processes and tools, including risk control self-assessments (RCSAs), likelihood assessment scales, and heatmaps.

Workbook: D22 Operational Risk Identification, Mitigation and Reporting • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D22 (map #75, 2 of 16 sources, notes only).
Vardeez: his crash-course notes label this LO "LO 43.b" (consolidated volume pp.135 and 136): RCSA purpose (it does not quantify risk), inherent versus residual risk, frequency, the process, limitations, output and mitigation, impact scales, the four-point likelihood scale (his Figure 43.3) and the heatmap (Figure 43.4).

Reported exam shapes

- **D22·S2** Risk and control self-assessment (RCSA): inherent and residual risk, scales, heatmap, ownership of outcomes.

What the questions look like: "which is correct" or EXCEPT items on what the RCSA is for, inherent versus residual risk, what a "1-in-10-year" rating means, why ratings are never multiplied, what a heatmap colour requires, and who owns the action plans. One question is re-filed from ORR-4 d (Swiss cheese), the factor-model tool that sits next to the RCSA.

See also: background to the reading in ORR-4 f, Section 1. Control types (preventive, detective, corrective, directive) are ORR-5 b.

1. The RCSA process

An **RCSA** evaluates the likelihood and impact of the operational risks of a business, both **inherent** (before the effect of existing controls) and **residual** (after evaluating the controls in place). It is typically annual; some firms have moved to quarterly for volatile risks. It runs as workshops facilitated by the risk function or, in larger firms, through questionnaires in risk software; a dedicated risk assessment unit (RAU) may conduct it. Participants discuss the main inherent risks, the key controls (preventive controls reduce likelihood, corrective controls reduce impact) and their effectiveness. At the end the firm should understand its inherent risks, control effectiveness and residual risks.

- **Purpose: awareness and prioritization, not measurement.** The main purpose is to prioritize risk management and mitigation. It is *not* a precise measure of exposure, "which is impossible when using an approximative, qualitative rating scale and self-assessments".
- **Evidence and back-testing.** Mature firms demand evidence of control testing before a control is rated effective, and back-test results against past incidents. Back-tests show that participants tend to **underestimate likelihood** and **overestimate impact**.
- **Variants.** RCA (risk and control assessment): the assessment must be evidenced (control testing, occurrences where controls worked, comparison with similar activities). RRSA (residual risk self-assessment): no inherent assessment, residual risk only.
- **Limitations.** Subjectivity, behavioural biases, limited data, and comparability across units assessed by different people. Remedy: standardized risk descriptions and precise rating definitions, so that "high" means the same thing everywhere.

2. Scales

Impact scales usually cover four types: financial, regulatory, customer and reputation, often with continuity of service added. Four- or five-point scales run from "insignificant" or "low" to "catastrophic" or "extreme". Financial impacts are expressed *relative* to revenue or operating income (GARP Figure 4.3: below 0.5%, 0.5% to 5%, 5% to 20%, then above), customer impacts as a share of the client base, so one scale fits units of any size: USD 100,000 is significant for a medium-sized department but minor for a large business unit.

Likelihood scales use a probability or a frequency ("once in x years"). A "1-in-10-year event" means a **10% chance of occurring within the next year**, not once over a ten-year horizon: the RCSA horizon is one year at most. History informs likelihood, but the past is not always a good predictor, especially for fast-moving risks (cyber, technology, regulatory sanctions).

Rating	Frequency of occurrence	Probability within one year
Likely	Once a year or more	Above 50%
Possible	Once in more than 1 to 5 years	20% to 50%
Unlikely	Once in 5 to 20 years	5% to 20%
Remote	Less than once in 20 years	Below 5%

3. The heatmap

The "RCSA matrix" or **heatmap** crosses likelihood and impact and colours each cell by the firm's risk appetite: **green** within appetite (regular monitoring only); **yellow** within appetite but approaching excess (active monitoring, possibly more mitigation); **orange or amber** above acceptable levels (an action plan to reduce likelihood or impact, or escalation and acceptance by management); **red** much beyond appetite (urgent mitigation plan). The colours depend on how the axes are defined.

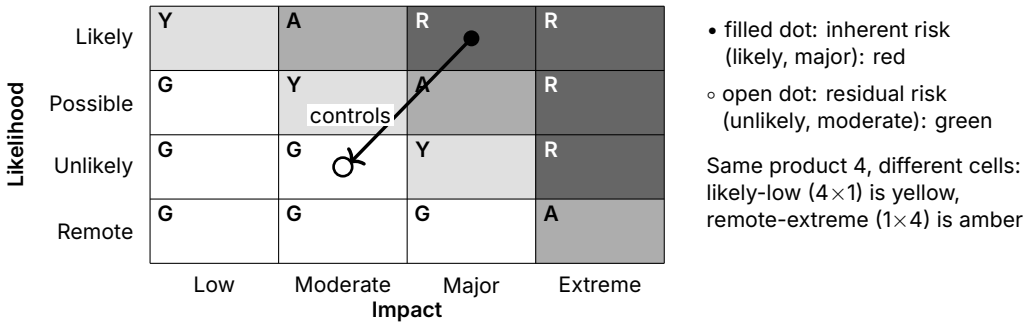


Figure 1. An illustrative heatmap consistent with the examples in the reading (likely-low yellow, remote-extreme amber, unlikely-extreme red). Colours are shown as grey levels and letters: G white, Y light grey, A mid grey, R dark grey. The arrow shows controls moving a risk from its inherent to its residual position.

Never multiply the ratings. The ratings are ordinal, non-linear and non-continuous measures. Multiplying probability by impact to reduce risks to a single number is, in GARP's words, "a still-widespread mistake". A frequent, low-impact risk and a remote, extreme one both score 4 (GARP writes them 1×4 and 4×1), yet they are not the same risk, and Figure 1 colours them differently.

4. Outcomes and ownership

Results are documented and submitted to **business-line managers for approval and sign-off**; line managers are responsible for the output and for the agreed action plans. An important value of the RCSA is to show whether a unit's control environment is in line with risk appetite. If it is, keep the controls and monitor. If a risk is above appetite, first *validate* the assessment (investigate the mitigation in place, cross-check opinions), then mitigate. Mitigation does not necessarily mean more controls: reduce transaction volumes, limit access rights, redesign or improve existing controls, or buy insurance. **Action plans are owned by the first line** (business-line managers), not by the second line, because buy-in creates the right incentives; the second or third line tracks them like audit recommendations.

Next to the RCSA: factor models (ORR-4 d, P4). The Swiss cheese model (Reason's "cumulative act model") treats each control layer as a slice with holes that open, shut and shift: one hole rarely causes harm, but a loss occurs when holes in all layers line up. Control failures should therefore be independent and compensate each other; assessing their independence is "at least as important" as assessing each control's reliability.

	RCSA	RCA	RRSA
Inherent risk	Assessed	Assessed	Not assessed
Residual risk	Assessed	Assessed	Assessed (the focus)
Evidence	Judgment; mature firms ask for control testing	Required: test results, occurrences, peer comparison	Judgment

Exam traps

- **Inherent with controls.** Inherent risk assumes the controls are absent; net of controls is residual.
- **RCSA as measurement.** It is qualitative and judgment-based; its purpose is awareness and prioritization.
- **Back-test bias reversed.** Participants underestimate likelihood and overestimate impact.
- **"1-in-10 years" as a ten-year horizon.** It is a 10% chance within the next year; horizons are one year at most.
- **Multiplying ratings.** $1 \times 4 \neq 4 \times 1$ in risk terms.
- **Absolute impact scales.** Relative scales (% of operating income or customers) fit units of any size.
- **Second-line ownership.** Action plans belong to the first line; the second or third line tracks them.
- **More controls as the only fix.** Volumes, access, redesign and insurance are also mitigation.

Practice questions: ORR-4 b

Question ORR-4 b.1

Bank Q91 • BT P2.T7.602.1

Silverfind Financial International is planning to conduct a risk control self-assessment (RCSA) for each of its business units. Which of the following is MOST LIKELY to be a feature or element of the firm's RCSA?

A. Staff within a business unit are excluded from providing input into their own business unit's RCSA scorecard in order to avoid conflicts of interest.

B. Any process with an inherent risk that is greater than its residual risk will be assigned a "red flag" because this is a situation that requires a process fix.

C. Managers will first identify and assess inherent risks by making no inferences about controls embedded in the process; i.e., controls are assumed to be absent.

D. In order to estimate realistic outcomes, risks are identified by assuming the mitigation impact of in-place controls; that is, the risk exposure sought is net of control and mitigation.

Question ORR-4 b.2

Bank Q93 • Schweser Module Quiz 45.1 Q2

Which of the following statements regarding risk assessment is most accurate?

A. Risk and control self-assessments (RCSAs) are a good mixture of qualitative and quantitative aspects.

B. The main purpose of risk assessment is to prioritize risk management and risk mitigation responses.

C. When backtesting the results of risk assessment against past incident experience, there is a tendency to overestimate the likelihood of an operational risk event.

D. When backtesting the results of risk assessment against past incident experience, there is a tendency to underestimate the impact of an operational risk event.

Question ORR-4 b.3

New • built from GARP Ch.4 (4.2)

A risk and control self-assessment (RCSA) workshop at a European asset manager has rated two risks above appetite. The second-line facilitator is drafting the follow-up memo. Which of the following statements is correct for the memo?

A. The action plans should be owned by the operational risk function that ran the workshop, because the business line is not independent of its own risks.

B. A risk rated "1-in-10-year" should be read as expected about once over ten years, so a ten-year horizon suits its assessment.

C. The action plans should be owned by the business-line managers who sign off the results and tracked by the second or third line; mitigation need not mean new controls.

D. Financial impacts should be rated in absolute currency amounts, so that the same loss receives the same rating in every department of the firm.

Question ORR-4 b.4

Bank Q89 • BT P2.T7.23.4.2 (rebuilt)

Ethan is designing the risk and control self-assessment (RCSA) process for his employer. His boss wants the process to generate reports for the board and eventually be automated. Ethan's initial design combines the two dimensions of likelihood and impact into a color-coded matrix (heatmap). Each dimension has a four-level scale numbered 1 to 4:

Likelihood	Remote $= 1$	Unlikely $= 2$	Possible $= 3$	Likely $= 4$
Impact	Low $= 1$	Moderate $= 2$	Major $= 3$	Extreme $= 4$

Regarding this RCSA process and heatmap, each of the following statements is true EXCEPT which is false?

A. A key function of the RCSA is to determine whether the control environment of an activity (or unit) is in line with the firm's risk appetite.

B. At the end of the RCSA exercise, the firm should have a good understanding of its inherent risks, control effectiveness, and residual risks.

C. Impact types commonly include financial, regulatory, customer, and reputation (with service continuity a common addition), and likelihood scales are expressed either as percentages or as frequencies of occurrence.

D. To compare loss events on a single dimension, the algorithm should multiply likelihood by impact, giving a score of 4 to both a likely-but-low-impact event (4×1) and a remote-but-extreme-impact event (1×4).

Question ORR-4 b.5

Bank Q92 • Mock 2 Q13 (rebuilt; stem clarified)

A bank uses a risk and control self-assessment (RCSA) matrix (heatmap) in which risks are plotted against a likelihood axis (remote, unlikely, possible, likely) and an impact axis (low, moderate, major, extreme). Cells use the usual four colors: green (within risk appetite, regular monitoring only), yellow (within appetite but approaching the limit), amber (above the permissible limit; exposure must be lowered or escalated for approval) and red (far beyond appetite; immediate mitigation required). In the bank's matrix, risks with an extreme impact are never green or yellow, and risks with a remote likelihood are never red. A risk is assessed as having a remote likelihood but an extreme impact. Which color is it most likely to be assigned?

A. Amber

B. Green

C. Red

D. Yellow

Question ORR-4 b.6 Bank Q104 • GARP PE1 Q15 • Mock 3 Q65 • re-filed from ORR-4 d

An operational risk manager is giving a presentation on the advantages and disadvantages of different approaches firms use to manage operational risk. The manager provides an example of a financial institution that uses the Swiss cheese model as a control structure to manage the risk of operational losses due to incorrect transaction processing. Which of the following is correct about using this control structure?

A. The failure of a single key control would directly result in an operational loss.

B. Every layer of control would have to fail in order for an operational loss to occur.

C. The probability of each control failure depends on whether the previous control failed.

D. Extreme operational losses become less likely while small operational losses become more likely.

Solutions • ORR-4 b

Solution ORR-4 b.1

Answer: C

Bank Q91 • BT P2.T7.602.1

Step 1 – Define the two risk levels

The RCSA covers the risk exposures "before the impact of existing controls has been assessed (inherent risks), and those that remain after the evaluation of the controls in place (residual risks)".

Step 2 – Apply to the first step

Inherent risk is assessed as if the controls were absent: C.

⇒ Inherent first, then controls, then residual.

Interpretation

The inherent level also tells management what could happen if the key controls fail, which is why the RCSA starts there.

Why the other options are wrong

A is incorrect. The RCSA is a *self*-assessment: the unit's own staff provide the input in workshops or questionnaires.

B is incorrect. Residual below inherent is the normal sign that controls work. A flag arises when residual risk exceeds appetite.

D is incorrect. A net-of-controls exposure is residual risk; starting there skips the inherent assessment.

LO: ORR-4 b: Explain operational risk-assessment processes and tools, including risk control self-assessments (RCSAs), likelihood assessment scales, and heatmaps. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 RCSA Process

Solution ORR-4 b.2

Answer: B

Bank Q93 • Schweser Module Quiz 45.1 Q2

Step 1 – The nature and purpose of an RCSA

RCSAs are "qualitative and largely judgement-based". "The main purpose of risk assessment is to prioritize risk management and mitigation responses"; comparable ratings make that ordering possible.

Step 2 – The back-testing result

Back-testing against past incidents shows "a tendency for participants to underestimate the likelihood while over-estimating the impact".

⇒ B is correct; C and D reverse the two biases.

Interpretation

The two biases pull in opposite directions, so a risk can land in roughly the right cell for the wrong reasons; back-testing is how mature firms check.

Why the other options are wrong

A is incorrect. RCSAs are qualitative, not a mix of qualitative and quantitative.

C is incorrect. Reversed: likelihood is underestimated.

D is incorrect. Reversed: impact is overestimated.

LO: ORR-4 b: Explain operational risk-assessment processes and tools, including risk control self-assessments (RCSAs), likelihood assessment scales, and heatmaps. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 RCSA Process; Impact and Likelihood Ratings and Assessments

Solution ORR-4 b.3 — Answer: C

New • built from GARP Ch.4 (4.2)

Step 1 – Who owns the outcome

Results are submitted to business-line managers for approval and sign-off; they are responsible for the output and for the action plans. "It is crucial for action plans to be owned by the first line (business-line managers) rather than the second line"; plans are "tracked and reported by the second line or the third line".

Step 2 – What mitigation can be

"Risk mitigation does not necessarily mean adding controls": reduce volumes, limit access rights, redesign controls, buy insurance.
$\Rightarrow$ C combines both points.

Interpretation

Ownership by the business creates the incentive to deliver; the risk function's role is to facilitate, challenge and track.

Why the other options are wrong

A is incorrect. Role misassignment: the second line facilitates and tracks; the first line owns.
B is incorrect. Scope error: a 1-in-10-year event has a 10% chance within the next year; RCSA horizons are one year at most.
D is incorrect. Relative scales (percent of revenue or operating income) make one definition fit departments of different sizes; an absolute amount significant for one unit is minor for another.

LO: ORR-4 b: Explain operational risk-assessment processes and tools, including risk control self-assessments (RCSAs), likelihood assessment scales, and heatmaps. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 Severity Assessment, Likelihood Assessment Scales, Outcome of RCSAs

Solution ORR-4 b.4 — Answer: D

Bank Q89 • BT P2.T7.23.4.2

Step 1 – Check A, B and C

A: an important value of the RCSA is to show whether the control environment is in line with appetite. B: the standard outputs are inherent risk, control effectiveness and residual risk. C: the usual impact types and the two ways of expressing likelihood.

Step 2 – Check D

The ratings are ordinal, "nonlinear, non-continuous" measures. "A still-widespread mistake is to multiply probability and impact"; "a frequent and low-impact risk (1×4) is not the same as an event with a remote probability but an extreme impact (4×1)".
$\Rightarrow$ D is the false statement.

Interpretation

The heatmap colours, set by risk appetite, rank the risks; a single product of ratings would place a near-catastrophic tail risk next to a routine nuisance (Figure 1).

Why the other options are wrong

A is incorrect. True: a key value of the RCSA.
B is incorrect. True: the three standard outputs.
C is incorrect. True: impact types and likelihood expressions as in the reading.

LO: ORR-4 b: Explain operational risk-assessment processes and tools, including risk control self-assessments (RCSAs), likelihood assessment scales, and heatmaps. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 Combining Likelihood and Impact: The Heatmap

Solution ORR-4 b.5 — Answer: A

Bank Q92 • Mock 2 Q13

Step 1 – Apply the matrix rules

Extreme impact rules out green and yellow; remote likelihood rules out red. Only amber remains.

Step 2 – Read what amber requires

Above the permissible limit: lower the likelihood or the impact, or escalate for management approval.

$\Rightarrow$ The tail risk is outside appetite even though it is remote.

Interpretation

The original stem gave only the colour definitions, but GARP notes that "the colors of the matrix and corresponding risk appetite depend on the definition of impacts and likelihood on the axes", so the answer depended on an unstated matrix. The added sentence fixes it; the bank's key (amber) matches the reading's example matrix (Figure 1).

Why the other options are wrong

B is incorrect. Green treats a remote likelihood as making an extreme impact acceptable.

C is incorrect. Red is excluded for remote risks in this matrix; in the reading's example, red is unlikely-extreme.

D is incorrect. Yellow understates the extreme impact; in the example it is the likely-low cell.

LO: ORR-4 b: Explain operational risk-assessment processes and tools, including risk control self-assessments (RCSAs), likelihood assessment scales, and heatmaps. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 Combining Likelihood and Impact: The Heatmap; SchweserNotes 2026 Book 3, Reading 45, LO 45.b (Heatmaps)

Solution ORR-4 b.6 — Answer: B

Bank Q104 • GARP PE1 Q15

Step 1 – The model

Reason: each defensive layer is a slice of Swiss cheese with holes. "The presence of holes in any one slice does not normally cause a bad outcome. Usually, this can happen only when the holes in many layers momentarily line up."

Step 2 – Apply to transaction processing

A loss from incorrect processing requires every control layer to fail at once: B.

$\Rightarrow$ With independent layers that each fail 10% of the time, three layers fail together with probability $0.1^3 = 0.001$.

Interpretation

This pleads for control layering where failure rates are independent and controls compensate each other's weaknesses, "rather than like a row of dominos". In an RCSA, it is why residual risk depends on how the controls are layered, not only on how good each one is.

Why the other options are wrong

A is incorrect. A single weakness normally causes no loss: that is the point of layering.

C is incorrect. Dependence between failures is the flaw the model warns against; it wants failures independent.

D is incorrect. Layering lowers the probability that a loss gets through; it does not shift losses from large to small.

LO: ORR-4 d: Describe the use of factor-based models that quantitatively assess operational risk, and explain the application of the Swiss cheese model and the bowtie tool. ORR-4 b: Explain operational risk-assessment processes and tools, including risk control self-assessments (RCSAs), likelihood assessment scales, and heatmaps. • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.3 Swiss Cheese: Control Layering

ORR-4 • Risk Measurement and Assessment • Vardeez: UNTIERED (crash-course notes)

ORR-4 c

P3 CONCEPT

Describe the differences among key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs).

Workbook: D22 Operational Risk Identification, Mitigation and Reporting • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D22 (map #75, 2 of 16 sources, notes only).
Vardeez: his crash-course notes label this LO "LO 43.c" (consolidated volume p.139). His Figure 43.10 sets the three indicators side by side: what each measures, an example, and its focus (KRI: future risk; KPI: current performance; KCI: control effectiveness).

Reported exam shapes

- **D22·S3** Key risk indicators, against KPIs and KCIs.

What the questions look like: classify a metric (overdue plan reviews, transactions per employee, error rates, data sensitivity); state what separates a KRI from a KCI; recognize that one metric can be all three; say what KRI thresholds express.

See also: background to the reading in ORR-4 f, Section 1. Single points of failure as resilience KRIs are in ORR-4 g; KRI reporting is ORR-6.

1. Three indicators, three questions

	Measures	GARP examples	Focus (Vardeez)
KRI	The level of exposure to a risk at a point in time: a rise or fall in its likelihood or its impact	Transactions per staff member; falling satisfaction scores; higher sales targets; key-person knowledge; data sensitivity on a server; value from the top-10 clients	Future risk
KPI	Performance or target achievement: how well the entity runs its operations	IT downtime or uptime; error rates on retail transactions; client satisfaction, net promoter score, complaints; share of services within SLAs	Current performance
KCI	Effectiveness of controls, in design or in performance	Missed due diligence items; lack of segregation of duties; errors overlooked in four-eyes checks; incomplete identification files	Control effectiveness

KRIs of likelihood and of impact. *Preventive* KRIs track the intensity of a *cause*. Likelihood KRIs: more transactions per staff member (errors), a drop in customer satisfaction (attrition), a higher sales level needed for a bonus (fraud). Impact KRIs: more proprietary knowledge held by one key employee (discontinuity if they leave), more sensitive data on a server (leakage), more value from the top-10 clients (attrition).

2. They overlap

"In practice, the same metrics can often be considered as performance indicators and risk indicators, or control indicators and risk indicators, or they may share elements of all three", especially when they signal breaches of minimum standards. Poor performance often becomes a source of risk, and a failing key control always does. Overdue confirmations of financial transactions are all three at once: poor back-office performance (KPI), a higher risk of legal disputes, processing errors or rogue trading

(KRI), and a failing control in transaction processing (KCI). In GARP's words, "a KPI turning amber becomes a KRI"; Tier-1 banks typically reclassify an issue unresolved after about three months as a KRI (ORR-6).

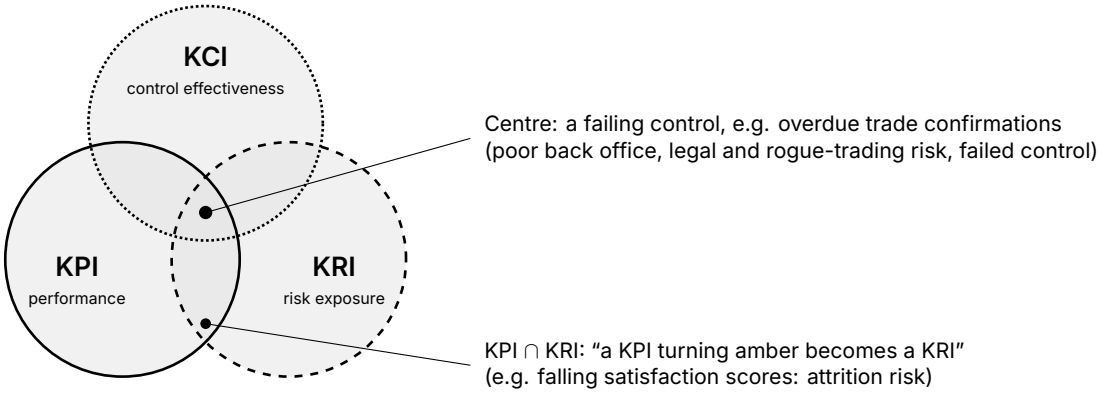


Figure 1. KPI (solid circle), KRI (dashed) and KCI (dotted) overlap; the darker the shading, the more roles a metric plays. A failing key control sits in the centre.

3. Thresholds, governance and data

- **Thresholds express appetite.** "KRI thresholds and governance reflect the risk appetite and risk tolerance levels of an organization." The metrics chosen show which objectives and risks matter most; the intervention thresholds show how strict management is (limits on key-person exposure, long-term vacancies, activity spikes, spare system capacity, untested back-ups). Box 4.2 reports KRIs against amber and red thresholds.
- **Maturity.** Comprehensive, preventive and reliable KRIs reflect a mature risk function.
- **Analytics.** Data analytics and machine learning improve the *selection and design* of preventive KRIs where data are abundant (card fraud, systems operations, payments, trading), separating true signals from normal volatility; NLP classifies event descriptions. Applications are "still nascent". They support KRIs and RCSAs; they do not replace them.

Exam traps

- **KRI and KCI swapped.** KRIs point at the risk (likelihood or impact); KCIs point at the control.
- **Overdue plan reviews.** Business continuity plans not reviewed by their due date are a KCI.
- **Error rates on transactions** are a KPI in GARP's lists; transactions per employee is a likelihood KRI.
- **Impact KRIs exist.** Data sensitivity, key-person knowledge and client concentration measure impact, not likelihood.
- **Exclusive categories.** One metric can be a KPI, a KRI and a KCI at once.
- **Uniform thresholds.** Thresholds differ by risk because they express appetite.
- **Machine learning replaces KRIs or RCSA.** It improves KRI design; it replaces nothing.

Practice questions: ORR-4 c

Question ORR-4 c.1

Bank Q94 • AP Mock 1 Q28

John, the CRO of Omega Bank, is implementing a new risk control system and introduces key risk indicators (KRIs) and key control indicators (KCIs). Some team members are confused about the difference. Which of the following best differentiates between KRIs and KCIs?

A. Both KRIs and KCIs measure the potential risks that may impact the achievement of strategic objectives.

B. KCIs identify potential risks, while KRIs measure the effectiveness of control mechanisms in mitigating those risks.

C. Both KRIs and KCIs monitor the effectiveness of risk control mechanisms.

D. KRIs identify potential risks that may hinder the achievement of an objective, while KCIs measure the effectiveness of mitigation mechanisms.

Question ORR-4 c.2

Bank Q97 • Schweser Module Quiz 45.2 Q1

One of the bank's compliance managers notices that there are two business continuity plans that have not been reviewed, and it is now past their review due date. The incomplete reviews of the business continuity plans are best described as a:

A. key assessment indicator.

B. key control indicator.

C. key performance indicator.

D. key risk indicator.

Question ORR-4 c.3

Bank Q96 • BT P2.T7.24.3.2 (rebuilt)

Wholesome Bank tracks several metrics for its retail operations: (i) error rates on customer transactions, (ii) the number of business continuity plans not reviewed before their due dates, (iii) the number of transactions processed per employee, and (iv) the sensitivity of data held on a server. The risk team wants to classify them as key risk indicators (KRIs), key performance indicators (KPIs), or key control indicators (KCIs). Which of the following classifications is most appropriate?

A. Error rates on customer transactions are a KCI.

B. An increase in transactions processed per employee is a KRI of likelihood (risk of error).

C. Business continuity plans not reviewed before due dates are a KPI.

D. An increase in the sensitivity of data held on a server is a KCI.

Question ORR-4 c.4 New • built from GARP Ch.4 (4.2)

The head of operational risk at a custody bank reviews the monthly dashboard and sees that the number of trade confirmations overdue by more than five days has tripled. Which of the following statements is most accurate?

A. The metric is a KPI only: it measures back-office performance, and it cannot serve as a KRI because it records events that have already happened.

B. The metric is a KCI only, because any metric linked to a control must be classified as a control indicator rather than as a risk indicator.

C. The metric should leave the KRI set, because KRIs must measure the impact of a risk and overdue confirmations say nothing about loss size.

D. The metric can act at once as a KPI, a KRI and a KCI: poor back-office performance, a higher risk of disputes or rogue trading, and a failing control.

Question ORR-4 c.5 Bank Q98 • BT P2.T7.602.2 (rebuilt)

Streethigh Bank is designing its key risk indicator (KRI) program for the equity settlement process. Management wants the KRIs to be preventive and to reflect its risk appetite. Which of the following statements is most consistent with best practice?

A. KRI intervention thresholds should be set identically across all processes so that results are comparable, regardless of risk appetite.

B. KRI thresholds express how strict management wishes to be in controlling and mitigating each risk, and so reflect risk appetite and tolerance.

C. A KRI should only be used if it is also a KCI, since a KRI that does not measure control effectiveness gives no useful signal.

D. KRIs should be lagging measures of realized losses, since leading measures cannot signal a change in exposure.

Question ORR-4 c.6 Bank Q95 • BT P2.T7.23.4.3

Sally is revising her firm's operational risk monitoring metrics. Her client attrition and retention metrics include likelihood key risk indicators (KRIs), such as drops in customer satisfaction, and impact KRIs, such as an increase in value generated by top-10 clients. She is also revising key performance indicators (KPIs) and key control indicators (KCIs). The net promoter score is an example of a potential KPI. Missed due diligence items are an example of a potential KCI. In regard to these metrics (KRI, KPI, and KCI), each of the following is true EXCEPT which is false?

A. Some metrics can be both KPIs and KRIs, or even share elements of all three (KPI, KRI, and KCI).

B. KRI thresholds and governance vary according to the organization's risk appetite and risk tolerance levels.

C. Natural language processing (NLP) machine learning methods are a cost-effective substitute for risk and control self-assessment (RCSA) because they eliminate the need to select and design KRIs.

D. A KPI is more likely to be a lagging metric, while a KRI is more likely to be a leading metric.

Solutions • ORR-4 c

Solution ORR-4 c.1

Answer: D

Bank Q94 • AP Mock 1 Q28

Step 1 – KRI

A KRI "provides information on the level of exposure to some operational risk at a given point in time": a rise or fall in the likelihood or impact of a risk.

Step 2 – KCI

KCIs "measure the effectiveness of controls, either in design or performance".
⇒ Risk exposure for KRIs, control effectiveness for KCIs: D.

Interpretation

A quick test for any metric: does it describe the risk (its causes or its stakes), the operation's performance, or a control?

Why the other options are wrong

A is incorrect. Treats both as risk measures; KCIs measure controls.
B is incorrect. Swaps the two definitions.
C is incorrect. Treats both as control measures; KRIs measure exposure.

LO: ORR-4 c: Describe the differences among key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs). • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 Key Risk Indicators; Key Indicators: Performance, Risks and Controls

Solution ORR-4 c.2

Answer: B

Bank Q97 • Schweser Module Quiz 45.2 Q1

Step 1 – Identify the control

The periodic review of a business continuity plan is a control; missing the due date means the control is not operating.

Step 2 – Classify

A metric of control operation is a KCI. "Business continuity plans not reviewed or updated before the set due dates" is a standard KCI example (Schweser; Vardeez's "old business continuity plans").
⇒ B.

Interpretation

The same overdue reviews also raise the impact of a future disruption, so the metric has a KRI flavour too; its primary reading is a control failure.

Why the other options are wrong

A is incorrect. "Key assessment indicator" is not one of the three types.
C is incorrect. KPIs measure how well operations run (complaints, downtime), not whether a control operates.
D is incorrect. A KRI tracks a cause of risk or its stakes; the stem describes a control lapse.

LO: ORR-4 c: Describe the differences among key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs). • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 Key Indicators; Schweser-Notes 2026 Book 3, Reading 45, LO 45.c

Solution ORR-4 c.3 — Answer: B

Bank Q96 • BT P2.T7.24.3.2

Step 1 – Classify each metric

(i) Error rates on retail transactions: a KPI in GARP's list. (ii) Plans not reviewed by their due dates: a KCI. (iii) Transactions per employee: a likelihood KRI (risk of error). (iv) Data sensitivity on a server: an impact KRI (leakage).

Step 2 – Match the options

Only B matches.
$\Rightarrow$ B.

Interpretation

Two of the four metrics are KRIs of different kinds: workload raises the chance of an error, data sensitivity raises the cost of a leak.

Why the other options are wrong

A is incorrect. Error rates measure how well the operation runs: a KPI.
C is incorrect. Overdue reviews are a control not operating: a KCI.
D is incorrect. Data sensitivity measures the stakes of a leak: an impact KRI, not a control measure.

LO: ORR-4 c: Describe the differences among key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs). • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 Definitions and Types; Key Indicators: Performance, Risks and Controls

Solution ORR-4 c.4 — Answer: D

New • built from GARP Ch.4 (4.2)

Step 1 – GARP's own example

"The failure of a control function is jointly a KPI, a KRI, and a KCI. For example, overdue confirmations of financial transactions can indicate poor back-office performance (KPI); increased risk of legal disputes, processing errors, or rogue trading (KRI); and signal control failures in transaction processing (KCI)."
$\Rightarrow$ D restates the example.

Step 2 – The general rule

"A key control failure always constitutes a source of risk", and "a KPI turning amber becomes a KRI".

Interpretation

The categories describe the angle from which a metric is read, not boxes that exclude each other (Figure 1).

Why the other options are wrong

A is incorrect. Absolute claim. Rising overdue confirmations signal a rising likelihood of future losses, which is what a preventive KRI does.
B is incorrect. Absolute claim. GARP's point is that control indicators and risk indicators overlap.
C is incorrect. Scope error. KRIs measure likelihood *or* impact; this one is a likelihood KRI.

LO: ORR-4 c: Describe the differences among key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs). • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 Key Indicators: Performance, Risks and Controls

Solution ORR-4 c.5 — Answer: B

Bank Q98 • BT P2.T7.602.2

Step 1 – What thresholds express

"KRI thresholds and governance reflect the risk appetite and risk tolerance levels of an organization"; "the thresholds of intervention express how strict management is in the control and mitigation of those risks".
⇒ B.

Interpretation

A settlement process with low appetite for failed trades will set tight amber and red levels on, say, unmatched trades; a lower-stakes process will set looser ones.

Why the other options are wrong

A is incorrect. Uniform thresholds ignore that tolerance differs by risk.
C is incorrect. KRIs measure exposure; they may overlap with KCIs but need not be control measures.
D is incorrect. Preventive KRIs are leading by design; realized losses are lagging.

LO: ORR-4 c: Describe the differences among key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs). • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 Key Indicators (KRI thresholds and governance)

Solution ORR-4 c.6 — Answer: C

Bank Q95 • BT P2.T7.23.4.3

Step 1 – Check A, B and D

A: the three overlap, and a failing control is all three. B: thresholds reflect appetite and tolerance. D: preventive KRIs are forward-looking (leading), KPIs report achieved performance (lagging).

Step 2 – Check C

Analytics and machine learning "are improving the selection and design of preventive KRIs", and NLP extracts information from event descriptions; their use "is still nascent". They help design KRIs; they do not remove the need for them or replace the RCSA.
⇒ C is false.

Interpretation

Analytics work best where data are captured automatically and continuously (card fraud, payments, trading); elsewhere judgment-based tools remain central.

Why the other options are wrong

A is incorrect. True: GARP's overlap point.
B is incorrect. True: thresholds express appetite.
D is incorrect. True as a tendency: KRIs lead, KPIs lag.

LO: ORR-4 c: Describe the differences among key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs). • **Reference:** GARP, Operational Risk and Resilience, Ch.4, 4.2 Data Analytics and KRIs; Key Indicators

ORR-5 • Risk Mitigation • Vardeez: UNTIERED (crash-course notes)

ORR-5 b

P3 CONCEPT

Compare different types of internal controls and provide examples of each type of internal control.

Workbook: D22 Operational Risk Identification, Mitigation and Reporting • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D22 (map #75, 2 of 16 sources, notes only). The map singles out "the control sibling set, preventive, detective, corrective, directive" as "a named GARP corruption operator and … worth securing even though the readings are deprioritised".
Vardeez: his crash-course notes label this LO "LO 44.b" (consolidated volume p.124), with the four types, what each does and one example each (his Figure 44.2). His label reads "Describe and provide examples of different types of internal controls, and explain the process of internal control design and control testing"; the official wording above is the one tested, and design and testing belong to ORR-5 c. ORR-5 is ROI rank 29 of 55 ("strike first").

Reported exam shapes

- **D22·S1** The control sibling set: preventive, detective, corrective, directive, with key controls, automation and testing.

What the questions look like: classify a control (training, reconciliation, exception report, continuity plan, dual authentication); spot the sibling swap (a back-up called preventive, a fraud alert called preventive); place the IIA four types against other classifications (key versus non-key, manual versus automated).

See also: Section 1 is the background for the whole of ORR-5; ORR-5 c points back to it. RCSA treatment of controls is ORR-4 b; the bowtie places preventive controls on the cause side and detective and corrective controls on the impact side (ORR-4 d).

1. Risk mitigation and the four Ts (background for ORR-5)

Risk mitigation covers all measures that reduce operational risk to a level acceptable to the firm while keeping the business running. Operational risk differs from market, credit and liquidity risk: a firm has less say over how much of it to accept. **External** operational risks (business environment, geopolitics, competition, regulation, external events) cannot be prevented, only reduced. **Internal** ones (people, processes, systems) are far more preventable, largely through internal controls. Operational risk cannot be fully eliminated, which is why every firm needs capital; part of the fees banks charge is compensation for the operational risk they bear on behalf of clients.

ISO 31000 lists four risk responses, the **four Ts**: **tolerate** (accept, for low inherent risks or for residual risks already well controlled); **treat** (internal controls and action plans, the most common response); **transfer** (insurance, outsourcing; accountability is not transferable); **terminate** (remove all exposure and its revenues; only when nothing else is acceptable).

2. The IIA classification: four types

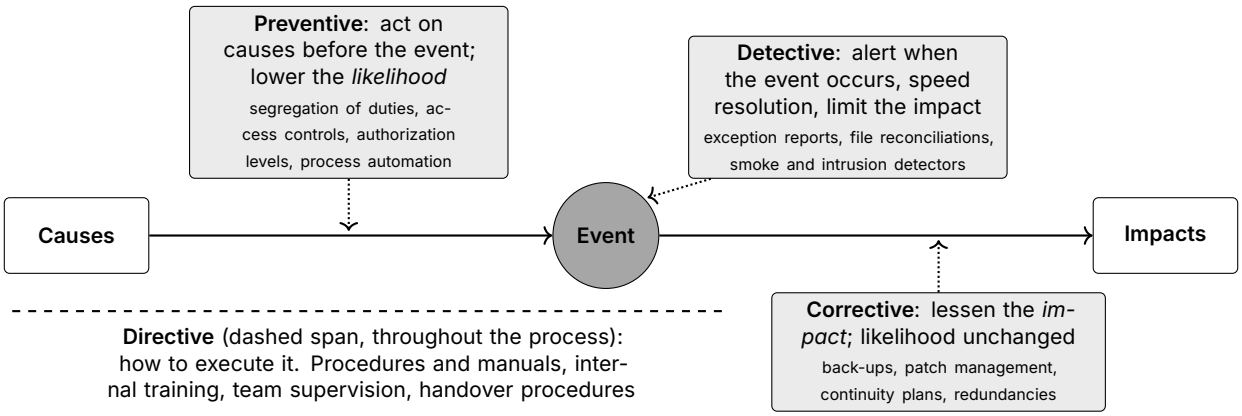


Figure 1. Where each control type acts along the path from causes to impacts (GARP Figure 5.2 examples). Dotted arrows show the point of action; the dashed span marks directive controls, which shape the whole process.

- **Preventive** controls take place before potential events and address their causes. **Segregation of duties** is perhaps the best-known fraud control: initiating, validating and settling a transaction are done by different parties (front office initiates, middle office validates, back office confirms and settles; supplier invoices are generated, validated, paid and accounted by different departments). Others: verification of records, reconciliation of signatures before executing an order, limitation of access, levels of authorization, and KYC (CDD in the EU), which also reduces other errors in account management.
- **Detective** controls alert when an incident occurs, accelerate its resolution and limit its impact: smoke alarms, intrusion detection, monitoring of suspicious network activity, credit card fraud notifications. A detective control **becomes preventive when it detects a cause**: a file reconciliation is detective if the error is already recorded, preventive if the error is caught before the transaction executes.
- **Corrective** controls lessen the impact when adverse events occur and "do not influence the likelihood of a risk happening": IT redundancies, back-ups, continuity plans, crisis communication. Backing up a computer will not stop it crashing; seatbelts and airbags do not prevent accidents.
- **Directive** controls are all the prescriptions for executing a process: policies and procedures, training and guidance, governance structure, roles and responsibilities. They do not always appear in control taxonomies, yet exist everywhere and are particularly effective when comprehensive and well executed.

Type	Acts	Mainly reduces	Typical exam examples
Preventive	Before the event, on causes	Likelihood	Segregation of duties, dual authorization, access controls, KYC
Detective	When the event occurs	Impact (faster resolution)	Exception reports, after-the-fact reconciliations, fraud alerts
Corrective	After the event	Impact only	Back-ups, redundancy, BCP, patch management, crisis communication
Directive	Throughout	Errors in execution	Policies, procedures, training, supervision

Key and non-key controls (another classification). A **key** (primary) control is sufficient on its own to prevent the risk from materializing; it can be corrective if it neutralizes the impact (a cloud back-up

of a laptop against accidental data loss). Most examples in GARP Figure 5.2 are key controls. A **non-key** (secondary) control reinforces key controls but cannot mitigate the risk on its own. Controls are also **manual or automated**: automation raises reliability but brings its own risks (ORR-5 c).

Correction to the source notes. Vardeez's Figure 44.2 describes corrective controls as "fix problems and prevent them from recurring". GARP is explicit that corrective controls "lessen the impact" and "do not influence the likelihood of a risk happening". Stopping a recurrence by acting on its cause is the job of a preventive control.

Exam traps

- **Corrective called preventive.** Back-ups and continuity plans do not prevent anything; they lessen the impact.
- **Detective called preventive.** Fraud alerts and smoke detectors fire when the event happens. Exception: a reconciliation run *before* execution is preventive.
- **Directive confused with detective.** Training and procedures tell people how to act; they do not alert.
- **Absolute claims.** Directive controls do not "always" appear in taxonomies; a detective control is not "never" preventive.
- **Classification swap.** Key, manual and automated are other classifications, not IIA types.
- **Automation reversed.** It turns human-error risk into technology and model risk, not the reverse.

Practice questions: ORR-5 b

Question ORR-5 b.1

Bank Q123 • AnalystPrep Q.5077

Controls can be classified in many ways. Which of the following is one of the control types in the classification of the Institute of Internal Auditors?

A. Preventive controls

B. Key controls

C. Manual controls

D. Automated controls

Question ORR-5 b.2

Bank Q121 • AnalystPrep Q.5066

Which of the four main categories of internal controls is implemented to reduce the likelihood of risks materializing by addressing their possible causes?

A. Detective controls

B. Corrective controls

C. Preventative controls

D. Directive controls

Question ORR-5 b.3 Bank Q125 • GARP PE2 Q14 • Mock 4 Q15

An operational risk manager at a large retail bank reviews the framework for the bank's risk mitigation controls and classifies controls as preventive, detective, corrective, or directive. Which of the following should the manager classify as a directive control?

A. An employee training program that explains the policies and procedures for reviewing new account applications

B. A notification to a credit card customer about a potentially fraudulent transaction on that customer's account

C. An implementation of an antivirus software update across all of the bank's IT systems

D. A dual-factor authentication protocol that is used to control access to critical business systems

Question ORR-5 b.4 Bank Q126 • Schweser Module Quiz 46.1 Q2

Business continuity planning (BCP) would most likely be described as a:

A. corrective control.

B. detective control.

C. directive control.

D. preventive control.

Question ORR-5 b.5 Bank Q120 • Schweser Module Quiz 44.2 Q2

An investor records its investments on its internal systems and reconciles them with the investment listing on the brokerage statement each month. This reconciliation is best described as a:

A. corrective control.

B. detective control.

C. directive control.

D. preventative control.

Question ORR-5 b.6

Bank Q119 • AnalystPrep Q.2476

XYZ Bank has an advanced credit risk management system that is capable of pricing derivatives and supporting the generation of VaR reports. The bank has a proper VaR system in place with daily reporting to the Risk Management Committee (RMC). The bank has delegated joint responsibilities for front- and back-office functions to its few employees. In light of this information, which of the following is most likely true?

A. Since the bank has an advanced credit risk management system in place, its risk management practices are satisfactory.

B. Since the bank has the capability to generate VaR reports, its risk management practices are satisfactory.

C. The reporting frequency to the RMC must be increased.

D. The joint responsibility for front- and back-office functions makes the bank more vulnerable to trading frauds.

Question ORR-5 b.7

Bank Q124 • BT P2.T7.23.6.1

Sarah is a senior risk manager at MetroBank designing a new risk mitigation system. Her plan includes: I. segregation of duties and authorization levels for high-value transactions to combat employee fraud; II. an intrusion detection system and real-time network monitoring for cyber threats; III. corrective controls such as IT system redundancies and crisis communication strategies; IV. new policies and procedures implemented through internal training; V. automation of as many controls as possible to increase reliability and free human resources. Which of the following statements about her plan is FALSE?

A. In regard to (I.), the segregation of duties is a preventative control.

B. In regard to (II.), the intrusion detection system is an example of a detective control.

C. In regard to (IV.), the policies and procedures are directive controls.

D. In regard to (V.), control automation transforms model risk into human error risk.

Solutions • ORR-5 b

Solution ORR-5 b.1

Answer: A

Bank Q123 • AnalystPrep Q.5077

Step 1 – The IIA four

GARP adopts the "simple and effective" classification of the Institute of Internal Auditors: preventive, detective, corrective and directive.

Step 2 – The other classifications

Key versus non-key classifies a control by whether it suffices on its own; manual versus automated by how it is executed.

$\Rightarrow$ Only "preventive" is an IIA type.

Interpretation

The classifications cross: a back-up can be corrective, key and automated at the same time.

Why the other options are wrong

B is incorrect. Key (primary) controls are defined by sufficiency, and span all four IIA types.

C is incorrect. Manual describes execution, not an IIA type.

D is incorrect. Automated describes execution, not an IIA type.

LO: ORR-5 b: Compare different types of internal controls and provide examples of each type of internal control. • **Reference:** GARP, Operational Risk and Resilience, Ch.5, 5.2 Preventive, Detective, Corrective, and Directive Controls; Key Controls; Control Automation

Solution ORR-5 b.2

Answer: C

Bank Q121 • AnalystPrep Q.5066

Step 1 – Match the definition

"Preventive controls are intended to reduce the likelihood of an incident. Preventive controls take place before potential risk events and address their causes."

$\Rightarrow$ C.

Interpretation

The comparison in one line: preventive lowers likelihood; detective and corrective work on impact; directive shapes how the process is run (Figure 1).

Why the other options are wrong

A is incorrect. Detective controls alert after an incident occurs.

B is incorrect. Corrective controls lessen the impact and "do not influence the likelihood".

D is incorrect. Directive controls are prescriptions for executing a process, not controls aimed at specific causes.

LO: ORR-5 b: Compare different types of internal controls and provide examples of each type of internal control. • **Reference:** GARP, Operational Risk and Resilience, Ch.5, 5.2 Preventive, Detective, Corrective, and Directive Controls

Solution ORR-5 b.3

Answer: A

Bank Q125 • GARP PE2 Q14

Step 1 – What a directive control is

"All the prescriptions and rules to execute a process: policies and procedures, training and guidance, governance structure, and roles and responsibilities."

Step 2 – Classify each option

A: training on procedures, directive. B: a fraud notification, detective. C: a software update is patch management, which GARP Figure 5.2 lists as corrective. D: dual-factor authentication is an access control, preventive.
⇒ A.

Interpretation

GARP stresses that directive controls are often missing from taxonomies, yet are particularly effective when comprehensive and well executed.

Why the other options are wrong

B is incorrect. Alerts after suspicious activity: detective.
C is incorrect. Patch management is listed under corrective controls.
D is incorrect. Access control stops unauthorized entry: preventive.

LO: ORR-5 b: Compare different types of internal controls and provide examples of each type of internal control. •
Reference: GARP, Operational Risk and Resilience, Ch.5, 5.2, Figure 5.2

Solution ORR-5 b.4 Answer: A

Bank Q126 • Schweser Module Quiz 46.1 Q2

Step 1 – What a BCP does

It keeps the business operating after a disruption: it reduces the damage, not the chance of the disruption.

Step 2 – Classify

GARP lists continuity plans among corrective controls, which "do not influence the likelihood of a risk happening, but lessen the pain if it does".
⇒ A.

Interpretation

The workbook's standing distractor: "back-ups and continuity plans are preventive because they prevent the loss of data and service". They prevent nothing; they cushion.

Why the other options are wrong

B is incorrect. A BCP does not detect anything.
C is incorrect. Although a BCP is a written plan, the reading classifies continuity planning as corrective.
D is incorrect. A BCP cannot stop the disruption from happening.

LO: ORR-5 b: Compare different types of internal controls and provide examples of each type of internal control. •
Reference: GARP, Operational Risk and Resilience, Ch.5, 5.2, Figure 5.2

Solution ORR-5 b.5 Answer: B

Bank Q120 • Schweser Module Quiz 44.2 Q2

Step 1 – When does the control act?

Monthly, after the investments have been recorded: it compares two records and flags differences that already exist.

Step 2 – Classify

A control that alerts after an error has occurred, so it can be resolved quickly, is detective.
⇒ B.

Interpretation

Timing decides. GARP: "File reconciliations, for instance, can be either detective controls, if the error is already made and recorded, or preventive controls, if the possible error is detected and

corrected before the execution of the transaction."

Why the other options are wrong

A is incorrect. Corrective controls lessen the impact (back-ups, redundancy); the reconciliation finds errors but does not itself limit the loss.
C is incorrect. Directive controls are rules and guidance; a reconciliation is a check.
D is incorrect. It would be preventive only if run before the transaction executes.

LO: ORR-5 b: Compare different types of internal controls and provide examples of each type of internal control. •
Reference: GARP, Operational Risk and Resilience, Ch.5, 5.2 (detective controls becoming preventive)

Solution ORR-5 b.6 — Answer: D

Bank Q119 • AnalystPrep Q.2476

Step 1 – Find the control gap

Front-office (initiate) and back-office (confirm and settle) duties sit with the same few people: there is no segregation of duties.

Step 2 – Why it matters

Segregation of duties is "perhaps the best-known control for fraud prevention". Without it one person can book and settle, and so conceal, unauthorized trades.
$\Rightarrow$ D.

Interpretation

Sophisticated measurement (pricing, VaR, daily reporting) does not replace a missing preventive control.

Why the other options are wrong

A is incorrect. A credit risk system says nothing about operational control gaps.
B is incorrect. VaR reporting is market risk measurement; it would not detect concealed trades.
C is incorrect. Daily reporting is already frequent; the gap is a missing preventive control.

LO: ORR-5 b: Compare different types of internal controls and provide examples of each type of internal control. •
Reference: GARP, Operational Risk and Resilience, Ch.5, 5.2 Preventive Controls (segregation of duties)

Solution ORR-5 b.7 — Answer: D

Bank Q124 • BT P2.T7.23.6.1

Step 1 – Check A, B and C

Segregation of duties and authorization levels: preventive. Intrusion detection: detective. Policies, procedures and training: directive. All three are true.

Step 2 – Check D

"Control automation also transforms the risk of human error into a technology risk and a model risk." D reverses the direction.
$\Rightarrow$ D is false.

Interpretation

Sarah's plan covers all four IIA types (III is corrective). Item V is sound only if the new technology and model risks are themselves controlled: alerts escalated, code tested, back-ups verified (ORR-5 c).

Why the other options are wrong

A is incorrect. True: segregation of duties is preventive.
B is incorrect. True: intrusion detection is detective.
C is incorrect. True: policies and training are directive.

LO: ORR-5 b: Compare different types of internal controls and provide examples of each type of internal control. ORR-5 c: Describe control automation, internal control design, and control testing, including risks and challenges that arise in these processes and ways to make them more effective. • **Reference:** GARP, Operational Risk and Resilience, Ch.5, 5.2, Figure 5.2; Control Automation

ORR-5 • Risk Mitigation • Vardeez: UNTIERED (crash-course notes)

ORR-5 c

P3 CONCEPT

Describe control automation, internal control design, and control testing, including risks and challenges that arise in these processes and ways to make them more effective.

Workbook: D22 Operational Risk Identification, Mitigation and Reporting • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D22 (map #75, 2 of 16 sources, notes only), shape S1 extends the control sibling set to key controls, automation and testing.
Vardeez: his crash-course notes label this LO "LO 44.c" (consolidated volume pp.124 and 125): key controls, the new risks of automation, the three weak designs (optimistic, collective, more of the same), the four tests, and who tests and how often (his Figure 44.3).

Reported exam shapes

- **D22·S1** The control sibling set: preventive, detective, corrective, directive, with key controls, automation and testing.

What the questions look like: what automation does to the risk profile; which designs are weak and how to fix them; which test suits which control; what makes testing effective; who tests. Knight Capital is the case.

See also: the four Ts and the four control types are in ORR-5 b (Section 1 is the background for ORR-5).

1. Control automation

Automation "significantly increases the reliability of a control": automated access restrictions that enforce segregation of duties, automated reconciliation of names and bank account details, system-based reasonableness (data validation) checks, digital face recognition, automated pricing and invoicing. Some risk managers see "no excuse" for manual controls, and automation can do what people cannot (cybersurveillance, card-fraud detection). But automation **transforms human-error risk into technology risk and model risk**: the system may fail, or the code may be wrong or become inadequate when markets change; with AI, biased training data can make a control seriously deficient.

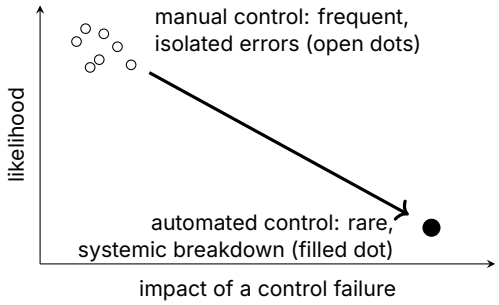


Figure 1. The "water mattress": automating a control moves the risk from high-likelihood, low-impact manual errors (open dots) to a low-likelihood, high-impact systemic failure (filled dot). Pressing one risk down raises another.

Breakdowns to plan for: type 1 errors (false positives) and type 2 errors (false negatives) in automated detection; controls disabled during system downtime; back-ups running on a full server, so no back-up exists (one IT department found a year of failed back-ups, with no alert ever sent). For

automated controls, even more than for manual ones, **early detection and escalation of alerts** are critical. **Knight Capital** (Box 5.1), then the largest market maker in the world: poorly tested new routing code turned 212 small retail orders into millions of erroneous orders in 154 stocks (397 million shares, gross exposure of nearly USD 7 billion), losing nearly USD 460 million in 45 minutes and needing a USD 400 million rescue. GARP's causes: code repurposing, inadequate version control, insufficient testing, unprioritized alerts, and no incident response procedure or person with authority to activate the circuit breaker.

2. Control design

Poorly designed controls cannot be applied effectively; they waste resources or, worse, give a false sense of security. Three weak designs:

- **Optimistic ("tick-box") controls** need exceptional ability or motivation from the controller: sign-offs for large volumes just before a deadline, accepting online terms and conditions, validating access rights from printed lists of coded names.
- **Collective controls** spread verification across several people and dilute accountability; the four-eyes (maker-checker) check is the common form. They work better between a manager and a subordinate, or across departments, with clear individual accountability.
- **"More of the same"**: answering a control failure by adding controls of the same design, such as more checkers after a collective control failed, or reinforcing an onboarding process that managers already bypass.

"More controls do not necessarily mean less risk." Good process design reduces inherent risk by organizing tasks, without adding controls. Controls are first evaluated in design, then tested for operating effectiveness.

3. Control testing

Control assessment is an essential part of residual risk assessment, and the focus of the industry is moving towards it because controls are observable and largely measurable. Four tests, in increasing scrutiny; the higher the inherent risk, the stronger the test:

Test (scrutiny rising)	What it involves	Suits
1 Self-certification or inquiry	The owner states the control works; no evidence	Secondary controls, low inherent risk
2 Examination	Written documentation of the process and evidence of results; moderate assurance	Automated controls; sampling of manual controls
3 Observation	Real-time oversight of the control being executed (or recorded); sampled	Key controls
4 Reperformance (parallel testing)	The tester reproduces the control on a sample and compares results: mystery shopping, bogus data or fictitious transactions, model validation with other data or independent code	The strongest assurance; highest risks

What makes testing effective: the **independence** of the tester from the control owner (except in self-certification); a **frequency** proportionate to the severity of the risk, higher for higher or unstable risks; and a **scope and sample** representative of the population, since small or biased samples give a false view.

Who tests. Historically internal audit; in many firms the first line now also routinely tests its key controls. The ORM function does not usually test controls itself, but needs assurance and evidence that they are assessed and that the results feed the assessment of operational risk. SOX controls (US) offer good practice to borrow.

Exam traps

- **Automation lowers everything.** It lowers likelihood but raises potential impact, and adds technology and model risk.
- **Silent automation.** An automated control without escalated alerts can fail for months unnoticed (the full-server back-up).
- **More controls as the cure.** "More of the same" dilutes accountability further; redesign instead.
- **Four eyes are always better.** Collective checks dilute accountability unless roles and accountability are clear.
- **Test and factor swapped.** Self-certification, examination, observation and reperformance are tests; independence, frequency and scope and sample are effectiveness factors.
- **Self-certification for key controls.** Only for secondary or low-risk controls.
- **The ORM function tests.** It obtains assurance; testing sits with internal audit and, increasingly, the first line.

Practice questions: ORR-5 c

Question ORR-5 c.1

Bank Q128 • AnalystPrep Q.5078

David Hans, FRM, works as the risk manager at ABC Bank. In one of his presentations, David states that a firm's internal controls are its foundation for risk mitigation. He further goes ahead to state several issues concerning internal controls. Which of the following statements is incorrect in this regard?

A. A key control is a control that can sufficiently mitigate risk on its own.

B. Controls can either be manual or automated in nature.

C. Control automation can transform human error risk into technology and model risk.

D. Automated data back-up is an essential component of control testing.

Question ORR-5 c.2

New • built from GARP Ch.5 (5.2 Control Automation)

The chief operating officer of a payments bank plans to replace a manual four-eyes check on outgoing payments with an automated, rule-based validation control. Which of the following statements best describes the effect on the bank's risk profile?

A. Automation removes the risk of control failure, because a coded rule is executed in exactly the same way every time.

B. Automation lowers both the likelihood and the impact of control failures, so the payment control no longer needs to be tested.

C. Automation converts technology and model risk into human error risk, which is easier for line managers to supervise.

D. Automation turns frequent, small manual errors into a rarer but potentially large systemic breakdown, and adds technology and model risk.

Question ORR-5 c.3

New • built from GARP Ch.5 (Box 5.1)

Knight Capital, then the largest market maker in the world, lost nearly USD 460 million in about 45 minutes after new routing code generated millions of erroneous orders. Which of the following best describes the ultimate cause identified in the reading?

A. A rogue trader who concealed positions in suspense accounts, made possible by weak segregation of duties between front and back office.

B. Code repurposing, weak version control, insufficient testing, unprioritized alerts, and no one with authority to activate the circuit breaker.

C. A cyberattack that exploited an unpatched vulnerability in the routing system, with an expired certificate that blinded network monitoring.

D. Excessive reliance on manual controls in order routing, which could not keep pace with the speed of algorithmic trading.

Question ORR-5 c.4 Bank Q129 • AnalystPrep Q.5079

An FRM candidate is preparing for May exam. In one of the open discussion forums, the candidate states that a control should be effectively designed so as to be applied effectively and hence be able to mitigate risk effectively. Ineffectively designed controls waste resources and may give unrealistic expectations resulting in vulnerabilities. He goes ahead to state the types of weakly designed controls. Which of the following is least likely a type of weakly designed control highlighted by the candidate?

A. "Optimistic control."

B. "More of the same."

C. "Collective controls."

D. "System-based data validation."

Question ORR-5 c.5 Bank Q130 • AnalystPrep Q.5080

The Bank of India is in the process of implementing an effective control system. Its risk management unit has clarified that control designs should be assessed, and if satisfactory, they can be tested to check whether they are operationally effective. Which of the following is not a type of control testing?

A. Examination

B. Observation

C. Self-certification

D. Independence

Question ORR-5 c.6 New • built from GARP Ch.5 (5.2 Control Testing)

An operational risk manager is reviewing a bank's annual control testing plan. Which of the following plans is most consistent with the reading?

A. Test the key manual control over high-value wire transfers through self-certification by its owner, who knows the control best.

B. Have the central operational risk function perform all control tests itself, because it owns the firm's operational risk framework.

C. Test the key wire-transfer control by observation or reperformance, by a tester independent of its owner and more often than low-risk controls.

D. Test every control once a year on the same small sample, so that the results are comparable across all controls of the bank.

Solutions • ORR-5 c

Solution ORR-5 c.1

Answer: D

Bank Q128 • AnalystPrep Q.5078

Step 1 – Check A, B and C

A: a key control is "sufficient, on its own, to prevent the risk from materializing". B: controls are manual or automated. C: automation "transforms the risk of human error into a technology risk and a model risk".

Step 2 – Check D

Automated back-up is a control (corrective, and an example of automation); its failure on a full server is an automated-control breakdown. It is not a type of control testing, which runs from self-certification to reperformance.

$\Rightarrow$ D is the incorrect statement.

Interpretation

The back-up example belongs to the risks of automation: a control that fails silently needs alerts and periodic testing, not the other way round.

Why the other options are wrong

A is incorrect. The standard definition of a key control.

B is incorrect. True: manual or automated.

C is incorrect. True: GARP's direction of the risk transfer.

LO: ORR-5 c: Describe control automation, internal control design, and control testing, including risks and challenges that arise in these processes and ways to make them more effective. • **Reference:** GARP, Operational Risk and Resilience, Ch.5, 5.2 Key Controls; Control Automation; Control Testing

Solution ORR-5 c.2

Answer: D

New • built from GARP Ch.5 (5.2 Control Automation)

Step 1 – What automation gains

Reliability: the rule runs every time, which removes most isolated human errors.

Step 2 – What it costs

"The shift from manual control to automated control transforms the high-likelihood/low-impact risks of isolated manual errors into the low-likelihood/high-impact risk of a systemic control breakdown", and adds the risk that the system fails or the code is wrong or outdated.

$\Rightarrow$ D (Figure 1).

Interpretation

The water mattress: effective mitigation trades the risks we do not want for risks we can accept, and then controls those. Here that means testing the rule, escalating alerts, and planning for downtime.

Why the other options are wrong

A is incorrect. Absolute claim: the system can fail or the code can be wrong; the risk changes form, it does not disappear.

B is incorrect. Polarity flip on impact, and automated controls still need testing (examination suits them).

C is incorrect. Direction reversed: human-error risk becomes technology and model risk.

LO: ORR-5 c: Describe control automation, internal control design, and control testing, including risks and challenges that arise in these processes and ways to make them more effective. • **Reference:** GARP, Operational Risk and Re-

silience, Ch.5, 5.2 Control Automation

Solution ORR-5 c.3 Answer: B

New • built from GARP Ch.5 (Box 5.1)

Step 1 – The facts

Poorly tested new code in the routing system turned 212 small retail orders into millions of erroneous orders in 154 stocks: 397 million shares, a gross exposure of nearly USD 7 billion, a loss of nearly USD 460 million in 45 minutes, and an emergency capital infusion of about USD 400 million.

Step 2 – GARP's diagnosis

"A perfect storm of code repurposing, inadequate version control, insufficient testing, lack of prioritization of alerts, and the absence of an incident response procedure and someone with the authority to activate the circuit breaker."
$\Rightarrow$ B.

Interpretation

Knight is the reading's case for automation risk: an automated process failing at machine speed, where early detection and escalation of alerts would have mattered most.

Why the other options are wrong

A is incorrect. Case cross-mapping: concealed positions and missing segregation of duties describe rogue trading cases, not Knight.
C is incorrect. Case cross-mapping: an unpatched vulnerability and an expired certificate are the Equifax lessons (ORR-9).
D is incorrect. Polarity flip: the failure was in automated systems and their controls, not in manual controls.

LO: ORR-5 c: Describe control automation, internal control design, and control testing, including risks and challenges that arise in these processes and ways to make them more effective. • **Reference:** GARP, Operational Risk and Resilience, Ch.5, Box 5.1 Case Study: The Massive Knight Capital Trading Loss

Solution ORR-5 c.4 Answer: D

Bank Q129 • AnalystPrep Q.5079

Step 1 – The three weak designs

Optimistic controls (tick-box sign-offs that need exceptional ability or motivation), collective controls (four-eyes checks that dilute accountability), and "more of the same" (adding controls of a design that already failed).

Step 2 – Place option D

System-based reasonableness (data validation) checks are one of GARP's examples of control *automation*, which increases reliability.
$\Rightarrow$ D is not a weak design.

Interpretation

The fixes follow from the diagnosis: give controllers time and information, attribute accountability clearly, and redesign rather than multiply.

Why the other options are wrong

A is incorrect. A named weak design.
B is incorrect. A named weak design.
C is incorrect. A named weak design.

LO: ORR-5 c: Describe control automation, internal control design, and control testing, including risks and challenges that arise in these processes and ways to make them more effective. • **Reference:** GARP, Operational Risk and Resilience, Ch.5, 5.2 Control Design; Control Automation

Solution ORR-5 c.5 Answer: D

Bank Q130 • AnalystPrep Q.5080

Step 1 – The four tests

Self-certification or inquiry, examination, observation, reperformance, in increasing scrutiny.

Step 2 – Place "independence"

Independence of the tester is one of the factors that influence the effectiveness of testing, with frequency and scope and sample.
⇒ D is not a type of test.

Interpretation

Independence is required for every test except self-certification, where by definition the owner reports on the control.

Why the other options are wrong

A is incorrect. Examination of documentation and evidence is a test.
B is incorrect. Observation of the control in real time is a test.
C is incorrect. Self-certification is the weakest test, but still a test.

LO: ORR-5 c: Describe control automation, internal control design, and control testing, including risks and challenges that arise in these processes and ways to make them more effective. • **Reference:** GARP, Operational Risk and Resilience, Ch.5, 5.2 Control Effectiveness

Solution ORR-5 c.6 Answer: C

New • built from GARP Ch.5 (5.2 Control Testing)

Step 1 – Match test to control

A key control over a high-risk activity calls for strong testing: observation ("suitable for key controls") or reperformance, the strongest form.

Step 2 – Apply the effectiveness factors

The tester should be independent of the control owner; frequency should be proportionate to the severity of the risk, with more frequent assessment for higher risks.
⇒ C.

Interpretation

The ladder in Section 3 maps risk to scrutiny: self-certification for secondary or low-risk controls, examination for automated controls, observation for key controls, reperformance where the stakes are highest.

Why the other options are wrong

A is incorrect. Self-certification provides no evidence and should be limited to secondary controls or low inherent risk.
B is incorrect. The ORM function does not usually test controls; it needs assurance from internal audit and the first line.
D is incorrect. Frequency should follow risk severity, and samples must be representative; small identical samples can give a false view of effectiveness.

LO: ORR-5 c: Describe control automation, internal control design, and control testing, including risks and challenges that arise in these processes and ways to make them more effective. • **Reference:** GARP, Operational Risk and Re-

silience, Ch.5, 5.2 Control Effectiveness; Control Testing and Risk Governance

ORR-7 • Integrated Risk Management • Vardeez: UNTIERED (crash-course notes)

ORR-7 b

P3 CONCEPT

Explain and differentiate between regulatory capital and economic capital requirements as prescribed in Basel regulations.

Workbook: D3 Regulatory vs Economic Capital and Capital Adequacy • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D3 (map #61, 3 of 16 sources) reports "unexpected loss, regulatory capital, economic capital" and names the discrimination: regulatory capital is a formula-driven minimum, economic capital the institution's own estimate.

Vardeez: his crash-course notes label this LO "LO 46.b" (consolidated volume p.224): the three pillars (his Figure 46.2), economic capital and the credit rating, RAROC, and risk aggregation. His wording differs from the official one: "Summarize the role of Basel regulatory capital and the process of determining internal economic capital." The official wording above is the one tested. ORR-7 is ROI rank 54 of 55 ("defer").

Reported exam shapes

- **D3·S1** Regulatory capital as a formula-driven minimum versus economic capital as the bank's own estimate.

What the questions look like: "which statement is correct" items that swap the two capitals, the three pillars, or the direction of the link between target rating, confidence level and capital. The bank's two calculation items on this LO (a UL-versus-regulatory comparison and a rating-to-confidence conversion) are left out under the TYPE rule; their ideas are covered conceptually in Questions ORR-7 b.1 and b.4.

See also: workbook D3.2 is worked under ORR-18 a; the RAROC formula is ORR-18 c; the Basel III buffers are ORR-22; operational risk capital models are ORR-4 f.

1. Capital in an ERM framework

Besides managing risks, ERM must ensure the solvency and sustainability of the firm through enough capital to cover the **unexpected losses** of all the main risk types. GARP lists four capital elements of an ERM framework: **regulatory capital** and supervision; **economic capital**; **RAROC** thresholds; and **capital aggregation** and diversification. Regulatory capital is the level *required* by the firm's risk-taking; economic capital is the level the firm *chooses*, consistent with its own risk appetite.

2. Regulatory capital: the Basel minimum

The BCBS, set up by the central bank governors of the G10, has three objectives: the solvency and soundness of financial intermediaries (the primary one, pursued through **regulatory capital**); protection of customers; and efficient, competitive institutions (pursued through fit-and-proper criteria, monitoring and reporting).

- **Basel I (1988):** capital for unexpected *credit* losses equal to 8% of risk-weighted assets, the "Cooke ratio": 8% of loans to the private sector (100% weight), 4% of uninsured mortgages (50%), 1.6% of interbank loans (20%), nothing for OECD sovereigns (0%).
- **1996:** extended to market risk with a VaR approach; **Basel II (2002):** added operational risk and rating-based credit capital, and introduced the **three pillars**. The overall 8% of RWA stayed unchanged throughout.

- **Basel III:** lessons of 2007 to 2009; a minimum liquidity ratio and a further 2.5% of RWA, built up in good times to protect in recessions and crises (see the correction box).
- **Not laws.** Basel frameworks are not legally binding; some jurisdictions enacted them (much of Basel II and III became EU law). In the US, Basel II was mandatory only for banks with assets above USD 250 billion or foreign assets above USD 10 billion, which had to adopt the AMA for operational risk.

The three pillars. **Pillar 1**, regulatory capital: a mandatory minimum for credit, market and operational risk, plus a minimum liquidity ratio (with the Sound Principles for operational risk management, revised 2021). **Pillar 2**, supervisory review: adjustments to Pillar 1 for the firm's specific risk profile, activities and quality of risk management, assessed by the regulator and the firm itself; since 2007 to 2009 often substantial capital add-ons. **Pillar 3**, market discipline: mandatory yearly or quarterly disclosure of financial and risk information.

3. Economic capital: the firm's own estimate

Regulatory capital "is not very risk sensitive and is unlikely to fully reflect the risk profile of the firm", especially under standardized approaches. Pillar 2 compensates for these insufficiencies, so **Pillars 1 and 2 combined are the closest regulatory equivalent to economic capital**. Economic capital is "the level of own funds (made of equity and subordinated debt) that a bank or an insurance company judges necessary to cover for any unexpected loss" across its risk types. Tier-1 banks estimate it with internal models plus qualitative overlays for hard-to-measure and emerging risks, and consider the interactions between risk types in normal and stressed conditions.

The credit rating link. The required level is largely set by the rating the firm wants to keep, which drives its cost of funds: more capital, a bigger buffer, better creditworthiness, cheaper funding. On average AAA firms default with probability 1 basis point a year and AA firms 3 basis points, so a bank aiming for AA covers unexpected losses at 99.97% (Figure 1). A higher target rating means a higher confidence level and more capital.

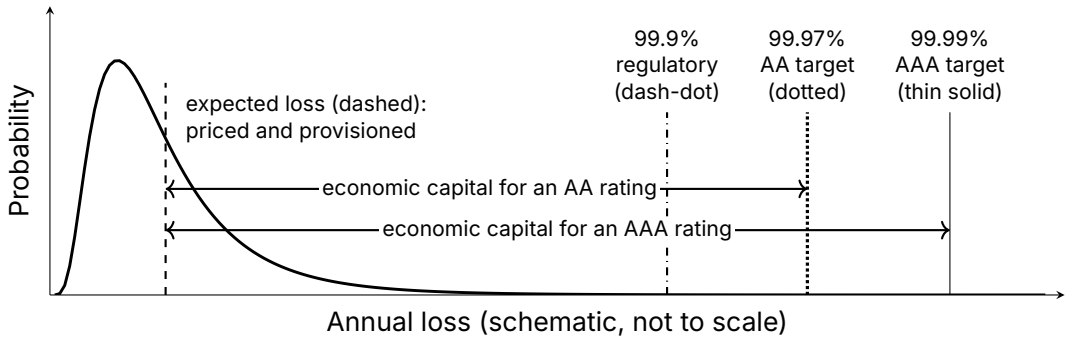


Figure 1. GARP Figure 7.4 redrawn as a loss distribution. Capital covers unexpected losses beyond the expected loss (dashed) up to the chosen confidence level: 99.97% for an AA target (dotted), 99.99% for AAA (thin solid). The 99.9% line (dash-dot) is the regulatory threshold used for credit and former AMA operational capital.

4. RAROC and aggregation

RAROC = expected after-tax risk-adjusted net income / economic capital (ORR-18). It is straightforward for credit, where EL can be estimated from history; for market risk EL is often set at 0; and it is generally *not* used for operational risk, because revenues are hard to attribute to it and economic capital is uncertain. Minimum RAROCs per transaction, client or business line let managers price deals, especially in credit.

Aggregation. Capital is first set per risk class, then aggregated with a correlation matrix. Because not all risks materialize at once, aggregated capital is *lower* than the sum of stand-alone amounts: the inter-risk diversification benefit, on top of intra-risk diversification within each class. Operational risk diversifies well because its drivers differ and it tends to move independently while credit and market correlations rise in crises: diversified operational risk capital can be 30% to 40% lower than the sum of its components. In the US, the focus has shifted from capital estimation to stress testing (CCAR).

> **Correction to the source notes.** (1) GARP Ch.7 says Basel III "introduced a countercyclical buffer that added an incremental capital requirement of 2.5% of RWA"; Schweser repeats it. The fixed 2.5% is the *capital conservation buffer*; the countercyclical buffer varies at the discretion of national supervisors between 0% and 2.5%, as GARP itself states in ORR-22. (2) Vardeez describes economic capital as "exceeding regulatory requirements". GARP does not say economic capital always exceeds regulatory capital: the two simply differ, and for some activities (securitization under Basel III, ORR-18) regulatory capital can be much higher than economic capital.

	Regulatory capital	Economic capital
Who sets it	The regulator (Basel standards, as enacted nationally)	The firm itself
Nature	A minimum from industrywide rules and formulas	The firm's estimate for its own risk profile
Purpose	Solvency and soundness of the system; customer protection	Survival, the target credit rating, capital allocation and pricing
Basis	8% of RWA (plus buffers); Pillar 1 plus Pillar 2 add-ons	Unexpected loss at a confidence level tied to the rating (AA: 99.97%)
Risk sensitivity	Low, especially under standardized approaches	High by design: internal models plus overlays
Closest link	Pillars 1 and 2 combined approximate economic capital	Feeds RAROC and the ICAAP

Exam traps

- **Sibling swap.** "Industrywide rules and formulas" and "a minimum" describe regulatory capital; "the firm's own estimate for its risk profile" describes economic capital.
- **Rating polarity.** A higher target rating needs a higher confidence level and more capital, not less.
- **Pillar swap.** Pillar 2 is supervisory review; Pillar 3 is market discipline (disclosure).
- **The 8% moved.** It stayed at 8% of RWA through 1996 and Basel II; Basel III added a buffer on top.
- **Basel as law.** Standards bind only where enacted.
- **Always larger.** Economic capital is not always above regulatory capital.
- **RAROC on regulatory capital.** The denominator is economic capital; RAROC is rarely used for operational risk.

- **Sum of stand-alone capital.** Aggregated capital is lower, because risks do not peak together.

Practice questions: ORR-7 b

Question ORR-7 b.1

New • built from GARP Ch.7 (7.3)

An internal auditor at a Canadian bank is reviewing a board paper that compares the bank's regulatory capital with its economic capital. Which of the following statements is correct for the paper to include?

A. Regulatory capital is a formula-driven minimum set by industrywide rules and is not very risk sensitive; economic capital is the bank's own estimate for unexpected losses.

B. Economic capital is set by the supervisor under Pillar 1, while regulatory capital is the bank's own internal estimate of its unexpected losses under Pillar 2.

C. Because regulatory capital is calibrated to the bank's own risk profile, the regulatory and economic figures must be equal for every business line.

D. Economic capital always exceeds regulatory capital, because it adds the bank's own buffer on top of the regulatory minimum for each business line.

Question ORR-7 b.2

Bank Q176 • AnalystPrep Q.5103 (rebuilt, key corrected in the bank)

A newly hired risk manager is presenting to the risk committee on how regulatory and economic capital help ensure an institution's solvency by covering unexpected losses. Which of the following statements is correct?

A. An enterprise risk management framework consists only of regulatory capital and economic capital.

B. Regulatory capital is the internal capital that firms estimate to reflect their own risk profile and potential unexpected losses.

C. Pillar 2 of the Basel framework concerns market discipline through mandatory risk disclosures.

D. Basel standards are not laws and are not legally binding in themselves; they take legal force only where national authorities enact them.

Question ORR-7 b.3

New • built from GARP Ch.7 (7.3 The Role of Regulatory Capital)

A risk analyst is summarizing the evolution of Basel regulatory capital for new graduates. Which of the following statements is accurate?

A. Basel I (1988) set capital for credit, market and operational risk at 8% of RWA, and Basel II raised that ratio when it introduced the three pillars.

B. Pillar 2 is market discipline through mandatory disclosures, and Pillar 3 is the supervisory review that adds capital for risks not captured by Pillar 1.

C. Basel III left the overall requirement at 8% of RWA, adding only a minimum liquidity ratio and no further capital requirement for banks.

D. The 8% of RWA set for credit risk in 1988 stayed unchanged when market risk was added in 1996 and operational risk in Basel II, which introduced three pillars.

Question ORR-7 b.4 New • built from GARP Ch.7 (7.3 The Role of Economic Capital)

The CFO of a bank that targets an AA rating asks how the target drives the bank's economic capital. On average, AAA-rated firms have a one-year default probability of 1 basis point and AA-rated firms of 3 basis points. Which of the following statements is correct?

A. The bank should size economic capital to cover unexpected losses at 99.97%; an AAA target would mean 99.99% and more capital.

B. The bank should size economic capital at 99.9%, the regulatory confidence level, because economic capital must use the Pillar 1 standard.

C. A higher target rating allows a lower confidence level, because a better-rated bank is less likely to default and needs less capital.

D. Economic capital is unrelated to the credit rating, which depends only on the bank's regulatory capital ratio under Pillar 1.

Question ORR-7 b.5 New • built from GARP Ch.7 (7.3 RAROC)

Which of the following statements about the use of economic capital in RAROC, as presented in the integrated risk management reading, is correct?

A. RAROC divides expected after-tax risk-adjusted net income by regulatory capital, which makes the measure comparable across banks.

B. RAROC is used mainly for operational risk, because operational losses can be attributed directly to the revenues that generate them.

C. RAROC is most straightforward for credit activities, where expected loss can be estimated from history, and is generally not used for operational risk.

D. For market risk, expected loss is usually large and easy to estimate, so RAROC is easier to apply to trading activities than to lending.

Question ORR-7 b.6 Bank Q174 • Mock 2 Q3 (rebuilt)

A risk manager at bank XYZ is aggregating stand-alone capital for credit risk, market risk and operational risk. Which of the following statements about the aggregated capital is correct?

A. Total aggregated capital equals the sum of the stand-alone capital amounts because each risk class must be fully covered independently.

B. Total aggregated capital is lower than the sum of the stand-alone amounts because not all risks materialize at the same time, which produces inter-risk diversification benefits.

C. Total aggregated capital is higher than the sum of the stand-alone amounts because interactions between risk classes compound losses.

D. Operational risk provides no diversification benefit because it is perfectly correlated with credit and market risk.

Solutions • ORR-7 b

Solution ORR-7 b.1 — Answer: A

New • built from GARP Ch.7 (7.3)

Step 1 – Regulatory capital

The Basel minimum: 8% of RWA plus buffers under Pillar 1, adjusted under Pillar 2. GARP: it "is not very risk sensitive and is unlikely to fully reflect the risk profile of the firm"; Crouhy (ORR-18) calls it "a set of industrywide rules and formulas" that "sets only a minimum".

Step 2 – Economic capital

The own funds the firm "judges necessary to cover for any unexpected loss", from internal models plus overlays, sized to its target rating.

$\Rightarrow$ A states the D3 discrimination.

Interpretation

The two answer different questions: the regulator's "what is the least this bank must hold?" and the bank's "what do we need to survive at our chosen confidence level?".

Why the other options are wrong

B is incorrect. Sibling swap: the regulator sets regulatory capital; the bank estimates economic capital.

C is incorrect. Regulatory capital is not calibrated to the firm's profile, and the two can differ widely by business line.

D is incorrect. Absolute claim: GARP never says economic capital always exceeds the regulatory figure; for some activities regulatory capital is the higher one (see the correction box).

LO: ORR-7 b: Explain and differentiate between regulatory capital and economic capital requirements as prescribed in Basel regulations. • **Reference:** GARP, Operational Risk and Resilience, Ch.7, 7.3 The Role of Regulatory Capital; The Role of Economic Capital; Ch.18, 18.1

Solution ORR-7 b.2 — Answer: D

Bank Q176 • AnalystPrep Q.5103

Step 1 – Legal status

"Although Basel regulatory frameworks are not laws and are not legally binding, some jurisdictions have passed additional legislation to have Basel recommendations enacted", for example in the EU.

$\Rightarrow$ D is correct.

Step 2 – Check the others

ERM covers governance, culture, appetite, risk management and four capital elements; regulatory capital is the externally set minimum; Pillar 2 is supervisory review.

Interpretation

The US example: Basel II was mandatory only for banks with assets above USD 250 billion or foreign assets above USD 10 billion.

Why the other options are wrong

A is incorrect. Too narrow: ERM includes governance, culture and appetite, and capital has four elements (with RAROC and aggregation).

B is incorrect. Describes economic capital, not regulatory capital.

C is incorrect. Pillar 3 is market discipline; Pillar 2 is the supervisory review process.

LO: ORR-7 b: Explain and differentiate between regulatory capital and economic capital requirements as prescribed

in Basel regulations. • **Reference:** GARP, Operational Risk and Resilience, Ch.7, 7.3 The Role of Regulatory Capital

Solution ORR-7 b.3 — Answer: D

New • built from GARP Ch.7 (7.3 The Role of Regulatory Capital)

Step 1 – The timeline

1988 Basel I: 8% of RWA for credit risk only. 1996: extended to market risk with VaR, "although the overall minimum requirement of 8% RWA did not change". 2002 Basel II: operational risk added, credit capital reformed, the three pillars introduced; "the overall requirement of 8% of RWA ... remained unchanged".
$\Rightarrow$ D.

Step 2 – Basel III

A minimum liquidity ratio and an additional 2.5% of RWA on top of the 8%.

Interpretation

The 8% is the constant of the story; what changed was the scope of risks covered and, with Basel II, the move beyond capital to supervision and disclosure.

Why the other options are wrong

A is incorrect. Basel I covered credit risk only, and the 8% was not raised by Basel II.
B is incorrect. Pillars swapped: Pillar 2 is supervisory review, Pillar 3 market discipline.
C is incorrect. Basel III added 2.5% of RWA on top of the 8% minimum (the capital conservation buffer).

LO: ORR-7 b: Explain and differentiate between regulatory capital and economic capital requirements as prescribed in Basel regulations. • **Reference:** GARP, Operational Risk and Resilience, Ch.7, 7.3 The Role of Regulatory Capital

Solution ORR-7 b.4 — Answer: A

New • built from GARP Ch.7 (7.3 The Role of Economic Capital)

Step 1 – Read the rating as a default probability

A 3 basis point default probability for AA means losses may exceed capital with probability 0.03%: GARP, "a bank aiming for an AA rating will calculate its economic capital such that it covers unexpected losses for any risk at a 99.97% confidence interval".

Step 2 – Move the target

AAA (1 basis point) means 99.99%, further into the tail, so more capital (Figure 1).
$\Rightarrow$ A.

Interpretation

Capital buys creditworthiness: "the larger the capital, the bigger the buffer against losses, the better the creditworthiness, the lower the costs of raising funds."

Why the other options are wrong

B is incorrect. Economic capital is the firm's own choice, set by its target rating, not by the 99.9% regulatory standard.
C is incorrect. Polarity flip: a higher rating needs a higher confidence level and more capital.
D is incorrect. GARP links the level of economic capital directly to the maintenance of the credit rating.

LO: ORR-7 b: Explain and differentiate between regulatory capital and economic capital requirements as prescribed in Basel regulations. • **Reference:** GARP, Operational Risk and Resilience, Ch.7, 7.3 The Role of Economic Capital, Figure 7.4

Solution ORR-7 b.5 — Answer: C

New • built from GARP Ch.7 (7.3 RAROC)

Step 1 – The formula

RAROC = expected after-tax risk-adjusted net income / economic capital: the numerator adjusts income for EL, the denominator is the equity needed for the risks taken.

Step 2 – Where it works

"RAROC is more straightforward for credit activities, where EL can be estimated using historical data, than for market risk, where EL is less straightforward and is often set at 0. RAROC is generally not used for operational risk."
$\Rightarrow$ C.

Interpretation

Operational risk is hard to attribute to revenues and its economic capital is uncertain, so it is managed through appetite, controls and resilience more than through RAROC.

Why the other options are wrong

A is incorrect. The denominator is economic capital, not regulatory capital.
B is incorrect. Reversed: RAROC is generally not used for operational risk.
D is incorrect. For market risk, EL is less straightforward and often set at 0.

LO: ORR-7 b: Explain and differentiate between regulatory capital and economic capital requirements as prescribed in Basel regulations. • **Reference:** GARP, Operational Risk and Resilience, Ch.7, 7.3 RAROC: Risk-Adjusted Return on Capital

Solution ORR-7 b.6 — Answer: B

Bank Q174 • Mock 2 Q3

Step 1 – From stand-alone to aggregate

Capital is first set per risk class, then aggregated through a correlation matrix (GARP Figure 7.5).

Step 2 – Why the total is smaller

"Because not all risks will materialize at the same time", and the classes follow different dynamics, aggregated capital is lower than the sum of the stand-alone amounts: the inter-risk diversification benefit.
$\Rightarrow$ B.

Interpretation

Operational risk adds large benefits: it typically has low correlation with financial risks, and diversified operational risk capital can be 30% to 40% lower than the sum of its components.

Why the other options are wrong

A is incorrect. A simple sum assumes perfect correlation and ignores diversification.
C is incorrect. Reverses the effect of imperfect correlation.
D is incorrect. Operational risk has low, not perfect, correlation with credit and market risk.

LO: ORR-7 b: Explain and differentiate between regulatory capital and economic capital requirements as prescribed in Basel regulations. • **Reference:** GARP, Operational Risk and Resilience, Ch.7, 7.3 Risk Aggregation for Capital Assessment

ORR-8 • Cyber-resilience: Range of Practices • Vardeez: UNTIERED (crash-course notes)

ORR-8 e

P3 CONCEPT

Describe practices for the governance of risks of interconnected third-party service providers.

Workbook: D2 Outsourcing and Third-Party Risk • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D2 (outsourcing, map #51, 3 of 16 sources). The map gives its modern angle as concentration risk in critical service providers and its resilience implications, which this reading defines.

Vardeez: untiered; ORR-8 is rank 8 of 55. Under "LO 47.e" (consolidated volume pp.40 to 41) his crash-course notes list six areas: governance (framework, roles, risk analysis, monitoring), business continuity and availability, confidentiality and integrity, visibility of interconnections, auditing and testing, resources and skills.

Reported exam shapes

- **S2** (D2) Concentration risk in a critical service provider and its resilience implications.

What the questions look like: "which practice is consistent" items on what a third party is, which risks the outsourcing framework must analyse, what supervisors expect (inventory, sub-outsourcing visibility, audit rights) and who stays responsible. Distractors move responsibility to the provider or the supervisor, or read concentration risk as industry-wide systemic risk.

See also: workbook A23.2 also tags this LO; it is worked under ORR-1 d. Workbook D2.2 (tagged ORR-12 a, ORR-13 a, ORR-4 g) applies the concentration shape to SR 13-19. The report's definition and structure are in ORR-8 b (P1), Section 1.

1. Who counts as a third party

All jurisdictions find it hard to gain assurance over cyber-resilience at one remove: regulators over banks, and banks over their providers. Banks lack control and visibility over third-party systems they depend on. For this report "third parties" is read broadly: **(i) all forms of outsourcing, including cloud**; **(ii) standardised and non-standardised services and products not usually seen as outsourcing** (power supply, telecommunication lines, commercial hardware and software); **(iii) interconnected counterparties**, financial or not, including FMIs (payment and settlement systems, trading platforms, central securities depositories, central counterparties). Third parties enlarge the regulators' perimeter of interest, and cloud makes it shared, so banks must build resilience "in partnership with third parties" (Figure 1, left).

2. The six areas of practice

Area	What banks are expected to do	Supervisory practice and examples
Governance	A board- or management-approved outsourcing framework: roles and responsibilities, what may be outsourced and on what conditions, risks to analyse before selection or renewal, recurring monitoring and risk assessments. A contractual framework: rights, obligations, a written detailed contract, also for intragroup outsourcing. Identify and prioritise interconnections; classify and respond to incidents per the service agreements	Intrusive on-site inspections of the framework, risk assessments and contracts; periodic off-site statements; prior notification or authorisation of material (cloud) outsourcing via questionnaires (not harmonised); thematic self-assessments; direct engagement with systemic providers (Australia); right to audit written into contracts (the Netherlands); regulatory cloud summits (Box 8.9)
Business continuity and availability	Business impact analysis; recovery objectives set **end to end** for critical activities; align critical suppliers' (and subcontractors') continuity plans with the bank's; planned redundancy for a **prompt transfer to a different provider**; test periodically. Advanced regulators: realistic, probable disruption scenarios, **at least yearly**, with providers in collaborative tests	Italy: scenarios must include catastrophic events at essential operators and third-party infrastructure (large cyberattacks). Expectations still centre on each bank's *standalone* continuity, an opportunity to extend testing across the ecosystem
Confidentiality and integrity	Contract clauses on confidentiality and security; verify, assess and monitor the provider's security practices; comply with personal-data and IP rules	Cloud rules on data location, segregation, use limits, security and exit; Luxembourg bars cloud staff from a bank's data without its explicit agreement and a mechanism to detect and control access; encryption under the bank's control; client consent
Visibility of interconnections	Inform the supervisor of material outsourcing; keep an **inventory of outsourced functions**; receive regular reports (service levels, controls); in some jurisdictions see **sub-outsourcing**	Luxembourg: hardware and software linked to each function; FFIEC and CPMI-IOSCO: connections and information flows; ISO, NIST, COBIT: identify and categorise suppliers
Auditing and testing	Guarantee **rights to inspect and audit**, cascaded to significant subcontractors in some jurisdictions	Rights granted directly to supervisors (France, Switzerland, Singapore); opinions may rest on the provider's external auditor, **pooled audits** (eight European banks jointly audited one cloud provider, June 2018) or the provider's internal audit; how to test compliance is not aligned; red teaming of interconnections (TIBER-EU can cover outsourced critical functions)
Resources and skills	Enough qualified staff to monitor providers beyond mere compliance, even if key people leave; external experts identified in advance	Belgium: monitoring and replacement plan for key staff; on-site checks of skills; CISSP-certified staff or ISO 9001 providers add assurance

3. Concentration risk and who stays responsible (shape S2)

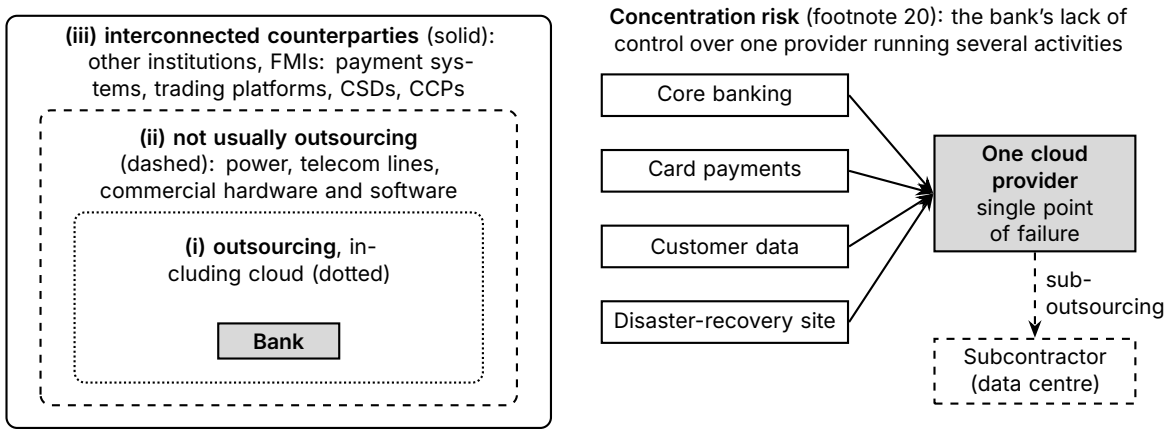


Figure 1. Left: the three groups of third parties, from the innermost dotted ring outwards. Right: concentration in one provider, with a dashed sub-outsourcing link the bank should be able to see. In this report concentration risk is the firm's lack of control over a single provider, not systemic risk to the industry.

- **Definition.** The risk list of the framework includes concentration risk, and footnote 20 pins it down: "not ... the potential systemic risk to the industry as a whole, but rather ... the potential lack of control of an individual firm over one single provider as multiple activities are outsourced to the same service provider."
- **Resilience implications.** One provider is a single point of failure for every activity it runs. The bank answers with the continuity tools above: end-to-end recovery objectives, the provider's plans aligned with its own, planned redundancy and an exit route to another provider (the opposite of vendor lock-in), and yearly tests on realistic scenarios that include the provider's failure.
- **Responsibility stays with the bank.** In Luxembourg, specialised providers ("PSFs") are licensed and supervised like banks, yet "the ultimate responsibility remains with the institution"; GARP warns that banks may then neglect monitoring and audit, thinking the supervisor does it (Box 8.8).
- **The supervisors' blind spot.** Mandates over providers vary; a **supervisory college** model for large, internationally active providers, cloud in particular, could cover the gaps from mandate limits and fragmentation.

Correction to the source notes. (1) Vardeez and SchweserNotes list seven risks for the outsourcing risk analysis (strategic, compliance, security, business continuity, vendor lock-in, counterparty, access). GARP lists **ten**: add **country, contractual and concentration risk**. Concentration is the reported exam shape, so use GARP's list. (2) SchweserNotes says banks "could also be required to transfer data to the cloud" and that Luxembourg lets cloud providers access a bank's data "only in instances when the bank is unable to access the cloud". GARP says neither: data *transferred* to the cloud must be covered by a contractual clause, and Luxembourg bars cloud staff from a bank's data without its explicit agreement and without a mechanism for the bank to detect and control access.

Exam traps

- **Scope.** Third parties include power, telecom lines, hardware, software and FMIs, not just outsourcing contracts; cloud is inside the outsourcing framework.
- **Concentration.** The firm's lack of control over one provider running several activities; not industry-wide systemic risk left to supervisors.

- **Role misassignment.** Ultimate responsibility never moves to the provider, a licensed PSF or the supervisor.
- **Risk list.** Ten risks; liquidity risk is not one of them.
- **Audit rights.** Some jurisdictions grant them directly to supervisors; pooled audits and the provider's external auditor's report can be accepted.
- **Testing.** At least yearly on realistic scenarios (advanced regulators); compliance-testing methods are not aligned across jurisdictions.
- **Vendor lock-in** is the inability to withdraw and absorb or transfer the activity; a credible second provider reduces it.

Practice questions: ORR-8 e

Question ORR-8 e.1

Bank Q205 • AnalystPrep Q.4478

In the context of cyber-resilience practices, which of the following is/are considered (a) third-party(ies)?

A. Cloud computing services

B. Computer hardware

C. Trading platforms

D. All of the above

Question ORR-8 e.2

Bank Q189 • AnalystPrep Q.4266 (rebuilt) • filed under ORR-8 a

According to the Basel Committee's report, regulated institutions' greater use of automation, third-party service providers and cloud services affects cyber-resilience in which of the following ways?

A. The attack surface grows and is accessible from anywhere, the perimeter of interest to regulators becomes bigger with third-party use, and cloud services make that perimeter shared

B. Outsourcing data processing to third parties shrinks the regulators' perimeter of interest because data is held outside the institution

C. Cloud services make the perimeter the sole responsibility of the cloud provider, so the bank's own cyber-resilience duties fall away

D. Greater automation reduces the attack surface, which lowers the incentive for cyber-adversaries to increase their capabilities

Question ORR-8 e.3

Bank Q204 • Schweser Module Quiz 49.2 Q2

Which of the following risks is least likely to be included in the risk analysis conducted as part of an outsourcing risk management framework?

A. Strategic risk.

B. Liquidity risk.

C. Compliance risk.

D. Vendor lock-in risk.

Question ORR-8 e.4 Bank Q206 • bank-written, GARP practice-exam style

A mid-sized bank is moving its payment-processing and customer-data storage to a cloud service provider that itself uses several subcontractors. The CRO asks an operational risk manager to design the bank's governance of this third-party relationship so that it is consistent with typical supervisory expectations on third-party cyber-resilience. Which of the following actions would be most appropriate for the manager to recommend?

A. Run scenario analyses of provider disruptions only once every three years, after the contract is renewed.

B. Treat the cloud arrangement as outside the outsourcing framework because the provider, not the bank, operates the infrastructure.

C. Rely on the provider's own policies for incident response and recovery without aligning them to the bank's policies.

D. Maintain an inventory of outsourced functions and obtain visibility into the provider's sub-outsourcing arrangements.

Question ORR-8 e.5 New • built from GARP Ch.8, Section 8.6 and Box 8.8

The head of internal audit at a Dutch bank must give the audit committee assurance over a cloud service provider that hosts two of the bank's critical functions. Seven other European banks use the same provider. Which of the following approaches is consistent with the supervisory practices observed by the Basel Committee?

A. Rely on the provider being a licensed specialist provider, since a licence moves ultimate responsibility for the outsourced functions to the provider.

B. Base the audit opinion on a pooled audit organised with the other banks, or on the provider's external auditor's report, where the jurisdiction accepts it.

C. Keep the right to inspect and audit with the bank alone, since no jurisdiction grants such rights directly to supervisors.

D. Treat the provider's compliance testing as settled, since most regulations are aligned on how compliance should be verified.

Question ORR-8 e.6 New • built from GARP Ch.8, Section 8.6 and footnote 20

A mid-sized European bank runs core banking, card payments, customer-data storage and its disaster-recovery site on one cloud service provider, which sub-outsources data-centre operations. The head of third-party risk is drafting a paper for the board on the bank's concentration risk and its resilience implications. Based on the Basel Committee's range of practices, which of the following statements should the paper include?

A. Concentration risk here means the systemic risk to the banking industry from many banks using one provider, so it is for supervisors to address rather than for the bank.

B. Continuity testing can stay confined to the bank's own systems, because observed supervisory expectations focus on each institution's standalone business continuity.

C. Concentration risk here means the bank's possible lack of control over one provider running several of its activities; the bank should set end-to-end recovery objectives and plan a prompt transfer to another provider.

D. Keeping the disaster-recovery site with the same provider is preferable, because adding a second provider would raise the bank's vendor lock-in risk.

Solutions • ORR-8 e

Solution ORR-8 e.1

Answer: D

Bank Q205 • AnalystPrep Q.4478

Step 1 – Recall GARP's broad definition

"Third parties" include "(i) all forms of outsourcing (including cloud computing services); (ii) standardised and non-standardised services and products that are typically not considered outsourcing (power supply, telecommunication lines, commercial hardware and software, etc); and (iii) interconnected counterparties such as other institutions (financial or not) and FMIs (eg payment and settlement systems, trading platforms, central securities depositories and central counterparties)".

Step 2 – Place each option

Cloud services are group (i), hardware group (ii), trading platforms group (iii).
$\Rightarrow$ All three: D.

Interpretation

The definition is broad because the bank's cyber-resilience depends on all of them, whether or not there is an outsourcing contract.

Why the other options are wrong

A is incorrect. True but incomplete: cloud is group (i), but B and C also qualify.
B is incorrect. True but incomplete: commercial hardware is group (ii).
C is incorrect. True but incomplete: trading platforms are interconnected counterparties, group (iii).

LO: ORR-8 e: Describe practices for the governance of risks of interconnected third-party service providers. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.6; SchweserNotes 2026 Book 3, Reading 49, LO 49.e

Solution ORR-8 e.2

Answer: A

Bank Q189 • AnalystPrep Q.4266 • filed under ORR-8 a

Step 1 – Automation and integration

More automation and integration with third-party providers and customers produce "an attack surface that is growing and is accessible from anywhere, and it incentivises cyber-adversaries to increase their capabilities".

Step 2 – The regulators' perimeter

"Increased use of third-party providers means that the perimeter of interest to financial sector regulators has gotten bigger, and greater use of cloud services means that the perimeter is also shared."
$\Rightarrow$ A states both effects.

Interpretation

"Shared service models require regulated institutions to think differently about how they build and maintain their cyber-resilience in partnership with third parties." Shared does not mean transferred: that is the root of every governance practice in Section 8.6. The bank filed this question under ORR-8 a (P4); it sits here because it explains why third-party governance matters.

Why the other options are wrong

B is incorrect. Polarity flip: third-party use makes the perimeter bigger, not smaller.
C is incorrect. Role misassignment: the perimeter is shared, not handed over; the bank keeps its duties.

D is incorrect. Polarity flip: automation and integration enlarge the attack surface and raise adversaries' incentives.

LO: ORR-8 a: Define cyber-resilience and compare recent regulatory initiatives in the area of cyber-resilience. ORR-8 e: Describe practices for the governance of risks of interconnected third-party service providers. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.1

Solution ORR-8 e.3 — Answer: B

Bank Q204 • Schweser Module Quiz 49.2 Q2

Step 1 – List the risks GARP expects to be analysed

Strategic, compliance, security, business continuity, vendor lock-in, counterparty, country, contractual, access and concentration risk.

Step 2 – Check the options

Strategic (A), compliance (C) and vendor lock-in (D) are on the list; liquidity risk is not.
$\Rightarrow$ B.

Interpretation

The analysis targets risks that arise from the service relationship itself. Liquidity is a balance-sheet risk of the bank, not a risk of the outsourcing arrangement. Note that the full list has ten items, three more than Vardeez and SchweserNotes give (see the correction box).

Why the other options are wrong

A is incorrect. Strategic risk is explicitly listed.
C is incorrect. Compliance risk is explicitly listed.
D is incorrect. Vendor lock-in risk is listed: "the general ability of an institution to withdraw from the service provider and to absorb the outsourced activity or transfer it to another service provider".

LO: ORR-8 e: Describe practices for the governance of risks of interconnected third-party service providers. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.6 (Governance of Third-Party Connections); SchweserNotes 2026 Book 3, Reading 49, LO 49.e

Solution ORR-8 e.4 — Answer: D

Bank Q206 • bank-written, GARP practice-exam style

Step 1 – Visibility expectations

Supervised institutions "are commonly expected to maintain an inventory of outsourced functions and to receive regular reports from service providers"; "some jurisdictions also require sub-outsourcing activities to be visible for the supervised entities so that the associated risks can also be managed".
$\Rightarrow$ D matches.

Step 2 – Test the other options

Continuity testing, the scope of the framework and the alignment of incident plans all have explicit expectations that A, B and C contradict.

Interpretation

With several subcontractors behind the provider, the bank's lack of control and visibility is the core problem; inventory plus sub-outsourcing visibility is the first answer to it.

Why the other options are wrong

A is incorrect. Advanced regulators expect tests for critical activities based on realistic and probable disruptive scenarios "conducted at least on a yearly basis", not every three years.

B is incorrect. Cloud computing is explicitly a form of outsourcing within the third-party framework.
C is incorrect. Regulations stress "aligning the business continuity plans of critical suppliers (and their subcontractors) with the needs and policies of the financial institution".

LO: ORR-8 e: Describe practices for the governance of risks of interconnected third-party service providers. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.6 (Visibility of Third-Party Connections; Business Continuity and Availability)

Solution ORR-8 e.5 — Answer: B

New • built from GARP Ch.8, Section 8.6 and Box 8.8

Step 1 – The audit right

Most requirements make supervised organisations guarantee "rights to inspect and audit" their providers; some cascade the right to significant subcontractors, and France, Switzerland and Singapore grant it directly to supervisors.

Step 2 – The basis for the opinion

"For several jurisdictions the audit opinion on the outsourcing arrangements may be formed based on the report of the service provider's external auditor. Others accept pooled audits, organised by multiple financial institutions", or the provider's internal audit under conditions. In June 2018 eight European institutions jointly audited a common cloud provider.
$\Rightarrow$ B.

Interpretation

Pooled and shared audit reporting on critical interconnections can make audits more effective and efficient. It does not change who is accountable: the bank still forms and owns the opinion.

Why the other options are wrong

A is incorrect. Role misassignment: even for licensed specialist providers (Luxembourg's PSFs) "the ultimate responsibility remains with the institution".
C is incorrect. False fact: France, Switzerland and Singapore grant the right directly to supervisory authorities.
D is incorrect. False fact: "most regulations are not aligned in terms of how compliance should be verified or tested".

LO: ORR-8 e: Describe practices for the governance of risks of interconnected third-party service providers. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.6 (Auditing and Testing) and Box 8.8

Solution ORR-8 e.6 — Answer: C

New • built from GARP Ch.8, Section 8.6 and footnote 20

Step 1 – Define concentration risk in this report

"Concentration risk" here "does not refer to the potential systemic risk to the industry as a whole, but rather to the potential lack of control of an individual firm over one single provider as multiple activities are outsourced to the same service provider".
$\Rightarrow$ A firm-level risk the bank must manage.

Step 2 – The resilience response

Recovery and resumption objectives are set "for critical business activities from an end-to-end perspective"; plans include "planned redundancy, so as to ensure the prompt transfer of outsourced activities to a different provider"; critical suppliers' continuity plans are aligned with the bank's; tests use realistic scenarios at least yearly.

⇒ C.

Interpretation

Four activities, including the recovery site, on one provider (and its subcontractor) is a single point of failure. The paper should map the dependency end to end, align and test the provider's plans with the bank's, and keep a real exit route.

Why the other options are wrong

A is incorrect. Scope error: footnote 20 explicitly excludes industry-wide systemic risk from the meaning used here.

B is incorrect. True fact, wrong conclusion: observed expectations do centre on standalone continuity, but where critical activities depend on third parties regulators stress aligned plans and testing, and the report sees room to extend testing across the ecosystem.

D is incorrect. Polarity flip: vendor lock-in is the inability to withdraw and transfer the activity; a second provider reduces it, while a recovery site at the same provider fails with the production systems.

LO: ORR-8 e: Describe practices for the governance of risks of interconnected third-party service providers. • **Reference:** BCBS (2018), GARP ORR Ch.8, Section 8.6 (Governance of Third-Party Connections, footnote 20; Business Continuity and Availability)

ORR-17 • Stress Testing Banks • Vardeez: IMPORTANT

ORR-17 a

P3 CONCEPT

Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital Assessment Program (SCAP) stress tests.

Workbook: C5 Basel III Post-Crisis Reforms and Stress-Test Regimes • Tier C C9 Stress-Testing Practices and Scenario Design • Tier C

WHAT IS TESTED HERE

Why P3. Tier C workbook topic: C5 sits at #30 on the topic map (4 of 16 sources) and C9 at #38 (3 of 16 sources). Neither section is in your August 2026 recall.
Vardeez: "Pre-SCAP vs post-SCAP" is theme 4 of his ORR list and the map's Vardeez focus for this LO. His notes label it "LO 56.a" (consolidated volume p.177; ORR-17 ranks 43 of 55 there, DEFER tier): a pre/post-SCAP table and a four-test comparison of disclosure.

Reported exam shapes

- **C5·S1** Pre-SCAP versus post-SCAP features of stress testing.
- **C5·S5** The SCAP / CEBS / EBA / CCAR sibling swap: which banks failed, base versus stress disclosure, which risk weights.
- **C9·S3** The SCAP / EBA / CCAR sibling swap on which regime did what.

What the questions look like: statement selection ("which statement in the training module is correct"). Each wrong option attaches a true feature to the wrong regime or year, or flips a pre/post-SCAP feature. No calculations. The numbers that matter are facts: 19 banks, 4% Tier 1 common, USD 75 billion, EUR 24 billion.

See also: workbook C9.2 carries the C9·S3 swap in its option C (SCAP against EBA 2011); it is worked under ORR-17 b. Modelling losses, revenues and the balance sheet over the horizon is ORR-17 c (P4, not built).

1. Why supervisory stress tests became the tool

There are three kinds of capital (and liquidity): the capital you *have*, the capital you *need* to support your business, and the capital the regulators *think* you need. Regulatory ratios, banks' own economic capital models and stress tests all try to size the second. Before failing or nearly failing, Bear Stearns, Washington Mutual, Fannie Mae, Freddie Mac, Lehman and Wachovia were adequately or even well capitalized under the regulatory rules in their public filings. Once those ratios lost credibility, broad-based supervisory stress testing became the new tool.

- **Two components** of a credible macro-prudential programme in a crisis: a credible estimate of the capital "hole", and a credible way to fill it. For SCAP the backstop was the Treasury's Capital Assistance Program (CAP), which stood ready to inject equity. CAP is a funding backstop, not a stress test, and no SCAP bank needed to draw on it.
- **Macro-prudential** supervision looks at the banking system as a whole; **micro-prudential** supervision looks at the safety of one institution.
- **"Pop quiz".** The crisis tests were sprung on banks at short notice, so they were hard to manipulate, revealed genuinely new information, and helped restore trust.

2. What SCAP changed (Vardeez's focus, shape C5·S1)

SCAP (March 2009) was the first macro-prudential stress test of the crisis, but the change at bank level was just as large. GARP's Table 17.2:

Pre-SCAP	Post-SCAP
Mostly single-factor shocks (or a handful)	Broad macro scenario with market-wide stress
Product or business-unit level	Comprehensive and firm-wide
Static	Dynamic and path dependent
Not usually tied to capital adequacy	Explicit post-stress common equity threshold (a going concern)
Losses only	Losses, revenues and costs

What SCAP did not change: it imposed one common supervisory scenario on every bank. Asking banks to submit results under their *own* baseline and stress scenarios, in addition to the common one, came with CCAR from 2011 (ORR-17 b).

3. The regimes, 2009 to 2012 (shapes C5·S5 and C9·S3)

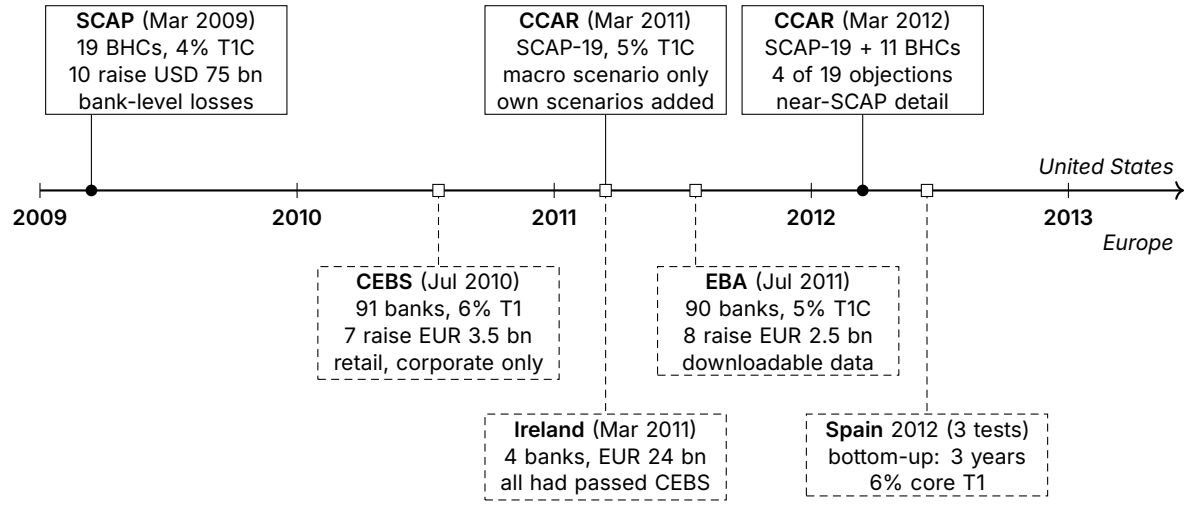


Figure 1. The macro-prudential stress tests in GARP Tables 17.1 and 17.3. US exercises sit above the line (filled circles, solid boxes); European exercises sit below it (open squares, dashed boxes). T1C is the Tier 1 common (core) ratio; the percentages are the post-stress hurdles.

- **Which banks failed.** SCAP: ten of the 19 had to raise capital, and none drew on CAP. CEBS 2010 looked mild (seven of 91), and markets reacted benignly until Ireland requested EU and IMF assistance a few months later. The four Irish banks, *all of which had passed CEBS*, then needed EUR 24 billion in a March 2011 exercise run largely by outside advisers (BlackRock). EBA 2011: eight of 90; five of the 25 Spanish banks did not pass, yet the required raise was EUR 0 once provisions and mandatory bond conversions counted. Spain then ran three more tests in 2012.
- **Which risk weights.** The US tests (SCAP, CCAR) used Basel I weights, which are not sensitive to obligor ratings. The European tests used Basel II weights, which are, so EBA banks needed stress *migration matrices* to project the whole future ratings distribution, not just defaults. A bank may need capital under one regime and not the other, which complicates US against Europe comparisons.
- **Scenario and horizon.** SCAP: two years, three macro variables (GDP growth, unemployment, house prices) plus an instantaneous historical market shock (30 June to 31 December 2008). EBA

2011: over 70 trading-book risk factors, eight macro factors for each of 21 countries, sovereign haircuts in seven maturity buckets. CCAR: nine quarters, because it starts from Q3 balance sheets. Every test insisted, to varying degrees, on common equity as the capital measure; CEBS 2010 still allowed some hybrids.

Comparison grid (GARP Tables 17.1 and 17.3; T1C is Tier 1 common, T1 is Tier 1):

Test	Banks and hurdle	Weights	Who had to raise capital	What was disclosed
SCAP Mar 2009	19 BHCs with assets of USD 100 bn or more (about 2/3 of banking assets); 4% T1C and 6% T1	Basel I	10 of 19, USD 75 bn; raised USD 77 bn in six months	Stress results only, bank level, projected losses for eight asset classes plus PPNR and reserve releases; supervisory estimates
CEBS Jul 2010	91 banks in 20 countries; 6% T1	Basel II	7 banks, EUR 3.5 bn	Base and stress, bank level, loss rates for overall retail and overall corporate only
Ireland Mar 2011	4 banks; 6% T1C stress, 10.5% T1C base; shrinkage allowed	Basel II	All 4, EUR 24 bn	Base and stress, bank level, loss rates, bank versus third-party loss estimates
CCAR Mar 2011	SCAP-19; 5% T1C	Basel I	No raise disclosed	Macro scenario only; no bank-level results
EBA Jul 2011	90 banks in 21 countries; 5% T1C	Basel II	8 banks, EUR 2.5 bn	Base and stress, bank level, retail, corporate and CRE loss rates, high exposure detail, downloadable
CCAR Mar 2012	SCAP-19 plus 11 BHCs over USD 50 bn; 5% T1C	Basel I	4 of 19 received an objection to their capital plan	Stress results only, bank level, loss rates and losses by asset class, PPNR; supervisory estimates

4. Disclosure: from Pandora's box to symmetric ignorance

- **SCAP "opened Pandora's box".** Until 2009, regulatory reports (the Y-9C) showed only *realized* losses. SCAP disclosed *projected* stress losses bank by bank, so the market could check the severity of the test at bank level. In a crisis of confidence that transparency was crucial.
- **CCAR 2011 published only the macro scenario.** Banks allowed to raise dividends were read as having "passed". The market digested this "without a hiccup": Schuermann's "symmetric ignorance".
- **Dodd-Frank** requires the Fed to disclose results, and **CCAR 2012** returned to near-SCAP detail (bank-level loss rates and dollar losses for first and second lien mortgages, C&I, CRE, cards, other consumer and other loans; PPNR; AFS/HTM gains and losses; trading and counterparty losses for the six largest trading firms).
- **Europe went further because it had to.** Ireland compared bank and third-party loss estimates; EBA 2011 published downloadable bank-level spreadsheets so analysts could apply their own sovereign haircuts. Funding liquidity was stressed but not disclosed.
- **Normal times (Goldstein and Sapra).** Detailed disclosure can cost more than it gives: window dressing to pass, traders leaning on public information instead of producing their own, and less informative prices. They favour aggregated results (loss rates by asset class, system-wide capital decline). In a crisis, bank-level detail with exposures is worth its cost.

Correction to the source notes. (1) Schweser writes that "19 SCAP banks were required to raise $75 billion". GARP: *ten* of the 19 were required to raise USD 75 billion (they raised USD 77 billion). (2) Schweser says RWA "are computed based on the Basel II risk weight definitions". That holds only for the European tests; SCAP and CCAR used Basel I weights (GARP 17.4). (3) Schweser and its module quiz call the Irish exercise "EBA Irish". It was a separate March 2011 test of the four Irish banks, run largely by outside advisers, before the July 2011 EBA test. (4) The LO wording says "European Banking Association"; the body is the European Banking *Authority*, successor to CEBS.

Exam traps

- **Pre/post polarity.** "Tied to capital adequacy", "dynamic", "firm-wide" and "revenues and costs" are post-SCAP. "Static, losses only, business unit" is pre-SCAP.
- **Own scenarios.** Banks' own baseline and stress scenarios came with CCAR 2011, in addition to (not instead of) the common scenario. Not a SCAP change.
- **Year swap on disclosure.** CCAR 2011: macro scenario only. CCAR 2012: near-SCAP bank-level detail.
- **Base versus stress.** SCAP and CCAR 2012 disclosed stress results only; CEBS, Ireland and EBA disclosed both.
- **Retail and corporate only** is CEBS 2010, not SCAP (SCAP gave loss rates by asset class).
- **Who failed.** The Irish banks *passed* CEBS 2010; the EUR 24 billion came from the March 2011 Irish exercise.
- **Risk weights.** Basel I for SCAP and CCAR; Basel II (ratings sensitive, migration matrices) for CEBS and EBA.
- **Ten, not 19.** Ten SCAP banks had to raise capital; none used CAP. CAP is a backstop, not a stress test.
- **Scenario size.** Three macro variables is SCAP; over 70 trading-book factors and eight macro factors per country is EBA 2011.

Practice questions: ORR-17 a

Question ORR-17 a.1

Bank Q379 • AnalystPrep Q.1993 (rebuilt)

Which of the following best describes stress testing as applied by banks and supervisors after the 2007 to 2009 financial crisis?

A. A simulation of how an institution's results hold up under deteriorating conditions, using adverse scenarios (e.g., a severe recession) or sensitivities (e.g., a sharp rise in interest rates)

B. A comparison of predicted losses with actual observed losses to judge the reliability of a bank's prediction models

C. A statistical estimate of the maximum loss over a given horizon at a given confidence level under normal market conditions

D. The administering of hypothetical credit assessments to a counterparty to estimate its probability of default

Question ORR-17 a.2 Bank Q372 • AnalystPrep Q.2307

Stress testing is a simulation technique used in banking to determine the ability of a financial institution to deal with an economic crisis. Which of the following is NOT a stress test exercise conducted by an authoritative body?

A. SCAP 2009: Supervisory Capital Assessment Program

B. CEBS 2010: Committee of European Banking Supervisors

C. CAP 2009: Treasury's Capital Assistance Program

D. CCAR 2011/2012: Comprehensive Capital Analysis and Review

Question ORR-17 a.3 Bank Q371 • AP Mock 2 Q57

The 2009 Supervisory Capital Assessment Program (SCAP) was an important stress test. Which of the following was least likely a risk factor taken into consideration during SCAP?

A. GDP growth

B. Unemployment

C. House price index

D. Inflation

Question ORR-17 a.4 Bank Q375 • Mock 2 Q74 (rebuilt)

In 2009, the Supervisory Capital Assessment Program (SCAP) allowed U.S. regulators to assess the capital strength of financial institutions. When comparing stress tests before and after SCAP, which of the following statements is incorrect?

A. Post-SCAP stress tests take a comprehensive, firm-wide look at the effect of the stress scenarios on the institution.

B. Pre-SCAP stress tests were explicitly tied to capital adequacy.

C. Pre-SCAP stress tests focused on losses only, rather than losses, revenues and costs.

D. Post-SCAP stress tests use broad macro scenarios with market-wide, multi-factor stresses.

Question ORR-17 a.5 Bank Q377 • Schweser Module Quiz 58.1 Q1

Which of the following changes in stress testing was not the result of the 2009 Supervisory Capital Assessment Program (SCAP)?

A. Banks are now required to provide the results of their own scenario stress tests.

B. Stress scenarios are now broader in nature.

C. Stress testing now focuses on the whole firm.

D. Stress testing now focuses on revenues, costs, and projected losses.

Question ORR-17 a.6

Bank Q374 • BT P2.T7.810.1

In regard to the historical evolution of the stress testing process, each of the following is true EXCEPT, which is inaccurate?

A. The U.S. Federal Reserve conducts an annual assessment of bank holding companies (BHCs) which includes a Comprehensive Capital Analysis and Review (CCAR) and Dodd-Frank supervisory stress tests.

B. The Committee of European Banking Supervisors (CEBS) oversees the most forward-looking and comprehensive regulatory stress tests, in particular with respect to liquidity risks, emerging cyber-risks, and the linkage between macro and intermediate risk factors.

C. The Supervisory Capital Assessment Program (SCAP) was the first of the macro-prudential stress tests of the global financial crisis; its state space had only three dimensions (GDP growth, unemployment, and house price index), and the market risk scenario was based in historical experience.

D. For the 2011 European Banking Authority (EBA) test, the supervisors specified over 70 risk factors for the trading book, eight macro-factors for each of 21 countries, plus sovereign haircuts across seven maturity buckets.

Question ORR-17 a.7

Bank Q376 • GARP PE2 Q54 (rebuilt)

A risk consultant presents the evolution of macro-prudential stress testing after the 2007 to 2009 crisis, comparing the 2009 Supervisory Capital Assessment Program (SCAP), the 2010 CEBS test, the 2011 EBA test and the 2011/2012 Comprehensive Capital Analysis and Review (CCAR). Which statement is correct?

A. The SCAP scenario was less severe than later U.S. tests and did not result in any capital raising by participating banks.

B. The 2011 CCAR disclosed bank-level loss rates, whereas the 2012 CCAR published only the macro scenario.

C. The 2011 EBA test made bank-level results available in downloadable form, including exposures by asset class and geography, which was more detailed than the 2010 CEBS test.

D. SCAP disclosed only overall retail and corporate loss rates, while the EBA test expanded disclosure to asset classes and regions.

Question ORR-17 a.8 Workbook C5.2 • S1, S5 • Map #30

An internal auditor at a European bank is reviewing a training module on the supervisory stress tests run in the US and Europe between 2009 and 2012. Which of the following statements in the module is correct?

A. Post-SCAP stress testing replaced single-factor shocks with a broad macro scenario applied firm-wide, but like pre-SCAP testing it remained static and confined to projected losses.

B. The 2011 CCAR asked banks to submit results under their own baseline and stress scenarios in addition to the common supervisory scenario, but published no bank-level results.

C. The 2011 EBA stress test applied Basel I risk weights, so banks needed only stressed default rates rather than full stressed rating migration matrices to project RWA.

D. All four Irish banks failed the 2010 CEBS stress test, which led directly to the March 2011 Irish exercise that revealed a capital need of EUR 24 billion.

Solutions • ORR-17 a

Solution ORR-17 a.1

Answer: A

Bank Q379 • AnalystPrep Q.1993

Step 1 – What a stress test asks

It is "the most basic of risk-based questions": how resilient is an exposure (a position, a loan, a whole portfolio) to deteriorating conditions? The stresses are either **sensitivities** (spreads double, prices drop, volatilities rise) or **scenarios** (October 1987, autumn 1998, post-Lehman, a severe recession).

⇒ A forward-looking simulation of adverse conditions.

Step 2 – How supervisors used it after the crisis

With regulatory capital ratios no longer credible, supervisors used broad stress tests to size the capital (and liquidity) a bank needs to support its risk taking.

Interpretation

The three distractors are other tools from the syllabus. Stress testing is the one that deliberately leaves normal conditions behind.

Why the other options are wrong

B is incorrect. That is backtesting: realized outcomes against model predictions, a backward-looking validation tool.

C is incorrect. That is VaR, a quantile calibrated to normal market conditions. Stress tests look at conditions beyond it.

D is incorrect. That is counterparty credit assessment. A stress test is applied to the bank's own portfolio, income and balance sheet.

LO: ORR-17 a: Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital Assessment Program (SCAP) stress tests. • **Reference:** Schuermann, Stress Testing Banks (2014), GARP ORR Ch.17, Sections 17.1 and 17.2; SchweserNotes 2026 Book 3, Reading 58, Module 58.1

Solution ORR-17 a.2

Answer: C

Bank Q372 • AnalystPrep Q.2307

Step 1 – List the supervisory exercises

SCAP (2009), the CEBS test (2010) and CCAR (2011 and 2012) are all macro-prudential stress tests run by supervisors (Table 17.3).

Step 2 – Place CAP

The Treasury's Capital Assistance Program was the *backstop*: if a SCAP bank could not convince investors to fill its capital hole, the Treasury would borrow and "downstream" the money as equity. It tests nothing.

⇒ The ten banks raised USD 77 billion privately; none drew on CAP funds.

Interpretation

A credible programme needs both a credible hole and a credible way to fill it; CAP was the second half, credible because the US Treasury was a credible debt issuer. (The bank labels it "TCAP"; GARP's abbreviation is CAP. Do not confuse it with the CAP of ORR-20, the capital adequacy process.)

Why the other options are wrong

A is incorrect. SCAP was the first macro-prudential stress test of the crisis.

B is incorrect. CEBS tested 91 European banks in July 2010.
D is incorrect. CCAR is the Federal Reserve's annual capital review, run since 2011.

LO: ORR-17 a: Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital Assessment Program (SCAP) stress tests. • **Reference:** Schuermann, GARP ORR Ch.17, Section 17.1 and Table 17.3

Solution ORR-17 a.3 — Answer: D

Bank Q371 • AP Mock 2 Q57

Step 1 – The SCAP state space

"The 2009 SCAP had a rather simple scenario specification. The state space had only three dimensions": GDP growth, unemployment and the house price index (HPI). The market risk scenario was historical (30 June to 31 December 2008).
⇒ Inflation was not one of the three.

Interpretation

Inflation appears as one of the eight macro factors per country in the 2011 EBA scenario. Keeping the two scenario specifications apart is the C9·S3 sibling swap.

Why the other options are wrong

A is incorrect. GDP growth was one of SCAP's three macro variables.
B is incorrect. Unemployment was one of SCAP's three macro variables.
C is incorrect. The house price index was one of SCAP's three macro variables.

LO: ORR-17 a: Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital Assessment Program (SCAP) stress tests. • **Reference:** Schuermann, GARP ORR Ch.17, Section 17.3

Solution ORR-17 a.4 — Answer: B

Bank Q375 • Mock 2 Q74

Step 1 – Recall Table 17.2

Pre-SCAP: mostly single shock, product or business-unit level, static, *not usually tied to capital adequacy*, losses only. Post-SCAP: broad macro scenario, firm-wide, dynamic, explicit post-stress common equity threshold, losses, revenues and costs.

Step 2 – Test each statement

A, C and D restate the table. B gives pre-SCAP testing a post-SCAP feature.
⇒ B is the incorrect statement.

Interpretation

The explicit link to a post-stress capital ratio (4% Tier 1 common in SCAP) is what turned a risk report into a capital test.

Why the other options are wrong

A is incorrect. Correct statement: post-SCAP testing is comprehensive and firm-wide.
C is incorrect. Correct statement: pre-SCAP testing looked at losses only.
D is incorrect. Correct statement: post-SCAP scenarios are broad macro scenarios with market-wide stress.

LO: ORR-17 a: Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital Assessment Program (SCAP) stress tests. • **Reference:** Schuermann, GARP ORR Ch.17, Section 17.1 and Table 17.2

Solution ORR-17 a.5 — Answer: A

Bank Q377 • Schweser Module Quiz 58.1 Q1

Step 1 – What SCAP changed

Broad macro scenario (B), firm-wide testing (C), losses plus revenues and costs (D), all tied to a post-stress capital ratio.

Step 2 – What SCAP did not change

SCAP imposed one common supervisory scenario on all 19 banks. CCAR, "in operation since 2011", asks banks to submit results under their own baseline and stress scenarios *in addition to* the common scenario.

$\Rightarrow$ Banks' own scenarios are a CCAR feature, not a SCAP result.

Interpretation

GARP calls the CCAR step "an important step forward from the 2009 SCAP": supervisors learn what each bank thinks its high-risk scenarios are, while still comparing banks on the common scenario.

Why the other options are wrong

B is incorrect. A genuine SCAP change: broad macro scenarios with market-wide stress.

C is incorrect. A genuine SCAP change: comprehensive, firm-wide testing.

D is incorrect. A genuine SCAP change: losses, revenues and costs instead of losses only.

LO: ORR-17 a: Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital Assessment Program (SCAP) stress tests. • **Reference:** Schuermann, GARP ORR Ch.17, Table 17.2 and Section 17.3; SchweserNotes 2026 Book 3, Reading 58, LO 58.b

Solution ORR-17 a.6 — Answer: B

Bank Q374 • BT P2.T7.810.1

Step 1 – Check the US and SCAP statements

A: the Fed's annual assessment of large BHCs combines CCAR with the Dodd-Frank supervisory stress tests. C: SCAP was the first macro-prudential test of the crisis, with a three-dimensional state space and a historical market shock. Both true.

Step 2 – Check the European statements

D is the 2011 EBA specification. B is false: CEBS ran the 2010 test (91 banks, market and credit risk only, loss rates only for overall retail and corporate) and was succeeded by the EBA. Its test was neither the most comprehensive nor focused on liquidity or cyber risk.

$\Rightarrow$ B is the inaccurate statement.

Interpretation

CEBS 2010 is the weakest European exercise in the chapter: mild results, thin disclosure, and the Irish banks it passed needed EUR 24 billion months later.

Why the other options are wrong

A is incorrect. True: CCAR and the Dodd-Frank tests are both part of the Fed's annual BHC assessment.

C is incorrect. True: SCAP's scenario had only three macro dimensions plus a historical market shock.

D is incorrect. True: this is the 2011 EBA scenario (over 70 trading-book factors, eight macro factors for each of 21 countries, sovereign haircuts in seven maturity buckets).

LO: ORR-17 a: Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital

Assessment Program (SCAP) stress tests. • **Reference:** Schuermann, GARP ORR Ch.17, Sections 17.1 and 17.3; Table 17.3

Solution ORR-17 a.7 Answer: C

Bank Q376 • GARP PE2 Q54

Step 1 – EBA 2011 against CEBS 2010

CEBS 2010 gave loss rates by firm only for overall retail and overall corporate. EBA 2011 disclosure was "much more extensive": exposure by asset class and geography, with all bank-level results downloadable in spreadsheet form.
⇒ C is correct.

Step 2 – Check the other three

SCAP required ten of its 19 banks to raise USD 75 billion (A false). The years in B are reversed. D gives SCAP the CEBS disclosure: SCAP released loss rates by major asset class.

Interpretation

Europe disclosed more because its supervisors had lost credibility after CEBS 2010: only bank-by-bank detail by asset class, country and maturity bucket let the market "do its own math".

Why the other options are wrong

A is incorrect. Ten of the 19 SCAP banks had to raise a total of USD 75 billion within six months (they raised USD 77 billion).
B is incorrect. Year swap: CCAR 2011 published only the macro scenario; CCAR 2012 disclosed near-SCAP bank-level detail.
D is incorrect. Sibling swap: "only overall retail and corporate loss rates" describes CEBS 2010. SCAP disclosed losses for eight asset classes.

LO: ORR-17 a: Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital Assessment Program (SCAP) stress tests. • **Reference:** Schuermann, GARP ORR Ch.17, Sections 17.1 and 17.5; Table 17.1

Solution ORR-17 a.8 Answer: B

Workbook C5.2 • S1, S5

Step 1 – Pre- versus post-SCAP (Table 17.2)

Post-SCAP testing is a broad macro scenario with market stress, comprehensive and firm-wide, dynamic and path dependent, tied to an explicit post-stress common equity threshold, and covers losses, revenues and costs.

Step 2 – Regime facts (Tables 17.1 and 17.3, Sections 17.3 and 17.5)

CCAR, in operation since 2011, "asks banks to submit results using their own scenarios (baseline and stress) in addition to results under the common supervisory stress scenario". The 2011 CCAR disclosure: "only the macro-scenario was published, with no bank-level results"; banks allowed to raise dividends were read as having passed.
⇒ The dual approach lets supervisors compare banks on the common scenario while learning what each bank thinks its own high-risk scenarios are.

Interpretation

B is correct. Contrast the 2009 SCAP (bank-level stress losses by asset class, supervisory estimates, stress results only) and the 2012 CCAR (near-SCAP detail; four of 19 did not pass in the sense of receiving an objection to their capital plans).

Why the other options are wrong

A is incorrect. Scope/condition error: the first clause is true, but post-SCAP testing is dynamic and path dependent and covers revenues and costs as well as losses; "static, losses only" describes pre-SCAP testing.
C is incorrect. Sibling swap: Basel I weights belong to the US exercises (SCAP, CCAR). The EBA test used Basel II weights, which are ratings sensitive, so banks had to use stress migration matrices to project the whole future ratings distribution, not just defaults.
D is incorrect. Polarity flip (case cross-mapping): "all of these banks had previously passed the CEBS stress test". The EUR 24 billion need for the four banks came from the 2011 exercise run largely by outside advisors after Ireland requested EU and IMF assistance.

LO: ORR-17 a: Describe the evolution of the stress testing process and compare the methodologies of historical European Banking Association (EBA), Comprehensive Capital Analysis and Review (CCAR), and Supervisory Capital Assessment Program (SCAP) stress tests. • **Reference:** Schuermann, Stress Testing Banks, International Journal of Forecasting 30:3 (2014), Sections 17.1, 17.3, 17.5; Tables 17.1, 17.2, 17.3

ORR-17 • Stress Testing Banks • Vardeez: IMPORTANT

ORR-17 b

P3 CONCEPT

Explain challenges in designing stress test scenarios, including the problem of coherence in modeling risk factors.

Workbook: C9 Stress-Testing Practices and Scenario Design • Tier C

WHAT IS TESTED HERE

Why P3. Tier C workbook topic: C9 sits at #38 on the topic map (3 of 16 sources), reported as "2 to 3 questions on stress testing related: appropriate practices". Not in your August 2026 recall. **Vardeez:** no separate map focus for this LO. His notes ("LO 56.b", consolidated volume p.177) give four reasons design is hard (multi-factor problems, joint outcomes, not everything goes bad at once, marked-to-market portfolios) and two responses (simple SCAP scenarios, bank-specific scenarios).

Reported exam shapes

- **C9·S1** Appropriate stress-testing practices as a best-practice audit: what to stress, how to aggregate, what to avoid.

What the questions look like: an auditor or examiner reviews a set of scenario assumptions and picks the incoherent one, or the provision that matches Schuermann's lessons. The workbook question mixes this reading with the market-driven scenario reading (IM-15).

See also: the regimes and their scenarios are in ORR-17 a, Section 3. The aggregation half of shape S1 (stressing counterparty exposures and adding them to loan stress losses) belongs to CR-21: workbook C9.1, worked there.

1. Recap

The supervisory tests of ORR-17 a each needed a scenario: SCAP (three macro variables plus a historical market shock, two years), EBA 2011 (over 70 trading-book factors, eight macro factors for each of 21 countries), CCAR (a common scenario plus each bank's own). Designing that scenario raises three problems: how severe to make it, how to keep it coherent, and whether one scenario can fit every bank.

2. The first choice: the authorities' risk appetite

"Perhaps the most fundamental choice" is **how severe and how long** the stress should be and **what post-stress hurdle** a bank must clear. GARP's sailing analogy: how severe and how long is the storm, and how solid must the boat still be once it has passed?

- The target is not strict solvency (just positive net worth) but **adequate capitalization after the stress**.
- **Length and hurdle are easy to compare.** SCAP: two years, 4% Tier 1 common. Spanish bottom-up test (2012): three years, 6% core Tier 1. A longer storm and a more solid boat mean a *lower* risk appetite: the Spanish authorities were more demanding.
- **Severity is not.** Authorities are reluctant to say "a 1 in 100 scenario" because such a statement is hard to make credibly. The Fed publishes time series of its scenario variables so users can judge severity variable by variable; a multivariate judgment is much harder.

3. Coherence: extreme, yet possible

Once the risk appetite is set, the principal challenge is **coherence**. Scenarios are inherently multi-factor: several financial and real risk factors take extreme *yet coherent* values together. It is not enough to specify only high unemployment, or only wider spreads, or only an equity crash: when one factor moves a lot, the others move too. The hard part is a coherent *joint* outcome (Figure 1).

- **Not everything goes bad at once.** Not all exchange rates can depreciate: some must appreciate. High inflation implies a policy response (a higher policy rate).
- **A flight to quality needs a destination.** There must be safe-haven assets, typically government bonds of the safest sovereigns (US, Japan, Germany, Switzerland). A scenario that stresses those sovereigns must name an alternative "risk-free" asset class to which capital flees.
- **Worst in the trading book.** Hundreds of thousands of marked-to-market positions map to tens of thousands of risk factors tracked daily for the VaR system. Coherent outcomes in that space, "short of resorting to historical realizations", are daunting.
- **Real and financial factors must also cohere.** SCAP's answer: a three-variable macro scenario plus the actual market moves of 30 June to 31 December 2008 (a massive flight to quality and a global bank failure). That gave a loose coherence of real and financial stresses. The price of a historical scenario: *it does not test for anything new*.

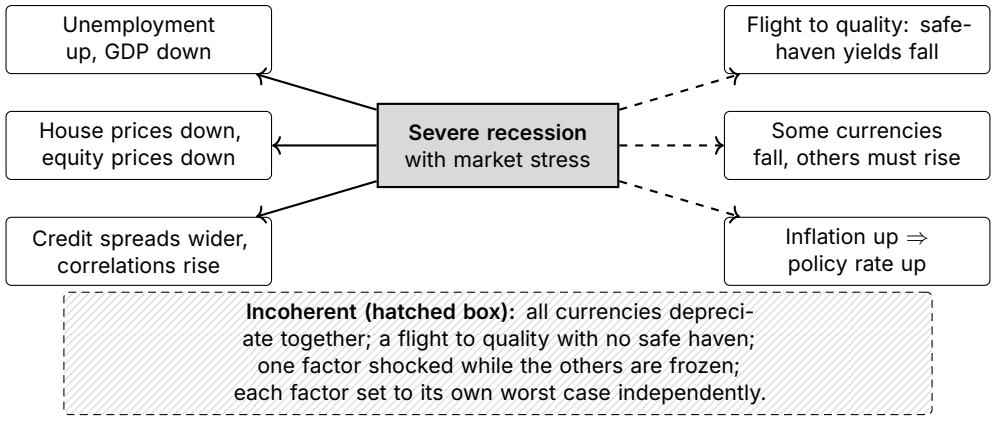


Figure 1. A coherent scenario moves its risk factors together. Solid arrows: factors that worsen together. Dashed arrows: the offsetting moves a coherent scenario must contain (a safe haven, appreciating currencies, a policy response). The hatched box lists the incoherent shortcuts an auditor should strike out.

4. One scenario for every bank?

Every supervisory test had imposed the **same scenario on all banks**, although any scenario is more severe for some business mixes and footprints than for others. This mirrors regulatory capital (the same for all banks by design) against economic capital (tailored to one bank). The problem is sharpest in "normal" times, when there is less agreement on what the relevant adverse scenario is.

- **CCAR's answer (since 2011):** banks submit results under their *own* baseline and stress scenarios *in addition to* the common supervisory scenario.
- **Two gains:** micro-prudential (supervisors learn each bank's own sensitivities and vulnerabilities) and macro-prudential (common risks across banks that were undiscovered or under-emphasized). Comparability is kept because every bank also runs the common scenario. ORR-20 b turns this into a requirement: the BHC scenario must reflect the BHC's unique vulnerabilities.

5. Plausibility tools you need for workbook C9.2 (from IM-15)

The market-driven scenario reading attacks the same problem from the portfolio side; it is worked in full under IM-15.

- **Few policy variables:** shock a small set and imply the rest through the covariance matrix. A small set limits arbitrariness and multicollinearity.
- **Three z-scores:** the *scenario* z-score measures severity (lower means more plausible); the *volatility* z-score measures magnitude with correlations set to zero; the *correlation* z-score measures consistency with the covariance matrix (near zero consistent, above 1.0 a warning).
- **Covariance for a crash:** estimate it from periods with similar crashes, because correlations among risky assets spike in crises. The same lesson as Section 3: the data window must match the stress.

Design question	Keep (coherent practice)	Strike (what to avoid)
How severe, how long, what hurdle	Set by the authorities' risk appetite; compare length and hurdle openly	Claiming a precise "1 in 100" severity for a multivariate scenario
Which factors move	Many factors moving jointly, real and financial	One factor at a time, others frozen; independent worst cases
What must offset	Safe havens, appreciating currencies, policy responses	All currencies down; flight to quality with nowhere to go
Historical or hypothetical	Historical moves for loose coherence, knowing they test nothing new	Relying only on history and calling the test forward-looking
Same or bank-specific	Common scenario plus each bank's own scenarios (CCAR)	Only one-size-fits-all; or own scenarios replacing the common one

Exam traps

- **Severe is not incoherent.** Correlations rising in stress, spreads widening while safe-haven yields fall, and rate rises after inflation are all coherent.
- **Incoherent combinations:** the major currencies all depreciating against a world basket; a flight to quality with no safe haven.
- **Historical scenarios** are coherent by construction (the moves happened together) but test nothing new.
- **Risk appetite polarity.** A longer horizon and a higher post-stress hurdle mean a *lower* risk appetite (Spain 2012 against SCAP).
- **Hurdle is not severity.** The hurdle is how solid the boat must be after the storm; severity is the storm.
- **Scenario size swap.** SCAP: three macro variables. EBA 2011: over 70 trading-book factors and eight macro factors per country.
- **Own scenarios** were added by CCAR, alongside (not instead of) the common supervisory scenario.
- **Z-score siblings.** Scenario z-score is severity; correlation z-score is consistency with the covariance matrix.

Practice questions: ORR-17 b

Question ORR-17 b.1

Bank Q383 • Schweser Module Quiz 58.2 Q1

Piper Hook, a bank examiner, is trying to make sense of stress tests done by one of the banks she examines. The stress tests are multi-factored and complex. The bank's scenarios specify extreme values for many risk factors at once, and Hook struggles to judge whether those joint values could really occur together. One of the key stress test design challenges that Hook must deal with in her examination of stress tests is:

A. multiplicity.

B. efficiency.

C. coherence.

D. efficacy.

Question ORR-17 b.2

New • built from GARP Ch.17

A supervisory policy analyst compares the design of two macro-prudential stress tests discussed by Schuermann:

Test	Scenario length	Post-stress hurdle
2009 SCAP (United States)	Two years	4% Tier 1 common
2012 bottom-up test (Spain)	Three years	6% core Tier 1

Which of the following conclusions about the design of these tests is most appropriate?

A. The Spanish authorities showed a higher risk appetite, because a longer scenario spreads the same losses over more years and makes the test easier to pass.

B. The Spanish authorities showed a lower risk appetite, because their banks had to remain better capitalized after a longer period of stress.

C. SCAP was the more severe test, because its lower post-stress hurdle implies that its scenario assumed larger losses.

D. The two tests can be ranked on overall severity by the "1 in 100" probability statements that supervisors attach to their multivariate scenarios.

Question ORR-17 b.3 Bank Q380 • BT P2.T7.24.14.2 (rebuilt, key corrected)

A bank's trading book consists of hundreds of thousands of marked-to-market positions mapped to tens of thousands of risk factors in its VaR system. A risk team must design a market-risk stress scenario whose risk-factor moves are jointly coherent. According to Schuermann, which approach is most practical for achieving coherence in this setting?

A. Specify an extreme move in the single most volatile risk factor and hold all other risk factors constant.

B. Set every risk factor to its own worst-case value independently, so that the scenario is as severe as possible.

C. Use historical realizations of risk-factor changes, such as the market moves from June 30 to December 31, 2008 used in the 2009 SCAP.

D. Estimate volatilities and correlations from VaR data and shock each risk factor to a fixed extreme quantile of its own distribution.

Question ORR-17 b.4 Bank Q382 • GARP PE1 Q63 • Mock 3 Q18

An internal auditor at a national bank is reviewing the assumptions of the scenarios that are used in the bank's stress tests. The auditor wants to ensure that the different sets of assumptions are plausible and that they exhibit the property of coherence. Which of the following combinations of assumptions used in a stress scenario would provide the auditor the greatest cause for concern about their coherence?

A. The USD, EUR, and JPY all depreciate at the same time against a basket of world currencies.

B. Correlations between returns of commodities used for industrial production and returns of industrial sector equities increase at the same time.

C. Yields on BBB-rated corporate debt increase as yields on AAA-rated short-term sovereign debt decrease.

D. Monetary authorities respond to higher consumer prices by raising central bank lending rates.

Question ORR-17 b.5 New • built from GARP Ch.17

The head of enterprise stress testing at a European bank is auditing the bank's scenario-design manual against the lessons Schuermann draws from the supervisory stress tests. Which of the following provisions should the head retain?

A. Each scenario shocks one risk factor at a time to an extreme value, holding the others at current levels, so that the source of every loss is easy to attribute.

B. Because a historical scenario is coherent by construction, the bank replays only the market moves of June to December 2008, which also ensures that new vulnerabilities are tested.

C. The bank runs only the common supervisory scenario, since adding a bank-specific scenario would prevent supervisors from comparing results across banks.

D. A flight-to-quality scenario that also stresses the bank's holdings of highly rated sovereign bonds must name the alternative asset class to which capital flees.

Question ORR-17 b.6 Workbook C9.2 • S2, S3 • Map #38

A portfolio risk manager at a London asset manager is drafting internal guidance on building plausible stress scenarios, drawing on the market-driven scenario (MDS) approach and on lessons from the supervisory bank stress tests. Which of the following statements should the manager keep in the guidance?

A. The scenario z-score measures how consistent a set of policy shocks is with the chosen covariance matrix, so a value close to zero signals a coherent scenario.

B. The set of policy variables should be kept large, so that the regression that implies the non-policy factor shocks leaves less room for arbitrariness.

C. The 2009 SCAP achieved coherence with a rich scenario of more than 70 trading-book risk factors and eight macro factors for each participating country.

D. For a market crash scenario, the covariance matrix should be estimated from periods with similar crashes, since correlations among risky assets spike in crises.

Solutions • ORR-17 b

Solution ORR-17 b.1

Answer: C

Bank Q383 • Schweser Module Quiz 58.2 Q1

Step 1 – Name the problem

The scenarios are multi-factor and extreme; the examiner cannot tell whether the joint values could occur together.

Step 2 – Match it to the reading

Scenarios must take "extreme yet coherent (or possible) values". The challenge of specifying a plausible joint outcome of all relevant risk factors is **coherence**.
⇒ Coherence is the named design challenge.

Interpretation

Severity alone is easy: shock everything. The design skill is making the extreme values fit together.

Why the other options are wrong

A is incorrect. "Multiplicity" is not a challenge named in the reading; it is built from the "many risk factors" in the stem.
B is incorrect. Efficiency concerns cost or speed, not the joint plausibility of risk-factor moves.
D is incorrect. Efficacy is a generic word, not the named challenge.

LO: ORR-17 b: Explain challenges in designing stress test scenarios, including the problem of coherence in modeling risk factors. • **Reference:** Schuermann, GARP ORR Ch.17, Section 17.3; SchweserNotes 2026 Book 3, Reading 58, LO 58.b

Solution ORR-17 b.2

Answer: B

New • built from GARP Ch.17

Step 1 – What the two numbers measure

The authorities' risk appetite fixes "how severe and how long the stress scenario should be, and what the post-stress hurdle is". In the sailing analogy: how long is the storm, and how solid must the boat be once it has passed.

Step 2 – Compare

Spain asked for a longer storm (three years against two) *and* a more solid boat afterwards (6% against 4%). Both make the test more demanding.
⇒ GARP: the Spanish design suggests "a lower risk appetite by the Spanish authorities than by the American".

Interpretation

Length and hurdle are the easy dimensions to compare. Scenario severity is the hard one, which is why option D fails.

Why the other options are wrong

A is incorrect. Polarity flip: a longer horizon accumulates more stress losses before the hurdle is tested; it does not dilute them.
C is incorrect. Confuses the hurdle with severity: the hurdle is the capital the bank must keep after the stress, not a measure of how severe the scenario is.
D is incorrect. Absolute claim: authorities are reluctant to make "1 in 100" statements because they are hard to make credibly; the Fed publishes variable time series so users can judge severity variable by variable.

LO: ORR-17 b: Explain challenges in designing stress test scenarios, including the problem of coherence in modeling risk factors. • **Reference:** Schuermann, GARP ORR Ch.17, Section 17.3

Solution ORR-17 b.3 — Answer: C

Bank Q380 • BT P2.T7.24.14.2

Step 1 – Why coherence is hard here

When one risk factor moves, the others do not stay fixed. With tens of thousands of risk factors, specifying a plausible joint move by judgment or by model is "daunting indeed".

Step 2 – The practical route

Finding coherent outcomes in such a space is daunting "short of resorting to historical realizations". Moves that actually happened together are coherent by construction. SCAP's market scenario did exactly this (30 June to 31 December 2008).

$\Rightarrow$ Historical realizations; the price is that they test nothing new.

Interpretation

The bank's original key was corrected to C; the rebuilt stem asks for the most *practical* route in a high-dimensional trading book, which is the historical one.

Why the other options are wrong

A is incorrect. One factor at a time ignores that factors move together (a volatility spike can freeze credit markets): the single-shock pre-SCAP approach.

B is incorrect. Independent worst cases confuse severity with coherence and can be mutually impossible (all currencies cannot depreciate together).

D is incorrect. Still treats each factor on its own; correlations estimated in calm periods need not hold in stress, and the reading does not offer this as a route to coherence.

LO: ORR-17 b: Explain challenges in designing stress test scenarios, including the problem of coherence in modeling risk factors. • **Reference:** Schuermann, GARP ORR Ch.17, Section 17.3

Solution ORR-17 b.4 — Answer: A

Bank Q382 • GARP PE1 Q63

Step 1 – The test for coherence

Can the assumptions occur together? "Not all exchange rates can depreciate at once; some have to appreciate."

Step 2 – Apply it

Exchange rates are relative prices. The USD, EUR and JPY dominate any world basket, so all three cannot fall against it at the same time.

$\Rightarrow$ A is internally inconsistent: the greatest cause for concern.

Interpretation

The other three are severe or unusual, not impossible. An auditor flags combinations that cannot happen, not combinations that hurt.

Why the other options are wrong

B is incorrect. Correlations typically rise in stress, so this is plausible: severity mistaken for incoherence.

C is incorrect. Wider corporate spreads with falling safe-haven yields is a classic flight to quality, which needs exactly such a safe haven.

D is incorrect. Raising rates in response to inflation is the policy response the reading says a high-inflation scenario must contain.

LO: ORR-17 b: Explain challenges in designing stress test scenarios, including the problem of coherence in modeling risk factors. • **Reference:** Schuermann, GARP ORR Ch.17, Section 17.3

Solution ORR-17 b.5 — Answer: D

New • built from GARP Ch.17

Step 1 – What a flight to quality requires

A scenario with a flight from risky assets must contain a (usually small) set of safe-haven assets, typically the bonds of the safest sovereigns. Questioning the safety of those sovereigns is a worthwhile scenario, "but it would need to define an alternative 'risk-free' asset class to which capital can flee".

$\Rightarrow$ D keeps the scenario coherent and should be retained.

Step 2 – Audit the other provisions

A is the single-shock design SCAP left behind. B relies on history alone. C ignores CCAR's dual approach.

Interpretation

This is the C9·S1 audit shape: what to stress (joint, offsetting moves), what to avoid (single factors, history alone, one size for all).

Why the other options are wrong

A is incorrect. One factor at a time is incoherent: when one factor moves significantly, the others move too.

B is incorrect. Half true: a historical scenario gives loose coherence, but "it does not test for anything new".

C is incorrect. False trade-off: CCAR keeps the common scenario for comparison and adds banks' own scenarios to reveal their specific vulnerabilities, "without sacrificing risk-discovery".

LO: ORR-17 b: Explain challenges in designing stress test scenarios, including the problem of coherence in modeling risk factors. • **Reference:** Schuermann, GARP ORR Ch.17, Section 17.3

Solution ORR-17 b.6 — Answer: D

Workbook C9.2 • S2, S3

Step 1 – Covariance choice (IM-15 b, c)

Z-scores and implied nonpolicy shocks both depend on the covariance matrix. "If you are modeling a market crash, you should use data or a covariance matrix from periods that experienced similar crashes, because correlations among risky assets typically spike during market crises. Relying only on 'normal' data would likely understate the severity of the stress."

Step 2 – Map the other statements to their true owners

Consistency with the covariance structure belongs to the correlation z-score; a small policy set is the MDS rule; the 70-plus factor scenario belongs to EBA 2011, while SCAP used GDP, unemployment and house prices plus a historical market shock.

Interpretation

D is correct. Its supervisory counterpart in ORR-17 is the same lesson from the other side: a historical shock gives loose coherence but "does not test for anything new", so the data window must match the stress being modelled.

Why the other options are wrong

A is incorrect. Sibling swap: the scenario z-score measures severity (lower means more plausible). The correlation z-score normalizes for magnitude and shows consistency with the covari-

ance matrix: near zero consistent, above 1.0 a warning.

B is incorrect. Polarity flip: "keeping the number of policy variables small helps minimize arbitrariness in the resulting perturbation vector"; a large set invites multicollinearity (do not add a variable with adjusted R^2 of 90% or more).

C is incorrect. Sibling swap (case cross-mapping): over 70 trading-book factors and eight macro factors for each of 21 countries describe the 2011 EBA test. The 2009 SCAP state space had only three dimensions with a historical market shock from June to December 2008.

LO: IM-15 b: Describe the scenario z-score, the volatility z-score, the correlation z-score, and the Mahalanobis distance, and explain how these are used in estimating the likelihood of occurrence and magnitude of scenarios. IM-15 c: Explain steps in the process of defining and developing market-driven scenarios, and describe the application of the MDS approach in the example provided. ORR-17 b: Explain challenges in designing stress test scenarios, including the problem of coherence in modeling risk factors. • **Reference:** Golub (ed.), BlackRock's Guide to Fixed-Income Risk Management, Ch.5 (via SchweserNotes Book 5, Reading 97, LO 97.b and 97.c); Schuermann, Stress Testing Banks, Section 17.3

ORR-18 • Risk Capital Attribution and Risk-Adjusted Performance Measurement • Vardeez: VERY IMPORTANT

ORR-18 a

P3 CONCEPT

Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital.

Workbook: D3 Regulatory vs Economic Capital and Capital Adequacy • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D3 sits at #61 on the topic map (3 of 16 sources), reported as "unexpected loss, regulatory capital, economic capital". Vardeez rates the chapter VERY IMPORTANT, but his ORR-18 focus pointers are the calculations (RAROC, hurdle rate, adjusted RAROC), not this LO.

Vardeez: his notes label this LO "LO 57.a" (consolidated volume p.2): a three-row table defining the three capital types, and four short points on why economic capital is used.

Reported exam shapes

- **S1** Regulatory capital as a formula-driven minimum versus economic capital as the bank's own estimate.

What the questions look like: statement questions (which is correct, which is the exception, which Roman numerals are true) built on sibling swaps between the three capital concepts, absolute qualifiers ("guarantees", "always") and the EL-versus-UL scope error. This is a CONCEPT LO: the bank's two calculation questions filed here (economic capital as worst-case loss minus EL) are not used; that arithmetic is Figure 1 of ORR-18 c.

See also: the composition of economic capital and the loss-distribution picture are in ORR-18 c (Section 3). Workbook A2.2 also tags this LO; it is worked under ORR-18 c (regulatory capital as a red-herring RAROC denominator).

1. Three kinds of capital, side by side

Recap from ORR-18 c: **economic capital** = **risk capital** + **strategic risk capital**, where strategic risk capital = goodwill + burned-out capital. GARP notes that "in most instances the generally accepted convention is that risk capital and economic capital are identical"; the strategic add-on is the "slight wrinkle".

	Risk capital	Economic capital	Regulatory capital
What it is	Cushion that keeps the firm a going concern "even in the event of a near-catastrophic worst-case scenario"	Risk capital plus strategic risk capital; usually used as a synonym for risk capital	Minimum capital imposed on a few regulated industries (banking, insurance) to protect small depositors and policyholders
How it is set	Worst-case loss minus EL at a chosen confidence level, generally over one year: a one-year VaR of unexpected loss	As risk capital, plus goodwill and burned-out capital	"Industrywide rules and formulas"; sets "only a minimum required level of capital adequacy"
Who chooses the parameters	Senior management (or the senior risk committee), usually endorsed by the board	The firm, as for risk capital	The regulator
Fit to true risk	Intended to capture the economic realities of the risks the firm runs	Same, plus the risk of strategic failure	"Rarely succeeds in capturing the true level of risk"; the gap "can be quite wide"
Main uses	Solvency; risk-based pricing	RAROC denominator; performance and compensation; entry and exit	Compliance floor

2. Regulatory versus economic capital (shape S1)

- **Scope.** Regulatory capital applies only to a few regulated industries; risk capital is relevant to any firm.
- **Method.** Regulatory capital is a formula-driven *minimum*. Economic capital is the firm's *own* estimate of the capital its risks consume, at a confidence level it chooses.
- **Firm versus business line.** Even if the two are similar for the whole firm, they can differ widely line by line: regulatory capital may say an activity is much riskier than management believes, or the reverse. Some practitioners "square the circle" by allocating the *higher* of the two to each line (Figure 1).
- **Basel III.** For some activities, such as securitization, regulatory capital may end up much higher than economic capital. Such an activity is then likely to migrate over time to the shadow banking sector, which can price it more attractively. Economic capital is still essential as the benchmark of the activity's *economic viability*.

Figure 1 puts illustrative numbers on the firm-versus-business-line point.

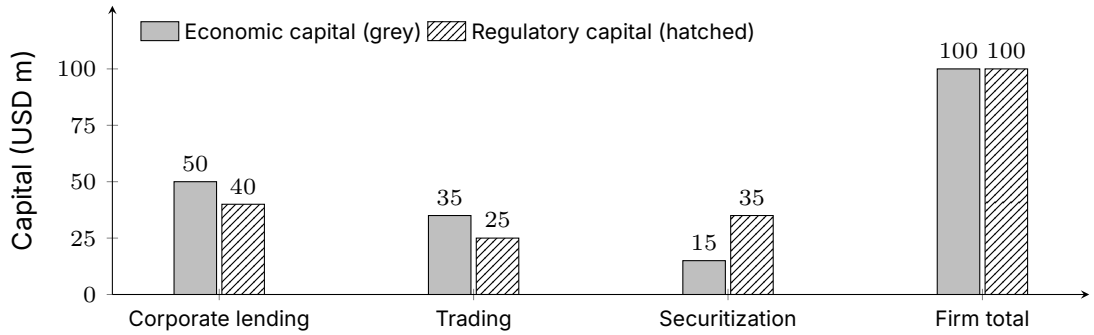


Figure 1. Illustrative numbers. The firm totals match (100 and 100), yet no business line agrees. Securitization carries more than twice its economic capital in regulatory capital, the pattern GARP links to migration to shadow banking. Allocating the higher of the two to each line would allocate $50 + 35 + 35 = 120$, more than either firm total.

Correction to the source notes. (1) Vardeez defines economic capital as the capital a firm needs to sustain risks "both expected and unexpected". In GARP, economic (risk) capital covers *unexpected* loss: the worst-case loss minus the expected loss. Expected loss is priced into the spread and covered by reserves, so "there is no need for risk capital as a buffer to absorb this risk". (2) Schweser says regulatory capital is a minimum "usually far below the firm's risk capital". GARP says only that the gap "can be quite wide", and that under Basel III regulatory capital may end up *much higher* than economic capital for some activities. Reject options that make regulatory capital always (or usually) the smaller number, or a floor that economic capital must exceed.

3. Confidence level and horizon: the firm's policy parameters

- Risk capital uses the same concepts as VaR, but its **confidence level and time horizon are key policy parameters** set by senior management and usually endorsed by the board. No firm can offer a 100% guarantee: at 99.9% there is a probability of around 1/10 of 1% that losses exceed risk capital over the horizon, generally one year.
- **Tied to the target rating and the risk appetite.** An AA target implies a one-year PD of 3 to 5 basis points, a confidence level of 99.95% to 99.97%. A higher target rating means a higher confidence level and more economic capital, never less.
- **The credit-risk view (CR-4, Schroeck).** $\text{EC}_p = \text{UL}_p \times \text{CM}$ and, per loan, $\text{EC}_i = \text{ULC}_i \times \text{CM}$: capital in proportion to the loan's contribution to portfolio risk, reflecting borrower quality and diversification, "contrary to the regulatory approach that assigns roughly 8% equity capital to credits on a standalone basis".

4. Motivations and methods (Box 18.1 and 18.2)

Why banks allocate capital with economic capital, GARP's four reasons:

1. **Capital absorbs risk, not just funding.** Banks lever up cheaply (debt-to-equity up to 20 to 1, against perhaps 2 to 1 for an industrial firm), and derivatives, guarantees and letters of credit need little funding yet draw on risk capital, so a risk capital cost must be imputed to each activity.
2. **Target solvency is part of the product.** Depositors, counterparties and policyholders are both customers and liability holders; a poorly rated bank is shut out of many markets.
3. **Banks are opaque.** Outside credit assessments are hard and quickly obsolete; enough risk capital and a strong risk culture reduce these "agency costs" by convincing rating agencies and other

outsiders.

4. **Capital is expensive.** Equity-like risk capital costs more than debt, and profitability is very sensitive to it: too much destroys returns, too little threatens the rating.

What it is used for. Beyond "how much capital keeps us solvent?": performance measurement and incentive compensation through RAPM and RAROC (economic, not accounting, profitability; ORR-18 c); entry and exit decisions using risk-adjusted performance and the diversification effect; and risk-based pricing through the "marginal economic capital requirement". "A single measure of risk capital cannot accommodate the four different purposes", hence stand-alone, fully diversified and marginal capital (ORR-18 g, P4).

Exam traps

- **Sibling swap.** "Industrywide rules and formulas" and "only a minimum" describe regulatory capital; "own estimate at a confidence level tied to the target rating" describes economic capital.
- **EL inside economic capital.** Economic capital is measured from EL to the worst case, not from zero.
- **Absolute qualifiers.** Economic capital does not *guarantee* survival; a lower confidence level does not *always* help.
- **Regulatory capital as a floor, or as always smaller.** It can be higher or lower, line by line; where it is higher, economic capital is still the benchmark of economic viability.
- **Polarity of the target rating.** Higher rating, higher confidence level, higher capital multiplier, more economic capital.
- **Strategic risk capital.** Goodwill and burned-out capital are strategic risk capital, not part of the unexpected-loss cushion.

Practice questions: ORR-18 a

Question ORR-18 a.1 Bank Q392 • BT P2.T7.24.11.1 (rebuilt)

A board plans to raise USD 75 million of capital. The CRO's report states:
Statement 1: USD 10 million will serve as a cushion to absorb unexpected losses from the firm's activities, sized so the firm remains solvent up to a 99.9% confidence level.
Statement 2: USD 5 million will cover potential write-offs on investments and acquisitions whose success is uncertain, proxied by spent (burned-out) capital and goodwill.
Which type of capital does each statement describe?

A. Both are strategic risk capital.

B. Statement 1: strategic risk capital; Statement 2: risk capital.

C. Both are risk capital.

D. Statement 1: risk capital; Statement 2: strategic risk capital.

Question ORR-18 a.2 Bank Q397 • BT P2.T7.1.2

Each of the following is true about the purpose of economic capital at a bank EXCEPT:

A. Economic capital, if properly calibrated, guarantees the bank will never default.

B. Economic capital is designed to keep a bank solvent; i.e., it is a solvency measure.

C. Economic capital provides a means for capital allocation within the bank.

D. Economic capital is a metric (a risk currency) that can be aggregated across and up and down the organization.

Question ORR-18 a.3 Bank Q389 • AnalystPrep Q.2211

The difference between risk capital and regulatory capital is that:

A. Regulatory capital only applies to a few closely monitored industries like banking and insurance.

B. While risk capital depends on an institution's individual characteristics and investment choices, regulatory capital is calculated based on industry-wide rules.

C. Aggregate risk capital and regulatory capital may be equal at firm level, but different at business-line level.

D. All of the above.

Question ORR-18 a.4 Bank Q398 • BT P2.T6.505.1 (rebuilt)

A bank is computing economic capital and wants to maintain a AA credit rating. Which of the following best describes how the confidence level for the economic capital calculation should be chosen?

A. At 95%, the level typically used for trading desk VaR limits, because the AA rating is based on day-to-day losses.

B. At 99%, the level used for regulatory capital, because regulatory and economic capital must share the same confidence level.

C. Above 99.95%, because the confidence level should correspond to the default probability implied by the target credit rating.

D. At whatever lower level minimizes the capital allocated, because a lower confidence level always improves risk-adjusted performance without affecting solvency.

Question ORR-18 a.5

Bank Q395 • BT P2.T7.1.1

Consider the following statements about economic capital (EC):

I. Economic capital must equal or exceed regulatory capital.

II. Economic capital should exceed equity capital.

III. Economic capital should equal the discounted stream of future excess return on capital.

IV. Economic capital absorbs expected losses (EL) and should equal the firm's reserves.

V. Economic capital absorbs unexpected losses (UL) up to a certain confidence level and over a specified time horizon.

Which of the above statements is (are) true?

A. I only

B. V only

C. I, II, and III

D. All are true

Question ORR-18 a.6

Bank Q394 • BT P2.T7.606.1

Peter Smith works at Bland Bancorp, a large international bank. At a board committee meeting he is asked to explain the difference between risk capital, economic capital, and regulatory capital. Which of the following is the true statement that is part of his response?

A. "Economic capital is less than risk capital because risk capital is the capital required to guarantee shareholders with 100.0% confidence that it holds enough risk capital to ride out any eventuality."

B. "Regulatory capital is almost certainly higher than economic capital in our securitization business; therefore, we do not need to know its economic capital. In other words, whenever regulatory capital exceeds economic capital, there is no reason or need to know economic capital."

C. "We need enough risk capital to absorb unexpected losses and remain solvent over a time horizon with a selected confidence level, but with respect to risk capital (unlike regulatory capital) the horizon and confidence belong to us as policy parameters."

D. "For capital budgeting purposes, we should use ex-ante RAROC with economic capital in the numerator; for performance evaluation, we should use ex-post RAROC with regulatory capital in the numerator."

Question ORR-18 a.7 Workbook D3.2 • S1, S2 • Map #61

An internal auditor at an Australian bank is reviewing a draft board paper that compares the bank's regulatory capital for credit risk with the economic capital produced by its internal credit portfolio model. The bank targets an AA rating and calibrates its model at the 99.97% confidence level. Which of the following statements is correct for the paper to include?

A. A bank targeting a higher credit rating can choose a lower confidence level, which lowers the capital multiplier applied to unexpected loss and so reduces the economic capital it must hold.

B. Economic capital is calculated with industrywide rules and formulas and sets only a minimum level of capital adequacy, whereas regulatory capital reflects the bank's own estimate of its risk.

C. Economic capital for credit risk is the capital needed to absorb the expected loss plus the unexpected loss up to the confidence level, so it is measured from zero loss rather than from EL.

D. Economic capital at the loan level equals the loan's unexpected loss contribution times the capital multiplier, which reflects diversification, unlike a regulatory approach assigning roughly 8% capital to each credit standalone.

Solutions • ORR-18 a

Solution ORR-18 a.1

Answer: D

Bank Q392 • BT P2.T7.24.11.1

Step 1 – Statement 1

A cushion for unexpected losses, sized to a chosen confidence level (99.9%), is **risk capital**: the worst-case loss minus the expected loss.

Step 2 – Statement 2

Capital set aside for possible write-offs on uncertain investments and acquisitions, measured as burned-out capital plus goodwill, is **strategic risk capital**.

$\Rightarrow$ Together they make up economic capital: risk capital plus strategic risk capital.

Interpretation

The amounts (USD 75, 10 and 5 million) do not matter; the descriptions do. Strategic risk capital covers the risk of strategic failure and is amortised as that risk fades; it is the "slight wrinkle" by which economic capital can exceed risk capital.

Why the other options are wrong

A is incorrect. Treats the unexpected-loss cushion in Statement 1 as strategic capital.

B is incorrect. Reverses the two assignments.

C is incorrect. Ignores that goodwill and burned-out capital measure strategic risk capital, not the unexpected-loss cushion.

LO: ORR-18 a: Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.1 and 18.4

Solution ORR-18 a.2

Answer: A

Bank Q397 • BT P2.T7.1.2

Step 1 – Test the absolute claim

Economic capital is sized at a confidence level below 100%. At 99.9% a probability of about 0.1% remains that losses exceed it over the horizon; GARP: "no firm can offer its stakeholders a 100 percent guarantee". So A is false, and it is the exception.

Step 2 – Check the other three

B: the traditional question is "how much capital is required for our firm to remain solvent". C: economic capital is used to allocate capital and capital costs to business lines. D: it is a common measure that can be compared and aggregated across units. All true.

Interpretation

"Guarantees" and "never" are absolute qualifiers; a confidence level always leaves a tail.

Why the other options are wrong

B is incorrect. True: economic capital is a solvency measure.

C is incorrect. True: it is the basis for allocating capital within the bank.

D is incorrect. True: it serves as a common risk currency across the organization.

LO: ORR-18 a: Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.1 and 18.2

Solution ORR-18 a.3 — Answer: D

Bank Q389 • AnalystPrep Q.2211

Step 1 – Statement A

True: regulatory capital applies only to a few regulated industries, such as banks and insurers, where regulators protect small depositors and policyholders.

Step 2 – Statement B

True: risk capital reflects the firm's own risks; regulatory capital follows industrywide rules and formulas and sets only a minimum.

Step 3 – Statement C

True: even when the firm totals are similar, the split across business lines can differ, which is why some firms allocate the higher of the two to each line.
⇒ All three are GARP's contrasts, so D.

Interpretation

These are the three differences GARP lists in 18.1, in the same order. The map's discriminator is B: a formula-driven minimum against the firm's own estimate.

Why the other options are wrong

A is incorrect. True but incomplete.
B is incorrect. True but incomplete.
C is incorrect. True but incomplete.

LO: ORR-18 a: Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.1

Solution ORR-18 a.4 — Answer: C

Bank Q398 • BT P2.T6.505.1

Step 1 – Link the confidence level to the rating

A credit rating carries a probability of default. An AA target implies a one-year PD of about 3 to 5 basis points, so the confidence level must be about 99.95% to 99.97%.

Step 2 – Read it as risk appetite

GARP calls the confidence level "the quantitative expression of the risk appetite of the firm". It is a policy choice made to fit the target rating.
⇒ Only C ties the confidence level to the default probability of the target rating.

Interpretation

Economic capital uses the firm's own parameters; neither a trading-limit convention nor the regulatory calculation sets them.

Why the other options are wrong

A is incorrect. 95% is a short-horizon trading-limit convention; as a one-year solvency standard it implies a 5% default probability, nowhere near AA.
B is incorrect. Nothing requires economic and regulatory capital to share a confidence level; economic capital's is the firm's policy parameter. A 99% one-year level would imply a 1% default probability, far below AA quality.
D is incorrect. A lower confidence level does cut capital and raise RAROC, but "always ... without affecting solvency" is false: it weakens the solvency standard and breaks the link to the AA target.

LO: ORR-18 a: Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital. • **Reference:** Crouhy, Galai and

Mark, Essentials 2e, Ch.17, 18.1 and 18.5 (Confidence Level)

Solution ORR-18 a.5

Answer: B

Bank Q395 • BT P2.T7.1.1

Step 1 – Statements I and II

I is false: regulatory capital is a formula-driven minimum that can be above or below economic capital (for securitization under Basel III it may be much higher). II is false: nothing ties economic capital to book equity; it is sized to the risk taken.

Step 2 – Statements III and IV

III is false: a discounted stream of excess returns describes value added (NPV, EVA), not capital. IV is false: EL is covered by pricing and reserves, and no risk capital is held for it.

Step 3 – Statement V

True: economic capital absorbs unexpected losses up to a confidence level over a horizon, generally one year.

$\Rightarrow$ Only V is true.

Interpretation

Two of the false statements are the core S1 traps: treating regulatory capital as a floor for economic capital (I), and putting EL inside economic capital (IV).

Why the other options are wrong

A is incorrect. Statement I treats regulatory capital as a floor; it can be higher or lower than economic capital.

C is incorrect. Adds II and III, which confuse economic capital with equity capital and with value added, to the false I.

D is incorrect. Includes IV, which puts expected losses inside economic capital.

LO: ORR-18 a: Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.1 and 18.4

Solution ORR-18 a.6

Answer: C

Bank Q394 • BT P2.T7.606.1

Step 1 – Statement A

False twice over: risk capital and economic capital are normally identical (economic capital adds strategic capital, so it is never the smaller), and no firm can offer 100% confidence.

Step 2 – Statement B

False: even where regulatory capital is much higher, as in securitization, economic capital is "essential for senior management as a benchmark to assess the economic viability of the activity".

Step 3 – Statement C

True: risk capital absorbs unexpected losses up to a confidence level over a horizon, and these are "key policy parameters that should be set by senior management" and endorsed by the board. Regulatory capital comes from industrywide formulas.

Step 4 – Statement D

False: economic capital is the RAROC *denominator* in both uses. Ex post evaluation swaps expected for realized revenues and losses; it does not switch to regulatory capital.

Interpretation

C states the S1 discriminator in the board's own words: the firm owns the parameters of its risk

capital; the regulator owns the formulas of regulatory capital.

Why the other options are wrong

A is incorrect. Reverses the relationship and assumes an impossible 100% confidence level.
B is incorrect. Economic capital is still needed to judge economic viability when regulatory capital is larger.
D is incorrect. Puts economic capital in the numerator and swaps in regulatory capital for performance evaluation.

LO: ORR-18 a: Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital. • **Reference:** Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.1, 18.4 and 18.5

Solution ORR-18 a.7 Answer: D

Workbook D3.2 • S1, S2

Step 1 – Economic capital at the loan level

Schroeck derives $EC_i = ULC_i \times CM$ (eq. 4.18): "the required economic capital at the single credit transaction level is directly proportional to its contribution to the overall portfolio credit risk".

Step 2 – The regulatory contrast

Footnote 62 contrasts this with "the regulatory approach that assigns roughly 8% equity capital to credits on a standalone basis", whereas the economic approach differentiates capital by borrower quality and reflects the benefits of diversification.
$\Rightarrow$ This is the map's discrimination: economic capital is the bank's own UL-based estimate; regulatory capital is a formula-driven minimum.

Interpretation

D is the only statement that gets both sides right. The other three each corrupt one fact: the direction of the rating effect, which concept is formula-driven, and where economic capital is measured from.

Why the other options are wrong

A is incorrect. Polarity flip. Box 4.1: a bank targeting a very high rating "must choose a very high confidence level (e.g., 99.97%), which corresponds to a higher capital multiplier", so economic capital rises. A lower CM belongs to a more aggressive bank targeting a lower rating.
B is incorrect. Sibling swap. Crouhy assigns "industrywide rules and formulas" and "only a minimum required level of capital adequacy" to regulatory capital; risk (economic) capital is intended to capture the economic realities of the risks the firm runs.
C is incorrect. Scope error. EL is "the foreseeable cost of doing business", covered by pricing and loan loss reserves, and "does not itself constitute risk". Economic capital is "the distance between the expected outcome and the unexpected (negative) outcome at a certain confidence level", i.e. $UL_p \times CM$ measured from EL.

LO: CR-4 a: Evaluate a bank's economic capital relative to its level of credit risk. CR-4 g: Describe how economic capital is derived. ORR-18 a: Define, compare, and contrast risk capital, economic capital, and regulatory capital and explain methods and motivations for using economic capital approaches to allocate risk capital. • **Reference:** Schroeck, Ch.5, Box 4.1, eqs. 4.17 and 4.18, footnote 62; Crouhy, Galai and Mark, Essentials 2e, Ch.17, 18.1

ORR-20 • Capital Planning at Large Bank Holding Companies • Vardeez: IMPORTANT

ORR-20 a

P3 CONCEPT

Describe the Federal Reserve's Capital Plan Rule and explain the seven principles of an effective capital adequacy process for bank holding companies (BHCs) subject to the Capital Plan Rule.

Workbook: D10 BHC Capital Planning and VaR Model Validation • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D10 sits at #53 on the topic map (2 of 16 sources), reported only as "BHC". The map adds that the reading is new or newly emphasised, which has historically meant heavier sampling. Not in your August 2026 recall.
Vardeez: his notes label this LO "LO 59.a" (consolidated volume p.131; ORR-20 ranks 31 of 55 there, STRIKE FIRST tier): the Rule in two lines and the seven principles as a table.

Reported exam shapes

- **D10·S1** Capital planning governance: board versus senior management, reporting of overlays.

What the questions look like: short fact checks on the Rule (who is covered, what horizon); "which principle has been violated" given a described failure; "which is not one of the seven principles"; and an auditor's governance check (who approves, what the board must see).

See also: the practices in each area are ORR-20 b. Workbook D10.1 also tags ORR-20 b; it is worked here. The 2009 SCAP and CCAR as stress tests are ORR-17 a.

1. The Capital Plan Rule and CCAR

- **Who.** All U.S.-domiciled, top-tier BHCs with total consolidated assets of USD 50 billion or more.
- **What.** Develop and maintain a **capital plan** supported by a robust process for assessing capital adequacy: the **capital adequacy process (CAP)**. The plan must project revenues, expenses, losses, reserves and pro forma capital levels (the minimum regulatory ratios, the tier 1 common ratio, and any other measures the BHC finds relevant) over the **nine-quarter** planning horizon, under expected conditions and a range of stressed scenarios, including a BHC-designed stress scenario. The **board of directors must approve** the plan.
- **Who checks. CCAR** is the Federal Reserve's annual supervisory program for assessing capital plans. In 2013 it covered the 18 BHCs that had taken part in the 2009 SCAP; the plans of the other BHCs subject to the Rule went through a separate Capital Plan Review, and from 2014 all of them go through CCAR.
- **Why.** Capital is "the first line of defense against losses", protecting the deposit insurance fund and taxpayers. A forward-looking plan governs the capital actions (dividends, repurchases, issuance and conversion) a BHC takes when conditions turn.
- **What the Fed assesses.** Risk identification, measurement and management; stressed loss and revenue estimation; and the governance and controls around them. Weaknesses can lead to an **objection** to the capital plan.
- **Three cautions.** The Dodd-Frank supervisory scenarios "play an important role" in CCAR but are not an all-encompassing assessment of a BHC's risks: an internal process that simply **mirrors the Federal Reserve's stress testing is a weak practice**. Practices called leading are **not a safe harbor**. Expectations are tailored: highest for the largest, most complex BHCs.

2. The seven principles of an effective CAP

The preamble to the Rule lists the elements on which the Fed judges a BHC's internal capital planning (GARP Figure 20.1). Learn them *in this order*: the numbering is how questions refer to them.

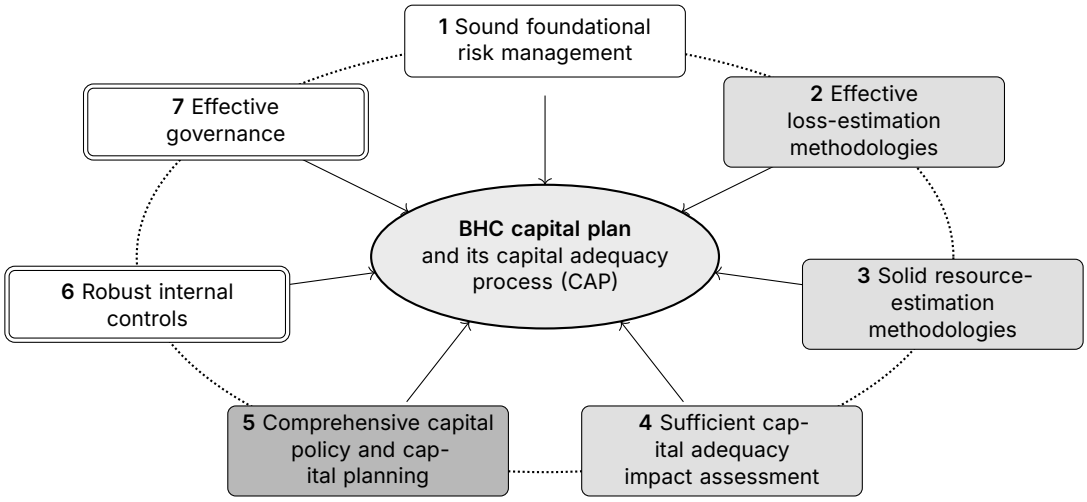


Figure 1. GARP Figure 20.1 redrawn as a ring around the capital plan, numbered clockwise from the top. Plain white box: the foundation (1). Light grey: the estimation chain (2 losses, 3 resources, 4 combined impact on capital). Dark grey: capital policy (5). Double border: controls and governance (6, 7).

Principle	What it requires (GARP Figure 20.1)	A failure that breaches it
1 Sound foundational risk management	Infrastructure to identify, measure, assess and control all material risks from the BHC's exposures and activities	Risk inventory misses off-balance-sheet exposures
2 Effective loss-estimation methodologies	Translate risk measures into potential losses over a range of stressful scenarios, and aggregate them across the BHC	Loss models cover too narrow a range of scenarios
3 Solid resource-estimation methodologies	Clear definition of available capital resources; estimate them (including projected revenues) over the *same* scenarios used for losses	Revenues projected under a milder scenario than losses
4 Sufficient capital adequacy impact assessment	Bring losses and resources together; assess the combined impact against the BHC's goals for the level and composition of capital	Post-stress ratios never compared with the capital goals
5 Comprehensive capital policy and capital planning	Capital goals, appropriate levels and composition, decisions on capital actions, capital contingency plans	No contingency plan; payouts not linked to goals
6 Robust internal controls	Policies and procedures, change control, model validation and independent review, comprehensive documentation, internal audit	A capital planning model never validated
7 Effective governance	Board and senior management oversight: periodic review of risk infrastructure and loss and resource methods, evaluation of goals, appropriateness of scenarios, review of limitations and uncertainties, approval of capital decisions	The board stops reviewing the loss-estimation methods

The two boundaries questions test. Validating or auditing a model is a *control* (6); periodically reviewing the methods and approving capital decisions is *governance* (7). Producing the stressed loss estimates is principle 2; combining them with resources against the goals is principle 4.

3. Governance in practice (shape D10·S1)

Board of directors	Senior management
Ultimate oversight and accountability for capital planning	Implements the activities the board authorizes; accountable to the board
Approves the capital plan (required by the Rule) and capital decisions, including distributions; the capital policy is approved by the board or a designated committee	**Recommends** capital goals and distributions, with analytical support
Receives information **at least quarterly** (or on material developments): current and post-stress pro forma capital against goals and targets, scenarios, key limitations, assumptions and uncertainties	Ensures effective controls and that stress scenarios are **sufficiently severe** and cover the BHC's material risks
Challenges results, recognizing they are estimates within a range; discusses weaknesses and acts on them	Identifies weaknesses, judges their materiality, and **reports them with remediation plans** to the board
Minutes show how decisions were made and what information was used	Ongoing (not one-time) assessment of all capital planning areas

Overlays. When management adjusts model estimates, the impact is quantified against the unadjusted estimates, and "management should always provide both the initial results and the results after any judgmental adjustments" to the board. Extensive overlays should prompt a review of whether better models are needed (ORR-20 b).

Correction to the source notes. (1) Vardeez's table (letters a to g) and Schweser's list (1 to 7) both put resource estimation *before* loss estimation. In GARP Figure 20.1, principle 2 is effective *loss*-estimation methodologies and principle 3 is solid *resource*-estimation methodologies. Use GARP's numbering (Figure 1). (2) Vardeez writes that the Rule covers BHCs "with over $50 billion in assets". The Rule covers U.S.-domiciled, top-tier BHCs with total consolidated assets of USD 50 billion *or more*.

Exam traps

- **Scope.** U.S.-domiciled, top-tier, total consolidated assets of USD 50 billion or more. Not income, not age, not foreign BHCs.
- **Horizon.** Nine quarters, not eight or twelve.
- **Controls versus governance.** Validation, documentation, change control and internal audit are principle 6; periodic review and approval by the board and senior management are principle 7.
- **Losses versus impact.** Producing stressed losses is principle 2; combining losses with resources against the capital goals is principle 4. Resources (3) are estimated over the *same* scenarios as losses.
- **Oversight is internal.** The BHC's own board and senior management, never a third-party assessor or peer BHCs.
- **Role swap.** The board approves; senior management recommends, implements and reports weaknesses.
- **Not a safe harbor.** Mirroring the Fed's stress tests is weak; leading practices are not a safe harbor.
- **Meeting minimum ratios today** does not free a BHC's dividends and buybacks: the Fed can object to the capital plan.

- **18, not 19.** CCAR 2013 covered the 18 BHCs that had taken part in the 19-bank SCAP.

Practice questions: ORR-20 a

Question ORR-20 a.1

Bank Q508 • Schweser Module Quiz 61.1 Q2

The Federal Reserve's Capital Plan Rule requires which of the following BHCs to develop a capital plan supported by an effective process for assessing capital adequacy?

A. All BHCs, whether U.S. or non-U.S. domiciled.

B. BHCs with more than five years of operational history.

C. BHCs with net annual income of more than USD 5 billion.

D. U.S.-domiciled BHCs with total consolidated assets of USD 50 billion or more.

Question ORR-20 a.2

Bank Q503 • AnalystPrep Q.2232

Fetterman Bank, a BHC subject to the Capital Plan Rule, is projecting its revenue and expenses for the capital plan. Over what planning horizon does the Federal Reserve's Capital Plan Rule require such estimates?

A. Eight quarters

B. Nine quarters

C. Twelve quarters

D. There is no explicit length of time defined by the Federal Reserve

Question ORR-20 a.3

Bank Q505 • BT P2.T7.806.1 (rebuilt)

Each of the following statements about capital planning at large BHCs supervised by the Federal Reserve is true EXCEPT:

A. The Comprehensive Capital Analysis and Review (CCAR) is the Federal Reserve's supervisory program for assessing the capital plans of large BHCs.

B. The Dodd-Frank Act supervisory stress tests play an important role in CCAR, using supervisory adverse and severely adverse scenarios.

C. Once a BHC meets the minimum regulatory capital requirements in normal, non-stressed times, the Federal Reserve cannot restrict its freedom to pay dividends or repurchase shares.

D. The seven principles of an effective capital adequacy process are: sound foundational risk management; effective loss-estimation methodologies; solid resource-estimation methodologies; sufficient capital adequacy impact assessment; comprehensive capital policy and capital planning; robust internal controls; and effective governance.

Question ORR-20 a.4

Bank Q506 • MK Mock 2 Q66

Kimco, a BHC, has its capital resource management and allocation process assessed by the Federal Reserve. Which of the following statements does NOT accurately describe one of the seven principles applied in the assessment?

A. Internal controls should be documented and subjected to internal audit.

B. A process should be in place to estimate potential losses and aggregate them on a firm-wide basis.

C. Oversight should be managed by a third-party risk assessor appointed by the BHC's board of directors.

D. Loss estimates and capital resources should be considered in determining the impact on capital adequacy.

Question ORR-20 a.5

Bank Q502 • AnalystPrep Q.2226

Minnetonka Bank, a BHC, finds that its process for translating risk measures into estimates of potential losses does not cover a satisfactory range of stressful scenarios and environments. Which principle of an effective capital adequacy process has been violated?

A. Sound foundational risk management

B. Effective loss-estimation methodologies

C. Sufficient capital adequacy impact assessment

D. Effective governance

Question ORR-20 a.6

Bank Q504 • AnalystPrep Q.2236

Campbell Bank, a BHC, has not had its risk infrastructure or its loss-estimation methodologies periodically reviewed by its board and senior management for more than a year. Which principle of an effective capital adequacy process does this most directly violate?

A. Sound foundational risk management

B. Sufficient capital adequacy impact assessment

C. Robust internal controls

D. Effective governance

Question ORR-20 a.7 Workbook D10.1 • S1, S2 • Map #53

An internal auditor at a large US bank holding company subject to the Capital Plan Rule is assessing the BHC's capital planning process against the Federal Reserve's description of the range of current practice. Which of the following observations should the auditor record as consistent with stronger practice?

A. The BHC's own stress scenario produces lower post-stress capital ratios than the supervisory severely adverse scenario, so its severity is accepted without further support.

B. Senior management, rather than the board, approves the capital plan, while the board is updated on capital adequacy and post-stress capital measures at least quarterly.

C. Where management overlays adjust modeled loss estimates, the board receives both the unadjusted model results and the results after the judgmental adjustments.

D. Wholesale losses under stress are projected with long-run average PD, LGD, and EAD by rating grade, since these averages span both expansions and downturns.

Solutions • ORR-20 a

Solution ORR-20 a.1

Answer: D

Bank Q508 • Schweser Module Quiz 61.1 Q2

Step 1 – The coverage test in the Rule

"All U.S.-domiciled, top-tier BHCs with total consolidated assets of $50 billion or more" must develop and maintain a capital plan supported by a robust capital adequacy process.
⇒ Two criteria only: U.S. domicile (top tier) and size by total consolidated assets.

Interpretation

The threshold is a balance-sheet size, the natural proxy for systemic importance. Expectations then rise further for the largest, most complex BHCs.

Why the other options are wrong

A is incorrect. The Rule covers only U.S.-domiciled, top-tier BHCs above the asset threshold.
B is incorrect. Operating history is not a criterion.
C is incorrect. The test is total consolidated assets, not net income.

LO: ORR-20 a: Describe the Federal Reserve's Capital Plan Rule and explain the seven principles of an effective capital adequacy process for bank holding companies (BHCs) subject to the Capital Plan Rule. • **Reference:** Board of Governors of the Federal Reserve System, Capital Planning at Large Bank Holding Companies (August 2013), GARP ORR Ch.20, Section 20.1; SchweserNotes 2026 Book 3, Reading 61, LO 61.a

Solution ORR-20 a.2

Answer: B

Bank Q503 • AnalystPrep Q.2232

Step 1 – The planning horizon

"The Capital Plan Rule requires BHCs to estimate revenue and expenses over the nine-quarter planning horizon." Losses, reserves and pro forma capital are projected over the same horizon.
⇒ Nine quarters.

Interpretation

GARP uses the nine quarters as a test of other practices: roll-rate models often lose predictive power well before nine quarters, and spreading an annual estimate evenly across four quarters does not give a careful quarterly path.

Why the other options are wrong

A is incorrect. Eight quarters (two years) is the round-number slip; the horizon is nine quarters.
C is incorrect. Twelve quarters (three years) overstates the horizon.
D is incorrect. The horizon is defined explicitly.

LO: ORR-20 a: Describe the Federal Reserve's Capital Plan Rule and explain the seven principles of an effective capital adequacy process for bank holding companies (BHCs) subject to the Capital Plan Rule. • **Reference:** Federal Reserve, GARP ORR Ch.20, Sections 20.7 (PPNR Projection Methodologies) and Box 20.1

Solution ORR-20 a.3

Answer: C

Bank Q505 • BT P2.T7.806.1

Step 1 – Check A, B and D

A: "CCAR is the Federal Reserve's supervisory program for assessing the capital plans." B: the Dodd-Frank supervisory scenarios and stress tests "play an important role in CCAR"; the Fed's scenarios include adverse and severely adverse ones. D: the seven principles of Figure 20.1, in

GARP's order. All true.

Step 2 – Check C

The Fed assesses planned capital actions (dividends, repurchases) in its review of the capital plan, and weaknesses "could lead to an objection to a BHC's capital plan". Meeting today's minimum ratios is not enough.

$\Rightarrow$ C is the false statement.

Interpretation

The whole point of the Rule is forward-looking: capital distributions are judged against capital adequacy under stress, not only under current conditions.

Why the other options are wrong

A is incorrect. True: CCAR is the supervisory program that assesses the plans.

B is incorrect. True: the supervisory stress tests play an important role in CCAR, though they are not all-encompassing.

D is incorrect. True: this is the list in GARP Figure 20.1.

LO: ORR-20 a: Describe the Federal Reserve's Capital Plan Rule and explain the seven principles of an effective capital adequacy process for bank holding companies (BHCs) subject to the Capital Plan Rule. • **Reference:** Federal Reserve, GARP ORR Ch.20, Sections 20.1, 20.2 and Figure 20.1

Solution ORR-20 a.4 Answer: C

Bank Q506 • MK Mock 2 Q66

Step 1 – Match A, B and D to the principles

A is principle 6 (comprehensive documentation and review by internal audit). B is principle 2 (estimate losses and aggregate them across the BHC). D is principle 4 (bring loss estimates and capital resources together to assess the impact on capital adequacy).

Step 2 – Test C against principle 7

Principle 7 is "effective board and senior management oversight of the CAP". Oversight belongs to the BHC's own board and management.

$\Rightarrow$ C does not describe any principle.

Interpretation

Independence is required of model validators and internal audit (principle 6), not of the oversight body. Outsourcing oversight would defeat the board's "ultimate oversight responsibility and accountability".

Why the other options are wrong

A is incorrect. Accurate: principle 6.

B is incorrect. Accurate: principle 2.

D is incorrect. Accurate: principle 4.

LO: ORR-20 a: Describe the Federal Reserve's Capital Plan Rule and explain the seven principles of an effective capital adequacy process for bank holding companies (BHCs) subject to the Capital Plan Rule. • **Reference:** Federal Reserve, GARP ORR Ch.20, Figure 20.1 and Section 20.4

Solution ORR-20 a.5 Answer: B

Bank Q502 • AnalystPrep Q.2226

Step 1 – Read the failure

The BHC's process for "translating risk measures into estimates of potential losses" does not cover a satisfactory range of stressful scenarios.

Step 2 – Find the principle with that wording

Principle 2: "effective processes for translating risk measures into estimates of potential losses over a range of stressful scenarios and environments and for aggregating those estimated losses across the BHC".

⇒ Effective loss-estimation methodologies.

Interpretation

The flaw is upstream: the loss estimates themselves. Principle 4 would only be breached if good estimates were then not combined with resources against the capital goals.

Why the other options are wrong

A is incorrect. Principle 1 is the infrastructure to identify, measure and control material risks, not the translation of risk measures into stressed losses.

C is incorrect. Principle 4 combines loss and resource estimates; the problem arises earlier, in producing the losses.

D is incorrect. Principle 7 is board and senior management oversight; nothing in the stem concerns oversight.

LO: ORR-20 a: Describe the Federal Reserve's Capital Plan Rule and explain the seven principles of an effective capital adequacy process for bank holding companies (BHCs) subject to the Capital Plan Rule. • **Reference:** Federal Reserve, GARP ORR Ch.20, Figure 20.1

Solution ORR-20 a.6 **Answer: D**

Bank Q504 • AnalystPrep Q.2236

Step 1 – Read the failure

No periodic review of the risk infrastructure and loss-estimation methodologies *by the board and senior management*.

Step 2 – Find the principle

Principle 7 lists "effective board and senior management oversight of the CAP, including periodic review of the BHC's risk infrastructure and loss- and resource-estimation methodologies".

⇒ Effective governance.

Interpretation

The tempting answer is internal controls, because "review" sounds like audit. The test: who is meant to act? Validators and internal audit point to principle 6; the board and senior management point to principle 7.

Why the other options are wrong

A is incorrect. Principle 1 is about having the infrastructure, not about its periodic review by the board.

B is incorrect. Principle 4 combines losses and resources against capital goals.

C is incorrect. Principle 6 covers policies, change control, validation, documentation and internal audit; the lapse here is in board and senior management oversight.

LO: ORR-20 a: Describe the Federal Reserve's Capital Plan Rule and explain the seven principles of an effective capital adequacy process for bank holding companies (BHCs) subject to the Capital Plan Rule. • **Reference:** Federal Reserve, GARP ORR Ch.20, Figure 20.1 and Section 20.4

Solution ORR-20 a.7 **Answer: C**

Workbook D10.1 • S1, S2

Step 1 – Overlays and reporting (Section 20.7)

If a BHC makes extensive adjustments to modeled estimates, "the impact of such adjustments should be quantified relative to unadjusted estimates" and documented for management and the board; "management should always provide both the initial results and the results after any judgmental adjustments".

⇒ The board can only challenge the result if it sees how far judgment moved the model; extensive overlays should also prompt a review of whether better models are needed.

Step 2 – Check the other observations against governance and scenario design

Board approval of the capital plan is required by the Rule (Section 20.4). Scenario severity must come from the BHC's unique vulnerabilities, and a harsher-than-supervisory outcome is not a safe harbor (Section 20.6). Long-run averages are excluded for stress projection (Section 20.7).

Interpretation

C is correct: it is a governance practice (S1) that keeps the board informed of model limitations before capital decisions are made.

Why the other options are wrong

A is incorrect. Absolute claim: "a BHC stress scenario that produces post-stress capital ratios lower than those under the supervisory severely adverse scenario is not, in and of itself, a safe harbor"; the scenario must still target the BHC's own vulnerabilities and be supported by a clear narrative.

B is incorrect. Role misassignment: "the board of directors is required to approve a BHC's capital plan under the Capital Plan Rule"; senior management implements board-authorized activities and makes recommendations to the board. The quarterly information clause is correct.

D is incorrect. Scope/condition error: "estimates based on long-run average behavior over a mix of conditions, including periods of economic expansion and downturn, are not appropriate for projecting losses under stress and should not be used for these purposes".

LO: ORR-20 a: Describe the Federal Reserve's Capital Plan Rule and explain the seven principles of an effective capital adequacy process for bank holding companies (BHCs) subject to the Capital Plan Rule. ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Board of Governors of the Federal Reserve System, Capital Planning at Large Bank Holding Companies (August 2013), Sections 20.4, 20.6, 20.7

ORR-20 • Capital Planning at Large Bank Holding Companies • Vardeez: IMPORTANT

ORR-20 b

P3 CONCEPT

Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections

Workbook: D10 BHC Capital Planning and VaR Model Validation • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D10 sits at #53 on the topic map (2 of 16 sources). Not in your August 2026 recall.

Vardeez: his notes label this LO "LO 59.b" (consolidated volume p.131): area-by-area tables of expected practices, then short notes on operational risk, market and counterparty risk, PPNR and projections.

Reported exam shapes

- **D10·S1** Capital planning governance: board versus senior management, reporting of overlays.
- **D10·S2** BHC scenario design and estimation practices that the Federal Reserve calls stronger or weaker.

What the questions look like: four practices, three of which the Fed names as weaker or lagging ("which would the auditor find most appropriate"); EXCEPT questions across the estimation methods; or a list of a BHC's plan features where you pick the ones that fail expectations. Learn the weak practices: they are the distractors.

See also: workbook D10.1 also tags this LO; it is worked under ORR-20 a. The seven principles and the board and senior management table are in ORR-20 a, Sections 2 and 3.

1. Recap

ORR-20 a gave the seven principles. This LO is the practice behind them, as the Fed observed it in CCAR 2013: practices it calls **stronger or leading**, and practices it calls **weaker, lagging** or, in some cases, unacceptable. Two ideas run through all of it: the BHC must be *BHC-specific* (generic assumptions and "standard" techniques are the most common lagging practice), and it must be *conservative* (no assumption that cannot be reasonably assured under stress). No practice, however leading, is a safe harbor.

2. Area by area: stronger against weaker practice

Area	Stronger or leading	Weaker or lagging
Risk identification	Systematic, repeatable, firm-wide; on- and off-balance-sheet positions, including noncontractual support; tests the enforceability of guarantees, netting and collateral under stress; a risk inventory refreshed as the business changes, with input from business lines, risk, finance and treasury; "other risks" (reputational, strategic, compliance) in net income projections or in a supported cushion above the capital target	Silo risk inventories not linked to the enterprise-wide inventory; cannot show how every risk is accounted for; cushion for other risks set by a simple rule (a percent of capital) or unsupported judgment; other risks ignored
Internal controls, model review and validation	Internal audit reviews the *full* end-to-end process; independent validation of all models (SR 11-7: conceptual soundness, ongoing monitoring with process verification and benchmarking, outcomes analysis); inventory including feeder models; sensitivity analysis and challenger models where backtesting is hard; validation covers management overlays; unvalidated models restricted; policies reviewed at least annually; robust MIS, reconciliation, documentation	Cannot identify all models in the process; high-impact models never reviewed; validators not independent of developers
Corporate governance	Expert, engaged board informed at least quarterly, including post-stress pro forma capital against goals and targets, limitations and assumptions; results treated as estimates within a range; senior management reports weaknesses with remediation timelines; minutes show the board's challenge	Capital recommendations on optimistic expectations without supporting information; key assumptions not identified; no information on controls; brief, opaque minutes
Capital policy, goals, targets, contingency	Written policy approved by the board or a designated committee, reevaluated at least annually; goals for level and composition of capital, current and stressed, reflecting stakeholders' expectations; **targets above goals**; payout ratios as maximums or targets; triggers for baseline and stress, on *projected* as well as actual results and on market indicators (CDS spreads, ratings, stock price); contingency actions realistic under stress, ranked by ease of execution and impact	Goals based solely on regulatory minimums or "well-capitalized" ratios; generic policy restating supervisory expectations; triggers on actual results only, or on minimum ratios only; few or infeasible contingency options; overreliance on past history

Area	Stronger or leading	Weaker or lagging
Stress testing and scenario design	BHC scenario tailored to its *unique vulnerabilities* (business model, asset-liability mix, footprint, portfolios, revenue drivers): for example a large counterparty default, an operational-risk event or natural disaster, an acute regional or industry stress; internal models combined with expert judgment; vendor scenarios tailored; a suite of scenarios (only one is submitted); enough variables; a clear narrative linking variables to risks	A generic recession similar to the supervisory severely adverse scenario; assuming the BHC gains market share in stress; missing regional or industry variables; narratives with features no variable reflects. A harsher result than the supervisory scenario is not a safe harbor
Estimating losses, revenues, expenses	Models as the basis, internal data first (external data adjusted to fit); segments by common risk characteristics; separate estimates where risk drivers differ; sensitivity analysis and challenger models; vendor models understood, customized, validated; overlays transparent, quantified against unadjusted results, both reported to the board; conservative data and assumptions; no foresight of the scenario path	Weak models used just to have a model; long-run average PD, LGD, EAD for stress; aggregate weighted-average LGD; selective exclusion of losses; drastic expense or origination cuts; the same strategic assumptions in baseline and stress; annual figures spread evenly over quarters without support
Capital adequacy impact: balance sheet and RWA	Balances projected from their drivers (paydowns, prepayments, nonperformance, new business); revenue, expense and balance sheet integrated (often ALM software); RWA consistent with projected exposures and scenario severity; ALLL adequate along the path and at the end; a central group aggregates with controls and reconciliation to regulatory and management reports	Favorable asset-mix shifts that cut risk weights; flight-to-quality deposit inflows; costless balance sheet shrinkage; margin improvement; RWA reductions from planned model enhancements; spreadsheets and untransparent manual adjustments in aggregation

3. Estimation methods GARP singles out

- **Credit losses.** Either an *economic* (expected loss) or an *accounting* (charge-off and recovery) approach; know how they differ in the timing of loss recognition. Expected loss: PD, LGD and EAD conditioned on the scenario, with drivers for each component (leading); LGD tied to collateral values under stress; EAD mostly static in practice, with loan-equivalent and credit-conversion-factor methods the stronger choice. **Rating transition** models (four steps: summary measure, time-series model, projection over nine quarters, back to quarterly matrices); judgmentally picking matrices from past stress periods is weak. **Roll-rate** models: weak predictive power beyond the near future; combining two models is weaker. **Net charge-off** models: avoid as the primary model for a material portfolio. **Scalars**: at most for immaterial portfolios.
- **AFS and HTM securities.** Test *all* credit-sensitive securities for other-than-temporary impairment (OTTI), with ratings that migrate under the scenario; lagging BHCs test only impaired or sub-investment-grade positions or hold ratings static.
- **Operational risk.** AMA models are not required. Start from complete internal loss data (keep legal reserves, acquired firms' losses and discontinued lines), add forward-looking and idiosyncratic elements. Approaches: regression (mostly on frequency; severity rarely correlates with the macro

factors), a modified LDA at a lower percentile (typically 70th to 98th, with sensitivity analysis of the choice), scenario analysis as an overlay, historical averages (backward-looking when used alone).

- **Market and counterparty risk.** Probabilistic approaches give a range of scenarios but are complex and hard to communicate; deterministic ones are easier to communicate but may miss scenarios. Most BHCs used deterministic scenarios for CCAR. Instantaneous shocks are suitably conservative; check plausibility (negative rates); use full revaluation; leading BHCs add an explicit default of their largest counterparties; risk mitigation only if executable with high confidence.
- **PPNR** (pre-provision net revenue: net interest income plus non-interest income minus non-interest expense). One coherent story with losses, balances and RWA (the same origination assumptions for balances, fees, costs and losses); net interest income built from balances, contractual terms and behaviour (prepayments, repricing, caps and floors); no revenue floors at historical levels; expenses that rise in a downturn (collections, foreclosed real estate) included.

4. From projections to post-stress capital

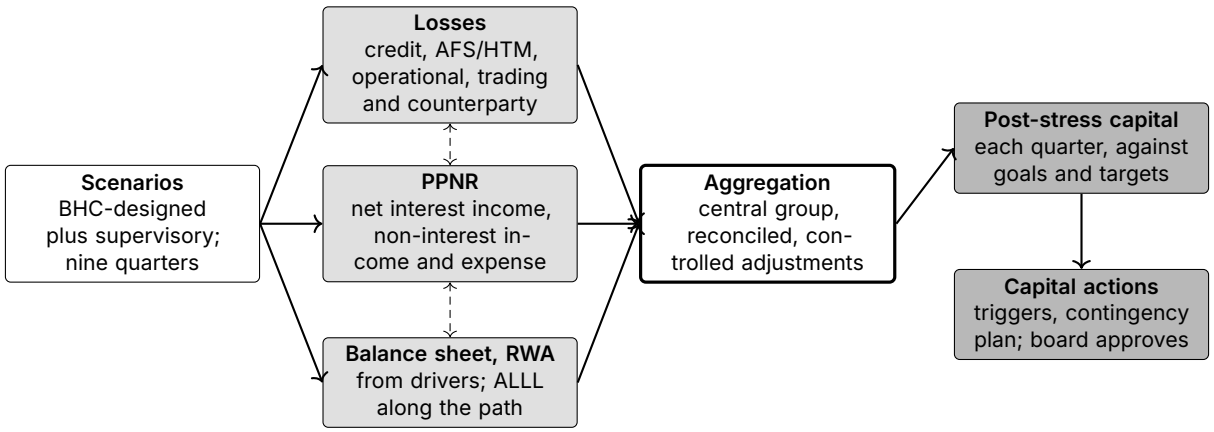


Figure 1. Enterprise-wide scenario analysis under the Capital Plan Rule. Solid arrows: the flow of projections. Dashed double arrows: the consistency GARP demands between losses, PPNR and balances ("a coherent story within each scenario"). Light grey: the three projection blocks; dark grey: the capital outcome and the decisions it drives.

- **RWA.** Built from projected exposures and their risk attributes, consistent with the severity of each scenario (trading RWA per dollar can rise with market volatility). No RWA reductions from model or data enhancements expected during the horizon.
- **ALLL.** Adequate along the scenario path and at its end, consistent with the loss estimates and balances. Methods that delay loss recognition (net charge-off models) need reserves built for losses not yet recognized.
- **Aggregation checks.** PPNR rising while balances fall is "generally inconsistent" and should be investigated. Post-stress results better than baseline call for a critical review of assumptions across portfolios. Spreadsheets in aggregation are a weak process; if unavoidable, add access and change controls and an audit trail.

Correction to the source notes. (1) Vardeez glosses PPNR as "Pre-Provision Net Revenue, less loss provisions". PPNR is net revenue *before* loss provisions: net interest income plus non-interest income minus non-interest expense. Provisions are deducted afterwards. (2) Vardeez files operational risk, market and

counterparty risk and PPNR under "Assessing the impact of capital adequacy". In GARP they are estimation methodologies (Section 20.7); the capital adequacy impact area (Section 20.8) covers the balance sheet and RWA, the ALLL and aggregation. (3) Schweser says losses should be aggregated by automated processes "without manual intervention or managerial adjustments". GARP's leading practice is an automated process with a clear audit trail and "mechanisms requiring approval and logging of judgmental adjustments and overrides". Adjustments are allowed; untransparent, unsupported ones are the lagging practice. (4) Schweser describes the expert judgment combined with internal models as "an outside expert's opinion". GARP asks for internal models combined with expert judgment, which need not be external.

Exam traps

- **No safe harbors.** Neither leading practice nor a BHC scenario harsher than the supervisory severely adverse one.
- **Assumptions that flatter the BHC:** market share gains, flight-to-quality deposits, margin improvement, costless shrinkage, drastic expense cuts, foresight of the scenario path. All weak.
- **Long-run average PD, LGD, EAD** span good and bad times: not for stress.
- **Method ladder.** Scalars only for immaterial portfolios; net charge-off models not primary for material ones; roll-rate weak beyond the near term; mixing two models is weaker.
- **Probabilistic versus deterministic.** The Fed prefers neither; most BHCs used deterministic scenarios; full revaluation for large moves.
- **Triggers and goals.** Targets sit above goals; triggers on projected results and market indicators, not only on actual results or regulatory minimums.
- **Overlays.** Allowed, but quantified and reported both before and after adjustment.
- **Operational risk data.** Do not drop legal reserves, acquired-firm losses or discontinued lines; AMA not required.
- **Board versus senior management.** Board approves the plan and receives information at least quarterly; senior management ensures severity and reports weaknesses with remediation plans.

Practice questions: ORR-20 b

Question ORR-20 b.1 Bank Q520 • Schweser Module Quiz 61.2 Q1

How many of the following statements are most likely correct? BHCs should have risk identification processes that evaluate:

I. on- and off-balance sheet positions.

II. risk transfer and/or risk mitigation techniques.

III. changes in institutions' risk profile due to portfolio quality.

IV. reputational risk.

A. One statement.

B. Two statements.

C. Three statements.

D. Four statements.

Question ORR-20 b.2

Bank Q515 • AnalystPrep Q.2971

Internal controls at bank holding companies (BHCs) should ensure the integrity of reported results and the documentation, review, and approval of all material changes to the capital planning process and its components. Such controls should exist at all levels of the capital planning process. Which of the following is NOT one of the specific control measures the Federal Reserve expects for this purpose?

A. Ensuring that MIS are robust enough to support capital analysis and decision making, with the flexibility to run ad hoc analysis when necessary.

B. Ensuring that documentation provides evidence that results and recommendations can be challenged by the board.

C. Providing for reconciliation and data integrity processes for all key reports.

D. Addressing the presentation of aggregate, enterprise-wide capital planning results, describing any manual adjustments made in the aggregation process and how they compensate for identified weaknesses.

Question ORR-20 b.3

Bank Q521 • Schweser Module Quiz 61.2 Q2

Which of the following statements is most likely correct?

A. Designing and testing a scenario-related default of a major counterparty is an example of BHC stress testing and a stress scenario design policy.

B. The internal controls policy of BHCs requires that senior management should furnish the board of directors with sufficient information to comprehend the BHC risk exposures.

C. A governance policy offers fundamental guidelines and principles to BHCs for capital issuance, use, distribution, and planning purposes.

D. Suspension or reduction in dividends or repurchase programs do not fall under the capital policy of BHCs.

Question ORR-20 b.4

New • built from GARP Ch.20

The corporate secretary of a US bank holding company subject to the Capital Plan Rule is drafting a responsibilities matrix for the capital planning process. Which of the following assignments is consistent with the Federal Reserve's supervisory expectations?

A. Senior management approves the final capital distributions in the plan, and the board reviews a summary of capital adequacy once a year after the plan has been submitted.

B. The board ensures that the stress scenarios are sufficiently severe and develops remediation plans for weaknesses in the process, which senior management then reviews.

C. The board approves the capital plan, the board or a designated board committee approves the capital policy, and the board receives capital information, including post-stress pro forma measures framed against the capital goals and targets, at least quarterly.

D. The board treats the post-stress capital ratios from enterprise-wide scenario analysis as precise point estimates, so that its decisions do not depend on management's discussion of model limitations.

Question ORR-20 b.5

Bank Q517 • BT P2.T7.806.3

Betaplanet International is a large bank holding company (BHC) with a high dependence on customer deposits. Betaplanet recently submitted its capital plan and stress scenarios to the Federal Reserve with the following features:

I. Betaplanet projected estimated revenue and expenses forward over a nine-quarter planning horizon.

II. Betaplanet separately estimated losses, revenues, and expenses under hypothetical stressed conditions for business lines that are sensitive to different risk drivers.

III. The adverse scenarios assume that Betaplanet will gain, respectively, +2.0% and +5.0% market share due to its competitive advantage and reputation for safety.

IV. For some portfolios where it has limited expertise, Betaplanet relied on commercial, third-party models.

V. For its wholesale portfolios, where it has limited history, Betaplanet supplemented internal data with external data.

VI. Betaplanet projected net interest income (NII) and its components but (due to its high dependence on deposits) excluded projections of non-interest income and non-interest expense.

Which of the features above are UNLIKELY to meet the regulatory expectations of the capital planning process?

A. None; all of the features are explicitly permitted.

B. III and VI: Betaplanet should not assume market share gains under a stress scenario, nor should it exclude non-interest income and expense from its projections.

C. II and IV: Betaplanet should not separate losses, revenues and expenses by business line, nor rely on third-party models at all.

D. I and V: Betaplanet must project revenue and expenses for at least five years, and it cannot rely on external data.

Question ORR-20 b.6

Bank Q516 • BT P2.T7.806.2

In regard to practices that can result in a strong and effective capital adequacy process, according to "Capital Planning at Large Bank Holding Companies: Supervisory Expectations and Range of Current Practice", each of the following is true EXCEPT which is false?

A. Most BHCs use some forms of expert judgment for some purposes, often as a management adjustment overlay to modeled outputs.

B. With respect to expected loss approaches, BHCs with leading practices were able to break down losses into PD, LGD, and EAD components, separately identifying key risk drivers for each of those components.

C. Although best practices in operational-risk models are still evolving, common approaches to operational loss estimation for stress scenarios include regression models, the modified loss-distribution approach (LDA), and scenario analysis.

D. With respect to market and counterparty credit risk, the Federal Reserve much prefers probabilistic approaches to deterministic approaches because deterministic approaches do not link stress scenarios to risk factor shocks.

Question ORR-20 b.7

Bank Q519 • MK Mock 4 Q14

An external auditor is reviewing the modeling processes used by a US-based bank to model operational losses as part of the bank's capital planning process. Using guidelines set by the Federal Reserve with respect to capital planning, which of the following processes or assumptions would the auditor find most appropriate?

A. Assuming a high positive correlation between operational risk severity and equity index movements during normal market conditions.

B. Using a net charge-off model to predict shorter-term credit losses and a roll-rate model to predict losses over a longer time horizon.

C. Incorporating forward-looking factors and idiosyncratic risk exposures into stressed operational loss estimates.

D. Modeling operational losses by projecting an annual loss estimate and then evenly distributing the losses across the four quarters of the year.

Question ORR-20 b.8

Bank Q518 • GARP PE2 Q13 (MK, rebuilt, key corrected)

The CRO of a large US-based bank holding company has asked a financial officer to develop a capital plan for the next 3-year period and to recommend a process for stress testing the capital plan over the same period. The officer wants to ensure that the plan conforms with the relevant guidelines for modeling revenues and losses across the entire planning period under both normal and stressed market conditions. Which of the following approaches will be appropriate for the officer to recommend?

A. Rely on scalar adjustments to baseline loss estimates for large loan portfolios to project losses during adverse market conditions.

B. Test credit-sensitive securities for other-than-temporary impairment using ratings that are projected to migrate under the stress scenario, rather than holding ratings static.

C. Model better-than-average revenue performance during times of stress to reflect the bank's competitive advantage.

D. Remove the impact of seasonality by dividing annual revenue and loss estimates for different types of products evenly across the year.

Question ORR-20 b.9

Bank Q511 • GARP PE1 Q34

Risk analysts at a large bank have been asked to implement a stress testing procedure for a newly mandated regulatory stress test. The stress test requires that the bank project its revenues, losses, and capital ratios for each quarter over a nine-quarter horizon. Which of the following actions or assumptions should the analysts recommend for the stress test that is consistent with best practices?

A. Use a full-revaluation approach to model the bank's complex derivative exposures.

B. Use minimum required regulatory capital ratios as the initial trigger for potential contingency capital actions to be taken.

C. Assume that the bank will exit its riskiest lines of business and reduce its expenses during the stress test horizon period.

D. Model the loss given default of the bank's loan portfolio using a weighted-average approach at the aggregate portfolio level.

Question ORR-20 b.10

New • built from GARP Ch.20

A model risk officer at a US bank holding company is reviewing the balance sheet and RWA projections that feed the post-stress capital ratios under the BHC's own stress scenario. Which of the following practices is consistent with the Federal Reserve's expectations?

A. Assuming that deposits flow in from weaker competitors in a flight to quality, which lowers the BHC's dollar cost of funding over the stress horizon.

B. Reducing projected RWA from the second year onward to reflect enhancements to internal risk models that are scheduled for approval during the horizon.

C. Accepting a projection in which PPNR rises while loan and deposit balances decline, because wider margins in stress offset the lower volumes.

D. Projecting loan balances from their drivers (contractual paydowns, modeled prepayments, nonperformance and new business), each checked for consistency with the scenario.

Solutions • ORR-20 b

Solution ORR-20 b.1

Answer: D

Bank Q520 • Schweser Module Quiz 61.2 Q1

Step 1 – Test each statement against Section 20.2

I: the process should "evaluate the full set of potential exposures stemming from on- and off-balance sheet positions". II: BHCs should closely assess "any assumptions about risk reduction resulting from risk transfer and/or mitigation techniques". III: risk measures should capture changes in the risk profile, including "changes in concentration or portfolio quality". IV: reputational risk is one of the "other risks" (with strategic and compliance risk) that must be identified and captured (Box 20.1).

⇒ All four belong in risk identification.

Interpretation

Hard-to-quantify risks are not excused from identification. They enter through net income projections over the nine quarters or a supported cushion above the capital target.

Why the other options are wrong

A is incorrect. Undercounts: all four statements are supported.

B is incorrect. Undercounts, probably by treating the mitigation and other-risk items as outside the process.

C is incorrect. Undercounts by one, typically by excluding reputational risk as unquantifiable.

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Section 20.2 and Box 20.1; SchweserNotes 2026 Book 3, Reading 61, LO 61.b

Solution ORR-20 b.2

Answer: B

Bank Q515 • AnalystPrep Q.2971

Step 1 – The specific controls listed under "Ensuring Integrity of Results"

GARP names four: MIS robust enough for capital analysis with flexibility for ad hoc analysis; reconciliation and data integrity processes for all key reports; presentation of aggregate results that describes manual adjustments and how they compensate for weaknesses; and accurate, timely reports to senior management and the board (including compliance with internal capital goals and targets).

⇒ A, C and D are on the list; B is not.

Step 2 – Where B belongs

Evidence that the board challenged results and recommendations is a feature of strong *documentation of decisions* (board minutes), part of governance in Section 20.4.

Interpretation

The question tests the controls versus governance boundary again: integrity controls make the numbers reliable; the board's challenge is what governance does with them. (Options reordered; the stem has been reworded for grammar.)

Why the other options are wrong

A is incorrect. A listed control: robust, flexible MIS.

C is incorrect. A listed control: reconciliation and data integrity for key reports.
D is incorrect. A listed control: transparent presentation of aggregate results and manual adjustments.

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Section 20.3 (Ensuring Integrity of Results) and Section 20.4 (Documenting Decisions)

Solution ORR-20 b.3

Answer: A

Bank Q521 • Schweser Module Quiz 61.2 Q2

Step 1 – Place each statement in its area

A significant counterparty default is one of GARP's examples of a risk that stronger BHCs build into their own stress scenarios, beyond the general recession of the supervisory scenarios (Section 20.6).
⇒ A is correct.

Step 2 – The misplaced statements

Informing the board of risk exposures is governance (B says internal controls). Guidelines for capital issuance, usage, distributions and planning define the capital *policy* (C says governance). Reducing or suspending dividends and repurchases is the core of the capital contingency plan inside the capital policy (D denies it).

Interpretation

A classification question across the seven areas: each distractor attaches a true practice to the wrong area. (Options reordered.)

Why the other options are wrong

B is incorrect. Area swap: sufficient information to the board is a governance expectation.
C is incorrect. Area swap: this is the definition of a capital policy.
D is incorrect. Polarity flip: the policy must explain the circumstances in which the BHC will reduce or suspend a dividend or repurchase program.

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Sections 20.4, 20.5 and 20.6

Solution ORR-20 b.4

Answer: C

New • built from GARP Ch.20

Step 1 – What the board must do

"The board of directors is required to approve a BHC's capital plan under the Capital Plan Rule." The capital policy "must be approved by the BHC's board of directors or a designated committee of the board". The board "should receive this information at least quarterly", including capital measures "on a post-stress, pro forma basis" framed against the goals and targets.
⇒ C assigns each task correctly.

Step 2 – What senior management must do

Ensure effective controls and that "the BHC's stress scenarios are sufficiently severe"; make recommendations on capital goals and distributions; identify weaknesses and develop remediation plans, and report both to the board.

Interpretation

This is shape D10·S1 in its purest form: the board approves and challenges; senior management implements, recommends and reports.

Why the other options are wrong

A is incorrect. Role misassignment and wrong frequency: capital decisions, including distributions, are approved by the board, which receives capital information at least quarterly.

B is incorrect. Role swap: ensuring severity and developing remediation plans are senior management's duties, reported to the board.

D is incorrect. Stronger boards "recognized that internal capital planning results are estimates and should be viewed as part of a range of possible results"; the board needs the limitations to challenge results.

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Sections 20.4 and 20.5

Solution ORR-20 b.5 **Answer: B**

Bank Q517 • BT P2.T7.806.3

Step 1 – Features that meet expectations

I: the Rule requires nine-quarter projections. II: BHCs "should separately estimate losses, revenues, or expenses for portfolios or business lines that are sensitive to different risk drivers". IV: third-party models are acceptable if staff understand them and they are validated under SR 11-7. V: external data may supplement a short internal history if it reasonably proxies the portfolio.

Step 2 – Features that fail

III: assuming the BHC is "viewed as strong compared to their competitors" and gains market share is a weaker practice, "contrary to the supervisory expectations". VI: the plan must project revenues and expenses, and PPNR has three parts; non-interest income and non-interest expense must be projected consistently with the scenario.

$\Rightarrow$ III and VI fail.

Interpretation

Both failures flatter the BHC: one adds revenue the stress would not bring, the other omits expenses (collections, foreclosed real estate) that a downturn pushes up.

Why the other options are wrong

A is incorrect. III and VI contradict supervisory expectations.

C is incorrect. Separate estimation by risk driver is expected, and validated vendor models are allowed.

D is incorrect. The horizon is nine quarters, and external data may supplement limited internal data.

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance

- Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Sections 20.6 and 20.7

Solution ORR-20 b.6

Answer: D

Bank Q516 • BT P2.T7.806.2

Step 1 – The true statements

A: "most BHCs use some forms of expert judgment for some purposes, generally as a management adjustment overlay to modeled outputs". B: leading practices break losses into PD, LGD and EAD, "separately identifying key risk drivers for each". C: regression models, modified LDA and scenario analysis (plus historical averages) are the common operational-risk approaches.

Step 2 – The false statement

GARP sets out strengths and weaknesses of both approaches: probabilistic ones give insight into a range of scenarios but are complex and hard to communicate; deterministic ones are easier to communicate but may miss scenarios. "For CCAR, most BHCs generally relied on a deterministic approach", and deterministic BHCs do translate scenarios into risk-factor shocks (step 2 of their three-step process).

$\Rightarrow$ D is false.

Interpretation

The Fed asks each approach to prove its weak point: probabilistic users must show they can generate scenarios more severe than history; deterministic users must show they have considered a range of scenarios that stress their key exposures.

Why the other options are wrong

A is incorrect. True statement.

B is incorrect. True statement.

C is incorrect. True statement.

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Section 20.7 (Qualitative Projections; Expected Loss Approaches; Operational Risk; Market Risk and Counterparty Credit Risk)

Solution ORR-20 b.7

Answer: C

Bank Q519 • MK Mock 4 Q14

Step 1 – What GARP expects for operational losses

"BHCs should use internal operational-loss data as a starting point to provide historical perspective, and then incorporate forward-looking elements, idiosyncratic risks, and tail events to estimate losses." Stronger practices combine approaches for exactly this purpose.

$\Rightarrow$ C is the appropriate process.

Step 2 – Check the others

Most BHCs found no meaningful correlation between macro variables and loss *severity* (A). B is about credit models, and reverses the roll-rate model's strength. D is the even-quarter shortcut GARP accepts only for highly uncertain items where it is conservative.

Interpretation

Operational risk is where historical data alone fails most: the stress estimate must add what the BHC has not yet experienced. (Options reordered.)

Why the other options are wrong

A is incorrect. Unsupported: severity rarely correlates with macro variables, and the assumption is about normal, not stressed, conditions.

B is incorrect. Off-target and reversed: roll-rate models are weak beyond the near future, and combining two models is a weaker practice.

D is incorrect. Spreading an annual figure evenly "does not reflect a careful estimate of the expected quarterly path".

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Section 20.7 (General Expectations; Roll-Rate Models; Operational Risk)

Solution ORR-20 b.8 — Answer: B

Bank Q518 • GARP PE2 Q13 (MK)

Step 1 – The OTTI practice

BHCs should test all credit-sensitive AFS and HTM securities for OTTI. Most used ratings migration projected under the stress scenario with a ratings-based threshold; "some BHCs with weaker practice used a ratings-based approach that kept the ratings static over the scenario horizon".
$\Rightarrow$ B is the stronger practice.

Step 2 – Check the others

Scalars are limited "at most" to immaterial portfolios (A). Better-than-average past performance must not be assumed to continue (C). Even quarterly spreading is acceptable only if the item is highly uncertain and the result conservative (D).

Interpretation

The bank's key was corrected to B. The three-year planning period in the stem is the CRO's own choice; the Rule's horizon is nine quarters, which does not change the answer.

Why the other options are wrong

A is incorrect. Scalars lack transparency and sensitivity to portfolio composition and scenario variables; not for large portfolios.

C is incorrect. An assumption that specifically benefits the BHC defeats the purpose of a stress test.

D is incorrect. Ignores the expected quarterly path of losses and revenue (it is not about seasonality).

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Section 20.7 (Scalar Adjustments; AFS and HTM Securities; Conservatism and Credibility)

Solution ORR-20 b.9 — Answer: A

Bank Q511 • GARP PE1 Q34

Step 1 – Revaluation under large shocks

Approximations may work for normal moves, but "BHCs should generally use full-revaluation methods for stress testing, given the very large risk-factor moves, especially for nonlinear positions".

⇒ A is consistent with best practice.

Step 2 – The weak practices among the options

B: triggers "based on minimum regulatory capital ratios only" are weak. C: assumed exits and expense cuts are mitigating actions that must be conservative and achievable under stress. D: a weighted-average LGD at aggregate level "without some level of segmentation" is a lagging practice.

Interpretation

Three of the four options are lifted from GARP's own list of weak practices; the correct one is the only conservative choice.

Why the other options are wrong

B is incorrect. Triggers at the regulatory minimum fire too late and ignore other stakeholders' expectations and market indicators.

C is incorrect. Drastic cuts and exits that cannot be reasonably assured under stress are weak assumptions.

D is incorrect. Aggregate weighted-average LGD hides variation by product, priority of claim, collateral and geography.

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Sections 20.5 (Capital Contingency Plan) and 20.7 (Expected Loss Approaches; Revaluation Methodologies)

Solution ORR-20 b.10 — Answer: D

New • built from GARP Ch.20

Step 1 – How balances should be projected

"BHCs with stronger practices separately considered the drivers of change to asset and funding balances, such as contractual paydowns, modeled prepayments, nonperformance, and new business activity for assets, rather than simply projecting targeted balances directly."

⇒ D is the stronger practice.

Step 2 – The favorable assumptions

GARP lists as aggressive: large asset-mix changes that cut risk weights, "flight-to-quality" assumptions and funding mix changes that increase deposits and reduce the cost of funding (A), significant shrinkage without its losses, and operating margin improvement. Separately, BHCs "should not assume any RWA reductions from potential data or model enhancements" (B), and "an increase in PPNR amid declining balances would appear generally inconsistent" (C).

Interpretation

The aggregation step is where these inconsistencies surface; a central group should challenge them rather than accept them.

Why the other options are wrong

A is incorrect. A flight-to-quality deposit inflow is one of GARP's four examples of a favorable balance sheet assumption.

B is incorrect. Planned model enhancements cannot reduce projected RWA.

C is incorrect. Rising PPNR amid falling balances warrants investigation; assumed margin improvement is itself a favorable assumption.

LO: ORR-20 b: Describe practices that can result in a strong and effective capital adequacy process for a BHC in the following areas: - Risk identification - Internal controls, including model review and validation - Corporate governance - Capital policy, including setting of goals and targets and contingency planning - Stress testing and stress scenario design - Estimating losses, revenues, and expenses, including quantitative and qualitative methodologies - Assessing the impact of capital adequacy, including risk-weighted asset (RWA) and balance sheet projections • **Reference:** Federal Reserve, GARP ORR Ch.20, Section 20.8 (Balance Sheet and RWAs; Aggregation of Projections)

ORR-21 • Capital Regulation Before the Global Financial Crisis • Vardeez: UNTIERED

ORR-21 a

P3 CONCEPT

Explain the motivations for introducing the Basel regulations, including key risk exposures addressed, and explain the reasons for revisions to Basel regulations over time.

Workbook: C5 Basel III Post-Crisis Reforms and Stress-Test Regimes • Tier C

WHAT IS TESTED HERE

Why P3. Tier C workbook topic: C5 (Basel III Post-Crisis Reforms and Stress-Test Regimes, #30 on the topic map, 4 of 16 sources), whose shape S4 is the Basel progression.
Vardeez: his notes label this LO "LO 60.a" (consolidated volume p.44): early banking practices, the BCBS (1974), Basel I (1988) and its two tiers of capital.

Reported exam shapes

- **C5·S4** The Basel I / 1996 / II / 2.5 / III progression, each change attached to the right accord.

What the questions look like: statement questions on why official regulation replaced private arrangements, what motivated the BCBS and Basel I, which risk each accord first covered, and why each revision came. No calculations.

Recap: the Basel timeline (Figure 1) and the accord-by-accord table are under ORR-21 c, Section 1.

See also: workbook C5.1 is worked here; it also tags ORR-21 d and e. The four bank questions filed under this LO are near-duplicates of one another, so one is used, with one question re-filed from LO 62.b (ORR-21 b) and one from LO 62.g (P4).

1. Before Basel: why official regulation

Before government regulation, a bank or insurer needed no approval; it survived by persuading clients to trust it, with prominent backers, large capital and imposing buildings. Failures were frequent, often through a run on a solvent institution that could not raise cash fast enough. The first "regulations" were private: firms banded together to share resources in a run. The Bank of England began as a private entity supporting other banks, and clearinghouse members shared financial statements and had rights of inspection.

GARP lists four triggers that moved regulation into the official sector:

1. **Panics too big for private help.** Only an entity able to print money could support the system, so government-controlled central banks replaced clearinghouses and private banks as lenders of last resort.
2. **Crises are costly for the whole economy** (often followed by depressions), so governments sought institutions solvent and liquid enough to survive plausible distress.
3. **Customers' complaints** of unfairness and of the difficulty of monitoring an institution's safety and soundness.
4. **Globalization.** As trade grew in the 1960s and 1970s: (i) large international banks became interlinked, so one failure hurt many countries; (ii) differences in capital requirements created competitive (dis)advantages; (iii) clearing and settlement mattered: when **Herstatt Bank** failed in 1974, different currency delivery times across time zones left large FX transactions unsettled.

Only official-sector cooperation could address these risks, so the **BCBS was created in 1974**, after Herstatt. IOSCO followed in 1983 and the IAIS in 1994.

2. Basel I: two motivating events

- **Solvency of cross-border banks.** Cross-border finance kept growing after Herstatt, so the G10 had a common interest in banks holding enough equity to absorb large losses.
- **A level playing field.** International banks competed in each other's home markets, but minimum capital differed widely; banks from low-minimum countries were thought to have an advantage. A global minimum would avoid a race to the bottom. GARP adds that the negotiations also involved maneuvering for competitive advantage.
- **Timing and status.** Published December 1987, agreed July 1988, fully implemented by the end of 1992. Agreed by the G10, a de facto global minimum by the early 2000s, with **no legal standing of its own**: nations adopt it through domestic law.
- **Design.** A dollar minimum was infeasible (banks differ in size), and a leverage ratio would disadvantage low-risk portfolios and favour high-risk ones. So the BCBS chose a **risk-based capital ratio**, with RWA that include off-balance-sheet and derivative exposures (Schweser adds that pre-1988 ratios to total assets missed the growing OTC derivatives, which did not change total assets).
- **Risk covered: credit risk only.**

3. Why the accord kept being revised

Revision	What exposed the gap (GARP)	What it added
1995 Amendment	Derivatives treatment "crude"; offsetting swaps each drew an add-on, penalising hedging, because in 1988 master agreements were untested in bankruptcy courts. By 1995 the BCBS trusted them	Bilateral netting of credit exposures
1996 Amendment	Market risk of the trading book was not captured; the 1987 crash; VaR in widespread use; quantitative market risk management mature	Market risk capital: standardized or internal VaR models
Basel II (2004)	By the mid-1990s Basel I was "not risk-based enough": one 100% weight for loans to highly rated corporates and for commercial real estate development; Nordic crises showed systemic problems in well-capitalized systems; advances in risk measurement; Barings made losses outside credit and market risk concrete; national supervision and disclosure varied widely	Risk-sensitive credit weights (IRB), operational risk capital, Pillars 2 and 3, QIS
Basel 2.5 and III	The 2007 to 2009 crisis (ORR-22)	Stressed VaR, IRC, CRM; capital quality, buffers, leverage and liquidity ratios

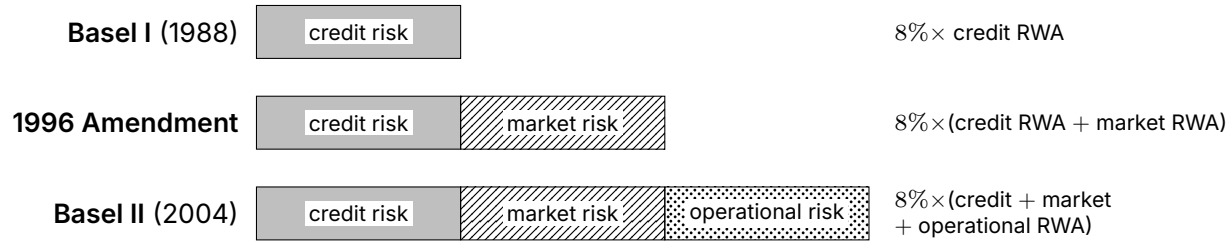


Figure 1. The risk exposures each pre-crisis accord addressed. Credit risk is grey, market risk (from 1996) hatched, operational risk (from Basel II) dotted. The 8% minimum on total RWA never changed; the denominator grew.

Comparison card: ORR-21 a

BCBS (1974)	after Herstatt (settlement across time zones); G10 central banks; IOSCO 1983, IAIS 1994
Basel I (1988)	solvency of cross-border banks + level playing field; risk-based ratio, not leverage; credit risk only; no legal standing
1995 Amendment	netting, once master agreements were trusted in bankruptcy
1996 Amendment	market risk of the trading book; 1987 crash, VaR
Basel II (2004)	not risk-based enough; Nordic crises; better measurement; operational risk (Barings); pillars for convergence
Basel 2.5, III	the 2007 to 2009 crisis (ORR-22 to ORR-24)

Exam traps

- **BCBS against Basel I.** Herstatt (1974) led to the BCBS, not to Basel I (1988). Herstatt was a settlement failure, not a capital or market risk event.
- **Wrong accord for a risk.** Credit 1988; market 1996; operational Basel II. Liquidity ratios and leverage are Basel III.
- **Wrong reason for a revision.** The 1987 crash and VaR drove 1996; the Nordic crises and "not risk-based enough" drove Basel II; untested master agreements explain the late arrival of netting.
- **Legal status.** Basel accords have no legal force of their own; nations adopt them through domestic law.
- **Ratio choice.** Basel I chose a risk-based ratio precisely because a leverage ratio would penalise low-risk portfolios.
- **Private before official.** Clearinghouses did monitor members; their limit was resources (no power to print money), not information.

Practice questions: ORR-21 a

Question ORR-21 a.1 New • built from GARP Ch.21

A trainee at a central bank asks why bank regulation moved from private arrangements to official supervision and international coordination. Which of the following explanations is correct?

A. Private support arrangements, such as clearinghouses that monitored members' solvency, could not cope with panics large enough that only an entity able to print money could support the system, so government-controlled central banks became lenders of last resort.

B. The Basel Committee was created in 1988 to publish Basel I, after the failure of Herstatt Bank showed that banks in countries with low capital minimums held too little equity.

C. The failure of Herstatt Bank in 1974 was a market risk event, a large trading loss on equities, which is why the first Basel accord set capital for market risk.

D. Official regulation began because private arrangements had no information on members' finances: clearinghouse members neither shared financial statements nor had rights of inspection.

Question ORR-21 a.2 Bank Q538 • AnalystPrep Q.4218 (rebuilt; re-filed from LO 62.b)

Which capital measure did the original Basel I accord use to judge the capital sufficiency of banks?

A. Capital divided by the book value of total on-balance-sheet assets

B. Capital divided by risk-weighted assets, including off-balance-sheet and derivative exposures

C. Capital divided by total customer deposits

D. Tier 1 capital divided by total assets, with no minimum for Tier 2 capital

Question ORR-21 a.3 Bank Q527 • AnalystPrep Q.1553 (rebuilt, key corrected)

Which of the following best describes the main motivations for the Basel Committee's introduction of the first international capital standard (Basel I, 1988)?

A. Capital rules differed widely across countries and were based on total assets, ignoring the riskiness of individual banks and off-balance-sheet exposures; internationally active banks in low-requirement countries were seen to have a competitive advantage.

B. A need to impose capital charges for market risk and operational risk, which banks had previously left unmeasured.

C. A need to replace regulatory capital rules with banks' internal models for credit risk, so that capital would reflect each bank's own estimates of default probability.

D. A need to introduce supervisory review and market discipline to complement minimum capital requirements.

Question ORR-21 a.4 Bank Q606 • Schweser Module Quiz 62.2 Q2 (re-filed from LO 62.g)

Which of the following accords first required banks to hold capital for operational risk?

A. Basel I

B. The 1996 Amendment to Basel I

C. Basel II

D. Solvency II

Question ORR-21 a.5 New • built from GARP Ch.21

A regulatory policy analyst is preparing a slide that pairs each pre-crisis revision of the Basel framework with the problem that prompted it. Which pairing is correct?

A. 1995 Amendment, netting: by 1995 the BCBS was confident that master agreements would hold up in bankruptcy, whereas the 1988 rules had penalised hedging by charging an add-on on each offsetting contract.

B. 1996 Amendment, market risk capital: banking crises in the Nordic countries had shown that systemic problems could occur even in well-capitalized banking systems.

C. Basel II, operational risk capital: the 1987 stock market crash had shown that trading book losses were not captured by credit risk-weighted assets.

D. Basel II, Pillars 2 and 3: supervisors wanted to remove national discretion entirely by replacing field supervisors' judgement with uniform rules.

Question ORR-21 a.6 Workbook C5.1 • S2, S3, S4 • Map #30

A regulatory policy analyst at a Canadian bank is presenting a timeline of the Basel accords, from Basel I to the December 2017 reforms, to a group of newly hired analysts. Which of the following statements is correct for the analyst to include?

A. Basel I required Tier 1 capital of at least 4% and total capital of at least 8% of risk-weighted assets, with Tier 2 capital allowed to make up as much as two-thirds of total capital.

B. The December 2017 reforms replaced the Basel II output floor, set at 80% of Basel I capital requirements, with a floor on standardised-approach RWA phased in from 50% in 2022 to 72.5% in 2027.

C. Basel II required internationally active banks to use the standardised approach for credit risk and reserved the IRB approaches for banks whose internal risk measures could not support more granular weights.

D. The December 2017 reforms widened the use of internal models by introducing an internally modelled approach for CVA risk and by retaining the AMA for banks with ten years of loss data.

Solutions • ORR-21 a

Solution ORR-21 a.1

Answer: A

New • built from GARP Ch.21

Step 1 – The limit of private arrangements

Banks banded together to support each other in runs, and clearinghouses monitored members' solvency. GARP: "If a panic was big enough, no entity without the power to print money would have enough resources to support the financial system."

⇒ Government-controlled central banks therefore became lenders of last resort: statement A.

Step 2 – Where Herstatt and the BCBS fit

Herstatt failed in 1974; differences in currency delivery times across time zones left large FX transactions unsettled. The BCBS was created the same year in response. Basel I came 14 years later.

Interpretation

Two separate causal chains are tested here: private to official regulation (panic size, economic cost, customer complaints, globalization), and Herstatt to the BCBS (settlement risk across borders). Basel I's own motivations are the next question.

Why the other options are wrong

B is incorrect. Wrong date and wrong cause: the BCBS dates from 1974, and Herstatt exposed settlement arrangements, not low capital minimums.

C is incorrect. Herstatt was a clearing and settlement failure, and Basel I covered credit risk only; market risk capital came with the 1996 Amendment.

D is incorrect. Polarity flip: clearinghouse members did share financial statements and had rights of inspection. The limit was resources, and the monitoring was private.

LO: ORR-21 a: Explain the motivations for introducing the Basel regulations, including key risk exposures addressed, and explain the reasons for revisions to Basel regulations over time. • **Reference:** Carey (GARP Risk Institute), Ch.21, introduction

Solution ORR-21 a.2

Answer: B

Bank Q538 • AnalystPrep Q.4218

Step 1 – Why a ratio

Banks differ greatly in size, so a minimum in dollars or pounds was infeasible.

Step 2 – Why risk-weighted

A leverage ratio (capital to book assets) would ignore the composition and riskiness of balance sheets: it would disadvantage banks with low-risk portfolios and advantage those with high-risk ones.

⇒ The BCBS chose capital over risk-weighted assets, with RWA covering off-balance-sheet and derivative exposures as well as on-balance-sheet assets.

Interpretation

Minimums: Tier 1 at least 4% and total capital at least 8% of RWA (ORR-21 b). GARP calls these risk-based ratios "a major innovation at the time", crude as they look today.

Why the other options are wrong

A is incorrect. A leverage-type ratio, the alternative the BCBS rejected because it ignores asset risk and off-balance-sheet positions.

C is incorrect. Deposits measure funding, not asset risk; no Basel ratio uses them.

D is incorrect. Basel I set both a Tier 1 and a total capital minimum, and the denominator was RWA, not total assets.

LO: ORR-21 a: Explain the motivations for introducing the Basel regulations, including key risk exposures addressed, and explain the reasons for revisions to Basel regulations over time. ORR-21 b: Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (The Risk-Based Capital Ratio)

Solution ORR-21 a.3 — Answer: A

Bank Q527 • AnalystPrep Q.1553

Step 1 – The state of capital rules before 1988

Requirements were inconsistent across countries and stated as ratios to total assets, which ignored the riskiness of assets. Off-balance-sheet OTC derivatives were growing but did not change total assets, so they did not change required capital.

Step 2 – The two GARP motivations

Growth of cross-border finance gave the G10 a common interest in adequately capitalized banks; differing national minimums gave banks in low-requirement countries a perceived advantage, so the BCBS wanted a level playing field.

$\Rightarrow$ Only A combines the risk-insensitivity of the old rules with the competitive motive.

Interpretation

Basel I answered with risk-weighted assets and an 8% minimum, covering credit risk only. Each distractor describes something that came later.

Why the other options are wrong

B is incorrect. Wrong accords: market risk capital came with the 1996 Amendment, operational risk with Basel II.

C is incorrect. Wrong accord: internal ratings-based approaches arrived with Basel II; Basel I used fixed regulatory weights.

D is incorrect. Wrong accord: supervisory review and market discipline are Pillars 2 and 3 of Basel II.

LO: ORR-21 a: Explain the motivations for introducing the Basel regulations, including key risk exposures addressed, and explain the reasons for revisions to Basel regulations over time. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1; SchweserNotes 2026 Book 3, Reading 62, LO 62.a

Solution ORR-21 a.4 — Answer: C

Bank Q606 • Schweser Module Quiz 62.2 Q2

Step 1 – Risk exposures by accord

Basel I (1988): credit risk only. 1996 Amendment: market risk of the trading book. Basel II (2004): operational risk, "the risk of loss resulting from inadequate or failed internal processes, people and systems, or from external events".

$\Rightarrow$ The first operational risk charge is Basel II's.

Interpretation

GARP ties the new charge to the rogue-trader losses at Barings in the mid-1990s, which made large losses from sources other than credit or market risk concrete. The 8% minimum stayed, but its base now includes operational risk RWA (Figure 1).

Why the other options are wrong

A is incorrect. Basel I covered credit risk only.

B is incorrect. The 1996 Amendment covered market risk, not operational risk.
D is incorrect. Solvency II is the EU framework for insurers, not a bank accord.

LO: ORR-21 a: Explain the motivations for introducing the Basel regulations, including key risk exposures addressed, and explain the reasons for revisions to Basel regulations over time. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Capital for Operational Risk)

Solution ORR-21 a.5 Answer: A

New • built from GARP Ch.21

Step 1 – The 1995 Amendment

The original Basel I gave almost no capital credit for netting: each of two offsetting swaps drew an add-on, which disincentivized hedging, because in 1988 master agreements "had not been sufficiently tested in bankruptcy courts". By 1995 the BCBS was more confident.
⇒ Statement A pairs the change with its stated reason.

Step 2 – Re-pair the distractors

1996 Amendment: the 1987 crash, VaR in widespread use, trading book market risk not captured. Basel II: Basel I not risk-based enough, the Nordic crises, technical advances, and Barings for operational risk. The pillars were a push toward convergence of national practice.

Interpretation

The S4 shape lists real reasons attached to the wrong revision. Anchor each revision to its trigger: hedging penalty (1995), trading losses and VaR (1996), risk insensitivity and Nordic crises (Basel II).

Why the other options are wrong

B is incorrect. The Nordic banking crises are one of GARP's reasons for Basel II, not for the 1996 market risk amendment.
C is incorrect. The 1987 crash is a reason for the 1996 market risk charge. Operational risk capital followed losses such as Barings.
D is incorrect. Absolute claim. Pillars 2 and 3 pushed national practices toward convergence: national discretion "was reduced", not removed, and Pillar 2 relies on supervisors' judgement of each bank's ICAAP.

LO: ORR-21 a: Explain the motivations for introducing the Basel regulations, including key risk exposures addressed, and explain the reasons for revisions to Basel regulations over time. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Netting; The 1995 and 1996 Amendments) and 21.2

Solution ORR-21 a.6 Answer: B

Workbook C5.1 • S2, S3, S4

Step 1 – Place each claim in its accord

Basel I (1988): risk-based ratios and capital definitions. Basel II (2004): credit risk options and the three pillars. December 2017 Basel III reforms: revised standardised approaches, constrained internal models, output floor.

Step 2 – Test the output floor claim against ORR-23 c

The Basel II floor was "calibrated at 80% of the relevant Basel I capital requirements" and was applied inconsistently. It is replaced by a floor based on the revised Basel III standardised approaches: RWA is the higher of RWA under approved approaches and 72.5% of RWA under the standardised approaches only, with the transitional percentage rising 50%, 55%, 60%, 65%, 70% and 72.5% from 1 January 2022 to 1 January 2027 (Table 23.5).

⇒ The floor limits the capital benefit an internal-models bank can draw relative to a standardised bank, keeping a level playing field and supporting comparability.

Interpretation

B is correct. It joins S3 (the two floors) to S4 (Basel II to Basel III progression); the other three statements each corrupt one attribute of the standardised versus internal-models split or of Basel I.

Why the other options are wrong

A is incorrect. Scope/condition error: Basel I capped Tier 2 at no more than half of total capital; Tier 1 above 4% could be counted toward the 8% requirement, not the other way round.

C is incorrect. Role misassignment: the roles are reversed. The standardised approach was "intended for banks with internal risk measures and risk management practices that were insufficient to support the IRB approaches"; the United States did not implement it and required internationally active banks to use IRB.

D is incorrect. Polarity flip: the reforms removed the internal model for CVA risk (leaving SA-CVA and BA-CVA) and replaced the AMA with a single standardised approach for all banks.

LO: ORR-21 a: Explain the motivations for introducing the Basel regulations, including key risk exposures addressed, and explain the reasons for revisions to Basel regulations over time. ORR-23 c: Describe the revised output floor introduced as part of the Basel III reforms and approaches to be used when calculating the output floor. • **Reference:** Carey, Capital Regulation Before the Global Financial Crisis (Basel I; Basel II, Capital for Credit Risk); BCBS, High-Level Summary of Basel III Reforms (Output Floor; Table 23.5; CVA Risk Framework; Operational Risk Framework)

ORR-21 • Capital Regulation Before the Global Financial Crisis • Vardeez: UNTIERED

ORR-21 b

P3 CALC

Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines.

Workbook: *none*

WHAT IS TESTED HERE

Why P3. Vardeez flags it outside a Very Important chapter: ORR-21 is untiered in his sheet, but his theme 3, "Basel III: three components and comparison with Basel I and II", needs Basel I as its baseline. No recall workbook section reports a shape for this LO.

Vardeez: his notes label this LO "LO 60.b" (consolidated volume pp.44 to 46): the 4% and 8% ratios, Tier 1 and Tier 2 instruments, the risk weights, credit conversion factors, the current and original exposure methods, and the Blue Star examples (RWA 175, swap credit equivalent 3.375, capital 14.27).

Reported exam shapes: none reported. The questions are built from the LO wording and Vardeez: capital tiers, on-balance-sheet RWA, off-balance-sheet conversion, derivative credit equivalents, and the capital ratio.

What the questions look like: a balance sheet, an off-balance-sheet book or a derivatives book, sometimes capital figures. You compute RWA, then 8% capital or the capital ratio. Distractors: 100% on uninsured residential mortgages, 20% on OECD governments, unweighted assets, Tier 1 only, a negative derivative value netted, the wrong add-on bucket, a credit equivalent left unweighted.

TYPE note: the verb is "Explain", but 23 of the 25 bank questions are numerical (approved CALC).

See also: the current exposure method with its add-on table, and netting, are under ORR-21 c, Sections 2 and 3.

1. The ratios and what counts as capital

$$\frac{\text{Tier 1 capital}}{\text{RWA}} > 4\% \qquad \frac{\text{Total capital}}{\text{RWA}} > 8\%$$

These are the "Cooke ratios" (after Peter Cooke of the Bank of England). Total capital is Tier 1 plus Tier 2; by design **Tier 2 may be no more than half of total capital**, and Tier 1 above 4% of RWA can be counted towards the 8%.

	GARP	Schweser and Vardeez (instrument lists)
Tier 1 (core)	Common equity and disclosed reserves (retained earnings, some minority interests) minus goodwill; later frameworks admit a limited amount of non-cumulative perpetual preferred stock	Equity minus goodwill; non-cumulative perpetual preferred stock
Tier 2 (supplementary)	General loan loss reserves (capped at 2%, later 1.25% of RWA); undisclosed reserves (including some revaluation reserves); hybrid instruments (unsecured, subordinated, not redeemable at the investor's option, payments deferrable)	Cumulative perpetual preferred stock; certain 99-year debentures; subordinated debt with an original maturity over five years

Two assumptions were implicit: Tier 1 preserves solvency, while Tier 2 funds recapitalization in resolution and cushions depositors; general loan loss reserves were not counted as solvency-preserving capital.

2. On-balance-sheet risk-weighted assets

$$\text{RWA} = \sum_{i=1}^{N} w_i A_i$$

Weight	Asset category (GARP Table 21.1)
0%	Cash; claims on OECD governments; instruments fully guaranteed by an OECD government (for example insured mortgages)
20%	Claims on OECD banks and OECD public sector entities (municipalities, Fannie Mae, Freddie Mac)
50%	Uninsured residential mortgages
100%	All other exposures: commercial and consumer loans, corporate bonds, claims on non-OECD banks

With weights capped at 100%, no position can add more than its book value to RWA. The table assumes no OECD government ever defaults, and that mortgages and bank claims lose less than typical loans: reasonable on the experience of the decades before 1988, much less so later (GARP notes that sovereigns borrowing in foreign currency, or inside the euro area, cannot simply print money).

GARP Example 21.1. A Canadian bank holds CAD 200 million of corporate loans (100%), CAD 100 million of Canadian government bonds (0%), CAD 100 million of government-insured mortgages (0%) and CAD 100 million of uninsured mortgages (50%):

$$\text{RWA} = 1.00 \times 200 + 0 \times 100 + 0 \times 100 + 0.50 \times 100 = \text{CAD } 250 \text{ million}$$

Book assets are 500 but RWA are 250, so the bank needs total capital of at least $8\% \times 250 = 20$, of which Tier 1 at least $4\% \times 250 = 10$ (Figure 1).

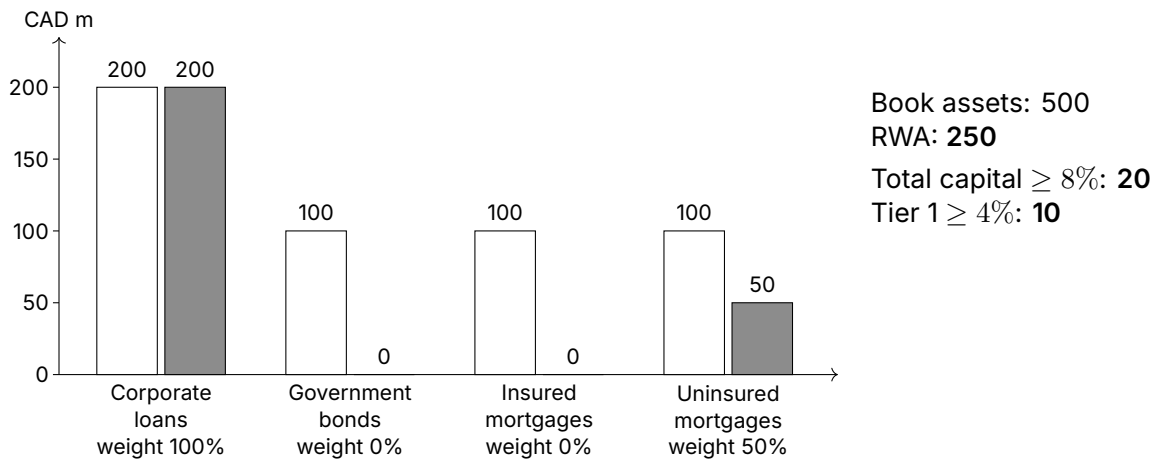


Figure 1. GARP Example 21.1. Open bars are book values, dark grey bars risk-weighted amounts. Half the balance sheet carries a zero weight, so RWA are half of book assets.

3. Off-balance-sheet items: credit conversion factors

Traditional off-balance-sheet exposures are first converted to a **credit equivalent** by a credit conversion factor (CCF); the result then takes the **counterparty's** risk weight:

CCF	Off-balance-sheet category (GARP Table 21.2)
100%	Guarantees on loans and bonds, bankers' acceptances and equivalents
50%	Warranties and standby letters of credit related to transactions
20%	Loan commitments with an original maturity of one year or more
0%	Loan commitments with an original maturity under one year

GARP's example: a USD 100 million five-year loan commitment to an OECD municipality converts to $20\% \times 100 = 20$, which takes the 20% weight of an OECD public sector entity: it adds only USD 4 million to RWA. Schweser's: a USD 200 million standby letter of credit to a government agency gives $50\% \times 200 = 100$, then $20\% \times 100 = 20$.

4. Derivatives: two methods for the credit equivalent

- **Current exposure method:** CEA $= \max(V, 0) + D \times L$, with D from the add-on table under ORR-21 c (interest rate swaps 0%, 0.5%, 1.5%; FX 1%, 5%, 7.5% for under one year, one to five years, over five years). A negative value contributes zero; it is never subtracted.
- **Original exposure method** (interest rate and FX contracts only): ignore the market value; nations choose original or remaining maturity M.

Maturity M (years)	Interest rate contracts	FX contracts
Under one year	0.5%	2%
One to two years	1%	5%
Over two years	$1\% + 1\% \times \text{INT}[M-1]$	$5\% + 3\% \times \text{INT}[M-1]$

GARP Example 21.2. USD 300 million of interest rate swaps and USD 300 million of FX swaps, USD 100 million each at 0.5, 1.5 and 2.5 years; market values $+30$ (swaps) and -10 (FX). Current exposure method: $30 + 0 \times 100 + 0.5\% \times 200 + 1\% \times 100 + 5\% \times 200 = 30 + 0 + 1 + 1 + 10 = 42$. Original exposure method: $0.5\% \times 100 + 1\% \times 100 + 2\% \times 100 + 2\% \times 100 + 5\% \times 100 + 8\% \times 100 = 18.5$ (GARP treats INT$[1.5]$ as 1 for the 2.5-year contracts).

Counterparty weight. The credit equivalent takes the counterparty's weight, but for derivatives GARP adds that "no risk weight could be more than 50%". Equity and commodity derivatives were not covered until the 1995 Amendment.

> **Correction to the source notes.** Vardeez (following Schweser) weights a swap with a corporate counterparty at 100%: the swap adds USD 3.375 million of RWA and Blue Star's capital is $(175 + 3.375) \times 8\% =$ USD 14.27 million. Basel I capped derivative counterparty weights at 50% (GARP: "no risk weight could be more than 50%"), so the corporate swap adds $3.375 \times 50\% = 1.6875$ and the capital is $(175 + 1.6875) \times 8\% =$ USD 14.14 million. GARP's own Example 21.2 also calls the corporate weight "100 percent", but only computes credit equivalents and never applies it. In the exam use the weight the stem states; the bank questions here state it.

5. Putting it together

Minimum total capital $= 8\% \times$ (on-balance-sheet RWA + off-balance-sheet RWA + derivative RWA)

Vardeez's Blue Star. Assets: USD 20 million Treasury bills (0%), 20 insured mortgages (0%), 50 uninsured mortgages (50%), 150 corporate loans (100%): RWA $= 25 + 150 = 175$. Add a USD 175 million interest rate swap with three years left and a value of +2.5: CEA $= 2.5 + 0.5\% \times 175 = 3.375$, which adds $3.375 \times 20\% = 0.675$ for an OECD bank counterparty, or 1.6875 for a corporate at the 50% cap.

Formula card: ORR-21 b

Ratios	Tier 1/RWA $> 4\%$; total capital/RWA $> 8\%$; Tier 2 $\leq$ half of total capital
On balance sheet	RWA $= \sum w_i A_i$; $w = 0\%$ (cash, OECD government), 20% (OECD bank, PSE), 50% (uninsured residential mortgage), 100% (other)
Off balance sheet	credit equivalent = CCF$\times$ principal (100%, 50%, 20%, 0%), then $\times$ counterparty weight
Derivatives, current exposure	CEA $= \max(V, 0) + D \times L$, then $\times$ counterparty weight (at most 50%)
Derivatives, original exposure	IR: 0.5%, 1%, $1\% + 1\%$ INT$[M-1]$; FX: 2%, 5%, $5\% + 3\%$ INT$[M-1]$; market value ignored
Capital	minimum total capital $= 8\%\times$ total RWA; minimum Tier 1 $= 4\%\times$ total RWA

Exam traps

- **Mortgage weights.** Uninsured residential mortgages 50%; government-insured 0%; commercial real estate 100%.
- **Sovereign against agency.** OECD central governments 0%; OECD banks and public sector entities (municipalities, agencies) 20%.
- **Unweighted assets.** The denominator is RWA, not book assets.
- **Tier 1 against total.** 4% is the Tier 1 floor; the capital requirement is 8%. Tier 2 counts only up to half of total capital.
- **Preferred stock.** Non-cumulative perpetual preferred is Tier 1; cumulative perpetual preferred is Tier 2.
- **Off balance sheet, two steps.** Apply the CCF, then the counterparty weight. Commitments under one year convert at 0%.
- **Negative derivative values.** Floored at zero; they never offset other contracts without netting (1995).
- **Add-on bucket.** Check the remaining maturity: exactly five years is in the one-to-five-year bucket.

Practice questions: ORR-21 b

Question ORR-21 b.1

Bank Q543 • BT P2.T7.20.7.2

With respect to the original Basel I accord, each of the following is true EXCEPT which is false?

A. There were only four risk weights: 0%, 20%, 50%, and 100%.

B. Total regulatory capital had to exceed 8.0% of risk-weighted assets (RWA), and Tier 1 capital had to exceed 4.0% of RWA.

C. Traditional off-balance-sheet exposures were converted to a credit equivalent that was then assigned a risk weight based on the counterparty.

D. The credit equivalent for derivatives was their current market value, so out-of-the-money positions reduced the bank's RWA.

Question ORR-21 b.2

Bank Q549 • AnalystPrep Q.2340

Osijek Commercial Bank has to calculate its Tier 1 and Tier 2 capital under Basel I regulations. It has the following capital structure (in EUR; the preferred stocks are perpetual):

Equity	50m
Subordinated debt (original maturity over 5 years)	30m
Cumulative preferred stock	5m
Noncumulative preferred stock	10m

What are the bank's Tier 1 and Tier 2 capital?

A. Tier 1: 55m; Tier 2: 10m

B. Tier 1: 55m; Tier 2: 40m

C. Tier 1: 60m; Tier 2: 5m

D. Tier 1: 60m; Tier 2: 35m

Question ORR-21 b.3

Bank Q540 • AnalystPrep Q.4223 (rebuilt)

A US bank holds $200 million of US Treasury bonds, $500 million of loans to corporations, $300 million of uninsured residential mortgages, and $250 million of claims on OECD public sector entities (e.g., municipalities). What are the bank's risk-weighted assets under the original Basel I accord?

A. $650 million

B. $700 million

C. $850 million

D. $1,250 million

Question ORR-21 b.4 Bank Q529 • AnalystPrep Q.3102 (rebuilt)

Bank A has $6 million of Tier 1 capital and $4 million of Tier 2 capital. Its assets are a $50 million claim on an OECD bank, $100 million of corporate loans, and $40 million of uninsured residential mortgages. Using Basel I risk weights, the bank's ratio of total capital to risk-weighted assets is closest to:

A. 4.6%

B. 5.3%

C. 6.7%

D. 7.7%

Question ORR-21 b.5 New • built from GARP Ch.21

A credit risk officer at a Belgian bank in 1993 is computing the bank's minimum total capital under the original Basel I guidelines. The bank's exposures (EUR million) are:

On balance sheet	
Cash	40
Bonds issued by OECD central governments	160
Claims on OECD banks	100
Uninsured residential mortgages	300
Loans to corporations	500
Off balance sheet	
Transaction-related standby letters of credit; counterparty an OECD bank	80
Undrawn commitments to corporations, original maturity two years	200
Undrawn commitments to corporations, original maturity six months	150

Credit conversion factors: transaction-related standby letters of credit 50%; commitments with an original maturity of one year or more 20%; under one year 0%. Which of the following is closest to the bank's minimum total capital?

A. EUR 28.72 million

B. EUR 53.60 million

C. EUR 57.44 million

D. EUR 60.00 million

Question ORR-21 b.6

Bank Q528 • AP Mock 1 Q41 (rebuilt)

Family Bank has entered a USD 100 million interest rate swap with a corporation. The swap has a remaining maturity of five years and a current value of USD 4.5 million. Basel I caps the risk weight of a derivative counterparty at 50%, so the corporation's weight for this swap is 50%. Add-on factors as a percentage of principal are:

Time remaining to maturity	Interest rate	Equity
<1 year	0.0	6.0
1 to 5 years	0.5	8.0
>5 years	1.5	10.0

Based on the table, the equivalent risk-weighted asset under Basel I is closest to:

A. USD 2,250,000

B. USD 2,500,000

C. USD 3,000,000

D. USD 5,000,000

Question ORR-21 b.7

Bank Q530 • AP Mock 3 Q21 (rebuilt)

Jinshi & Houshi Corporation has adopted the Basel I framework and must maintain at least 8% capital to risk-weighted assets. The add-on factors (percent of principal) are:

Remaining maturity	Interest rate	FX and gold	Equity	Precious metals ex gold	Other commodities
<1 yr	0.0	1.0	6.0	7.0	10.0
1 to 5 yr	0.5	5.0	8.0	7.0	12.0
>5 yr	1.5	7.5	10.0	8.0	15.0

The bank made the following transactions:

(a) A seven-year interest rate swap, notional USD 400 million, current market value $-$USD 3 million.

(b) A three-year interest rate swap, notional USD 170 million, current value $+$USD 7 million.

(c) A four-month commodity derivative, principal USD 80 million, currently worth USD 4 million.

What is the capital requirement if the counterparty is a corporation (risk weight 0.5), assuming no netting?

A. USD 0.517 million

B. USD 0.914 million

C. USD 1.034 million

D. USD 2.068 million

Solutions • ORR-21 b

Solution ORR-21 b.1 — Answer: D

Bank Q543 • BT P2.T7.20.7.2

Step 1 – Check A to C

Four weights: 0%, 20%, 50%, 100% (A true). Total capital above 8% and Tier 1 above 4% of RWA (B true). Off-balance-sheet items are converted by a CCF and then weighted by counterparty, as in GARP's USD 100 million commitment to an OECD municipality: $20\% \times 100 = 20$, then $20\% \times 20 = 4$ (C true).

Step 2 – Test D

The current exposure method sets the credit equivalent to $\max(V, 0)$ plus an add-on $D \times L$. A negative value is floored at zero and never subtracts.
$\Rightarrow$ D is false.

Interpretation

Before the 1995 Amendment, negative values could not offset anything; afterwards they offset only within one counterparty's netting agreement (ORR-21 c).

Why the other options are wrong

A is incorrect. True: Basel I had exactly four weights.
B is incorrect. True: the Cooke ratios.
C is incorrect. True: CCF first, counterparty weight second.

LO: ORR-21 b: Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Risk-Weighted Assets; Tables 21.1 and 21.2)

Solution ORR-21 b.2 — Answer: D

Bank Q549 • AnalystPrep Q.2340

Step 1 – Tier 1

Equity plus non-cumulative perpetual preferred stock: $50 + 10 =$ EUR 60m.

Step 2 – Tier 2

Subordinated debt with original maturity over five years plus cumulative perpetual preferred stock: $30 + 5 =$ EUR 35m.

Step 3 – The Tier 2 limit

Tier 2 (35) is below half of total capital (95), so all of it counts.

Interpretation

The key is the preferred stock: non-cumulative dividends can be skipped for good, so the instrument absorbs losses like equity (Tier 1); cumulative dividends pile up as a claim, so it is Tier 2.

Why the other options are wrong

A is incorrect. Swapped the two preferred stocks and left out the subordinated debt: Tier 1 $= 50 + 5 = 55$, Tier 2 $= 10$.
B is incorrect. Swapped the two preferred stocks: Tier 1 $= 50 + 5 = 55$, Tier 2 $= 30 + 10 = 40$.
C is incorrect. Tier 1 right, but Tier 2 counts only the cumulative preferred and omits the 30m subordinated debt.

LO: ORR-21 b: Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 ("Capital"); SchweserNotes 2026 Book 3, Reading 62, LO 62.b

Solution ORR-21 b.3 — Answer: B

Bank Q540 • AnalystPrep Q.4223

Step 1 – Weight each holding

Treasury bonds (OECD government) $0\% \times 200 = 0$; corporate loans $100\% \times 500 = 500$; uninsured residential mortgages $50\% \times 300 = 150$; OECD public sector entities $20\% \times 250 = 50$.

Step 2 – Sum

$$\text{RWA} = 0 + 500 + 150 + 50 = \$700 \text{ million}$$

Interpretation

RWA are 56% of the USD 1,250 million book; the minimum total capital is $8\% \times 700 = \$56$ million. (The bank version's option of \$600 million matched no single error; it is replaced by the 0%-on-municipalities slip.)

Why the other options are wrong

A is incorrect. Weighted the public sector entities at 0%, like OECD governments: $500 + 150 = 650$.

C is incorrect. Weighted the mortgages at 100%: $500 + 300 + 50 = 850$.

D is incorrect. No risk weighting at all: the book value of 1,250.

LO: ORR-21 b: Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Risk-Weighted Assets; Table 21.1)

Solution ORR-21 b.4 — Answer: D

Bank Q529 • AnalystPrep Q.3102

Step 1 – RWA

$$50 \times 20\% + 100 \times 100\% + 40 \times 50\% = 10 + 100 + 20 = 130$$

Step 2 – Total capital ratio

$$\frac{6 + 4}{130} = 7.69\%$$

$\Rightarrow$ Below the 8% minimum.

Interpretation

The Tier 1 ratio is $6/130 = 4.6\%$, which passes the 4% test; it is the total capital ratio that fails. Tier 2 of 4 is less than Tier 1 of 6, so all of it counts.

Why the other options are wrong

A is incorrect. Tier 1 only: $6/130 = 4.6\%$.

B is incorrect. Unweighted assets: $10/190 = 5.3\%$.

C is incorrect. Mortgages weighted at 100%: RWA $= 150$, $10/150 = 6.7\%$.

LO: ORR-21 b: Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (The Ratio and Minimum Values)

Solution ORR-21 b.5 **Answer: C**

New • built from GARP Ch.21

Step 1 – On-balance-sheet RWA

$$0 \times 40 + 0 \times 160 + 20\% \times 100 + 50\% \times 300 + 100\% \times 500 = 0 + 0 + 20 + 150 + 500 = 670$$

Step 2 – Convert the off-balance-sheet items

Standby letters of credit $50\% \times 80 = 40$; two-year commitments $20\% \times 200 = 40$; six-month commitments $0\% \times 150 = 0$.

Step 3 – Apply the counterparty weights

$$40 \times 20\% + 40 \times 100\% = 8 + 40 = 48$$

$\Rightarrow$ The standby letters of credit take the 20% weight of the OECD bank counterparty.

Step 4 – RWA and capital

$$\text{RWA} = 670 + 48 = 718, \qquad 8\% \times 718 = \text{EUR } 57.44 \text{ million}$$

Interpretation

At least half, EUR 28.72 million $(4\% \times 718)$, must be Tier 1. The EUR 150 million of six-month commitments add nothing: short commitments convert at 0%.

Why the other options are wrong

A is incorrect. Applied the 4% Tier 1 floor instead of the 8% total requirement: $4\% \times 718 = 28.72$.
B is incorrect. Left out the off-balance-sheet items: $8\% \times 670 = 53.60$.
D is incorrect. Converted the standby letters of credit but did not apply the OECD bank's 20% weight: $\text{RWA} = 670 + 40 + 40 = 750$, $8\% \times 750 = 60.00$.

LO: ORR-21 b: Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Risk-Weighted Assets; Tables 21.1 and 21.2)

Solution ORR-21 b.6 **Answer: B**

Bank Q528 • AP Mock 1 Q41

Step 1 – Current exposure

$$\max(V, 0) = \max(4.5, 0) = \text{USD } 4.5 \text{ million}$$

Step 2 – Add-on

A remaining maturity of exactly five years falls in the "1 to 5 years" bucket: $0.5\% \times 100 = 0.5$.

Step 3 – Credit equivalent and RWA

$$\text{CEA} = 4.5 + 0.5 = 5.0, \qquad \text{RWA} = 5.0 \times 50\% = \text{USD } 2.5 \text{ million}$$

Interpretation

The bank version left the counterparty weight unstated and relied on the 50% cap. Because Schweser and Vardeez weight a corporate swap at 100% (see the correction box in Section 4), the stem now states the 50% weight. The equity column is a red herring.

Why the other options are wrong

A is incorrect. Omitted the add-on and weighted the current value only: $4.5 \times 50\% = 2.25$.

C is incorrect. Used the over-five-years add-on of 1.5%: $(4.5 + 1.5) \times 50\% = 3.0$.
D is incorrect. Stopped at the credit equivalent (equivalently, a 100% weight): 5.0.

LO: ORR-21 b: Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Current Exposure Method)

Solution ORR-21 b.7 — Answer: C

Bank Q530 • AP Mock 3 Q21

Step 1 – Credit equivalent of each contract

(a) Value floored at zero; over five years, interest rate: $0 + 1.5\% \times 400 = 6.00$.
(b) One to five years, interest rate: $7 + 0.5\% \times 170 = 7.85$.
(c) Under one year, other commodities: $4 + 10\% \times 80 = 12.00$.

Step 2 – Total, RWA and capital

$$\text{CEA} = 6.00 + 7.85 + 12.00 = 25.85, \qquad \text{RWA} = 25.85 \times 0.5 = 12.925$$

$$\text{Capital} = 8\% \times 12.925 = \text{USD } 1.034 \text{ million}$$

Interpretation

Without netting, the -3 value of swap (a) cannot reduce anything, yet its add-on still counts: a deep out-of-the-money swap still has potential future exposure.

Why the other options are wrong

A is incorrect. Applied 4% (the Tier 1 floor) instead of 8%: $12.925 \times 4\% = 0.517$.
B is incorrect. Let the -3 value of (a) offset its add-on $(-3 + 6 = 3)$, which is netting: $22.85 \times 0.5 \times 8\% = 0.914$.
D is incorrect. Used a 100% weight instead of the stated 50%: $25.85 \times 8\% = 2.068$.

LO: ORR-21 b: Explain the calculation of risk-weighted assets and the capital requirement per the original Basel I guidelines. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (Current Exposure Method; Equity and Commodity Derivatives)

ORR-21 • Capital Regulation Before the Global Financial Crisis • Vardeez: UNTIERED

ORR-21 d

P3 CONCEPT

Describe changes to the Basel regulations made as part of Basel II, including the three pillars.

Workbook: C5 Basel III Post-Crisis Reforms and Stress-Test Regimes • Tier C

WHAT IS TESTED HERE

Why P3. Tier C workbook topic (C5, #30 on the topic map), and Vardeez flags Basel II as a baseline for his theme "Basel III: three components and comparison with Basel I and II".
Vardeez: his notes label this LO "LO 60.d" (consolidated volume pp.47 to 48): Basel I's limitations (borrower creditworthiness ignored, no default correlation and so no diversification benefit) and the three pillars.

Reported exam shapes

- **C5·S4** The Basel I / 1996 / II / 2.5 / III progression, each change attached to the right accord.

What the questions look like: statement and EXCEPT questions on Basel II's four innovations, the content of each pillar, the Pillar 2 principles, the Pillar 3 disclosures, and which risk Basel II added. No calculations.

Recap: why Basel II came is ORR-21 a, Section 3; the timeline is ORR-21 c, Figure 1.

See also: workbook C5.1 also tags this LO; it is worked under ORR-21 a. The credit risk approaches are ORR-21 e and f; the operational risk approaches (ORR-21 g) are P4 and not built.

1. What Basel II kept and what it changed

Discussions began in the late 1990s and the "final" text was published in 2004, with frequent revisions afterwards (Schweser: proposed June 1999, implemented from 2007; it applied to internationally active banks). Basel II **kept** the 8% minimum on RWA, the Tier 1 and Tier 2 definitions and the 1996 market risk rules. GARP lists **four innovations**:

1. **Credit risk weights from modern credit risk concepts and banks' internal risk measures** (the IRB approaches; also a more rating-sensitive standardized approach).
2. **Capital for operational risk**, in addition to credit and market risk.
3. **Pillar 2 (supervisory review) and Pillar 3 (public disclosure)** alongside Pillar 1 (minimum capital).
4. **Repeated Quantitative Impact Studies (QIS):** banks contributed detailed data, supervisors analysed it, and the design was fine-tuned.

The first two drew the most public attention; GARP stresses that the pillars were a major development too.

2. Pillar 1: minimum capital requirements

$$\text{total capital} = 0.08 \times (\text{credit RWA} + \text{market RWA} + \text{operational RWA})$$

- **Credit risk:** standardized (external ratings), Foundation IRB, Advanced IRB (ORR-21 e, f). OECD membership no longer sets the weights.
- **Market risk:** unchanged from 1996 (standardized method or internal VaR models).

- **Operational risk (new):** basic indicator approach (15% of average annual gross income over three years, ignoring negative years), standardized approach (business-line multipliers of 12%, 15% or 18%), advanced measurement approach (internal 99.9% one-year measure; no longer permitted). Details are ORR-21 g (P4).

Schweser's professor's note: Basel II generally lowered credit risk capital, and the new operational risk charge brought the total back to roughly Basel I levels.

3. Pillar 2: supervisory review

GARP: supervisors were to require banks to hold **more than the minimum** capital and to run an **internal capital adequacy assessment process (ICAAP)** that reflects their risk profile. Supervisors assess the ICAAP and act if not satisfied; they **intervene early** (prompt corrective action) when capital threatens to fall below the minimum; they encourage better risk management and push for remedies. National discretion over enforcement was **reduced**, and regulators were to be transparent about implementation, including requirements above the minimum. The four principles as Hull and the bank questions phrase them:

1. Banks assess overall capital adequacy against their risk profile and have a strategy for maintaining capital.
2. Supervisors review and evaluate those assessments and take action if not satisfied.
3. Supervisors expect banks to operate above the minimum and can require capital in excess of it.
4. Supervisors intervene early and require rapid remedial action if capital is not maintained or restored.

Pillar 2 also covers risks outside Pillar 1, such as interest rate risk in the banking book.

4. Pillar 3: market discipline

Banks publish more **qualitative** disclosures (corporate structure, applicability of the accord and approaches used, accounting practices) and **quantitative** disclosures (capital, exposures, risk measures), in the hope that pressure from market participants improves practice. Hull and Schweser list: the entities the rules apply to; the terms of all capital instruments; the instruments in Tier 1 and Tier 2; the capital requirement for each of credit, market and operational risk; other risks; and how the risk management function is organized. GARP adds that disclosure practices stayed uneven for many years, until the Basel Committee added clarity and pressure.

Why pillars at all. Through the early 2000s regulatory philosophy ranged from supervision-heavy (field supervisors' judgement) to rules-heavy (detailed rules, compliance checks), and disclosure varied widely: banks in some nations did not even disclose Basel I ratios or RWA. The pillars were a push toward convergence.

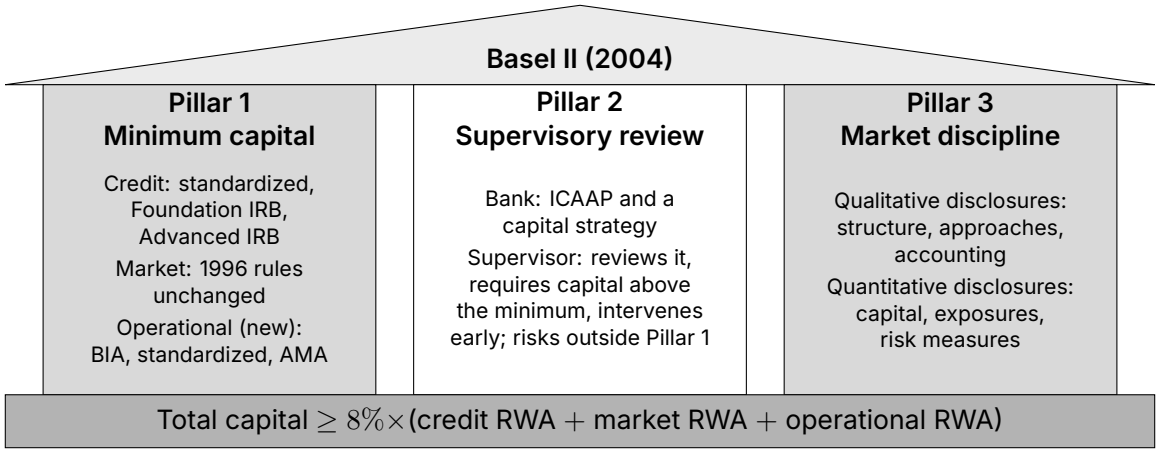


Figure 1. The three pillars of Basel II, resting on the 8% minimum whose base now includes operational risk. The outer pillars are shaded light grey and the middle one is white only to separate them.

Comparison card: ORR-21 d

	Who acts	Content and key words
Pillar 1	Bank, under rules	8% of credit + market + operational RWA; three credit options, 1996 market rules, three operational options
Pillar 2	Supervisor and bank	ICAAP; review and action; capital above the minimum; early intervention; less national discretion
Pillar 3	Bank, for the market	qualitative and quantitative disclosures; market discipline
Innovations		IRB weights; operational risk capital; Pillars 2 and 3; repeated QIS
Unchanged		8% minimum; RWA; capital tiers; 1996 market risk charge

Exam traps

- **RWA kept.** Basel II refined risk weights; it did not abolish RWA or the 8% minimum.
- **Wrong accord.** Stressed VaR is Basel 2.5; capital buffers, CET1 and the leverage ratio are Basel

III; market risk capital is 1996.

- **Pillar 2 direction.** Supervisors expect capital *above* the minimum; they do not discourage it.
- **Pillar 3 is separate.** Regulatory disclosure is not waived because accounting statements are published.
- **Not a pillar.** Corporate governance is not one of the three pillars.
- **Diversification.** Among Pillar 1 options, the internal models approach for market risk recognises diversification; IRB correlations are fixed by formula and the operational standardized approach adds business lines.

Practice questions: ORR-21 d

Question ORR-21 d.1

Bank Q562 • BT P2.T7.24.5.2 (rebuilt)

A junior risk analyst reviews the Basel II framework and summarizes her understanding as follows:

1. Pillar 1 sets minimum capital requirements, equal to 8% of risk-weighted assets covering credit, market and operational risk.
2. Under Pillar 2, banks must have an internal capital adequacy assessment process (ICAAP) that reflects their risk profile, and supervisors review it and may require capital above the minimum.
3. Pillar 3 requires banks to disclose qualitative and quantitative information on their risks and capital, so that market discipline can operate.
4. Basel II is designed to encourage banks to hold as much capital as possible, so that regulatory requirements align with investment objectives.

Which of the above statements is NOT correct?

A. Statement 1

B. Statement 2

C. Statement 3

D. Statement 4

Question ORR-21 d.2 New • built from GARP Ch.21

The head of regulatory reporting at a Portuguese bank is summarizing for the audit committee what changed in Pillar 1 when the bank moved from Basel I (with the 1996 Amendment) to Basel II. Which of the following statements is correct?

A. The minimum total capital ratio stayed at 8% of risk-weighted assets, but operational risk RWA were added to credit and market risk RWA, while the 1996 treatment of market risk was carried over largely unchanged.

B. The minimum total capital ratio rose from 8% to 10.5% of risk-weighted assets, because Basel II added a capital conservation buffer on top of the minimum.

C. Basel II replaced the 1996 internal models approach for market risk with a charge that adds a stressed VaR term to the current VaR term.

D. Under the Basel II standardized approach, OECD membership remained the basis for sovereign and bank risk weights, with external ratings used only for corporate exposures.

Question ORR-21 d.3 Bank Q569 • BT P2.T7.20.8.1

Peter is studying for the FRM exam and wants to understand the difference between the original Basel I accord (the 1988 accord, which includes the 1995/1996 Amendments) and Basel II, published in 2004. His colleague Mary says that significant innovations in Basel II, compared with the original accord, included:

I. In addition to credit risk and market risk, Basel II required capital for operational risk.

II. Basel II eliminated risk weights and risk-weighted assets (RWA) and replaced them with direct calculation of risk charges.

III. Basel II contained specific requirements for supervision related to capital and risk management (Pillar 2) and required public disclosures (Pillar 3).

IV. To fine-tune the accord's design, Basel II made repeated use of Quantitative Impact Studies (QIS), to which banks contributed data that was analyzed by supervisors.

Is Mary correct?

A. Yes, all four statements are correct.

B. I. and II. are correct, but III. and IV. are inaccurate.

C. Only II. is inaccurate, but I., III., and IV. are correct.

D. Unfortunately, none of her statements are correct.

Question ORR-21 d.4

Bank Q563 • BT P2.T7.518.1

The Second Pillar (Pillar 2) of Basel II is concerned with the supervisory review process. Four key principles of supervisory review are specified. Each of the following is a principle EXCEPT, which is inaccurate?

A. Banks should have a process for assessing their overall capital adequacy in relation to their risk profile and a strategy for maintaining their capital levels.

B. Supervisors should review and evaluate banks' internal capital adequacy assessments and strategies, as well as their ability to monitor and ensure compliance with regulatory capital ratios, and take appropriate supervisory action if not satisfied with the result of this process.

C. Supervisors should discourage banks from operating above the minimum regulatory capital limits because this tends to be associated with regulatory arbitrage.

D. Supervisors should seek to intervene at an early stage to prevent capital from falling below the minimum levels required to support the risk characteristics of a particular bank and should require rapid remedial action if capital is not maintained or restored.

Question ORR-21 d.5

Bank Q564 • BT P2.T7.518.2

In regard to the Third Pillar, Hull writes, "Pillar 3 of Basel II is concerned with increasing the disclosure by a bank of its risk assessment procedures and capital adequacy. The extent to which regulators can force banks to increase their disclosure varies from jurisdiction to jurisdiction." According to Hull, each of the following is true about this Third Pillar, EXCEPT, which is inaccurate?

A. Banks should disclose the structure of the risk management function and how it operates.

B. Banks should disclose the terms and conditions of the main features of all capital instruments.

C. If a bank publishes an annual report with GAAP-compliant financial reports, then additional Third Pillar disclosure is waived due to redundancies.

D. Banks should disclose the entities in the banking group to which Basel II is applied and adjustments made for entities to which it is not applied.

Question ORR-21 d.6

Bank Q565 • AP Mock 2 Q66

Pillar 1 of Basel II allows banks to use a range of approaches to compute capital for operational, credit and market risk. Which of the following approaches allows a bank to explicitly recognise diversification benefits?

A. The Foundation Internal Ratings Based approach for credit risk.

B. The Advanced IRB approach for credit risk.

C. The Standardized approach for operational risk.

D. The internal models-based approach for market risk.

Solutions • ORR-21 d

Solution ORR-21 d.1

Answer: D

Bank Q562 • BT P2.T7.24.5.2

Step 1 – Test statements 1 to 3

Pillar 1: total capital $= 0.08\times$(credit + market + operational RWA): true. Pillar 2: ICAAP, supervisory review, power to require capital above the minimum: true. Pillar 3: qualitative and quantitative disclosure for market discipline: true.

Step 2 – Test statement 4

Basel II sets *minimum* capital tied to risk and relies on supervision and disclosure; it never aims to maximize capital.

$\Rightarrow$ Statement 4 is the one that is not correct.

Interpretation

The three pillars split the work: rules set the floor (Pillar 1), supervisors judge whether each bank needs more (Pillar 2), and the market sees enough to discipline the bank (Pillar 3).

Why the other options are wrong

A is incorrect. Statement 1 is true; choosing it confuses Basel II's Pillar 1 with Basel I, which covered credit risk only.

B is incorrect. Statement 2 is true: ICAAP and supervisory review are the core of Pillar 2.

C is incorrect. Statement 3 is true: disclosure is the purpose of Pillar 3.

LO: ORR-21 d: Describe changes to the Basel regulations made as part of Basel II, including the three pillars. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2

Solution ORR-21 d.2

Answer: A

New • built from GARP Ch.21

Step 1 – What Pillar 1 kept

The 8% minimum on RWA and the 1996 market risk charge (standardized method or internal VaR models).

Step 2 – What Pillar 1 changed

Operational risk RWA joined the denominator, and credit risk weights became risk-sensitive: ratings under the standardized approach, internal estimates under IRB.

$\Rightarrow$ Statement A.

Interpretation

Basel II rebuilt the *measurement* of risk inside the same 8% ratio. Higher minimums and buffers had to wait for Basel III.

Why the other options are wrong

B is incorrect. Wrong accord: the 2.5% capital conservation buffer (8% plus 2.5% $= 10.5\%$) is Basel III.

C is incorrect. Wrong accord: the stressed VaR term is Basel 2.5 (in force by end-2011); Basel II left market risk on the 1996 basis.

D is incorrect. Polarity flip: OECD status no longer matters under the Basel II standardized approach; ratings set the weights for sovereigns and banks as well as corporates.

LO: ORR-21 d: Describe changes to the Basel regulations made as part of Basel II, including the three pillars. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Basel II; The Standardized Approach)

Solution ORR-21 d.3 — Answer: C

Bank Q569 • BT P2.T7.20.8.1

Step 1 – Match against GARP's four innovations

I: operational risk capital, true. III: Pillars 2 and 3, true. IV: repeated QIS, true.

Step 2 – Test II

Basel II kept RWA as the denominator of the capital ratio and introduced more sophisticated risk weight formulas for credit risk.

⇒ Only II is inaccurate: C.

Interpretation

The fourth innovation, QIS, is the one most often forgotten: banks supplied detailed data and supervisors used it to calibrate the accord before and after 2004.

Why the other options are wrong

A is incorrect. Accepts II, but RWA were retained.

B is incorrect. Accepts II and rejects III and IV, which are genuine innovations.

D is incorrect. Would require all four to be false; I, III and IV are true.

LO: ORR-21 d: Describe changes to the Basel regulations made as part of Basel II, including the three pillars. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Basel II)

Solution ORR-21 d.4 — Answer: C

Bank Q563 • BT P2.T7.518.1

Step 1 – The four principles

(1) Banks have a process for assessing capital adequacy and a capital strategy. (2) Supervisors review and evaluate it and act if not satisfied. (3) Supervisors expect banks to operate above the minimum and can require capital in excess of it. (4) Supervisors intervene early.

Step 2 – Match the options

A is principle 1, B principle 2, D principle 4. C reverses principle 3.

⇒ C is the inaccurate one.

Interpretation

GARP's own wording: Pillar 2 "mandated that supervisors require banks to have more than the minimum amount of capital". Capital above the minimum is the aim, not a sign of arbitrage.

Why the other options are wrong

A is incorrect. True: the ICAAP principle, a duty of the bank.

B is incorrect. True: the supervisory review principle.

D is incorrect. True: early intervention and prompt corrective action.

LO: ORR-21 d: Describe changes to the Basel regulations made as part of Basel II, including the three pillars. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Pillar 2)

Solution ORR-21 d.5 — Answer: C

Bank Q564 • BT P2.T7.518.2

Step 1 – The required Pillar 3 disclosures

The entities Basel II applies to; the terms of all capital instruments; the instruments in Tier 1 and Tier 2; capital requirements for credit, market and operational risk; other risks; the structure and operation of the risk management function.

⇒ A, B and D are on the list.

Step 2 – Test C

Pillar 3 is a regulatory disclosure regime separate from accounting reports; GAAP statements do not waive it.

Interpretation

GARP notes that disclosure practice stayed uneven for years, even under Pillar 3, which is why the Basel Committee later added clarity and pressure: a waiver for GAAP reporters would point the other way.

Why the other options are wrong

A is incorrect. True: the risk management function must be described.
B is incorrect. True: terms and conditions of capital instruments are required.
D is incorrect. True: the scope of application within the group must be disclosed.

LO: ORR-21 d: Describe changes to the Basel regulations made as part of Basel II, including the three pillars. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.2 (Pillar 3); SchweserNotes 2026 Book 3, Reading 62, LO 62.d

Solution ORR-21 d.6 **Answer: D**

Bank Q565 • AP Mock 2 Q66

Step 1 – Where correlation enters each approach

IRB (Foundation and Advanced): a supervisory formula with a prescribed correlation; capital is portfolio-invariant and adds across exposures. Operational standardized approach: business-line charges simply added. Market risk internal models: the bank's own VaR, which reflects estimated correlations within categories (and across them at the supervisor's discretion).
$\Rightarrow$ Only D recognises diversification explicitly.

Interpretation

This is why banks with material trading books preferred internal models in 1996: lower capital through diversification. Under the AMA a bank could also argue for less than perfect correlation, but only by convincingly defending it; it is not among the options.

Why the other options are wrong

A is incorrect. F-IRB uses the bank's PD inside a formula with a fixed correlation; no bank-specific diversification.
B is incorrect. A-IRB adds the bank's LGD, EAD and M, but the correlation is still set by the formula.
C is incorrect. The standardized approach for operational risk adds the business-line charges, implicitly assuming perfect correlation.

LO: ORR-21 d: Describe changes to the Basel regulations made as part of Basel II, including the three pillars. • **Reference:** Carey (GARP Risk Institute), Ch.21, 21.1 (internal models) and 21.2 (The IRB Approach; Capital for Operational Risk)

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis • Vardeez: UNTIERED

ORR-22 b

P3 CONCEPT

Explain the process of calculating the incremental risk capital charge for positions held in a bank's trading book.

Workbook: *none*

WHAT IS TESTED HERE

Why P3. No workbook section is homed here (the IRC appears only in the revision notes of D4 and A4); Vardeez flags Basel 2.5 for this LO in a reading his sheet leaves untiered.
Vardeez: Basel 2.5, his "LO 61.b" (consolidated volume p.227): the IDRC at 99.9% and one year, its extension to downgrades, and three "key IRC elements" (liquidity horizons, constant level of risk, specific risk charge). Two of his statements need correcting (box in Section 3). His theme 9 (Basel 2.5 calculation) is mapped to ORR-22 a, not here.

Reported exam shapes: none reported; the questions are built from the LO wording and Vardeez.
What the questions look like: statement and EXCEPT questions on why the IRC exists, its 99.9% one-year calibration, what it adds to the 2005 IDRC, the liquidity horizon and constant level of risk, and the boundary with the comprehensive risk charge. No calculations: the LO is "explain the process".

1. Where the IRC sits

The IRC is the second of the three Basel 2.5 trading-book changes (stressed VaR, IRC, comprehensive risk charge; background in ORR-22 a, Section 1). It "roughly" captures **jump-to-default** risk, and after the crisis also **rating-migration** risk, of credit-sensitive positions held in the trading book. Ordinary market risks (rates, FX, equity prices, credit spreads as market moves) stay in VaR and stressed VaR.

2. The process, step by step

1. **The arbitrage it closes.** Banking-book credit capital is a one-year 99.9% measure (IRB). Trading-book capital was a 10-day 99% VaR times a multiplier, plus the specific risk charge. By the early 2000s banks had learned that, even with the specific risk charge, most banking-book exposures needed less capital in the trading book, so many **illiquid instruments posing default risk were placed in the trading book**.
2. **2005: the incremental default risk charge (IDRC).** Two variants: an internal model of default risk calibrated to the IRB's **99.9th percentile at a one-year horizon**, or, without such a model, a "standardized" or "current exposure" approach similar to Basel I specific risk charges. In practice trading-book capital became the **greater of market risk capital and banking-book capital**.
3. **The crisis lesson: widen the scope.** Most credit-related losses in 2007 to 2009 came from **rating changes, wider credit spreads and lost liquidity, not defaults**. The IDRC became the IRC: same 99.9% one-year standard, but banks must also estimate losses from **downgrades** (credit-sensitive rather than only default-sensitive instruments).
4. **Assign a liquidity horizon** to each position: the time over which it could be sold and replaced. It differs by position but is **never less than three months**.
5. **Simulate over the year with a constant level of risk.** At the end of each liquidity horizon, any position that has been downgraded or has defaulted is **sold, with the loss recorded**, and replaced

by a position with the **same pre-downgrade rating**. Portfolio credit quality is held approximately constant (Figure 1).

6. **Read off the IRC** as the 99.9th percentile of the simulated one-year loss distribution. Rebalancing books many small downgrade losses but makes defaults less likely, so the constant level of risk assumption **generally reduces** the one-year 99.9% VaR relative to holding the positions all year (Schweser).

Securitizations and other correlation-book positions are taken out of the IRC: for them the comprehensive risk charge replaces both the IRC and the specific risk charge (ORR-22 c).

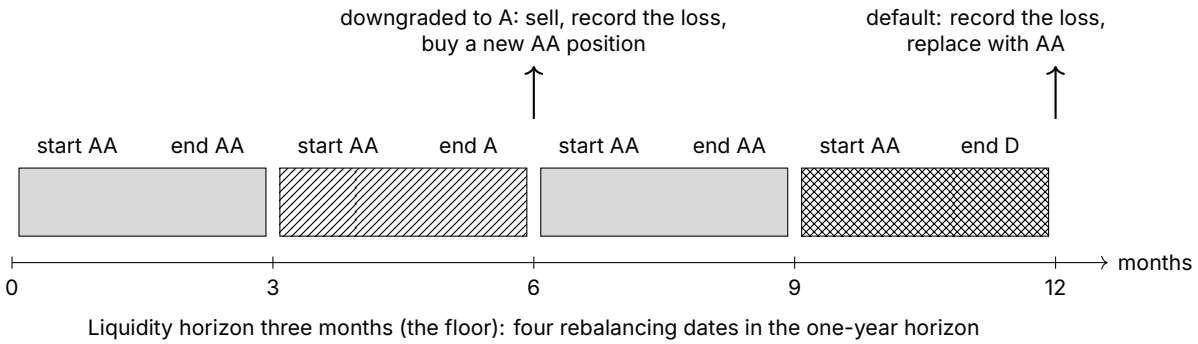


Figure 1. Constant level of risk for one AA position with a three-month liquidity horizon. Grey blocks: no rating change. Hatched block: downgraded to A, sold at the end of the horizon with the loss recorded and replaced by AA. Crosshatched block: default, loss recorded, replaced by AA. The IRC is the 99.9th percentile of the one-year sum of such losses across the portfolio.

3. The three Basel 2.5 charges side by side

	Stressed VaR	Incremental risk charge	Comprehensive risk charge
Positions	Whole trading book	Credit-sensitive positions (bonds, CDS)	Correlation book: securitizations, re-securitizations, derivatives on them
Risk captured	Market moves in a stress year	Default and rating migration	Default correlation, spreads, recoveries, hedges
Measure	10-day 99% VaR, $\max(\text{SVaR}_{t-1}, m_s\text{SVaR}_{avg})$	One-year 99.9% VaR with liquidity horizons (≥ 3 months)	Standardized table by rating, or an approved internal model
Replaces	Nothing (added)	Nothing (added; the 2005 IDRC evolved into it)	The IRC and the specific risk charge for those positions

Correction to the source notes. (1) Vardeez's LO 61.a summary describes the IRC as "aimed at capturing the risk from non-trading book items that could affect the trading book". The IRC captures default and migration risk of credit positions *held in the trading book*; what motivated it was that banking-book-type, default-risky instruments had been moved into the trading book, where capital was lower. (2) His notes list the specific risk charge as the third "key IRC element". The SRC is a separate charge from the 1996 Amendment (multiplier 4 under internal models); the IRC is added alongside it, and only for the correlation book are both replaced, by the CR charge.

Exam traps

- **Calibration swap.** The IRC is one-year 99.9%; the 10-day 99% VaR with a multiplier is the market risk measure it was designed to supplement.
- **Default only.** That was the 2005 IDRC; the IRC adds rating migration.
- **Direction of the arbitrage.** Trading-book capital was the *lower* one; instruments moved *into* the trading book.
- **Liquidity horizon floor.** Never less than three months.
- **Polarity of rebalancing.** Constant level of risk generally lowers the 99.9% VaR (downgrade losses are booked, but defaults become less likely).
- **Scope.** Securitizations and re-securitizations go to the CR charge, not the IRC.

Practice questions: ORR-22 b

Question ORR-22 b.1

Bank Q637 • AnalystPrep Q.4288 (rebuilt)

In 2005 the Basel Committee proposed an incremental default risk charge (IDRC) for trading book instruments. Which description of the proposal is most accurate?

A. An internal default model calibrated to the 99.9th percentile at a one-year horizon, as in the IRB approach, or, absent such a model, a standardized or current exposure approach similar to Basel I specific risk charges.

B. An internal default model calibrated to a 99% confidence level over a 10-day horizon, multiplied by a factor of at least three.

C. Only a standardized approach based on external ratings, with no internal model permitted.

D. A stressed VaR using a 250-day period of market stress, added to the usual VaR.

Question ORR-22 b.2

Bank Q634 • AnalystPrep Q.4035 (key corrected in the bank; options reordered)

Which of the following risks is specifically recognized by the incremental risk charge (IRC)?

A. Interest rate risk

B. Foreign exchange risk

C. Jump-to-default risk

D. Equity price risk

Question ORR-22 b.3 Bank Q636 • BT P2.T7.520.2

Basel 2.5 introduced three changes to market risk capital: a stressed VaR, an incremental risk charge (IRC), and a comprehensive risk measure for instruments dependent on credit correlation. In regard to the IRC, each of the following is true EXCEPT which statement is untrue?

A. The IRC was introduced because instruments in the trading book often required less regulatory capital than equivalent instruments in the banking book.

B. The IRC is calculated as the one-year 99.9% value at risk (VaR) for losses from credit instruments in the trading book.

C. The IRC excludes ratings changes or migrations because a rating change does not itself lead to default within the one-year horizon.

D. The constant level of risk assumption assumes that the bank will have the opportunity to rebalance its portfolio during the year so that default risk is mitigated.

Question ORR-22 b.4 Bank Q638 • Schweser Module Quiz 63.1 Q2 (options reordered)

Banks are required to rebalance their portfolios as the creditworthiness of bonds declines, leading to losses over time but generally not to outright default. This requirement to specify a liquidity horizon for each instrument in the portfolio and rebalance at the end of the liquidity horizon is part of the:

A. comprehensive risk charge calculation.

B. net stable funding charge formula.

C. countercyclical buffer estimation.

D. incremental risk charge calculation.

Question ORR-22 b.5 New • built from GARP Ch.22

The head of a credit trading desk at a German bank is drafting the documentation for the desk's incremental risk charge model. The desk holds corporate bonds in the trading book. Which of the following statements in the draft is correct?

A. Each bond is assigned a liquidity horizon, and for the most liquid bonds the horizon may be set as short as one month.

B. A bond downgraded from AA to A within its six-month liquidity horizon is assumed sold at the end of the horizon, with the loss recorded, and replaced by an AA-rated bond.

C. Because the portfolio is rebalanced to its initial credit quality, the constant level of risk assumption generally increases the one-year 99.9% VaR relative to holding the positions all year.

D. The charge is a 10-day 99% VaR of default losses only, multiplied by a factor of at least three, as for general market risk.

Question ORR-22 b.6 Bank Q635 • BT P2.T7.20.9.2

In regard to the incremental risk charge (IRC) in Basel 2.5, each of the following is true EXCEPT, which is false?

A. The IRC is calculated as the one-year 99.9% value at risk (VaR) for losses on credit instruments in the trading book.

B. The IRC is designed to account for correlation risks in the correlation book, which includes securitizations and re-securitizations.

C. The IRC (itself an amended IDRC) was motivated by regulatory arbitrage; consequently, required capital in the trading book is the greater of market risk capital and banking book capital.

D. In addition to default risk, via its constant level of risk rebalancing assumption, the IRC measures credit deterioration (ratings downgrades and/or credit spread widening) and/or loss of liquidity.

Solutions • ORR-22 b

Solution ORR-22 b.1

Answer: A

Bank Q637 • AnalystPrep Q.4288

Step 1 – The problem the IDRC addressed

Illiquid, default-risky instruments were being placed in the trading book because capital there was lower than in the banking book.

Step 2 – The two variants proposed

An internal model of default risk calibrated like the IRB (99.9th percentile, one year); or, without such a model, a standardized or current exposure approach resembling Basel I specific risk charges.

$\Rightarrow$ In practice, trading-book capital became the greater of market risk and banking-book capital.

Interpretation

The calibration is the point: matching the banking book's 99.9% one-year standard removes the incentive to switch books.

Why the other options are wrong

B is incorrect. Describes the 1996 market risk VaR (10-day 99% times a multiplier), the very measure that produced the low capital.

C is incorrect. Leaves out the internal-model variant; both were proposed.

D is incorrect. Describes stressed VaR, a separate Basel 2.5 change.

LO: ORR-22 b: Explain the process of calculating the incremental risk capital charge for positions held in a bank's trading book. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Incremental Risk Charge

Solution ORR-22 b.2

Answer: C

Bank Q634 • AnalystPrep Q.4035

Step 1 – What the IRC adds

A one-year 99.9% charge for credit events on credit-sensitive trading-book positions: default ("roughly capturing the jump-to-default risk") and, after the crisis, rating migration.

Step 2 – Match the options

Interest rate, FX and equity price risk are market risks captured by VaR and stressed VaR.

$\Rightarrow$ Only jump-to-default is a credit event.

Interpretation

GARP's own summary of the second Basel 2.5 change: "capital for incremental risk was added (roughly capturing the jump-to-default risk)". (The bank's original key was corrected to this answer.)

Why the other options are wrong

A is incorrect. Interest rate risk is general market risk, in VaR and SVaR.

B is incorrect. FX risk is general market risk, in VaR and SVaR.

D is incorrect. Equity price risk is general market risk, in VaR and SVaR.

LO: ORR-22 b: Explain the process of calculating the incremental risk capital charge for positions held in a bank's trading book. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 (introduction and Incremental Risk Charge)

Solution ORR-22 b.3 — Answer: C

Bank Q636 • BT P2.T7.520.2

Step 1 – Test A, B and D

A: the trading book needed less capital than the banking book, which created the arbitrage: true. B: the IRC is a one-year 99.9% VaR on credit instruments in the trading book: true. D: rebalancing at each liquidity horizon to the original rating mitigates default risk: true.

Step 2 – Test C

The 2005 IDRC covered defaults only. Because most crisis credit losses came from rating changes, spreads and liquidity, "the scope of the proposal was increased to include changes in ratings".
⇒ C is false: the IRC explicitly includes migration.

Interpretation

The step from IDRC to IRC is exactly the addition of rating migration, so C states the IDRC, not the IRC.

Why the other options are wrong

A is incorrect. True: regulatory arbitrage between the books was the motivation.
B is incorrect. True: this is the IRC's calibration.
D is incorrect. True: this is the constant level of risk assumption.

LO: ORR-22 b: Explain the process of calculating the incremental risk capital charge for positions held in a bank's trading book. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Incremental Risk Charge; SchweserNotes 2026 Book 3, Reading 63, LO 63.b

Solution ORR-22 b.4 — Answer: D

Bank Q638 • Schweser Module Quiz 63.1 Q2

Step 1 – Recognize the two features

A liquidity horizon per instrument (at least three months) and rebalancing to the original rating at the end of each horizon, with the downgrade loss recorded.
⇒ These are the liquidity horizon and the constant level of risk assumption of the IRC.

Interpretation

Rebalancing means the bank books small losses on downgraded positions but rarely carries a position all the way into default.

Why the other options are wrong

A is incorrect. The comprehensive risk charge covers the correlation book, by rating table or internal model; it has no liquidity-horizon rebalancing rule.
B is incorrect. The NSFR is a Basel III funding ratio; nothing in it is rebalanced.
C is incorrect. The countercyclical buffer is a capital add-on set by national supervisors.

LO: ORR-22 b: Explain the process of calculating the incremental risk capital charge for positions held in a bank's trading book. • **Reference:** SchweserNotes 2026 Book 3, Reading 63, LO 63.b; Carey (GARP Risk Institute), Ch.22, 22.2

Solution ORR-22 b.5 — Answer: B

New • built from GARP Ch.22

Step 1 – The replacement rule

"Any position that is downgraded or that defaults is replaced by a position with the same pre-downgrade rating. A loss is recorded from sale of the downgraded or defaulted position."
⇒ B describes this exactly: sell at the end of the horizon, book the loss, buy AA again.

Step 2 – Check the other three against the rules

The replacement period "differs across positions according to their liquidity but is never less than three months". Rebalancing keeps credit quality roughly constant and generally reduces the 99.9% VaR. The calibration is one-year 99.9%, covering downgrades as well as defaults.

Interpretation

The process is: liquidity horizon per position, simulate defaults and downgrades, rebalance at each horizon, take the 99.9th percentile of the one-year loss.

Why the other options are wrong

A is incorrect. The floor is three months; one month is not allowed.

C is incorrect. Polarity flip: rebalancing makes default less likely, so it generally lowers the one-year 99.9% VaR.

D is incorrect. Describes the market risk VaR with its multiplier, restricted to defaults; the IRC is one-year 99.9% and includes migration.

LO: ORR-22 b: Explain the process of calculating the incremental risk capital charge for positions held in a bank's trading book. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Incremental Risk Charge; SchweserNotes 2026 Book 3, Reading 63, LO 63.b

Solution ORR-22 b.6 Answer: B

Bank Q635 • BT P2.T7.20.9.2

Step 1 – Test A, C and D

A: one-year 99.9% VaR of credit losses in the trading book: true. C: the IRC grew from the 2005 IDRC, a response to arbitrage between the books, with trading-book capital the greater of market risk and banking-book capital: true. D: the IRC covers downgrades and the effects of spreads and liquidity through its rebalancing assumption: true.

Step 2 – Test B

Securitizations, re-securitizations and derivatives on them form the correlation book. For them the comprehensive risk charge *replaces* the IRC and the specific risk charge.

$\Rightarrow$ B is false.

Interpretation

The boundary question: credit-sensitive single-name positions go to the IRC; correlation-sensitive tranched positions go to the CR charge (ORR-22 c).

Why the other options are wrong

A is incorrect. True: the IRC's definition.

C is incorrect. True: the regulatory-arbitrage origin and its consequence.

D is incorrect. True: migration and rebalancing are what distinguish the IRC from the IDRC.

LO: ORR-22 b: Explain the process of calculating the incremental risk capital charge for positions held in a bank's trading book. ORR-22 c: Describe the comprehensive risk (CR) capital charge for portfolios of positions that are sensitive to correlations between default risks. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 (Incremental Risk Charge; Correlations and the Comprehensive Risk Measure)

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis • Vardeez: UNTIERED

ORR-22 c

P3 CONCEPT

Describe the comprehensive risk (CR) capital charge for portfolios of positions that are sensitive to correlations between default risks.

Workbook: *none*

WHAT IS TESTED HERE

Why P3. No workbook section is homed here (the CR charge appears in the revision notes of D4 and A4); Vardeez flags Basel 2.5 for this LO in an untiered reading.
Vardeez: Basel 2.5, his "LO 61.c" (consolidated volume p.228): a single charge replacing the IRC and the specific risk charge for correlation-dependent instruments (ABS, CDOs), with dollar-for-dollar capital below BB— or unrated.

Reported exam shapes: none reported; the questions are built from the LO wording and Vardeez.
What the questions look like: statement and EXCEPT questions on what the CR charge replaces, why correlation-sensitive instruments needed it, how to read the standardized table, and what an internal model must capture. The table's numbers appear in the notes for recognition only: this is a describe LO, so bank Q641 (a three-tranche charge calculation) is left out under the TYPE rule.

1. Scope and motivation

The CR charge is the third Basel 2.5 change (background in ORR-22 a, Section 1). It applies to the **correlation book**: securitizations, re-securitizations and derivatives written on securitizations (Schweser's examples: ABS and CDOs). For these instruments it is a **single charge that replaces both the IRC and the specific risk charge**.

Why a separate charge. Basel II's credit capital rests on the Gordy (2003) model, which treats the correlation parameter as **constant across obligors and over time** (though not across asset types). That is reasonable for portfolios of ordinary debt in the banking book. It is not reasonable for the correlation book: a securitization places a portfolio in a special-purpose vehicle and issues **tranched liabilities** of different seniority, and changes in correlation have large effects on tranche values. Before the crisis, prices of AAA tranches were consistent with a near-zero PD; during the crisis market PD estimates rose sharply and tranche prices fell. In normal times highly rated tranches look safe; under stress correlations rise and even the highest-rated tranches can lose (Schweser).

2. The standardized approach

Banks may use a standardized approach that depends **only on the rating of the instrument** (and on whether it is a securitization or a re-securitization):

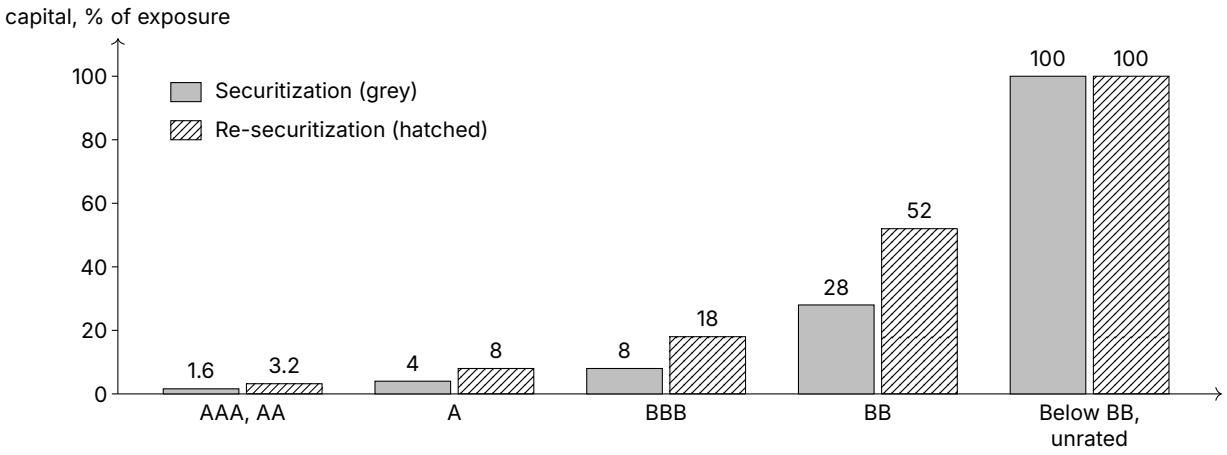


Figure 1. GARP Table 22.1 redrawn: capital as a percentage of exposure (not risk weights) under the standardized CR charge. Re-securitizations carry roughly twice the securitization charge in every rated bucket; below BB or unrated, both are 100%.

- **Capital, not risk weights.** The percentages are capital as a fraction of exposure; do not multiply them by 8%. Per USD 10 million: AA securitization USD 0.16 million, BBB re-securitization USD 1.8 million, unrated tranche USD 10 million.
- **Re-securitizations** (the underlying pool is itself the tranched liabilities of securitization vehicles, as in a CDO of ABS) are more vulnerable to changes in correlation, so their charges are much higher.
- **Below BB or unrated**: 100%. These tranches are the most exposed to losses in the underlying pool and "in effect must be financed entirely with capital" (dollar-for-dollar).
- In the US, Dodd-Frank does not allow ratings in capital rules, so the US has had to devise CR rules without them (Schweser).

3. Internal models

With supervisory approval a bank may estimate the CR charge with an internal model, but the model-based charge **may not be less than a fraction of the standardized charge**. Because these instruments are complex, and a model is usually wanted to capture hedges better, the model must be "unusually complete, complicated and robust". GARP's list: multiple default and rating-change events; volatility in correlations and in credit spreads; basis risk (for example CDS against the underlying index); the dynamics of hedges; volatility in recovery rates; ideally simulations that revalue the whole portfolio on each iteration. Schweser adds that the bank must routinely run rigorous stress tests. (Later, FRTB moved securitizations to the standardized approach only, because model results varied too much across banks: MR-18 c.)

	Incremental risk charge (ORR-22 b)	Comprehensive risk charge
Positions	Credit-sensitive single-name positions	Correlation book: securitizations, re-securitizations, derivatives on them
Key risk	Default and rating migration	Changes in default correlation and their effect on tranches
Method	One-year 99.9% VaR, liquidity horizons, constant level of risk	Rating table (capital % of exposure) or approved internal model with a floor
Relation	Added to VaR, SVaR and the SRC	Replaces the IRC and the SRC for these positions

Exam traps

- **What it replaces.** Both the IRC and the specific risk charge, for the correlation book only; it does not replace VaR or stressed VaR.
- **Risk weights.** The table is capital as a percentage of exposure.
- **Re-securitization direction.** Higher charges than securitizations, never lower.
- **The top of the table.** The maximum is 100% (below BB or unrated), not the 28% BB securitization charge.
- **AAA tranches are not exempt.** Their crisis losses are why the charge exists.
- **Internal models are floored** at a fraction of the standardized charge and need supervisory approval.
- **Gordy's assumption.** Constant (not zero) correlation, across obligors and over time.

Practice questions: ORR-22 c

Question ORR-22 c.1

New • built from GARP Ch.22

The head of the correlation trading desk at a UK bank asks why Basel 2.5 introduced a separate comprehensive risk (CR) charge for the desk instead of relying on the treatment of credit risk in the IRB framework. Which of the following is the best explanation?

A. The IRB framework assumes default correlation is zero, which overstates diversification in every credit portfolio, including ordinary loan books.

B. The Gordy model behind IRB holds correlation constant across obligors and over time; that suits ordinary debt portfolios, but tranche values move sharply when correlations change.

C. Correlation-sensitive instruments had been placed in the banking book to exploit its lower capital, so the CR charge moves them into the trading book.

D. Highly rated tranches had defaulted frequently before the crisis, so the CR charge was calibrated to the observed pre-crisis default rates of AAA tranches.

Question ORR-22 c.2

Bank Q642 • New in the bank (GARP practice-exam style)

A risk manager is explaining the Basel 2.5 comprehensive risk (CR) charge to the trading desk heads. Which of the following statements is correct?

A. Under the standardized approach, a re-securitization carries the same capital charge as a securitization with the same rating because the charge depends only on the rating.

B. Highly rated securitization tranches are excluded from the CR charge because they are not exposed to losses even when default correlations rise.

C. A bank approved to use an internal model may set the CR charge at whatever level the model produces, since approval removes any link to the standardized approach.

D. The CR charge applies to the correlation book and replaces both the incremental risk charge and the specific risk charge for those positions.

Question ORR-22 c.3

New • built from GARP Ch.22

A market risk analyst is classifying positions in the bank's correlation book for the Basel 2.5 standardized comprehensive risk charge. Which of the following positions should be charged on the re-securitization schedule?

A. A CDO whose collateral pool consists of mezzanine tranches issued by residential mortgage securitization vehicles.

B. A residential mortgage-backed security whose collateral pool consists of prime first-lien mortgages.

C. A synthetic CDO tranche referencing a portfolio of 100 single-name corporate credit default swaps.

D. A collateralized loan obligation tranche backed by a pool of leveraged corporate loans.

Question ORR-22 c.4 New • built from GARP Ch.22

A risk analyst is presenting the Basel 2.5 standardized approach to the comprehensive risk charge to the bank's securitization traders. Which of the following statements is correct?

A. The percentages in the table are risk weights, so a BBB securitization requires capital of 8% of exposure multiplied by the 8% minimum capital ratio.

B. Re-securitizations attract lower charges than securitizations with the same rating, because their underlying pools are themselves diversified tranches.

C. Tranches rated below BB, or unrated, attract a 100% charge, so in effect the bank must finance such positions entirely with capital.

D. The charge for a tranche depends on its rating, on its seniority within the deal and on the bank's own estimate of default correlation.

Question ORR-22 c.5 Bank Q640 • BT P2.T7.520.3

According to Hull, each of the following is true about the comprehensive risk measure (CRM) EXCEPT, which is not accurate?

A. The CRM is a single capital charge replacing the incremental risk charge and the specific risk charge for instruments dependent on credit correlation.

B. The CRM can be calculated using a standardized approach which determines a charge based on the credit rating (e.g., BBB+ to BBB−) of the securitization or re-securitization.

C. The maximum capital charge under the standardized approach is 28.0%, which applies to the securitization with the lowest credit rating.

D. The Basel Committee allows banks with supervisory approval to use their internal models to calculate the CRM for unrated positions, but the models developed by banks have to be sophisticated in order to be approved by bank supervisors.

Question ORR-22 c.6 New • built from GARP Ch.22

A bank applies to its supervisor to calculate the comprehensive risk charge for its correlation book with an internal model. Which of the following conditions applies to the model?

A. It must capture multiple default and rating-change events, volatility in correlations and spreads, basis risk, hedge dynamics and recovery volatility, and its charge is floored at a fraction of the standardized charge.

B. Once approved, it replaces the standardized approach entirely, so the bank no longer needs to compute the standardized charge for the correlation book.

C. It need only reproduce the incremental risk charge calculation: a one-year 99.9% VaR of default and migration losses under a constant level of risk.

D. Because it captures hedges more precisely, its charge is expected to exceed the standardized charge, which therefore acts as a cap on the model result.

Solutions • ORR-22 c

Solution ORR-22 c.1

Answer: B

New • built from GARP Ch.22

Step 1 – The IRB assumption

Basel II assumes the Gordy (2003) correlation parameter is constant across obligors and over time (though not across asset types).
⇒ Reasonable for portfolios of debt instruments in the banking book.

Step 2 – Why it fails for the correlation book

Securitizations issue tranches of different seniority; "correlations change over time and such changes can have large effects on the value of tranches". AAA tranche prices implied near-zero PD before the crisis and fell when market PD estimates rose.

Interpretation

The CR charge exists because tranche value is a function of correlation, which the IRB framework treats as a fixed parameter.

Why the other options are wrong

A is incorrect. The Gordy model uses a positive, constant correlation, not zero; and GARP calls the assumption reasonable for ordinary debt portfolios.
C is incorrect. Wrong book and wrong charge: the arbitrage ran into the *trading* book, where capital was lower, and it is the IRC's story (ORR-22 b).
D is incorrect. Polarity flip: pre-crisis prices implied a near-zero PD for AAA tranches; losses came with the crisis.

LO: ORR-22 c: Describe the comprehensive risk (CR) capital charge for portfolios of positions that are sensitive to correlations between default risks. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Correlations and the Comprehensive Risk Measure

Solution ORR-22 c.2

Answer: D

Bank Q642 • New in the bank

Step 1 – Scope

The CR charge covers the correlation book (securitizations, re-securitizations, derivatives on them) and replaces the IRC and the specific risk charge for those positions.
⇒ D is correct.

Step 2 – Test the other statements

The standardized charge depends on the rating, but on a higher schedule for re-securitizations; highly rated tranches are included; internal-model charges are floored at a fraction of the standardized charge.

Interpretation

Each wrong option drops one condition: the re-securitization schedule, the inclusion of top-rated tranches, the floor.

Why the other options are wrong

A is incorrect. Re-securitizations are more vulnerable to correlation changes and carry much higher charges (BBB: 18% against 8%).
B is incorrect. Rising correlations in stress can hit even the highest-rated tranches; that is why they are included.
C is incorrect. The model-based charge may not be less than a fraction of the standardized

charge, and needs supervisory approval.

LO: ORR-22 c: Describe the comprehensive risk (CR) capital charge for portfolios of positions that are sensitive to correlations between default risks. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Correlations and the Comprehensive Risk Measure, Table 22.1

Solution ORR-22 c.3 — Answer: A

New • built from GARP Ch.22

Step 1 – The definition

A re-securitization is a securitization whose underlying pool consists of "the tranched liabilities of securitization vehicles".

Step 2 – Apply it

A CDO holding mezzanine RMBS tranches has tranches as collateral: a re-securitization. The RMBS (mortgages), the synthetic CDO (single-name CDS) and the CLO (loans) all reference ordinary assets.

Interpretation

Tranches of tranches compound the sensitivity to correlation, which is why the re-securitization schedule is roughly twice the securitization schedule in every rated bucket.

Why the other options are wrong

B is incorrect. Mortgages are ordinary assets: a securitization.
C is incorrect. A synthetic CDO referencing single-name CDS is a securitization of credit exposures, not of tranches.
D is incorrect. A CLO pools loans: a securitization.

LO: ORR-22 c: Describe the comprehensive risk (CR) capital charge for portfolios of positions that are sensitive to correlations between default risks. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Correlations and the Comprehensive Risk Measure; SchweserNotes 2026 Book 3, Reading 63, LO 63.c

Solution ORR-22 c.4 — Answer: C

New • built from GARP Ch.22

Step 1 – Read the table correctly

The percentages are "capital as a fraction of the exposure, not risk weights". They depend only on the rating, on the securitization or re-securitization schedule.

Step 2 – The bottom of the rating scale

Below BB, or unrated: 100% on both schedules. These tranches are the most exposed to pool losses, so "in effect they must be financed entirely with capital".
$\Rightarrow$ C is correct.

Interpretation

Dollar-for-dollar capital is the standardized approach's way of saying such a tranche behaves like equity in the underlying pool.

Why the other options are wrong

A is incorrect. Treats capital percentages as risk weights; the 8% is already the capital.
B is incorrect. Polarity flip: re-securitizations are charged more (for example 18% against 8% at BBB).
D is incorrect. The standardized charge depends only on the rating (and the schedule); bank correlation estimates enter only an approved internal model.

LO: ORR-22 c: Describe the comprehensive risk (CR) capital charge for portfolios of positions that are sensitive to

correlations between default risks. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2, Table 22.1

Solution ORR-22 c.5 — Answer: C

Bank Q640 • BT P2.T7.520.3

Step 1 – The standardized schedule

Securitizations: 1.6%, 4%, 8%, 28%, 100% for AAA/AA, A, BBB, BB, below BB or unrated; re-securitizations 3.2%, 8%, 18%, 52%, 100%.
⇒ 28% is the BB securitization charge; the maximum is 100%. C is false.

Step 2 – The true statements

A: the CR charge replaces the IRC and SRC for correlation-dependent instruments. B: the standardized charge is rating based. D: internal models need supervisory approval and must be sophisticated.

Interpretation

The question tests the top of the table. Below BB the tranche absorbs pool losses first, so it is capitalized dollar for dollar. (Option D follows Hull's "unrated positions"; GARP allows approved internal models for the CR charge generally.)

Why the other options are wrong

A is incorrect. True: the CR charge is a single replacement charge for the correlation book.
B is incorrect. True: the standardized approach depends only on the rating (on the right schedule).
D is incorrect. True as stated: approval and sophistication are both required.

LO: ORR-22 c: Describe the comprehensive risk (CR) capital charge for portfolios of positions that are sensitive to correlations between default risks. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2, Table 22.1; Hull, RMFI (Basel 2.5)

Solution ORR-22 c.6 — Answer: A

New • built from GARP Ch.22

Step 1 – What the model must capture

"Multiple default and rating change events; volatility in correlations and credit spreads; basis risk (e.g., the difference between CDS and underlying index values); the dynamics of hedges; and volatility in recovery rates", ideally by full-revaluation simulation.

Step 2 – The floor

"The model-based charge may not be less than a fraction of the charge under the standardized approach."
⇒ A states both conditions.

Interpretation

A floor (not a cap) on the model, and an unusually demanding list of risks, because the instruments are complex and the model's main attraction, better recognition of hedges, is also where it can understate risk.

Why the other options are wrong

B is incorrect. The standardized charge still matters: it sets the floor.
C is incorrect. The IRC model (default and migration, constant level of risk) is far from enough; correlation, spread and recovery volatility, basis risk and hedge dynamics are required.
D is incorrect. Direction reversed: the standardized charge sets a floor under the model, not a cap above it.

LO: ORR-22 c: Describe the comprehensive risk (CR) capital charge for portfolios of positions that are sensitive to correlations between default risks. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.2 Correlations and the Comprehensive Risk Measure; SchweserNotes 2026 Book 3, Reading 63, LO 63.c

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis • Vardeez: UNTIERED

ORR-22 d

P3 CALC

Define in the context of Basel III and calculate where appropriate: - Tier 1 capital and its components - Tier 2 capital and its components - Required Tier 1 equity capital, total Tier 1 capital, and total capital

Workbook: *none*

WHAT IS TESTED HERE

Why P3. Vardeez flags "Basel III components" for this LO (his theme 3, "Basel III: three components and comparison with Basel I and II", spans ORR-21 to 23) in a reading his sheet leaves untiered; no workbook section is homed here.
Vardeez: his "LO 61.d" (consolidated volume p.228): the list of Basel III changes and his capital-stack figure (CET1 4.5%, AT1 1.5%, Tier 2 2%, total 8%), plus the downward adjustments for pension deficits and cross-holdings.

Reported exam shapes: none reported; the questions are built from the LO wording and Vardeez.
What the questions look like: sort balance-sheet items into Core Tier 1, Additional Tier 1, Tier 2 or a deduction; compute a capital ratio, or test a bank against the three minimums using total RWA; statement questions on what Basel III changed.

See also: workbook D25.1 also tags this LO (a CoCo's AT1 or Tier 2 status); it is worked under ORR-22 g. Buffers are ORR-22 e; the leverage ratio is ORR-22 f.

1. What Basel III changed in the definition of capital

In the depths of the crisis market participants cared only about **tangible common equity**, capital that could absorb losses and keep a bank going. Many pre-crisis capital elements had proved unable to do that. Basel III therefore **eliminated Tier 3**, **split Tier 1** into Tier 1 Equity Capital (Core Tier 1, CET1) and Additional Tier 1 (AT1), restricted Core Tier 1 to high-quality capital, and raised the minimum ratios. Capital requirements "were significantly increased relative to Basel 2 because minimum ratios were increased, and allowable capital was constricted".

Layer	Components (GARP, with Schweser's additions)
Tier 1 Equity (Core Tier 1, CET1)	Common equity; retained earnings; a limited amount of minority interest and of unrealized gains and losses. *Deducted:* goodwill and other intangibles, deferred tax assets, any shortfall of reserves against IRB expected losses (Schweser adds retained-earnings changes from securitizations and from the bank's own credit risk, DVA).
Additional Tier 1	Unsecured, unguaranteed, non-cumulative perpetual preferred equity, subordinated to depositors and subordinated debt, callable only after five years or more; debt with triggers that cause conversion to equity or write-down (CoCos, ORR-22 g); approved minority interest not in Core Tier 1.
Tier 2	Absorbs losses *after failure*, protecting depositors and other creditors. Subordinated debt (unsecured, unguaranteed, subordinated to depositors, original maturity of five years or more, callable only after five years); general loan loss reserves not allocated to specific positions, capped at 1.25% of standardized RWA or 0.6% of IRB RWA (Schweser adds some preferred stock, such as cumulative perpetual).
Other deductions	Defined-benefit pension plan deficits (surpluses are not added); certain cross-holdings within a group; mortgage servicing rights above 10% of common equity.

Going concern and gone concern. Common equity absorbs losses while the bank is a going concern; Tier 2 absorbs losses once it is not. Depositors rank above Tier 2 in liquidation, so while Tier 2 is positive depositors should in principle be paid in full (Schweser).

2. The minimum ratios

$$\frac{\text{Core Tier 1}}{\text{RWA}} \geq 4.5\%, \qquad \frac{\text{Core Tier 1} + \text{AT1}}{\text{RWA}} \geq 6\%, \qquad \frac{\text{Tier 1} + \text{Tier 2}}{\text{RWA}} \geq 8\% \text{ (unchanged)}$$

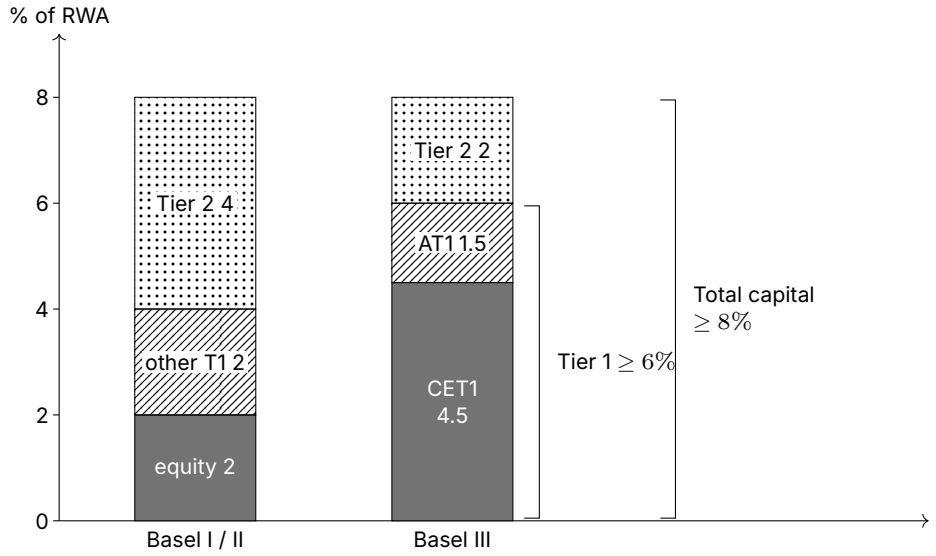


Figure 1. Minimum capital as a percentage of RWA. Dark: common equity (Basel I 2%, Basel III CET1 4.5%); hatched: the rest of Tier 1; dotted: room for Tier 2. Only the cumulative levels (4.5%, 6%, 8%) are requirements: Basel III sets no stand-alone AT1 or Tier 2 minimum, and a bank may meet all of it with CET1. Buffers on top: ORR-22 e.

The 8% total is the Basel I and II figure, but every layer now has a stricter definition. Under Basel I the equity requirement was 2% and Tier 1 4% of RWA (Schweser). Required amounts are the ratios times **total** RWA (credit + market + operational).

3. Worked example

A bank on the standardized approach has RWA of USD 800 million and the items below (USD million): common shares 40; retained earnings 25; eligible minority interest and unrealized gains 3; goodwill 6; deferred tax assets 2; non-cumulative perpetual preferred 8; CoCos with a 7% Core Tier 1 trigger 4; 10-year subordinated debt 12; general loan loss reserves 12.

$$\text{CET1} = 40 + 25 + 3 - 6 - 2 = 60 \qquad \text{AT1} = 8 + 4 = 12 \qquad \text{Tier 1} = 72$$
$$\text{GLLR cap} = 1.25\% \times 800 = 10 \qquad \text{Tier 2} = 12 + 10 = 22 \qquad \text{Total} = 94$$

Ratio	Capital	Ratio	Required ($\% \times 800$)	Surplus
Core Tier 1	60	7.50%	$4.5\% \to 36$	24
Total Tier 1	72	9.00%	$6\% \to 48$	24
Total capital	94	11.75%	$8\% \to 64$	30

Two of the 12 of reserves do not count (cap). A defined-benefit pension deficit of 5 would cut CET1 to 55 (6.88%): still above 4.5%, but below the 7% that applies once the conservation buffer is added (ORR-22 e).

Formula card: ORR-22 d

Core Tier 1	common equity + retained earnings + limited minority interest and unrealized gains/losses − goodwill, intangibles, DTAs, IRB reserve shortfall
Tier 1, total capital	Tier 1 = CET1 + AT1; total = Tier 1 + Tier 2; Tier 3 eliminated
Minimums	CET1/RWA $\geq 4.5\%$; Tier 1/RWA $\geq 6\%$; total/RWA $\geq 8\%$; RWA = credit + market + operational
Reserve cap	general loan loss reserves in Tier 2 $\leq 1.25\%$ of standardized RWA (0.6% of IRB RWA)
Basel I comparison	equity 2%, Tier 1 4%, total 8%

Exam traps

- **Goodwill sign.** Deducted from Core Tier 1, never added; also DTAs.
- **Preferred in CET1.** Non-cumulative perpetual preferred is AT1, not Core Tier 1.
- **Subordinated debt.** Tier 2 (five years or more), not Tier 1.
- **Layer minimums that do not exist.** AT1 "1.5%" and Tier 2 "2%" are room, not requirements; there is no 5.5% Tier 2 rule.
- **Wrong ratio.** 4.5% is CET1, 6% is Tier 1, 8% is total; 7% is CET1 *with* the conservation buffer; 4% is the old Basel I Tier 1 minimum.
- **Partial RWA.** Divide by total RWA, including market and operational risk.
- **Each test separately.** A bank can pass the total capital test and fail CET1.

Practice questions: ORR-22 d

Question ORR-22 d.1 Bank Q657 • BT P2.T7.521.1

Under Basel III, a bank's total regulatory capital consists of Tier 1 equity capital, Additional Tier 1 capital and Tier 2 capital (Tier 3 capital was eliminated). About the bank's total regulatory capital, each of the following is true EXCEPT which is false?

A. Tier 1 equity capital (core Tier 1) includes share capital and retained earnings.

B. Tier 1 equity capital (core Tier 1) excludes goodwill and deferred tax assets.

C. Additional Tier 1 capital (non-core) consists of items such as noncumulative preferred stock that are not common equity.

D. Tier 2 capital is "going-concern capital" that must be equity, cannot be debt, ranks above depositors in a liquidation, and includes noncumulative preferred stock.

Question ORR-22 d.2 Bank Q660 • Schweser Module Quiz 63.2 Q1

Under Basel III, capital must be adjusted downward to reflect which of the following?

A. Planned bonuses for managers.

B. Deficits in defined benefit pension plans.

C. Corporate convertible debt.

D. There is no requirement under Basel III to adjust capital downward for anything.

Question ORR-22 d.3 Bank Q645 • AP Mock 2 Q8 (options in ascending order)

Rosenborg Bank from Trondheim, Norway, is preparing for Basel III implementation. Its risk management team has established that as of 31 March 2018, the bank's Tier 1 capital amounts to 5% of risk-weighted assets. Is this acceptable?

A. Yes, total Tier 1 capital should be at least 2% of risk-weighted assets (RWA).

B. Yes, total Tier 1 capital should be at least 4% of RWA.

C. No, total Tier 1 capital should be at least 6% of RWA.

D. No, total Tier 1 capital should be at least 8% of RWA.

Question ORR-22 d.4 Bank Q649 • AnalystPrep Q.3246 (options in ascending order)

Consider a bank balance sheet with: common stock of USD 730,000,000; an unrealized long-term marketable equity securities gain of USD 33,000,000; five-year subordinated debt of USD 28,000,000; goodwill of USD 92,000,000. Based on Basel III capital requirements and solely on the above information, the Tier 1 and Tier 2 capital amounts are, respectively:

A. USD 671,000,000 and USD 28,000,000

B. USD 730,000,000 and USD 0

C. USD 730,000,000 and USD 61,000,000

D. USD 822,000,000 and USD 33,000,000

Question ORR-22 d.5

Bank Q659 • GARP PE1 Q76 • Mock 3 Q5

A treasury analyst at a bank is calculating the bank's Basel III regulatory capital ratios for its year-end financial reporting. The analyst considers the following items on the bank's balance sheet:

Item	EUR million
Common equity	2,010
Non-callable preferred equity	500
Subordinated debt	1,500
Retained earnings	3,210
Goodwill from prior acquisitions	850

The bank has total risk-weighted assets of EUR 49,700 million. What is the Core Tier 1 (CET1) capital ratio that the analyst should calculate?

A. 8.79%

B. 9.80%

C. 10.50%

D. 11.51%

Question ORR-22 d.6

Bank Q654 • AnalystPrep Q.5938 (rebuilt)

A bank has risk-weighted assets (RWA) of USD 250 million. Its capital consists of Tier 1 equity capital of USD 10 million, Additional Tier 1 capital of USD 4 million, and Tier 2 capital of USD 8 million. Considering only the Basel III minimum ratios (4.5% Tier 1 equity, 6.0% total Tier 1, 8.0% total capital) and ignoring all buffers, which of the following is correct?

A. The bank meets all three minimum requirements.

B. The bank meets the total capital requirement but falls short on both the Tier 1 equity and the total Tier 1 requirements.

C. The bank meets the Tier 1 equity requirement but falls short on the total Tier 1 and total capital requirements.

D. The bank falls short on all three minimum requirements.

Question ORR-22 d.7

Bank Q658 • BT P2.T7.521.2

As of full implementation in 2019, each of the following regulatory capital requirements under Basel III is accurate EXCEPT which is not?

A. Core Tier 1 equity capital must be at least 4.5% of risk-weighted assets; including the capital conservation buffer, the core Tier 1 requirement is 7.0%.

B. Total Tier 1 capital (Tier 1 equity capital plus Additional Tier 1 capital) must be at least 6.0% of risk-weighted assets at all times.

C. Tier 2 capital must be at least 5.5% of risk-weighted assets; the capital conservation buffer can be counted toward Tier 2 capital.

D. Total capital (total Tier 1 plus Tier 2) must be at least 8.0% of risk-weighted assets at all times; including the capital conservation buffer, the minimum total capital requirement is 10.5%.

Question ORR-22 d.8 Bank Q643 • BT P2.T6.24.6.3 (rebuilt)

Assess Company XYZ's capital adequacy over the last three years, as measured by the three key capital ratios (CET1, Tier 1 and total capital, each divided by total RWAs). Excerpt from the annual report disclosure (USD million):

Item	2017	2016	2015
Common Equity Tier 1 capital	146,424	142,367	137,100
Additional Tier 1 capital	22,639	20,443	17,600
Tier 2 capital	22,456	27,564	38,200
Total regulatory capital	191,519	190,374	192,900
Credit risk RWAs	960,763	989,639	968,600
Market risk RWAs	44,100	36,910	49,600
Operational risk RWAs	293,825	256,300	224,300
Total RWAs	1,298,688	1,282,849	1,242,500

Based on the above, the capital adequacy of Company XYZ over the last three years signals which of the following conditions?

A. Mixed

B. Declining

C. Improving

D. Not enough data to determine

Solutions • ORR-22 d

Solution ORR-22 d.1

Answer: D

Bank Q657 • BT P2.T7.521.1

Step 1 – Check A, B and C

Core Tier 1 is common equity (share capital) and retained earnings, net of goodwill, other intangibles and deferred tax assets; AT1 holds non-common items such as non-cumulative perpetual preferred. All true.

Step 2 – Check D

Tier 2 is designed to absorb losses *after failure* (gone-concern), consists mainly of subordinated *debt* (and general reserves), and ranks *below* depositors. Non-cumulative preferred is AT1.
$\Rightarrow$ D contains four errors.

Interpretation

The going-concern/gone-concern split is the organizing idea: CET1 and AT1 absorb losses while the bank operates; Tier 2 protects depositors once it has failed.

Why the other options are wrong

A is incorrect. True: share capital and retained earnings are Core Tier 1.
B is incorrect. True: goodwill and DTAs are deducted from Core Tier 1.
C is incorrect. True: non-cumulative preferred is Additional Tier 1.

LO: ORR-22 d: Define in the context of Basel III and calculate where appropriate: Tier 1 capital and its components; Tier 2 capital and its components; required Tier 1 equity capital, total Tier 1 capital, and total capital. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 The Definition of Capital

Solution ORR-22 d.2

Answer: B

Bank Q660 • Schweser Module Quiz 63.2 Q1

Step 1 – The required deductions

Beyond goodwill, intangibles and DTAs, Basel III deducts defined-benefit pension plan deficits, certain cross-holdings within a group, and mortgage servicing rights above 10% of common equity.
$\Rightarrow$ Of the options, only pension deficits is on the list.

Interpretation

A pension deficit is a claim on the bank that ranks with other liabilities; a surplus is not added back (Schweser), because it may not be available to absorb losses.

Why the other options are wrong

A is incorrect. Planned bonuses are not a listed deduction.
C is incorrect. Convertible debt with appropriate triggers can count as AT1; it is not deducted.
D is incorrect. Several deductions are required.

LO: ORR-22 d: Define in the context of Basel III and calculate where appropriate: Tier 1 capital and its components; Tier 2 capital and its components; required Tier 1 equity capital, total Tier 1 capital, and total capital. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 The Definition of Capital

Solution ORR-22 d.3 — Answer: C

Bank Q645 • AP Mock 2 Q8

Step 1 – The Tier 1 minimum

Basel III: Core Tier 1 $\geq 4.5\%$ and total Tier 1 $\geq 6\%$ of RWA.

Step 2 – Compare

$5\% < 6\%$: not acceptable.

Interpretation

5% would have cleared the Basel I/II Tier 1 minimum of 4%; Basel III raised it to 6% and tightened what counts.

Why the other options are wrong

A is incorrect. 2% was the old equity requirement, not a Tier 1 minimum.
B is incorrect. 4% is the Basel I/II Tier 1 minimum.
D is incorrect. 8% is the total capital minimum (Tier 1 plus Tier 2).

LO: ORR-22 d: Define in the context of Basel III and calculate where appropriate: Tier 1 capital and its components; Tier 2 capital and its components; required Tier 1 equity capital, total Tier 1 capital, and total capital. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 The Definition of Capital

Solution ORR-22 d.4 — Answer: A

Bank Q649 • AnalystPrep Q.3246

Step 1 – Tier 1

Common stock plus the unrealized gain (Core Tier 1 includes a limited amount of unrealized gains), less goodwill:

$$730 + 33 - 92 = \text{USD } 671 \text{ million}$$

Step 2 – Tier 2

Subordinated debt with an original maturity of five years or more: USD 28 million.

Interpretation

Goodwill has no loss-absorbing value in a failure, so it comes off Core Tier 1.

Why the other options are wrong

B is incorrect. Ignored the gain and the goodwill, and left the subordinated debt out of Tier 2.
C is incorrect. Ignored the goodwill deduction and put the gain in Tier 2 with the debt: $33+28 = 61$.
D is incorrect. Added goodwill ($730 + 92 = 822$) and put the gain in Tier 2.

LO: ORR-22 d: Define in the context of Basel III and calculate where appropriate: Tier 1 capital and its components; Tier 2 capital and its components; required Tier 1 equity capital, total Tier 1 capital, and total capital. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 The Definition of Capital

Solution ORR-22 d.5 — Answer: A

Bank Q659 • GARP PE1 Q76

Step 1 – Core Tier 1

Common equity and retained earnings, less goodwill:

$$\text{CET1} = 2{,}010 + 3{,}210 - 850 = \text{EUR } 4{,}370 \text{ million}$$

$\Rightarrow$ Preferred equity is AT1 and subordinated debt is Tier 2; neither enters CET1.

Step 2 – Ratio

$$\text{CET1 ratio} = 4{,}370/49{,}700 = 8.79\%$$

Interpretation

Comfortably above the 4.5% minimum and the 7% level with the conservation buffer.

Why the other options are wrong

B is incorrect. Added the preferred equity: $4{,}870/49{,}700 = 9.80\%$.
C is incorrect. Forgot to deduct goodwill: $5{,}220/49{,}700 = 10.50\%$.
D is incorrect. Both errors: $5{,}720/49{,}700 = 11.51\%$.

LO: ORR-22 d: Define in the context of Basel III and calculate where appropriate: Tier 1 capital and its components; Tier 2 capital and its components; required Tier 1 equity capital, total Tier 1 capital, and total capital. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 The Definition of Capital

Solution ORR-22 d.6 — Answer: B

Bank Q654 • AnalystPrep Q.5938

Step 1 – Tier 1 equity

$10/250 = 4.00\% < 4.5\%$ (needs 11.25): fails.

Step 2 – Total Tier 1

$(10 + 4)/250 = 5.60\% < 6.0\%$ (needs 15): fails.

Step 3 – Total capital

$(14 + 8)/250 = 8.80\% \geq 8.0\%$ (needs 20): passes.

Interpretation

Tier 2 rescues the total capital ratio but cannot fill a Core Tier 1 or Tier 1 gap: each test stands alone.

Why the other options are wrong

A is incorrect. Judges the bank on total capital alone.
C is incorrect. Reads 4.00% as meeting 4.5%, and leaves Tier 2 out of total capital $(14/250 = 5.60\%)$.
D is incorrect. Leaves Tier 2 out of total capital; with it the ratio is 8.80%.

LO: ORR-22 d: Define in the context of Basel III and calculate where appropriate: Tier 1 capital and its components; Tier 2 capital and its components; required Tier 1 equity capital, total Tier 1 capital, and total capital. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 The Definition of Capital

Solution ORR-22 d.7 — Answer: C

Bank Q658 • BT P2.T7.521.2

Step 1 – Check A, B and D

CET1 4.5%, $+2.5\%$ CCB $= 7.0\%$; Tier 1 6.0%; total 8.0%, $+2.5\% = 10.5\%$. All true.

Step 2 – Check C

There is no stand-alone Tier 2 minimum: the gap between 6% and 8% leaves room for at most 2% of Tier 2, and nothing forces any. The conservation buffer is Tier 1 equity, so Tier 2 cannot count toward it.
$\Rightarrow$ C is false on both counts.

Interpretation

Vardeez's capital-stack figure labels Tier 2 "2% RWA"; read that as room, not a requirement.

Why the other options are wrong

A is incorrect. True: 4.5% plus the 2.5% buffer.
B is incorrect. True: the Tier 1 minimum.
D is incorrect. True: 8% plus the 2.5% buffer.

LO: ORR-22 d: Define in the context of Basel III and calculate where appropriate: Tier 1 capital and its components; Tier 2 capital and its components; required Tier 1 equity capital, total Tier 1 capital, and total capital. ORR-22 e: Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs). • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3; SchweserNotes 2026 Book 3, Reading 63, LO 63.d and 63.e

Solution ORR-22 d.8 Answer: A

Bank Q643 • BT P2.T6.24.6.3

Step 1 – CET1 ratio

2015: $137{,}100/1{,}242{,}500 = 11.03\%$; 2016: 11.10%; 2017: $146{,}424/1{,}298{,}688 = 11.27\%$. Rising.

Step 2 – Tier 1 ratio

2015: $154{,}700/1{,}242{,}500 = 12.45\%$; 2016: 12.69%; 2017: $169{,}063/1{,}298{,}688 = 13.02\%$. Rising.

Step 3 – Total capital ratio

2015: $192{,}900/1{,}242{,}500 = 15.53\%$; 2016: 14.84%; 2017: $191{,}519/1{,}298{,}688 = 14.75\%$. Falling, as Tier 2 shrank from 38,200 to 22,456.

$\Rightarrow$ Two ratios improve, one declines: mixed.

Interpretation

Quality improved (more CET1 and AT1) while quantity at the gone-concern layer fell. Each ratio uses total RWA, the sum of credit, market and operational RWA. (The stem now states that capital and RWA are in USD million.)

Why the other options are wrong

B is incorrect. Looks only at the total capital ratio.
C is incorrect. Looks only at the CET1 and Tier 1 ratios.
D is incorrect. Every input for all three ratios is given.

LO: ORR-22 d: Define in the context of Basel III and calculate where appropriate: Tier 1 capital and its components; Tier 2 capital and its components; required Tier 1 equity capital, total Tier 1 capital, and total capital. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 The Definition of Capital

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis • Vardeez: UNTIERED

ORR-22 e

P3 CALC

Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs).

Workbook: *none*

WHAT IS TESTED HERE

Why P3. Vardeez flags "Basel III buffers" for this LO in an untiered reading; no workbook section is homed here (C5 lists the buffers in its revision notes).
Vardeez: his "LO 61.e" (consolidated volume pp.228 to 229): the conservation buffer protects banks in distress, his Figure 61.2 (7% Core Tier 1, 8.5% Tier 1, 10.5% total "in normal times only"), G-SIB buffers of 1% to 3.5%, and a countercyclical buffer of 0% to 2.5% set by the economic cycle.
Reported exam shapes: none reported; the questions are built from the LO wording and Vardeez.
What the questions look like: add the buffers to the minimums for a G-SIB in a given bucket, with a countercyclical rate (sometimes a weighted average across countries); test a bank's ratios; find the dividend limit inside the buffer zone; statement questions on the three rationales.

1. Three buffers above the minimums

Basel III asks for capital above the minimum fractions of RWA (ORR-22 d) because banks must stay a **going concern after absorbing losses**, not merely solvent at the point of maximum loss, and government recapitalization in the crisis was unpopular.

Buffer	Size (CET1)	Rationale
Capital conservation buffer (CCB)	2.5% of RWA	Follows the US Prompt Corrective Action system (1991): as ratios approach the minimums, supervisory intervention grows more stringent to restore well-capitalized status. Built in normal times, when equity is easier to raise; drawn down in stress.
G-SIB buffer	1, 1.5, 2, 2.5 or 3.5% by the bank's score	Same logic as the CCB, plus the very large social cost of a G-SIB's distress (and the higher volatility of losses at some G-SIBs): a larger buffer further reduces the chance of failure.
Countercyclical buffer (CCyB)	0 to 2.5%, national supervisors' discretion	(i) Overheating: higher requirements restrict credit supply, damping the credit cycle and perhaps the frequency and severity of crises. (ii) Cost of capital: raising capital is cheaper in good times, so raise the CCyB in booms and cut it in busts.

- **Consequences of a breach.** Formally, restrictions on dividends and bonuses and a plan to restore the ratios; supervisors may go further. Breaching a buffer is less severe than breaching a minimum. A G-SIB or CCyB breach has consequences similar to a CCB breach; because supervisors can cut the CCyB at any time, its consequences can be eased by lowering it.
- **G-SIB identification.** The FSB scores size, interconnectedness, complexity, international activity and other matters. The 2018 list had 29 G-SIBs; none has ever been in the 3.5% bucket, and since 2013 only HSBC and JPMorgan Chase have been in the 2.5% bucket. G-SIBs are a subset of SIFIs: institutions whose failure or distress would cause substantial problems for the financial system or the real economy.

- **International banks.** The CCyB may differ across nations, so the consolidated CCyB is a **weighted average** of the rates in each nation where the bank has exposures.
- **G-SIB leverage buffer** (2017, implemented from 2022): one-half of the risk-based G-SIB buffer, excluding the CCB and CCyB. (Earlier US rule: 2 and 3 point leverage buffers; 2018 US proposal: half of the CCB plus the G-SIB buffer.)

2. Calculating the requirements

All three buffers are met with Core Tier 1, so each one lifts *all three* ratios by the same amount. With the CCB alone the normal-time requirements are **7%, 8.5% and 10.5%**.

Worked example. A G-SIB in the 1.0% bucket has RWA of EUR 500 billion and leverage exposure of EUR 1,400 billion. Its private-sector credit exposures are 60% at home (CCyB 0.5%) and 40% abroad (CCyB 1.0%), so its CCyB is $0.6(0.5\%) + 0.4(1.0\%) = 0.7\%$. Buffers $= 2.5 + 1.0 + 0.7 = 4.2\%$.

Requirement	Minimum	With buffers	EUR billion
Core Tier 1 / RWA	4.5%	8.7%	43.5
Tier 1 / RWA	6.0%	10.2%	51.0
Total capital / RWA	8.0%	12.2%	61.0
Tier 1 / leverage exposure	3.0%	$3.0\% + \frac{1}{2}(1.0\%) = 3.5\%$	49.0

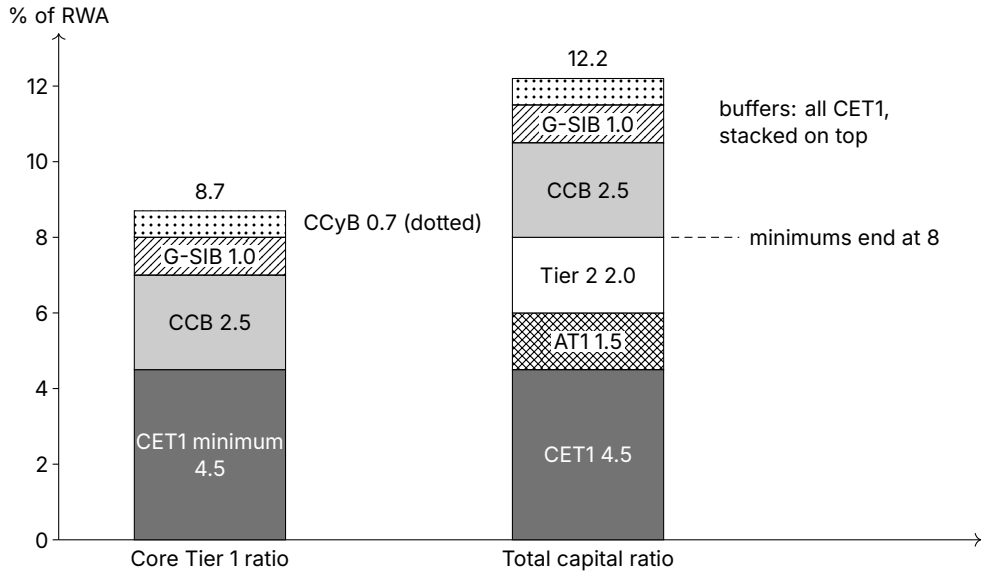


Figure 1. The worked example as two capital stacks. Dark grey: CET1 minimum; crosshatched: AT1; open: Tier 2; light grey: conservation buffer; hatched: G-SIB buffer; dotted: countercyclical buffer. The buffers are the same CET1 amounts in both bars; only the minimum layers below them differ.

Dividend restrictions inside the buffer zone (Schweser; quartiles of the zone above the 4.5% CET1 minimum):

CET1 ratio (%), CCB only	4.5 to 5.125	5.125 to 5.75	5.75 to 6.375	6.375 to 7.0	above 7.0
Minimum earnings retained	100%	80%	60%	40%	0%

Schweser's example: a CET1 ratio of 6% sits in the third quartile, so at least 60% of earnings is retained and dividends are capped at 40%. A positive CCyB or G-SIB buffer widens the zone, so the same ratio falls into a lower quartile (Question ORR-22 e.5).

Formula card: ORR-22 e

Buffer-inclusive ratios	CET1 $\geq 4.5\% + B$; Tier 1 $\geq 6\% + B$; total $\geq 8\% + B$; $B = 2.5\% +$ G-SIB + CCyB
G-SIB buckets	1.0, 1.5, 2.0, 2.5, 3.5% (CET1)
CCyB	0 to 2.5%; international bank: $\sum_j w_j \, \text{CCyB}_j$, w_j the share of exposures in country j
G-SIB leverage	$3\% + \frac{1}{2} \times$ G-SIB buffer (Tier 1)
Distribution limit	zone width B split into quartiles above 4.5%: retain 100, 80, 60, 40%

Exam traps

- **CCB versus CCyB.** The CCB is a fixed 2.5%; the 0 to 2.5% national-discretion buffer aimed at the credit cycle is the CCyB.
- **"At all times".** 7%, 8.5% and 10.5% are normal-time levels; the buffer is meant to be drawn down in stress.
- **Additive, not substitute.** The G-SIB buffer is added to the CCB, not in place of it.
- **Buffer quality.** Buffers are CET1; Tier 2 cannot meet them.
- **Weighted CCyB.** Use exposure weights, not the home rate, the maximum or a simple average.
- **Leverage buffer.** Half the G-SIB surcharge only (not the CCB or CCyB).
- **Retention versus payout.** Quartile tables give the share retained; the dividend cap is one minus it.

Practice questions: ORR-22 e

Question ORR-22 e.1

Bank Q666 • Schweser Module Quiz 63.2 Q2 (options reordered)

The capital conservation buffer:

A. is intended to protect banks from the countercyclical nature of bank earnings.

B. causes the Tier 1 equity capital ratio requirement to increase to 7% of risk-weighted assets in normal economic periods.

C. can be set between 0.0% and 2.5% of risk-weighted assets, and is at the discretion of the regulators in individual countries.

D. requires that total capital to risk-weighted assets must be 10.5% at all times.

Question ORR-22 e.2

Bank Q667 • AnalystPrep Q.2360 (rebuilt)

CIB Bank is designated a global systemically important bank (G-SIB) by the Financial Stability Board. Which statement best describes the designation and its consequences?

A. Its distress would cause substantial problems for the global financial system or economy, so it must hold an additional capital buffer of 1% to 3.5% of RWA, depending on its systemic importance score.

B. Its distress would cause substantial problems for the global financial system, so its G-SIB buffer replaces the 2.5% capital conservation buffer.

C. It is designated because its total assets exceed a fixed threshold, and national supervisors set an additional buffer of 0% to 2.5% at their discretion.

D. Because governments are expected to rescue it, it is exempt from the capital conservation buffer and dividend restrictions.

Question ORR-22 e.3

Bank Q664 • BT Mock Q8 • BT P2.T7.20.10.1

In addition to the minimum capital ratios, as of early 2019 Basel specifies three buffers: the capital conservation buffer (CCB), the G-SIB buffer and the countercyclical buffer (CCyB). Your colleague Mary makes the following five points:

I. For all three, the additional buffer must be CET1.

II. For all three, breach of the buffer requirements implies the bank's ability to pay dividends will be restricted.

III. The CCB requires an additional 2.5% of CET1 capital and is meant to ensure that banks have an additional layer of usable capital that can be drawn down when losses are incurred.

IV. The additional G-SIB requirement includes five buckets (1.0%, 1.5%, 2.0%, 2.5%, 3.5%) and is meant to reduce the likelihood and severity of the failure of a global systemically important financial institution.

V. The CCyB requirement varies between zero and 2.5% and is meant to protect the banking sector from periods of excess aggregate credit growth associated with the build-up of system-wide risks.

Is Mary correct in her summary?

A. No, none of her statements is correct.

B. I. and II. are correct, but III., IV. and V. are wrong.

C. III., IV. and V. are correct, but I. and II. are wrong.

D. Yes, all five statements are correct.

Question ORR-22 e.4 Bank Q661 • AnalystPrep Q.3096 (rebuilt; options in ascending order)

Prime Bank has risk-weighted assets (RWA) of USD 200 million. Under fully phased-in Basel III, what is the minimum Common Equity Tier 1 (CET1) capital the bank must hold to satisfy the CET1 minimum plus the capital conservation buffer (ignoring any G-SIB or countercyclical buffer)?

A. USD 9,000,000

B. USD 12,000,000

C. USD 14,000,000

D. USD 16,000,000

Question ORR-22 e.5 Bank Q665 • BT P2.T7.521.3 (rebuilt; options reordered)

A bank has a CET1 (Tier 1 equity) ratio of 6.0%. Distributions are constrained when the CET1 ratio lies inside the buffer zone above the 4.5% minimum. The zone is divided into four equal quartiles, and the minimum share of earnings that must be retained is:

Quartile of buffer zone (lowest to highest)	Minimum earnings retained
1st	100%
2nd	80%
3rd	60%
4th	40%
Above the buffer zone	0%

With no countercyclical buffer (CCyB), the buffer zone is the 2.5% conservation buffer (CET1 from 4.5% to 7.0%). With a 2.5% CCyB, the zone is 5.0% wide (CET1 from 4.5% to 9.5%). What is the maximum dividend, as a percent of earnings, that can be paid (i) with no CCyB and (ii) with a 2.5% CCyB?

A. (i) 0%; (ii) 0%

B. (i) 40%; (ii) 20%

C. (i) 40%; (ii) 40%

D. (i) 60%; (ii) 80%

Question ORR-22 e.6

Bank Q668 • BT P2.T7.20.11.3

The Basel Committee developed a methodology for assigning global systemically important banks (G-SIBs) to one of five buckets:

Bucket	Score range	Higher loss absorbency requirement (CET1, % of RWA)
5	530 to 629	3.50%
4	430 to 529	2.50%
3	330 to 429	2.00%
2	230 to 329	1.50%
1	130 to 229	1.00%

As of November 2019, Bank of America was a USD 2.4 trillion G-SIB assigned to Bucket 2. Including the buffer requirements due to its status as a G-SIB, what are its minimum CET1 risk-weighted ratio and its minimum leverage ratio (excluding the countercyclical buffer, which can be zero)?

A. Minimum CET1 ratio 7.00%; minimum leverage ratio 3.00%

B. Minimum CET1 ratio 8.50%; minimum leverage ratio 3.75%

C. Minimum CET1 ratio 10.50%; minimum leverage ratio 4.50%

D. Minimum CET1 ratio 10.50%; minimum leverage ratio 5.25%

Question ORR-22 e.7

New • built from GARP Ch.22

A capital planning analyst at a European G-SIB in the 1.5% bucket is computing the bank's fully buffered CET1 requirement. RWA are EUR 400 billion. The bank's private-sector credit exposures and the countercyclical buffer rates that apply to them are:

Country	Share of exposures	CCyB rate
Home country X	50%	1.0%
Country Y	30%	2.5%
Country Z	20%	0.0%

Which of the following is closest to the minimum CET1 capital the bank must hold in normal times, including all buffers?

A. EUR 33.0 billion

B. EUR 38.0 billion

C. EUR 39.0 billion

D. EUR 44.0 billion

Question ORR-22 e.8 Bank Q655 • BT P2.T7.20.9.3 (rebuilt)

The CRO of LGX, a G-SIB in the 1.5% bucket, is reporting on the bank's capital adequacy. Capital and exposure data (USD billion) are: Common equity Tier 1 (CET1) capital 2.40; noncumulative preferred stock (Additional Tier 1) 0.90; Tier 2 capital 1.70; risk-weighted assets (RWA) 36.00; total leverage exposure 65.00. The fully phased-in requirements are:

CET1 ratio (4.5% + 2.5% CCB + 1.5% G-SIB)	8.50%
Tier 1 ratio (6.0% + 2.5% CCB + 1.5% G-SIB)	10.00%
Total capital ratio (8.0% + 2.5% CCB + 1.5% G-SIB)	12.00%
Leverage ratio, Tier 1 / total exposure (3.0% + $\frac{1}{2}$ × 1.5% G-SIB)	3.75%

For which of the four ratios does the bank meet the requirement?

A. Leverage and total capital ratios are sufficient, but CET1 and Tier 1 ratios are too low

B. Tier 1 and leverage ratios are sufficient, but CET1 and total capital ratios are too low

C. Only the CET1 ratio is sufficient; Tier 1, total capital and leverage ratios are too low

D. All four ratios are sufficient

Solutions • ORR-22 e

Solution ORR-22 e.1

Answer: B

Bank Q666 • Schweser Module Quiz 63.2 Q2

Step 1 – What the CCB is

A fixed 2.5% of RWA in Tier 1 equity, built in normal times and drawn down in stress.

Step 2 – Its effect on the requirements

Normal-time Core Tier 1: $4.5\% + 2.5\% = 7\%$ (Tier 1 8.5%, total 10.5%).
$\Rightarrow$ B is correct.

Interpretation

The CCB's rationale is Prompt Corrective Action: as capital approaches the minimum, payouts are restricted so the bank rebuilds capital itself.

Why the other options are wrong

A is incorrect. Cyclicality is the countercyclical buffer's purpose.
C is incorrect. Describes the CCyB (0 to 2.5%, national discretion); the CCB is fixed and not discretionary.
D is incorrect. 10.5% applies in normal periods; the buffer is meant to be used in stress, so not "at all times".

LO: ORR-22 e: Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs). • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 Buffers; SchweserNotes 2026 Book 3, Reading 63, LO 63.e

Solution ORR-22 e.2

Answer: A

Bank Q667 • AnalystPrep Q.2360

Step 1 – The designation

An entity is systemically important if its failure or distress would cause substantial problems in the financial system or the real economy; the FSB combines proxies for size, interconnectedness, complexity, international activity and other matters.

Step 2 – The consequence

An additional CET1 buffer of 1, 1.5, 2, 2.5 or 3.5% by score, on top of the CCB (and any CCyB).

Interpretation

The G-SIB buffer reflects the social cost of a G-SIB's distress; reforms aim to make such banks less likely to fail and able to fail without a bailout.

Why the other options are wrong

B is incorrect. The G-SIB buffer is additional to the CCB, not a substitute.
C is incorrect. Designation uses a multi-factor score, not a size threshold, and 0 to 2.5% at national discretion describes the CCyB.
D is incorrect. The opposite: G-SIBs face more requirements, and breaching the G-SIB buffer restricts distributions like a CCB breach.

LO: ORR-22 e: Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs). • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 Systemically Important Financial Institutions; Buffers

Solution ORR-22 e.3 — Answer: D

Bank Q664 • BT Mock Q8

Step 1 – Statements I and II

All three buffers are held in CET1 (Tier 1 equity), and a breach of any of them restricts dividends and bonuses: GARP says breaches of the G-SIB buffer and of the CCyB have consequences similar to a CCB breach.

Step 2 – Statements III to V

CCB 2.5%, a usable layer drawn down in losses; G-SIB buckets 1 to 3.5%, reducing the likelihood of a G-SIB failure; CCyB 0 to 2.5%, aimed at excess aggregate credit growth (the overheating rationale).

$\Rightarrow$ All five are correct.

Interpretation

A recall question that checks size, quality, consequence and purpose of each buffer at once.

Why the other options are wrong

A is incorrect. Every statement is accurate.

B is incorrect. Wrongly rejects the correct sizes and purposes in III to V.

C is incorrect. Wrongly rejects I and II: the buffers are CET1 and their breach constrains distributions.

LO: ORR-22 e: Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs). • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 Buffers; SchweserNotes 2026 Book 3, Reading 63, LO 63.e

Solution ORR-22 e.4 — Answer: C

Bank Q661 • AnalystPrep Q.3096

Step 1 – Required CET1 ratio

$4.5\% + 2.5\% = 7.0\%$ of RWA.

Step 2 – Amount

$7.0\% \times 200 =$ USD 14 million.

Interpretation

The buffer sits on top of the CET1 minimum and is also CET1.

Why the other options are wrong

A is incorrect. Ignored the buffer: $4.5\% \times 200 = 9$.

B is incorrect. Used the Tier 1 minimum: $6\% \times 200 = 12$.

D is incorrect. Used the total capital minimum: $8\% \times 200 = 16$.

LO: ORR-22 e: Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs). • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 Buffers

Solution ORR-22 e.5 — Answer: B

Bank Q665 • BT P2.T7.521.3

Step 1 – (i) No CCyB: zone 4.5% to 7.0%

Quartiles 0.625% wide: 4.5 to 5.125, 5.125 to 5.75, 5.75 to 6.375, 6.375 to 7.0. A 6.0% ratio is in the 3rd quartile: retain at least 60%, pay at most 40%.

Step 2 – (ii) 2.5% CCyB: zone 4.5% to 9.5%

Quartiles 1.25% wide: 4.5 to 5.75, 5.75 to 7.0, 7.0 to 8.25, 8.25 to 9.5. A 6.0% ratio is in the 2nd quartile: retain at least 80%, pay at most 20%.

Interpretation

A larger required buffer pushes the same CET1 ratio into a lower quartile and tightens payouts. Part (i) reproduces Schweser's example (6% CET1, retain 60%).

Why the other options are wrong

A is incorrect. Treats any ratio below the buffer target as a full dividend ban; 6.0% is above the minimum and inside the zone, so payouts are limited, not barred.
C is incorrect. Ignores the CCyB in part (ii), keeping the 4.5% to 7.0% zone.
D is incorrect. Reports the shares retained (60%, 80%) instead of the maximum dividend.

LO: ORR-22 e: Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs). • **Reference:** SchweserNotes 2026 Book 3, Reading 63, LO 63.e; Carey (GARP Risk Institute), Ch.22, 22.3 Buffers

Solution ORR-22 e.6 — Answer: B

Bank Q668 • BT P2.T7.20.11.3

Step 1 – CET1 requirement

$4.5\% + 2.5\%$ (CCB) $+ 1.5\%$ (bucket 2) $= 8.5\%$.

Step 2 – Leverage requirement

G-SIB leverage buffer $= \frac{1}{2} \times 1.5\% = 0.75\%$ (the CCB and CCyB are not included), so $3\% + 0.75\% = 3.75\%$.

Interpretation

The 2017 leverage buffer keeps the risk-based and leverage constraints in step for G-SIBs.

Why the other options are wrong

A is incorrect. Non-G-SIB figures: no surcharge on either ratio.
C is incorrect. 10.5% is the buffer-inclusive total capital ratio (or 7% plus the 3.5% bucket); 4.5% adds the full 1.5% surcharge to the leverage minimum instead of half.
D is incorrect. Repeats 10.5% and takes half of 10.5% as the leverage ratio.

LO: ORR-22 e: Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs). • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 Buffers; BCBS, High-Level Summary of Basel III Reforms (Ch.23, Leverage Ratio Buffer)

Solution ORR-22 e.7 — Answer: C

New • built from GARP Ch.22

Step 1 – Weighted CCyB

$$0.50(1.0\%) + 0.30(2.5\%) + 0.20(0\%) = 0.50\% + 0.75\% = 1.25\%$$

$\Rightarrow$ An international bank's CCyB is a weighted average of the national rates.

Step 2 – Fully buffered CET1 ratio

$$4.5\% + 2.5\%\ (\text{CCB}) + 1.5\%\ (\text{G-SIB}) + 1.25\%\ (\text{CCyB}) = 9.75\%$$

Step 3 – Amount

$$9.75\% \times 400 = \text{EUR } 39.0 \text{ billion}$$

Interpretation

The CCyB follows the location of the bank's exposures, not its headquarters. A simple average of the three rates (1.17%) would give EUR 38.7 billion, close to the answer but wrong in principle.

Why the other options are wrong

A is incorrect. Omitted the G-SIB buffer: $8.25\% \times 400 = 33.0$.
B is incorrect. Applied the home-country rate to all exposures: $9.5\% \times 400 = 38.0$.
D is incorrect. Applied the highest national rate: $11.0\% \times 400 = 44.0$.

LO: ORR-22 e: Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs). • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 Buffers

Solution ORR-22 e.8 Answer: A

Bank Q655 • BT P2.T7.20.9.3

Step 1 – Risk-based ratios

CET1 $2.40/36.00 = 6.67\% < 8.50\%$: fails. Tier 1 $3.30/36.00 = 9.17\% < 10.00\%$: fails. Total $5.00/36.00 = 13.89\% \geq 12.00\%$: passes.

Step 2 – Leverage ratio

Tier 1 $3.30/65.00 = 5.08\% \geq 3.75\%$: passes.

Interpretation

The bank clears every bare minimum (4.5%, 6%, 8%, 3%) but not the buffer-inclusive CET1 and Tier 1 levels, so it faces distribution constraints rather than a breach of minimums. The leverage requirement was restated as $3\% + \frac{1}{2}(1.5\%) = 3.75\%$ to match the G-SIB rule (the bank's version used 4.00%); the answer is unchanged. On Core Tier 1, as GARP Ch.22 words the leverage ratio, the bank would show $2.40/65 = 3.69\%$ and fail: see the correction box in ORR-22 f.

Why the other options are wrong

B is incorrect. Calls Tier 1 sufficient ($9.17\% < 10\%$) and total capital insufficient ($13.89\% > 12\%$).
C is incorrect. Calls CET1 sufficient ($6.67\% < 8.5\%$); the total capital and leverage ratios in fact pass.
D is incorrect. Compares CET1 and Tier 1 with the bare minimums instead of the buffer-inclusive requirements.

LO: ORR-22 e: Describe the motivations for and calculate the capital conservation buffer and the countercyclical buffer, including special rules for globally systemically important banks (G-SIBs). ORR-22 d and f (ratios). • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 (Definition of Capital; Leverage Ratio; Buffers)

ORR-22 • Solvency, Liquidity and Other Regulation After the Global Financial Crisis • Vardeez: UNTIERED

ORR-22 g

P3 CONCEPT

Describe the mechanics of contingent convertible bonds (CoCos) and explain the motivations for banks to issue them.

Workbook: D25 Contingent Convertible Bonds • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: D25 sits at #70 of the topic map (1 of 16 sources, reported as "Coco bonds").
Vardeez: his "LO 61.g" (consolidated volume p.230): CoCos convert from debt to equity automatically under stress; they let a bank keep debt in normal times, preserving ROE, while giving a safety net of equity in a crisis. His triggers: a fall in the Tier 1 equity ratio, a supervisory finding that the bank needs public support, a minimum ratio of market capitalization to assets. He mentions conversion only; GARP adds the write-down (Section 2).

Reported exam shapes

- **D25·S1** Trigger mechanics: Core Tier 1 to RWA threshold or the regulator's nonviability declaration, and the 5.125% line between Additional Tier 1 and Tier 2.
- **D25·S2** Equity conversion versus principal write-down: both increase equity.
- **D25·S3** AT1 ranking and the inversion controversy: CoCo holders bear losses not so different from equity holders'.

What the questions look like: statement questions on a term sheet or a briefing: who triggers conversion, what happens to equity, which capital tier the bond counts in, and why a bank issues something that should be expensive.

See also: workbook D25.1 also tags ORR-22 d (capital tiers). Recapitalization and bail-in are ORR-22 h.

1. The mirror image of a convertible

Traditional convertibles were issued by non-financial firms that wanted to avoid the dilution of issuing equity before their performance improved; they convert *at the holder's option* when the share price rises above thresholds in the indenture. **CoCos** are the mirror image: they cause a bank's equity to **increase when distress occurs**, through triggers written into the indenture, **not at the option of the holder**.

2. Mechanics

- **Triggers.** A common trigger is the ratio of **Core Tier 1 capital to RWA falling below a threshold** (an accounting trigger; Credit Suisse's 2011 CoCos used one), or the bank's **primary regulator declaring it nonviable** (Schweser: supervisors determine it needs public-sector support to avoid insolvency). Schweser adds a third: a **minimum ratio of market capitalization to assets**, which may reduce balance-sheet manipulation but can invite share-price manipulation.
- **Loss absorption.** "Equity increases either because the bond converts to equity or because its value is written down." A write-down issues no shares, but a liability disappears with no matching asset loss, so equity still rises.
- **Capital treatment.** A CoCo counts as **Additional Tier 1 if the trigger threshold is 5.125% or higher**, and as Tier 2 otherwise. Numerically, 5.125% is the 4.5% Core Tier 1 minimum plus a

quarter of the 2.5% conservation buffer, so an AT1 CoCo converts while the bank is still above its minimum, as a going concern.

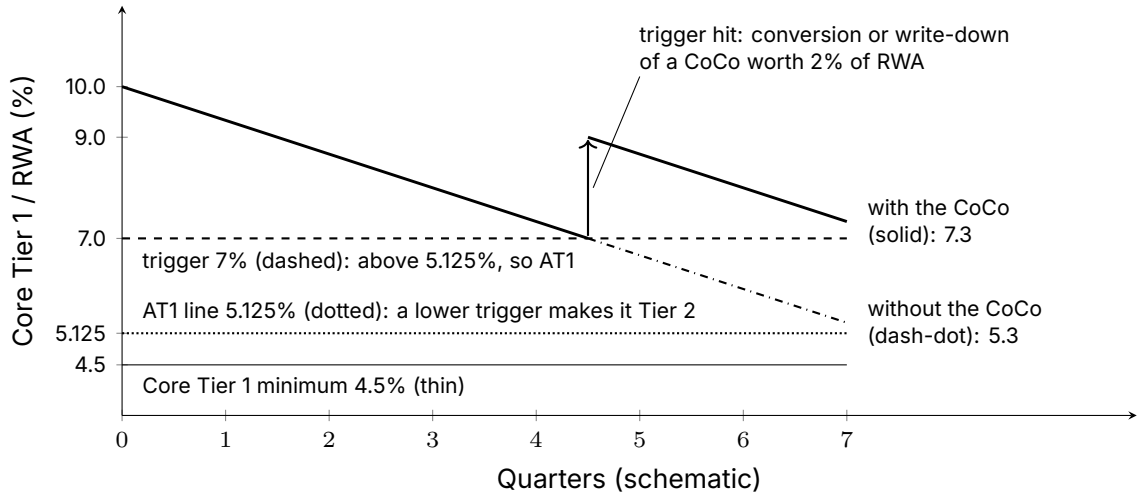


Figure 1. Schematic. Losses push the Core Tier 1 ratio (solid) down to a 7% trigger; conversion or write-down adds 2 points of equity at once, and the ratio resumes from 9%. The dash-dot line is the same bank without the CoCo, which would sit just above the AT1 line after seven quarters.

3. Why banks issue them, and the cost puzzle

- **For the bank.** In normal times a CoCo is debt: it does not appear in the equity account until converted, so the bank reports a **higher return on equity**. In stress it becomes loss-absorbing equity, supplied by **private bondholders rather than the government**, which helps the bank avoid insolvency and a bailout (Schweser, Vardeez).
- **The cost puzzle.** "It is not obvious why the market would price CoCos to make the cost of capital for them less than the cost of equity." Holders receive little or none of the upside when the bank does well, but "bear losses not so different from those of equity holders when a bank fails". So CoCos **should be expensive** to issue; the advantage is accounting (reported ROE), not cheap capital. Investors are paid for this with higher yields.
- **Resolution.** The FSB (2014) asked each G-SIB to hold enough total loss-absorbing capacity (TLAC) to recapitalize itself, by converting bonds to equity or by bail-in. CoCo conversion terms are written into the indenture and often require conversion *while the bank still appears solvent*; bail-ins are governed by national law, with details chosen by the authorities after they have seized control of the bank.
- **Ranking (outside the GARP text).** AT1 normally ranks above common equity, but holders can lose everything while shareholders keep value: in March 2023 about CHF 16 billion of Credit Suisse AT1 bonds were written down to zero under their viability terms, while shareholders received UBS shares. Carey's "not so different from equity holders" is the in-syllabus version of this point.

	Traditional convertible	CoCo	Bail-in
Issuer	Non-financial firms	Banks	Banks in resolution
Converts when	Share price is high (good times)	Distress: capital-ratio trigger or nonviability	Authorities have seized control
Decided by	Holder's option	Indenture terms (or the regulator's declaration)	National law, authorities' choices
Effect on equity	Dilution on conversion	Equity rises (conversion or write-down)	Wholesale debt written down or converted

Exam traps

- **Role swap.** CoCos convert on the indenture's trigger or the regulator's declaration, never at the holder's option.
- **Polarity.** Traditional convertibles convert when the share price rises; CoCos when the bank weakens. A market trigger fires when market capitalization to assets *falls* below a minimum.
- **Write-down is not equity-neutral.** Both mechanisms raise equity.
- **5.125% scope.** A Core Tier 1 trigger is not enough for AT1: the threshold must be 5.125% or higher, otherwise Tier 2.
- **Cost direction.** Economically expensive; the issuer's gain is a higher reported ROE.
- **Absolute claims on ranking.** Holders are not shielded until shareholders are wiped out.

Practice questions: ORR-22 g

Question ORR-22 g.1

Bank Q698 • Schweser Module Quiz 63.3 Q1

Which of the following statements is correct regarding the mechanics and motivations of contingent convertible bonds (CoCos)?

I. During normal financial periods, CoCos are debt and do not drag down return on equity.

II. During periods of financial stress, CoCos convert to equity, providing a cushion against loss, which helps prevent insolvency.

A. Statement I only.

B. Statement II only.

C. Both Statements I and II.

D. Neither Statement I nor II.

Question ORR-22 g.2 Bank Q691 • AnalystPrep Q.5617 (rebuilt; options reordered)

According to GARP, how do contingent convertible bonds (CoCos) cause a bank's equity to increase when distress occurs?

A. Triggers written into the indenture lead the bond either to convert into equity or to be written down, regardless of the holder's wishes.

B. Bondholders exercise a conversion option when the share price rises above a threshold set in the indenture.

C. The bank must repurchase the bonds at par, funding the repurchase with new government equity.

D. Interest on the bonds is suspended permanently and the principal becomes a deposit.

Question ORR-22 g.3 Bank Q693 • AnalystPrep Q.5628 (rebuilt; options reordered)

Which of the following is a potential CoCo conversion trigger based on the judgment of the bank's supervisor?

A. Conversion occurs if the bank's stock price exceeds a threshold specified in the indenture.

B. Conversion occurs when the ratio of market capitalization to assets rises above a set level.

C. Conversion occurs only if bondholders vote to convert at their option.

D. Conversion occurs automatically if supervisors determine the bank needs public-sector aid (equity capital) to avoid insolvency.

Question ORR-22 g.4 Bank Q692 • AnalystPrep Q.5619 (rebuilt)

Under the treatment described in GARP, a CoCo whose trigger is a Core Tier 1 capital to risk-weighted assets ratio of 5.125% or higher may be included in a bank's:

A. Common equity Tier 1 capital.

B. Additional Tier 1 capital.

C. Tier 2 capital only.

D. No regulatory capital category.

Question ORR-22 g.5

Bank Q695 • BT P2.T7.20.10.3 (options reordered)

As Mark Carey explains, "Banks will fail in the future in spite of Basel I, II, III and later reforms. To limit the disruptions caused by such failures, the FSB agreed in 2014 that national resolution regimes for G-SIBs would have 12 key attributes and that each G-SIB should have sufficient total loss absorbing capacity (TLAC) to enable it to recapitalize itself. Recapitalization might be accomplished by causing convertible bonds to become equity or by bail-in, in which certain wholesale debt liabilities are either written down or converted to equity." In regard to this and other reforms, which of the following statements is TRUE?

A. CoCo bonds contain an embedded put option that gives the buyer the right, but not the obligation, to purchase equity at a predetermined conversion price.

B. Gold plating is when a national regulator applies a less onerous (lower) regulatory capital ratio to its domestic banks, giving them a competitive advantage against international banks.

C. CoCo bonds are attractive to banks because they do not decrease return on equity (ROE) prior to conversion, and they are also attractive to regulators because they absorb losses when triggered if distress occurs.

D. The TLAC minimums developed by the FSB will be gradually phased out and replaced by the leverage and liquidity ratios in Basel IV as they are phased in.

Question ORR-22 g.6

Bank Q697 • GARP PE1 Q70

A junior analyst at a banking regulatory agency is reviewing a report on a failed bank that had issued a high volume of contingent convertible bonds (CoCos), some still outstanding at failure. The analyst researches CoCos, including their mechanics, accounting, and treatment under Basel guidelines. Which of the following will the analyst find correct about CoCos?

A. CoCos give their holders the option to convert them into the equity of the issuing bank either before maturity or at maturity, depending on the type of CoCo.

B. CoCos give their holders the option to convert their medium- or long-term debt to short-term debt if certain interest rate conditions specified in the indenture are met.

C. CoCos may be included in Tier 2 capital but not in Tier 1 or Additional Tier 1 capital due to the risks they pose to the issuing bank and the difficulties in pricing them.

D. CoCos can be more expensive for banks to issue than equity, but they allow the issuing bank to report a higher return on equity until they are converted.

Question ORR-22 g.7 Workbook D25.1 • S1, S2, S3 • Map #70

A capital management analyst at a Japanese bank holding company is preparing a briefing for the asset-liability committee on a proposed issue of perpetual contingent convertible bonds. The draft term sheet states:

- Loss absorption: permanent write-down of principal; the bonds never convert into shares
- Trigger: the ratio of Core Tier 1 capital to RWA falls below 7%, or the bank's primary regulator declares the bank nonviable
- Coupons: non-cumulative

Which of the following statements is correct for the analyst to include in the briefing?

A. Because the bonds are written down rather than converted into shares, a trigger event would leave the bank's equity unchanged and would only reduce its future interest expense.

B. Because the trigger is defined on Core Tier 1 capital, the bonds would qualify as Additional Tier 1 capital whatever threshold were chosen, including the 4.5% Core Tier 1 minimum.

C. A trigger event would increase the bank's equity through the write-down, and with a 7% threshold the bonds can be included in Additional Tier 1 capital rather than Tier 2 capital.

D. Because the bonds are debt until a trigger event, their holders cannot bear any loss until the bank's common shareholders have been completely wiped out.

Solutions • ORR-22 g

Solution ORR-22 g.1

Answer: C

Bank Q698 • Schweser Module Quiz 63.3 Q1

Step 1 – Statement I

A CoCo is a debt instrument when issued and does not appear in the equity account until converted, so it does not weigh on reported ROE. True.

Step 2 – Statement II

When the trigger is hit the CoCo converts to equity (or is written down), adding a loss cushion when it is needed and helping prevent insolvency. True.

Interpretation

The two statements are the two halves of the motivation: debt in good times, equity in bad times, supplied by private holders.

Why the other options are wrong

A is incorrect. Rejects II, the loss-absorbing purpose itself.
B is incorrect. Rejects I, the accounting advantage that makes CoCos attractive to issuers.
D is incorrect. Rejects both; confuses CoCos with traditional convertibles.

LO: ORR-22 g: Describe the mechanics of contingent convertible bonds (CoCos) and explain the motivations for banks to issue them. • **Reference:** SchweserNotes 2026 Book 3, Reading 63, LO 63.g; Carey (GARP Risk Institute), Ch.22, 22.4 CoCos

Solution ORR-22 g.2

Answer: A

Bank Q691 • AnalystPrep Q.5617

Step 1 – GARP's description

CoCos "cause a bank's equity to increase when distress occurs, as reflected by triggers written into the indenture, and not at the option of the holder. With CoCos, equity increases either because the bond converts to equity or because its value is written down."
$\Rightarrow$ A is a restatement of the text.

Interpretation

GARP calls CoCos the mirror image of traditional convertibles: distress rather than success, the indenture rather than the holder.

Why the other options are wrong

B is incorrect. The traditional convertible mechanism: holder's option, high share price.
C is incorrect. A repurchase with government money is the bailout CoCos are meant to avoid.
D is incorrect. No CoCo mechanism turns principal into a deposit.

LO: ORR-22 g: Describe the mechanics of contingent convertible bonds (CoCos) and explain the motivations for banks to issue them. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.4 CoCos

Solution ORR-22 g.3

Answer: D

Bank Q693 • AnalystPrep Q.5628

Step 1 – The three triggers

Tier 1 equity to RWA below a threshold (accounting); supervisors' judgment that the bank needs public-sector aid to avoid insolvency (GARP: the regulator declares it nonviable); a minimum ratio of market capitalization to assets (market).

⇒ Only D is a supervisory-judgment trigger.

Interpretation

Credit Suisse's 2011 CoCos carried both the accounting trigger and the supervisory trigger.

Why the other options are wrong

A is incorrect. A high stock price is the traditional convertible's condition.
B is incorrect. Polarity: the market trigger fires when the ratio *falls below* a minimum, and it is market-based, not supervisory.
C is incorrect. CoCo conversion is not at the holders' option.

LO: ORR-22 g: Describe the mechanics of contingent convertible bonds (CoCos) and explain the motivations for banks to issue them. • **Reference:** SchweserNotes 2026 Book 3, Reading 63, LO 63.g; Carey (GARP Risk Institute), Ch.22, 22.4 CoCos

Solution ORR-22 g.4 — Answer: B

Bank Q692 • AnalystPrep Q.5619

Step 1 – GARP's rule

"CoCos may be included in Additional Tier 1 Capital if the threshold is 5.125 percent or higher, and Tier 2 capital otherwise."
⇒ A threshold of 5.125% or more: AT1.

Interpretation

The higher threshold means the bond absorbs losses while the bank is still a going concern, which is what AT1 is for.

Why the other options are wrong

A is incorrect. CoCos are debt until converted, so they are not Core Tier 1.
C is incorrect. Tier 2 applies only when the threshold is below 5.125%.
D is incorrect. CoCos qualify as regulatory capital, AT1 or Tier 2.

LO: ORR-22 g: Describe the mechanics of contingent convertible bonds (CoCos) and explain the motivations for banks to issue them. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.4 CoCos

Solution ORR-22 g.5 — Answer: C

Bank Q695 • BT P2.T7.20.10.3

Step 1 – The CoCo statement

Before conversion a CoCo is debt and does not dilute reported ROE; when triggered it converts or is written down, absorbing losses without public money. Banks and regulators both gain.
⇒ C is true.

Step 2 – The other reforms

Gold plating ("superequivalent" rules) means a national requirement *higher* than Basel's, as in Switzerland. TLAC is an additional loss-absorbency requirement for G-SIBs, not something being phased out.

Interpretation

The question ties CoCos to the resolution reforms: conversion of CoCos and bail-in of wholesale debt are the two routes to TLAC-based recapitalization.

Why the other options are wrong

A is incorrect. There is no holder option to buy equity: conversion is mandatory on the trigger (and a right to buy would be a call, not a put).
B is incorrect. Reversed: superequivalent rules are stricter, not more lenient.

D is incorrect. Invented: TLAC complements the capital, leverage and liquidity rules.

LO: ORR-22 g: Describe the mechanics of contingent convertible bonds (CoCos) and explain the motivations for banks to issue them. ORR-22 h: Provide examples of legislative and regulatory reforms that were introduced after the 2007-2009 financial crisis. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.4 (Resolution Planning; CoCos) and 22.5

Solution ORR-22 g.6 Answer: D

Bank Q697 • GARP PE1 Q70

Step 1 – Cost

Holders get little of the upside but bear losses not so different from equity holders' when the bank fails, so CoCos "should be expensive for a bank to issue".

Step 2 – The advantage

"Because they do not appear in the equity account until converted, a bank can report a higher return on equity."
⇒ D states both halves.

Interpretation

The motivation is accounting, not cheap funding. The failed bank in the stem is a reminder that CoCos absorb losses before shareholders are necessarily wiped out.

Why the other options are wrong

A is incorrect. Conversion is triggered by the indenture or the regulator, not chosen by the holder.
B is incorrect. Invented: there is no conversion into short-term debt.
C is incorrect. CoCos with a threshold of 5.125% or more count as AT1; only lower-threshold ones are Tier 2.

LO: ORR-22 g: Describe the mechanics of contingent convertible bonds (CoCos) and explain the motivations for banks to issue them. • **Reference:** Carey (GARP Risk Institute), Ch.22, 22.4 CoCos

Solution ORR-22 g.7 Answer: C

Workbook D25.1 • S1, S2, S3

Step 1 – Write-down and equity

Carey: "With CoCos, equity increases either because the bond converts to equity or because its value is written down." Writing down the principal removes a liability with no matching asset loss, so equity rises.

Step 2 – Classification

"CoCos may be included in Additional Tier 1 Capital if the threshold is 5.125 percent or higher, and Tier 2 capital otherwise"; 7% clears the bar, so the issue counts toward the 6% Tier 1 minimum.
⇒ The write-down design absorbs losses while the bank is still a going concern, which is exactly what the higher AT1 threshold is meant to ensure.

Interpretation

C is correct: it combines the S2 point (both mechanisms raise equity) with the S1 point (the 5.125% line).

Why the other options are wrong

A is incorrect. Sibling swap. It treats the write-down as if only conversion created equity. Both mechanisms increase equity; the write-down simply does it without issuing shares.

B is incorrect. Scope/condition error. It drops the threshold condition: a Core Tier 1 trigger is necessary but not sufficient. A trigger at 4.5%, below 5.125%, would leave the bonds in Tier 2.
D is incorrect. Absolute claim. Carey says holders "bear losses not so different from those of equity holders when a bank fails"; a principal write-down can wipe out the holders while shareholders retain value, as with the March 2023 Credit Suisse AT1 write-down (outside-source).

LO: ORR-22 g: Describe the mechanics of contingent convertible bonds (CoCos) and explain the motivations for banks to issue them. ORR-22 d: Define in the context of Basel III and calculate where appropriate: Tier 1 capital and its components; Tier 2 capital and its components; required Tier 1 equity capital, total Tier 1 capital, and total capital.
• **Reference:** Carey (GARP Risk Institute), Ch.22, 22.3 The Definition of Capital and 22.4 CoCos

ORR-24 • Basel III: Finalising Post-Crisis Reforms • Vardeez: UNTIERED

ORR-24 b

P3 CONCEPT

Compare the Standardized Measurement Approach (SMA) to earlier methods of calculating operational risk capital, including the Advanced Measurement Approaches (AMA).

Workbook: *none*

WHAT IS TESTED HERE

Why P3. Vardeez flags it outside his tiered chapters: ORR-24 is untiered (rank 12 of 55 in the consolidated volume), and his theme 5, "LDA approach", is not named in any 2026 LO; the map anchors it here, at the AMA comparison, next to ORR-4 f.

Vardeez: pointer "SMA vs AMA (where LDA sits)". His notes label this LO "LO 63.b" (consolidated volume p.54) and compare the two approaches on five rows: introduction, methodology, flexibility, challenges, objective.

Reported exam shapes: none reported; the questions below are built from the LO wording and Vardeez's pointer.

What the questions look like: "which statement best describes a difference" between the new standardised approach and the AMA (or the basic indicator and standardised approaches of Basel II). Distractors swap which approach is model-based and which is flexible, claim that internal losses are new to the SA, date the AMA to Basel III, keep the AMA as an option, or read 12%, 15% and 18% as business-line betas.

See also: the mechanics of the business indicator, ILM and loss component are ORR-24 a (P4, not built; recapped in Section 1). Basel II approaches: ORR-21 g. LDA modelling: ORR-4 f (workbook D19). Loss data criteria: ORR-24 c.

1. The new standardised approach in one page

The name. The Basel Committee consulted on a "Standardised Measurement Approach" (SMA); the December 2017 standard calls it simply **the standardised approach** (GARP Ch.2: the SMA "was later renamed Standardized Approach"). It replaces *all* existing Basel II approaches and applies to internationally active banks on a consolidated basis. Three building blocks, starting with the business indicator, whose components are each averaged over three years (absolute values taken year by year first):

$$\begin{aligned} \text{BI} &= \overline{\text{ILDC}} + \overline{\text{SC}} + \overline{\text{FC}} \\ \text{ILDC} &= \min\left(\left|\text{interest income} - \text{interest expense}\right|;\ 2.25\% \times \text{interest-earning assets}\right) \\ &\quad + \text{dividend income} \\ \text{SC} &= \max(\text{other operating income};\ \text{other operating expense}) + \max(\text{fee income};\ \text{fee expense}) \\ \text{FC} &= \left|\text{net P\&L, trading book}\right| + \left|\text{net P\&L, banking book}\right| \end{aligned}$$

- **BIC**: the BI times **marginal** coefficients, 12% up to EUR 1 billion, 15% from 1 to 30 billion, 18% above 30 billion. GARP's example: BI of EUR 35 billion gives $0.12 + 29 \times 15\% + 5 \times 18\% =$ EUR 5.37 billion.
- **Loss component** LC $= 15\times$ average annual operational losses over the previous 10 years, and

$$\text{ILM} = \ln\left(\text{e} - 1 + \left(\frac{\text{LC}}{\text{BIC}}\right)^{0.8}\right), \qquad \text{ORC} = \text{BIC} \times \text{ILM}, \qquad \text{RWA} = 12.5 \times \text{ORC}.$$

ILM $= 1$ when LC $=$ BIC, above 1 when losses are high relative to the BIC, below 1 when they are low; it rises with LC/BIC at a decreasing rate (Figure 1). For BI of EUR 10 billion (BIC 1.47), average losses of EUR 120 million give LC 1.80, ILM 1.063 and capital 1.56; average losses of EUR 60 million give LC 0.90, ILM 0.873 and capital 1.28.

- **Bucket 1** (BI $\leq$ EUR 1 billion): ILM $= 1$, so capital $= 12\% \times$ BI (loss data may be admitted at national discretion). At national discretion supervisors may set ILM $= 1$ for *all* banks; full disclosure still applies.

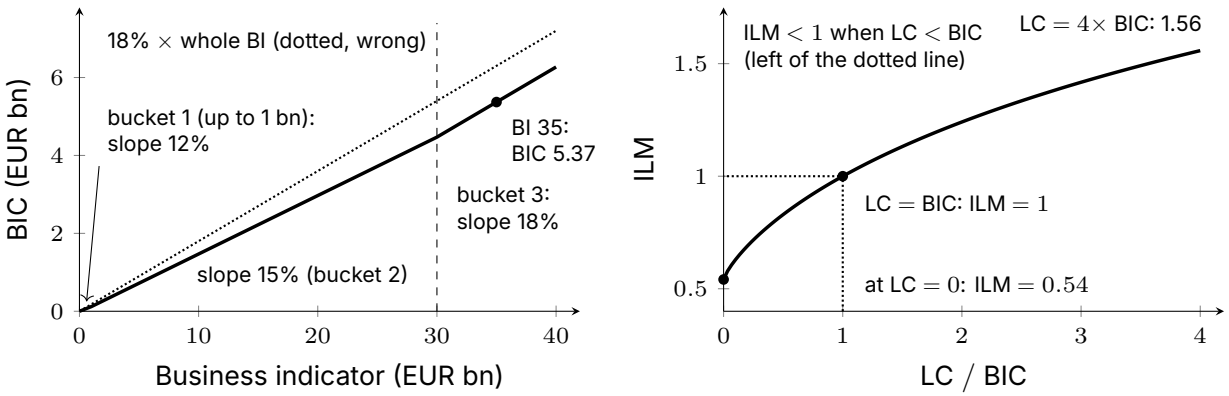


Figure 1. Left: the BIC is piecewise linear in the BI, with slopes 12%, 15% and 18% on the slice inside each bucket (solid); applying 18% to the whole BI (dotted) is the classic error. The dashed line marks the bucket 2 to bucket 3 boundary at EUR 30 billion. Right: the ILM rises with LC/BIC at a decreasing rate and passes through 1 where losses match the BIC (dotted).

Correction to the source notes. (1) Vardeez describes the BI as the "three-year average of a bank's income from interest, leases, and dividends". That is only the ILDC; the BI is ILDC + SC + FC, as his own formula shows. (2) His Figure 63.1 lists the BIC as $0.12\times$ BI, $0.15\times$ BI and $0.18\times$ BI by bucket. The 15% and 18% are *marginal* coefficients on the slice of BI inside each bucket, as his own worked example applies them: BI of EUR 40 billion gives 6.27, not $0.18 \times 40 = 7.20$. (3) GARP's Chapter 22 summary ("Key Changes: Operational Risk") says the BIC "equals the BI times an Internal Loss Multiplier". Chapter 24 is the authority: BIC = marginal coefficients × BI, and capital = BIC × ILM.

2. The earlier methods (Basel II)

Basel II, which first put operational risk into Pillar 1, offered three approaches:

- **Basic indicator approach (BIA):** 15% (the alpha) of average annual **gross income** over three years, ignoring years with negative or zero gross income. Not intended for internationally active banks.
- **The standardised approach (TSA):** gross income split across eight business lines, each multiplied by a **beta of 12%, 15% or 18%** according to the perceived riskiness of the line; negative capital may offset positive capital within a year, and years with negative total capital are ignored. GARP's Example 21.4: TSA USD 9.21 billion against BIA USD 9.83 billion.
- **Advanced measurement approaches (AMA):** the bank's own model, validated by its supervisor, of a one-year loss distribution read at the **99.9th percentile**. Four required inputs: internal loss data (at least five years), external loss data, scenario analysis, and business environment and internal control factors (BEICF). Correlation assumptions across the seven event types must be defended; insurance may offset at most 20% of the charge. Approval took about three years and some 30 qualitative and quantitative criteria.

Where the LDA sits. The loss distribution approach was the most widespread AMA technique: frequency (usually Poisson) and severity (lognormal or heavier tailed) fitted separately to internal and external losses, convolved into an annual loss distribution by Monte Carlo, completed in the tail with extreme value theory or scenarios, and read at the 99.9th percentile. It belonged to the **AMA**, a Pillar 1 internal model. Under the new standardised approach nothing is modelled for Pillar 1; GARP Ch.4 notes that the large banks' modelling effort has moved to **Pillar 2 capital** (**ICAAP**), stress testing and operational resilience. Mechanics of the LDA: ORR-4 f, workbook D19.

3. Why the earlier methods were replaced

- **AMA: too flexible to compare.** A principles-based framework with a wide range of internal modelling practices. The hoped-for convergence on best practice never came, leaving **poor comparability** across banks and **overly complex** calculations (Schweser).
- **Capital proved insufficient** to cover some banks' losses, and losses from misconduct and inadequate systems and controls showed how hard operational risk is to model (GARP Ch.23). Carey adds that AMA capital became a material share of some banks' requirements because internal data contained large penalties, and the AMA "lost favor".
- **BIA and TSA: gross income is a weak proxy.** The TSA's business-line betas assumed some lines were riskier than others; losses over the following 20 years "did not match expectations" (GARP Ch.2).

What the new approach changes. One **non-model-based** method for all banks, combining a financial-statement proxy (the BI replaces gross income) with the bank's own **loss history** (the ILM). Its coefficients rise with **size**, not with business line, reflecting the view that operational risk rises more than proportionally with size. It gains simplicity and comparability; it loses the AMA's forward-looking inputs (scenarios, BEICF) and bank-specific modelling. Where supervisors set ILM $= 1$, which GARP Ch.2 expects many will, capital depends on size alone.

Comparison card: ORR-24 b

	BIA	TSA	AMA	New SA (SMA)
Exposure proxy	gross income, 3-year average	gross income by 8 business lines	bank's own loss distribution	business indicator (ILDC + SC + FC)
Coefficient	15%	betas 12/15/18% by business line	none: 99.9th percentile	12/15/18% marginal, by BI size
Loss data	none	none	internal, external, scenarios, BEICF	10 years of internal losses via the ILM
Model	no	no	yes (LDA, scenarios)	no
Strength	simple	some line sensitivity	risk-tailored, forward-looking	simple, comparable, loss-sensitive
Weakness	not risk-sensitive	betas did not match losses	complex, not comparable	backward-looking; ILM may be set to 1
Status	removed	removed	removed	sole Pillar 1 approach

Exam traps

- **Which is model-based.** The AMA is model-based and flexible; the new SA is non-model-based and standardised. Swapping them is the standard distractor.
- **Internal losses are not new.** The AMA already used internal loss data (with external data, scenarios and BEICF); the SA keeps only internal losses, through the ILM.
- **Which accord.** The AMA is Basel II; the SA is the December 2017 Basel III reform. The AMA is not an option any more, whatever the bank's data.
- **12/15/18% twice.** Business-line betas in the TSA; size-based marginal coefficients in the SA.
- **Negative years.** The BIA drops them; the SA uses absolute values (a trading loss still adds to the FC).
- **Where the LDA sits.** In the AMA (and now Pillar 2), never in the Pillar 1 SA: the loss component is 15 times *average* losses, not a modelled percentile.

Practice questions: ORR-24 b

Question ORR-24 b.1

Bank Q741 • Schweser Module Quiz 65.1 Q4

Which of the following statements best describes a difference between the standardized approach and older operational risk capital approaches?

A. The advanced measurement approach (AMA) was introduced as part of the Basel III revisions.

B. The AMA was more flexible in its application than the standardized approach.

C. The standardized approach accounts for internal loss experiences that were not factored into the AMA.

D. The standardized approach uses a model-based methodology, while the AMA was more flexible and principles-based.

Question ORR-24 b.2

Bank Q724 • BT P2.T7.23.2.1 • re-filed from LO 65.a

Although operational risk was a concept of practical importance prior to 2004, that is the year Basel II introduced it formally into prudential regulation. Along with Basel II's three Pillars (i.e., regulatory capital, supervisory review, and market discipline), the BCBS published Principles for the Sound Management of Operational Risk (PSMOR), which were revised in 2011 and again in March 2021. In regard to Basel's First Pillar, the original capital calculation allowed for a choice between two standardized approaches or an internal (aka, advanced) approach. However, few banks were able to successfully adopt the advanced approach, while the standardized approaches were criticized for the lack of risk sensitivity. Consequently, Basel III replaced them with a single approach that is now called the Standardized Approach (SA). Which of the following best summarizes the Standardized Approach to the operational risk capital (ORC) charge under the Basel regulations?

A. The ORC is a multiple (i.e., a $12\times$, $15\times$ or $18\times$ scalar multiplier) of the average annual losses incurred over the ten previous years.

B. The ORC is a percentage (i.e., a 12%, 15% or 18% marginal coefficient) of the Business Indicator (BI) scaled by the Internal Loss Multiplier (ILM), where the BI is the sum of various income statement and/or balance sheet items.

C. The ORC is the minimum of either (i) 2.25% of interest-earning assets or (ii) the absolute value of the net interest income.

D. The ORC is $15\% \pm 3\%$ of the Internal Loss Indicator (ILI) scaled by the Business Segment Multiplier (BSM), where the ILI is the sum of the absolute values of the trading and banking books.

Question ORR-24 b.3 New • built from GARP Ch.24, Ch.21 and Ch.2

A risk analyst at a mid-sized Canadian bank notices that the percentages 12%, 15% and 18% appear both in the Basel II standardized approach (TSA) for operational risk and in the Basel III standardised approach. The head of operational risk asks how the two approaches differ. Which of the following statements is correct?

A. In both approaches the percentages vary by business line, but the Basel III approach applies them to the business indicator instead of gross income.

B. Like the basic indicator approach, the Basel III approach ignores years in which the relevant income items were negative.

C. In the TSA the percentages are betas that vary by business line; in the Basel III approach they are marginal coefficients that rise with the size of the business indicator.

D. In the Basel III approach a bank whose business indicator exceeds EUR 30 billion applies 18% to its whole business indicator.

Question ORR-24 b.4 Bank Q742 • bank-written, GARP style

A bank that has used an internally developed advanced measurement approach (AMA) to set operational risk capital is preparing for the Basel III standardized approach. The head of operational risk asks an analyst to explain why the Basel Committee replaced the earlier approaches, including the AMA. Which of the following statements is most accurate?

A. The AMA permitted such a wide range of internal modeling practices that capital outcomes were difficult to compare across banks, and the standardized approach replaces it with a single non-model-based method.

B. The AMA ignored bank-specific loss experience, so the standardized approach was created to introduce internal loss data into the capital calculation for the first time.

C. The AMA was a rigid, rules-based framework, so the standardized approach was created to give banks more discretion over how they model operational risk.

D. The standardized approach is an optional alternative, and banks that have received supervisory approval may continue to use the AMA for regulatory capital.

Question ORR-24 b.5 New • built from GARP Ch.4 and Ch.24

An operational risk modeller at a European bank that held AMA approval built its Pillar 1 capital with a loss distribution approach (LDA): Poisson frequency and lognormal severity fitted to internal and external losses, completed in the tail with scenario data, and read at the 99.9th percentile of the one-year aggregate loss. The bank now applies the Basel III standardised approach. Which of the following statements about the LDA is most accurate?

A. The LDA remains the Pillar 1 engine: the 99.9th percentile of the aggregate loss distribution now feeds the loss component in place of average losses.

B. The LDA is now prohibited, since the standardised approach requires banks to stop modelling operational risk losses for any purpose.

C. The LDA is now used only by bucket 1 banks, which do not include internal loss data in the standardised approach.

D. The LDA no longer sets Pillar 1 capital, which follows a prescribed formula of the business indicator and average past losses; it can still serve Pillar 2 (ICAAP) capital and stress testing.

Question ORR-24 b.6 Bank Q743 • bank-written, GARP style

Two internationally active banks each report a business indicator (BI) of EUR 10 billion. The business indicator component (BIC) of each is therefore EUR 1.47 billion. Bank X has a loss component well above its BIC, whereas Bank Y has a loss component well below its BIC. A risk consultant compares how the Basel III standardized approach and the earlier AMA would treat the two banks. Which of the following statements is correct?

A. Under the standardized approach, both banks would hold EUR 1.47 billion because bank-specific losses affect capital only under the AMA.

B. Under the standardized approach, Bank X would hold more capital than Bank Y because its internal loss multiplier exceeds one, whereas under the AMA capital differences also depended on each bank's choice of model.

C. Under the standardized approach, Bank Y would hold more capital than Bank X because a low loss component raises the internal loss multiplier above one.

D. Under the standardized approach, differences in the two banks' capital would depend on each bank's internal model of its loss distribution, as was the case under the AMA.

Solutions • ORR-24 b

Solution ORR-24 b.1 — Answer: B

Bank Q741 • Schweser Module Quiz 65.1 Q4

Step 1 – Characterise each approach

AMA: Basel II, a principles-based framework that let each bank estimate capital with its own internal models, using internal loss data among its four inputs. New SA: one non-model-based formula for all banks, combining the business indicator with the bank's own loss history.

Step 2 – Test the options

Only B is consistent: the AMA allowed far more flexibility.

Interpretation

Flexibility is exactly what the Committee gave up: it bought comparability and simplicity at the cost of bank-tailored measurement.

Why the other options are wrong

A is incorrect. Wrong accord: the AMA is Basel II (2004, comprehensive version 2006); Basel III replaced it.

C is incorrect. The AMA used internal loss data (plus external data, scenarios and BEICF); internal losses are not new to the SA.

D is incorrect. Reversed: the SA is non-model-based; the AMA was the model-based, principles-based one.

LO: ORR-24 b: Compare the Standardized Measurement Approach (SMA) to earlier methods of calculating operational risk capital, including the Advanced Measurement Approaches (AMA). • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.1 and 24.2; SchweserNotes 2026 Book 3, Reading 65, LO 65.b

Solution ORR-24 b.2 — Answer: B

Bank Q724 • BT P2.T7.23.2.1

Step 1 – The three building blocks

BI (ILDC + SC + FC, built from income statement and balance sheet items), BIC (the BI times marginal coefficients of 12%, 15% and 18%), and ILM (from the loss component and the BIC).

Step 2 – Assemble the charge

ORC = BIC × ILM: a percentage of the BI, scaled by the bank's loss experience.

Interpretation

The stem's history is the comparison of this LO: two standardised approaches lacking risk sensitivity and an advanced approach few banks could adopt, replaced by one formula that keeps a little loss sensitivity through the ILM.

Why the other options are wrong

A is incorrect. Losses enter only through the loss component (15 times average annual losses) inside the ILM; capital is not a multiple of losses.

C is incorrect. That is the cap on the net interest term inside the ILDC, one piece of the BI, not the capital charge.

D is incorrect. "ILI" and "BSM" are invented; the absolute values of the trading and banking book results form the FC, one component of the BI.

LO: ORR-24 b: Compare the Standardized Measurement Approach (SMA) to earlier methods of calculating operational risk capital, including the Advanced Measurement Approaches (AMA). • **Reference:** BCBS, Basel III: Finalising

Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.2 The Standardised Approach

Solution ORR-24 b.3 Answer: C

New • built from GARP Ch.24, Ch.21 and Ch.2

Step 1 – The TSA

Gross income of eight business lines, each multiplied by a beta of 12%, 15% or 18% "depending on the perceived riskiness of the underlying business line".

Step 2 – The new SA

The BI is multiplied by marginal coefficients of 12% (up to EUR 1 billion), 15% (1 to 30 billion) and 18% (above 30 billion): "the marginal increase in the BIC resulting from a one unit increase in the BI".

$\Rightarrow$ Same numbers, different logic: riskiness of the line against size of the bank.

Interpretation

GARP Ch.2: the reform "departed from this view, as operational losses incurred in banks' various lines of business over the past 20 years did not match expectations", and the rising coefficients recognise that operational risk grows more than proportionally with size.

Why the other options are wrong

A is incorrect. The SA has no business-line split; its coefficients depend on the BI bucket.

B is incorrect. The BIA ignores negative years; the BI uses absolute values year by year (net interest, trading and banking book results), so a loss-making year still adds to it.

D is incorrect. The coefficients are marginal: 18% applies only to the BI above EUR 30 billion.

LO: ORR-24 b: Compare the Standardized Measurement Approach (SMA) to earlier methods of calculating operational risk capital, including the Advanced Measurement Approaches (AMA). • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.2 and Table 24.1; Carey, GARP ORR Ch.21, Capital for Operational Risk; Chapelle, GARP ORR Ch.2, Until January 2023: BIA, TSA, AMA

Solution ORR-24 b.4 Answer: A

Bank Q742 • bank-written, GARP style

Step 1 – The AMA's problem

A principles-based framework with a wide range of modelling practices; the hoped-for convergence to best practice did not happen, leaving poor comparability and overly complex calculations.

Step 2 – The response

A single, non-model-based method that combines financial statement information with the bank's own loss data, and that replaces all existing Basel II approaches.

Interpretation

Comparability is the keyword: two banks with the same risk could report very different AMA capital simply because they modelled it differently.

Why the other options are wrong

B is incorrect. The AMA did use internal loss data; internal losses are not new to the SA.

C is incorrect. Reversed: the AMA was the flexible one, and the SA takes discretion away.

D is incorrect. The SA "replaces all existing approaches in the Basel II framework"; the AMA cannot be kept.

LO: ORR-24 b: Compare the Standardized Measurement Approach (SMA) to earlier methods of calculating operational risk capital, including the Advanced Measurement Approaches (AMA). • **Reference:** BCBS, Basel III: Finalising

Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.1; SchweserNotes 2026 Book 3, Reading 65, LO 65.b

Solution ORR-24 b.5 — Answer: D

New • built from GARP Ch.4 and Ch.24

Step 1 – Where the LDA sat

The LDA is "the most widespread technique in operational risk modeling": it was the engine of most AMA models, the Pillar 1 internal model approach.

Step 2 – What the SA uses instead

A prescribed formula: BIC from the business indicator, ILM from the loss component, which is 15 times *average* annual losses over ten years. No percentile is modelled.

Step 3 – What happens to the models

GARP Ch.4: with the SA "there are no formal requirements for financial institutions to model their operational risk capital anymore", but the effort "is now being transferred to modeling Pillar 2 and operational capital requirements under ICAAP, as well as stress testing".
$\Rightarrow$ D is the accurate statement.

Interpretation

This is Vardeez's "where the LDA sits": inside the AMA, now outside Pillar 1.

Why the other options are wrong

A is incorrect. The loss component is 15 times average annual losses, not a modelled 99.9th percentile.
B is incorrect. Absolute claim: banks may still model for Pillar 2, ICAAP and stress testing.
C is incorrect. Bucket 1 banks have ILM $= 1$; no bank uses an LDA for Pillar 1.

LO: ORR-24 b: Compare the Standardized Measurement Approach (SMA) to earlier methods of calculating operational risk capital, including the Advanced Measurement Approaches (AMA). • **Reference:** Chapelle, GARP ORR Ch.4, 4.4 Operational Risk Modeling and Capital (LDA; Capital Modeling for Operational Risk); BCBS, GARP ORR Ch.24, 24.2

Solution ORR-24 b.6 — Answer: B

Bank Q743 • bank-written, GARP style

Step 1 – Same BIC

Both banks are in bucket 2 with BIC $= 12\% \times 1 + 15\% \times 9 =$ EUR 1.47 billion.

Step 2 – ILM

LC $>$ BIC gives ILM > 1 (Bank X holds more than 1.47); LC $<$ BIC gives ILM < 1 (Bank Y holds less).

Step 3 – Contrast with the AMA

Under the AMA, capital reflected each bank's own modelling choices as well as its losses.
$\Rightarrow$ B captures both halves.

Interpretation

The SA keeps loss sensitivity, but through one prescribed formula, so two banks with the same BI and the same loss history hold the same capital.

Why the other options are wrong

A is incorrect. Losses do enter the SA through the ILM for banks above bucket 1, and both banks are in bucket 2.
C is incorrect. Reversed: a loss component below the BIC gives ILM below one and lower capital.
D is incorrect. The SA is non-model-based; the ILM follows a prescribed formula.

LO: ORR-24 b: Compare the Standardized Measurement Approach (SMA) to earlier methods of calculating operational risk capital, including the Advanced Measurement Approaches (AMA). • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.2 (BIC, ILM, capital requirement)

ORR-24 • Basel III: Finalising Post-Crisis Reforms • Vardeez: UNTIERED

ORR-24 c

P3 CONCEPT

Describe general and specific criteria recommended by the Basel Committee for the identification, collection, and treatment of operational loss data.

Workbook: D22 Operational Risk Identification, Mitigation and Reporting • Tier D

WHAT IS TESTED HERE

Why P3. Tier D workbook topic: shape S4 of section D22 (map #75, 2 of 16 sources, Vardeez notes only) is loss-data collection.

Vardeez: his notes label this LO "LO 63.c" (consolidated volume p.54): general criteria (procedures, dates, the credit and market boundary, Level 1 mapping, comprehensiveness) and specific criteria (an inclusion policy, gross loss and recoveries).

Reported exam shapes

- **D22·S4** Loss-data collection: regulatory criteria, fields, dates, boundary events, completeness.

What the questions look like: classify items (in or out of gross loss), pick the reference date, decide when a recovery may be netted, apply the observation period, the threshold and the credit and market boundary, and judge exclusion requests. Amounts appear as data, but no calculation is needed.

See also: the standardised approach itself is recapped in ORR-24 b, Section 1. Loss data fields and good practice beyond the regulatory minimum (near misses, indirect losses, four dates): ORR-4 a.

1. Why loss data matter in the standardised approach

Internal losses enter capital through the loss component, LC $= 15\times$ average annual losses over ten years, and so through the ILM (ORR-24 b). Hence:

- Banks with **BI above EUR 1 billion** must use loss data as a direct input; bucket 1 banks may, at national discretion. Supervisors review data quality periodically.
- Banks that **fail the loss data standards** hold capital of at least **100% of the BIC**, and supervisors may require an ILM above 1. The exclusion of their loss data, and any multiplier, must be disclosed.
- A subsidiary in bucket 2 or above uses its own losses only; one that fails the qualitative standards uses 100% of the BIC.

2. General criteria (GARP 24.5)

	Criterion	What to remember
a	10-year observation period	5 years acceptable, exceptionally, on first moving to the SA when good data are unavailable for more than 5 years (not expected for current AMA banks). Under 5 years: capital from the BIC alone (supervisors may still require fewer years of losses if the ILM exceeds 1).
b	Documented procedures	for identification, collection and treatment; validated before use; regular independent review by internal and/or external audit.
c	Level 1 mapping	a supervisor *may request* the mapping to the Basel II Level 1 event types; the bank documents its allocation criteria.

	Criterion	What to remember
d	Comprehensiveness and threshold	all material activities and exposures, all subsystems and locations. Threshold EUR 20,000; for average losses supervisors may raise it to EUR 100,000 for buckets 2 and 3.
e	Fields	gross loss; date of occurrence (where available), discovery and accounting; recoveries; descriptive information on drivers and causes, in detail proportional to the loss.
f	Credit boundary	credit-related operational losses in credit RWA: **out**; credit-related losses *not* in credit RWA: **in**.
g	Market boundary	market-related operational losses are operational risk: **in**.
h	Independent review	processes to review independently the comprehensiveness and accuracy of loss data.

3. Specific criteria (GARP 24.6)

A bank needs a **policy** that sets when an event in its internal loss database enters the **SA loss data set**, covering the gross loss definition, the reference date and grouped losses.

- **Gross loss** is before recoveries of any type; **net loss** is after them. A **recovery** is an independent occurrence, separate in time, in which funds come from a third party (insurers, fraud perpetrators, misdirected transfers recovered). Banks identify gross loss, insurance recoveries and non-insurance recoveries, and use **losses net of recoveries**, but a recovery reduces the loss **only after payment is received**. **Receivables** do not count, nor do **tax effects**.
- **Reference date:** the **date of accounting** builds the data set. A **legal** loss enters no later than the date of accounting, which for legal events is the date a legal reserve for the probable estimated loss is set up in the P&L.
- **Grouped losses:** losses from one event, or from related events over time, posted over several years go to the corresponding years of the database, **in line with their accounting treatment**.

Included in gross loss	Excluded from gross loss
direct P&L charges, impairments, settlements and write-downs	general maintenance contracts on property, plant and equipment
external expenses directly linked to the event (legal, advisers, suppliers) and repair or replacement costs	internal or external spending on upgrades, improvements and risk assessment after the event
provisions or reserves booked in the P&L against the potential loss	insurance premiums
pending losses in suspense accounts (if material, in a period commensurate with size and age)	
timing losses spanning more than one accounting period that give rise to legal risk (if material)	

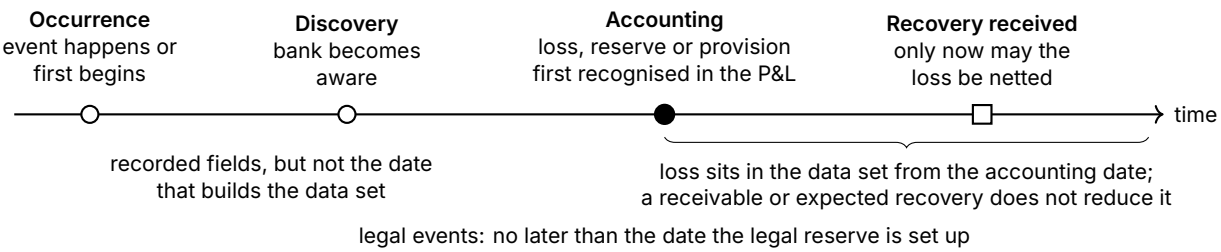


Figure 1. Reference dates of a loss event. All three dates are collected (open circles and the filled circle), but the date of accounting (filled circle) builds the SA loss data set; a recovery (square) reduces the loss only once the money has been received.

4. Exclusions, acquisitions and disclosure (GARP 24.7 to 24.10)

- **Excluding loss events** from the loss component needs **supervisory approval**, should be **rare** and strongly justified. The supervisor asks whether the cause could recur elsewhere in the bank; for settled legal exposures and divested businesses the bank must show no similar or residual exposure. Requests face a **materiality threshold** (for example, more than 5% of average losses) and a **minimum retention** in the database (for example, three years), except that **divested activities** have no retention period. Number and amount of exclusions are disclosed under **Pillar 3**.
- **Divested activities** may also be excluded from the BI, with approval and disclosure. Losses and BI items from **mergers and acquisitions** must be included.
- **Disclosure:** banks with BI above EUR 1 billion, or using loss data, disclose annual loss data for each of the ten years, gross and after recoveries and exclusions, even where ILM is set to 1, plus the BI sub-items for three years.

Correction to the source notes. (1) Schweser writes that "when a bank first moves to the standardized approach, a EUR 20,000 gross loss threshold is acceptable. Afterward, this threshold may be increased to EUR 100,000 for banks in buckets 2 and 3". GARP sets EUR 20,000 as the minimum threshold, with no link to the first move; the EUR 100,000 is a national discretion of the supervisor, for the calculation of average annual losses, for banks in buckets 2 and 3. (2) Schweser allocates losses from related events posted over several years to "the year in which the loss actually occurred". GARP allocates them to the corresponding years "in line with their accounting treatment", consistent with the date of accounting. (3) Vardeez's "exclusion of credit risk, but include market risk" is too broad: only credit-related operational losses already in credit RWA are excluded; those not in credit RWA are included. His "banks must classify loss data into Level 1 categories" is, in GARP, a mapping the supervisor may request; and his "with less than 5 years, no ILM is possible" omits that supervisors may require fewer years of losses when the ILM exceeds 1.

Summary card: ORR-24 c

Window	10 years (5 on first moving to the SA, exceptionally); under 5: BIC only
Threshold	EUR 20,000 (EUR 100,000 at discretion for buckets 2 and 3)
Boundary	credit-related in credit RWA: out; credit-related not in credit RWA: in; market-related: in
Reference date	date of accounting; legal events no later than the legal reserve
Net of recoveries	only after payment is received; receivables and tax effects do not count
Gross loss in	P&L charges, linked external costs, provisions, material pending and timing losses
Gross loss out	maintenance contracts, post-event upgrades, insurance premiums

Exclusions	supervisory approval, rare, materiality, retention period (none for divestments), Pillar 3

Exam traps

- **Wrong date.** The data set is built on the date of *accounting*, not discovery or occurrence.
- **Netting too early.** An expected, probable or receivable recovery cannot be netted; only cash received.
- **Boundary sibling swap.** Market-related operational losses stay in; only credit-related losses already in credit RWA come out.
- **Provisions and legal costs are in.** Reserves booked in the P&L and directly linked legal fees are part of gross loss.
- **Premiums and upgrades are out**, and so are maintenance contracts.
- **Threshold scope.** EUR 20,000 is a minimum for the SA data set; EUR 100,000 is a supervisor's option for buckets 2 and 3.
- **Five years is an exception**, for a first move to the SA, not the standard window.
- **Exclusions are not automatic.** They need approval; divested activities skip only the retention period.

Practice questions: ORR-24 c

Question ORR-24 c.1

Bank Q737 • Mock 2 Q15 • re-filed from LO 65.a

Titan Bank is planning to move to the standardized approach for operational risk capital and wants to incorporate the loss component into its calculation for the coming fiscal year. The bank opened 8 years ago and only has reliable loss data for the last 6 years. Will it still be able to use the loss component and the standardized approach?

A. No, as the bank must have at least a 10-year observation period overall and specifically for loss data.

B. No, as the bank must be in existence for at least 10 years, with reliable loss data for the last 5 years.

C. Yes, as reliable loss data is not required as long as the bank has been in existence for at least 5 years.

D. Yes, as the bank will be eligible as long as the loss data covering at least the last 5 years is deemed good quality and reliable.

Question ORR-24 c.2

Bank Q746 • Schweser Module Quiz 65.1 Q5

In deriving the standardized approach loss dataset for an individual bank, each of the following items will most likely be included in the gross loss calculation EXCEPT:

A. legal fees of EUR 900,000 associated with an unusual risk event.

B. a EUR 2 million settlement tied to a recent operational risk event.

C. a EUR 1.4 million reserve booked to the income statement to cover a potential operational loss.

D. EUR 1.75 million spent on maintenance contracts tied to the bank's property, plant and equipment.

Question ORR-24 c.3

Bank Q744 • BT Mock Q43 • BT P2.T7.20.12.2

Acme Financial's Business Indicator (BI) is well in excess of EUR 1.0 billion, so it must use loss data as a direct input into its operational risk capital calculation under the standardized approach. Regarding the general and specific criteria recommended by the Basel Committee for the identification, collection and treatment of operational loss data, which of the following is TRUE?

A. P&L provisions or reserves against potential loss impacts are included in the gross loss computation.

B. All internal loss events must be included in the gross loss computation regardless of the size of the loss.

C. Legal expenses are excluded from the gross loss computation because they represent the realization of legal risk.

D. Receivables should be counted as recoveries unless the particular receivable causes the current ratio to exceed an internal limit.

Question ORR-24 c.4

Bank Q745 • BT P2.T7.601.3 (rebuilt)

In regard to a recent loss event, your firm's accounting staff has itemized the following amounts associated with the event:

- Gross loss due to the event: USD 5,000,000
- Forgone revenue (opportunity cost): USD 3,000,000
- Estimated, non-rapid recovery with 50% probability, not yet received: USD 1,500,000
- Insurance premiums paid by the firm while the event occurred: USD 12,500

How does the event enter the standardized approach loss data set?

A. Net of the USD 1.5 million expected recovery, since the recovery is linked to the event and has been identified.

B. Net of a probability-weighted recovery of USD 0.75 million, reflecting the 50% chance of receiving it.

C. At the USD 5 million gross loss: the recovery cannot be netted until it is received, and neither the forgone revenue nor the premium is part of the loss.

D. At the USD 5 million gross loss plus the forgone revenue, less the insurance premium, since all three arise from the same event.

Question ORR-24 c.5 New • built from GARP Ch.24

An operational risk analyst at a German bank with a business indicator of EUR 12 billion is deciding which of last year's events belong in the standardised approach loss data set. The supervisor has not raised the collection threshold.

I. A EUR 3 million loan loss after a borrower's collateral was found to be fraudulently overvalued; the loss is already captured in the bank's credit risk RWA.

II. A EUR 1.2 million trading loss caused by a booking error that left an FX position unhedged.

III. A EUR 15,000 penalty for a late regulatory filing.

IV. A EUR 400,000 loss on loans disbursed to fraudsters using stolen identities, recorded as an operational loss and not reflected in credit risk RWA.

Which of these events should be included?

A. II only

B. II and IV only

C. I, II and IV only

D. II, III and IV only

Question ORR-24 c.6 New • built from GARP Ch.24

The head of loss data at a UK bank is drafting the policy for building the standardised approach loss data set. Which of the following rules is consistent with the Basel Committee's criteria?

A. Losses enter the data set on their date of discovery, since that is when the bank becomes aware of the event.

B. Losses from one event that are posted to the accounts over several years are recorded in full in the year in which the event first occurred.

C. A legal loss enters the data set no later than the date on which a legal reserve for the probable estimated loss is established in the P&L.

D. An insurance claim accepted by the insurer is netted against the gross loss as soon as it is lodged, since it is a receivable linked to the event.

Question ORR-24 c.7 New • built from GARP Ch.24

A European bank sold its consumer finance subsidiary last year and has just settled a large mis-selling case in a retail business line it still operates. The CFO asks the head of operational risk whether these losses can be removed from the loss component of the standardised approach. Which of the following statements is correct?

A. A bank may exclude any loss that it judges no longer relevant to its risk profile, provided the loss is older than five years.

B. Exclusion needs supervisory approval and should be rare; the bank must show the cause could not recur elsewhere in its operations, and exclusions are disclosed under Pillar 3.

C. Losses from the divested subsidiary can be excluded only after a minimum retention period in the loss database, typically three years.

D. Settled legal losses are excluded automatically once paid, since a settled case leaves no residual legal exposure.

Solutions • ORR-24 c

Solution ORR-24 c.1

Answer: D

Bank Q737 • Mock 2 Q15

Step 1 – The standard window

General criterion (a): internally generated loss data used for regulatory capital must be based on a 10-year observation period.

Step 2 – The transition rule

"When the bank first moves to the standardised approach, a five-year observation period is acceptable on an exceptional basis when good-quality data are unavailable for more than five years."
$\Rightarrow$ Titan has six years of reliable data: it qualifies, provided the data are of good quality.

Interpretation

The test is the length and quality of the loss data, not the age of the bank. Two refinements: a bank with fewer than five years of good data uses the BIC alone, and the five-year treatment is not expected to apply to banks that currently use the AMA (they should already hold ten years).

Why the other options are wrong

A is incorrect. Ignores the five-year transitional rule.
B is incorrect. There is no 10-year existence requirement; only the loss data history matters.
C is incorrect. The five years must be good-quality data; existence alone is irrelevant.

LO: ORR-24 c: Describe general and specific criteria recommended by the Basel Committee for the identification, collection, and treatment of operational loss data. • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.2 (Internal Loss Multiplier) and 24.5 (a), footnote 4

Solution ORR-24 c.2

Answer: D

Bank Q746 • Schweser Module Quiz 65.1 Q5

Step 1 – The inclusion list

Gross loss includes direct charges (impairments, settlements), external expenses directly linked to the event (legal and advisory fees), repair or replacement costs, and provisions or reserves booked in the P&L. A, B and C are all on it.

Step 2 – The exclusion list

Costs of general maintenance contracts on property, plant or equipment; post-event spending on upgrades and improvements; insurance premiums.
$\Rightarrow$ D is the exception.

Interpretation

Maintenance contracts are ordinary running costs, not a consequence of an operational risk event.

Why the other options are wrong

A is incorrect. Legal fees with a direct link to the event are included.
B is incorrect. A settlement is a direct P&L charge and is included.
C is incorrect. A reserve booked against a potential operational loss is included.

LO: ORR-24 c: Describe general and specific criteria recommended by the Basel Committee for the identification, collection, and treatment of operational loss data. • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.6 (gross loss inclusions and exclusions); SchweserNotes 2026 Book 3, Reading 65, LO 65.c

Solution ORR-24 c.3 — Answer: A

Bank Q744 • BT Mock Q43

Step 1 – Gross loss components

Provisions or reserves accounted for in the P&L against the potential operational loss impact are an explicit inclusion, so A is true.

Step 2 – Check the others

A minimum threshold (EUR 20,000; EUR 100,000 at national discretion for buckets 2 and 3) applies, so not every event is included. Legal expenses directly related to the event are included. Receivables never count as recoveries.

Interpretation

Provisions enter at the date of accounting, which is why legal losses usually enter the data set when the legal reserve is booked, long before any settlement is paid.

Why the other options are wrong

B is incorrect. Ignores the EUR 20,000 minimum threshold.
C is incorrect. Reversed: legal expenses with a direct link to the event are part of gross loss.
D is incorrect. Recoveries count only once payment is received; the "current ratio" test is invented.

LO: ORR-24 c: Describe general and specific criteria recommended by the Basel Committee for the identification, collection, and treatment of operational loss data. • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.5 (d) and 24.6

Solution ORR-24 c.4 — Answer: C

Bank Q745 • BT P2.T7.601.3

Step 1 – The gross loss

The USD 5 million loss is the starting point.

Step 2 – The recovery

"Recoveries can be used to reduce losses only after the bank receives payment. Receivables do not count as recoveries." A recovery that has not been received, however probable, cannot be netted, at full value or probability-weighted.

Step 3 – The other items

Insurance premiums are an explicit exclusion. Forgone revenue is an opportunity cost: it is not a P&L charge, expense or provision, so it is none of the items that make up gross loss.
⇒ The event enters at USD 5 million until a recovery is actually received.

Interpretation

When the USD 1.5 million arrives, the net loss falls to USD 3.5 million. (The bank's version asked for the amount, with options 3.5, 4.25, 5.0 and 6.49 million; the options are restated as treatments so the block stays within its CONCEPT type.)

Why the other options are wrong

A is incorrect. Nets a recovery that has not been received.
B is incorrect. Nets a probability-weighted recovery; only cash received counts.
D is incorrect. Adds an opportunity cost and nets a premium; the premium is simply excluded and forgone revenue is not a loss item.

LO: ORR-24 c: Describe general and specific criteria recommended by the Basel Committee for the identification, collection, and treatment of operational loss data. • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.6 (Gross Loss, Net Loss, and Recovery Definitions; exclusions)

Solution ORR-24 c.5 — Answer: B

New • built from GARP Ch.24

Step 1 – Credit boundary

Event I is a credit-related operational loss already accounted for in credit risk RWA: excluded. Event IV is credit-related but not in credit RWA: included.

Step 2 – Market boundary

Event II is a market-related operational loss; such losses "are treated as operational risk": included.

Step 3 – Threshold

Event III, EUR 15,000, is below the EUR 20,000 minimum threshold: not in the SA data set (the bank may still record it internally).
$\Rightarrow$ II and IV.

Interpretation

The boundary rules stop double counting: a loss already capitalised in credit RWA is not capitalised again. Comprehensiveness (all material activities, subsystems and locations) is checked against that rule set, not against every event the bank ever records.

Why the other options are wrong

A is incorrect. Drops event IV, which is not in credit RWA and so must be included.
C is incorrect. Adds event I, which is already in credit RWA.
D is incorrect. Adds event III, which is below the EUR 20,000 threshold.

LO: ORR-24 c: Describe general and specific criteria recommended by the Basel Committee for the identification, collection, and treatment of operational loss data. • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.5 (d), (f), (g)

Solution ORR-24 c.6 — Answer: C

New • built from GARP Ch.24

Step 1 – The reference date

"Banks must use the date of accounting for building the loss data set", and "a date no later than the date of accounting for including losses related to legal events". For legal events that is the date a legal reserve is established for the probable estimated loss.
$\Rightarrow$ C is consistent with the criteria.

Step 2 – Grouped losses and recoveries

Losses posted over several years are allocated to the corresponding years "in line with their accounting treatment". Recoveries reduce losses only after payment is received.

Interpretation

All three dates (occurrence, discovery, accounting) are collected as fields, but only the accounting date decides the year a loss belongs to (Figure 1).

Why the other options are wrong

A is incorrect. Discovery is a recorded field, not the date that builds the data set.
B is incorrect. Grouped losses follow their accounting treatment year by year, not the year of occurrence (see the correction box).
D is incorrect. A lodged claim is a receivable; it cannot be netted until the insurer pays.

LO: ORR-24 c: Describe general and specific criteria recommended by the Basel Committee for the identification, collection, and treatment of operational loss data. • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.5 (e) and 24.6

Solution ORR-24 c.7 **Answer: B**

New • built from GARP Ch.24

Step 1 – The exclusion rule

Banks "may request supervisory approval to exclude certain operational loss events that are no longer relevant"; exclusion "should be rare and supported by strong justification". Supervisors consider whether the cause could occur in other areas of the bank's operations, and expect the bank to show no similar or residual legal exposure.

Step 2 – Conditions and disclosure

A materiality threshold (for example, more than 5% of average losses), a minimum retention period in the database (for example, three years) except for divested activities, and Pillar 3 disclosure of the number and amount of exclusions.
$\Rightarrow$ B states the rule.

Interpretation

The mis-selling case is in a business line the bank still runs, so a similar loss could recur: exclusion is unlikely. The divested subsidiary's losses are the stronger candidate, and they skip the retention period.

Why the other options are wrong

A is incorrect. Exclusion is the supervisor's decision, not the bank's, and there is no five-year rule.
C is incorrect. Reversed: losses related to divested activities are *not* subject to a minimum retention period.
D is incorrect. Nothing is excluded automatically; the bank must demonstrate there is no similar or residual exposure.

LO: ORR-24 c: Describe general and specific criteria recommended by the Basel Committee for the identification, collection, and treatment of operational loss data. • **Reference:** BCBS, Basel III: Finalising Post-Crisis Reforms (December 2017), GARP ORR Ch.24, 24.7 Exclusion of Losses from the Loss Component